

Техническое задание по итогам глубокого аудита

Баги, дыры безопасности, мокапы и мёртвые механики. Каждая находка подтверждена по коду с указанием файла и строки; критичные и высокие проверены двумя независимыми проверяющими.

541

Подтверждено

4

P0 критично

42

P1 высокий

264

P2 средний

231

P3 низкий

Дата: 25.09.2026 · прод 61dd266 · зон проверено: 24 · отклонено проверкой: 4

1. Сводка по зонам

Код	Зона	P0	P1	P2	P3
VW	Экран приёма врача (заключение, диагноз, назначения, рекоменд...	-	2	11	15
DC	Остальной кабинет врача	-	2	9	15
Q	Живая очередь, киоск, ТВ-табло, талоны	-	3	11	11
AP	Записи, календарь, ресепшн, слоты, цены визита	-	2	10	11
PT	Пациенты и медицинские случаи в CRM	-	3	16	8
ST	Настройки клиники, пользователи, филиалы, кабинеты, права	1	-	8	10
DR	Управление врачами (CRM)	-	1	10	10
TG	Telegram-бот, переписки, рассылки, уведомления, воркеры	-	5	20	14
MA	Мини-апп пациента и публичные страницы клиники	1	4	15	4
AN	Аналитика, выручка, оплаты, биллинг, экспорты	-	2	25	8
AC	Центр действий, действия, AI, база знаний	-	4	15	9
SEC	Аутентификация, мультитенантность, безопасность, платформа	1	6	3	4
LD	Публичный лендинг, запись с сайта, SEO	-	2	8	7
CD	Клинические документы, больничные, рецепты, анализы, направл...	1	1	7	8
CT	Справочники: препараты, МКБ-10, услуги, оверлеи клиники, избра...	-	-	13	7
INF	Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэк...	-	-	12	7
CM	Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, ...	-	-	16	11
UX	Сквозной проход: мокапы, заглушки, фейковые данные, i18n	-	-	10	5
G1	Журнал доступа к медданным и полнота аудита (кто смотрел, кто ...	-	1	9	4
G2	Операционные скрипты, сиды и демо-данные на живом проде	-	1	10	15
G3	Сквозная матрица «мутация → событие → SSE → обновление эк...	-	-	3	11
G4	Клинические справочные данные и реальное покрытие CDS (риск...	-	2	12	9
G5	Платформенная панель SUPER_ADMIN и жизненный цикл подпис...	-	-	4	11
G6	Рабочее место оператора Telegram: правая панель чата, композе...	-	1	7	17

2. План работ по волнам

Порядок по серьёзности. Внутри волны задачи одной зоны лучше брать пачкой: они задевают одни и те же файлы.

Волна 1. P0, чинить немедленно (4)

- ST-01** Цена услуги в «Настройки → Услуги» показывается и сохраняется в тийинах под подписью «Цена (UZS)» — цены становятся в 100 раз ниже
- MA-01** Захват чужой медкарты через /api/miniapp/auth: номер телефона из тела запроса привязывает любой Telegram к существующему пациенту
- SEC-01** Анонимные «киосочные» API доступны из интернета: ФИО и записи пациента по номеру телефона, создание и отметка прибытия в живой очереди без какой-либо аутентификации
- CD-01** Хранимый XSS через файлы документов: SVG от пациента из Mini App (и любой HTML от сотрудника) исполняется на neurofax.uz с сессией сотрудника

Волна 2. P1 (42)

- VW-01** Конструктор назначений теряет правки: несколько быстрых действий собираются из устаревшего снимка строк, и доза тихо откатывается
- VW-02** Памятка пациента фиксируется при первой подписи и больше не пересобирается: после правки в 24-часовом окне или отката визита в PDF и Mini App остаются отменённые назначения и старый диагноз
- DC-01** «Завершить приём» на «Мой день» закрывает визит без подписи заключения, а подписать оставшийся черновик потом нигде
- DC-02** Кабинет врача вне всех сессионных проверок: сменить пароль и включить 2FA невозможно, таймаут простоя не работает
- Q-01** Киоск не может отметить пришедшего по записи: ищет только уже WAITING/IN_PROGRESS, а CONFIRMED-записи и при прямом чекине не переводятся в WAITING — пациент получает второй визит в живой очереди
- Q-02** Общее ТВ-табло /tv: зелёный экран вызова «Пройдите в кабинет» не исчезает, пока не придёт следующий вызов
- Q-03** Регистрация walk-in по телефону молча прикрепляет визит к другому пациенту с тем же номером (родственник), введённое ФИО и год рождения выбрасываются
- AP-01** Выходной день врача доступен для записи: без строк расписания на день недели подставляется 09:00–19:00
- AP-02** Кнопки напоминаний на странице «Записи» не отправляют своё сообщение, зато досрочно рассылают каскадные напоминания и рапортуют об успехе
- PT-01** В CRM-карточке пациента невозможно исправить ФИО, телефон, дату рождения, пол, адрес, паспорт
- PT-02** Запись из Mini App, автоматически привязанная к случаю, не пересчитывается по правилу бесплатного повтора
- PT-03** Поиск «Фамилия ГТТГ» (привычка врача) почти всегда ничего не находит
- DR-01** Страница «Врачи» и вкладки профиля врача всегда получают 400: запрос записей с limit=500 при максимуме 200, вся аналитика тихо показывает нули
- TG-01** Голосовые, кружки, аудио, стикеры и геолокации пациентов теряются: в CRM видно только «Без текста»
- TG-02** Любое изменение времени напоминания в настройках и шаблоны онбординга дают сообщения с пустыми полями, только на русском, а смещения больше 72 часов вообще не срабатывают
- TG-03** Пациенты с подтверждённой записью (все записи по телефону и киоску, а также нажавшие «Подтверждаю») не получают напоминаний за 1 день и за 3 часа
- TG-04** Сообщения сотрудников в «новый» диалог с пациентом не уходят в Telegram, но в CRM показываются как доставленные
- TG-05** Хранимый XSS в CRM: любой пользователь Telegram может прислать боту SVG/HTML-файл, который открывается в origin neurofax.uz с сессией сотрудника
- MA-02** Запись «за родственника» создаётся на владельца: мастер записи теряет ?onBehalfOf при каждом переходе
- MA-03** Самостоятельная регистрация клиник — макет: «подтверждение по email» не отправляется, токен приходит прямо в ответе, любой создаёт клинику и ADMIN на проде
- MA-04** Существующий пациент клиники, открывший бота без invite, получает дубль-карту; запись со своим номером падает с 500, а после invite у двух карт один telegramId
- MA-05** Чужую карту можно «добавить в семью» по ФИО и телефону и читать всю медицину через onBehalfOf

AN-01	Две несовместимые конвенции курса USD: после ввода курса «12600» в настройках приём оплат падает с 500, LTV по USD считается неверно
AN-02	Оплаты из UI никогда не привязываются к визиту: «Топ врачей по выручке» пуст, у врача выручка 0, в карточке визита «Нет оплат», блокировка цены оплаченного визита не срабатывает
AC-01	«Отложить» навсегда убирает задачу: отложенные задачи не возвращаются ни в Центр действий, ни в брифинг ресепшн, ни в виджет колл-центра
AC-02	Время записи/слота в карточках Центра действий и брифинга показывается в UTC — на 5 часов раньше реального; «запись завтра» пишется и для сегодняшних
AC-03	Задача «Контрольный визит» (VISIT_FOLLOW_UP_DUE) и алерт «Низкая оценка» (LOW_NPS_RECEIVED) стираются через 48 часов — задолго до даты контроля
AC-04	Исход звонка для строк риск-листа «Нет связи» никуда не сохраняется: «Отказался» не отменяет запись, «Подтвердил» не подтверждает; «Не дозвонился» отмечает пациента как «на связи»
SEC-02	POST /api/crm/auth/totp-required — анонимный оракул пароля без лимита, позволяющий перебор в обход ограничения на вход
SEC-03	Rate-limit по подменяемому X-Forwarded-For: злоумышленник обходит лимит, а клиника за одним IP блокируется; при 429 вход зависает, а «Выйти» молча не разлогинивает
SEC-04	В сид-скриптах, рассчитанных на прод, защиты известные пароли: SUPER_ADMIN «super», ADMIN 1@1.uz/«1», реальные врачи NeuroFax — «doctor»
SEC-05	Деактивированный, пониженный в роли или перенесённый в другую клинику сотрудник сохраняет прежний доступ до 24 часов
SEC-06	Контроль сессий (idle-таймаут, 8-часовая ротация, «одна сессия на пользователя») фактически не работает, а активных сотрудников выкидывает на логин
SEC-07	Пароль меняется без знания текущего при mustChangePassword, а сброс/смена пароля не отзывают активные сессии — сброс не вытесняет злоумышленника
LD-01	Заявки с сайта уходят в никуда: Lead пишется в БД, но ни один экран CRM его не читает и никто не получает уведомление
LD-02	Хранимый XSS на публичной странице врача: имя/специальность из профиля врача вставляются в JSON-LD без экранирования </script>
CD-02	Документы, подпись врача, бланк/логотип и фото упаковок открываются по «голому» URL MinIO → 403 AccessDenied в кабинете врача, библиотеке CRM и на печати
G1-01	Правка подписанного заключения в 24-часовом окне безвозвратно стирает подписанный вариант: нет снимка «до», PDF перезаписывается по тому же ключу
G2-01	seed-prod-demo.ts вместо заявленных 30 создаёт 540 демо-пациентов и при каждом запуске добавляет до 540 будущих записей к реальным врачам на 14:00–22:00 по Ташкенту
G4-01	В базе взаимодействий CDS всего 43 пары на 28 препаратов и ни одной на 78 неврологических и психиатрических препаратов: на противопоказанных сочетаниях врач видит зелёное «Конфликтов не найдено»
G4-02	Проверка аллергии сравнивает подстроки: аллергия на «пенициллин» или «Амоксициллин» не срабатывает на Амоксиклав и ампициллин, а пищевая аллергия на «мед» блокирует Сумамед, варфарин и десятки других препаратов
G6-01	Черновик, вложения и inline-кнопки композера не сбрасываются при переключении диалога: файл и текст для пациента А уходят пациенту В

Волна 3. P2 (264)

VW-03	Finalize переводит в COMPLETED визит в любом статусе, включая отменённый и неявку, в обход машины статусов
VW-04	«Завершить приём» не дожидается уже отправленных сохранений диагноза, назначений и динамики и гоняется с ними
VW-05	«Изменения в лечении» в печати и памятке объявляют препарат отменённым, если он продолжен текстовой строкой
VW-06	«Отправить в Telegram» сразу после подписи отправляет без заключения (PDF ещё не отрендерен) или устаревший PDF, а сообщает об успехе
VW-07	Автоматическая памятка всегда собирается на русском, даже для пациентов с узбекским языком
VW-08	Воркер напоминаний меняет updatedAt заметки, и следующая правка на экране заключения получает ложное «изменено в другом окне»
VW-09	Изменение или отмена контрольного визита после подписи не доходит до задачи ресепшена «Контрольный визит»

VW-10	Исправление диагноза после подписи (в окне 24 ч или через откат) оставляет в карте пациента старый диагноз ACTIVE
VW-11	Колокольчик «Напоминания пациенту включены» по умолчанию ничего не делает: без выбранного времени приёма напоминания не создаются
VW-12	Применение протокола обещает перенести жалобы, анамнез, осмотр и анализы, но переносит только назначения и рекомендации; в UI остался служебный текст «в G3»
VW-13	Проверка взаимодействий и аллергий (CDS) молча пропадает при любой ошибке сервера
DC-03	CSV-экспорт истории визитов падает с 500 для пациентов с кириллическим именем
DC-04	Глобальные Telegram-тосты в кабинете врача: превью всех сообщений клиники со звуком, «Открыть» ведёт в пустой чат
DC-05	Записи в статусе CONFIRMED (все телефонные) выпадают из «Сегодняшних», «Следующего приёма», бейджа «Мой день» и карточки пациента
DC-06	История визитов показывает исходное заключение без исправлений (amendments)
DC-07	Круглая стрелка у завершённой записи в один клик снимает подпись заключения и отключает пациенту напоминания о лекарствах
DC-08	На карточке текущего пациента зашифрованная заметка пациента показывается шифротекстом
DC-09	Настройки уведомлений врача (12 переключателей) сохраняются, но нигде не читаются
DC-10	Открытие диалога врачом обнуляет «непрочитано» у ресепшена; бейдж «Telegram» врача раздут общими обращениями
DC-11	Список заключений: пагинация по изменяемому updatedAt с курсором по id — дубли и пропуски, порядок не по дате подписи
Q-04	PATCH /queue-status: медсестра может менять статусы, врач — управлять очередью чужого врача, NO_SHOW ставится до времени визита
Q-05	«Пришёл»/«Вызвать» доступны для записей других дней: интейк без проверки «сегодня» тратит сегодняшний счётчик талонов на будущую запись
Q-06	Выбор услуги на киоске — декорация: услуга и цена показываются, но на сервер не передаются
Q-07	Киоск загружает список врачей и длину очередей один раз при открытии страницы — «Перед вами N чел.» весь день устаревшее
Q-08	Киоск и табло берут «кто работает сегодня» только из дня недели: врач в отпуске или с истёкшим графиком получает walk-in, врач без графика невидим
Q-09	Киоск открывает каждый талон в новой вкладке, которая остаётся на экране: следующий посетитель видит талон предыдущего
Q-10	На ТВ при вызове озвучивается и показывается имя не того пациента (предыдущего) или никакое, хотя сервер присылает инициалы вызванного
Q-11	Печатный талон показывает время в UTC (на 5 часов раньше) и зашитые «NEUROFAX-B», «Неврологический центр» и телефон вместо данных клиники
Q-12	Префикс талона всегда «С» у всех врачей: номера C-001, C-002... одновременно выдаются каждому врачу и совпадают
Q-13	Проверка «один пациент на приёме» — чтение без блокировки и без границы дня: гонка даёт два IN_PROGRESS, а незакрытый вчерашний визит блокирует врача
Q-14	Фоновый sweep ставит NO_SHOW только в status (queueStatus не трогает) и «прогульщиками» делает пропущенных walk-in по техническому endDate
AP-03	PATCH и POST записи принимают patientId, medicalCaseId, queueStatus и денежные поля без проверок
AP-04	«Не явился» с ресепшн, массово и воркером не пересчитывает цены случая; воркер не обновляет queueStatus
AP-05	Бесплатный повтор считается 24-часовыми интервалами: визит на N-й день после обеда оплачивается полностью
AP-06	В карточке записи можно сменить канал и время у талона живой очереди (WALKIN): пациент выпадает из очереди или получаем 500
AP-07	Завершение приёма с ресепшн (queue-status) не выполняет пост-эффекты визита, и они теряются навсегда
AP-08	Запись из CRM сохраняется с итоговой ценой null, если её не привязали к случаю
AP-09	Запись можно перенести в прошлое из карточки и массовым переносом
AP-10	Календарь даёт перетащить и растянуть завершённый, отменённый или идущий приём; сервер не проверяет статус при переносе
AP-11	Откат отмены или неявки врачом не проверяет занятость слота и не восстанавливает напоминания
AP-12	Ресепшн застревает на вчерашнем дне после полуночи, а выбор дня в панели врачей переключает всю

	страницу и позволяет вызвать пациента на другой день
PT-04	QR-инвайт на распечатанном заключении — ключ к медкарте на предъявителя на 30 дней, без сверки телефона
PT-05	SUPER_ADMIN без входа в клинику читает пациентов всех клиник через GET-эндпоинты, минуя грант имперсонации и журнал просмотров
PT-06	«Последний визит» пациента может застрять на старой дате; статистика не обновляется из части путей завершения
PT-07	«Удаление» пациента по DSAR оставляет персональные данные, жёсткое удаление никогда не выполнится, заявку не создать из CRM
PT-08	Баланс/долг пациента: поле balance никогда не пишется, «Долг» в карточке считается по отменённым и будущим записям
PT-09	Выгрузка данных пациента (DSAR) не работает ни по одному пути: кнопка недостижима, скачивание 405, ссылка невалидна, пароля нет, расшифровка невозможна
PT-10	Закрытие или передача случая не останавливает активные назначения — напоминания о лекарствах продолжают уходить
PT-11	Медицинские данные доступны и редактируемы немедицинскими ролями: скрытие вкладки «Медицина» косметическое
PT-12	Назначения: выбор врача-автора в форме игнорируется, любой врач может менять и удалять чужие назначения, время «9:00» молча отбрасывается
PT-13	Плитки KPI на странице «Пациенты» считаются по первым 50 загруженным строкам, «Средний чек» — это средний LTV
PT-14	Правка телефона пациента на занятый или некорректный номер даёт 500; имя с годом при правке не разбирается
PT-15	Сегменты пациентов (VIP/Новые/Активные/Остывают/Потерянные) никогда не пересчитываются — вкладки, страницы сегментов и «Центр действий» мертвы
PT-16	Случай: «Оплачено», нумерация «Первичный/Повторный» и «Итого начислено» считают отменённые и будущие визиты
PT-17	Сортировка таблицы пациентов по колонкам не работает — меняется только направление
PT-18	Фильтр «Дата посещения» на самом деле фильтрует по дате регистрации и теряет последний день периода
PT-19	Экспорт пациентов: игнорирует поиск и даты с экрана, CSV-инъекция через ФИО из Telegram, деньги в тийинах, у не-админов «в очереди» без результата
ST-02	«Секреты и токены» в настройках клиники: стёртое поле обнуляет токен/секрет бота, смена без переустановки webhook глушит бот, а уведомления продолжают числиться отправленными
ST-03	Администратор клиники не может сбросить 2FA сотруднику — потеря телефона означает блокировку до вмешательства разработчика
ST-04	Жизненный цикл логина врача ломает привязку к карточке: после повторной активации — бесконечный редирект, после смены роли карточку нельзя перепривязать
ST-05	Интеграции «Платежи», «Телефония» и «Настроить» у Telegram сохраняют ключи, которые никто не читает, но показывают «Подключено»
ST-06	Отключение филиала «запирает» сотрудников в пустом филиале; филиал по умолчанию можно отключить, выбор филиала переживает выход и смену пользователя
ST-07	Переключатель «Клиника активна» у админа клиники: выключает мини-апп и онлайн-запись без подтверждения и снимает блокировку, поставленную платформой
ST-08	Приветствие и авто-сообщения бота: плейсхолдеры утекают пациентам, узбекский текст не редактируется, приветствие захардкожено «Neurofax»
ST-09	Фильтр журнала аудита по датам теряет весь последний день и сдвигает границы на 5 часов
DR-02	«Особая цена» и «Длительность» услуги у врача — мёртвая настройка: запись берёт базовую цену/длительность, киоск показывает другую цену, единицы ввода не определены
DR-03	«Цена приёма (UZS)» при создании врача сохраняется без ×100: пациенты живой очереди этого врача оплачивают сумму в 100 раз меньше
DR-04	В CRM нет формы редактирования врача: ФИО, специализацию, цену приёма, процент зарплаты, цвет, фото и привязку к логину после создания изменить нельзя
DR-05	Виджет «Быстрая запись к врачу» — муляж: кнопка «Создать запись» ничего не делает, услуги и время захардкожены
DR-06	Добавление отпуска не предупреждает о уже записанных пациентах в этот период и не рассылает событие обновления слотов

DR-07	Инвариант «у активной услуги есть хотя бы один активный врач» обходится через редактор услуг врача, PATCH врача и повторную активацию услуги
DR-08	Показатели страницы «Врачи» выдуманы: ёмкость 10 записей/день и часы 9–18 захардкожены, «Выручка сегодня» показывает месяц, статус «Обед» и «Ближайшее окно» не связаны с реальностью, потери завышены в 100 раз
DR-09	Процент зарплаты, цена приёма, userId и токен ТВ всех врачей отдаются любой роли (ресепшн, медсестра, колл-центр)
DR-10	Редактор услуг врача молча снимает услугу с врача, если в поле длительности ввели значение вне 5–600, и теряет несохранённые правки при фоновом обновлении
DR-11	Смена кабинета врача не переносит кабинет в уже созданных будущих записях: напоминания и очередь отправляют пациента в старый кабинет, новый хозяин кабинета получает ложное «кабинет занят»
TG-06	KPI центра уведомлений искажены: ошибки за сегодня почти не считаются, «Отправлено» удвоено INAPP-дублиями, «Доставлено» — только внутренние баннеры, у каждой успешной отправки «1 попытка повтора»
TG-07	QR «Подключить Telegram» из заключения и кнопка врача «Привязать Telegram» не работают, если автоответ бота выключен или тред в режиме оператора
TG-08	«Повторить» и «Отправить повторно» для напоминаний о приёме всегда тихо превращаются в «Отменено»; retry API не проверяет статус и может дублировать уже отправленное
TG-09	Анкета перед визитом и запрос NPS никогда не отправляются (шаблоны не создаются), но в записях проставляется «уведомлено»
TG-10	Аудитория рассылки обрезается 10 000 пациентов до фильтра по Telegram; запуск кампании не защищён от двойного запуска
TG-11	Диалоги из бота никогда не привязываются к карточке пациента, а ручная привязка не записывает Telegram в карточку: дубли пациентов, напоминания не доходят, врачи видят все переписки
TG-12	Диспетчер уведомлений игнорирует backoff ретраев и отсрочку лимита, плодит дубли задач в BullMQ; зависшие в SENDING строки не восстанавливаются
TG-13	Минутный планировщик сканирует всю базу без фильтров и порядка с жёсткими лимитами: при росте клиники дни рождения, долги и повторные визиты молча пропускаются
TG-14	Напоминание о бесплатном повторном визите уходит с пустыми названием и телефоном клиники
TG-15	Напоминания о приёме лекарств в Telegram не отправляются: шаблон medication.reminder нигде не создаётся, хотя врач включает «Напоминать пациенту в Telegram»
TG-16	Новая клиника после онбординга не получает шаблоны отмены, переноса, неявки, опоздания и полос 5д/3ч; готовый набор default-templates не используется
TG-17	Отправка из CRM может висеть до ~2 минут: nginx отдаёт 504, оператор отправляет повторно и пациент получает дубли; FAILED возвращается как успех без кнопки «повторить»
TG-18	Перенос записи самим пациентом в мини-аппе оставляет его без напоминаний и без подтверждения нового времени
TG-19	Письмо врачу о заявке с сайта: HTML-инъекция из публичной формы, битая ссылка и обходимый rate-limit
TG-20	Поздравление с днём рождения приходит пациенту один раз за всю жизнь, в 05:00 утра и без названия клиники
TG-21	При втором переносе записи пациент не получает уведомление о новом времени
TG-22	При нескольких шаблонах на одно событие выбирается случайный: выключатели и тексты «Авто-сообщений» могут не действовать
TG-23	Узбекский текст шаблонов никогда не отправляется: все автоматические уведомления уходят на русском
TG-24	Шаблоны и рассылки с символами «<» или «&» не доставляются: текст сотрудника уходит в Telegram с parse_mode HTML без экранирования
TG-25	Шаблоны из редактора не срабатывают (всегда trigger MANUAL), канал «Email» ничего не доставляет, панель «Триггеры» показывает связи по ключу, а не по реальному правилу
MA-06	QR-коды на бумаге не открываются: /v/<token> (подлинность заключения) и /t/<code> (талон) перехватываются next-intl; /v к тому же падает на fail-closed тенанте
MA-07	initData (ключ ко всей карте на 24 часа) передаётся в URL, пишется в access-лог nginx и принимается любым эндпоинтом мини-аппа
MA-08	Автовыбор услуги в мастере: берутся неактивные услуги, у врача без услуг кнопка «Записаться» заблокирована навсегда, из нескольких консультаций выбирается случайная
MA-09	Анкету перед визитом нельзя заполнить для подтверждённых записей (CONFIRMED): не отправляется и отклоняется с текстом «запись уже завершена»
MA-10	Внутренние заметки ресепшена по записи («Заметки» в CRM) и служебные поля уходят пациенту в API

мини-аппа

- MA-11** Карточка «План лечения» пишет «Лечение завершено» после первого визита: знаменатель выдуман, подтверждённые записи не учитываются
- MA-12** Кнопки «Скачать мои данные», «Удалить аккаунт», «Отменить удаление» всегда дают ошибку: запросы без clinicSlug
- MA-13** Напоминания о лекарствах: «Отложить» больше не напомнит, неотвеченные никогда не истекают и копятся, главная показывает недельной давности дозу как текущую
- MA-14** Нет лимитов на онлайн-записи: один Telegram-аккаунт может занять все слоты врачей, время вне сетки, любая услуга у любого врача
- MA-15** Пациент может отменить уже идущий приём (IN_PROGRESS): DELETE не проверяет статус
- MA-16** Перенос записи из мини-аппа обнуляет скидки и бесплатный повтор: priceFinal = priceBase, оплаченная запись тоже переоценивается
- MA-17** Перенос из мини-аппа: время считается в часовом поясе телефона, переносятся живая очередь, WAITING и NO_SHOW, при смене врача остаётся старый кабинет
- MA-18** Режим родственника наполовину сломан: отмена, перенос, ICS, выбор случая и заключение для записей родственника дают 404/403, а анализы и документы показывают данные владельца
- MA-19** Реферальная программа — мёртвая функция: коды никто не погашает, настройка «% вознаграждения» ни на что не влияет
- MA-20** Сегодняшняя запись и живая очередь пропадают из мини-аппа: фильтр «предстоящие» = date >= now
- AN-03** KPI врачей за «30 дней / 90 дней / с начала года» никогда не включает текущий месяц
- AN-04** KPI врачей: при возврате на «30 дней» таблица не перезагружается и показывает данные предыдущего диапазона
- AN-05** «Средний LTV» на странице аналитики — выдуманное число: всегда 1 500 000 сум
- AN-06** Врач видит выручку всей клиники и коллег: фильтр по врачу в /api/crm/analytics «открывается» при отсутствии Doctor-записи или чужом branch-cookie
- AN-07** Индикатор роста выручки на аналитике завышен: неделя делится на 3 и 4 дня, неявки считаются от всех записей
- AN-08** Каждая оплата перезаписывает счётчик визитов пациента количеством платежей
- AN-09** Конструктор отчётов: вместо врачей и филиалов — технические ID, заголовки на английском с «(tiins)», сортировка игнорируется
- AN-10** Мера LTV в отчётах суммирует уникальные ЗНАЧЕНИЯ LTV, а не пациентов
- AN-11** Нет способа исправить или вернуть оплату из интерфейса; изменение суммы не пересчитывает LTV, частичный возврат игнорируется в выручке
- AN-12** Номер счёта уникален глобально, а нумерация — по клинике: вторая клиника не может выставить первый счёт
- AN-13** Онлайн-оплата подписки через Payme/Click не может завершиться: вебхуки не соответствуют протоколам провайдеров
- AN-14** Отчёты конструктора теряют последний день периода и считают границы в UTC
- AN-15** Полоса «Путь пациента» считает новых пациентов, первичные и повторные визиты по выдуманным коэффициентам
- AN-16** Потери от пустых слотов не учитывают отпуска врачей и считают час занятым/пустым грубо
- AN-17** Признак «спящий» никогда не снимается: потери от спящих пациентов растут навсегда и выводятся всплеском в первый день периода
- AN-18** Рассылаемые по расписанию отчёты не соответствуют периодичности: «ежедневный» шлёт скользящие 30 дней или один и тот же застывший период
- AN-19** Реактивация шлёт «вернитесь к нам» пациентам с подтверждённой будущей записью, с пустыми данными клиники и всегда по-русски
- AN-20** Сводка /api/crm/dashboard отдаёт выручку клиники врачу и колл-оператору; при выбранном филиале выручка остаётся общеклинической
- AN-21** Слайдеры «что если» в прогнозе: «снизить неявки» и «заполнить пустые слоты» не меняют итоговые KPI
- AN-22** Статус CONFIRMED забыт в прогнозе, движении пустых слотов, загрузке в сайдбаре и фильтре конструктора отчётов
- AN-23** Сумма оплаты «150.000» записывается как 150 сум
- AN-24** Тепловая карта расписания смещена на 5 часов (часы в UTC), а «свободно» всегда равно числу записей
- AN-25** Финансовый дашборд: через минуту 90-дневный график сжимается до текущего месяца, «Обновлено» показывает время запроса, а не данных
- AN-26** Экспорт отчёта в CSV/PDF падает с 500, если в названии отчёта кириллица

AN-27	Экспорт пациентов/записей: кнопка видна всем ролям, но работает только у ADMIN; ошибки молчат; фильтры и формат файла неверны
AC-05	CASE_REPEAT_DUE напоминает о повторном визите пациентам, которые уже пришли на повтор или подтвердили его
AC-06	PAYMENT_OVERDUE сканирует всю историю визитов каждые 15 минут и заваливает список карточками по старым визитам
AC-07	«Высокий риск неявки 60%» получает каждый новый пациент и даже пациент, уже сидящий в очереди
AC-08	«Отклонить» и «Готово» не работают: движок каждые 15 минут воскрешает закрытую задачу в OPEN
AC-09	«Перезвонить позже» и «Хочет прийти позже» не всплывают в назначенный день; запись пациента при этом остаётся в расписании
AC-10	«Перенести» фиксирует исход RESCHEDULED и закрывает строку ещё до того, как запись перенесена
AC-11	«Свободный слот завтра» и «потери» считаются для врача в отпуске: детектор игнорирует DoctorTimeOff и сроки действия расписания
AC-12	Выключатель AI действует только на интерфейс: AI-эндпоинты живы, NL-ассистент отправляет ФИО пациентов во внешний LLM без редактирования, без ключа отдаёт заглушки как ответ
AC-13	Голос→SOAP работает в проде при выключенном AI: без ключей пишет в медицинский случай фейковый текст «Пациент жалуется на головную боль», с ключами — в последний открытый случай врача, не обязательно того пациента
AC-14	Кнопки-переходы из Центра действий ведут на несуществующие страницы (404) или теряют контекст пациента
AC-15	Мокапы на экране Центра действий: «Среднее время ответа», «Загрузка врачей», «Потери сегодня» и AI-рекомендации показывают выдуманные или подменённые цифры
AC-16	Операторы колл-центра и медсёстры видят «Нет приоритетных действий»: API Центра действий отвечает им 403, ошибка глотается, виджет подтверждений в колл-центре скрывается
AC-17	Решённые проблемы висят до 48 часов: оплаченный визит остаётся «задолженностью», отменённая запись — «не подтверждена», занятый слот — «свободен завтра»
AC-18	Список задач и брифинг ресепшн показывают не самые срочные, а самые новые задачи (обрезка до 50/5/30 по createdAt); KPI считаются по урезанной выборке
AC-19	Эндпоинт исхода звонка позволяет врачу отменять и подтверждать любые записи клиники, не проверяет тип задачи и игнорирует результат доменной операции
SEC-08	SUPER_ADMIN не обязан иметь 2FA для /admin, /api/platform и /api/admin, а для impersonation проверка 2FA пропускается
SEC-09	Аудит-журнал хранит расшифрованные паспорт и заметки пациента, а при DSAR-удалении/анонимизации — полную личность пациента
SEC-10	Лимиты тарифов не применяются нигде; «Приостановить клинику» и Clinic.active=false не блокируют вход и работу персонала
LD-03	canonical, hreflang и sitemap указывают на /ru-адреса, которые next-intl редиректит на корень; юридические страницы объявляют каноническим адресом главную
LD-04	privacy/terms с force-static замораживают список врачей в форме заявки (и год в футере) до следующего деплоя
LD-05	sitemap.xml кешируется на этапе сборки без БД и в проде никогда не содержит страниц врачей; lastModified всегда равен дате сборки
LD-06	Календарь формы записи сохраняет дату на день раньше выбранной (toISOString в поясе UTC+5)
LD-07	Прайс на сайте захардкожен в i18n-файлах и не связан с каталогом услуг CRM
LD-08	Ушедшего врача нельзя убрать с публичного сайта: getDoctors показывает и неактивных, а удалить врача с историей нельзя
LD-09	Форма заявки заставляет выбрать врача из списка «записываемых». Без активных врачей её невозможно отправить, остальные направления приходится записывать на чужого врача
LD-10	Форма заявки не принимает номера операторов 33, 88, 77, 50, 20 и показывает «Произошла ошибка»
CD-03	Время и даты на печатных документах в UTC: «Дата финализации», время исправлений и «Документ сформирован» на заключении сдвинуты на 5 часов
CD-04	Загрузка документов из Mini App без лимитов частоты и объёма: один пациент может заполнить диск общего сервера
CD-05	Кнопка «Подпись» (планшет подписи) в карточке пациента никогда не сохраняет: data:URL длиннее лимита fileUrl в 1000 символов
CD-06	Происхождение документа неразличимо: заключения и направления системы помечены «От пациента», а файлы пациента выглядят как клинические «Результат/Направление/Согласие»

CD-07	Рецепт, больничный, анализы и направление к врачу: UI удалён 15.07 (1622b12), а бэкенд, печать, публичная проверка и воркер живы; выданные ранее документы нельзя найти, перепечатать или аннулировать
CD-08	Сервер доверяет fileUrl из тела запроса: можно привязать чужой файл, удалить любой объект хранилища и отправить пациенту в Telegram файл по произвольному bucket/key
CD-09	Юридически значимые документы можно удалить или подменить: DELETE не защищает заключения/направления/подписанные согласия, «Заменить файл» сохраняет «подписано» и стирает оригинал
CT-01	«Чем заменить»: клик по аналогу в справочнике ничего не делает, а в ящике назначения открывает ДРУГОЙ препарат
CT-02	В каталоге МКБ нет подрубрик сахарного диабета E10–E14 (.0–.9), нет главы U (COVID-19), есть мусорная запись «K91.4, — N99.5»
CT-03	Импорт госреестра склеивает разные вещества по общему бренду: инъекции «толперизон + лидокаин» попадают в карточку монопрепарата «Толперизон»
CT-04	Каталог МКБ в приёме: глава G (по умолчанию) не листается дальше 200 кодов, третий клик «Ещё» возвращает 400
CT-05	Клинический «самообучаемый» каталог диагнозов ставит формулировки без кода выше кодов МКБ, и удалить их нельзя
CT-06	Названия диагнозов МКБ оторваны от родительской рубрики: «D33.0 Головного мозга над мозговым наметом» и D43.0 с тем же текстом
CT-07	Поиск МКБ не находит частые неврологические формулировки и выдаёт мусор: «ТИА» → тиамин, «боль в шее» → рак, «полинейропатия» → пусто
CT-08	Поиск МКБ ставит противоположный или более тяжёлый диагноз первым: «мигрень с аурой» → G43.0 «без ауры», «сотрясение мозга» → S06.7 «с продолжительной комой»
CT-09	Поиск препарата в конструкторе назначений не находит сам препарат («Парацетамол») при большом числе совпадений
CT-10	Сохранение клинического переопределения препарата молча стирает дозировку для пожилых
CT-11	Справочник МКБ врача: 2315 кодов (главы P, Q, V–Y) недоступны, висит постоянное жёлтое предупреждение, а в браузер уходит 1,2 МБ JSON
CT-12	Фильтр «Без рецепта» в справочнике показывает рецептурные препараты (z.coerce.boolean превращает «false» в true)
CT-13	Фото упаковки для препаратов общего справочника не работает: первая загрузка падает с 500, а сохранённая ссылка ведёт в закрытый MinIO (403)
INF-01	/api/health всегда отвечает workers: ok (заглушка): сторож не видит упавший воркер, Sentry не установлен
INF-02	CSV-экспорт отдаёт неверные данные: суммы в тийнах, строки теряются и задваиваются при пагинации, фильтры экрана игнорируются
INF-03	Certbot обновляет сертификат, но nginx его не перечитывает (обещанного reload нет)
INF-04	EventOutbox растёт бесконечно: воркер каждые 200 мс сканирует всю таблицу, каждый автосейв врача пишет строку, PHI хранится вечно
INF-05	Postgres/Redis/MinIO медицинской системы в одной docker-сети с десятком чужих проектов; Redis без пароля; общие имена сервисов
INF-06	Replay SSE в CRM мёртвый: после любого обрыва события за время разрыва теряются, и данные ничем не обновляются
INF-07	S3/admin API MinIO публично открыт на https://neurofax.uz/files/ , хотя приложение этот путь больше не использует
INF-08	Бэкап не содержит ключей шифрования и конфигов: после потери сервера зашифрованные поля не восстановит
INF-09	Напоминания о лекарствах перестанут приходить новым пациентам: выборка 500 рецептов без сортировки, а рецепты никогда не завершаются
INF-10	Публичный SSE табло раздаёт appointmentId всех записей, а /api/queue/status/:id по этому id отдаёт данные пациента кому угодно
INF-11	Тексты пациенту, которые генерирует воркер, только на русском: кнопка «Подтверждаю», напоминания о лекарствах, DSAR-сообщения
INF-12	Часовой тик напоминаний о лекарствах идёт не в начале часа: опоздание до 59 минут, задержанный тик теряет целый час
CM-01	SIP-вебхук теряет события: любая ошибка БД возвращается как 200, operatorId жёстко FK на User, нет TTL «звонящих», неоднозначные timestamp

- CM-02** «Создать карточку» из колл-центра и «Создать пациента» в топбаре открывают только список пациентов: параметры ?new=true&phone= игнорируются
- CM-03** Внутренние направления к коллеге никуда не доходят: входящие направления не показываются, статус никогда не меняется, регистратура их не видит
- CM-04** Глобальный поиск прячет найденное сервером: cmdk повторно фильтрует результаты по строке value
- CM-05** Загрузка документа в библиотеке: нужно вручную вводить внутренний ID пациента, mimeType и размер теряются, файл остаётся сиротой при ошибке
- CM-06** Заметки к звонку теряют набранный текст: ответ автосохранения перезаписывает поле ввода
- CM-07** Кнопки «Завершить» и «Пропуск» в колл-центре не меняют статус звонка: звонок остаётся «Звонит», пропуски не считаются, другие операторы не узнают
- CM-08** Колл-центр не работает для роли CALL_OPERATOR: подтверждение, запись, создание пациента и виджет «К подтверждению» закрыты 403
- CM-09** Межклиничная подмена ID: calls/online-requests/documents принимают patientId/operatorId/appointmentId из тела без проверки клиники, а вложенный include отдаёт ФИО и телефон чужого пациента
- CM-10** Неотвеченный звонок, закрытый событием hangup, не считается пропущенным и засчитывается воронкой как состоявшийся разговор
- CM-11** Панель активного звонка показывает неверную «Следующую запись», средний чек и историю; ссылка «Открыть» ведёт на 404
- CM-12** Принудительная смена пароля заклинивается: после успешной смены сотрудника снова возвращает на форму, а вторая попытка падает с «введите текущий пароль» без поля ввода
- CM-13** Пропущенные звонки: бейдж есть, списка для перезвона нет нигде
- CM-14** Публичный сайт: кнопка «Записаться» в мобильном меню ничего не делает; якорные ссылки меню мертвы на страницах врача/политики
- CM-15** Смена пароля без аудита, без отзыва других сессий и без лимита попыток; отключение 2FA игнорирует «2FA для всех»
- CM-16** Фильтр документов по датам: конец периода исключается, выбор одного дня всегда пусто (UTC вместо Ташкента)
- UX-01** AI «выключен» (AI_ENABLED=false), но сервер продолжает генерировать и сохранять AI/mock-текст в медкарту (summaryCache, soapDraft) и отправлять медданные провайдеру
- UX-02** KPI ресепшена искажены: «В очереди сейчас» считает все непришедшие брони, «Прибыли сегодня» = завершённые, «сум сум», загрузка без подтверждённых
- UX-03** Аналитика показывает выдуманные данные: «Причины неявок» с фиксированными процентами, синтетическая «Динамика загрузки клиники», смещённые дельты
- UX-04** Политика конфиденциальности и условия на сайте содержат ложные утверждения (серверы в Узбекистане, шифрованные бэкапы 30 дней, никаких третьих лиц, SMS)
- UX-05** Просмотр подписанного визита у врача показывает время визита и подписи в UTC (–5 ч)
- UX-06** Публичные экраны для пациентов только на русском: талон, страница очереди /q, ТВ-табло и голосовой вызов
- UX-07** Сломанный ICU-синтаксис в 9 сообщениях (ru и uz): вместо текста показывается ключ — конфликт записи «Врач занят до...», карточки «Низкий NPS» и «Контрольный визит» в Центре действий
- UX-08** Телефония — макет: «Call Center», виджет звонков на ресепшене и карточка «Телефония» в настройках выглядят рабочими, но реальной интеграции нет
- UX-09** Центр действий: «Пропущенные заявки» ведёт на 404 и всегда 0, «Запустить реактивацию» открывает список пациентов с ошибкой, «Telegram-рассылка» не открывает рассылку
- UX-10** Шаблоны уведомлений: канал Email предлагается, но отправка всегда FAILED; «Тестовая отправка» всегда падает (patientId «dev-fake-patient»)
- G1-02** IP в журнале аудита и журнале просмотров подделывается заголовком X-Forwarded-For
- G1-03** Все записи аудита из мини-аппа пишутся с clinicId = NULL и без автора, поэтому администратор клиники их никогда не видит
- G1-04** Входы сотрудников (успешные и неудачные) и выходы нигде не пишутся в журнал аудита
- G1-05** Доступ к чужой карте через «семью» в мини-аппе не оставляет следов по пострадавшему пациенту: событие привязки записано на владельца, чтения от имени родственника не пишутся
- G1-06** Журнал просмотров медкарт не фиксирует врачей и большинство путей чтения: пишется только из трёх CRM-роутов, контекст «Экспорт» не пишется никогда
- G1-07** Правки и удаления аллергий, диагнозов и хронических заболеваний в карте аудируются без прежних значений
- G1-08** Сбой расшифровки поля пациента роняет весь список пациентов 500-й ошибкой без события

ENCRYPTION_DECRYPT_FAILED; заметка, начинающаяся с «v1:», сохраняется незашифрованной и ломает чтение

- G1-09** Удаление пациента из CRM каскадом стирает журнал просмотров, аллергии, диагнозы, курсы лекарств и DSAR-заявки; проверка «следов» неполная и даёт 500
- G1-10** Экран «Журнал аудита»: строки событий налезает друг на друга, ошибка API показывается как «ничего не найдено», фильтровать можно только по внутренним id
- G2-02** Dev-сид seed-labs-reminders-dev.ts записывает выдуманные анализы (включая CRITICAL) и задачи реальным пациентам и врачам всех клиник
- G2-03** RUNBOOK §5 утверждает, что на проде нет реальных пациентов, и предписывает регулярно запускать seed-today-live, который удаляет все сегодняшние записи с подписанными заключениями
- G2-04** Runbook ротации ключа при компрометации велит сменить APP_SECRET/AUTH_SECRET, что без механизма перешифрования ломает 2FA, Telegram-бота и интеграции; раздел «ключ потерян» описывает несуществующее поведение
- G2-05** _destructive-guard опирается на косвенный признак (≥ 20 строк AuditLog за 72 ч во всей БД), сам печатает команду обхода и подключён лишь к 3 из примерно 12 разрушительных скриптов
- G2-06** seed-clinical-life.ts от имени реальных врачей подписывает выдуманные заключения, выписывает е-рецепты и пишет 1500 поддельных записей аудита с их userId
- G2-07** seed-demo-data.ts без предохранителя занимает весь свободный день реальных врачей демо-записями (сдвиг UTC на 5 часов) и подмешивает демо-оплаты в выручку
- G2-08** seed-neurofax-real.ts без транзакции деактивирует всех врачей, услуги и кабинеты, откатывает цены и расписания к прайсу 18.05 и снова активирует уволенных врачей
- G2-09** wipe-neurofax-demo и seed-mega не удаляют Referral: удаление пациентов молча падает, а сброс patientCounter в 0 навсегда ломает регистрацию новых пациентов
- G2-10** Скрипты шаблонов возвращают снятые напоминания за 5 и 2 часа: seed-prod-demo и backfill-new-templates (по NEW-CLINIC.md) включают их заново, а reminder-cadence вопреки описанию выключает кастомные напоминания админа
- G2-11** Скрипты шифрования не проверяют, что ключ совпадает с ключом приложения: encrypt-auth-secrets берёт локальный .env, encrypt-existing-pii молча шифрует публичным dev-ключом
- G3-01** «Я на месте» из мини-аппа: отметка нигде в CRM не отображается, кроме 4-секундного тоста на странице ресепшена, а свипер потом ставит пациенту «Не явился»
- G3-02** Аллергия, внесённая медсестрой или в CRM, не доходит до открытого экрана приёма: CDS продолжает показывать зелёное «Конфликтов нет»
- G3-03** Исправление заключения (amendment) нигде не транслируется: события нет, экран визита в мини-аппе всегда показывает исходный диагноз и рекомендации
- G4-03** CDS проверяет только назначения текущего визита: текущая терапия пациента (активные курсы, лекарства из анкеты), хронические диагнозы и противопоказания из карточки препарата не учитываются
- G4-04** Библиотека памяток — мёртвая функция: врачу негде вставить ни 17 глобальных памяток, ни памятки клиники (выбор в приёме удалён), а среди глобальных нет ни одной неврологической
- G4-05** В карточке CDS не видно, к какому препарату относится предупреждение об аллергии или «одном классе», а одинаковые заголовки склеиваются: «Я учёл» гасит сразу несколько предупреждений
- G4-06** В поле «Как принимать» подставляется справочный текст дозирования для врача («Старт..., титровать до...», «Депрессия: ...; нейропатическая боль: ...»), и он уходит пациенту в памятку и печать, хотя в свёрнутой строке назначения его не видно
- G4-07** Дозой по умолчанию становится первая «доза» каталога, а это часто концентрация или упаковка («100 ЕД/мл» для инсулина, «667 мг/мл», «5%», «1 флакон», «1мл» из реестра). Форму выбрать нельзя: цитиколин всегда уходит как инъекция, ацикловир как крем
- G4-08** Импорт госреестра заводит отдельные строки для уже известных веществ (Тромбо АСС, КЛОСАРТ, КАРБАЛЕКС, «Диклофенак натрия», комбинации с НПВС и ИАПФ): у них нет ни пар взаимодействий, ни категории беременности, ни противопоказаний
- G4-09** Пересев пресетов (seed-presets.ts и SQL-вариант для прода) стирает все пресеты, которые врачи-неврологи и кардиологи создали сами, во всех клиниках
- G4-10** Повторный запуск seed-drugs.ts после импорта госреестра удаляет около 1800 торговых названий, прикреплённых к курируемым препаратам
- G4-11** Повторный запуск seed-protocols.ts удаляет личные протоколы врачей и протоколы клиники с теми же кодами МКБ, а скрытые клиникой глобальные протоколы снова появляются
- G4-12** Проверка «Один класс АТС» даёт ложные тревоги на стандартной политерапии (ламотриджин + леветирacetам, пирацетам + цитиколин) и пропускает реальные дубли (два бензодиазепина, один и тот же

НПВС двумя строками, комбинации с тем же веществом)

- G4-13** Проверка беременности молча пропускает около 95% каталога: у 124 курируемых и у всех препаратов реестра категория UNKNOWN (симвастатин, периндоприл, телмисартан, фенитоин, пароксетин, клоназепам, метотрексат, изотретиноин), а у пациенток без указанного пола проверка вообще не запускается
- G4-14** Текстовое распознавание в CDS ломается на брендах с ®, дефисом, «+» или скобками («Энап», «Но-шпа», «Витамин D3», «Леводопа + карбидопа») и путает бренд с коротким названием («Лизинокор» → «Лизин», «Кардилопин» → дилтиазем, «Аскорутин» → «АСК»)
- G5-01** «Продлить триал» не возвращает клинику с истёкшим триалом в TRIAL, два пути продления ведут себя по-разному, а «Восстановить (14 дн)» переводит платящую клинику в пробный режим
- G5-02** Бессрочная подписка: пробный период и оплаченный период никогда не заканчиваются, а красный баннер «Пробный период истёк — оплатите» висит у всего персонала вечно
- G5-03** Клиника, созданная из /admin, получает подписку не при создании: до первого открытия «Тарификации» она живёт на Basic, а при открытии страницы ей молча выдаётся 30-дневный Pro-триал
- G5-04** Страницы /admin/users и /admin/audit падают при загрузке: у SelectListItem пустое значение value="", Radix Select бросает исключение
- G6-02** «Записать» из Telegram-чата создаёт запись с каналом «Телефон», и она сразу считается подтверждённой
- G6-03** Вкладка «Неотвеченные» непригодна: открытый диалог сразу помечается прочитанным и через секунду исчезает из списка и из окна чата; при входе в раздел свежий диалог «читается» без участия оператора
- G6-04** Кнопка «Шаблоны» в композере вставляет шаблоны уведомлений с неподставленными {{patient.firstName}}, {{appointment.time}}, и пациент получает текст с фигурными скобками
- G6-05** Новые входящие в уже открытом чате остаются непрочитанными: бейдж, «Неотвеченные» и счётчик в шапке растут, пока оператор смотрит на переписку
- G6-06** Открытый чат показывает не последние сообщения: прокрутка остаётся вверху (самые старые из 50) или сохраняет позицию предыдущего диалога
- G6-07** Переход к конкретному диалогу не работает: виджет ресепшн передаёт ?с= вместо ?conv=, а ?conv= из поиска и кнопка «Открыть» в тосте дают пустую панель, если диалога нет на загруженной странице или в текущем фильтре
- G6-08** Рассылки и автоматические сообщения бота не попадают в переписку: оператор видит ответ пациента, но не видит, на что тот отвечает

Бэклог. P3 (231)

- VW-14** CDS сопоставляет текстовые назначения с препаратами других клиник (каталог не фильтруется по clinicId)
- VW-15** «История диагнозов» ведёт на 404 для визитов других врачей
- VW-16** «Частые препараты» добавляются текстовой строкой, а не структурной: без сетки приёма, напоминаний и проверки по id
- VW-17** В блоке «Было раньше» кнопка «Взять» скрыта для всех прошлых диагнозов без кода МКБ
- VW-18** Выбор клинического (выученного) диагноза в справочнике МКБ пишет diagnosisCode="" и плодит дубли в диагнозах пациента
- VW-19** Двойной клик «Завершить приём» подписывает дважды: сжигается номер документа, номер меняется, дублируются события и диагнозы
- VW-20** Инструкция «Как принимать», введённая в узбекском интерфейсе, не попадает в русскую печать и в автоматическую памятку
- VW-21** На экране заключения кнопки «Применить стандарт» видимы и кликабельны, но ничего не делают
- VW-22** Оптимистическая блокировка PATCH не атомарна: две одновременные записи с одной версией обе проходят
- VW-23** Параметр ?embed=1 позволяет печатать заключение без записи в журнал аудита
- VW-24** Печать пакета до подписи показывает инструкцию нажать несуществующую кнопку «Сформировать»; пакет обещает рецепты и направления, которые больше нигде создать
- VW-25** Подтверждение CDS-предупреждений необязательно и не сохраняется: CONTRAINDICATED не мешает подписи, после перезагрузки «учтённые» снова красные
- VW-26** Правка телефона на экране приёма: очистка поля приводит к 400 с сырым текстом «Validation Error», любой ввод от 3 символов принимается без проверки формата
- VW-27** Фото упаковки глобальных препаратов не доходит до назначений, печатной памятки и Telegram: читается Drug.photoUrl вместо оверлея клиники
- VW-28** Экран приёма видит только первые 50 записей дня: при загруженном дне текущий пациент может «пропасть»

DC-12	«Мой день» не обновляется по времени: «Следующая запись» не появляется без SSE-события, после обрыва SSE очередь устаревает
DC-13	«Написать» из карточки пациента не открывает диалог, если он не в первых 50 тредах
DC-14	«Отменить приём» в меню текущего пациента срабатывает без подтверждения, отменённого «живого» пациента вернуть нельзя
DC-15	Аналитика врача принимает неограниченный диапазон дат
DC-16	Аналитика врача: плитки «Протокол применён» и «Проверено анализы» всегда 0
DC-17	Декоративные элементы и заглушки, выглядящие рабочими
DC-18	Жёстко русская локаль и локальное время браузера в кабинете
DC-19	Мёртвые doctor-API и хуки (анализы, входящие направления), один из них отдаёт шифротекст
DC-20	На экране истории визитов видны только 5 аллергий, кнопка «Показать ещё» ничего не делает
DC-21	Напоминания врача — сиротская функция: страница скрыта из меню, на «Мой день» не выводятся, в срок никто не уведомляет
DC-22	Подпись врача обещана «в PDF-печать заключений», но нигде не используется, превью сломано
DC-23	Поиск в шапке находит всех пациентов клиники, но карточка открывается как «Пациент не найден»
DC-24	Статистика сайдбара перезапрашивается у каждого врача на любое событие клиники
DC-25	Тип «Консультация/Повторный» в расписании считается по текущему числу визитов; SKIPPED показывается как «Уже был»
DC-26	Три несовместимых «сегментации» пациента и сырые enum/только-русские подписи
Q-15	Generic PATCH /appointments/[id] принимает queueStatus в обход машины состояний и ролей; интейк в WAITING без Serializable даёт дубли номеров талонов
Q-16	bulk-status: NO_SHOW-уведомления уходят по всем присланным id (включая чужие/ненайденные), массовая отмена обходит ядро отмены, массовый старт — правило «один на приеме»
Q-17	«Убрать из очереди» у врача — это обычная отмена: walk-in пациенту уходит уведомление «запись отменена», хотя при постановке в очередь он ничего не получал
Q-18	Вызов из кабинета врача шлёт Telegram «Вас вызывают» всегда по-русски, игнорируя язык пациента (у ресепшена — правильно)
Q-19	Диалог талона на ресепшене теряет пол и источник нового пациента и показывает «Талон выдан» при повторном нажатии
Q-20	Киоск смешивает клиники: поиск пациента и услуги идут в клинику по умолчанию, а запись/чекин — в клинику из ?с=
Q-21	Короткий код талона (ticketCode) и QR «для сканирования на ресепшене» ни к чему не подключены в CRM
Q-22	Панель очереди ресепшена «залипает» в порядке после перетаскивания: срочность, вызовы и чужие изменения не отображаются до перезагрузки
Q-23	Перетаскивание в живой очереди переписывает queuedAt — «ждёт N мин» у врача и время ожидания становятся ложными; exact=false игнорируется
Q-24	Страница статуса талона /q/[id] пустая для пропущенных, отменённых и неявок — пациент продолжает ждать
Q-25	Часы в шапке киоска не идут — на экране приветствия время замирает на момент последнего действия
AP-13	GET записи отдаёт полную карточку пациента (паспорт, адрес, заметки) всем ролям
AP-14	«Умные рекомендации» и «Обновить очередь» на ресепшн — псевдо-действия
AP-15	Короткий код талона генерируется через Math.random, а публичный резолвер /t/[code] не ограничен по частоте
AP-16	Массовый перенос не пересчитывает цены случая и не снимает отметку «пришёл» при смене дня
AP-17	Номера страниц в таблице записей только для вида: по ним нельзя перейти
AP-18	Ошибки смены статуса показываются сырыми кодами: «conflict:another_visit_in_progress», «HTTP 409», ключ i18n
AP-19	Пересчёт цен случая делает $O(N^2)$ запросов внутри транзакции при каждом переносе
AP-20	Плитки и правая панель календаря показывают эвристики вместо данных
AP-21	Плитки на странице «Записи» считаются по первой загруженной странице и подписаны неверно
AP-22	Подпись «Повторный визит N из M» в карточке учитывает отменённые визиты, а цена считается без них
AP-23	Фильтр «Услуга» на странице «Записи» ничего не фильтрует
PT-20	/api/crm/patients/stats тянет до 7000 строк на каждое открытие списка; список пересчитывает count и groupBy на каждой подгрузке
PT-21	В печатной «Карте случая» и в инфопанели дата рождения «только год» печатается как 01.01.ГГГГ; время формирования документа в UTC
PT-22	Диалог приглашения в Telegram никогда не показывает «уже привязан» — вместо этого ошибка «conflict»

PT-23	Жалоба, диагноз и заметки случая редактируются однострочным полем — многострочный текст схлопывается при сохранении
PT-24	Карточка пациента заполнена макетными элементами: вечный «Активный пациент», аватар «онлайн», кнопки без действий, выдуманные сроки
PT-25	Мёртвые поля пациента: «Следующий визит» никогда не заполняется, скидка пациента не применяется, номер карты P-00125 нигде не показывается
PT-26	Поиск пациентов матчит подстроки в шифротексте паспорта — в выдаче появляются случайные пациенты
PT-27	Пороги «приоритет», «LTV высокий/средний» и «апселл» заданы в тийинах как суммы: 10 000 и 3 000 сум
ST-10	/crm/services и /crm/rooms открывают админские редакторы для всех ролей
ST-11	API пользователей отдаёт в браузер и записывает в журнал аудита TOTP-секреты и хэши кодов восстановления сотрудников
ST-12	GET авто-сообщений создаёт шаблоны в БД: просмотр включает новые рассылки и обходит режим «только просмотр»
ST-13	PATCH кабинета принимает любой branchId без проверки и не переносит врача; проверка «кабинет занят» зависит от выбранного филиала
ST-14	«Тариф и счета»: оплата Click/Payme — заглушка, «Сменить тариф» плодит неоплачиваемые счета, заголовки на английском
ST-15	Вход в систему чувствителен к регистру email
ST-16	Лимиты тарифа (пользователи, филиалы, пациенты, записи) и часть платных функций нигде не применяются
ST-17	Настройки клиники «Шаг сетки», «Начало/конец дня», «Часовой пояс» и часовой пояс филиала сохраняются, но не влияют на запись
ST-18	Ошибки в настройках показываются сырыми кодами, переключатели не откатываются при отказе сервера
ST-19	Экран «Роли и права» утверждает, что отражает реализацию, но показывает ограничения, которых в коде нет
DR-12	serviceld в списке услуг при создании/правке врача не проверяется на принадлежность клинике: возможна межклиничная связь врача с чужой услугой
DR-13	userId врача в POST/PATCH не проверяется: админ может привязать врача к любому пользователю (в т.ч. другой клиники), а «Удалить навсегда» деактивирует этого пользователя в обход всех проверок
DR-14	«Повторные визиты» в карточке случаев врача считают будущие и отменённые записи
DR-15	Вкладка «Обзор» профиля врача показывает нули вместо «нет доступа» для ресепшн и медсестры; кнопки редактирования видны ролям без права
DR-16	Врач через PATCH /api/crm/doctors/[id] может сам себя активировать после деактивации, сменить ФИО, slug и фото на публичном сайте
DR-17	Панель «AI рекомендации» содержит выдуманные тексты с фиктивными числами, кнопка «Настроить вид» ничего не делает
DR-18	Поля расписания validFrom/validTo/isActive принимаются API, но игнорируются движком записи, а CRM-редактор при сохранении их сбрасывает; время «99:99» проходит валидацию
DR-19	Рейтинг врача (Doctor.rating, reviewCount) нигде не пересчитывается: отзывы NPS собираются, а в шапке профиля, статистике и мини-аппе рейтинга нет
DR-20	Удаление отпуска не проверяет, что период принадлежит врачу из URL: врач может удалить отпуск коллеги; несуществующий id даёт 500
DR-21	Фильтры API врачей/услуг: isActive=false превращается в true, а поиск по имени объединяется со специализацией через ИЛИ
TG-26	Inline-кнопки в сообщениях — нерабочая функция: нажатия пациента нигде не видны, а кнопка без callback_data ломает отправку
TG-27	POST /api/crm/notifications/sends позволяет колл-оператору отправить любой текст с HTML-ссылками от имени бота клиники на любой chat_id, в обход инбокса
TG-28	Redis для BullMQ запущен с политикой вытеснения allkeys-lru: при нехватке памяти пропадают задачи и расписания воркеров
TG-29	{{patient.firstName}} подставляет фамилию: «Каримов, спасибо, что были у нас»
TG-30	Быстрое действие «Подтвердить запись» только вставляет текст «Подтверждаю вашу запись», саму запись не подтверждает
TG-31	Воронка рассылок показывает «Доставлено 0 · Прочитано 0» у каждой рассылки — метрики, которые система не собирает
TG-32	Врач (и любой сотрудник) читает, пишет и меняет любой диалог по id в обход скоупа; PATCH принимает patientId и assignedToId без проверки клиники

TG-33	Врач, медсестра и колл-оператор видят в шапке Telegram-инбокса нули: API статистики им запрещён, ошибка не показывается
TG-34	Кнопка «✓ Подтверждаю» в напоминании стирает сам текст напоминания: у пациента пропадают дата, время и врач
TG-35	Лента «Уведомления» показывает в основном будущие напоминания: 200 строк по scheduledFor по убыванию, свежие отправки и ошибки вытесняются
TG-36	На каждое входящее сообщение оператору показываются два тоста, второй — с безымянным «Пациент»
TG-37	Приветствие бота повторяется после каждой паузы в 30 минут и после каждого рестарта; в запасном тексте захардкожено «клиника Neurofax»
TG-38	Режим long-poll (TG_USE_POLLING=true) безвозвратно теряет апдейты во время рестарта приложения и не видит новые клиники
TG-39	Режим «Бот» подписан «Бот сам ведёт переписку с пациентом», но бот максимум отправляет одно приветствие, а без TG_BOT_AUTOREPLY=1 молчит полностью
MA-21	Кнопка «Я на месте» видна для записей, которые ресепшен уже поставил в очередь (WAITING), и нажатие даёт «Ошибка»
MA-22	Мёртвые и недостижимые части мини-аппа: API чата без экрана, /my/family/add без ссылки, экран выбора языка недостижим, событие doctor.scheduleChanged не доходит
MA-23	Оценку NPS можно поставить будущей или отменённой записи, двойной тап создаёт два отзыва
MA-24	Проверка больничного: «действует сегодня» считается по дате UTC, с 00:00 до 05:00 по Ташкенту ответ неверный
AN-28	CSV «Скачать отчёт» на главной аналитике выгружает выручку в тийинах
AN-29	PDF счёта показывает не тот тариф, за который выставлен счёт
AN-30	«Среднее время ожидания» всегда 0 секунд: calledAt и startedAt ставятся одним и тем же моментом
AN-31	В аналитике показываются сырые коды: статусы «comp/book», источники «WEBSITE/OTHER»; валюта платежа игнорируется в суммах
AN-32	После прочтения чата в Telegram-инбоксе счётчик в шапке не обновляется (неверный ключ кэша)
AN-33	Раздел «Аналитика» виден регистратору/медсестре/оператору, но открывается с ошибкой; плитка «Выручка» на ресепшене ведёт на 404
AN-34	Роуты отчётов и биллинга обходят createApiHandler: нет MFA-рейта, SUPER_ADMIN в режиме «войти как» получает 403
AN-35	Создание оплаты доверяет appointmentId/patientId из тела запроса (в т.ч. чужой клиники и несовпадающих пациентов)
AC-20	LOW_DOCTOR_SCHEDULE считает день недели и часы смен в UTC вокруг ташкентской полуночи — вычитание отпусков смещено
AC-21	OVERDUE_FOLLOW_UP работает наоборот (показывает визиты 1–7 дней назад и исчезает, когда follow-up реально просрочен) и не называет пациента
AC-22	«Обработано сегодня» в риск-листе завышено: учитываются исходы прошлых дней и записи не на сегодня
AC-23	Глобальный поиск: пациенты возвращаются без сортировки (случайные 5 из совпадений), поиск стартует с 1 символа и делает ILIKE по заметкам всех записей
AC-24	Нет экрана истории задач: вкладки «Отложенные/Отклонённые/Сделано», «Вернуть в работу» и диалог причины отклонения не подключены
AC-25	Ошибки детекторов и действия пользователей не видны: сбойный детектор тихо перестаёт создавать задачи, чужие закрытия не приходят по SSE
AC-26	Прогноз времени приёма для табло/киоска: общая выборка истории на всех врачей, у менее загруженных врачей подставляется дефолт
AC-27	Уникальный INN препарата глобален для всех клиник: клиника не может добавить свой препарат, если такой же INN завела другая клиника; удалённый препарат нельзя ни вернуть, ни создать заново
AC-28	Эскалация после 3 недозвонов живёт до 15 минут: движок перезаписывает severity
SEC-11	Tenant-расширение пропускает любые неизвестные операции без скоупинга (fail-open), например updateManyAndReturn
SEC-12	Подписанный cookie tfa_pending нигде не проверяется, а пароль на время 2FA хранится открытым текстом в sessionStorage
SEC-13	Редирект на /\${locale}/login даёт 404 для узбекской локали
SEC-14	Страница /admin/clinics/[id]/billing полагается только на проверку в layout: рендерится с правами SUPER_ADMIN для любого пользователя и создаёт подписку при открытии
LD-11	GET /api/leads отдаёт заявки (имена и телефоны) любой роли, включая NURSE и DOCTOR, в обход матрицы прав

LD-12	SEO-мелочи: дублируется « NeuroFax» в title врача, нет og:image при summary_large_image, SSR отдаёт lang="ru" на узбекских страницах, ссылка на врача относительная
LD-13	app/robots.ts мёртвый: его перекрывает public/robots.txt, правки robots.ts на прод не попадут
LD-14	Заголовки frame-ancestors 'self' и X-Frame-Options SAMEORIGIN на всех путях блокируют Telegram Mini App в Telegram Web
LD-15	Пользовательское соглашение обещает SMS-подтверждения, онлайн-оплату и удержание за позднюю отмену, которых в системе нет
LD-16	Сайт рекламирует Telegram, но нигде не даёт на него ссылку: CONTACT.telegram = "#", бот показан текстом в макете
LD-17	Тёмная тема сотрудников протекает на публичный сайт: белый текст на белом фоне
CD-10	Двойные записи аудита при выдаче и отмене рецепта и больничного
CD-11	Диалог рецепта молча выбрасывает незаполненные препараты (латентно: диалог сейчас не смонтирован)
CD-12	Направление на анализы: PATCH допускает любые переходы статуса, отменённое печатается без пометки, подготовка к анализам из панелей теряется
CD-13	Номера RX/SL/LO уникальны глобально, а считаются по клинике и без повтора: вторая клиника и параллельные выписки получают 500
CD-14	Нумерация #N в списках документов делает коррелированный подсчёт без clinicId: проход по таблице на каждую строку
CD-15	Ограничение «врач видит только своих пациентов» обходится через /documents/[id], /documents/file и /sign; врач без профиля видит все документы клиники
CD-16	Печатные шаблоны: рецепт, больничный и бланк анализов только по-русски; PDF направления без номера и строк подписи/печати; публичная проверка больничного показывает текст причины отмены
CD-17	Тип «Заключение» не поддержан в UI и API-фильтре: вместо названия сырой ключ или «CONCLUSION», заключения нельзя отфильтровать
CT-14	Избранное: ошибки POST/DELETE глотаются, при сбое GET звёзды молча пропадают
CT-15	Карточки ~2,5 тыс. препаратов из госреестра показывают технический мусор: «МНН» вида ugr:glyukozamin, бейдж UNKNOWN, инсулин в категории «ЖКТ»
CT-16	Код МКБ, набранный кириллицей (M54.5, C06.0), ничего не находит
CT-17	Оверлей каталога принимает переопределения без проверки типов, и пустой патч при создании скрывает запись
CT-18	Поиск по справочникам не видит клинические переименования, а фильтр Rx игнорирует переопределённый rxOnly
CT-19	Режим «Без фото» никогда не убывает, счётчики справочника расходятся со списком
CT-20	Сохранение или сброс переопределения админом стирает фото упаковки, загруженное врачом
INF-13	.env.example неполон и местами вводит в заблуждение: без FIELD_ENCRYPTION_KEY прод не стартует, сторож и почта молча выключены
INF-14	SSE-потoki: уволенный сотрудник продолжает получать события, утечка подписки при уходе клиента во время replay, набор родственников в Mini App заморожен
INF-15	restore.sh (и его DRY_RUN) сообщает об успехе при частично проваленном восстановлении
INF-16	Выдача заключений и направлений пациенту может навсегда застрять: 25 постоянно падающих записей блокируют все новые
INF-17	Гарантия доставки через outbox ломается на переходе воркер→app: сбой публикации в Redis проглатывается, а строка помечается DELIVERED
INF-18	Деплой-контур не воспроизводим из репозитория: реальный _deploy.sh не в git, прод-конфиги в skip-worktree, ops/deploy.sh в репо ошибочен
INF-19	Мёртвые realtime-механики: события без слушателей, недостижимые фильтры, заявленная задержка не соответствует факту
CM-17	«Онлайн-заявки» — мёртвая функция: API без страницы и без источника данных, ссылка из центра действий ведёт на 404
CM-18	Бесконечный редирект /doctor ↔ /crm для врача без карточки Doctor или без clinicId
CM-19	Библиотека документов скрывает ошибки загрузки и имеет недоделанные элементы
CM-20	Виджет «К подтверждению»: «Позвонить» не звонит, прошедшие записи подписаны «сегодня»
CM-21	Вход SUPER_ADMIN в клинику: кнопка «Отмена» в confirm даёт режим записи (WRITE)
CM-22	Загрузка кабинетов в сайдбаре занижена (не учитывает CONFIRMED), «записей сегодня» включает отменённые
CM-23	Смена филиала не сбрасывает клиентский кеш: списки остаются от прежнего филиала
CM-24	Смена языка в топбаре CRM не сохраняется в профиле и откатывается при следующем входе

CM-25	Страница витрины компонентов доступна в проде (200 «Недоступно»), dev-хелпер MissingKeyWarner не используется
CM-26	Топбар и сайдбар не учитывают роль и тариф: кнопки «Выдать талон (F2)», «Новая запись» у медсестры/оператора, «Настройки» у всех, иконки Звонки/Telegram ведут на 404
CM-27	Тост «Входящий звонок» в очереди колл-центра практически никогда не показывается; подпись «обновляется каждые 5 секунд» ложная
UX-11	Брендинг захардкожен под NeuroFah во всех арендаторах; собственный поддомен сохраняется, но не работает; логотип не показывается в CRM, хотя это обещано
UX-12	Мелкие i18n-дефекты: русские месяцы в кабинете врача для uz, английские подписи в RU, отсутствующий ключ
UX-13	Мёртвые кнопки на рабочих экранах (записи, карточка пациента, кабинет врача, ресепшен)
UX-14	После удаления SMS интерфейс продолжает обещать SMS (правила напоминаний, кампании, настройки)
UX-15	Правая панель «Центр действий» на странице «Пациенты» — макет: карточки не кликаются, счётчики подменены, кнопки мёртвые
G1-11	CSV-выгрузки всей базы пациентов бессрочно лежат в /tmp/exports контейнера, их скачивание не аудируется, а после рестарта файлы становятся сиротами
G1-12	Автосейв заключения пишет строку AuditLog на каждый PATCH, включая пустые; у AuditLog и PatientView нет срока хранения и архива
G1-13	Двухшаговая загрузка документов оставляет в MinIO файлы с медданными без записи в БД: их не видно, не удалить по DSAR и не отследить
G1-14	Резервный код 2FA можно использовать дважды при параллельных входах, а при одновременном использовании двух кодов один «воскресает»
G2-12	HTTP-stress-скрипты против neurofah помечают реальный неоплаченный визит как оплаченный и затирают адрес клиники без восстановления
G2-13	backfill-birth-year-from-name.ts меняет ФИО и дату рождения пациентов всех клиник без фильтра по клинике и без аудита
G2-14	cleanup-test-conversations.ts в SYSTEM-контексте выводит все чаты всех клиник и удаляет переписки по префиксу Telegram chat id во всех тенантах
G2-15	connect-tg-bot.ts не проверяет, что бот уже привязан к другой клинике, и не пишет аудит
G2-16	guard-e2e.ts заводит в живой клинике аккаунт врача guard-e2e@neurofah.uz с паролем из репозитория и без 2FA
G2-17	poke-webhook.ts отправляет секрет вебхука прод-клиники на захардкоженный адрес trycloudflare
G2-18	prisma/seed-drugs.ts при перезапуске удаляет бренды госреестра у курируемых препаратов и откатывает добавленные формы: CDS и поиск перестают узнавать торговые названия
G2-19	prisma/seed.ts при повторном запуске переписывает реальные реквизиты клиники neurofah заглушками «ул. Пример, 1» и тексты шаблонов уведомлений
G2-20	seed-drug-interactions.ts стирает все взаимодействия глобально и вставляет их по одному без транзакции, а в деплое его никто не запускает
G2-21	seed-joe-two.ts выдаёт номер пациента в обход атомарного счётчика и создаёт walk-in без queuedAt и номера талона у захардкоженного прод-врача
G2-22	stress-appointments.ts до любых HTTP-вызовов удаляет в neurofah все оплаты без пациента и записи, а группа Z подделывает /start от имени реального пациента
G2-23	tg-relay-worker.js — открытый ретранслятор Bot API: проксирует любой чужой токен
G2-24	Демо-пациенты сидов получают настоящие Telegram ID и номера телефонов и ничем не отделены от реальных: напоминания уходят посторонним, колл-центр получает задачи звонить незнакомцам
G2-25	Ротация и бэкфилл шифрования перезаписывают строки по id без проверки версии и теряют параллельные правки; ошибки батчей не отражаются в коде выхода
G2-26	Сиды и stress-скрипты путают единицы денег: цены 2 000 сум, LTV VIP 30–100 тыс. сум, долги по 500 сум
G3-04	Аллергии и лекарства из анкеты перед визитом не доходят ни до врача, ни до CDS; событие revisit.submitted у персонала никто не слушает
G3-05	Дыры в аудите мутаций: перенос записи пациентом из мини-аппа, привязка случая, walk-in и чек-ин с киоска не попадают в журнал аудита
G3-06	Изменение назначений после подписи (правка в 24 ч, откат визита) не публикует prescription.updated: открытый экран «Лекарства» в мини-аппе показывает отменённый препарат и старую дозу
G3-07	Карточка «Заключение готово» и кнопка PDF в мини-аппе не появляются вживую: document.created инвалидирует не тот ключ
G3-08	Мини-апп attach-case перепривязывает любую запись пациента, включая завершённые и уже привязанные

- врачом, к другому случаю, неаtomарно и без следа
- G3-09** Мини-апп не получает события подтверждения записи и авто-неявки: у них нет patientId, серверный фильтр их отбрасывает
- G3-10** Открытая карточка записи (drawer) в ресепшене, календаре и «Записях» никогда не обновляется по SSE: статус, время и цена остаются на момент открытия
- G3-11** Подтверждение записи закрывает задачу «К подтверждению» в БД без события: у операторов виджет и центр действий показывают уже подтвердивших, а «Риск на сегодня» не слушает отмены и смену статуса
- G3-12** При переводе записи к другому врачу у прежнего врача «Мой день», расписание и табло у двери не обновляются: событие несёт только нового врача
- G3-13** Привязка и отвязка визита к случаю (CRM и мини-апп) пересчитывает цены нескольких записей, но не публикует ни одного события: у других сотрудников и у пациента старая цена
- G3-14** Событие notification.sent для канала INAPP молча отбрасывается CRM-клиентом: схема payload не знает INAPP
- G4-15** seed-handouts.ts при каждом запуске деактивирует все памятки, созданные клиниками
- G4-16** «Риск при диагнозе» не повышает серьёзность: пара НПВС + ИАПФ при ХБП или ХСН остаётся жёлтой MODERATE
- G4-17** Аллергия со степенью по умолчанию «Лёгкая» выводится жёлтым «Умеренное» с текстом «Не назначать», а реакция «анафилаксия» степень не повышает
- G4-18** Импорт реестра сопоставляет строки и с собственными препаратами других клиник: глобальный препарат может «влиться» в частную строку одной клиники и пропасть у остальных
- G4-19** Кнопки быстрой записи аллергии в CDS предлагают технические коды («uzg:karbaleks», «aspirin_cardio», «iron_sorbifer») и сохраняют их в карточку пациента
- G4-20** Контент протоколов: «Острый средний отит» рассчитан на детей, но предлагает взрослые таблетки (Амоксиклав 625 мг ×3, Парацетамол 500 мг); опечатка «Бекламетазон»; 16 из 20 протоколов не неврологические
- G4-21** Одинаковые препараты заведены в каталоге дважды под разными id (леводопа + карбидопа, Магне В6, Панангин, витамин D3, Сорбифер, тизанидин MP), и копия из extra-каталога лишена ATC, категории беременности, дозирования и пар
- G4-22** Пары взаимодействий не учитывают лекарственную форму: глазные капли ципрофлоксацина с азитромицином или гель диклофенака с ибупрофеном получают MAJOR «Не комбинировать»
- G4-23** Референсные диапазоны лабораторного справочника (с учётом пола) нигде не используются, возрастных нет, а в протоколах вместо названий анализов видны коды
- G5-05** GET/PATCH/DELETE /api/platform/clinics/[id] отдают в браузер всю строку Clinic, включая webhook-секрет Telegram, токен бота и kioskPin
- G5-06** PATCH /api/platform/users/[id] переносит и понижает сотрудников без проверок, которые есть в CRM: можно оставить клинику без ADMIN, а у врача обрывается связь с профилем Doctor
- G5-07** «Пароль владельца» сбрасывает пароль «самого старого ADMIN» и заранее не показывает, чей именно, а окно с одноразовым паролем закрывается по Esc или клику мимо
- G5-08** В платформенной панели /admin нет выхода из аккаунта, а у раздела «Шифрование» в шапке написано «Клиники — CRUD платформы»
- G5-09** Окончание 60-минутной имперсонации не попадает в журнал: ветка SUPER_ADMIN_IMPERSONATE_EXPIRED недостижима, грант не закрывается, переход из клиники в клинику не пишет ENDED
- G5-10** Переключатель «Активна» в /admin/clinics одним кликом без подтверждения отключает у живой клиники мини-апп, киоск, ТВ-табло очереди и форму записи на сайте
- G5-11** Платформенная страница «Интеграции» — фасад: Telegram-подключение и его выключатель ни на что не влияют, платёжные ключи не читаются, карточка SMS мёртвая, а единственный реально читаемый секрет (SIP) хранится и показывается открытым текстом
- G5-12** Раздел «Здоровье» показывает зелёный ОК для Redis, BullMQ и MinIO по одному наличию env-переменной, ничего не пингует, и не показывает состояние воркеров
- G5-13** Раздел «Использование»: KPI «SMS» всегда 0, а «TG сообщения» считают все исходящие сообщения чатов (включая in-app) и не учитывают Telegram-напоминания
- G5-14** Смена тарифа и статуса в «Тарификации» срабатывает одним выбором из списка без подтверждения, посреди дня отключает колл-центр, Telegram-инбокс и Про-функции, а аудит не сохраняет прежних значений для отката
- G5-15** Страница «Шифрование» каждую минуту пишет строку в журнал аудита и гоняет 12 полных COUNT по таблицам пациентов, заваливая платформенный аудит

- G6-09** «+ Пополнить баланс» и меню «Ещё → Случаи / Платежи / Документы» в панели чата открывают только обзор карточки: параметры ?action=topup и ?tab= никто не читает
- G6-10** «Авто-сообщения»: при ошибке загрузки спиннер крутится бесконечно, текст «Не удалось загрузить» никогда не показывается
- G6-11** «Быстрые действия → Записать на приём» в композере ничего не делает, если правая панель скрыта
- G6-12** «Риск неявок» в панели чата занижен: процент считается от всех записей пациента, включая будущие и отменённые
- G6-13** «Связанные темы» считаются по русским подстрокам: узбекские сообщения не учитываются, «сум» ловит «сумка» и «сумма», клик по теме часто ничего не находит
- G6-14** «Создать пациента» в чате молча привязывает диалог к существующей (в том числе удалённой) карточке с тем же телефоном; отвязать нельзя, ошибки показываются сырыми кодами
- G6-15** Быстрые ответы: {{patient.firstName}} пустой в непривязанных диалогах (приходит «, здравствуйте!»), язык выбирается по интерфейсу оператора, данные клиники могут подставиться пустыми
- G6-16** Карточка «AI-ассистент» в чате — это эвристика по трём русским словам с зашитой «уверенностью 92%»; флаг AI_ENABLED сделает её «живой», и пациенту будут уходить инструкции для оператора; бейдж «верифицирован» никогда не показывается
- G6-17** Карточка «Статистика Telegram · за 30 дней» в панели чата считается по подгруженным сообщениям; «Ответы бота» включают ответы операторов; «Среднее время ответа» искажает автоприветствие
- G6-18** Колл-оператор и медсестра видят в Telegram-чате «Создать пациента» и «Записать», но API отвечает 403, и в тосте появляется «Forbidden»
- G6-19** Окно рассылки пишет «Рассылка завершена» и перестаёт обновляться, пока часть сообщений ещё в статусе SENDING; счётчик «x/y» так и не доходит до конца
- G6-20** После «Открыть в Telegram» из карточки пациента инбокс остаётся отфильтрованным по одному пациенту: фильтр не виден и снять его нельзя
- G6-21** Предпросмотр рассылки не совпадает с тем, что придёт пациенту: ****жирный**** показан жирным (в Telegram придут звёздочки), HTML-теги наоборот, данные клиники — заглушки «ул. Примерная, 1», неизвестные {{...}} видны в превью, а пациенту уходят пустыми
- G6-22** Пустые диалоги (открытые из мини-аппа или карточки пациента без сообщений) висят вверху инбокса и открываются автоматически; счётчики «Все/Горячие/Тёплые/Холодные» считают только загруженные строки
- G6-23** Рассылка уходит пациентам без согласия: аудитория игнорирует consentMarketing, поэтому галочка «Согласен получать уведомления» в мини-аппе и «Согласие на рассылки: Нет» в карточке ничего не меняют
- G6-24** Теги в правой панели чата ни на что не влияют: пишутся в Conversation.tags, но не фильтруют инбокс и не доступны в «Рассылке → По тегам» (там Patient.tags); при быстром добавлении теги теряются
- G6-25** Центр уведомлений показывает тексты с HTML-сущностями («G'ulom», «"..."») и сырые значения статусов и каналов (SENDING, DONE, CANCELLED, TG)

VW · Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

VW-01 P1 · ВЫСОКИЙ бар

Конструктор назначений теряет правки: несколько быстрых действий собираются из устаревшего снимка строк, и доза тихо откатывается

ГДЕ

src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:206, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:225, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:703, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:715, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:879, src/app/[locale]/doctor/reception/_hooks/use-visit-note.ts:246, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:109

СЦЕНАРИЙ

Врач раскрывает строку «Карбамазепин», вводит дозу «200 мг» вместо «100 мг» и сразу кликает чип «Утро». Blur отправляет PATCH1 {dose:200}, клик отправляет PATCH2, собранный из снимка {dose:100, times:[MORNING]}. Сервер применяет оба по очереди, итог: доза 100 мг. Поле дозы после ответа сбрасывается на 100. Аналогично: «Утро», затем «Вечер» до ответа сервера оставляют только «Вечер»; два препарата, добавленные подряд из поиска и подсказок, оставляют только второй.

ПОСЛЕДСТВИЯ

В подписанное заключение, памятку, сетку приёма и напоминания Mini App уходит не та доза или схема, которую врач ввёл. Сценарий «ввёл дозу, кликнул время» повторяется на каждом приёме.

ЧТО СДЕЛАТЬ

В конструкторе, как в advice-panel, читать текущий массив из кэша (qc.getQueryData(visitNoteKey)) и синхронно записывать туда результат до отправки, то есть делать оптимистичное обновление. Либо добавить onMutate в usePatchVisitNote для visitPrescriptions. Альтернатива: хранить локальный черновик строк в конструкторе и отправлять его с дебаунсом. То же сделать для handleCatalogPick и handleApplyProtocol.

КРИТЕРИЙ ПРИЁМКИ

E2E или компонентный тест: изменить дозу и сразу кликнуть два чипа времени при задержке сети 500 мс. В БД доза новая и оба времени приёма сохранены. Два препарата, добавленные подряд, оба на месте.

ДОКАЗАТЕЛЬСТВО В КОДЕ

addDraft, updateRow и removeRow (строки 206-243) собирают полный replace-all массив из `rows = note.visitPrescriptions` (снимок рендера, строка 151). usePatchVisitNote (use-visit-note.ts:246-275) не делает оптимистичного обновления кэша: строки меняются только после ответа сервера. CommitInput сохраняет дозу onBlur (строки 703, 879), чипы времени вызывают onChange с `row.timesOfDay` из того же снимка (строки 715-724). PATCH-и сериализуются очередью patchQueues, и второй берёт expectedUpdatedAt уже после первого ответа, поэтому 409 не возникает и перезапись проходит молча. В advice-panel и mutateChips эту же проблему уже исправили чтением кэша (комментарий «Lost-update guard»), в конструкторе нет. handleCatalogPick и handleApplyProtocol (structured-fields-panel.tsx:109-120, 180) тоже строят массив из `note`.

VW-02 P1 · ВЫСОКИЙ целостность данных

Памятка пациента фиксируется при первой подписи и больше не пересобирается: после правки в 24-часовом окне или отката визита в PDF и Mini App остаются отменённые назначения и старый диагноз

ГДЕ

src/app/api/crm/visit-notes/[id]/finalize/route.ts:99, src/app/api/crm/visit-notes/[id]/finalize/route.ts:141, src/app/api/crm/visit-notes/[id]/route.ts:171, src/app/api/crm/appointments/[id]/route.ts:241, src/server/workers/visit-note-handout.ts:193, src/app/api/miniapp/visit-summary/[appointmentId]/route.ts:76, src/app/[locale]/doctor/reception/_components/notes-editor-panel.tsx:63

СЦЕНАРИЙ

Врач подписывает приём: «Конкор 5 мг утром». Через 2 часа на экране /doctor/conclusions/[id] исправляет дозу на 10 мг и диагноз. Воркер перерисовывает PDF: в тексте памятки «Диагноз: <старый>», «Назначения: Конкор 5 мг — утром», а ниже в «Схеме приёма» уже Конкор 10 мг. В Mini App в сводке визита пациент видит только старый текст с 5 мг. То же после отката визита, изменения назначений и повторной подписи.

ПОСЛЕДСТВИЯ

Пациент получает документ с двумя противоречащими схемами лечения и старым диагнозом (в Mini App вообще только старую). Это прямой риск неверного приёма препаратов и юридически противоречивый документ с номером и QR.

ЧТО СДЕЛАТЬ

Не хранить назначения и диагноз как замороженный текст памяти. Вариант А: пересобирать `patientHandoutMarkdown` из структурных полей при каждой финализации и при каждом `in-window PATCH`, который меняет `diagnosis/visitPrescriptions/prescriptions/advice/followUp` (пока нет ручного редактора памяти); при откате (`appointments/[id] revert`) обнулять автособранную память. Вариант Б (правильнее): хранить в `markdown` только «ручной» текст, а диагноз, список назначений, рекомендации и контрольный визит рендерить в `print-route`, `conclusion-pdf` и `miniapp visit-summary` из структурных полей в момент рендера (как уже сделано с сеткой и диффом). Заодно убрать дубль: сейчас назначения выводятся дважды (список в `markdown` плюс сетка).

КРИТЕРИЙ ПРИЁМКИ

Подписать приём, в течение 24 ч изменить дозу и диагноз на экране заключения, дождаться тика воркера: в PDF, в печати памяти (`?type=handout`) и в Mini App `visit-summary` везде новая доза и новый диагноз, упоминаний старой дозы нет. Откатить визит, удалить препарат, подписать снова: препарат исчез из всех трёх мест. Unit-тест: `finalize` после `revert` пересобирает память.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`finalize/route.ts:99-118`: ``const composedHandout = note.patientHandoutMarkdown?.trim() ? null : composePatientHandout({... diagnosisName, complaints, prescriptions: [...formatPrescriptionLines(note.visitPrescriptions...), ...note.prescriptions], advice, followUp })``, и строки 141-143 записывают результат в `patientHandoutMarkdown`. Больше `composePatientHandout` нигде не вызывается (`grep`: только `finalize`). Вкладку памяти убрали (`notes-editor-panel.tsx:63-66`), поэтому ни один UI не пишет `patientHandoutMarkdown`. `PATCH` в окне 24 ч (`route.ts:171-173`) только ставит `handoutStaleAt`, текст памяти не пересобирается. Откат визита (`appointments/[id]/route.ts:241-261`) переводит заметку в `DRAFT`, но `patientHandoutMarkdown` не очищает; при повторной подписи строка 99 видит непустую память и пропускает сборку. Воркер (`visit-note-handout.ts:193-194`) рендерит PDF из сохранённого `markdown` (`handoutMarkdown`) плюс сетку приёма из АКТУАЛЬНЫХ `visitPrescriptions`. Mini App `visit-summary` (`route.ts:76`) отдаёт тот же устаревший `handoutMarkdown`.

VW-03 P2 · СРЕДНИЙ бар

Finalize переводит в COMPLETED визит в любом статусе, включая отменённый и неявку, в обход машины статусов

ГДЕ

`src/app/api/crm/visit-notes/[id]/finalize/route.ts:149`, `src/app/api/crm/visit-notes/[id]/finalize/route.ts:42`, `src/app/api/crm/appointments/[id]/route.ts:497`

СЦЕНАРИЙ

Ресепшен отменил визит (пациент ушёл), а у врача экран не обновился (SSE отвалился). Врач нажимает «Завершить приём»: отменённый визит становится `COMPLETED`, пациенту уходит «Спасибо за визит» и NPS, статистика визитов растёт.

ПОСЛЕДСТВИЯ

Неверные статусы визитов, ложные сообщения пациенту, искажение отчётов и выручки (завершённый визит без оплаты).

ЧТО СДЕЛАТЬ

В `finalize` разрешать закрытие визита только из `IN_PROGRESS` (и, возможно, `WAITING`), с той же проверкой `canTransitionAt`. Для `CANCELLED/NO_SHOW` возвращать 409 `appointment_not_active` и не подписывать.

КРИТЕРИЙ ПРИЁМКИ

POST `finalize` для заметки отменённого визита возвращает 409, статус визита не меняется, триггеры не срабатывают.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`finalize` проверяет только ``note.appointment.status !== "COMPLETED" (149)` и безусловно применяет `completionFields` (`status` и `queueStatus COMPLETED`), плюс `fireTrigger('appointment.completed')` и `refreshPatientVisitStats`. Сам `PATCH appointment` проверяет переходы через `canTransitionAt` (`appointments/[id]/route.ts:497, 923`), `finalize` эту проверку обходит.

«Завершить приём» не дожидается уже отправленных сохранений диагноза, назначений и динамики и гоняется с ними**ГДЕ**

src/app/[locale]/doctor/reception/_components/visit-action-bar.tsx:88, src/app/[locale]/doctor/reception/_hooks/reception-context.tsx:218, src/app/[locale]/doctor/reception/_components/notes-editor-panel.tsx:282, src/app/[locale]/doctor/reception/_hooks/use-visit-note.ts:285, src/app/[locale]/doctor/reception/_hooks/use-loud-patch.ts:79

СЦЕНАРИЙ

Врач выбирает диагноз или препарат и сразу жмёт «Завершить приём». Finalize читает заметку до PATCH: памятка собирается без только что выбранного препарата, либо PATCH приходит после подписи с устаревшим expectedUpdatedAt и получает 409 («изменено в другом окне»), и изменение теряется. Иногда появляется диалог «подписать без диагноза?», хотя диагноз выбран секунду назад.

ПОСЛЕДСТВИЯ

Подписанный документ и памятка расходятся с тем, что врач видел на экране. Путаница и потеря последнего действия.

ЧТО СДЕЛАТЬ

В flushDraftEdits дополнительно ожидать хвост patchQueues.get(notelId). Finalize выполнять через ту же очередь (patchQueues), чтобы он стартовал после всех отправленных PATCH. Кнопку блокировать, пока patch.isPending.

КРИТЕРИЙ ПРИЁМКИ

Тест: при задержке PATCH 1 с выбрать препарат и сразу нажать «Завершить приём». Finalize уходит после ответа PATCH, в памятке и сетке есть препарат, 409 не возникает.

ДОКАЗАТЕЛЬСТВО В КОДЕ

flushDraftEdits перебирает только зарегистрированные flush-колбэки (reception-context.tsx:218-225). Единственный такой колбэк, текст заключения (notes-editor-panel.tsx:282-289), при чистом тексте сразу возвращается ('if (text === null) return;') и в очередь patchQueues не встаёт. Структурные карточки сохраняют через patch.mutate без регистрации (use-loud-patch.ts:79). Finalize (use-visit-note.ts:285-291) идёт прямым fetch мимо patchQueues. Проверка пустых секций (visit-action-bar.tsx:123-125) читает кэш, в котором нет ещё не пришедших ответов.

«Изменения в лечении» в печати и памятке объявляют препарат отменённым, если он продолжен текстовой строкой**ГДЕ**

src/app/api/crm/visit-notes/[id]/print/route.ts:487, src/lib/catalogs/treatment-diff.ts:124, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:178, src/app/api/crm/visit-notes/[id]/print/route.ts:1126

СЦЕНАРИЙ

На прошлом визите «Конкор» был структурной строкой, сегодня врач продолжил его кликом по «частым препаратам». В заключении и памятке: «Изменения в лечении: отменено: Конкор», а в назначениях «Конкор 5 мг».

ПОСЛЕДСТВИЯ

Противоречивая медицинская информация на подписанном документе и в памятке. Пациент может прекратить приём.

ЧТО СДЕЛАТЬ

Включить текстовые строки в сопоставление (по нормализованному имени из формата строки) или не выводить REMOVED для препаратов, которые встречаются среди legacy-строк текущего визита. Частые препараты добавлять структурной строкой.

КРИТЕРИЙ ПРИЁМКИ

Прошлый визит: структурный Конкор; текущий: Конкор текстовой строкой. В печати нет «отменено: Конкор».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Дифф строится только по visitPrescriptions: `diffTreatments(previousVisit.visitPrescriptions, note.visitPrescriptions)` (487-497), а всё, что не сопоставилось, помечается REMOVED (treatment-diff.ts:124-126). Текстовые строки note.prescriptions (legacy) в дифф не входят, хотя печатаются в «Назначениях» (1126-1131). Чипы «частые

препараты» добавляют именно текстовую строку (prescription-constructor.tsx:178-186, onAddLegacyLine). Дифф выводится и в клинической печати, и в памятке пациента (handoutDiffSection).

VW-06 P2 · СРЕДНИЙ UX

«Отправить в Telegram» сразу после подписи отправляет без заключения (PDF ещё не отрендерен) или устаревший PDF, а сообщает об успехе

ГДЕ

src/app/api/crm/visit-notes/[id]/send-telegram/route.ts:119, src/app/[locale]/doctor/_components/telegram-send-panel.tsx:91, src/server/workers/visit-note-handout.ts:42, src/app/[locale]/doctor/reception/_components/active-patient-card.tsx:284

СЦЕНАРИЙ

Врач подписывает приём, пациент уже привязан, врач сразу жмёт «Отправить в Telegram». Уходит только загруженный снимок МРТ, тост «Отправлено: 1». Заключения у пациента нет, а врач уверен, что отправил.

ПОСЛЕДСТВИЯ

Пациент уходит без заключения. Ложная уверенность персонала.

ЧТО СДЕЛАТЬ

Возвращать в ответе флаг conclusionIncluded/conclusionPending. Если заметка FINALIZED без актуального PDF (нет Document или handoutStaleAt не null), отрендерить синхронно или вернуть 409 conclusion_rendering и показать «Заключение готовится, повторите через минуту». До подписи кнопку скрывать или помечать «только вложения».

КРИТЕРИЙ ПРИЁМКИ

Нажать отправку в течение 30 с после подписи: либо заключение приходит, либо показывается явное сообщение, что оно ещё готовится. Тост успеха не появляется без заключения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Документ CONCLUSION создаёт воркер с тиком 30 с (TICK_INTERVAL_MS, 42). send-telegram отправляет то, что уже есть в Document по visitNoteId/appointmentId (119-137) и возвращает {sent, failed} без признака, было ли среди них заключение (214). Панель показывает «Отправлено: n» (telegram-send-panel.tsx:91-97). На экране приёма кнопка доступна и до подписи (active-patient-card.tsx:284-286). После отката или правки в окне отправляется старый PDF, пока handoutStaleAt не обработан.

VW-07 P2 · СРЕДНИЙ переводы

Автоматическая памятка всегда собирается на русском, даже для пациентов с узбекским языком

ГДЕ

src/app/api/crm/visit-notes/[id]/finalize/route.ts:101, src/app/api/crm/visit-notes/[id]/finalize/route.ts:60, src/server/workers/visit-note-handout.ts:138, src/lib/catalogs/handout-composer.ts:115

СЦЕНАРИЙ

Пациент из Сурхандарьи с preferredLang=UZ получает в Mini App PDF «Bemor uchun eslatma», а весь текст рекомендаций внутри на русском.

ПОСЛЕДСТВИЯ

Пациент, который не читает по-русски, не понимает инструкции по лечению. Документ выглядит неряшливо.

ЧТО СДЕЛАТЬ

Выбирать patient.preferredLang в finalize и передавать locale 'uz'|'ru' в composePatientHandout и formatPrescriptionLines. Лучше рендерить памятку по языку в момент рендера (см. находку о замороженной памятке), тогда переключатель RU/UZ в печати тоже будет работать для тела памятки.

КРИТЕРИЙ ПРИЁМКИ

Подписать приём пациенту с preferredLang=UZ: в PDF, печати ?type=handout и Mini App текст памятки на узбекском. Для RU-пациента на русском.

ДОКАЗАТЕЛЬСТВО В КОДЕ

finalize/route.ts:101-113: `composePatientHandout({ locale: "ru", ..., prescriptions: formatPrescriptionLines(..., "ru", ...) })`. Выборка пациента (строка 60) не содержит preferredLang, хотя композер полностью поддерживает uz (handout-composer.ts:115-138). Воркер выбирает язык PDF по `note.patient.preferredLang === "UZ"` (строка 138), а print-route по preferredLang (194-195). Получается, что заголовки и сетка на узбекском, а тело памятки («Здравствуйте», «Назначения — что и как принимать», «Берегите себя») на русском.

Воркер напоминаний меняет updatedAt заметки, и следующая правка на экране заключения получает ложное «изменено в другом окне»**ГДЕ**

src/server/workers/visit-note-handout.ts:659, src/server/workers/visit-note-handout.ts:264, src/app/api/crm/visit-notes/[id]/route.ts:100, src/app/api/crm/visit-notes/[id]/route.ts:190, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:159

СЦЕНАРИЙ

Врач в «Заключениях» исправляет дозу первого препарата, через минуту меняет длительность второго и получает «Изменено в другом окне», правка откатывается. То же, если открыть заключение сразу после подписи и сохранить позже первого тика воркера.

ПОСЛЕДСТВИЯ

Коррекции после подписи срываются без реального конфликта. Врач повторяет ввод или бросает правку, и в документе остаётся ошибка.

ЧТО СДЕЛАТЬ

Ставить medicationsBridgedAt raw-SQL (UPDATE "VisitNote" SET "medicationsBridgedAt"=... WHERE id=...), не трогая updatedAt, так же, как в generateConclusion. Либо вынести технические якоря из механизма версии (отдельная колонка revision, которую инкрементит только PATCH).

КРИТЕРИЙ ПРИЁМКИ

Unit/интеграционный тест: после runMedicationBridgeTick значение updatedAt заметки не меняется. Две последовательные правки назначений с интервалом больше 30 с на экране заключения обе сохраняются без 409.

ДОКАЗАТЕЛЬСТВО В КОДЕ

bridgeNote завершается `prisma.visitNote.update({ data: { medicationsBridgedAt: now } })` (строки 659-662), а Prisma @updatedAt при этом двигает updatedAt. Рядом, в generateConclusion (264-276), авторы специально чистят handoutStaleAt raw-SQL, чтобы фоновая запись не вызывала 409 у открытого редактора. В мосте такой защиты нет. PATCH сравнивает expectedUpdatedAt с before.updatedAt (route.ts:100-107). Каждая in-window правка назначений ставит medicationsBridgedAt=null (190-192), и примерно через 30 с воркер снова пишет в заметку. conclusion-detail при ошибке показывает saveErrorConflict и откатывает карточку refetch'em (159-173).

Изменение или отмена контрольного визита после подписи не доходит до задачи ресепшена «Контрольный визит»**ГДЕ**

src/app/api/crm/visit-notes/[id]/route.ts:190, src/server/workers/visit-note-handout.ts:632, src/server/workers/visit-note-handout.ts:678, src/app/[locale]/doctor/_components/diagnosis-follow-up-cards.tsx:88

СЦЕНАРИЙ

Врач подписал «контроль через 7 дней», затем в окне 24 ч поменял на 14. У пациента в PDF «через 14 дн.», а ресепшен через 7 дней звонит и приглашает на контроль. Если контроль отменён, звонок всё равно будет.

ПОСЛЕДСТВИЯ

Ресепшен вызывает пациента не в тот день или без надобности. Расхождение между документом пациента и задачами клиники.

ЧТО СДЕЛАТЬ

В PATCH при изменении followUpDays/followUpNote у подписанной заметки обновлять или удалять Action (upsertAction по dedupe visitNoteId с новой dueDate, либо expire), или сбрасывать отдельный якорь followUpSyncedAt, который воркер синхронизирует. В FollowUpCard для подписанной заметки считать дату от finalizedAt.

КРИТЕРИЙ ПРИЁМКИ

Подписать с контролем 7 дн., в окне сменить на 14: Action.dueDate равен finalizedAt+14 (по Ташкенту). Очистить контроль: Action закрыт или удалён. Дата в карточке совпадает с PDF.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Action VISIT_FOLLOW_UP_DUE создаётся только внутри bridgeNote (632-656), а он запускается только при medicationsBridgedAt=null (678). PATCH сбрасывает этот якорь только при rxChanged (route.ts:190-192). Изменение followUpDays/followUpNote подписанной заметки ставит handoutStaleAt, PDF перерисовывается с

новой датой, а задача ресепшена остаётся со старой dueDate. При очистке контрольного визита задача не удаляется. FollowUpCard считает «к дате» от Date.now(), а не от finalizedAt (88-91), и на экране заключения дата расходится с PDF.

VW-10 P2 · СРЕДНИЙ целостность данных

Исправление диагноза после подписи (в окне 24 ч или через откат) оставляет в карте пациента старый диагноз ACTIVE

ГДЕ

src/app/api/crm/visit-notes/[id]/route.ts:119, src/app/api/crm/visit-notes/[id]/finalize/route.ts:208, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:358, src/app/api/crm/appointments/[id]/route.ts:229, src/app/api/crm/visit-notes/[id]/route.ts:171, src/app/api/crm/visit-notes/[id]/finalize/route.ts:211, src/app/api/crm/patients/[id]/diagnoses/route.ts:35

ТАКЖЕ НАШЛИ ЗОНЫ

Остальной кабинет врача

СЦЕНАРИЙ

Врач подписал G43.0, через час понял, что это G44.2, и исправил на экране заключения. В CRM-карте пациента («Диагнозы») висит активный G43.0, а G44.2 там нет. После отката и повторной подписи с новым кодом активны оба.

ПОСЛЕДСТВИЯ

Неверный активный диагноз в медкарте. Его видят другие врачи и ресепшен, он влияет на историю диагнозов.

ЧТО СДЕЛАТЬ

При in-window PATCH, меняющем диагноз подписанной заметки, и при повторной подписи привязывать PatientDiagnosis к visitNotelId (добавить поле sourceVisitNotelId) и переносить или деактивировать строку, созданную этой заметкой, если других подписанных заметок с этим диагнозом нет. Либо пересчитывать диагнозы пациента из подписанных заметок.

КРИТЕРИЙ ПРИЁМКИ

Подписать G43.0, в окне сменить на G44.2: в /api/crm/patients/[id]/diagnoses активен только G44.2 (или G43.0 помечен как RESOLVED/исправлен). Откат с повторной подписью с другим кодом не оставляет старый диагноз ACTIVE.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PatientDiagnosis создаётся или обновляется только в finalize (строки 208-244). Поиск идёт по новому коду, старую строку никто не трогает. PATCH (route.ts:119-120) меняет diagnosisCode/diagnosisName подписанной заметки и PatientDiagnosis не синхронизирует. Экран заключения прямо предлагает исправлять диагноз в окне (conclusion-detail.tsx:358-368, DiagnosisCard → applyStructuredPatch). Откат по комментарию appointments/[id]/route.ts:229-234 специально оставляет PatientDiagnosis, а повторная подпись с другим кодом создаёт вторую строку, старая остаётся ACTIVE. learnClinicDiagnosis при PATCH тоже не вызывается.

VW-11 P2 · СРЕДНИЙ мёртвая механика

Колокольчик «Напоминания пациенту включены» по умолчанию ничего не делает: без выбранного времени приёма напоминания не создаются

ГДЕ

src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:100, src/app/[locale]/doctor/reception/_components/parsed-from-text-card.tsx:37, src/server/workers/visit-note-handout.ts:521, src/server/workers/medication-reminder.ts:116, src/messages/ru.json:6249, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:669

СЦЕНАРИЙ

Врач добавляет препарат из каталога или «Добавить все» из текста и видит синий колокольчик. Пациенту ни одно напоминание не приходит: курс в Mini App есть, а remindersEnabled=false.

ПОСЛЕДСТВИЯ

Функция напоминаний, ради которой структурируют назначения, по умолчанию не работает, а интерфейс утверждает обратное.

ЧТО СДЕЛАТЬ

Либо требовать выбор времени приёма при включённом колокольчике (подсветка строки, блок подписи или диалог при финализации), либо выводить время из текста (парсер «2 раза в день» → утро+вечер) и из defaultDosing. Колокольчик без времени показывать как «нет расписания».

КРИТЕРИЙ ПРИЁМКИ

Строка без времени приёма показывает «не выбрано время, напоминаний не будет». После выбора времени и подписи у Prescription remindersEnabled=true. Разобранная строка «2 раза в день» получает MORNING+EVENING.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Все новые строки создаются с `timesOfDay: []` и `remindPatient: true`: draftFromDrug (100/105), «Свой препарат» (465/470), разбор из текста (parsed-from-text-card.tsx:37/42). Мост ставит remindersEnabled = clinic.medicationRemindersEnabled && schedule.times.length > 0` (521-522), воркер напоминаний берёт только remindersEnabled:true (medication-reminder.ts:116). Подсказка parsedRx.hint (ru.json:6249) обещает, что после добавления «работали ... напоминания пациенту». Бел-иконка показывает «Напоминания пациенту включены» (669, ru.json:6167). Схема при этом обычно записана в «Как принимать» («по 1 таб 2 раза в день») из defaultDosing.

VW-12 P2 · СРЕДНИЙ мокап / заглушка

Применение протокола обещает перенести жалобы, анамнез, осмотр и анализы, но переносит только назначения и рекомендации; в UI остался служебный текст «в G3»

ГДЕ

src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:160, src/app/[locale]/doctor/reception/_components/apply-protocol-dialog.tsx:106, src/app/[locale]/doctor/reception/_components/apply-protocol-dialog.tsx:140, src/messages/ru.json:6272, src/messages/ru.json:6269, src/app/[locale]/doctor/settings/_components/presets-tab.tsx:40

СЦЕНАРИЙ

Врач видит в превью протокола жалобы и осмотр, нажимает «Применить» и ожидает их в заключении, а их нет. Доктор или админ настраивает пресеты «Жалобы», а на приёме их нигде нет. Врач читает «в G3» и не понимает, что это значит.

ПОСЛЕДСТВИЯ

Интерфейс обманывает ожидания. Врач тратит время на ручной ввод и не доверяет протоколам. Служебная фаза разработки видна врачу.

ЧТО СДЕЛАТЬ

Решить продуктивно: либо вставлять жалобы, анамнез и осмотр протокола текстом в заключение (через requestBodyAppend) и показывать это в превью, либо убрать эти секции из превью диалога, настроек пресетов и формы протокола в CRM. Заменить labsHint и fallbackSummary на правдивый текст без «G3».

КРИТЕРИЙ ПРИЁМКИ

После «Применить» всё, что было в превью, оказывается в заметке, либо не показывается в превью. В ru/uz нет строк с «G3». В настройках пресетов нет полей, которые нигде не используются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Диалог показывает секции complaintsTemplate, anamnesisTemplate, examinationTemplate и recommendedLabs (106-147), а его doc-комментарий (5-13) говорит «merges each template array into the corresponding visit-note field». handleApplyProtocol (structured-fields-panel.tsx:160-223) переносит только prescriptionItems/prescriptionsTemplate, adviceTemplate, followUpDays и conclusionTemplateMd; жалобы, анамнез, осмотр и анализы молча отбрасываются. fallbackSummary: «Применит шаблон ко всем структурированным полям» (ru.json:6269). labsHint: «будут привязаны к лабораторному модулю в G3» (ru.json:6272, в uz так же). Настройки врача всё ещё позволяют создавать пресеты COMPLAINTS/ANAMNESIS/EXAMINATION (presets-tab.tsx:40-42), но на экране приёма этих полей нет, и пресеты не показываются.

VW-13 P2 · СРЕДНИЙ баг

Проверка взаимодействий и аллергий (CDS) молча пропадает при любой ошибке сервера

ГДЕ

src/app/[locale]/doctor/reception/_hooks/use-cds-drug-check.ts:58, src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:145

СЦЕНАРИЙ

Endpoint /api/crm/cds/drug-check падает (таймаут БД при загрузке всего каталога, 403 после смены роли, 500). Врач назначает препарат, на который у пациента записана аллергия, и не видит ни красного, ни зелёного блока. Экран выглядит так же, как для препарата вне каталога.

ПОСЛЕДСТВИЯ

Защитный механизм выключается незаметно. Возможна подпись назначения с противопоказанием.

ЧТО СДЕЛАТЬ

Различать ошибку и пустой результат: при `!res.ok` бросать исключение и показывать в карточке явное «Проверка взаимодействий недоступна, повторить», с `retry`. Не маскировать ошибку пустым результатом.

КРИТЕРИЙ ПРИЁМКИ

Смоделировать 500 от `drug-check`: в карточке назначений видно предупреждение «проверка недоступна» с кнопкой повтора.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`fetchCheck`: ``if (!res.ok) { return { warnings: [], resolvedDrugs: [], unresolvedLines: [] }; }`` (58-60). Сетевые ошибки дают `query error`, и `data` остаётся `undefined`. Карточка при ``!result`` и при ``resolvedDrugs.length === 0`` возвращает `null` (145-149). Состояние ошибки не отображается ни в одной ветке.

VW-14 РЗ · НИЗКИЙ безопасность

CDS сопоставляет текстовые назначения с препаратами других клиник (каталог не фильтруется по `clinicId`)

ГДЕ

`src/server/cds/drug-check.ts:127`, `src/server/cds/drug-check.ts:215`, `src/lib/tenant-allowlist.ts:43`

СЦЕНАРИЙ

Клиника В добавила свой препарат «Карбамазепин ретард» со своими АТС и категорией беременности. У врача клиники А текстовая строка «Карбамазепин ретард 200 мг» сопоставляется с препаратом клиники В, и предупреждения строятся по чужим, возможно ошибочным, данным. В ответе CDS видны названия препаратов другой клиники.

ПОСЛЕДСТВИЯ

Данные одной клиники влияют на клиническую проверку в другой; мелкая межтенантная утечка каталога. Лишняя нагрузка на БД на каждое изменение назначений.

ЧТО СДЕЛАТЬ

Во всех запросах `Drug` в `drug-check` добавить ``OR: [{ clinicId: null }, { clinicId }]`` (`clinicId` из `input`). Кэшировать индекс каталога в памяти процесса с коротким TTL.

КРИТЕРИЙ ПРИЁМКИ

Unit-тест: при наличии активного `Drug` с `clinicId` другой клиники и совпадающим `nameRu` строка не резолвится в него. SQL-лог `drug-check` содержит фильтр по `clinicId`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`resolveDrugs`: ``prisma.drug.findMany({ where: { active: true }, ... })`` (127-137), без условия ``clinicId IN (null, ctx.clinicId)``. `Drug` входит в `MODELS_WITHOUT_TENANT` (`tenant-allowlist.ts:43`), поэтому автоскоупа нет. По схеме `Drug.clinicId` задаётся для собственных препаратов клиники (Ф4), и маршруты должны фильтровать вручную. `pinnedDrugs` (215-226) тоже без фильтра. Кроме того, каталог целиком со всеми брендами грузится на каждую проверку, в которой есть текстовые строки.

VW-15 РЗ · НИЗКИЙ UX

«История диагнозов» ведёт на 404 для визитов других врачей

ГДЕ

`src/app/[locale]/doctor/reception/_components/diagnosis-history-card.tsx:55`, `src/app/[locale]/doctor/visits/[patientId]/[visitId]/page.tsx:94`

СЦЕНАРИЙ

Невролог кликает диагноз, поставленный терапевтом, и получает 404.

ПОСЛЕДСТВИЯ

Сломанная навигация, похоже на баг системы.

ЧТО СДЕЛАТЬ

Для чужих визитов не делать ссылку (или вести на `read-only` просмотр, если политика доступа разрешает).

КРИТЕРИЙ ПРИЁМКИ

Строки чужих визитов не кликабельны либо открывают разрешённый просмотр без 404.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Карточка показывает диагнозы всех врачей клиники и для каждой строки ставит `Link` на ``/doctor/visits/${patientId}/${d.visitNoteId}`` (53-57). Страница визита возвращает `notFound`, если ``note.doctorId !==`

VW-16 РЗ · НИЗКИЙ UX

«Частые препараты» добавляются текстовой строкой, а не структурной: без сетки приёма, напоминаний и проверки по id

ГДЕ

src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:178, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:277

СЦЕНАРИЙ

Врач назначает привычный препарат одним кликом по «частым»: в памятке нет строки в сетке приёма, напоминаний нет, в диффе лечения препарат выглядит отменённым.

ПОСЛЕДСТВИЯ

Самый быстрый путь назначения даёт неполноценное назначение.

ЧТО СДЕЛАТЬ

Возвращать в frequent-drugs drugId и схему последнего назначения и добавлять структурную строку (draftFromDrug + lastDose), текстовую строку оставить только для препаратов вне каталога.

КРИТЕРИЙ ПРИЁМКИ

Клик по частому препарату из каталога создаёт структурную строку с drugId.

ДОКАЗАТЕЛЬСТВО В КОДЕ

onFrequentClick собирает строку `\${label} \${lastDose}` и вызывает onAddLegacyLine (178-186), а тот кладёт её в note.prescriptions (structured-fields-panel.tsx:277-281). Мост напоминаний и сетка приёма работают только с visitPrescriptions. Карточка «Найдено в тексте» (parsedRx.hint) прямо говорит, что без структурной строки напоминания и проверки не работают.

VW-17 РЗ · НИЗКИЙ баг

В блоке «Было раньше» кнопка «Взять» скрыта для всех прошлых диагнозов без кода МКБ

ГДЕ

src/app/[locale]/doctor/_components/diagnosis-follow-up-cards.tsx:532, src/app/[locale]/doctor/reception/_hooks/use-patient-diagnoses.ts:9

СЦЕНАРИЙ

Повторный визит: в «Было раньше» стоит «Дорсопатия шейного отдела» (без кода), но кнопки «Взять» нет, и врач перепечатывает диагноз.

ПОСЛЕДСТВИЯ

Функцию для повторных визитов сломали ровно для тех диагнозов, ради которых её правили.

ЧТО СДЕЛАТЬ

Сравнивать пару (code, нормализованное name): isCurrent = code ? code===note.code : name.trim().toLowerCase()===note.name?.trim().toLowerCase().

КРИТЕРИЙ ПРИЁМКИ

Прошлый текстовый диагноз при пустом текущем диагнозе показывает «Взять», клик переносит текст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`isCurrent={d.diagnosisCode === note.diagnosisCode}` (532). Для свободного текста diagnosisCode=null (use-patient-diagnoses.ts:9-10; endpoint специально возвращает такие строки). Когда у текущей заметки кода нет (новый визит или текстовый диагноз), `null === null` даёт true, и кнопка «Взять» скрывается.

VW-18 РЗ · НИЗКИЙ целостность данных

Выбор клинического (выученного) диагноза в справочнике МКБ пишет diagnosisCode="" и плодит дубли в диагнозах пациента

ГДЕ

src/app/[locale]/doctor/reception/_components/icd-catalog-drawer.tsx:230, src/server/icd10/clinic-catalog.ts:118, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:347, src/app/api/crm/visit-notes/[id]/finalize/route.ts:238

СЦЕНАРИЙ

Врач выбирает в «Справочнике» диагноз, выученный клиникой без кода. После нескольких визитов в карте

пациента несколько одинаковых диагнозов.

ПОСЛЕДСТВИЯ

Мусор и дубли в медкарте.

ЧТО СДЕЛАТЬ

В drawer передавать `r.code || null`. На сервере в PATCH нормализовать пустой `diagnosisCode` в `null`.

КРИТЕРИЙ ПРИЁМКИ

Выбор клинического диагноза без кода сохраняет `diagnosisCode=null`. Повторная подпись не создаёт дубль `PatientDiagnosis`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`searchClinicCatalog` отдаёт ``code: r.code ?? ""`` (118). `Drawer` вызывает ``onPick(r.code, r.nameRu)`` без ``|| null`` (230, 267), в отличие от `DiagnosisCard` (``r.code || null``). Панель сохраняет `diagnosisCode: ""` (347). В `finalize` пустая строка `falsy`, поэтому поиск идёт по ``icd10Code: null`` (не совпадает с `""`), а создаётся строка с ``icd10Code: note.diagnosisCode`` = `""` (238). При каждом визите появляется новая строка.

VW-19 РЗ · НИЗКИЙ баг · требует проверки на живых данных

Двойной клик «Завершить приём» подписывает дважды: сжигается номер документа, номер меняется, дублируются события и диагнозы

ГДЕ

`src/app/[locale]/doctor/reception/_components/visit-action-bar.tsx:119`, `src/app/[locale]/doctor/reception/_components/visit-action-bar.tsx:160`, `src/app/api/crm/visit-notes/[id]/finalize/route.ts:76`, `src/app/api/crm/visit-notes/[id]/finalize/route.ts:129`, `src/app/api/crm/visit-notes/[id]/finalize/route.ts:211`

СЦЕНАРИЙ

На медленном Wi-Fi врач дважды нажимает «Завершить приём». Заключению присваивается NF-2026-000124, номер 000123 сожжён. Если первый PDF уже напечатан, номер на бумаге не совпадает с системой. В карте может появиться дубль диагноза.

ПОСЛЕДСТВИЯ

Дыры и подмены в нумерации юридических документов, дубли диагнозов и событий.

ЧТО СДЕЛАТЬ

На клиенте ставить флаг «идёт подпись» (`useRef`) до `flush` и блокировать кнопку. На сервере делать `updateMany({ where: { id, status: 'DRAFT' } })` внутри транзакции; при `count=0` возвращать `alreadyFinalized` без выделения номера. Номер выделять только после успешного условного апдейта.

КРИТЕРИЙ ПРИЁМКИ

Два параллельных `POST finalize`: один возвращает `alreadyFinalized`, `DocumentCounter` увеличен на 1, `PatientDiagnosis` одна строка, событие `appointment.statusChanged` одно.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`onFinalize` сначала `await flushBeforeFinalize()` и только потом `mutateAsync` (строки 103-131), а кнопка заблокирована только по `finalize.isPending` (160). Во время `flush` второй клик проходит, и проверка ``finalize.isPending`` в `doFinalize` смотрит в устаревшее замыкание. На сервере статус проверяется до транзакции (76-78), а `update` в транзакции (132-145) не содержит условия `status='DRAFT'`. Второй запрос со старым `note.documentNumber=null` снова вызывает `allocateDocumentNumber` (129-131) и перезаписывает номер. Повторно обновляется `appointment`, эмитятся события, выполняются `findFirst/create PatientDiagnosis` (211-244), что может дать дубль.

VW-20 РЗ · НИЗКИЙ переводы

Инструкция «Как принимать», введённая в узбекском интерфейсе, не попадает в русскую печать и в автоматическую памятку

ГДЕ

`src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:782`, `src/lib/catalogs/prescription-format.ts:127`, `src/app/api/crm/visit-notes/[id]/finalize/route.ts:111`

СЦЕНАРИЙ

Врач с узбекским интерфейсом пишет «ovqatdan keyin, 1 oy» для пациента с RU. В печати и памятке остаётся каталожная русская инструкция или пусто.

ПОСЛЕДСТВИЯ

Индивидуальные указания врача теряются в документе пациента.

ЧТО СДЕЛАТЬ

Хранить одну инструкцию врача (instruction + lang) или при ru откатываться на instructionUz, если он изменён врачом. Показывать в конструкторе оба поля либо явно пометать язык.

КРИТЕРИЙ ПРИЁМКИ

Инструкция, введённая в uz-интерфейсе, видна в печати для RU-пациента (как есть или с пометкой).

ДОКАЗАТЕЛЬСТВО В КОДЕ

В узбекской локали поле редактирует instructionUz (782-789), а instructionRu остаётся дефолтом каталога (draftFromDrug: `instructionRu: d.defaultDosing?.adult`). formatPrescriptionLine для ru берёт только instructionRu, без отката на Uz (127-130). Памятка собирается на 'ru' (finalize 111-113), сетка для RU-пациентов берёт instructionRu (render-handout.ts:184-187).

VW-21 P3 · НИЗКИЙ мокап / заглушка

На экране заключения кнопки «Применить стандарт» видимы и кликабельны, но ничего не делают

ГДЕ

src/app/[locale]/doctor/_components/diagnosis-follow-up-cards.tsx:436, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:370

СЦЕНАРИЙ

В окне 24 ч врач на экране заключения нажимает «Применить стандарт G43», и ничего не происходит.

ПОСЛЕДСТВИЯ

Мёртвая кнопка, врач теряет доверие к интерфейсу.

ЧТО СДЕЛАТЬ

Сделать onRequestApplyProtocol необязательным пропсом и не рендерить кнопки протоколов, если он не передан.

КРИТЕРИЙ ПРИЁМКИ

На /doctor/conclusions/[id] кнопок «Применить стандарт» нет, на экране приёма есть.

ДОКАЗАТЕЛЬСТВО В КОДЕ

conclusion-detail передаёт `onRequestApplyProtocol={() => {}}` с комментарием «the affordance is simply not offered» (370), но DiagnosisCard рендерит `protocols.map(... onClick={() => onRequestApplyProtocol(p)})` всегда, когда !disabled (436-441).

VW-22 P3 · НИЗКИЙ баг

Оптимистическая блокировка PATCH не атомарна: две одновременные записи с одной версией обе проходят

ГДЕ

src/app/api/crm/visit-notes/[id]/route.ts:100, src/app/api/crm/visit-notes/[id]/route.ts:227

СЦЕНАРИЙ

Два окна (приём и заключение) сохраняют почти одновременно с одним expectedUpdatedAt: обе проверки проходят, и последнее сохранение молча затирает первое.

ПОСЛЕДСТВИЯ

Редкая, но именно та тихая потеря, от которой механизм должен защищать.

ЧТО СДЕЛАТЬ

В транзакции делать updateMany({ where: { id, updatedAt: expected } }) и при count=0 возвращать 409 (или SELECT ... FOR UPDATE перед проверкой).

КРИТЕРИЙ ПРИЁМКИ

Тест с двумя параллельными PATCH с одной версией: один 200, другой 409.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Версия сравнивается с `before` из findUnique вне транзакции (68, 100-107), а update в транзакции идёт по `where: { id }` без условия на updatedAt (227-229).

Параметр `?embed=1` позволяет печатать заключение без записи в журнал аудита

ГДЕ

`src/app/api/crm/visit-notes/[id]/print/route.ts:85`, `src/app/api/crm/visit-notes/[id]/print/route.ts:1563`

СЦЕНАРИЙ

Сотрудник открывает `/api/crm/visit-notes/<id>/print?embed=1` и печатает чужое заключение (для ADMIN доступны любые), след в журнале печати не остаётся.

ПОСЛЕДСТВИЯ

Дыра в аудите доступа к медицинским документам.

ЧТО СДЕЛАТЬ

Писать аудит и для `embed` (другим action, например `visit_note.preview`, с дедупом по минуте) либо разрешать `embed` только при заголовке `Sec-Fetch-Dest: iframe` и `same-origin`.

КРИТЕРИЙ ПРИЁМКИ

Запрос с `embed=1` оставляет запись аудита (`preview`).

ДОКАЗАТЕЛЬСТВО В КОДЕ

`pickEmbed` читает ``searchParams.get("embed") === "1" (85-87)`, и все ветки пишут `audit` только ``if (!embed)` (1031, 1531, 1563)`. Документ при этом полностью рендерится, его можно распечатать через `Cmd+P`.

Печать пакета до подписи показывает инструкцию нажать несуществующую кнопку «Сформировать»; пакет обещает рецепты и направления, которые больше нигде создать

ГДЕ

`src/app/api/crm/visit-notes/[id]/print/route.ts:803`, `src/app/[locale]/doctor/reception/_components/active-patient-card.tsx:133`, `src/app/[locale]/doctor/reception/_components/e-prescription-dialog.tsx:1`

СЦЕНАРИЙ

Врач до подписи печатает пакет, пациенту выдаётся лист с текстом «нажмите Сформировать». Врач ищет, где выписать рецепт или направление для пакета, и не находит.

ПОСЛЕДСТВИЯ

Сбивающий с толку текст на бумаге пациента; мёртвый код.

ЧТО СДЕЛАТЬ

Заменить `emptyHint` на «Памятка формируется после подписи» или скрывать раздел памятки в пакете до подписи. Удалить неиспользуемые диалоги и хуки либо вернуть точки входа, если функции нужны.

КРИТЕРИЙ ПРИЁМКИ

В печати пакета до подписи нет упоминания «Сформировать». Неиспользуемые файлы удалены или подключены.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`emptyHint`: «Памятка ещё не сформирована. На экране приёма нажмите «Сформировать»» (`print route 791-808`), но вкладку памятки удалили, а до подписи `patientHandoutMarkdown` всегда пуст. Кнопка «Печать пакета» доступна для `DRAFT` (`active-patient-card.tsx:135-142`, `disabled` только без `visitNoted`) и включает `handoutInner` (`1523-1529`). Комментарий говорит «`conclusion + handout + issued e-prescriptions + referrals`» (`133-134`), но `e-prescription-dialog`, `sick-leave-dialog`, `referral-dialog`, `lab-order-dialog` и `save-protocol-dialog` никуда не импортируются (`grep: 0` использований; удалены из UI коммитом `1622b12`). Файлы остались мёртвым кодом.

Подтверждение CDS-предупреждений необязательно и не сохраняется:

CONTRAINDICATED не мешает подписи, после перезагрузки «учтённые» снова красные

ГДЕ

`src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:11`, `src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:117`, `src/app/[locale]/doctor/reception/_components/visit-action-bar.tsx:74`, `src/app/api/crm/cds/drug-check/route.ts:6`

СЦЕНАРИЙ

Пациентке с аллергией на карбамазепин назначают карбамазепин: красное `CONTRAINDICATED`. Врач не нажимает «Я учёл» и подписывает, подпись проходит. Если врач всё же отметил причину, то после перехода на

вкладку «История» и обратно предупреждение снова красное, и при повторной отметке пишется дубль override.

ПОСЛЕДСТВИЯ

Журнал обоснований неполон, контроль качества по CDS недостоверен; противопоказание можно подписать без явного решения.

ЧТО СДЕЛАТЬ

Перед финализацией требовать обоснование для CONTRAINDICATED/MAJOR (или хотя бы диалог подтверждения). Состояние подтверждения восстанавливать из GET /api/crm/cds-overrides?visitNotelId=. Исправить комментарий.

КРИТЕРИЙ ПРИЁМКИ

Нельзя подписать заметку с неподтверждённым CONTRAINDICATED без диалога. После перезагрузки подтверждённые предупреждения отображаются как учтённые, повторного override не создаётся.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий карточки (11-14) обещает «persisted to localStorage as already-acknowledged», но acknowledged хранится только в useState (117-119) и теряется при размонтировании. emptySectionsOf/onFinalize (visit-action-bar.tsx:74-132) не учитывают CDS-предупреждения, finalize-route их тоже не проверяет, хотя drug-check/route.ts:6-9 говорит «Doctors must still acknowledge/override». Записанные CdsOverride при повторной загрузке не читаются.

VW-26 P3 · НИЗКИЙ UX

Правка телефона на экране приёма: очистка поля приводит к 400 с сырым текстом «ValidationError», любой ввод от 3 символов принимается без проверки формата

ГДЕ

src/app/[locale]/doctor/reception/_components/editable-phone.tsx:44, src/app/[locale]/doctor/reception/_components/editable-phone.tsx:59, src/server/schemas/patient.ts:32

СЦЕНАРИЙ

Врач стирает ошибочный номер и видит тост «ValidationError». Либо вводит «123» и сохраняет.

ПОСЛЕДСТВИЯ

Непонятная ошибка; неверный номер ломает напоминания и привязку Telegram.

ЧТО СДЕЛАТЬ

Валидировать номер на клиенте (+998XXXXXXXXXX) и не отправлять пустое значение. Показывать локализованное сообщение phoneSaveFailed.

КРИТЕРИЙ ПРИЁМКИ

Пустой ввод блокирует сохранение с понятной подсказкой, некорректный формат не сохраняется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Отправляется `{ phone: next || null }` (44), а схема требует `z.string().min(3).max(40)` (patient.ts:32, partial), поэтому null даёт 400. Тост показывает `e.message`, то есть «ValidationError» (59). Формат номера не проверяется, а от телефона зависят напоминания и привязка Mini App.

VW-27 P3 · НИЗКИЙ мёртвая механика

Фото упаковки глобальных препаратов не доходит до назначений, печатной памятки и Telegram: читается Drug.photoUrl вместо оверлея клиники

ГДЕ

src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:131, src/app/api/crm/visit-notes/[id]/route.ts:45, src/app/api/crm/visit-notes/[id]/print/route.ts:818, src/app/api/crm/visit-notes/[id]/send-telegram/route.ts:88, src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:648

СЦЕНАРИЙ

Клиника загрузила фото упаковки «Мидокалм» (глобальный препарат). В поиске фото есть. После добавления в назначения фото исчезает; в печатной памятке нет блока «Как выглядит упаковка»; в Telegram фото не уходит.

ПОСЛЕДСТВИЯ

Функция, о которой просила клиника, на основном каталоге не работает. Сотрудники загружают фото впустую.

ЧТО СДЕЛАТЬ

В GET/PATCH заметки, print и send-telegram после загрузки строк подмешивать photoUrl из loadClinicOverlays(clinicId, 'DRUG') по drugId (как в catalogs/drugs). Вынести это в общий хелпер resolveDrugPhotos(clinicId, drugIds).

КРИТЕРИЙ ПРИЁМКИ

Загрузить фото для глобального препарата и назначить его: фото видно в строке назначения, в печати ?type=handout и приходит в Telegram.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Для глобального препарата (clinicId=null) фото сохраняется в ClinicCatalogOverlay.overridesJson.photoUrl (photo/route.ts:131-135, setOverlayPhoto). Поиск применяет оверлей (catalogs/drugs route: applyClinicOverlay), и в выпадающем списке фото видно. Заметка, печать и Telegram берут `include: { drug: { select: { photoUrl: true } } }` прямо из строки Drug (route.ts:45, 233; print 175, 818-824; send-telegram 88-94, 177-181), а там для глобальных препаратов null.

VW-28 РЗ · НИЗКИЙ баг

Экран приёма видит только первые 50 записей дня: при загруженном дне текущий пациент может «пропасть»

ГДЕ

src/app/[locale]/doctor/reception/_hooks/use-doctor-queue.ts:75, src/app/[locale]/doctor/reception/_hooks/use-doctor-queue.ts:100, src/app/[locale]/doctor/reception/_hooks/reception-context.tsx:81

СЦЕНАРИЙ

В насыщенный день (живая очередь, отмены) у невролога больше 50 записей. Вечерний пациент IN_PROGRESS по дате на второй странице, и экран приёма пишет «нет активного пациента». Заключение не открыть.

ПОСЛЕДСТВИЯ

Врач не может вести приём и подписывать в пиковые дни.

ЧТО СДЕЛАТЬ

Активный визит получать отдельным запросом (status=IN_PROGRESS, doctor=me) или через /api/crm/doctors/me/today. Очередь либо догружать, либо не использовать для поиска активного визита.

КРИТЕРИЙ ПРИЁМКИ

Сид с 60 записями на сегодня, IN_PROGRESS последний по времени: экран приёма открывает его заметку.

ДОКАЗАТЕЛЬСТВО В КОДЕ

useDoctorQueue запрашивает /api/crm/appointments за сегодня с limit=50, sort=date asc, без фильтра статуса (75-83). useInfiniteQuery, но fetchNextPage для этого ключа нигде не вызывается (grep). flattenQueue берёт только загруженные страницы (100-105), а inProgress ищется среди них (reception-context.tsx:81). В выборку входят CANCELLED/NO_SHOW/COMPLETED.

ДС · Остальной кабинет врача

ДС-01 P1 · ВЫСОКИЙ баг

«Завершить приём» на «Мой день» закрывает визит без подписи заключения, а подписать оставшийся черновик потом негде

ГДЕ

src/app/[locale]/doctor/my-day/_components/current-patient-card.tsx:254, src/app/[locale]/doctor/my-day/_components/schedule-card.tsx:550, src/app/[locale]/doctor/my-day/_hooks/use-appointment-status-mutation.ts:113, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:235, src/app/[locale]/doctor/reception/_hooks/reception-context.tsx:81, src/app/api/crm/visit-notes/[id]/finalize/route.ts:149, src/app/[locale]/doctor/reception/_hooks/reception-context.tsx:151, src/app/[locale]/doctor/my-day/_components/current-patient-card.tsx:253, src/app/[locale]/doctor/my-day/_hooks/use-appointment-status-mutation.ts:112, src/app/api/crm/appointments/[id]/route.ts:643, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:234

ТАКЖЕ НАШЛИ ЗОНЫ

Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

СЦЕНАРИЙ

Врач ведёт приём, пишет заключение на экране «Приём», возвращается на «Мой день» и жмёт зелёную «Завершить приём» (или жмёт «Вызвать» следующему и соглашается «Завершить текущий приём и начать нового?»). Визит становится COMPLETED, заключение остаётся черновиком. В «Заключения → Черновики» он его видит, жмёт «Открыть в приёме» — открывается приём другого/пустого пациента. Подписать нельзя.

ПОСЛЕДСТВИЯ

Пациент не получает заключение (Telegram/мини-апп), нет номера документа, диагноз не попадает в карту пациента и в «Было раньше» на следующих приёмах, курсы лекарств не создаются — нет напоминаний пациенту. Медицинская документация приёма неполная, в массовом ежедневном сценарии.

ЧТО СДЕЛАТЬ

На «Мой день» (карточка текущего, строка расписания, switch-флоу) для IN_PROGRESS не делать PATCH status=COMPLETED: вызывать /api/crm/visit-notes/[id]/finalize с тем же подтверждением пустых разделов, либо уводить на экран приёма с явным appointmentId. На сервере запретить DOCTOR переводить визит в COMPLETED общим PATCH, если у визита есть DRAFT-заключение (или авто-финализировать). В conclusion-detail для DRAFT с appointment.status=COMPLETED добавить кнопку «Подписать» (finalize уже поддерживает COMPLETED) и deep-link в приём с id визита.

КРИТЕРИЙ ПРИЁМКИ

«Завершить приём» на «Мой день» и в switch-диалоге приводит к FINALIZED-заключению или к экрану подписи; в «Черновиках» нет DRAFT по COMPLETED-визитам без рабочей кнопки «Подписать»; после подписи создан PatientDiagnosis и пациенту ушло заключение.

ДОКАЗАТЕЛЬСТВО В КОДЕ

На карточке текущего пациента для IN_PROGRESS основная кнопка — `action: { kind: "status", toStatus: "COMPLETED" }` (current-patient-card.tsx:254-259); в строке расписания `onClick={() => onFire("COMPLETED")}` (schedule-card.tsx:550). Обе шлют PATCH /api/crm/appointments/[id] {status:"COMPLETED"}; прямая ветка этого роута ставит только completedAt/endDate/queueStatus и VisitNote не трогает. Switch-флоу в use-appointment-status-mutation.ts:112-121 (409 another_visit_in_progress → window.confirm → PATCH активного визита в COMPLETED) делает то же самое. Подписание есть только в reception/visit-action-bar через useFinalizeVisitNote (единственный вызов /finalize в UI), а reception берёт только сегодняшний IN_PROGRESS из очереди (reception-context.tsx:81). В conclusion-detail для DRAFT нет кнопки «Подписать», есть только ссылка на `/\${locale}/doctor/reception` без id визита (строки 235-243). Finalize (route.ts:149, 200-245, 287-299) — единственное место, где создаётся PatientDiagnosis, выделяется documentNumber, пересчитывается статистика, собирается handout и шлётся fireTrigger пациенту. Роут diagnoses (doctors/me/patients/[patientId]/diagnoses) показывает только FINALIZED.

Кабинет врача вне всех сессионных проверок: сменить пароль и включить 2FA невозможно, таймаут простоя не работает**ГДЕ**

src/proxy.ts:47, src/proxy.ts:91, src/proxy.ts:222, src/app/[locale]/crm/layout.tsx:63, src/app/[locale]/doctor/settings/_components/security-tab.tsx:96, src/app/[locale]/doctor/layout.tsx:28, src/server/auth/security-policy.ts:63, src/proxy.ts:48, src/app/api/crm/users/route.ts:121, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:611, src/app/[locale]/doctor/settings/_components/security-tab.tsx:95, src/lib/api-handler.ts:245, src/lib/post-login-redirect.ts:35, src/proxy.ts:220, src/lib/api-handler.ts:241

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа, Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония, Настройки клиники, пользователи, филиалы, кабинеты, права

СЦЕНАРИЙ

а) Админ выдал врачу временный пароль (mustChangePassword) — врач не будет принуждён сменить его и не сможет сделать это сам. б) Клиника включила «2FA для всех» — врач логинится, все виджеты «Мой день» падают с 403 MFA_REQUIRED, страницу подключения открыть нельзя, кабинет мёртв. в) Врач ушёл от общего ПК в кабинете — кабинет не разлогинивается по простоя; сессия, выбитая новым входом, продолжает работать на /doctor.

ПОСЛЕДСТВИЯ

Нельзя сменить скомпрометированный пароль, включение обязательной 2FA блокирует всех врачей, нет таймаута на ПК с PHI.

ЧТО СДЕЛАТЬ

Распространить проверки proxy (session lifetime, mustChangePassword, TOTP) на /(ru|uz)?/doctor/*; сделать экраны смены пароля и 2FA доступными врачу (исключить /crm/me/* из редиректа CRM layout для DOCTOR или встроить security-client в /doctor/settings); добавить проверку UserSession в createApiHandler.

КРИТЕРИЙ ПРИЁМКИ

Врач с mustChangePassword после входа попадает на смену пароля и может её завершить; врач включает 2FA из кабинета; при require2faForAll неподключённого врача ведёт на подключение; после idle-timeout /doctor/* редиректит на логин.

ДОКАЗАТЕЛЬСТВО В КОДЕ

proxy.ts применяет UserSession idle-timeout/8h re-потацию/клик, редирект mustChangePassword и принудительный TOTP только внутри `if (crm)` для `CRM\_PATH = /^(?:(ru|uz))?/crm.../`; пути /doctor/* идут сразу в intlMiddleware. doctor/layout.tsx проверяет только session/role/clinicId. Врачи после логина попадают в /doctor (post-login-redirect: DOCTOR → doctor). Смена пароля и подключение 2FA живут только на /crm/me/change-password и /crm/me/security, но crm/layout.tsx:63-66 редиректит любого DOCTOR из /crm в /doctor, поэтому страницы недоступны; СТА «Безопасность» (security-tab.tsx:96) ведёт на /crm/me/security и возвращает на «Мой день». При require2faForAll api-handler.enforceTotpEnrollment отдаёт MFA_REQUIRED на все doctor-API, исключения только /api/crm/me/totp. createApiHandler UserSession не проверяет. _ROADMAP.md называет эту ссылку «FALSE ALARM» и утверждает, что «proxy page-layer gate prevents stale users» — для /doctor это неверно.

CSV-экспорт истории визитов падает с 500 для пациентов с кириллическим именем**ГДЕ**

src/app/api/crm/doctors/me/patients/[patientId]/visits/export/route.ts:195, src/app/api/crm/doctors/me/patients/[patientId]/visits/export/route.ts:200, src/app/api/crm/doctors/me/patients/[patientId]/visits/export/route.ts:37

СЦЕНАРИЙ

Врач на /doctor/visits/<id> жмёт «Экспорт CSV» для «Иванова Ивана» — скачивается файл с JSON {"error": "internal_error", ...} вместо таблицы.

ПОСЛЕДСТВИЯ

Экспорт не работает почти для всех пациентов клиники; в аудите ложные записи об экспорте.

ЧТО СДЕЛАТЬ

ASCII-фолбэк filename + `filename\*=UTF-8"...`; аудит после формирования ответа; префиксовать ячейки,

начинающиеся с = + - @, апострофом.

КРИТЕРИЙ ПРИЁМКИ

Экспорт для кириллического имени отдаёт 200 text/csv с корректным именем файла; unit-тест на роут.

ДОКАЗАТЕЛЬСТВО В КОДЕ

filename строится из patient.fullName с сохранением [А-Яа-яЁё] и кладётся в `Content-Disposition: attachment; filename="..."`. Значения заголовков Response обязаны быть ByteString: проверено на Node 22 — `new Response("x",{headers:{'Content-Disposition':attachment; filename="visits-Иванов..."}})` бросает «Cannot convert argument to a ByteString». Роут documents/file прямо описывает эту ловушку и использует filename*. Аудит visit_list.exported пишется ДО падения. Дополнительно комментарий у csvCell «Always quote — covers ... formula injection» неверен: кавычки не защищают от =HYPERLINK(...) в Excel.

ДС-04 P2 · СРЕДНИЙ безопасность

Глобальные Telegram-тосты в кабинете врача: превью всех сообщений клиники со звуком, «Открыть» ведёт в пустой чат

ГДЕ

src/app/[locale]/doctor/layout.tsx:71, src/components/layout/global-tg-alerts.tsx:49, src/components/layout/global-tg-alerts.tsx:80, src/app/[locale]/doctor/messages/_hooks/messages-context.tsx:72

СЦЕНАРИЙ

Во время приёма у врача пищит и всплывает «Мадина: опять приступ...» — пациентка другого врача. Клик «Открыть» — пустой экран сообщений без выбранного диалога.

ПОСЛЕДСТВИЯ

Утечка содержимого переписки между caseload, отвлечение на приёме, мёртвая кнопка.

ЧТО СДЕЛАТЬ

Фильтровать тосты по doctorConversationScope (флаг в payload или проверка), поддержать ?conv= в doctor messages.

КРИТЕРИЙ ПРИЁМКИ

Врач получает тосты только по своим диалогам; «Открыть» выбирает нужный тред.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Layout монтирует `

ДС-05 P2 · СРЕДНИЙ баг

Записи в статусе CONFIRMED (все телефонные) выпадают из «Сегодняшних», «Следующего приёма», бейджа «Мой день» и карточки пациента

ГДЕ

src/app/api/crm/doctors/me/patients/route.ts:130, src/app/api/crm/doctors/me/patients/route.ts:236, src/app/api/crm/doctors/me/patients/[patientId]/summary/route.ts:95, src/app/api/crm/doctors/me/sidebar-stats/route.ts:109, src/server/appointments/book.ts:351, src/app/api/crm/appointments/route.ts:157

СЦЕНАРИЙ

Ресепшен записала пациента по телефону на сегодня 15:00. Врач открывает «Пациенты → Сегодняшние» — пациента нет; в строке «Следующий приём: —», статус «Давно не был»; в карточке пациента «Ближайшая запись: нет записей»; бейдж «Мой день» меньше реального.

ПОСЛЕДСТВИЯ

Врач видит неверную картину дня и пациента: может решить, что пациент не записан на контроль, продублировать запись, недооценить загрузку.

ЧТО СДЕЛАТЬ

Вынести единый набор предвизитных статусов (BOOKED, CONFIRMED, WAITING и т.п.) в lib и использовать во всех четырёх местах.

КРИТЕРИЙ ПРИЁМКИ

CONFIRMED-запись на сегодня видна во вкладке «Сегодняшние», в колонке «Следующий приём», в summary.upcomingAppointment и учитывается в todayBadge.

ДОКАЗАТЕЛЬСТВО В КОДЕ

AUTO_CONFIRM_CHANNELS = [PHONE, KIOSK] → book.ts:351 создаёт запись со status CONFIRMED

(doctor-current-visit.ts:79 прямо пишет: «CRM bookings auto-confirm, so CONFIRMED is the default pre-visit state»).

Но: вкладка «today» — `status: { in: ["BOOKED", "WAITING", "IN\_PROGRESS", "COMPLETED"] }` (patients/route.ts:130); колонка «Следующий приём» — `status: { in: ["BOOKED", "WAITING"] }` (236); summary.upcomingAppointment — `["BOOKED", "WAITING", "IN\_PROGRESS"]` (summary/route.ts:95); todayBadge считает только BOOKED/WAITING/IN_PROGRESS (sidebar-stats:109-114). На nextAppointmentWithMeAt опирается и статус строки в patients-table deriveStatus.

DC-06 P2 · СРЕДНИЙ целостность данных

История визитов показывает исходное заключение без исправлений (amendments)

ГДЕ

src/app/[locale]/doctor/visits/[patientId]/[visitId]/page.tsx:56, src/app/[locale]/doctor/visits/[patientId]/[visitId]/_components/visit-note-readonly.tsx:1, src/app/[locale]/doctor/patients/[id]/_components/visits-section.tsx:201, prisma/schema.prisma:2254, src/app/[locale]/doctor/conclusions/[id]/_components/conclusion-detail.tsx:403

СЦЕНАРИЙ

Через 2 дня после подписи врач добавил исправление «ошибка в дозировке: карбамазепин 200 мг, не 400». Через месяц на повторном приёме он открывает карточку → История визитов → визит и видит исходное «400 мг» без какой-либо отметки об исправлении.

ПОСЛЕДСТВИЯ

Неверные медицинские данные в основном месте просмотра истории; риск повторить ошибочное назначение.

ЧТО СДЕЛАТЬ

Подгружать amendments в /doctor/visits/[p]/[v] и выводить блок «Исправления»; в visits API отдавать amendmentsCount и показывать бейдж «Есть исправления» в visits-section и visits-list.

КРИТЕРИЙ ПРИЁМКИ

У заключения с исправлением на странице визита виден блок исправлений, в строке истории — индикатор.

ДОКАЗАТЕЛЬСТВО В КОДЕ

VisitDetailPage выбирает поля заметки без amendments (page.tsx:56-88), VisitNoteReadOnly рендерит только исходные поля; grep по amend в visits-компонентах и visits-section пуст. VisitNoteAmendment по схеме «Rendered as an appended block; never merged back into the original fields». Исправления видны только на /doctor/conclusions/[id] (AmendmentsSection, строка 403) и в печати.

DC-07 P2 · СРЕДНИЙ целостность данных

Круглая стрелка у завершённой записи в один клик снимает подпись заключения и отключает пациенту напоминания о лекарствах

ГДЕ

src/app/[locale]/doctor/my-day/_components/schedule-card.tsx:578, src/app/[locale]/doctor/my-day/_components/schedule-card.tsx:659, src/app/api/crm/appointments/[id]/route.ts:235

СЦЕНАРИЙ

Врач раскрывает «Завершённые» и случайно жмёт стрелку — визит снова «идёт», заключение стало черновиком, пациенту перестали приходить напоминания; при вызове следующего пациента «Завершить текущий?» закрывает его уже без подписи (см. дефект про «Завершить приём»).

ПОСЛЕДСТВИЯ

Снятие подписи медицинского документа случайным кликом, пациент без напоминаний о приёме лекарств.

ЧТО СДЕЛАТЬ

Подтверждающий диалог с явным текстом «Заключение будет снято с подписи, напоминания приостановлены».

КРИТЕРИЙ ПРИЁМКИ

Revert завершённого визита из расписания требует явного подтверждения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

RevertButton → onFire(revertTarget,{revert:true}) без подтверждения; сервер при COMPLETED→IN_PROGRESS переводит VisitNote FINALIZED→DRAFT и делает prescription.updateMany remindersEnabled:false (route.ts:235-275). Кнопка стоит рядом с «Уже был» в свёрнутом блоке «Завершённые».

На карточке текущего пациента зашифрованная заметка пациента показывается шифротекстом

ГДЕ

src/app/api/crm/doctors/me/today/route.ts:207, src/app/api/crm/doctors/me/today/route.ts:286, src/server/patient/cipher-fields.ts:53, src/server/crypto/field-cipher.ts:108, src/app/[locale]/doctor/my-day/_components/current-patient-card.tsx:384

СЦЕНАРИЙ

Ресепшен в карте пациента пишет «аллергия на анальгин». Пациента записывают без комментария. У врача на «Мой день» в блоке «Заметка о пациенте» строка вида «v1:Q2x....Zk....».

ПОСЛЕДСТВИЯ

Врач не видит клинически важную пометку (аллергии, особенности), видит мусор в основном рабочем экране.

ЧТО СДЕЛАТЬ

В today route расшифровывать пациента через hydratePatientForRead перед использованием notes. Проверить остальные прямые чтения зашифрованных полей (в зоне: doctors/me/patients/[patientId]/prescriptions отдаёт Prescription.notes сырым).

КРИТЕРИЙ ПРИЁМКИ

При зашифрованной заметке и пустом комментарии визита карточка показывает расшифрованный текст; unit-тест today route со значением `v1:`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Patient.notes шифруется при записи (serializePatientForWrite: `out.notes = encryptIfPresent(...)`), формат `v1:<iv>:<tag>:<ct>`), в production без ключа приложение не стартует (field-cipher.ts:108-114), т.е. шифрование всегда включено. /today выбирает `patient.notes: true` (строка 207) и кладёт `p.notes?.trim()` в `complaints` как фолбэк, если у визита нет comments (286-292), без hydratePatientForRead/decryptIfEncrypted. Карточка рендерит это под заголовком «Заметка о пациенте» (current-patient-card.tsx:384-390).

Настройки уведомлений врача (12 переключателей) сохраняются, но нигде не читаются

ГДЕ

src/app/api/crm/doctors/me/notification-prefs/route.ts:25, src/app/[locale]/doctor/settings/_components/notifications-tab.tsx:30, src/lib/tenant-allowlist.ts:29, src/app/api/crm/doctors/me/notification-prefs/route.ts:54, src/app/[locale]/doctor/settings/_components/security-tab.tsx:1

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Врач включает «Telegram: новое сообщение» — ничего не приходит; выключает «В приложении» — тосты продолжают появляться.

ПОСЛЕДСТВИЯ

Мокап-настройка в проде, подрывает доверие.

ЧТО СДЕЛАТЬ

Реализовать учёт prefs (минимум gating GlobalTgAlerts по messageNew_inApp и напоминаний по reminderDue_*) или убрать вкладку.

КРИТЕРИЙ ПРИЁМКИ

Каждый переключатель меняет поведение, либо вкладка скрыта.

ДОКАЗАТЕЛЬСТВО В КОДЕ

grep по doctorNotificationPref и полям *_inApp/*_email/*_telegram: только этот роут и вкладка настроек. Ни один воркер/отправитель их не читает; доставки уведомлений врачу по email/Telegram для этих событий нет. GlobalTgAlerts показывает тосты независимо от messageNew_inApp.

DC-10 P2 · СРЕДНИЙ баг

Открытие диалога врачом обнуляет «непрочитано» у ресепшена; бейдж «Telegram» врача раздут общими обращениями

ГДЕ

src/app/[locale]/doctor/messages/_components/chat-panel.tsx:80, src/app/api/crm/conversations/[id]/route.ts:54, src/server/conversations/doctor-scope.ts:27, src/app/api/crm/doctors/me/sidebar-stats/route.ts:85

СЦЕНАРИЙ

Незнакомый человек пишет в Telegram клиники: у всех врачей бейдж +1. Один врач открывает диалог — у ресепшена пропадает индикатор непрочитанного, обращение остаётся без ответа.

ПОСЛЕДСТВИЯ

Пропущенные обращения пациентов, шум в кабинетах врачей.

ЧТО СДЕЛАТЬ

Хранить прочтение per-user (или не делать markRead для DOCTOR в неназначенных диалогах); не считать unlinked-диалоги в бейдж врача.

КРИТЕРИЙ ПРИЁМКИ

Открытие диалога врачом не меняет unread у ресепшена; бейдж врача считает только его пациентов и назначенные ему диалоги.

ДОКАЗАТЕЛЬСТВО В КОДЕ

unreadCount один на диалог; при открытии чат шлёт PATCH {markRead:true} → `data.unreadCount = 0`. Скопн врача включает все `patientId: null` диалоги (фронт-дверь клиники), sidebar-stats суммирует их unreadCount в бейдж.

DC-11 P2 · СРЕДНИЙ баг

Список заключений: пагинация по изменяемому updatedAt с курсором по id — дубли и пропуски, порядок не по дате подписи

ГДЕ

src/app/api/crm/visit-notes/route.ts:64, src/app/[locale]/doctor/conclusions/_components/conclusions-list.tsx:160

СЦЕНАРИЙ

Врач листает «Подписанные» вниз, в это время worker перерисовал handout — одно заключение появляется дважды (дубли key), другое пропадает; давно подписанное заключение прыгает наверх.

ПОСЛЕДСТВИЯ

Неполный/дублированный список, врач может не найти заключение.

ЧТО СДЕЛАТЬ

Для FINALIZED сортировать по finalizedAt desc, id desc; для DRAFT — createdAt; курсор по стабильной папе.

КРИТЕРИЙ ПРИЁМКИ

Прокрутка без дублей/пропусков при параллельных изменениях; порядок по дате подписи.

ДОКАЗАТЕЛЬСТВО В КОДЕ

orderBy: { updatedAt: "desc" } без тай-брейкера + cursor:{id}; updatedAt меняется автосейвом черновиков и перерисовкой handout после подписи. UI показывает finalizedAt ?? updatedAt, а сортирует по updatedAt.

DC-12 P3 · НИЗКИЙ баг

«Мой день» не обновляется по времени: «Следующая запись» не появляется без SSE-события, после обрыва SSE очередь устаревает

ГДЕ

src/app/[locale]/doctor/my-day/_hooks/use-doctor-today.ts:161, src/components/providers/query-provider.tsx:29, src/lib/doctor-current-visit.ts:74, src/hooks/use-live-events.ts:132, src/app/[locale]/doctor/my-day/_hooks/use-doctor-schedule.ts:37

СЦЕНАРИЙ

10:45, в клинике тихо. Запись на 11:00 — карточка показывает «Нет активного приёма» до первого события в очереди. Опоздавший на 40 минут всё ещё висит «Следующая запись». После сна ноутбука живая очередь не обновляется.

ПОСЛЕДСТВИЯ

Врач пропускает записанного пациента или работает по устаревшей очереди.

ЧТО СДЕЛАТЬ

refreshInterval ~60s для /today и /schedule (или таймер до ближайшей границы окна) и инвалидация doctor-ключей при переключении SSE.

КРИТЕРИЙ ПРИЁМКИ

За 15 минут до записи карточка появляется без действий; после реконнекта SSE данные перезапрашиваются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Фолбэк «ближайшая запись» считается на сервере от now в момент запроса (окно -30...+15 мин, doctor-current-visit.ts:74-84). useDoctorToday/useDoctorSchedule: staleTime 15s, без refreshInterval; QueryProvider отключает refreshOnWindowFocus и refreshOnReconnect; onopen в use-live-events только сбрасывает retry, ресинка нет. Обновление только по appointment/queue событиям этого врача.

DC-13 РЗ · НИЗКИЙ баг

«Написать» из карточки пациента не открывает диалог, если он не в первых 50 тредах

ГДЕ

src/app/[locale]/doctor/messages/_components/chat-panel.tsx:42, src/app/[locale]/doctor/messages/_components/chat-panel.tsx:97, src/app/api/crm/conversations/route.ts:93, src/app/[locale]/doctor/messages/_hooks/messages-context.tsx:102

СЦЕНАРИЙ

Врач жмёт «Написать» у пациента, с которым переписка была 2 месяца назад — открывается «Сообщения» без выбранного чата.

ПОСЛЕДСТВИЯ

Нельзя написать пациенту из карточки.

ЧТО СДЕЛАТЬ

Загружать выбранный диалог отдельным запросом (GET /conversations/[id]) независимо от списка.

КРИТЕРИЙ ПРИЁМКИ

«Написать» всегда открывает нужный тред.

ДОКАЗАТЕЛЬСТВО В КОДЕ

find-or-create ставит selectedId, но ChatPanel ищет `conversations.find(c => c.id === selectedId)` в загруженной первой странице (limit 50, orderBy lastMessageAt desc); если не найдено — пустое состояние «выберите диалог». Скоуп врача включает все unlinked-треды, так что первая страница быстро забивается.

DC-14 РЗ · НИЗКИЙ UX

«Отменить приём» в меню текущего пациента срабатывает без подтверждения, отменённого «живого» пациента вернуть нельзя

ГДЕ

src/app/[locale]/doctor/my-day/_components/current-patient-card.tsx:534, src/app/[locale]/doctor/my-day/_components/live-queue-card.tsx:84, src/app/api/crm/doctors/me/schedule/route.ts:126

СЦЕНАРИЙ

Врач промахивается в выпадающем меню и отменяет идущий приём пациента из живой очереди — пациент исчезает из всех списков, вернуть его врач не может.

ПОСЛЕДСТВИЯ

Потеря визита/черновика, нужна помощь ресепшена.

ЧТО СДЕЛАТЬ

Подтверждение для «Отменить приём» (особенно для IN_PROGRESS) и отображение отменённых walk-in с кнопкой возврата.

КРИТЕРИЙ ПРИЁМКИ

Отмена требует подтверждения; отменённый сегодня walk-in можно восстановить.

ДОКАЗАТЕЛЬСТВО В КОДЕ

onSelect={() => fire("CANCELLED")} без confirm, доступно и для IN_PROGRESS (TRANSITIONS IN_PROGRESS→CANCELLED разрешён). В живой очереди удаление с confirm есть. Walk-in исключены из расписания (NOT channel WALKIN), completedWalkins содержит только COMPLETED — у отменённого walk-in нет кнопки возврата в UI врача.

Аналитика врача принимает неограниченный диапазон дат

ГДЕ

src/app/api/crm/doctors/me/analytics/route.ts:48, src/app/api/crm/doctors/me/analytics/route.ts:86, src/app/api/crm/doctors/me/analytics/route.ts:164

СЦЕНАРИЙ

Врач в кастомном диапазоне ошибкой выбирает 0001-01-01 → 9999-12-31 — процесс Node создаёт миллионы объектов и подвисает для всей клиники.

ПОСЛЕДСТВИЯ

Потенциальное зависание сервера.

ЧТО СДЕЛАТЬ

Ограничить диапазон (например, 366 дней), не выбирать bodyMarkdown целиком.

КРИТЕРИЙ ПРИЁМКИ

Запрос с диапазоном больше лимита → 400.

ДОКАЗАТЕЛЬСТВО В КОДЕ

from/to — любые YYYY-MM-DD; dayCount = (toEnd-from)/день, по нему в цикле создаются бакеты; findMany заметок тянет bodyMarkdown всех подписанных за период.

Аналитика врача: плитки «Протокол применён» и «Проверено анализов» всегда 0

ГДЕ

src/app/api/crm/doctors/me/analytics/route.ts:153, src/app/api/crm/doctors/me/analytics/route.ts:216, src/app/api/crm/doctors/me/analytics/route.ts:134, src/app/[locale]/doctor/analytics/_components/analytics-dashboard.tsx:241, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:160, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:217

ТАКЖЕ НАШЛИ ЗОНЫ

Аналитика, выручка, оплаты, биллинг, экспорты

СЦЕНАРИЙ

Врач ежедневно применяет протоколы — плитка «Протокол применён 0 (0% от заключений)»; «Проверено анализов 0».

ПОСЛЕДСТВИЯ

Фейковые KPI в проде, ложные выводы о работе врача.

ЧТО СДЕЛАТЬ

Фиксировать применение протокола структурно (appliedProtocolId на VisitNote или событие) и считать по нему; плитку анализов убрать до интеграции.

КРИТЕРИЙ ПРИЁМКИ

После применения протокола и подписи счётчик растёт; мёртвых нулевых плиток нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

protocolApplied считает заметки, где bodyMarkdown содержит «Применён протокол» (216-222), но handleApplyProtocol нигде не пишет этот маркер — только дописывает conclusionTemplateMd протокола. labResultsReviewed считает LabResult (134-140), а LabResult создаётся только POST /doctors/me/labs, который UI не вызывает.

Декоративные элементы и заглушки, выглядящие рабочими

ГДЕ

src/app/[locale]/doctor/patients/_components/patients-header.tsx:69, src/app/[locale]/doctor/patients/_components/ai-assistant-panel.tsx:94, src/app/[locale]/doctor/patients/_components/ai-assistant-panel.tsx:84, src/app/[locale]/doctor/messages/_components/chat-panel.tsx:365, src/app/[locale]/doctor/visits/[patientId]/_components/patient-header-live.tsx:127, src/app/[locale]/doctor/visits/[patientId]/page.tsx:149

СЦЕНАРИЙ

Врач нажимает «Настроить вид» — ничего; диктует ресепшену «карта X7KQ2A» — у них такой карты нет.

ПОСЛЕДСТВИЯ

Ощущение недоделанного продукта, неверный номер карты.

ЧТО СДЕЛАТЬ

Убрать мёртвые кнопки или реализовать; показывать Р-номер через lib/patient-number; вывести сегменты из-под «в разработке» или убрать панель.

КРИТЕРИЙ ПРИЁМКИ

Нет кнопок без действия; № карты совпадает с CRM.

ДОКАЗАТЕЛЬСТВО В КОДЕ

«Настроить вид» — button без onClick; кнопка «Свернуть» AI-панели без onClick, а вся панель (с реальными сегментами) завернута в InDevelopment при AI_ENABLED=false и неинтерактивна; вкладка композера — button без действия; поле «Тип приёма» всегда `value=""`; «№ карты» = `patient.id.slice(-6).toUpperCase()` вместо patientNumber (P-00125), который используется в CRM/чеках.

ДС-18 РЗ · НИЗКИЙ переводы

Жёстко русская локаль и локальное время браузера в кабинете

ГДЕ

src/app/[locale]/doctor/_components/doctor-topbar.tsx:27, src/app/[locale]/doctor/visits/[patientId]/[visitId]/_components/print-visit-button.tsx:15, src/app/[locale]/doctor/visits/[patientId]/_components/visits-list.tsx:482, src/app/api/crm/doctors/me/today/route.ts:297, src/app/[locale]/doctor/schedule/_components/agenda-shell.tsx:205

СЦЕНАРИЙ

Узбекоязычный врач печатает заключение со страницы визита — получает русскую версию; вкладка «Весь день», открытая с вечера, утром подписывает вчерашний день «Сегодня».

ПОСЛЕДСТВИЯ

Непереведённые документы и неверные подписи дат.

ЧТО СДЕЛАТЬ

Брать язык из locale, форматировать с timeZone Asia/Tashkent, использовать useTashkentToday в agenda.

КРИТЕРИЙ ПРИЁМКИ

В uz-локали печать и даты на узбекском, «Сегодня» корректно после полуночи.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Топбар: RU_MONTHS/RU_WEEKDAYS и getHours() браузера; печать визита `?lang=ru` зашита, в меню visits-list печать без lang; today route подставляет «Приём»; agenda-shell `today = useMemo(startOfDay(new Date()), [])` — застывает после полуночи и берётся по TZ браузера (в отличие от useTashkentToday). Формат дат по всему кабинету — Intl ru-RU без timeZone, кроме live-queue-card.

ДС-19 РЗ · НИЗКИЙ мёртвая механика

Мёртвые doctor-API и хуки (анализы, входящие направления), один из них отдаёт шифротекст

ГДЕ

src/app/api/crm/doctors/me/labs/route.ts:44, src/app/api/crm/doctors/me/labs/[id]/route.ts:37, src/app/api/crm/doctors/me/labs/unread/route.ts:36, src/app/api/crm/doctors/me/patients/[patientId]/prescriptions/route.ts:97, src/app/[locale]/doctor/my-day/_hooks/use-doctor-referrals.ts:31, src/app/[locale]/doctor/reception/_components/referral-dialog.tsx:56

СЦЕНАРИЙ

При будущем подключении этих эндпоинтов врач увидит шифротекст в заметках назначений; входящие направления коллег никто не видит.

ПОСЛЕДСТВИЯ

Поддерживаемый, но неиспользуемый код создаёт ложное ощущение готовых функций.

ЧТО СДЕЛАТЬ

Удалить или подключить; в prescriptions route расшифровывать notes.

КРИТЕРИЙ ПРИЁМКИ

Нет неиспользуемых роутов/хуков, либо они подключены и покрыты тестом.

ДОКАЗАТЕЛЬСТВО В КОДЕ

UI не вызывает POST/PATCH /doctors/me/labs, /labs/unread, /patients/[id]/labs/prescriptions/documents (grep по src/app/[locale] и src/components). useIncomingReferrals и ReferralDialog нигде не смонтированы — направления нельзя ни создать, ни увидеть входящие. prescriptions route отдаёт Prescription.notes без расшифровки (шифруется в prescription/cipher-fields.ts).

DC-20 РЗ · НИЗКИЙ бар

На экране истории визитов видны только 5 аллергий, кнопка «Показать ещё» ничего не делает

ГДЕ

src/app/[locale]/doctor/visits/[patientId]/page.tsx:92, src/app/[locale]/doctor/visits/[patientId]/page.tsx:98, src/app/[locale]/doctor/visits/[patientId]/_components/patient-meta-row-live.tsx:53

СЦЕНАРИЙ

У пациента 6-я аллергия «карбамазепин» — на экране истории её нет, «Показать ещё» не раскрывает список.

ПОСЛЕДСТВИЯ

Риск назначить препарат, на который у пациента аллергия.

ЧТО СДЕЛАТЬ

Загружать все аллергии/хроники (или count + раскрытие) и повесить обработчик на кнопку.

КРИТЕРИЙ ПРИЁМКИ

Все аллергии пациента видны или раскрываются по кнопке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

patientAllergy.findMany и patientChronicCondition.findMany с `take: 5`; кнопка `{("meta.showMore")}` без onClick.

DC-21 РЗ · НИЗКИЙ мёртвая механика

Напоминания врача — сиротская функция: страница скрыта из меню, на «Мой день» не выводятся, в срок никто не уведомляет

ГДЕ

src/app/[locale]/doctor/_components/doctor-sidebar.tsx:57, src/app/api/crm/doctors/me/today/route.ts:4, src/app/api/crm/doctors/me/reminders/route.ts:9, src/app/[locale]/doctor/notifications/_hooks/use-doctor-reminders.ts:44

СЦЕНАРИЙ

Врач по прямой ссылке /doctor/notifications создаёт «Перезвонить пациенту в пятницу 10:00» — в пятницу ничего не происходит, в меню раздела нет.

ПОСЛЕДСТВИЯ

Задачи врача теряются.

ЧТО СДЕЛАТЬ

Выводить due-напоминания на «Мой день»/бейдж и вернуть пункт меню, либо воркер уведомлений; иначе удалить функцию.

КРИТЕРИЙ ПРИЁМКИ

Напоминание с remindAt<=now видно на «Мой день»; к списку есть путь из навигации.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий в сайдбаре: «Уведомления hidden — the «Мой день» today-tasks surface those items instead», но /today выбросил блок reminders (route.ts:4-13), my-day их не рендерит. Модель Reminder читается только двумя роутами reminders (grep prisma.reminder); воркера по remindAt нет; SNOOZED никогда не возвращается в PENDING.

DC-22 РЗ · НИЗКИЙ мёртвая механика

Подпись врача обещана «в PDF-печать заключений», но нигде не используется, превью сломано

ГДЕ

src/app/[locale]/doctor/settings/_components/signature-tab.tsx:149, src/messages/ru.json:7070, src/app/api/crm/visit-notes/[id]/print/route.ts:875, src/app/api/crm/sick-leaves/[id]/print/route.ts:260, src/app/api/crm/doctors/me/analytics/route.ts:23

СЦЕНАРИЙ

Врач загружает подпись, видит «Подпись сохранена» и битую картинку; печатает заключение — подписи нет.

ПОСЛЕДСТВИЯ

Вводящая в заблуждение настройка: врачи считают, что документы подписаны.

ЧТО СДЕЛАТЬ

Либо выводить подпись в печать заключения (через прокси или data:), хранить ключ и показывать превью через /api/crm/documents/file; либо скрыть вкладку. Ограничить формат png/jpeg на клиенте и сервере.

КРИТЕРИЙ ПРИЁМКИ

Загруженная подпись видна в настройках и на печатной форме заключения, либо вкладки нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Подзаголовок вкладки: «Подставляется в PDF-печать заключений». Печать заключения содержит только текстовые слоты «Врач: .../Пациент: ...» (print/route.ts:875-878), signatureUrl читают только sick-leaves и e-prescriptions print, а кнопки создания этих документов убраны (analytics/route.ts:23-28). signatureUrl — сырой MinIO URL из upload, `

DC-23 РЗ · НИЗКИЙ баг

Поиск в шапке находит всех пациентов клиники, но карточка открывается как «Пациент не найден»

ГДЕ

src/app/[locale]/doctor/_components/doctor-search.tsx:86, src/app/[locale]/doctor/_components/doctor-search.tsx:104, src/app/api/crm/doctors/me/patients/[patientId]/summary/route.ts:74, src/app/[locale]/doctor/patients/[id]/_components/patient-detail.tsx:1

СЦЕНАРИЙ

Врач ищет «Турматов» (записан к коллеге или только что создан ресепшеном), кликает результат — «Пациент не найден».

ПОСЛЕДСТВИЯ

Тупик в частом сценарии, непоследовательная модель доступа.

ЧТО СДЕЛАТЬ

Либо искать только по caseload (/doctors/me/patients?q=), либо разрешить read-only карточку пациента клиники и дать действие «Поставить в очередь».

КРИТЕРИЙ ПРИЁМКИ

Каждый результат поиска открывается, либо в поиске только пациенты врача.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поиск идёт в клиникный /api/crm/patients?q=...&limit=8 и ведёт на /doctor/patients/[id]; карточка грузит doctors/me/patients/[id]/summary, который отдаёт 404 при отсутствии записи к этому врачу (summary/route.ts:74-78) → patient-detail показывает detail.notFound. Заодно поиск раскрывает ФИО/телефоны вне caseload, хотя остальные doctor-роуты декларируют anti-leak.

DC-24 РЗ · НИЗКИЙ производительность

Статистика сайдбара перезапрашивается у каждого врача на любое событие клиники

ГДЕ

src/app/[locale]/doctor/_hooks/use-doctor-sidebar-stats.ts:39, src/app/api/crm/doctors/me/sidebar-stats/route.ts:73

СЦЕНАРИЙ

Ресепшен в час пик двигает очередь — у всех N врачей параллельно перезапрашивается sidebar-stats.

ПОСЛЕДСТВИЯ

Лишняя нагрузка на БД кратно числу врачей.

ЧТО СДЕЛАТЬ

Фильтровать события по doctorId как в useDoctorToday.

КРИТЕРИЙ ПРИЁМКИ

События чужого врача не вызывают рефетч sidebar-stats.

ДОКАЗАТЕЛЬСТВО В КОДЕ

useLiveQueryInvalidation по appointment.* и tg.message.new без shouldInvalidate (в отличие от useDoctorToday/useDoctorSchedule с eventTargetsDoctor). Каждый рефетч — 3 запроса, включая aggregate по conversation с вложенными OR-фильтрами.

Тип «Консультация/Повторный» в расписании считается по текущему числу визитов; SKIPPED показывается как «Уже был»

ГДЕ

src/app/api/crm/doctors/me/schedule/route.ts:97, src/app/api/crm/doctors/me/schedule/route.ts:151, src/lib/doctor-schedule-status.ts:29

СЦЕНАРИЙ

Первичный пациент после завершения визита в тот же день превращается в «Повторный», сводка дня пересчитывается задним числом; пропущенный пациент помечен «Уже был».

ПОСЛЕДСТВИЯ

Неверная статистика дня и статус.

ЧТО СДЕЛАТЬ

Тип считать на момент записи (или по MedicalCase), SKIPPED отображать отдельно.

КРИТЕРИЙ ПРИЁМКИ

Тип записи не меняется после завершения; SKIPPED имеет свою метку.

ДОКАЗАТЕЛЬСТВО В КОДЕ

appointmentTypeOf(patient.visitsCount) — visitsCount клиникный и пересчитывается при завершении визита (refreshPatientVisitStats). scheduleStatusOf: SKIPPED → "done" → UI «Уже был».

Три несовместимых «сегментации» пациента и сырые enum/только-русские подписи

ГДЕ

src/app/[locale]/doctor/patients/_components/patients-table.tsx:82, src/lib/doctor-patient-segments.ts:48, src/app/[locale]/doctor/patients/_components/selected-patient-card.tsx:238, src/app/api/crm/doctors/me/patient-segments/route.ts:93, src/app/[locale]/doctor/patients/_components/segmentation-card.tsx:216

СЦЕНАРИЙ

Пациент во вкладке «Вернулись» с бейджем «Давно не был»; в uz-интерфейсе донут по-русски, в карточке «Сегмент: DORMANT».

ПОСЛЕДСТВИЯ

Путаница в статусах, непереведённый интерфейс.

ЧТО СДЕЛАТЬ

Один классификатор для бейджа и вкладок; переводить сегменты через messages.

КРИТЕРИЙ ПРИЁМКИ

Бейдж строки совпадает с вкладкой; нет сырых enum и русских строк в uz.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Бейдж строки: >90 дней = «Давно не был» (deriveStatus), вкладка «Давно не были» = >180 дней (RETURNED_MAX_DAYS). Сегмент донута «active» подписан «На приёме» (последний визит ≤30 дн.), а статус строки «На приёме» = сейчас IN_PROGRESS. В карточке выводится сырой Patient.segment («ACTIVE», «NEW»); подписи донута приходят с сервера только на русском (DOCTOR_SEGMENT_LABELS_RU).

Q · Живая очередь, киоск, ТВ-табло, талоны

Q-01 P1 · ВЫСОКИЙ бар

Киоск не может отметить пришедшего по записи: ищет только уже WAITING/IN_PROGRESS, а CONFIRMED-записи и при прямом чекине не переводятся в WAITING — пациент получает второй визит в живой очереди

ГДЕ

src/app/api/kiosk/checkin/route.ts:69, src/app/api/c/[slug]/queue/checkin/route.ts:82, src/app/api/c/[slug]/queue/checkin/route.ts:96, src/app/kiosk/page.tsx:247, src/server/appointments/book.ts:352, src/app/kiosk/page.tsx:259, src/app/kiosk/page.tsx:335, src/server/appointments/walkin.ts:179, src/app/api/c/[slug]/queue/checkin/route.ts:97, src/app/api/c/[slug]/queue/checkin/route.ts:106, src/server/appointments/book.ts:351, src/server/workers/appointment-lifecycle-sweep.ts:49

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита, Мини-апп пациента и публичные страницы клиники

СЦЕНАРИЙ

Пациентка записана по телефону на 14:00 (CONFIRMED). В 13:50 вводит номер на киоске — киоск говорит «выберите врача», она выбирает своего невролога и получает живой талон C-012. Ресепшн видит её запись как «не пришла», в 15:00+ фоновый sweep ставит записи NO_SHOW и шлёт «вы пропустили приём», а в живой очереди она стоит отдельным визитом по цене консультации.

ПОСЛЕДСТВИЯ

Главный сценарий самообслуживания для записанных пациентов не работает; дубли визитов, ложные неявки и уведомления, искажение статистики и оплаты.

ЧТО СДЕЛАТЬ

В /api/kiosk/checkin искать на сегодня BOOKED/CONFIRMED/WAITING/IN_PROGRESS (и SKIPPED для возврата), на будущее — BOOKED/CONFIRMED. В /api/c/[slug]/queue/checkin переводить BOOKED/CONFIRMED/SKIPPED в WAITING через общий applyWaitingIntake (как queue-status), синхронно писать status и queueStatus.

КРИТЕРИЙ ПРИЁМКИ

Для CONFIRMED-записи на сегодня киоск показывает «Найдена запись», после «Получить талон» в БД status=queueStatus=WAITING, queuedAt заполнен, на ресепшене бейдж «Пришёл»; новый WALKIN не создаётся. Для записи на завтра показывается экран «У вас есть запись».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поиск записей для киоска: queueStatus: { in: ['WAITING','IN_PROGRESS'] } (при этом комментарий выше говорит 'skip CANCELLED/SKIPPED/COMPLETED'). Записи создаются с queueStatus BOOKED или CONFIRMED (book.ts:352; PHONE/KIOSK авто-подтверждаются), поэтому пришедший по записи пациент никогда не попадает ни в шаг 'checkin', ни в 'upcoming' (будущие записи тоже фильтруются по WAITING/IN_PROGRESS — экран «У вас есть запись на DD.MM» фактически недостижим). Киоск уводит его в 'select-doctor' и создаёт WALKIN через registerWalkin. Сам /queue/checkin: queueStatus: appt.queueStatus === 'BOOKED' ? 'WAITING' : appt.queueStatus и status только для BOOKED — CONFIRMED-запись получает queueOrder/ticketSeq и печатный талон, но остаётся CONFIRMED без queuedAt; SKIPPED тоже остаётся SKIPPED при выдаче «Вы в очереди!».

Q-02 P1 · ВЫСОКИЙ бар

Общее ТВ-табло /tv: зелёный экран вызова «Пройдите в кабинет» не исчезает, пока не придёт следующий вызов

ГДЕ

src/app/tv/page.tsx:47, src/app/tv/page.tsx:61, src/hooks/use-queue-board.ts:155

СЦЕНАРИЙ

Утром первый вызов: «Пройдите в кабинет 3, талон C-001». Табло в холле остаётся зелёным с этим текстом весь день до следующего вызова, список ожидающих не виден; пациенты думают, что вызывают C-001 до сих пор.

ПОСЛЕДСТВИЯ

Общее табло очереди неработоспособно: скрыт список очереди, показывается устаревший вызов, путаница в холле.

ЧТО СДЕЛАТЬ

Разделить побочные эффекты вызова и автоскрытие: таймер скрывает привязать только к call.seq (как в /tv/d через dismissedSeq), не очищать его при смене doctors; либо вычислять overlay из call+dismissedSeq без setState в эффекте с deps doctors.

КРИТЕРИЙ ПРИЁМКИ

Открыть /tv, вызвать пациента: через 15 секунд оверлей исчезает и виден список, в том числе при приходе обновлений борда во время показа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Эффект с deps [call, doctors]: при новом call ставит overlayTimer = setTimeout(setOverlay(null), 15000) и возвращает cleanup () => clearTimeout(overlayTimer.current). Тот же queue.called вызывает scheduleRefetch (use-queue-board.ts:155) → через 400 мс setBoard(new object) → doctors = board.doctors новая ссылка → React выполняет cleanup (таймер снят) и перезапускает эффект, который выходит на `call.seq === lastCallSeq.current` без нового таймера. overlay остаётся навсегда (fixed inset-0 z-50 закрывает весь борд). Персональное табло /tv/d этим не страдает (там dismissedSeq в отдельном эффекте).

Q-03 P1 · ВЫСОКИЙ целостность данных

Регистрация walk-in по телефону молча прикрепляет визит к другому пациенту с тем же номером (родственник), введённое ФИО и год рождения выбрасываются

ГДЕ

src/server/appointments/walkin.ts:105, src/server/appointments/walkin.ts:114, src/app/[locale]/doctor/my-day/_components/add-walkin-dialog.tsx:95, src/app/[locale]/crm/reception/_components/walkin-ticket-dialog.tsx:94, prisma/schema.prisma:1859

СЦЕНАРИЙ

Мать привела сына, врач в «Мой день» жмёт «Новый пациент», вводит «Каримов Тимур 2012» и телефон матери. Сервер находит карту матери и ставит в очередь её; врач открывает визит и пишет заключение, диагноз и назначения ребёнка в медкарту матери.

ПОСЛЕДСТВИЯ

Медицинские данные записываются в чужую медкарту (неверные диагнозы, назначения, лекарственные взаимодействия у другого человека), это риск для здоровья и юридический риск.

ЧТО СДЕЛАТЬ

При создании «нового пациента» с номером, который уже принадлежит другой карте, возвращать конфликт с найденным пациентом (ФИО, год рождения) и требовать явного выбора: «это он» / «другой человек — ввести другой телефон или оставить поле пустым». Пересмотреть уникальность phoneNormalized (разрешить несколько пациентов на один номер с пометкой «контактный телефон»). Обернуть find-or-create пациента в ту же транзакцию или обрабатывать P2002 повтором поиска.

КРИТЕРИЙ ПРИЁМКИ

Диалог врача/ресепшена с ФИО, отличным от владельца номера, показывает предупреждение и не создаёт визит без подтверждения; на киоске существующий владелец номера показывается как «Это вы? И.И.» с кнопкой «Нет»; двойное одновременное создание не даёт 500.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ветка { fullName, phone }: patient = prisma.patient.findFirst({ clinicId, phone IN variants }); если найден — используется он, fullName и распознанный год рождения (parsePatientIdentity) игнорируются без какой-либо проверки совпадения имени. Эта ветка используется киоском, формой «Новый пациент» в талоне ресепшена и диалогом «Новый пациент» врача. В модели Patient стоит @@unique([clinicId, phoneNormalized]) — два человека с одним номером невозможны, поэтому любой член семьи с общим телефоном попадает в чужую карту. Врачу в ответ показывается только тост «Добавлен, талон C-005» без имени. Дополнительно: создание пациента идёт вне сериализуемой транзакции очереди — два одновременных нажатия с новым номером дают P2002 и 500.

Q-04 P2 · СРЕДНИЙ безопасность

PATCH /queue-status: медсестра может менять статусы, врач — управлять очередью чужого врача, NO_SHOW ставится до времени визита

ГДЕ

src/app/api/crm/appointments/[id]/queue-status/route.ts:38, src/app/api/crm/appointments/[id]/queue-status/route.ts:51, src/app/api/crm/appointments/[id]/queue-status/route.ts:66, src/lib/appointments/lifecycle.ts:69, src/app/api/crm/appointments/[id]/queue-status/route.ts:68, src/lib/appointments/lifecycle.ts:127, src/lib/permissions/matrix.ts:113, src/app/api/crm/appointments/[id]/route.ts:147

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

Медсестра (по матрице прав только чтение) из devtools переводит записи в «Не пришёл» или «Пропущен». Врач А переводит пациентов врача Б в IN_PROGRESS/COMPLETED — на табло врача Б звучит вызов, пациенту уходит Telegram «Вас вызывают».

ПОСЛЕДСТВИЯ

Нарушение ролевой модели, возможность саботажа очереди коллег и ложных вызовов пациентов.

ЧТО СДЕЛАТЬ

В queue-status вызывать canMutateStatus(role) (403 для NURSE/CALL_OPERATOR), для DOCTOR проверять принадлежность записи, использовать canTransitionAt с датой визита и запускать тот же no-show триггер, что и generic PATCH.

КРИТЕРИЙ ПРИЁМКИ

PATCH от NURSE → 403; от врача по чужой записи → 403; NO_SHOW для записи через 2 часа → 409 too_early_for_no_show.

ДОКАЗАТЕЛЬСТВО В КОДЕ

roles: ['ADMIN','RECEPTIONIST','DOCTOR','NURSE']; комментарий утверждает, что NURSE 'already excluded by canMutateStatus', но canMutateStatus в роуте не вызывается (grep: используется только в UI). canRoleAdvanceTo для целей без владельцев (WAITING, SKIPPED, NO_SHOW, CONFIRMED) возвращает true для любой роли. Проверки 'врач — только свои записи' нет (в generic PATCH она есть: before.doctor.userId !== ctx.userId → 403). Переход проверяется canTransition без canTransitionAt, т.е. NO_SHOW доступен до начала слота, и fireTrigger для no-show здесь не вызывается.

Q-05 P2 · СРЕДНИЙ баг

«Пришёл»/«Вызвать» доступны для записей других дней: интейк без проверки «сегодня» тратит сегодняшний счётчик талонов на будущую запись

ГДЕ

src/app/api/crm/appointments/[id]/queue-status/route.ts:203, src/server/appointments/intake.ts:64, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:81, src/lib/appointments/lifecycle.ts:314

СЦЕНАРИЙ

Ресепшн просматривает завтрашний день и по ошибке жмёт «Пришёл». Запись завтра уже «пришла», ей выдан сегодняшний номер C-017; завтра счётчик талонов этого врача начнётся с C-018, а сама запись никогда не уйдёт в неявку.

ПОСЛЕДСТВИЯ

Испорченная нумерация, ложные «пришедшие», невидимые на завтрашнем табло/в очереди ошибки.

ЧТО СДЕЛАТЬ

В queue-status/generic PATCH/bulk-status запрещать переход в WAITING/IN_PROGRESS для записей не сегодняшнего ташкентского дня (как not_today в публичном чекине); в UI не показывать «Пришёл»/«Начать» для не сегодняшних дней.

КРИТЕРИЙ ПРИЁМКИ

PATCH queue-status WAITING для записи на завтра → 409 not_today; в панели завтрашнего дня нет кнопки «Пришёл».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ресепшн может выбрать другой день (DayPickerDropdown → useTodayAppointments(selectedDate)), панель очереди показывает для CONFIRMED-записей основную кнопку «Пришёл» (getQuickActions не проверяет дату). queue-status → applyWaitingIntake → allocateQueueOrder({ at: now }) выделяет номер из СЕГОДНЯШНЕГО счётчика, ставит queuedAt=now и WAITING записи на завтра. Публичный чекин имеет проверку not_today, CRM-пути — нет. Sweep WAITING не трогает, строка висит WAITING.

Q-06 P2 · СРЕДНИЙ мокап / заглушка

Выбор услуги на киоске — декорация: услуга и цена показываются, но на сервер не передаются

ГДЕ

src/app/kiosk/page.tsx:320, src/app/kiosk/page.tsx:338, src/app/kiosk/page.tsx:797, src/server/appointments/walkin.ts:224

СЦЕНАРИЙ

Пациент на киоске выбирает «ЭЭГ — 250 000 сум», подтверждает. В визите нет услуги, цена = консультация врача; на кассе и у врача услуга не видна, в талоне строка «Услуга» не печатается.

ПОСЛЕДСТВИЯ

Пациент видит одну цену, касса — другую; ресепшену приходится переспрашивать и вводить услугу вручную.

ЧТО СДЕЛАТЬ

Либо передавать выбранную услугу (serviceld, не название) в walk-in и сохранять её с ценой из ServiceOnDoctor, либо убрать шаг выбора услуги с киоска.

КРИТЕРИЙ ПРИЁМКИ

После выбора услуги на киоске в визите стоит primaryService и priceFinal этой услуги, в печатном талоне есть строка «Услуга».

ДОКАЗАТЕЛЬСТВО В КОДЕ

handleSelectService сохраняет selectedService (строка с названием) и показывает её с ценой на экране подтверждения; handleConfirm отправляет в /queue/walkin только { fullName, phone, doctorId, lang }. registerWalkin не принимает услугу: serviceld не ставится, priceBase/priceFinal = doctor.pricePerVisit.

Q-07 P2 · СРЕДНИЙ баг

Киоск загружает список врачей и длину очередей один раз при открытии страницы — «Перед вами N чел.» весь день устаревшее

ГДЕ

src/app/kiosk/page.tsx:187, src/app/kiosk/page.tsx:196, src/app/kiosk/page.tsx:805, src/app/api/c/[slug]/queue/doctors/route.ts:54

СЦЕНАРИЙ

Киоск включили в 8:00, очереди пустые. В 12:00 у невролога 15 человек, но киоск показывает «0 в очереди, перед вами 0 чел.», пациент выбирает этого врача, рассчитывая сразу зайти.

ПОСЛЕДСТВИЯ

Пациенты получают ложную информацию о загрузке врачей и распределяются неравномерно; жалобы на ожидание.

ЧТО СДЕЛАТЬ

Перезапрашивать борд при каждом входе на шаг выбора врача и/или подписаться на /queue/events (как ТВ); считать «перед вами» как waiting + (current ? 1 : 0).

КРИТЕРИЙ ПРИЁМКИ

Через час работы киоск показывает те же числа, что /tv; после нового walk-in с ресепшена счётчик на киоске растёт без перезагрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

useEffect с deps [slug] один раз забирает /queue/board и /api/kiosk/doctors; resetAll не перезагружает, SSE/поллинга нет. doctors[].waiting = d.waiting.length (без пациента на приёме), и именно это показывается как «Перед вами N чел.» и «N в очереди». Эндпоинт /queue/doctors, где правильно считается waiting+current, киоском не используется.

Q-08 P2 · СРЕДНИЙ баг

Киоск и табло берут «кто работает сегодня» только из дня недели: врач в отпуске или с истёкшим графиком получает walk-in, врач без графика невидим

ГДЕ

src/app/api/c/[slug]/queue/board/route.ts:36, src/server/appointments/walkin.ts:82, prisma/schema.prisma:1689

СЦЕНАРИЙ

Невролог в отпуске (оформлен DoctorTimeOff). Киоск продолжает предлагать его, пациент берёт талон и ждёт несколько часов. И наоборот, врач вышел в субботу вне графика — ресепшн ставит ему пациентов, а на табло его колонки нет.

ПОСЛЕДСТВИЯ

Пациенты стоят в очереди к отсутствующему врачу; табло не отражает реальную работу.

ЧТО СДЕЛАТЬ

Учитывать validFrom/validTo и DoctorTimeOff на текущий момент при построении списка; в registerWalkin для анонимного киоска отклонять врача вне смены; на табло добавлять врачей, у которых есть активные строки сегодня.

КРИТЕРИЙ ПРИЁМКИ

Врач с DoctorTimeOff на сегодня не отображается на киоске и /queue/walkin для него → 409; врач с сегодняшними WAITING без графика виден на /tv.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Фильтр врачей: schedules: { some: { weekday, isActive: true } } — validFrom/validTo графика и DoctorTimeOff (startAt/endAt) не учитываются. registerWalkin проверяет только doctor.isActive. Киоск берёт список врачей из этого же борда. Врач, у которого сегодня есть walk-in из CRM, но нет графика на этот день недели, отсутствует на /tv и киоске.

Q-09 P2 · СРЕДНИЙ UX

Киоск открывает каждый талон в новой вкладке, которая остаётся на экране: следующий посетитель видит талон предыдущего

ГДЕ

src/app/kiosk/page.tsx:303, src/app/kiosk/page.tsx:351, src/app/ticket/[id]/_components/auto-print.tsx:11

СЦЕНАРИЙ

Пациент получил талон и ушёл. На экране киоска остаётся открытая вкладка его талона (инициалы, врач, услуга, QR на страницу статуса). Следующий человек видит чужой талон и не видит стартовый экран; к вечеру в браузере киоска сотни вкладок.

ПОСЛЕДСТВИЯ

Киоск перестаёт работать без вмешательства персонала, раскрытие данных предыдущего пациента, утечка памяти браузера.

ЧТО СДЕЛАТЬ

Печатать талон в скрытом iframe на той же странице или закрывать окно по событию afterprint; не менять фокус киоска.

КРИТЕРИЙ ПРИЁМКИ

После выдачи талона киоск остаётся на своём экране и через 30 секунд возвращается к приветствию; новых вкладок не создаётся.

ДОКАЗАТЕЛЬСТВО В КОДЕ

После чекина/записи setTimeout(() => window.open(`/ticket/\${id}`, '_blank'), 500). AutoPrint только вызывает window.print(); window.close()/afterprint нет, у страницы талона нет возврата на киоск. Сброс киоска через 30 с происходит в фоновой вкладке.

Q-10 P2 · СРЕДНИЙ баг

На ТВ при вызове озвучивается и показывается имя не того пациента (предыдущего) или никакое, хотя сервер присылает инициалы вызванного

ГДЕ

src/app/tv/page.tsx:51, src/app/tv/page.tsx:59, src/app/tv/d/[token]/page.tsx:124, src/hooks/use-queue-board.ts:145, src/hooks/use-doctor-board.ts:149, src/server/realtime/board-stream.ts:55

СЦЕНАРИЙ

У врача на приёме Иванов И. Ресепшн жмёт «Вызвать из очереди» → подтверждает завершение → стартует Петрова. Табло в холле голосом: «Иванов И., пройдите в кабинет 3», на экране «Иванов И. · Талон C-007». Иванов (уже вышедший) возвращается, Петрова не понимает, что зовут её. Для записи без талона озвучивается «Следующий пациент».

ПОСЛЕДСТВИЯ

Путаница при вызове, пациенты пропускают свою очередь или заходят не в свой черёд.

ЧТО СДЕЛАТЬ

Сохранять patientName из payload queue.called в QueueCall/DoctorCall и использовать его для оверлея и озвучки; снимок борда использовать только как запасной вариант.

КРИТЕРИЙ ПРИЁМКИ

При «завершить + вызвать следующего» с обоих рабочих мест табло /tv и /tv/d озвучивают и показывают инициалы именно вызванного пациента.

ДОКАЗАТЕЛЬСТВО В КОДЕ

queue.called несёт patientName (initials) — он в белом списке SAFE_PAYLOAD_KEYS, эмиттеры его заполняют (queue-status/route.ts:290, [id]/route.ts ~447). Но QueueCall/DoctorCall в хуках его не сохраняют, а страницы берут имя из снимка борда на момент события: /tv — doc?.current?.fullName (оверлей ставится один раз и не обновляется), /tv/d — announce(data?.queue.current?.fullName). Снимок обновляется только через 400 мс debounce. Ресепшн «Вызвать из очереди» (doctor-queue-card.tsx:146,160) и врачебный «переключить пациента» (use-appointment-status-mutation.ts:119) сначала завершают текущий визит и через миллисекунды стартуют следующий — в снимке current ещё предыдущий пациент.

Q-11 P2 · СРЕДНИЙ переводы

Печатный талон показывает время в UTC (на 5 часов раньше) и зашитые «NEUROFAX-B», «Неврологический центр» и телефон вместо данных клиники

ГДЕ

src/app/ticket/[id]/page.tsx:69, src/app/ticket/[id]/page.tsx:70, src/app/ticket/[id]/page.tsx:120, src/app/ticket/[id]/page.tsx:192, src/app/ticket/[id]/page.tsx:156, src/app/[locale]/crm/reception/_components/walkin-ticket-dialog.tsx:182, Dockerfile:43, src/app/ticket/[id]/page.tsx:121, src/lib/constants.ts:17

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита, Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Пациент встал в очередь в 09:15, на бумажном талоне «Дата: 23.09.2026 04:15». Любая другая клиника на платформе печатает талоны с брендом NEUROFAX-B и чужим телефоном.

ПОСЛЕДСТВИЯ

Неверные данные на каждом бумажном талоне; мультиклиничность печати сломана.

ЧТО СДЕЛАТЬ

Форматировать с timeZone: 'Asia/Tashkent' (или tashkentComponents), название/телефон/адрес брать из Clinic записи.

КРИТЕРИЙ ПРИЁМКИ

Талон walk-in, выданный в 09:15 по Ташкенту, печатает 09:15; название и телефон совпадают с настройками клиники.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Серверный компонент: dateStr = appointment.date.toLocaleDateString('ru-RU'), timeStr = toLocaleTimeString('ru-RU', ...) без timeZone; контейнер без TZ (Dockerfile/docker-compose не задают) → UTC. timeStr печатается в строке «Дата:» каждого талона и как запасной заголовок. Шапка и подвал захардкожены: 'NEUROFAX-B', 'Неврологический центр', '+998 71 200 00 07 | neurofax.uz' (номер не совпадает с clinic.phone в сидах), хотя clinicId в записи есть.

Q-12 P2 · СРЕДНИЙ бар

Префикс талона всегда «С» у всех врачей: номера С-001, С-002... одновременно выдаются каждому врачу и совпадают

ГДЕ

src/server/services/ticket-number.ts:15, prisma/schema.prisma:834, src/server/appointments/queue-order.ts:50, src/app/api/crm/doctors/me/today/route.ts:311, src/app/api/crm/doctors/me/today/route.ts:356, src/server/appointments/queue-order.ts:48

ТАКЖЕ НАШЛИ ЗОНЫ

Остальной кабинет врача, Управление врачами (CRM)

СЦЕНАРИЙ

У двух неврологов одновременно в очереди по талону С-005. Общее табло объявляет «Талон С-005, пройдите в кабинет 3» — встают оба пациента; на ресепшене «у кого С-005?» неоднозначно.

ПОСЛЕДСТВИЯ

Неуникальные номера талонов в пределах клиники, путаница при вызове и поиске пациента по талону.

ЧТО СДЕЛАТЬ

Хранить у врача явный буквенный префикс талона (поле в Doctor, уникальное в клинике, настраивается в админке) или выводить префикс из номера кабинета; ticketNumberFor должен брать его, а не первую букву cuid.

КРИТЕРИЙ ПРИЁМКИ

У двух врачей талоны начинаются с разных префиксов; на табло и в печати номера различимы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ticketNumberFor: prefix = doctorId.charAt(0).toUpperCase(). Doctor.id = @default(cuid()); cuid v1 всегда начинается с 'c', поэтому префикс у всех врачей 'C' (комментарии в коде сами приводят 'C-003', 'C-001 и C-002', 'C-017'). Счётчик allocateQueueOrder ведётся отдельно по doctorId, т.е. у каждого врача свой C-001. Документированный замысел — «А-001, В-042» (разные буквы по врачам).

Q-13 P2 · СРЕДНИЙ бар

Проверка «один пациент на приёме» — чтение без блокировки и без границы дня: гонка даёт два IN_PROGRESS, а незакрытый вчерашний визит блокирует врача

ГДЕ

src/server/appointments/active-visit.ts:17, src/app/api/crm/appointments/[id]/queue-status/route.ts:113, src/server/appointments/queue-projection.ts:124, src/app/[locale]/doctor/my-day/_components/schedule-card.tsx:364, src/app/api/crm/appointments/[id]/route.ts:365, src/server/workers/appointment-lifecycle-sweep.ts:49, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:76, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:117

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита, Остальной кабинет врача

СЦЕНАРИЙ

Ресепшн и врач одновременно запускают разных пациентов одного врача — оба в IN_PROGRESS. Или врач вчера не закрыл визит: сегодня «Вызвать» даёт «уже идёт приём: <вчерашний пациент>», при этом «Мой день» и табло показывают, что приёма нет.

ПОСЛЕДСТВИЯ

Нарушение инварианта очереди, путаница на табло, лишние действия врача утром.

ЧТО СДЕЛАТЬ

Проверять и обновлять в одной Serializable-транзакции (или частичный уникальный индекс на doctorId WHERE status='IN_PROGRESS'); незакрытые IN_PROGRESS прошлых дней закрывать/помечать ночной задачей и явно показывать врачу.

КРИТЕРИЙ ПРИЁМКИ

Параллельный запуск двух пациентов одного врача даёт один успех и один 409; вчерашний IN_PROGRESS виден врачу как «незакрытый визит» и не блокирует молча.

ДОКАЗАТЕЛЬСТВО В КОДЕ

findOtherActiveVisit — findFirst по status IN_PROGRESS без фильтра по дате, выполняется отдельно от последующего update (не в транзакции, без Serializable/unique-индекса). Проекция очереди (табло) берёт только сегодняшние строки и current = own.find(...) — при двух IN_PROGRESS показывает произвольного.

Q-14 P2 · СРЕДНИЙ целостность данных

Фоновый sweep ставит NO_SHOW только в status (queueStatus не трогает) и «прогульщиками» делает пропущенных walk-in по техническому endDate

ГДЕ

src/server/workers/appointment-lifecycle-sweep.ts:49, src/server/workers/appointment-lifecycle-sweep.ts:93, src/server/workers/appointment-lifecycle-sweep.ts:128, src/server/appointments/walkin.ts:151, src/lib/queue-ordering.ts:107, src/server/workers/appointment-lifecycle-sweep.ts:121, src/server/workers/appointment-lifecycle-sweep.ts:126, src/app/api/crm/appointments/bulk-status/route.ts:91, src/app/api/c/[slug]/queue/lookup/route.ts:57, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:208

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Пациент живой очереди пришёл в 9:00, в 10:50 его вызвали, он был в туалете — ресепшн нажал «Пропустить». В 10:55 sweep переводит его в NO_SHOW и отправляет в Telegram «Вы пропустили приём», хотя он стоит у стойки. Параллельно утренние записи, не отмеченные вовремя, у врача исчезают как неявки, а на ресепшене висят как «Подтверждена».

ПОСЛЕДСТВИЯ

Ложные уведомления пациентам, расхождение двух статусных колонок между врачом и ресепшеном, искажение метрик неявок, «воскрешение» закрытых визитов.

ЧТО СДЕЛАТЬ

Sweep должен писать status и queueStatus вместе (и cancelled/audit через общий хелпер), и исключать channel = WALKIN (у живой очереди нет времени — таймаут SKIPPED считать от calledAt/updatedAt, если он вообще нужен). Queue-status роут должен проверять переход и по status, отказывая, если status терминальный.

КРИТЕРИЙ ПРИЁМКИ

После тика sweep у авто-неявки status=queueStatus=NO_SHOW, на ресепшене она в «неявках»; SKIPPED walk-in с датой регистрации 2 часа назад не меняется sweep'ом и не получает no-show уведомление.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Sweep выбирает status IN [BOOKED, CONFIRMED, SKIPPED] и endDate < now-60мин и пишет data: { status: 'NO_SHOW' } — queueStatus остаётся BOOKED/CONFIRMED/SKIPPED (completion.ts прямо описывает, что ресепшн читает queueStatus). Ресепшн раскладывает полосы по queueStatus ?? status (queue-ordering.ts:107-109), поэтому авто-неявка остаётся в «Записях» как «Подтверждена» с кнопкой «Пришёл»; queue-status роут берёт from = queueStatus и разрешает BOOKED/SKIPPED→WAITING, молча воскрешая NO_SHOW. Для walk-in endDate = момент регистрации + 30 мин (walkin.ts:151, окно по миграции 20260627 чисто техническое), значит walk-in, ждавший > 1,5 ч и получивший SKIPPED при вызове, на ближайшем тике (раз в 10 мин) становится NO_SHOW, и fireTrigger('appointment.no-show') шлёт ему «вы не пришли».

Q-15 P3 · НИЗКИЙ баг

Generic PATCH /appointments/[id] принимает queueStatus в обход машины состояний и ролей; интейк в WAITING без Serializable даёт дубли номеров талонов

ГДЕ

src/server/schemas/appointment.ts:69, src/app/api/crm/appointments/[id]/route.ts:496, src/app/api/crm/appointments/[id]/route.ts:590, src/app/api/crm/appointments/[id]/route.ts:735

СЦЕНАРИЙ

Одновременно киоск выдаёт walk-in талон и в карточке визита/у врача запись переводится в «Пришёл» через generic PATCH — оба получают C-014. Врач вызывает «C-014», встают двое. Или скрипт/устаревшая вкладка ставит queueStatus IN_PROGRESS второму пациенту врача — на ТВ «на приёме» случайный из двух.

ПОСЛЕДСТВИЯ

Дубли печатных номеров, обход инварианта «один на приёме», расхождение status/queueStatus.

ЧТО СДЕЛАТЬ

Убрать queueStatus из UpdateAppointmentSchema (писать только производно от status) либо валидировать его теми же проверками; интейк в WAITING выполнять через runQueueTx (Serializable) везде.

КРИТЕРИЙ ПРИЁМКИ

PATCH { queueStatus: 'IN_PROGRESS' } → 400/409; параллельный тест (киоск + PATCH status WAITING) не даёт

одинаковых ticketSeq у одного врача за день.

ДОКАЗАТЕЛЬСТВО В КОДЕ

UpdateAppointmentSchema содержит queueStatus: AppointmentStatusEnum.optional(). Проверки canTransitionAt, canRoleAdvanceTo и findOtherActiveVisit выполняются только `if (body.status !== undefined)`; data = { ...body } пишет queueStatus как есть. Поэтому { queueStatus: 'IN_PROGRESS' } или { queueStatus: 'WAITING' } с CANCELLED/COMPLETED проходит без проверок и рассинхронизирует колонки. applyWaitingIntake в этом роуте выполняется в обычной prisma.\$transaction (комментарий: 'existing default isolation is preserved'), тогда как allocateQueueOrder рассчитан на Serializable (queue-order.ts:4-10) — параллельная выдача с киоском/ресепшеном читает тот же max и выдаёт одинаковый ticketSeq.

Q-16 РЗ · НИЗКИЙ баг

bulk-status: NO_SHOW-уведомления уходят по всем присланным id (включая чужие/ненайденные), массовая отмена обходит ядро отмены, массовый старт — правило «один на приёме»

ГДЕ

src/app/api/crm/appointments/bulk-status/route.ts:52, src/app/api/crm/appointments/bulk-status/route.ts:92, src/app/api/crm/appointments/bulk-status/route.ts:195, src/app/api/crm/appointments/bulk-status/route.ts:34

СЦЕНАРИЙ

Сотрудник одной клиники присылает bulk NO_SHOW с id записей другой клиники — их пациентам уходит «Вы пропустили приём», хотя записи не изменены. Массовая отмена через API оставляет пациентам напоминания «ждём вас завтра».

ПОСЛЕДСТВИЯ

Ложные сообщения пациентам (в т.ч. межклинические), некорректные напоминания, обход инвариантов очереди.

ЧТО СДЕЛАТЬ

Возвращать 404/422, если existing.length !== ids.length; триггеры слать только по реально изменённым строкам; CANCELLED направлять через cancelAppointment; IN_PROGRESS/COMPLETED в bulk запретить либо проверять одного активного на врача и вызывать общий хелпер завершения.

КРИТЕРИЙ ПРИЁМКИ

bulk NO_SHOW с чужим id → 422 и ноль NotificationSend; bulk CANCELLED переводит напоминания в CANCELLED; bulk IN_PROGRESS двух записей одного врача → 409.

ДОКАЗАТЕЛЬСТВО В КОДЕ

existing = findMany (tenant-scoped), но несоответствие длины body.ids не проверяется; for (const id of body.ids) fireTrigger({ kind: 'appointment.no-show' }) — materializeForAppointment грузит запись в SYSTEM-контексте по id без clinicId, т.е. сообщение 'вы не пришли' материализуется и для id, которые не обновились (другая клиника, опечатка). CANCELLED идёт через updateMany без cancelAppointment: не гасятся QUEUED-напоминания, нет cancelledBy, нет уведомления об отмене. IN_PROGRESS/COMPLETED разрешены ресепшену (STATE_OWNERS включает RECEPTIONIST, хотя комментарий строк 34-37 утверждает обратное), без findOtherActiveVisit, без queue.called и без эффектов завершения.

Q-17 РЗ · НИЗКИЙ UX

«Убрать из очереди» у врача — это обычная отмена: walk-in пациенту уходит уведомление «запись отменена», хотя при постановке в очередь он ничего не получал

ГДЕ

src/app/[locale]/doctor/my-day/_components/live-queue-card.tsx:89, src/app/api/crm/appointments/[id]/route.ts:866, src/server/notifications/triggers.ts:791

СЦЕНАРИЙ

Врач убирает ошибочно добавленную строку пациента, который реально стоит в очереди (или стоял дубль). Пациенту в Telegram приходит «Ваша запись отменена», он уходит домой.

ПОСЛЕДСТВИЯ

Ложное сообщение пациенту, риск потери пациента.

ЧТО СДЕЛАТЬ

Для WALKIN при удалении из очереди не слать шаблон отмены (или отдельный шаблон/без уведомления), указывать cancelledBy='staff' и причину; рассмотреть отдельный статус «удалён как ошибочный».

КРИТЕРИЙ ПРИЁМКИ

Удаление walk-in из очереди врачом не создаёт NotificationSend с шаблоном отмены.

ДОКАЗАТЕЛЬСТВО В КОДЕ

removeFromQueue → PATCH { status: 'CANCELLED' } → fireTrigger({ kind: 'appointment.cancelled' }) → onAppointmentCancelled(generic) → materializeForAppointment без учёта channel=WALKIN. registerWalkin при создании никаких триггеров не шлёт. Кнопка задумана для удаления ошибочно добавленной строки/дубля.

Q-18 РЗ · НИЗКИЙ переводы

Вызов из кабинета врача шлёт Telegram «Вас вызывают» всегда по-русски, игнорируя язык пациента (у ресепшена — правильно)

ГДЕ

src/app/api/crm/appointments/[id]/route.ts:468, src/server/telegram/call-notice.ts:46

СЦЕНАРИЙ

Пациенту с языком UZ, вызванному врачом из «Мой день», приходит сообщение на русском; вызванному ресепшеном — на узбекском.

ПОСЛЕДСТВИЯ

Непоследовательная локализация, хуже понятность для узбекоязычных пациентов.

ЧТО СДЕЛАТЬ

Заменить ручной sendMessage в ветке call на sendCallNotice с lang = patient.preferredLang.

КРИТЕРИЙ ПРИЁМКИ

Вызов врачом пациента с preferredLang=UZ отправляет «Sizni chaqirishmoqda!».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ветка ?call=true собирает текст вручную: `<b>Вас вызывают!</b>...Врач: ...` и не выбирает patient.preferredLang. queue-status использует sendCallNotice с COPY.UZ. Модуль call-notice прямо заявляет, что существует, чтобы два пути 'can never drift apart', но врачебный путь его не использует.

Q-19 РЗ · НИЗКИЙ UX

Диалог талона на ресепшене теряет пол и источник нового пациента и показывает «Талон выдан» при повторном нажатии

ГДЕ

src/app/[locale]/crm/reception/_components/walkin-ticket-dialog.tsx:99, src/app/[locale]/crm/reception/_components/walkin-ticket-dialog.tsx:125, src/components/appointments/new-appointment-dialog/patient-picker.tsx:261, src/app/[locale]/crm/reception/_components/walkin-ticket-dialog.tsx:118, src/app/api/crm/appointments/walkin/route.ts:100

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

Ресепшн заполняет пол и источник «Instagram» — в карте пациента их нет, аналитика источников теряет данные. При повторном клике ресепшн видит «Талон C-009 выдан» и печатает второй экземпляр, думая, что это новый талон.

ПОСЛЕДСТВИЯ

Потеря введённых данных, неверная маркетинговая статистика, путаница с талонами.

ЧТО СДЕЛАТЬ

Принимать gender/source в /api/crm/appointments/walkin и сохранять при создании; при duplicate показывать «Пациент уже в очереди, талон ...».

КРИТЕРИЙ ПРИЁМКИ

Новый пациент из диалога талона создаётся с указанными полом и источником; повторное нажатие показывает информационное сообщение о существующем талоне.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PatientPicker в режиме нового пациента рендерит поля «Пол» и «Источник», но body = { doctorId, newPatient: { fullName, phone } } — gender и source отбрасываются (схема роута их и не принимает). Флаг duplicate из ответа игнорируется: toast.success(toastIssued) в любом случае (врачебный диалог duplicate обрабатывает).

Киоск смешивает клиники: поиск пациента и услуги идут в клинику по умолчанию, а запись/чекин — в клинику из ?с=

ГДЕ

src/app/kiosk/page.tsx:172, src/app/kiosk/page.tsx:238, src/lib/public-clinic.ts:27, src/hooks/use-public-clinic-slug.ts:12

СЦЕНАРИЙ

Вторая клиника/филиал ставит киоск /kiosk?с=clinic2. Посетитель вводит номер — киоск показывает ФИО и записи пациента из клиники neurofax, услуги и цены тоже из neurofax, а чекин по найденной записи падает 404 (запись другой клиники).

ПОСЛЕДСТВИЯ

Межклиническая утечка ПДн и неработающий киоск для любой клиники, кроме дефолтной (сейчас латентно, при подключении второго тенанта — сразу).

ЧТО СДЕЛАТЬ

Передавать slug во все запросы киоска (?с=\${slug}) или перевести /api/kiosk/* на путь /api/c/[slug]/kiosk/*; убрать молчаливый фолбэк на DEFAULT_CLINIC_SLUG для запросов с данными пациентов.

КРИТЕРИЙ ПРИЁМКИ

/kiosk?с=clinic2 ищет пациентов, услуги и создаёт визиты только в clinic2; без с= и без токена киоска запросы с ПДн отклоняются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

slug берётся из ?с= (usePublicClinicSlug) и используется для /api/c/\${slug}/queue/board|walkin|checkin, но fetch('/api/kiosk/doctors') и fetch('/api/kiosk/checkin?phone=...') идут без с=, а resolvePublicClinic для /api/kiosk/* берёт ?с ?? ?clinicSlug ?? DEFAULT_CLINIC_SLUG.

Короткий код талона (ticketCode) и QR «для сканирования на ресепшене» ни к чему не подключены в CRM

ГДЕ

src/app/t/[code]/page.tsx:30, src/app/c/[slug]/my/_components/ticket-sheet.tsx:9, src/app/api/crm/appointments/route.ts:43, src/app/ticket/[id]/page.tsx:64

СЦЕНАРИЙ

Пациент показывает на ресепшене QR/код из Telegram. Ресепшн сканирует — открывается страница статуса для пациента; ввод кода в поиск записей ничего не находит; отметить приход по коду нельзя.

ПОСЛЕДСТВИЯ

Функция выглядит готовой, но не работает: ресепшн тратит время, ищет вручную.

ЧТО СДЕЛАТЬ

Добавить поиск по ticketCode в CRM и/или страницу /crm/checkin/<code> для персонала (отметка «Пришёл» по QR); печатать ticketCode на бумажном талоне.

КРИТЕРИЙ ПРИЁМКИ

Ввод кода из мини-аппа в поиск CRM находит запись; сканирование QR авторизованным сотрудником ведёт к карточке с кнопкой «Пришёл».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Мини-апп показывает QR /t/<ticketCode> и код 'для ручного ввода' с комментарием 'the QR the reception desk scans'. /t/[code] лишь редиректит на публичную /q/<id> (страница пациента), никакого чекина. Поиск в /api/crm/appointments (q) ищет по ФИО/телефону/врачу, но не по ticketCode; других потребителей ticketCode в CRM нет. Печатный талон киоска кодирует /q/<id>, ticketCode на бумаге не печатается, хотя walkin.ts минтит его 'so the paper slip carries a QR/lookup code'.

Панель очереди ресепшена «залипает» в порядке после перетаскивания: срочность, вызовы и чужие изменения не отображаются до перезагрузки

ГДЕ

src/app/[locale]/crm/reception/_components/doctor-queue-panel.tsx:148, src/app/[locale]/crm/reception/_components/doctor-queue-panel.tsx:157, src/app/[locale]/crm/reception/_components/doctor-queue-panel.tsx:161, src/app/api/crm/appointments/reorder/route.ts:89, src/app/[locale]/crm/appointments/_hooks/use-appointment.ts:468, src/app/[locale]/crm/reception/_components/doctor-queue-panel.tsx:149

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

Ресепшн перетаскила пациента, через минуту врач вызвал первого. Дальше весь день панель показывает порядок на момент перетаскивания: нажатие «Срочно» ничего не меняет на экране, хотя на ТВ пациент уже первый; перестановки со второго рабочего места не видны.

ПОСЛЕДСТВИЯ

Ресепшн видит порядок очереди, отличный от реального (ТВ, врач), и объявляет пациентам неверную позицию.

ЧТО СДЕЛАТЬ

Сбрасывать pendingOrder в onSettled мутации reorder (после инвалидации) или при любом изменении набора id/queuePriority; не держать локальный override дольше одного round-trip.

КРИТЕРИЙ ПРИЁМКИ

После перетаскивания и последующего вызова/нового walk-in/«Срочно» панель показывает тот же порядок, что /tv и кабинет врача.

ДОКАЗАТЕЛЬСТВО В КОДЕ

pendingOrder сбрасывается только если серверный live совпал с ним поэлементно и по длине (строки 150-159). visibleLive строится из pendingOrder, новые строки докидываются вниз (170). Любое изменение состава (вызвали голову очереди → длина меньше; пришёл новый walk-in → длина больше) или недостижимый порядок из-за queuePriority делают совпадение невозможным, и override живёт до размонтирования. Кнопка «В начало очереди» меняет queuePriority, но строка не двигается, т.к. порядок берётся из pendingOrder.

Перетаскивание в живой очереди переписывает queuedAt — «ждёт N мин» у врача и время ожидания становятся ложными; exact=false игнорируется

ГДЕ

src/app/api/crm/appointments/reorder/route.ts:82, src/app/api/crm/appointments/reorder/route.ts:94, src/app/api/crm/doctors/me/today/route.ts:330, src/app/[locale]/doctor/my-day/_components/live-queue-card.tsx:144

СЦЕНАРИЙ

Пациент пришёл в 11:40, ресепшн перетаскивает его на первое место (он пришёл по экстренному направлению). У врача в «Живой очереди» он теперь «ждёт 2 ч 40 мин» (штамп 9:00:00 от первого в списке), а реально ждавшие 2 часа показываются как пришедшие на секунды позже.

ПОСЛЕДСТВИЯ

Врач и ресепшн видят неверное время ожидания, решения «кого брать» принимаются по ложным данным; потерян факт времени прихода.

ЧТО СДЕЛАТЬ

Хранить время прихода отдельно от ключа сортировки: добавить отдельное поле порядка (например queueRank) или использовать queuePriority/ручной порядок, а queuedAt не трогать; при конфликте с приоритетом явно сообщать ресепшену.

КРИТЕРИЙ ПРИЁМКИ

После перетаскивания метка «ждёт N мин» у каждого пациента совпадает с реальным временем прихода; порядок на табло совпадает с перетасканным.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Reorder ставит queuedAt = base + idx*1000, где base = min(queuedAt) всего набора. Тот же queuedAt — источник метки «ждёт с .../ждёт N мин» (today/route.ts:330, live-queue-card.tsx:144-162) и единственный штамп прихода. Фильтра по статусу/дате у reorder нет (любые id врача). Если в наборе есть queuePriority>0, requested order

недостижим, сервер возвращает `exact=false`, клиент (`useReorderQueue`) это поле не читает; по ТЗ (TZ-two-lanes §2.1) ответ должен быть всегда `exact=true`.

Q-24 РЗ · НИЗКИЙ UX

Страница статуса талона `/q/[id]` пустая для пропущенных, отменённых и неявок — пациент продолжает ждать

ГДЕ

`src/app/q/[id]/page.tsx:158`, `src/app/q/[id]/page.tsx:163`, `src/app/api/queue/status/[id]/route.ts:65`

СЦЕНАРИЙ

Пациента вызвали, он отошёл — ресепшн нажал «Пропустить». Он смотрит в телефоне страницу по QR: талон С-008, никаких сообщений — и продолжает сидеть, хотя его уже пропустили. То же, если врач убрал его из очереди (отмена).

ПОСЛЕДСТВИЯ

Пациенты не узнают, что пропустили вызов или сняты с очереди; лишние конфликты у стойки.

ЧТО СДЕЛАТЬ

Добавить состояния `SKIPPED` («Вы пропустили вызов, подойдите на ресепшн»), `CANCELLED` и `NO_SHOW` с понятным текстом (`ru/uz`).

КРИТЕРИЙ ПРИЁМКИ

Для записи в `SKIPPED/CANCELLED/NO_SHOW` страница `/q` показывает соответствующее сообщение, а не пустую карточку.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ветки отображения: `isInProgress`, `isArrivedBooking` (только `schedule lane` и `WAITING/BOOKED/CONFIRMED`), `isWaiting` (`WAITING live`), `isCompleted`. Для `SKIPPED/CANCELLED/NO_SHOW` ни одна не срабатывает: остаётся синяя «активная» карточка с номером талона и пустым блоком статуса. API для `live`-строки не в `WAITING/IN_PROGRESS` возвращает `position 0`.

Q-25 РЗ · НИЗКИЙ UX

Часы в шапке киоска не идут — на экране приветствия время замирает на момент последнего действия

ГДЕ

`src/app/kiosk/page.tsx:367`, `src/app/kiosk/page.tsx:406`

СЦЕНАРИЙ

Киоск простоял час на приветствии — показывает 09:12 при реальном 10:15.

ПОСЛЕДСТВИЯ

Неверное время на публичном экране, подрывает доверие к системе.

ЧТО СДЕЛАТЬ

Добавить `setInterval`, обновляющий время раз в 30–60 секунд, и форматировать с `timeZone 'Asia/Tashkent'`.

КРИТЕРИЙ ПРИЁМКИ

Через несколько минут простоя время на киоске совпадает с реальным.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`const now = new Date()` вычисляется при рендере; интервала обновления нет (в отличие от `/tv`, где `setInterval 1 c`). На шаге `welcome` состояние не меняется, перерисовок нет.

АР · Записи, календарь, ресепшн, слоты, цены визита

АР-01 Р1 · ВЫСОКИЙ баг

Выходной день врача доступен для записи: без строк расписания на день недели подставляется 09:00–19:00

ГДЕ

src/server/services/appointments.ts:148, src/server/services/appointments.ts:207, src/app/api/miniapp/slots/route.ts:47, src/server/doctors/update-schedule.ts:79, src/app/[locale]/crm/doctors/[id]/_components/schedule-editor.tsx:191, src/server/actions/detectors/low-doctor-schedule.ts:4, src/app/api/c/[slug]/queue/board/route.ts:40

ТАКЖЕ НАШЛИ ЗОНЫ

Мини-апп пациента и публичные страницы клиники, Управление врачами (CRM)

СЦЕНАРИЙ

Невролог работает с понедельника по пятницу. Пациент в мини-аппе открывает воскресенье, видит слоты 09:00...18:40 и записывается; сервер бронь принимает (outside_schedule не срабатывает). В воскресенье пациент приходит к закрытому кабинету. Ресепшн в CRM тоже видит воскресные слоты.

ПОСЛЕДСТВИЯ

Записи на нерабочие дни, массово через мини-апп: пациенты приходят к закрытому кабинету, репутационный ущерб.

ЧТО СДЕЛАТЬ

Fallback 09–19 применять только если у врача нет ни одной активной строки расписания. При наличии расписания отсутствие строк на weekday означает выходной: пустой список слотов, а detectConflicts возвращает outside_schedule. Учитывать validFrom/validTo.

КРИТЕРИЙ ПРИЁМКИ

Unit-тест: у врача с расписанием Пн–Пт findAvailableSlots(воскресенье) = [], а detectConflicts(воскресенье 10:00) = outside_schedule. У врача без расписания прежние слоты 09–19.

ДОКАЗАТЕЛЬСТВО В КОДЕ

findAvailableSlots: `schedules.length > 0 ? ... : [{ start: "09:00", end: "19:00" }]`, где выборка идёт по `{ doctorId, weekday, isActive: true }`. Отсутствие строк на конкретный день недели считается «рабочим днём по умолчанию». detectConflicts проверяет график только внутри `if (schedules.length > 0)`, иначе бронь проходит при любом времени. Редактор расписания хранит только рабочие интервалы (updateDoctorSchedule: deleteMany + createMany из entries), поэтому выходной = отсутствие строк. Тот же findAvailableSlots пытается CRM SlotPicker и /api/miniapp/slots. validFrom/validTo сохраняются и валидируются, но при расчёте слотов не читаются.

АР-02 Р1 · ВЫСОКИЙ мокап / заглушка

Кнопки напоминаний на странице «Записи» не отправляют своё сообщение, зато досрочно рассылают каскадные напоминания и рапортуют об успехе

ГДЕ

src/app/[locale]/crm/appointments/_components/appointments-right-rail.tsx:173, src/app/[locale]/crm/appointments/_components/appointments-right-rail.tsx:190, src/app/[locale]/crm/appointments/_components/appointments-right-rail.tsx:214, src/app/[locale]/crm/appointments/_components/appointments-right-rail.tsx:234, src/app/api/crm/appointments/bulk-reminders/route.ts:39, src/app/api/crm/appointments/bulk-reminders/route.ts:77, src/server/workers/notifications-send.ts:90, scripts/reminder-cadence-5d3d1d3h.ts:53

СЦЕНАРИЙ

В 09:00 регистратор нажимает «Напомнить всем». Пациенту с приёмом в 16:00 сразу приходит «через 3 часа в 16:00 ждём вас», а в 13:00 настоящее напоминание уже не придёт (строка израсходована). На экране тост «Поставлено в очередь: 12». Пациенты, уже сидящие в холле (WAITING), после «Подтвердить всех» получают «ждём вас через 3 часа».

ПОСЛЕДСТВИЯ

Неверные сообщения пациентам, потеря настоящих напоминаний, персонал уверен, что пациентам напомнили; три блока панели показывают выдуманные цифры.

ЧТО СДЕЛАТЬ

bulk-reminders: отправлять только строки, созданные этим вызовом (вернуть их ids из materialize), и использовать отдельный шаблон «ручное напоминание» без проверки дрейфа. Воркер не должен отправлять строки со scheduledFor > now. UI: «Подтвердить прибытие» сделать bulk-status WAITING (или убрать кнопку);

убрать константы 14:00 / 5 мин / count=1 или подключить реальные данные кампаний; «Открыть кампании» сделать ссылкой.

КРИТЕРИЙ ПРИЁМКИ

После «Напомнить всем» создаётся ровно одна новая строка ручного напоминания на каждую запись, и уходят только они. Каскадные строки остаются QUEUED с исходным scheduledFor. В правой панели нет захадркоженных значений, «Открыть кампании» только переходит на страницу.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Все три кнопки правой панели вызывают bulk-reminders с триггером `appointment.reminder-2h`. Шаблона с offsetMin -120 нет в DEFAULT_APPOINTMENT_TEMPLATES (там только -7200/-4320/-1440/-180), а миграция каскада деактивирует все остальные APPOINTMENT_BEFORE (CANONICAL_OFFSETS). В итоге findTemplateFor возвращает null, и materializeForAppointmentsBulk ничего не создаёт (skipped). Затем роут выбирает `notificationSend` со `status: QUEUED, scheduledFor: { gte: now - 5s }` по этим записям. Это будущие каскадные строки (например, «за 3 часа», запланированная на 13:00), и роут сразу ставит их на отправку. deliver() в воркере не проверяет scheduledFor <= now, проверка дрейфа offsetMin для каскадной строки проходит, и сообщение уходит немедленно. Даже с 2h-шаблоном новую строку со scheduledFor = now отменила бы проверка дрейфа (notifications-send.ts:146-163). Сам UI тоже макетный: «Подтвердить прибытие / Подтвердить всех» для WAITING-пациентов шлёт то же напоминание, а не подтверждает прибытие. В карточке «Telegram-рассылки — Запланирована на {time}» зашиты константы `broadcastTime = "14:00"` и `count={1}`, а кнопка «Открыть кампании» не открывает кампании, а рассылает всем BOOKED+WAITING. «Обновлено {min} мин назад» берёт константу `lastUpdatedMin = 5`.

AP-03 P2 · СРЕДНИЙ безопасность

PATCH и POST записи принимают patientId, medicalCaseId, queueStatus и денежные поля без проверок

ГДЕ

src/server/schemas/appointment.ts:60, src/server/schemas/appointment.ts:69, src/server/schemas/appointment.ts:80, src/server/schemas/appointment.ts:25, src/app/api/crm/appointments/[id]/route.ts:590, src/app/api/crm/appointments/[id]/route.ts:720, src/server/appointments/book.ts:338, src/lib/prisma.ts:146, src/app/api/crm/appointments/[id]/route.ts:60

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

Сотрудник или скомпрометированная учётка врача отправляет PATCH {patientId: <другой пациент>}, и визит с заключением и оплатами «переезжает» к другому пациенту. PATCH {medicalCaseId: <случай другого пациента>} делает визит бесплатным повтором, PATCH {priceFinal: 0} обнуляет счёт.

ПОСЛЕДСТВИЯ

Порча медицинских связей (визит расходится с заключением), финансовые манипуляции без отдельного аудита, потенциальный доступ к карточке пациента другой клиники.

ЧТО СДЕЛАТЬ

Убрать patientId из UpdateAppointmentSchema. medicalCaseId менять только через attach/detach с проверкой patientId. queueStatus принимать только вместе со status через тот же guard. Денегные поля вынести в отдельный эндпоинт с ролью ADMIN (или RECEPTIONIST) и аудитом price.override. В POST проверять, что пациент и случай принадлежат клинике.

КРИТЕРИЙ ПРИЁМКИ

PATCH {patientId} возвращает 400, PATCH {queueStatus} без status тоже 400. PATCH {priceFinal} от DOCTOR возвращает 403. POST с чужим medicalCaseId возвращает 422.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`const data = { ...body }` пишет в Appointment всё из UpdateAppointmentSchema. patientId: не проверяется ни существование в клинике, ни совпадение с VisitNote.patientId. medicalCaseId: не проверяется, что случай принадлежит этому пациенту. queueStatus: проверки перехода и роли выполняются только при body.status, поэтому `{queueStatus:"COMPLETED"}` проходит без canTransition/canRoleAdvanceTo и рассинхронизирует колонки. priceFinal/discountPct/discountAmount доступны в том числе DOCTOR на своих визитах. services[].priceOverride задаёт любой priceSnap. Тенант-расширение фильтрует только where, FK в data не проверяются: patientId другой клиники сохранится, и GET [id] (include: { patient: true }) вернёт карточку чужого пациента. В POST bookAppointment тоже не проверяет patientId и medicalCaseId на принадлежность клинике и пациенту.

AP-04 P2 · СРЕДНИЙ целостность данных

«Не явился» с ресепшн, массово и воркером не пересчитывает цены случая; воркер не обновляет queueStatus

ГДЕ

src/server/pricing/recompute-appointment-price.ts:206, src/app/api/crm/appointments/[id]/route.ts:692, src/app/api/crm/appointments/[id]/queue-status/route.ts:214, src/app/api/crm/appointments/bulk-status/route.ts:144, src/server/workers/appointment-lifecycle-sweep.ts:128, src/lib/queue-ordering.ts:107

СЦЕНАРИЙ

Пациент записан на первичный приём 01.10 и повторный 05.10 в одном случае, повторный бесплатный. На первичный он не пришёл, воркер ставит NO_SHOW, а повторный остаётся за 0 сум, хотя теперь это первый реальный визит. Одновременно строка неявки висит в «Записанных» на ресепшн с кнопкой «Пришёл» и не попадает в KPI «Не явились».

ПОСЛЕДСТВИЯ

Потеря выручки на повторных визитах, рассинхрон двух колонок статуса, неверные списки ресепшн и KPI. При отметке неявки с панели пациент не получает сообщение.

ЧТО СДЕЛАТЬ

Единое ядро markNoShow(): обе колонки статуса, recomputeCaseAppointments, fireTrigger no-show, событие через outbox. Использовать в queue-status, bulk-status и воркере; bulk-status для CANCELLED и COMPLETED переключить на ядра cancel/complete.

КРИТЕРИЙ ПРИЁМКИ

Любой путь отметки NO_SHOW даёт status = queueStatus = NO_SHOW, пересчитывает цену следующего визита случая до полной и создаёт NotificationSend no-show. Отдельный тест на воркер.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Движок бесплатных повторов намеренно не считает CANCELLED/NO_SHOW «первым визитом», и PATCH [id] при NO_SHOW вызывает recomputeCaseAppointments (statusKillsVisit). Но реальные пути это обходят. Карточка кабинета и карточка записи идут через queue-status: простой update без пересчёта и без fireTrigger no-show. Массовое «Не пришёл» идёт через bulk-status: updateMany без пересчёта; там же CANCELLED минует cancelAppointment, так что пациент не получает уведомление, а цены не пересчитываются. Автосвип делает `data: { status: "NO\_SHOW" }` без пересчёта и без queueStatus. При этом splitReceptionLanes берёт `queueStatus ?? status`, а KPI «Не явились» (/api/crm/dashboard:111) группирует по queueStatus.

AP-05 P2 · СРЕДНИЙ баг

Бесплатный повтор считается 24-часовыми интервалами: визит на N-й день после обеда оплачивается полностью

ГДЕ

src/server/pricing/recompute-appointment-price.ts:88, src/server/pricing/recompute-appointment-price.ts:234, src/server/pricing/recompute-appointment-price.ts:251

СЦЕНАРИЙ

Первичный приём в понедельник в 10:00, у услуги бесплатный повтор 7 дней. Повторный приём в следующий понедельник в 15:00: прошло 7 дней 5 часов, это больше 7×24 часов, поэтому полная цена, хотя в аудите daysFromFirst = 7 и по правилам клиники визит бесплатный.

ПОСЛЕДСТВИЯ

Переплата пациентов и конфликты на кассе; цена расходится с объявленной политикой.

ЧТО СДЕЛАТЬ

Сравнивать календарные дни в Asia/Tashkent: разница между tashkentComponents(first).date и tashkentComponents(current).date в днях должна быть не больше N.

КРИТЕРИЙ ПРИЁМКИ

Unit-тест при freeRepeatDays = 7: первый визит пн 10:00, повтор через неделю в пн 15:00 бесплатный; повтор во вторник следующей недели 09:00 (8-й день) платный.

ДОКАЗАТЕЛЬСТВО В КОДЕ

withinDayWindow делает `return ms <= days \* dayMs`, то есть сравнивает миллисекунды между стартами визитов, хотя комментарий обещает «calendar-day diff (floor on milliseconds)». daysFromFirst для аудита считается как `Math.floor(ms / day)`. Подсказка в настройках услуги: «Если в течение N дней пациент возвращается... повторный визит бесплатен».

AP-06 P2 · СРЕДНИЙ баг

В карточке записи можно сменить канал и время у талона живой очереди (WALKIN): пациент выпадает из очереди или получаем 500

ГДЕ

src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:82, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:184, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:655, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:733, src/server/schemas/appointment.ts:75, src/app/api/crm/appointments/[id]/route.ts:575, prisma/migrations/20260627120000_appointment_walkin_overlap_exempt/migration.sql:27, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:736

ТАКЖЕ НАШЛИ ЗОНЫ

Живая очередь, киоск, ТВ-табло, талоны

СЦЕНАРИЙ

Регистратор открывает талон живой очереди и по ошибке меняет канал на «Телефон». Пациент исчезает из очереди врача и с ТВ-табло, или появляется тост «internal_error».

ПОСЛЕДСТВИЯ

Потеря места в живой очереди, «невидимые» визиты, ошибки 500 у персонала.

ЧТО СДЕЛАТЬ

Для WALKIN-строк сделать канал и время только для чтения. На сервере запретить смену channel у WALKIN и перенос времени WALKIN-строк. Ловить 23P01 в PATCH и отвечать 409 doctor_busy.

КРИТЕРИЙ ПРИЁМКИ

PATCH {channel: "PHONE"} для WALKIN возвращает 400/409. В карточке талона канал и время не редактируются. Ошибка 23P01 в PATCH превращается в 409.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Выбор канала показывается для любой записи (CHANNELS = PHONE/TELEGRAM/WEBSITE). Схема запрещает только переход в WALKIN, но не из него. При смене WALKIN на PHONE timeChanged = false, конфликты не проверяются, и строка попадает под EXCLUDE-ограничение (channel <> "WALKIN"). Если она пересекается с бронью того же врача, Postgres бросает 23P01, и api-handler отдаёт 500 internal_error. Без пересечения визит переезжает из «Живой очереди» в «Записанные» со временем прихода в качестве слота. Кроме того, canEditTime = canReschedule(WAITING) = true и для walk-in: выбор слота на другой день запускает unarriveOnDayMove, и получается WALKIN в статусе CONFIRMED, который не отображается ни в одной полосе ресепшн.

AP-07 P2 · СРЕДНИЙ баг

Завершение приёма с ресепшн (queue-status) не выполняет пост-эффекты визита, и они теряются навсегда

ГДЕ

src/app/api/crm/appointments/[id]/queue-status/route.ts:142, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:139, src/app/api/crm/appointments/[id]/route.ts:886, src/app/api/crm/visit-notes/[id]/finalize/route.ts:281, src/lib/appointments/lifecycle.ts:111, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:146

ТАКЖЕ НАШЛИ ЗОНЫ

Telegram-бот, переписки, рассылки, уведомления, воркеры, Живая очередь, киоск, ТВ-табло, талоны

СЦЕНАРИЙ

Врач ведёт приём Каримова. Регистратор жмёт «Вызвать из очереди» и подтверждает переключение: Каримов получает COMPLETED через queue-status. Через 10 минут врач подписывает заключение, finalize видит COMPLETED и не обновляет visitCount/lastVisitAt и не отправляет «Спасибо за визит». Пациент, пригласивший Каримова, скидку не получает.

ПОСЛЕДСТВИЯ

Неверные сегменты NEW/ACTIVE/DORMANT и дата последнего визита (детектор «спящих» создаёт ложные задачи), пациенты не получают благодарность, реферальная программа не начисляет бонусы.

ЧТО СДЕЛАТЬ

Ввести единое ядро completeAppointment() по образцу cancelAppointment/confirmAppointment: completionFields, fireTrigger completed, начисление реферальной награды, lastContact, статистика визитов; идиоматично по отдельному флагу. Вызывать его из PATCH, queue-status, bulk-status и finalize. finalize должен запустить

эффекты, если они ещё не выполнялись, а не смотреть на статус записи.

КРИТЕРИЙ ПРИЁМКИ

При завершении с ресепшн у пациента обновлены lastVisitAt/visitCount, создан NotificationSend «спасибо», начислена реферальная награда (если есть реферер). Последующий finalize ничего не дублирует. Тесты на все четыре пути.

ДОКАЗАТЕЛЬСТВО В КОДЕ

STATE_OWNERS разрешает RECEPTIONIST/ADMIN переводить визит в COMPLETED. queue-status для COMPLETED пишет только status/queueStatus/completedAt/endDate, без fireTrigger(appointment.completed), mintReferralRewardOnCompletion, bumpPatientLastContact и refreshPatientVisitStats: они есть только в PATCH /appointments/[id] (стр. 886-908). «Вызвать из очереди» и «Начать запись» в карточке кабинета сначала отправляют `queueStatus: "COMPLETED"` для текущего пациента; кнопка статуса COMPLETED в карточке записи тоже идёт через queue-status. Когда врач потом подписывает заключение, finalize выполняет эффекты только `if (note.appointment.status !== "COMPLETED")`, а статус к этому моменту уже COMPLETED. Реферальная награда в finalize не начисляется вообще. Массовое завершение через bulk-status (доступно RECEPTIONIST по API) тоже идёт без эффектов.

AP-08 P2 · СРЕДНИЙ баг

Запись из CRM сохраняется с итоговой ценой null, если её не привязали к случаю

ГДЕ

src/app/api/crm/appointments/route.ts:198, src/server/appointments/book.ts:287, src/components/appointments/NewAppointmentDialog.tsx:391, src/components/appointments/NewAppointmentDialog.tsx:719, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:444, src/app/[locale]/crm/appointments/_hooks/use-appointments-list.ts:363

СЦЕНАРИЙ

Пациент с открытым случаем у терапевта записывается к неврологу на консультацию за 150 000 сум, регистратор закрывает окно выбора случая. В карточке «Итого 0 сум», после оплаты 150 000 статус «Частично», в вырубке врача визит на 0.

ПОСЛЕДСТВИЯ

Неверные суммы в карточке, статусах оплаты, комиссиях врачей и LTV.

ЧТО СДЕЛАТЬ

В роуте не подменять отсутствие значения на null (`priceFinal: body.priceFinal`), в book.ts трактовать null как «не задано», цену всегда считать на сервере. Привязку к случаю выполнять на сервере в транзакции брони (как autoAttachCase в мини-аппе).

КРИТЕРИЙ ПРИЁМКИ

POST с услугами и без priceFinal сохраняет priceFinal = priceBase – скидки независимо от выбора случая. Тест в book.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роут передаёт `priceFinal: body.priceFinal ?? null`, а диалог priceFinal не отправляет, поэтому приходит null. В bookAppointment стоит `input.priceFinal !== undefined ? input.priceFinal : priceBase - скидки`; null !== undefined, значит priceFinal = null, хотя priceBase посчитан, и скидки из тела игнорируются. Цену «чинит» только последующий клиентский attach к случаю (recomputeAppointmentPrice). Если у пациента два и больше открытых случаев или один у другого врача, открывается выбор случая (ветка 3, стр. 719); закрытие этого окна или сетевая ошибка оставляют priceFinal = null. Карточка показывает `appt.priceFinal ?? 0`, а paymentStatusFor при target = 0 и имеющейся оплате возвращает PARTIAL.

AP-09 P2 · СРЕДНИЙ баг

Запись можно перенести в прошлое из карточки и массовым переносом

ГДЕ

src/server/services/appointments.ts:67, src/server/services/appointments.ts:251, src/components/appointments/SlotPicker.tsx:86, src/app/api/crm/appointments/bulk-reschedule/route.ts:147, src/app/[locale]/crm/calendar/_components/calendar-view.tsx:344

СЦЕНАРИЙ

Регистратор в карточке ошибается месяцем и выбирает 23.08 вместо 23.10. Запись уходит в прошлое, пациенту приходит «приём перенесён на 23.08», а воркер сразу ставит NO_SHOW и шлёт «вы не пришли». Массовый перенос на -1 день тоже проходит.

ПОСЛЕДСТВИЯ

Потерянные записи, ложные неявки и сообщения пациентам.

ЧТО СДЕЛАТЬ

В `detectConflicts` запретить новое время начала в прошлом и для переносов (разрешать, только если время не меняется). В `SlotPicker` минимальная дата — сегодня, `findAvailableSlots` для прошедших дат отдаёт пустой список. Для `resize` та же проверка.

КРИТЕРИЙ ПРИЁМКИ

PATCH {date: вчера} возвращает 409 `in_past`. `bulk-reschedule` с отрицательным сдвигом в прошлое возвращает 409. В `SlotPicker` нельзя выбрать прошедшую дату.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`detectConflicts` отвергает прошедшее время только ``if (!larges.excludeld && ...)``. Любой перенос (PATCH, `bulk-reschedule`) передаёт `excludeld`, поэтому `in_past` никогда не возвращается; комментарий в `bulk-reschedule` о том, что `in_past` всегда блокирует, коду не соответствует. У `SlotPicker` нет минимальной даты, а `findAvailableSlots` убирает прошедшие слоты только для сегодняшнего дня (`'isToday'`) и для прошедшей даты отдаёт полный день. `Resize` в календаре прошлое не проверяет.

АР-10 Р2 · СРЕДНИЙ целостность данных

Календарь даёт перетащить и растянуть завершённый, отменённый или идущий приём; сервер не проверяет статус при переносе

ГДЕ

`src/app/[locale]/crm/calendar/_components/calendar-view.tsx:192`, `src/app/[locale]/crm/calendar/_components/calendar-view.tsx:246`, `src/app/[locale]/crm/calendar/_components/calendar-view.tsx:344`, `src/app/[locale]/crm/calendar/_components/calendar-view.tsx:440`, `src/app/api/crm/appointments/[id]/route.ts:545`, `src/app/api/crm/appointments/[id]/route.ts:869`, `src/server/notifications/triggers.ts:970`

СЦЕНАРИЙ

1) Регистратор случайно тянет завершённый в 09:00 приём Иванова в колонку другого невролога на 15:00 и подтверждает. У завершённого визита меняются врач, кабинет и время: визит пропадает из истории врача А, выручка и комиссия уходят врачу Б, а заключение остаётся за врачом А. 2) В сетке висит красный блок отменённой записи; его сдвигают, и пациенту в Telegram уходит «Ваш приём перенесён на 15:00», хотя запись отменена. 3) Растягивание идущего или завершённого приёма меняет `durationMin/endDate` без подтверждения.

ПОСЛЕДСТВИЯ

Искажение медицинской и финансовой атрибуции визитов, ложные сообщения пациентам; отменённые блоки визуально занимают свободные слоты.

ЧТО СДЕЛАТЬ

Сервер: в PATCH при изменении `date/time/durationMin/doctorId` требовать `actionsFor(before.status).canReschedule`, иначе 409 `invalid_transition`; `onAppointmentRescheduled` пропускает `CANCELLED/NO_SHOW/COMPLETED`. Клиент: `editable` и `durationEditable` только для событий в `BOOKED/CONFIRMED/WAITING/SKIPPED`; для `resize` те же проверки «в прошлое» и диалог подтверждения; отменённые записи и неявки скрывать фильтром или рисовать неинтерактивными.

КРИТЕРИЙ ПРИЁМКИ

PATCH {time} для `COMPLETED/CANCELLED/NO_SHOW/IN_PROGRESS` возвращает 409. В календаре такие блоки не перетаскиваются и не растягиваются. Перенос отменённой записи не создаёт `NotificationSend «rescheduled»`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`FullCalendar` настроен как ``editable eventStartEditable eventDurationEditable`` для всех событий. События строятся из всех записей диапазона без фильтра по статусу, так что `CANCELLED/NO_SHOW/COMPLETED` тоже рисуются в сетке. `handleEventDrop` проверяет только «в прошлое» (`computeRescheduledSlot`), `handleEventResize` не проверяет ничего и не спрашивает подтверждения. PATCH `/api/crm/appointments/[id]` применяет ``timeChanged`` (`date/time/durationMin/doctorId`) без проверки `before.status: canReschedule` проверяется только в UI карточки (`ScheduleSection`). После сохранения вызывается ``fireTrigger({ kind: startMoved ? "appointment.rescheduled" : ... })``, а `onAppointmentRescheduled` статус не проверяет и материализует сообщение «приём перенесён».

AP-11 P2 · СРЕДНИЙ бар

Откат отмены или неявки врачом не проверяет занятость слота и не восстанавливает напоминания

ГДЕ

src/app/api/crm/appointments/[id]/route.ts:171, src/app/api/crm/appointments/[id]/route.ts:214, src/app/api/crm/appointments/[id]/route.ts:219, src/server/appointments/cancel.ts:143, src/server/appointments/cancel.ts:218

СЦЕНАРИЙ

Пациент отменил запись в мини-аппе, слот занял другой пациент; врач нажимает «Вернуть» и получает ошибку 500. Если слот свободен, запись восстанавливается, но пациент считает её отменённой и напоминаний не получает.

ПОСЛЕДСТВИЯ

Ошибки у врача и «воскрешённые» визиты без ведома пациента, что ведёт к неявкам.

ЧТО СДЕЛАТЬ

В откате CANCELLED/NO_SHOW вызывать detectConflicts с excludeId и при конфликте отвечать 409 doctor_busy. После отката отправлять пациенту уведомление о восстановлении и заново планировать напоминания. Отдельно решить, может ли врач откатывать отмену, сделанную пациентом.

КРИТЕРИЙ ПРИЁМКИ

Откат при занятом слоте возвращает 409 doctor_busy. При свободном слоте пациенту создан NotificationSend о восстановлении и новые QUEUED-напоминания.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ветка ?revert=true для CANCELLED/NO_SHOW → BOOKED вызывает только findOtherActiveVisit (для IN_PROGRESS) и сразу пишет status = queueStatus = BOOKED. detectConflicts не вызывается: если освобождённый слот уже занят, EXCLUDE-ограничение бросает 23P01 внутри транзакции, и врач получает 500. Отмена (cancelAppointment) перевела все QUEUED-уведомления в CANCELLED и отправила пациенту «приём отменён». Откат не вызывает scheduleAppointmentReminders и никак не уведомляет пациента; confirmedAt остаётся заполненным при статусе BOOKED.

AP-12 P2 · СРЕДНИЙ бар

Ресепшн застревает на вчерашнем дне после полуночи, а выбор дня в панели врачей переключает всю страницу и позволяет вызвать пациента на другой день

ГДЕ

src/app/[locale]/crm/reception/_components/reception-page-client.tsx:73, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:81, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:252, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:339, src/app/api/crm/appointments/[id]/queue-status/route.ts:304, src/app/[locale]/crm/appointments/_hooks/use-appointments-filters.ts:240

СЦЕНАРИЙ

Компьютер ресепшн не выключали на ночь: утром экран показывает вчерашние записи как сегодняшние, а KPI смешивают вчерашний список и сегодняшний /dashboard. Регистратор выбирает «Завтра», чтобы посмотреть, кто придёт, и по привычке жмёт «Начать запись»: завтрашний пациент получает «Вас вызывают! Кабинет 5», а у врача запускается визит.

ПОСЛЕДСТВИЯ

Работа по неверному дню, ложные вызовы пациентов, визиты, начатые не в тот день.

ЧТО СДЕЛАТЬ

Обновлять «сегодня» по таймеру и при фокусе вкладки (или хранить режим «сегодня» отдельно от конкретной даты). Выбор дня ограничить панелью врачей, остальные виджеты всегда показывают реальное сегодня. Для дней, отличных от сегодня, скрыть кнопки «Пришёл», «Начать», «Вызвать». На сервере в queue-status для WAITING/IN_PROGRESS требовать, чтобы визит был сегодняшним (как `not\_today` в /queue/checkin).

КРИТЕРИЙ ПРИЁМКИ

Вкладка, открытая до полуночи, после 00:00 показывает новый день без перезагрузки. У завтрашней брони нет кнопки старта, а PATCH queue-status IN_PROGRESS для неё возвращает 409 not_today.

ДОКАЗАТЕЛЬСТВО В КОДЕ

selectedDate инициализируется один раз через `useState(() => { d.setHours(0,0,0,0) })` и в полночь не меняется. useTodayAppointments(selectedDate) питает не только панель врачей, но и «Общую очередь», KPI «Записей на

сегодня», «Срочные оповещения», «Умные рекомендации» и выдвижной список. На странице «Записи» apiFilters считаются через `useMemo(() => resolveWindow(state), [state])`, поэтому режим «Сегодня» после полуночи тоже не пересчитывается. queue-status не проверяет дату визита, а при переходе в IN_PROGRESS отправляет пациенту Telegram «Вас вызывают» (sendCallNotice). Карточка кабинета показывает «Начать запись» для брони выбранного дня.

AP-13 РЗ · НИЗКИЙ безопасность

GET записи отдаёт полную карточку пациента (паспорт, адрес, заметки) всем ролям

ГДЕ

src/app/api/crm/appointments/[id]/route.ts:54, src/app/api/crm/appointments/[id]/route.ts:60

СЦЕНАРИЙ

Оператор колл-центра открывает карточку записи, и в ответе API приходят паспорт и адрес пациента.

ПОСЛЕДСТВИЯ

Избыточная выдача персональных данных ролям, которым они не нужны.

ЧТО СДЕЛАТЬ

Выбирать только нужные поля через select, как в list-poyte.

КРИТЕРИЙ ПРИЁМКИ

Ответ GET /appointments/[id] не содержит passport, address и notes.

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET доступен ADMIN/RECEPTIONIST/DOCTOR/NURSE/CALL_OPERATOR и включает `patient: true` (все поля Patient: passport, address, notes, telegramId...) и `payments: true`. Карточке записи нужны только ФИО, телефон, фото, пол, дата рождения и сегмент.

AP-14 РЗ · НИЗКИЙ мокап / заглушка

«Умные рекомендации» и «Обновить очередь» на ресепшн — псевдо-действия

ГДЕ

src/app/[locale]/crm/reception/_components/bottom-row.tsx:250, src/app/[locale]/crm/reception/_components/bottom-row.tsx:286, src/app/[locale]/crm/reception/_components/queue-column.tsx:180, src/app/[locale]/crm/reception/_hooks/use-reception-live.ts:371

СЦЕНАРИЙ

Регистратор жмёт «Применить», видит тост и календарь, но ничего не перераспределено. Жмёт «Обновить очередь», чтобы подтянуть нового пациента, а очередь не меняется.

ПОСЛЕДСТВИЯ

Подрыв доверия к системе и пропущенные действия (напоминания так и не отправлены).

ЧТО СДЕЛАТЬ

Убрать эти действия или реализовать их (например, «Отправить» — реальная рассылка по BOOKED с подтверждением). «Обновить очередь» должна инвалидировать ['reception','appointments','today'] и dashboard.

КРИТЕРИЙ ПРИЁМКИ

Кнопки с действием в подписи не ограничиваются тостом или переходом. «Обновить очередь» делает запрос к /api/crm/appointments.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Кнопка «Применить» у рекомендации «Перераспределите очередь» только показывает тост с тем же текстом и открывает календарь. «Отправить» у «Напоминания пациентам» открывает Action Center и ничего не отправляет. Совет «перенаправить N пациентов из кабинета X» бессмыслен при жёсткой привязке кабинета к врачу и учитывает в том числе завершённые визиты. Кнопка «Обновить очередь» вызывает `aiScores.refetch()`: это запрос к /api/crm/ai/queue (AI выключен, `enabled: AI\_ENABLED` = false, но refetch() всё равно выполняется), а список записей не обновляется.

Короткий код талона генерируется через Math.random, а публичный резолвер /t/[code] не ограничен по частоте

ГДЕ

src/server/appointments/ticket-code.ts:22, src/server/appointments/ticket-code.ts:37, src/app/t/[code]/page.tsx:23

СЦЕНАРИЙ

Бот перебирает /t/XXXXXX и собирает связки «инициалы + невролог + услуга + время».

ПОСЛЕДСТВИЯ

Небольшой, но реальный канал утечки медицинского контекста.

ЧТО СДЕЛАТЬ

Генерировать код через crypto.randomInt длиной 8 и больше; rate-limit на /t и /q по IP; проверку уникальности выполнять через runUnscoped; ловить P2002 и генерировать заново.

КРИТЕРИЙ ПРИЁМКИ

Код генерируется криптостойко длиной не меньше 8. Больше N запросов к /t с одного IP в минуту получают 429.

ДОКАЗАТЕЛЬСТВО В КОДЕ

randomCode(): 6 символов из алфавита в 30 знаков (около $7,3 \cdot 10^8$ вариантов) через некриптостойкий Math.random. /t/[code] — анонимная страница (исключена в matcher proxy), без rate-limit: делает runUnscoped findUnique по ticketCode и редиректит на /q/{appointmentId}, откуда /ticket/{id} показывает инициалы, врача, кабинет, услугу и время. При десятках тысяч записей перебор находит валидный код в среднем за десятки тысяч запросов. Проверка уникальности в generateTicketCode выполняется в TENANT-контексте (clinicId подмешивается в where), а ticketCode уникален глобально, поэтому межклиничная коллизия даст P2002 и ответ 500.

Массовый перенос не пересчитывает цены случая и не снимает отметку «пришёл» при смене дня

ГДЕ

src/app/api/crm/appointments/bulk-reschedule/route.ts:63, src/app/api/crm/appointments/bulk-reschedule/route.ts:188, src/app/api/crm/appointments/[id]/route.ts:612, src/app/api/crm/appointments/[id]/route.ts:703

СЦЕНАРИЙ

Выбирают 5 записей, включая уже пришедшего пациента, и переносят на +1 день. Пришедший завтра числится WAITING с сегодняшним queuedAt, а бесплатный повтор, вышедший после переноса за окно, остаётся бесплатным.

ПОСЛЕДСТВИЯ

Неверные очереди и цены после массовых переносов.

ЧТО СДЕЛАТЬ

Переиспользовать логику PATCH: снимать отметку прихода при смене дня и вызывать recomputeCaseAppointments по затронутым случаям.

КРИТЕРИЙ ПРИЁМКИ

После массового переноса WAITING-записи на другой день у неё status = CONFIRMED и queuedAt = null, цены случаев пересчитаны.

ДОКАЗАТЕЛЬСТВО В КОДЕ

bulk-reschedule разрешает переносить WAITING (canReschedule) и в транзакции меняет только date/endDate/time. Одиночный PATCH при смене дня выполняет unarriveOnDayMove (status CONFIRMED, queuedAt = null) и пересчитывает цены случая (siblingRepriceNeeded); здесь ни того, ни другого нет.

Номера страниц в таблице записей только для вида: по ним нельзя перейти

ГДЕ

src/app/[locale]/crm/appointments/_components/appointments-table.tsx:777, src/app/[locale]/crm/appointments/_components/appointments-table.tsx:795

СЦЕНАРИЙ

Регистратор нажимает «1», находясь на третьей странице, и ничего не происходит.

ПОСЛЕДСТВИЯ

Ложная навигация.

ЧТО СДЕЛАТЬ

Убрать номера страниц или реализовать постраничный переход.

КРИТЕРИЙ ПРИЁМКИ

Номера страниц либо отсутствуют, либо переводят на нужную страницу.

ДОКАЗАТЕЛЬСТВО В КОДЕ

У кнопок с номером больше текущей страницы стоит `disabled={p > currentPage}`, а `onClick` срабатывает только при `p > currentPage`. Кликабельных номеров нет, вернуться назад нельзя; реальная навигация только через «Загрузить ещё».

Ошибки смены статуса показываются сырыми кодами:

«`conflict:another_visit_in_progress`», «HTTP 409», ключ `i18n`

ГДЕ

src/app/[locale]/crm/appointments/_hooks/use-appointment.ts:152, src/app/[locale]/crm/appointments/_hooks/use-appointment.ts:237, src/app/[locale]/crm/appointments/_hooks/use-appointment.ts:314, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:180, src/app/[locale]/crm/appointments/_components/appointments-bulk-bar.tsx:58

СЦЕНАРИЙ

Регистратор жмёт «Начать» у второго пациента, пока идёт приём, и видит «`conflict:another_visit_in_progress`» и «Не удалось изменить статус».

ПОСЛЕДСТВИЯ

Непонятные сообщения и лишние обращения в поддержку.

ЧТО СДЕЛАТЬ

Единый маппер причин в локализованный текст для ru и uz (`another_visit_in_progress`, `too_early_for_no_show`, `role_cannot_advance_to`, `not_revertable`, `doctor_not_found`, `bad_phone`); не дублировать тосты.

КРИТЕРИЙ ПРИЁМКИ

Для каждой причины из API есть ключ в ru и uz; в тостах нет строк с «`conflict:`» или «HTTP».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`useSetQueueStatus.onError` делает `toast.error(err.message || ...)` и не исключает `AppointmentConflictError`, у которой сообщение `conflict:${reason}`; карточка добавляет второй тост `statusError`. `useDeleteAppointment` бросает `HTTP ${status}`, откуда тост «HTTP 409»; `403 role_cannot_advance_to` превращается в «HTTP 403». Массовая панель переводит причину через `namespace appointments.drawer.conflict`, где нет ключа `too_early_for_no_show`, хотя «Не пришёл» для будущих BOOKED включена (`actionsFor`), и `next-intl` показывает сам ключ. Диалог выдачи талона показывает сырые `doctor_not_found/bad_phone`.

Пересчёт цен случая делает $O(N^2)$ запросов внутри транзакции при каждом переносе

ГДЕ

src/server/pricing/recompute-appointment-price.ts:319, src/server/pricing/recompute-appointment-price.ts:218, src/app/api/crm/appointments/[id]/route.ts:750

СЦЕНАРИЙ

Пациент с эпилепсией наблюдается 3 года в одном случае; перетаскивание его записи в календаре занимает секунды и держит транзакцию с блокировками.

ПОСЛЕДСТВИЯ

Медленные операции и риск таймаутов по мере роста истории.

ЧТО СДЕЛАТЬ

Загружать соседей один раз, один раз определять первый визит и обновлять только изменившиеся строки (батчем).

КРИТЕРИЙ ПРИЁМКИ

Перенос визита в случае с 60 визитами выполняет константное число запросов плюс обновления изменённых строк (проверка по логу запросов).

ДОКАЗАТЕЛЬСТВО В КОДЕ

recomputeCaseAppointments для каждого визита случая вызывает recomputeAppointmentPrice, а тот делает findUnique с payments/services, findMany всех соседних визитов и update. PATCH вызывает это при любом timeChanged, если визит входит в случай (перетаскивание, resize, смена врача). Для хронического неврологического случая с 60 визитами это около 180 запросов и 60 выборок всех соседей в одной транзакции.

AP-20 P3 · НИЗКИЙ мокап / заглушка

Плитки и правая панель календаря показывают эвристики вместо данных

ГДЕ

src/app/[locale]/crm/calendar/_components/calendar-tiles.tsx:60, src/app/[locale]/crm/calendar/_components/calendar-tiles.tsx:66, src/app/[locale]/crm/calendar/_components/calendar-tiles.tsx:87, src/app/[locale]/crm/calendar/_components/calendar-right-rail.tsx:124

СЦЕНАРИЙ

В клинике 6 врачей по 10 часов, а плитка показывает «Свободные слоты: 0», хотя в расписании десятки свободных окон. В недельном виде «Записей сегодня: 214».

ПОСЛЕДСТВИЯ

Администратор планирует загрузку по выдуманным цифрам.

ЧТО СДЕЛАТЬ

Считать свободные слоты через findAvailableSlots по расписанию каждого врача на сегодня. «Подтверждено» = CONFIRMED и пришедшие. Исключить WAITING из риска неявки. Подписи привязать к реальному диапазону.

КРИТЕРИЙ ПРИЁМКИ

Плитка свободных слотов совпадает с суммой слотов SlotPicker по активным врачам на сегодня.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Плитка «Свободные слоты / сегодня» считается как $(11 \cdot 60 - \text{сумма длительностей всех записей дня, включая отменённые}) / 30$ сразу для всех врачей. В правой панели «Свободные слоты сегодня» по врачам — тот же «Rough heuristic — assume 11h workday», причём по всему видимому диапазону (неделе), а не по сегодня и не по расписанию. «Подтверждено» = IN_PROGRESS + COMPLETED, а статус CONFIRMED не учитывается нигде. «Высокий риск no-show» включает WAITING-пациентов, которые уже больше 15 минут сидят в холле. «Записей сегодня» в недельном виде показывает всю неделю.

AP-21 P3 · НИЗКИЙ UX

Плитки на странице «Записи» считаются по первой загруженной странице и подписаны неверно

ГДЕ

src/app/[locale]/crm/appointments/_components/appointments-tiles.tsx:63, src/app/[locale]/crm/appointments/_hooks/use-appointments-list.ts:273, src/app/[locale]/crm/appointments/_hooks/use-appointments-list.ts:282

СЦЕНАРИЙ

В день 80 записей: плитка «Не подтверждены: 12» при реальных 25, а пациенты в холле не входят в «Прибыли».

ПОСЛЕДСТВИЯ

Неточные сводки для ресепшн.

ЧТО СДЕЛАТЬ

Считать плитки на сервере (расширить tally на UX-корзины) или отдельным запросом; привести формулы и подписи в соответствие.

КРИТЕРИЙ ПРИЁМКИ

Числа в плитках совпадают с выборкой по всем страницам; подписи соответствуют формулам.

ДОКАЗАТЕЛЬСТВО В КОДЕ

tallyBuckets(rows) считает только уже загруженные строки (страница по 50). При серверном фильтре по статусу

(bucket = booked → status = BOOKED) остальные плитки обнуляются. Сервер возвращает `tally`, но он не используется. «Прибыли — Готовы к приёму» = IN_PROGRESS + COMPLETED, ждущие WAITING не считаются. «Скоро — В ближайший час» на деле считает окно в 15 минут. «Опоздания — от 5 до 15 мин» на деле охватывает время от начала приёма до конца + 15 минут.

АР-22 РЗ · НИЗКИЙ UX

Подпись «Повторный визит N из M» в карточке учитывает отменённые визиты, а цена считается без них

ГДЕ

src/app/api/crm/appointments/[id]/route.ts:103, src/server/pricing/recompute-appointment-price.ts:218

СЦЕНАРИЙ

Первичный приём отменён, новая запись оплачивается по полной цене как первая, а в карточке написано «Повторный визит 2 из 2».

ПОСЛЕДСТВИЯ

Регистратор объясняет пациенту противоречие между подписью и ценой.

ЧТО СДЕЛАТЬ

Считать номер визита по тем же правилам, что и движок цен.

КРИТЕРИЙ ПРИЁМКИ

При отменённом первом визите карточка показывает «Первичный визит».

ДОКАЗАТЕЛЬСТВО В КОДЕ

visitNumberInCase считается по всем визитам случая (`findMany({ where: { medicalCaseId } })`) вместе с CANCELLED и NO_SHOW, а движок цен исключает их при выборе первого визита.

АР-23 РЗ · НИЗКИЙ мёртвая механика

Фильтр «Услуга» на странице «Записи» ничего не фильтрует

ГДЕ

src/app/[locale]/crm/appointments/_hooks/use-appointments-filters.ts:255, src/app/[locale]/crm/appointments/_hooks/use-appointments-list.ts:152, src/server/schemas/appointment.ts:88, src/app/api/crm/appointments/route.ts:26

СЦЕНАРИЙ

Администратор выбирает услугу «ЭЭГ», чтобы увидеть записи на исследование; список не меняется, но выглядит отфильтрованным.

ПОСЛЕДСТВИЯ

Неверные выборки и решения по неполным данным.

ЧТО СДЕЛАТЬ

Добавить serviceId в QueryAppointmentSchema и условие `OR: [{ serviceId }, { services: { some: { serviceId } } }]`.

КРИТЕРИЙ ПРИЁМКИ

После выбора услуги в списке остаются только записи с этой услугой (основной или в строках услуг).

ДОКАЗАТЕЛЬСТВО В КОДЕ

UI отправляет `serviceId` в query, но в QueryAppointmentSchema этого поля нет (zod его отбрасывает), и GET-роут не строит условие по услуге. При этом индикатор «есть фильтры» загорается.

РТ · Пациенты и медицинские случаи в CRM

РТ-01 Р1 · ВЫСОКИЙ баг

В CRM-карточке пациента невозможно исправить ФИО, телефон, дату рождения, пол, адрес, паспорт

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/patient-info-panel.tsx:88, src/app/[locale]/crm/patients/[id]/_components/patient-info-panel.tsx:205, src/app/[locale]/crm/patients/[id]/_components/patient-header.tsx:98, src/app/[locale]/crm/patients/[id]/_components/patient-card-client.tsx:171

СЦЕНАРИЙ

Пациент зарегистрировался через Mini App — имя из профиля Telegram «Jasur», без даты рождения. Ресепшен хочет внести ФИО и дату рождения — кнопка «Редактировать» не реагирует. В заключении врача не печатается возраст, поиск по фамилии не находит пациента.

ПОСЛЕДСТВИЯ

Базовая операция регистратуры сломана; ошибки в анкете нельзя исправить, это портит заключения, поиски и напоминания.

ЧТО СДЕЛАТЬ

Подключить редактирование демографии в карточке: либо вернуть PatientHeader/InlineField в PatientCardClient, либо реализовать диалог редактирования по кнопке «Редактировать» (ФИО с разбором года, телефон с проверкой дубля, дата рождения, пол, адрес, паспорт, источник, язык). Удалить мёртвый код.

КРИТЕРИЙ ПРИЁМКИ

Ресепшен в /crm/patients/[id] меняет дату рождения и телефон, изменения сохраняются и видны после перезагрузки; кнопка «Редактировать» открывает форму.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Единственный компонент с инлайн-редактированием демографии — PatientHeader (InlineField на стр. 98, 130, ...) — нигде не импортируется (grep: единственный импорт 'patient-header' — в чужом модуле doctor/visits). Карточка рендерит PatientHero + PatientInfoPanel (patient-card-client.tsx:171-209). В PatientInfoPanel у блока «Основная информация» передан `action={tCommon("edit")}` без onAction (стр. 88), а SidebarCard рендерит `

РТ-02 Р1 · ВЫСОКИЙ баг

Запись из Mini App, автоматически привязанная к случаю, не пересчитывается по правилу бесплатного повтора

ГДЕ

src/server/cases/attach.ts:94, src/server/cases/attach.ts:112, src/server/appointments/book.ts:409, src/server/appointments/book.ts:660, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:103, src/server/appointments/book.ts:404, src/server/appointments/book.ts:648, src/server/cases/attach.ts:116, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:101, src/app/api/crm/cases/[id]/attach-appointment/route.ts:91

ТАКЖЕ НАШЛИ ЗОНЫ

Мини-апп пациента и публичные страницы клиники

СЦЕНАРИЙ

У пациента открыт случай «Головные боли», первичный визит 01.09, у услуги «Консультация невролога» freeRepeatDays=14. 10.09 он записывается на повтор через Mini App — запись молча попадает в случай, но priceFinal остаётся полной (например 300 000 сум). Если бы ресепшен привязал ту же запись в CRM, цена стала бы 0. На кассе с пациента берут полную сумму.

ПОСЛЕДСТВИЯ

Прямые деньги: пациенты переплачивают за положенный бесплатный повтор, при разборе — конфликт и возвраты; цена зависит от канала записи.

ЧТО СДЕЛАТЬ

В autoAttachCase (ветки created и auto) и в miniapp attach-case выполнять привязку в транзакции вместе с recomputeAppointmentPrice(tx, appointmentId) и recomputeCaseAppointments(tx, caseId), с аудитом appointment.free_repeat_applied как в CRM. Создание случая сделать атомарным (блокировка по patientId или

частичный уникальный индекс на один автоматический OPEN-случай).

КРИТЕРИЙ ПРИЁМКИ

Бронирование из Mini App повторного визита в окне freeRepeatDays при одном открытом случае даёт priceFinal=0 и запись аудита free_repeat_applied. Два одновременных бронирования пациента без открытых случаев создают один случай.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В booking-транзакции пересчёт цены делается только `if (input.medicalCaseId)` (book.ts:409-417); Mini App передаёт не medicalCaseId, а autoAttachCaseOptions, и autoAttachCase вызывается уже ПОСЛЕ транзакции (book.ts:660-665). autoAttachCase делает голый `prisma.appointment.update({ data: { medicalCaseId } })` (attach.ts:105-108 и 114-117) без recomputeAppointmentPrice/recomputeCaseAppointments. CRM-путь /api/crm/cases/[id]/attach-appointment, наоборот, пересчитывает (attach-appointment/route.ts:68-94). Ручной выбор случая в Mini App (attach-case/route.ts:83,103) тоже без пересчёта. Кроме того, ветка «0 открытых случаев» создаёт случай вне транзакции: два параллельных бронирования создают два случая «Новая жалоба».

РТ-03 Р1 · ВЫСОКИЙ баг

Поиск «Фамилия ГГГГ» (привычка врача) почти всегда ничего не находит

ГДЕ

src/app/api/crm/patients/route.ts:47, src/app/api/crm/patients/route.ts:79, src/app/api/crm/patients/route.ts:87, tests/unit/patient-search-by-year.test.ts:51

СЦЕНАРИЙ

Врач в поиске кабинета (doctor-search.tsx) или в диалоге «Живая очередь» (add-walkin-dialog.tsx) набирает «Турматов 1969», как привык. Пациент Турматов Отабек 1969 г.р. в базе есть, но список пуст. Врач создаёт нового пациента — дубль карты, история визитов разрывается.

ПОСЛЕДСТВИЯ

Основной сценарий поиска врача не работает, растут дубли карт, врач не видит анамнез.

ЧТО СДЕЛАТЬ

Когда в терме найден завершающий год с именем, строить where только из AND (имя-часть + диапазон birthDate), не добавляя OR с полным термом; либо OR-условия строить по namePart. Переписать тест так, чтобы он проверял результат запроса к реальной БД/фикстуре, а не форму объекта.

КРИТЕРИЙ ПРИЁМКИ

GET /api/crm/patients?q=Турматов%201969 возвращает пациента «Турматов Отабек» с birthDate 1969-01-01 и телефоном без «1969». Интеграционный тест на это.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Для запроса «Турматов 1969» код ставит `where.AND = [{ fullName contains 'Турматов' }, { birthDate: 1969 }]` (79-82) и ЗАТЕМ безусловно `where.OR = or` (87), где `or` = [fullName contains БЕСЬ терм «Турматов 1969», passport contains терм, telegramUsername contains терм, phone contains терм, phoneNormalized contains '1969', phoneNormalized contains '+1969']. Prisma объединяет AND и OR через И, поэтому строка должна одновременно иметь фамилию+год рождения И содержать «Турматов 1969» в имени (год из имени как раз вырезается parsePatientIdentity) или «1969» в телефоне. Юнит-тест копирует ту же форму запроса и проверяет только наличие ключа AND, поэтому ошибку не ловит.

РТ-04 Р2 · СРЕДНИЙ безопасность

QR-инвайт на распечатанном заключении — ключ к медкарте на предъявителя на 30 дней, без сверки телефона

ГДЕ

src/app/api/crm/visit-notes/[id]/print/route.ts:607, src/server/telegram/invite-token.ts:152, src/server/telegram/invite-token.ts:56, src/app/api/crm/patients/[id]/telegram-invite/route.ts:26, src/app/api/telegram/webhook/[clinicSlug]/route.ts:477

СЦЕНАРИЙ

Пациент уносит распечатанное заключение и отдаёт его работодателю / в аптеку / оставляет в такси. Любой, кто отсканирует QR в течение 30 дней раньше самого пациента, становится «этим пациентом» в Mini App: видит все заключения и документы и дальше получает новые документы в Telegram. То же при отправке ссылки ресепшеном «не тому номеру». Если сканирует мама, уже привязанная к своей карте, её Telegram оказывается на двух картах, и Mini App показывает одну из них случайно.

ПОСЛЕДСТВИЯ

Утечка PHI третьим лицам через бумажный документ; путаница карт при повторной привязке одного Telegram.

ЧТО СДЕЛАТЬ

При consume требовать подтверждение контакта (request_contact) и совпадение номера с картой; сократить TTL токена на бумаге (или печатать ссылку на бота без персонального токена); запретить привязку Telegram, уже связанного с другой картой, кроме явной семейной связи; показывать персоналу в карточке, кем и когда привязан Telegram.

КРИТЕРИЙ ПРИЁМКИ

Скан QR с чужого Telegram без подтверждённого совпадающего номера не привязывает карту. Telegram, уже привязанный к пациенту А, не может быть привязан к пациенту Б через инвайт. Тесты на consumeInviteToken для обоих случаев.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Печать заключения вставляет QR с `https://t.me/<bot>?start=<token>` для непривязанного пациента (print/route.ts:607-624). Токен живёт 30 дней (INVITE_TTL_MS, invite-token.ts:152; telegram-invite/route.ts:26) и переиспользуется 24ч. consumeInviteToken (invite-token.ts:53-137) при `/start <token>` от ЛЮБОГО пользователя проверяет только clinicId, consumedAt, expiresAt и что у карты пуст telegramId — затем пишет `telegramId: input.telegramId`. Нет сверки номера телефона из Telegram с Patient.phoneNormalized и нет проверки, что этот Telegram уже привязан к другой карте клиники (webhook route.ts:477-490 просто вызывает consume).

PT-05 P2 · СРЕДНИЙ безопасность

SUPER_ADMIN без входа в клинику читает пациентов всех клиник через GET-эндпоинты, минуя грант имперсонации и журнал просмотров

ГДЕ

src/lib/api-handler.ts:359, src/lib/api-handler.ts:303, src/app/api/crm/patients/[id]/route.ts:46, src/app/api/crm/patients/export/route.ts:41

СЦЕНАРИЙ

Сотрудник платформы с ролью SUPER_ADMIN (или украденная сессия такого пользователя) без оформления гранта имперсонации с причиной запрашивает /api/crm/patients/export и получает CSV пациентов всех клиник; в журнале просмотров PHI записей нет.

ПОСЛЕДСТВИЯ

Обход модели гранта/аудита для самой привилегированной роли; кросс-тенантная выгрузка PHI без следа.

ЧТО СДЕЛАТЬ

В createApiListHandler, как и в createApiHandler, отклонять ctx.kind === "SUPER_ADMIN" для /api/crm/* (или требовать явный opt-in для платформенных GET); писать PatientView для любого вида контекста.

КРИТЕРИЙ ПРИЁМКИ

GET /api/crm/patients под SUPER_ADMIN без активного гранта возвращает 400 ClinicNotSelected; тест на list-handler.

ДОКАЗАТЕЛЬСТВО В КОДЕ

createApiHandler отклоняет контекст SUPER_ADMIN без клиники («ClinicNotSelected», api-handler.ts:303-312), а createApiListHandler (стр. 359-405) такой проверки не имеет и выполняет handler в runWithTenant({kind:"SUPER_ADMIN"}) — Prisma-расширение для этого вида не подставляет clinicId (prisma.ts:215-221). checkRoles пропускает SUPER_ADMIN в любые роли. В итоге GET /api/crm/patients, /patients/[id], /patients/export (CSV), /cases/[id] отдадут данные ВСЕХ клиник; recordPatientView пропускается (if (ctx.kind === "TENANT")), patients/[id]/route.ts:46). Комментарий в documents/file/route.ts:10-13 утверждает обратное: «SUPER_ADMIN without impersonation does not see any tenant data».

PT-06 P2 · СРЕДНИЙ баг

«Последний визит» пациента может застрять на старой дате; статистика не обновляется из части путей завершения

ГДЕ

src/server/patient/last-contacted.ts:88, src/app/api/crm/appointments/[id]/queue-status/route.ts:142, src/app/api/crm/appointments/bulk-status/route.ts:96

СЦЕНАРИЙ

У пациента есть старый завершённый визит без completedAt (март). Вчера он был на приёме, завершённом через доску очереди. В карточке «Последний визит: 12.03», детектор «спящих» считает его ушедшим и шлёт реактивационную рассылку.

ПОСЛЕДСТВИЯ

Неверная дата последнего визита в карточке, списке и детекторах; ложные реактивации.

ЧТО СДЕЛАТЬ

Использовать `{ completedAt: { sort: "desc", nulls: "last" } }` или сортировку по COALESCE(completedAt, date) через raw; вызывать refreshPatientVisitStats из queue-status и bulk-status при переходе в COMPLETED и при откате.

КРИТЕРИЙ ПРИЁМКИ

Пациент с одной COMPLETED-записью без completedAt (старая дата) и одной новой с completedAt получает lastVisitAt = новая дата. Завершение визита через queue-status обновляет lastVisitAt/visitsCount.

ДОКАЗАТЕЛЬСТВО В КОДЕ

refreshPatientVisitStats берёт последний визит через `orderBy: [{ completedAt: "desc" }, { date: "desc" } ]` (last-contacted.ts:86-89). В Postgres DESC сортирует NULL первыми, поэтому любая COMPLETED-запись с completedAt=NULL (комментарий в том же файле, стр. 77-81, прямо признаёт существование таких «legacy» строк) выигрывает у всех свежих визитов, и lastVisitAt = её старая дата слота. Кроме того, refreshPatientVisitStats вызывается только из appointments/[id] PATCH и visit-notes finalize; queue-status (стр. 142-143) и bulk-status (стр. 96) переводят запись в COMPLETED и ставят completedAt, но статистику пациента не обновляют.

РТ-07 Р2 · СРЕДНИЙ целостность данных

«Удаление» пациента по DSAR оставляет персональные данные, жёсткое удаление никогда не выполнится, заявку не создать из CRM

ГДЕ

src/server/dsar/anonymize.ts:64, src/server/workers/data-deletion.ts:80, src/server/workers/data-deletion.ts:159, src/server/workers/data-deletion.ts:234, src/app/api/crm/patients/[id]/route.ts:116, src/app/api/crm/dsar/deletions/route.ts:76, prisma/migrations/20260422080121_phase-1-initial/migration.sql:915, src/server/workers/data-deletion.ts:158, prisma/migrations/20260422080121_phase-1-initial/migration.sql:1002, prisma/migrations/20260422080121_phase-1-initial/migration.sql:972, src/server/workers/data-deletion.ts:95, src/server/workers/data-deletion.ts:157, src/server/workers/data-deletion.ts:244, prisma/migrations/202605065513_add_medical_case/migration.sql:76, src/app/api/crm/dsar/deletions/route.ts:23

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы, Telegram-бот, переписки, рассылки, уведомления, воркеры

СЦЕНАРИЙ

Пациент в Mini App просит удалить данные; через 90 дней карта становится «Удалённый пациент», но в «Лидях» и «Онлайн-заявках» по-прежнему его ФИО и телефон, в истории уведомлений — «Здравствуйте, Иванов Иван...», в документах — PDF заключений с ФИО. Админ, выбравший режим HARD_DELETE через API, видит «Одобрено» вечно. Админ пытается удалить дубль, получивший рассылку, — 500.

ПОСЛЕДСТВИЯ

Право на удаление/обезличивание выполняется лишь формально (юридический риск); жёсткое удаление — мёртвая функция, способная заблокировать очередь; нет рабочего пути для заявки из клиники.

ЧТО СДЕЛАТЬ

Составить полный перечень носителей PII и чистить их в транзакции (Lead, OnlineRequest, Communication, NotificationSend, Call, Conversation, документы в MinIO, birthDate), либо осознанно сохранять меддокументацию по закону с явной политикой; HARD_DELETE убрать или реализовать каскадом с проверкой сроков хранения; переводить упавшие задачи в FAILED с причиной и не давать им занимать весь батч; добавить в карточку кнопку «Заявка на удаление/обезличивание» для ADMIN и понятную обработку 409; учесть все RESTRICT-связи в DELETE; скрывать deletedAt-пациентов из списков.

КРИТЕРИЙ ПРИЁМКИ

После анонимизации поиск по старому телефону/ФИО не находит ни пациента, ни лидов/заявок/уведомлений; HARD_DELETE либо завершается, либо переходит в FAILED без повторов; админ создаёт заявку из карточки; DELETE пациента с одной рассылкой не даёт 500.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ANONYMIZE: buildAnonymizationPayload чистит только поля строки Patient (anonymize.ts:64-89) и оставляет birthDate/gender; scrubPatientPhiCarriers (data-deletion.ts:80-116) обнуляет лишь soapDraft, Appointment.notes, PatientReview.comment и тексты сообщений. Остаются: Lead.name/phone и OnlineRequest.name/phone (связаны patientId), Communication.body, NotificationSend.body (тексты напоминаний с именем), Call.summary, VisitNote (заключения), документы в MinIO (PDF с ФИО), а также AuditLog с plaintext-снимками (см. отдельную находку). HARD_DELETE: `prisma.patient.delete` (стр. 159) падает на FK ON DELETE RESTRICT

(Appointment_patientId_fkey migration.sql:915, NotificationSend:1002, MedicalCase add_medical_case/migration.sql:76, LabResult и др.) — ошибка ловится в runDsarTick «will retry next tick» (стр. 241-249), задача навсегда остаётся APPROVED; тик берёт 50 самых старых due-задач (стр. 234-239), и ≥50 застрявших блокируют все остальные. DELETE /api/crm/patients/[id] при наличии записей отвечает 409 useDsar (стр. 116-130), но в UI нет ни одного вызова POST /api/crm/dsar/deletions — админ получает toast «HTTP 409». Проверка DELETE не учитывает NotificationSend/LabResult/LabOrder/SickLeave/Referral (тоже RESTRICT) — такие пациенты дают 500. Заявка из Mini App сразу APPROVED без ревизии и без проверки сроков хранения меддокументации (miniapp/account/delete/route.ts:93-100), хотя комментариев в patients/[id]/route.ts:107-115 обещает «retention checks». Анонимизированная карта остаётся в списке/поиске, её можно переименовать и записать на приём.

PT-08 P2 · СРЕДНИЙ мёртвая механика

Баланс/долг пациента: поле balance никогда не пишется, «Долг» в карточке считается по отменённым и будущим записям

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/patient-finance-card.tsx:32, src/app/[locale]/crm/patients/[id]/_components/patient-finance-card.tsx:107, src/app/[locale]/crm/patients/[id]/_components/tabs/payments-tab.tsx:100, src/app/api/crm/patients/route.ts:38, src/app/api/crm/patients/[id]/stats/route.ts:74

СЦЕНАРИЙ

Пациент записан на следующую неделю (300 000 сум) и один раз отменял визит — в карточке «Долг: 600 000 сум», хотя он ничего не должен. Во вкладке «Оплаты» у того же пациента «Баланс: 0 сум». Ресепшен вносит оплату через вкладку «Оплаты» — «Долг» на обзоре не уменьшается.

ПОСЛЕДСТВИЯ

Персонал видит ложный долг (риск требовать деньги с пациента) или не видит реальный; три несогласованных числа по деньгам в одной карточке.

ЧТО СДЕЛАТЬ

Определить одну формулу долга (сумма priceFinal только COMPLETED/в работе минус все PAID-платежи пациента, с учётом валюты) и вычислять её на сервере в одном эндпоинте; либо реально поддерживать Patient.balance в транзакциях платежей/завершения визитов. Убрать отменённые/будущие записи из «начислено». Кнопку «Изменить запись» удалить или подключить.

КРИТЕРИЙ ПРИЁМКИ

Пациент с одной будущей записью и одной отменённой без завершённых визитов имеет долг 0 во всех местах карточки и не попадает в фильтр должников. Оплата без привязки к записи уменьшает долг. Тест на функцию расчёта.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Patient.balance (schema.prisma:1763) не записывается ни одним путём приложения (grep: только чтение; ненулевые значения есть лишь в scripts/seed-mega-neurofax.ts:277). При этом его показывают: вкладка «Оплаты» — карточка «Баланс» (payments-tab.tsx:100-124), статистика для Telegram-инбокса (stats/route.ts:74), фильтр «должники» (patients/route.ts:38-40). Карточка «Финансы» на обзоре считает долг иначе: `billed += a.priceFinal` по ВСЕМ записям (включая CANCELLED, NO_SHOW и будущие BOOKED — priceFinal при отмене не обнуляется, grep `priceFinal: null` пуст), минус только платежи, привязанные к записям (стр. 32-40). Платёж, добавленный кнопкой «Добавить платёж» во вкладке «Оплаты», создаётся без appointmentId (payments-tab.tsx:293-300) и в этот расчёт не попадает. Кнопка «Изменить запись» в карточке без onClick (стр. 107-110).

PT-09 P2 · СРЕДНИЙ мёртвая механика

Выгрузка данных пациента (DSAR) не работает ни по одному пути: кнопка недостижима, скачивание 405, ссылка невалидна, пароля нет, расшифровка невозможна

ГДЕ

src/app/[locale]/crm/settings/dsar/_components/dsar-review-client.tsx:147, src/app/api/crm/dsar/exports/[id]/download/route.ts:23, src/app/api/crm/dsar/exports/[id]/download/route.ts:47, src/server/dsar/zip.ts:255, src/server/workers/data-export.ts:476, src/app/[locale]/crm/patients/[id]/_components/patient-quick-actions.tsx:60

СЦЕНАРИЙ

Пациент по закону просит копию своих данных. Администратор не находит кнопку в карточке. Пациент сам запрашивает в Mini App — получает ZIP и пароль в Telegram, запускает decrypt.sh — «Decryption failed — wrong

passphrase?». Админ в настройках жмёт «Скачать» — ошибка.

ПОСЛЕДСТВИЯ

Обязательство по выдаче персональных данных (закон о персональных данных РУз) не выполняется; функция выглядит готовой, но не работает.

ЧТО СДЕЛАТЬ

Добавить кнопку выгрузки в карточку (ADMIN). Сменить метод в UI на GET или роут на POST; отдавать файл через стриминговый прокси `fetchObject`, а не `presigned URL`. Для админского пути показывать пароль один раз в ответе/UI. Отказаться от `GCM+openssl enc`: использовать ZIP с AES (стандартный инструмент) или AES-CBC+HMAC, реально расшифровываемый штатным `openssl`, и покрыть тестом «зашифровал → расшифровал скриптом». Создавать бакет при старте или класть в основной бакет с префиксом.

КРИТЕРИЙ ПРИЁМКИ

Админ из карточки запускает выгрузку, в Настройки → DSAR скачивает архив и видит пароль; `decrypt.sh` из архива на чистом macOS/Linux с OpenSSL 3 восстанавливает `data.json`; `e2e/интеграционный тест` на полный цикл.

ДОКАЗАТЕЛЬСТВО В КОДЕ

1) Запуск выгрузки из CRM есть только в `PatientQuickActions` (`patient-quick-actions.tsx:60-72`), который используется лишь в неимпортируемом `PatientHeader` — кнопки в интерфейсе нет. 2) Кнопка «Скачать» в Настройки → DSAR шлёт `method: "POST"` (`dsar-review-client.tsx:146-151`), а роут экспортирует только GET (`download/route.ts:23`) — ответ 405, `toast «downloadError»`. 3) Даже GET отдаёт `getSignedUrl(...)` (стр. 47) — `presigned URL` через `MINIO_PUBLIC_URL`, который за `nginx /files/` даёт `SignatureDoesNotMatch` (это прямо описано в заголовке `src/app/api/crm/documents/file/route.ts:4-8`). 4) Если у админа нет `telegramId`, воркер оставляет архив в `READY` (`data-export.ts:476`), а пароль генерируется и хранится только `bcrypt`-хешем (стр. 379-380) — его никто никогда не видит; комментарий «`shown once at creation`» в `download/route.ts:6-8` ложен (`POST data-export` возвращает только `jobId`). 5) `decrypt.sh` в архиве вызывает `openssl enc -d -aes-256-gcm ... -tag`` (`zip.ts:255-260`); `openssl enc` не поддерживает AEAD — локальная проверка на OpenSSL 3.6.3 даёт «`enc: AEAD ciphers not supported`» и «`unknown option -tag`»; соль передаётся бинарной строкой, ошибки `kdf` маскируются ``|| true`` (стр. 247-252). 6) Бакет по умолчанию «`exports`» (`data-export.ts:66`) не создаётся ни кодом, ни `ops/docker-compose` — при отсутствии `MINIO_EXPORTS_BUCKET` загрузка падает на стадии `upload` (требует проверки на проде).

PT-10 P2 · СРЕДНИЙ баг

Заккрытие или передача случая не останавливает активные назначения — напоминания о лекарствах продолжают уходить

ГДЕ

`src/app/api/crm/cases/[id]/route.ts:147`, `src/server/workers/medication-reminder.ts:113`

СЦЕНАРИЙ

Врач закрывает случай «Передан в другую клинику» — пациент продолжает ежедневно получать в Telegram «Пора принять Карбамазепин 200 мг», хотя лечение ведёт уже другой врач и схема могла смениться.

ПОСЛЕДСТВИЯ

Пациент получает устаревшие указания по приёму препаратов — риск для здоровья и жалобы.

ЧТО СДЕЛАТЬ

При закрытии случая переводить `ACTIVE`-назначения в `COMPLETED/CANCELLED` (с подтверждением в диалоге закрытия) или фильтровать в воркере по `medicalCase.status = OPEN`; публиковать `prescription.updated`.

КРИТЕРИЙ ПРИЁМКИ

После закрытия случая ни одно назначение этого случая не попадает в тик напоминаний; тест на воркер/PATCH.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`PATCH` случая при переходе `OPEN→RESOLVED/ABANDONED/TRANSFERRED` только ставит `closedAt/closedReason` (`cases/[id]/route.ts:146-162`) и не трогает `Prescription`. Воркер напоминаний выбирает ``status: "ACTIVE", remindersEnabled: true, clinic.medicationRemindersEnabled, patient.deletedAt: null`` (`medication-reminder.ts:113-119`) — статус случая не учитывается. Для назначений с `days=null` (бессрочные) напоминания идут бесконечно.

Медицинские данные доступны и редактируемы немедицинскими ролями: скрытие вкладки «Медицина» косметическое

ГДЕ

src/app/[locale]/crm/patients/[id]/_hooks/use-current-role.ts:40, src/app/[locale]/crm/patients/[id]/_components/tabs/medical-tab.tsx:98, src/app/[locale]/crm/patients/[id]/_components/patient-info-panel.tsx:169, src/app/api/crm/patients/route.ts:127, src/app/api/crm/cases/[id]/route.ts:123, src/app/api/crm/patients/[id]/diagnoses/route.ts:27

СЦЕНАРИЙ

Врач пишет в «Медицина → Заметки» план лечения и деликатные жалобы. Оператор колл-центра видит этот текст на обзоре карточки и может выгрузить паспорта и заметки всей базы, листая /api/crm/patients?limit=200. Ресепшен, внося «просит перезвонить после 18:00» в «Заметки», затирает план лечения врача. Ресепшен может изменить диагноз и SOAP в случае.

ПОСЛЕДСТВИЯ

Нарушение принципа минимально необходимого доступа к PHI; порча клинических записей немедицинским персоналом без следа в медицинской истории.

ЧТО СДЕЛАТЬ

Разделить поля: служебная заметка (Patient.notes) и клиническая заметка (отдельная сущность с автором/датой, только клинические роли). Закрыть на сервере GET/PATCH медицинских данных, деталей случаев и soapDraft/diagnosis для RECEPTIONIST/CALL_OPERATOR (роль-матрица в createApiHandler). Из списка пациентов не отдавать passport/notes/summaryCache — только поля для таблицы.

КРИТЕРИЙ ПРИЁМКИ

Под ролью CALL_OPERATOR GET /api/crm/patients/[id]/diagnoses и PATCH /api/crm/cases/[id] {diagnosisText} возвращают 403; ответ /api/crm/patients не содержит passport/notes; правка «Заметок» ресепшеном не меняет клиническую заметку врача.

ДОКАЗАТЕЛЬСТВО В КОДЕ

canViewMedical скрывает вкладку «Медицина» для RECEPTIONIST и CALL_OPERATOR только в UI (use-current-role.ts:40-42, patient-card-client.tsx:152-155). Серверные GET аллергий/хронических/диагнозов открыты всем пяти ролям (allergies/route.ts:33, chronic-conditions/route.ts:24, diagnoses/route.ts:27). Во вкладке «Медицина» блок «Заметки (свободная форма) — Жалобы, наблюдения, план лечения» (ru.json:1403-1404) пишет в Patient.notes (medical-tab.tsx:98) — ТО ЖЕ поле, что показывается и редактируется в блоке «Заметки» на обзоре, доступном ресепшену (patient-info-panel.tsx:141-184, save на 169; PATCH разрешён RECEPTIONIST, patients/[id]/route.ts:65). Список пациентов отдаёт расшифрованные passport и notes каждой строки всем ролям включая CALL_OPERATOR, limit до 200 (route.ts:25, 127). Случаи: GET детали открыт CALL_OPERATOR (cases/[id]/route.ts:78), PATCH разрешён RECEPTIONIST, включая diagnosisText, diagnosisCode и soapDraft (стр. 123; schemas/medical-case.ts:29-36).

Назначения: выбор врача-автора в форме игнорируется, любой врач может менять и удалять чужие назначения, время «9:00» молча отбрасывается

ГДЕ

src/app/[locale]/crm/cases/[id]/_components/prescriptions-card.tsx:244, src/app/api/crm/cases/[id]/prescriptions/route.ts:46, src/app/api/crm/cases/[id]/prescriptions/[prescriptionId]/route.ts:46, src/app/[locale]/crm/cases/[id]/_components/prescriptions-card.tsx:80

СЦЕНАРИЙ

Врач Б выбирает в форме «Врач: А» (ведущий врач случая) — назначение сохраняется от имени Б. Врач Б меняет дозу в назначении врача А — в карточке пациента назначение по-прежнему подписано врачом А. Врач вводит «8:00, 20:00» — получает ошибку «укажите время», а «08:00, 9:00» — напоминание только в 08:00.

ПОСЛЕДСТВИЯ

Искажение авторства медицинских назначений; пропущенные напоминания о приёме.

ЧТО СДЕЛАТЬ

Для DOCTOR скрыть/зафиксировать выбор автора в UI; при изменении чужого назначения требовать права (автор или ADMIN) и сохранять lastEditedBy; парсить время с ведущим нулём/нормализовать «9:00»→«09:00» и валидировать диапазон 00:00–23:59, показывать ошибку по отброшенным значениям.

КРИТЕРИЙ ПРИЁМКИ

Врач не может выбрать другого автора; PATCH чужого назначения врачом (не автором) даёт 403 или фиксирует редактора; «9:00, 21:00» сохраняется как ["09:00","21:00"], «25:99» отклоняется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Форма требует выбрать врача (``if (!form.id && !form.doctorId) toast doctorRequired``, `prescriptions-card.tsx:244`; `select rx-doctor` стр. 391-406), но для роли DOCTOR сервер игнорирует `body.doctorId` и пишет автором текущего врача (`prescriptions/route.ts:46-56`). PATCH/DELETE (`prescriptions/[prescriptionId]/route.ts:37-60, 137-161`) проверяют только роль ADMIN/DOCTOR и принадлежность к случаю — любой врач меняет препарат/дозу чужого назначения, а автором остаётся исходный врач. `parseTimes` оставляет только строки строго ``^\\d{2}:\\d{2}$`` (стр. 76-81): «9:00, 21:00» сохраняется как только «21:00» без предупреждения; «25:99» проходит.

РТ-13 Р2 · СРЕДНИЙ мокап / заглушка

Плитки KPI на странице «Пациенты» считаются по первым 50 загруженным строкам, «Средний чек» — это средний LTV

ГДЕ

`src/app/[locale]/crm/patients/_components/patients-tiles.tsx:61`, `src/app/[locale]/crm/patients/_components/patients-tiles.tsx:82`, `src/app/[locale]/crm/patients/_components/patients-tiles.tsx:150`, `src/app/[locale]/crm/patients/_components/patients-page-client.tsx:154`

СЦЕНАРИЙ

В клинике 800 пациентов. Администратор открывает «Пациенты»: «Активные: 12 (1,5%)», «Спящие >30 дней: 5 (0,6%)», «Средний чек: 1 800 000 сум». Пролистывает таблицу вниз — «Активные» становится 35. Руководитель принимает решения по этим цифрам.

ПОСЛЕДСТВИЯ

Управленческие показатели на главном экране модуля ложные и нестабильные.

ЧТО СДЕЛАТЬ

Считать KPI на сервере по всей выборке (`count/aggregate` с теми же фильтрами), средний чек — как среднее `priceFinal` завершённых визитов или сумма оплат / число визитов. Плитки брать из отдельного эндпоинта, а не из `rows`.

КРИТЕРИЙ ПРИЁМКИ

Значения плиток не меняются при прокрутке списка и совпадают с SQL-подсчётом по всей базе клиники; «Средний чек» равен средней оплате за визит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`PatientsTiles` получает ``rows`` — только загруженные страницы бесконечного списка (по 50, `patients-page-client.tsx:87, 154`). Счётчики «Новые за неделю», «Активные», «Спящие >30 дней» считаются циклом по `rows` (стр. 69-81), а проценты делятся на ``total`` — число всех пациентов с сервера (стр. 82-85). «Средний чек» = ``ltvSum / ltvCount`` — средний пожизненный доход пациента, а не средний чек визита (стр. 77-80, 86, 150-158). При пролистывании списка цифры в плитках меняются.

РТ-14 Р2 · СРЕДНИЙ баг

Правка телефона пациента на занятый или некорректный номер даёт 500; имя с годом при правке не разбирается

ГДЕ

`src/app/api/crm/patients/[id]/route.ts:74`, `src/lib/phone.ts:13`, `src/lib/api-handler.ts:342`, `src/app/[locale]/doctor/patients/[id]/_components/overview-section.tsx:66`

СЦЕНАРИЙ

Врач исправляет номер пациента на настоящий, который уже записан на дубль-карту, — `toast «internal_error»`. Врач правит ФИО как привык «Турматов О 1969» — год остаётся в имени, поиск по году и строка «г.р.» в заключении снова ломаются.

ПОСЛЕДСТВИЯ

Нельзя исправить телефон без понимания ошибки; внутренние сообщения БД уходят в UI; возвращается проблема «год в имени».

ЧТО СДЕЛАТЬ

В PATCH валидировать телефон (минимальная длина цифр), проверять дубль и отвечать 409 `phone_already_exists` с `id` карты, ловить P2002; применять `parsePatientIdentity` к `fullName` как в POST; не отдавать текст Prisma в ответе.

КРИТЕРИЙ ПРИЁМКИ

PATCH на занятый номер возвращает 409 с patientId существующей карты; PATCH fullName «Иванов И 1980» сохраняет имя без года и birthDate 1980-01-01 (если не задана).

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH: `if (body.phone) data.phoneNormalized = normalizePhone(body.phone)` и сразу `prisma.patient.update` (route.ts:73-81) — без проверки уникальности (clinicId, phoneNormalized), без try/catch P2002. normalizePhone для «abc» возвращает "" (phone.ts:13-16) — второй такой пациент тоже упирается в уникальность. api-handler возвращает 500 `{error:"internal\_error", message: <текст Prisma>}` (стр. 342-352). POST делает pre-check (patients/route.ts:163-173), PATCH — нет. Кроме того, POST разбирает «Турматов О 1969» в имя+birthDate, а PATCH (единственный путь правки имени — кабинет врача, overview-section.tsx:66-80) сохраняет год прямо в fullName.

РТ-15 Р2 · СРЕДНИЙ мёртвая механика

Сегменты пациентов (VIP/Новые/Активные/Остывают/Потерянные) никогда не пересчитываются — вкладки, страницы сегментов и «Центр действий» мертвы

ГДЕ

src/app/api/crm/patients/route.ts:32, src/app/api/crm/patients/route.ts:105, src/app/[locale]/crm/patient/s/segments/_components/segment-view.tsx:72, src/app/[locale]/crm/patients/_components/patients-right-rail.tsx:118, src/app/[locale]/crm/patients/_components/patients-tiles.tsx:141, src/app/api/miniapp/auth/route.ts:102

СЦЕНАРИЙ

Администратор открывает вкладку «Активные» — 0 пациентов; «Новые» — вся база. Нажимает плитку «Спящие >30 дней: 42» — открывается пустая страница «Остывают». Запускает рассылку по сегменту «Активные» — не уходит ни одному пациенту; по «Новым» — уходит всем, включая постоянных.

ПОСЛЕДСТВИЯ

Ключевой инструмент CRM-сегментации — макет; рассылки уходят не тем людям; решения принимаются по нулевым/ложным цифрам.

ЧТО СДЕЛАТЬ

Сделать ежедневный пересчёт segment (крон) по правилам на основе visitsCount/lastVisitAt/ltv (единые с doctor-patient-segments.ts) и пересчёт при завершении визита; либо убрать сегменты из UI и рассылок до реализации. Плитку «Спящие» вести на фильтр, считающийся тем же правилом.

КРИТЕРИЙ ПРИЁМКИ

После завершения второго визита пациент переходит в ACTIVE; через N дней без визита — в DORMANT. Счётчики вкладок и страниц сегментов совпадают с плитками. Тест на функцию классификации и крон.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Patient.segment имеет default NEW (schema.prisma:1758) и ставится NEW при создании (patients/route.ts:198, miniapp/auth/route.ts:102). Ни один воркер/крон/маршрут не пересчитывает segment (grep по src/server и src/app/api: писатели segment есть только в создании и в ручном PATCH). При этом на нём построены: вкладки-счётчики и фильтр списка (route.ts:32, 105-124), страницы /crm/patients/segments/active и /dormant (segment-view.tsx:72-75 фильтруют segment=ACTIVE/DORMANT), «Центр действий» в правой панели (patients-right-rail.tsx:118-146: «Позвонить пациентам — давно не были» = число DORMANT, «Написать в Telegram — не записаны после консультации» = число NEW), рассылки по сегменту (server/campaigns/audience.ts:116-117). Плитка «Спящие >30 дней» считает по lastVisitAt, но ведёт на страницу с фильтром segment=DORMANT (patients-tiles.tsx:141-149).

РТ-16 Р2 · СРЕДНИЙ баг

Случай: «Оплачено», нумерация «Первичный/Повторный» и «Итого начислено» считают отменённые и будущие визиты

ГДЕ

src/app/[locale]/crm/cases/[id]/_components/case-detail-client.tsx:923, src/app/[locale]/crm/cases/[id]/_components/case-detail-client.tsx:816, src/app/api/crm/cases/[id]/pdf/route.ts:178, src/app/api/crm/cases/[id]/pdf/route.ts:260, src/app/[locale]/crm/cases/[id]/_components/case-detail-client.tsx:921

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Пациент отменил визит 01.09, пришёл 03.09 и оплатил 300 000 сум, записан на 20.09. В случае: «Оплачено: 900 000 сум», визит 03.09 помечен «Повторный (2-й)», в печатной карте «Итого начислено 600 000 сум» и тот же

«Повторный».

ПОСЛЕДСТВИЯ

Неверные деньги и неверная медицинская классификация визитов в документе, который отдаёт пациенту/страховой.

ЧТО СДЕЛАТЬ

Загружать платежи в детали случая и показывать реально оплаченное; нумерацию визитов и «первичный» считать только по состоявшимся визитам (как в `recomputeAppointmentPrice`); «Итого» — только по завершённым/в работе; подписи привести в соответствие.

КРИТЕРИЙ ПРИЁМКИ

Для сценария выше: «Оплачено 300 000», визит 03.09 — «Первичный», в печати «Итого начислено 300 000».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`CaseStatsCard` суммирует ``a.priceFinal`` всех визитов случая (включая `CANCELLED`, `NO_SHOW`, будущие `BOOKED` и неоплаченные) и выводит под подписью «Оплачено» (`statsTotalPaid`, `ru.json:1611`) (`case-detail-client.tsx:921-935, 953`); код сам признаёт в комментарии, что оплаты не загружены. «Бесплатных повторов» считает любой `priceFinal===0`, включая отменённые. Номер визита = индекс в массиве всех записей (стр. 816-817) — отменённый первый визит делает реальный первый «Повторным». В печатной «Карте случая» «Первичный/Повторный (N-я)» тоже по индексу всех записей (`pdf/route.ts:260, 287`), тогда как движок цен исключает `CANCELLED/NO_SHOW` из определения первого визита (`recompute-appointment-price.ts:216-224`); «Итого начислено» включает будущие `BOOKED` (стр. 178-184).

PT-17 P2 · СРЕДНИЙ баг

Сортировка таблицы пациентов по колонкам не работает — меняется только направление

ГДЕ

`src/app/[locale]/crm/patients/_components/patients-page-client.tsx:184`, `src/app/[locale]/crm/patients/_hooks/use-patients-filters.ts:92`, `src/app/[locale]/crm/patients/_components/patients-table.tsx:253`

СЦЕНАРИЙ

Ресепшен кликает заголовок «Последний визит», чтобы увидеть, кто давно не был, — порядок не меняется (остаётся «по дате регистрации»), стрелка на колонке не появляется.

ПОСЛЕДСТВИЯ

Сортировка списка пациентов фактически недоступна.

ЧТО СДЕЛАТЬ

Добавить в `usePatientsFilters` метод `setFilters(patch)` для атомарного обновления нескольких ключей (или функциональное обновление от актуальных `searchParams`) и использовать его в `onSortChange`.

КРИТЕРИЙ ПРИЁМКИ

Клик по «LTV» меняет URL на `sort=ltv&dir=desc` и порядок строк; повторный клик переключает на `asc`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`onSortChange` вызывает подряд ``setFilter("sort", sort); setFilter("dir", dir);`` (`patients-page-client.tsx:184-187`). `setFilter` строит ``next = { ...state, [key]: value }`` из замкнутого ``state`` и делает `router.replace` (`use-patients-filters.ts:92-104`). Второй вызов собирает URL из того же старого `state` без нового `sort` и заменяет первый — в URL остаётся старая колонка сортировки. При клике на другую колонку `handleSortChange` передаёт (новая колонка, "desc") (`patients-table.tsx:253-259`).

PT-18 P2 · СРЕДНИЙ баг

Фильтр «Дата посещения» на самом деле фильтрует по дате регистрации и теряет последний день периода

ГДЕ

`src/app/[locale]/crm/patients/_components/patients-filters.tsx:149`, `src/app/[locale]/crm/patients/_components/patients-filters.tsx:189`, `src/app/api/crm/patients/route.ts:41`

СЦЕНАРИЙ

Администратор выбирает «Дата посещения 01.09–15.09», чтобы увидеть, кто был на приёме, — получает пациентов, зарегистрированных в этот период, без зарегистрированных 15-го.

ПОСЛЕДСТВИЯ

Выборки и решения на основе неверного фильтра.

ЧТО СДЕЛАТЬ

Либо переименовать в «Дата регистрации», либо реализовать фильтр по lastVisitAt/визитам; границы периода считать через tashkentDayBounds (to = конец дня по Ташкенту, lt следующего дня); убрать дублирующий фильтр сегмента.

КРИТЕРИЙ ПРИЁМКИ

Пациент, зарегистрированный 15.09 в 14:00 по Ташкенту, попадает в период 01.09–15.09; подпись соответствует полю.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ячейка фильтра подписана `filters.labelDate` = «Дата посещения» (ru.json:373), aria-label «Последний визит от», но пишет registeredFrom/registeredTo (patients-filters.tsx:149-195), а сервер фильтрует `createdAt` (route.ts:41-46). registeredTo приходит как «2026-09-15» → z.coerce.date → 2026-09-15T00:00Z, условие `lte` отсекает всех, зарегистрированных 15.09 после 05:00 по Ташкенту. Также «Статус» и «Сегменты» — два фильтра на один и тот же параметр segment (стр. 125, 198).

РТ-19 Р2 · СРЕДНИЙ баг

Экспорт пациентов: игнорирует поиск и даты с экрана, CSV-инъекция через ФИО из Telegram, деньги в тийинах, у не-админов «в очереди» без результата

ГДЕ

src/app/[locale]/crm/patients/_components/export-button.tsx:26, src/server/workers/exports.ts:80, src/server/workers/exports.ts:142, src/app/api/crm/patients/export/route.ts:27, src/app/api/miniapp/auth/route.ts:45, src/server/workers/exports.ts:100

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Администратор ищет «Турматов», фильтрует период и жмёт «Экспорт» — получает всю базу. Кто-то зарегистрировался в боте с именем «=HYPERLINK("http://evil","Нажми")» — при открытии CSV в Excel формула выполняется. В файле LTV «15000000» вместо 150 000 сум. Ресепшен жмёт «Экспорт» — видит «в очереди», файла никогда нет.

ПОСЛЕДСТВИЯ

Неверные выгрузки, уязвимость при открытии в Excel, путаница в суммах ×100.

ЧТО СДЕЛАТЬ

Передавать и применять все фильтры экрана (q, даты) через общую функцию построения where со списком; префиксовать ячейки, начинающиеся с = + - @ \t, апострофом; выгружать суммы в сумах с подписью; скрывать кнопку для не-ADMIN и показывать ошибку.

КРИТЕРИЙ ПРИЁМКИ

CSV совпадает с отфильтрованным на экране списком; ячейка ФИО «=1+1» выгружается как «'=1+1»; LTV 150 000 сум выгружается как 150000.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ExportButton передаёт только segment/gender/source/tag (export-button.tsx:26-42); поиск q и период registeredFrom/To, видимые в фильтрах, отбрасываются, exportPatients их и не поддерживает (exports.ts:142-150). csvEscape (exports.ts:80-92 и patients/export/route.ts:27-39) экранирует только кавычки/запятые, не нейтрализует ведущие = + - @; fullName пациента из Mini App берётся из профиля Telegram (miniapp/auth/route.ts:45-49), т.е. контролируется посторонним. Колонки ltv и balance выгружаются в тийинах без пересчёта (exports.ts:97-111). POST /api/crm/exports только ADMIN, но кнопка видна всем, toast «поставлено в очередь» показывается сразу (export-button.tsx:40-41), ошибка 403 не отображается.

РТ-20 Р3 · НИЗКИЙ производительность

/api/crm/patients/stats тянет до 7000 строк на каждое открытие списка; список пересчитывает count и groupBy на каждой подгрузке

ГДЕ

src/app/api/crm/patients/stats/route.ts:70, src/app/api/crm/patients/route.ts:103

СЦЕНАРИЙ

В базе 10 000 пациентов: каждое открытие «Пациенты» передаёт по сети тысячи ФИО и телефонов, которые не показываются; поиск врача на каждую букву делает 3 полных скана таблицы.

ПОСЛЕДСТВИЯ

Лишняя нагрузка на БД/сеть и лишняя передача PII; неточные данные для рассылок.

ЧТО СДЕЛАТЬ

Разделить эндпоинт: считать источники/теги агрегатами SQL (groupBy/unnest), дни рождения — SQL по месяцу/дню; count/groupBy считать только для первой страницы.

КРИТЕРИЙ ПРИЁМКИ

Эндпоинт статистики не возвращает и не читает построчно ФИО/телефоны; загрузка второй страницы списка выполняет один запрос.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Статистика читает до 5000 пациентов с ФИО/телефоном (для дней рождения и возрастных групп) и 2000 строк тегов (stats/route.ts:57-86), но правая панель списка использует только sources; birthdays/ageGroups/gender нигде не отображаются (grep), а при >5000 пациентов с датой рождения «возрастные группы» и «дни рождения» неполные (take без сортировки). topTags для рассылок считаются по случайным 2000 строкам. Список пациентов при каждой догрузке страницы заново выполняет count и groupBy по всей таблице с ILIKE-поиском (route.ts:103-113), в т.ч. при каждом нажатии клавиши в поиске врача.

РТ-21 РЗ · НИЗКИЙ баг

В печатной «Карте случая» и в инфопанели дата рождения «только год» печатается как 01.01.ГГГГ; время формирования документа в UTC

ГДЕ

src/app/api/crm/cases/[id]/pdf/route.ts:309, src/app/api/crm/cases/[id]/pdf/route.ts:593, src/app/[locale]/crm/patients/[id]/_components/patient-info-panel.tsx:100, src/lib/patients/parse-identity.ts:110

СЦЕНАРИЙ

72 из 94 пациентов заведены с годом в имени. В распечатке карты случая у них «Дата рождения: 01.01.1969», документ «сформирован в 09:15», хотя печатали в 14:15.

ПОСЛЕДСТВИЯ

Выдуманная дата рождения на медицинском документе; неверное время формирования.

ЧТО СДЕЛАТЬ

В PDF и инфопанели использовать isYearOnlyBirthDate → «1969 г.р.»; время формирования форматировать через formatClinicDateTime (Asia/Tashkent).

КРИТЕРИЙ ПРИЁМКИ

Для пациента с birthDate 1969-01-01T00:00Z печать и инфопанель показывают «1969 г.р.»; время формирования совпадает с ташкентским.

ДОКАЗАТЕЛЬСТВО В КОДЕ

parse-identity.ts:110-130 прямо требует: год-only дату (1 января UTC) показывать как «1969 г.р.», «печатать 01.01.1987 — значит выдумать факт на медицинском документе». Список и шапка это соблюдают (isYearOnlyBirthDate), но PDF случая печатает `formatDate(mcase.patient.birthDate, locale, "short")` (pdf/route.ts:309-311, 532-533), а инфопанель — `formatDate(patient.birthDate, ...)` (patient-info-panel.tsx:96-103). Подпись «Сформировано: ... HH:MM» формируется formatDate без timeZone на сервере в UTC (pdf/route.ts:593) — на 5 часов раньше ташкентского времени.

РТ-22 РЗ · НИЗКИЙ баг

Диалог приглашения в Telegram никогда не показывает «уже привязан» — вместо этого ошибка «conflict»

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/telegram-invite-dialog.tsx:87, src/server/http.ts:33, src/app/api/crm/patients/[id]/telegram-invite/route.ts:88

СЦЕНАРИЙ

Пациент только что нажал /start по ссылке, а у ресепшена открыта старая карточка; он жмёт «Telegram» — видит ошибку «conflict» вместо «Пациент уже привязан как @username».

ПОСЛЕДСТВИЯ

Непонятная ошибка для персонала, мёртвая ветка UI.

ЧТО СДЕЛАТЬ

Проверять `body.reason === "already\_linked"`.

КРИТЕРИЙ ПРИЁМКИ

При 409 already_linked диалог показывает блок «Уже привязан» с username.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Сервер отвечает ``conflict("already_linked", ...) → `{ error: "conflict", reason: "already_linked", telegramId, telegramUsername }`` (http.ts:33-42, route.ts:87-92). Клиент проверяет ``body.error === "already_linked"``` (dialog:87) — условие никогда не выполняется, уходит в ветку ``{ kind: "error", message: "conflict" }`` (стр. 102-106).

РТ-23 РЗ · НИЗКИЙ бар

Жалоба, диагноз и заметки случая редактируются однострочным полем — многострочный текст схлопывается при сохранении

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/inline-field.tsx:151, src/app/[locale]/crm/cases/[id]/_components/case-detail-client.tsx:583, src/app/[locale]/crm/cases/[id]/_components/case-detail-client.tsx:605

СЦЕНАРИЙ

В случае записана жалоба из Mini App в несколько строк; врач исправляет одно слово — весь текст сохраняется одной строкой, в печатной карте структура потеряна.

ПОСЛЕДСТВИЯ

Порча клинического текста при редактировании.

ЧТО СДЕЛАТЬ

Для этих полей использовать Textarea (сохранение по Ctrl+Enter/кнопке).

КРИТЕРИЙ ПРИЁМКИ

Правка многострочной жалобы сохраняет переводы строк.

ДОКАЗАТЕЛЬСТВО В КОДЕ

InlineField рендерит ``<Input>`` (inline-field.tsx:151), Enter сохраняет. Им редактируются primaryComplaint, diagnosisText и notes случая (case-detail-client.tsx:583, 605, 646), которые отображаются с whitespace-pre-line и в печати как многострочный блок. Браузер удаляет переводы строк из value однострочного input, и первая же правка сохраняет текст одной строкой.

РТ-24 РЗ · НИЗКИЙ мокап / заглушка

Карточка пациента заполнена макетными элементами: вечный «Активный пациент», аватар «онлайн», кнопки без действий, выдуманные сроки

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/patient-hero.tsx:164, src/app/[locale]/crm/patients/[id]/_components/patient-hero.tsx:214, src/app/[locale]/crm/patients/[id]/_components/patient-right-rail.tsx:177, src/app/[locale]/crm/patients/[id]/_components/patient-right-rail.tsx:204, src/app/[locale]/crm/patients/[id]/_components/patient-recommendations-card.tsx:47, src/app/[locale]/crm/patients/_components/patient-right-rail.tsx:158

СЦЕНАРИЙ

Ресепшен кликает «Позвонить пациентам — давно не были», «Показать все рекомендации», «Подробнее» в блоке коммуникаций — ничего не происходит. Карта удалённого по DSAR пациента помечена «Активный пациент» с зелёной точкой «онлайн».

ПОСЛЕДСТВИЯ

Интерфейс вводит персонал в заблуждение и выглядит готовым там, где функциональности нет.

ЧТО СДЕЛАТЬ

Убрать или подключить каждую кнопку: статус пациента вычислять (активный/спящий/удалён по deletedAt), убрать индикатор online, «Подробнее» переключать вкладку (поддержать ?tab=), рекомендации либо на реальных правилах с реальными сроками (из протоколов/записей), либо скрыть; «Центр действий» вести на отфильтрованные списки/очередь обзвона.

КРИТЕРИЙ ПРИЁМКИ

В карточке и списке нет кликабельных элементов без действия; статус анонимизированной карты отображается как «Удалён»; «Подробнее» открывает вкладку «Коммуникации».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Аватар всегда ``status="online"``` (patient-hero.tsx:164); бейдж «Активный пациент» выводится безусловно (стр. 213-215), в правой панели «Статус: Активный» безусловно (patient-right-rail.tsx:172-180) — в том числе для анонимизированных карт. Ссылка «Подробнее» ведёт на ``?tab=communications`` (стр. 204), но PatientCardClient

читает только hash `#case-` — переход ничего не открывает. «Рекомендуемые действия» — правила с выдуманным числом «Рекомендуется через {14 - floor(since/2)} дней» (patient-recommendations-card.tsx:42-49), «Напомнить о записи» зависит от nextVisitAt, который никогда не пишется; кнопка «Показать все рекомендации» без onClick (стр. 131-135). На странице списка «Центр действий»: три пункта с курсором-указателем и шевроном без обработчиков, «Смотреть все действия» и «Все сегменты» без onClick (patients-right-rail.tsx:158-207, 249-255). «Изменить запись» в финансовой карточке без onClick (patient-finance-card.tsx:107-110).

РТ-25 РЗ · НИЗКИЙ мёртвая механика

Мёртвые поля пациента: «Следующий визит» никогда не заполняется, скидка пациента не применяется, номер карты P-00125 нигде не показывается

ГДЕ

src/app/[locale]/crm/patients/_components/patients-table.tsx:362, src/app/[locale]/crm/patients/[id]/_components/patient-hero.tsx:101, src/lib/patient-number.ts:13, src/server/schemas/patient.ts:46

СЦЕНАРИЙ

Пациент записан на завтра, но в списке «Нет записи». Звонящий называет номер карты — его нельзя найти поиском. У двух пациентов, зарегистрированных подряд на ресепшене, в карточке одинаковый ID: CMF3K2.

ПОСЛЕДСТВИЯ

Персонал видит ложную информацию о записи; фича номеров карт вложена, но недоступна; ID вводит в заблуждение.

ЧТО СДЕЛАТЬ

Поддерживать nextVisitAt при создании/переносе/отмене/завершении записей (или вычислять ближайшую BOOKED-запись в запросе). Показывать formatPatientNumber(patientNumber) вместо cuid-префикса и искать по номеру в списке. discountPct пациента либо применять при бронировании, либо убрать из схемы.

КРИТЕРИЙ ПРИЁМКИ

Пациент с будущей записью показывает её дату в колонке; в карточке виден «P-000NN», поиск «P-00125» находит пациента.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Patient.nextVisitAt никем не пишется (grep по src: только чтение и сиды), при этом колонка «Следующий визит» в списке (patients-table.tsx:362-399) у реальных пациентов всегда «— Нет записи», а рекомендация «Записать на повторный визит» срабатывает даже при наличии будущей записи. Patient.discountPct принимается API (schemas/patient.ts:46), но нигде не применяется в ценообразовании (grep по appointments/pricing — используется только скидка записи из тела запроса). patientNumber выделяется атомарно при каждом создании, но formatPatientNumber/parsePatientNumber (patient-number.ts:13-30) не используются нигде; вместо номера карточка показывает ID: » + первые 6 символов cuid (patient-hero.tsx:101, 191) — это префикс метки времени, одинаковый у пациентов, созданных в одно и то же ~47-секундное окно.

РТ-26 РЗ · НИЗКИЙ баг

Поиск пациентов матчит подстроки в шифротексте паспорта — в выдаче появляются случайные пациенты

ГДЕ

src/app/api/crm/patients/route.ts:56, src/server/crypto/field-cipher.ts:174

СЦЕНАРИЙ

Врач в поиске кабинета (limit=8, сортировка по дате создания) набирает «Али»: в первые 8 результатов попадают пациенты, у которых в base64-шифротексте паспорта есть «ali», и нужный Алиев вытесняется из выдачи.

ПОСЛЕДСТВИЯ

Нерелевантная выдача в основном поиске, риск выбрать не того пациента.

ЧТО СДЕЛАТЬ

Убрать passport из OR (или искать только по строкам без префикса v\d+), а для поиска по паспорту добавить blind-index (HMAC) колонку.

КРИТЕРИЙ ПРИЁМКИ

Поиск «v1» и двухбуквенные запросы не возвращают пациентов только из-за шифротекста; тест с зашифрованным паспортом.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В OR поиска стоит `{ passport: { contains: term, mode: "insensitive" } }` (route.ts:54-57). Паспорт хранится как `v1:<iv

base64>:<tag base64>:<ct base64>` (field-cipher.ts:174-179) — ~55-60 символов base64. Регистронезависимый ILIKE по такому тексту для коротких термов («Ali», «ов», «AA») даёт случайные совпадения, а для «v1» — все пациенты с паспортом. Комментарий в коде признаёт, что по шифротексту искать нельзя, но условие оставлено.

PT-27 P3 · НИЗКИЙ баг

Пороги «приоритет», «LTV высокий/средний» и «апселл» заданы в тийинах как суммы: 10 000 и 3 000 сум

ГДЕ

src/app/[locale]/crm/patients/_components/patients-table.tsx:102, src/app/[locale]/crm/patients/[id]/_components/patient-hero.tsx:131, src/app/[locale]/crm/patients/[id]/_components/patient-recommendations-card.tsx:73, src/app/[locale]/crm/patients/[id]/_components/patient-recommendations-card.tsx:81

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Пациент заплатил за одну консультацию 150 000 сум (15 000 000 тийин) — в таблице у него красный «Высокий приоритет», в карточке LTV «Высокий», и ему рекомендуют апселл, как и всем остальным платившим.

ПОСЛЕДСТВИЯ

Колонка «Приоритет» и оценки LTV бессмысленны — все платившие одинаково «горячие».

ЧТО СДЕЛАТЬ

Перевести пороги в тийины осознанно (например 100 000 000 и 30 000 000 = 1 000 000 и 300 000 сум) и вынести в общую константу/настройку клиники.

КРИТЕРИЙ ПРИЁМКИ

Пациент с LTV 150 000 сум имеет низкий приоритет, с LTV 1 500 000 сум — высокий; одинаковые пороги в таблице, карточке и рекомендациях.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ltv хранится в тийинах (formatMoney делит на 100). priorityFor: `if (p.ltv >= 1\_000\_000) return "high"; if (p.ltv >= 300\_000) return "medium"` (patients-table.tsx:102-107) — это 10 000 и 3 000 сум. То же в карточке: ltvTone high при `patient.ltv >= 1\_000\_000` (patient-hero.tsx:130-141) и рекомендация «Предложить комплексное обследование» при `patient.ltv >= 300\_000` (patient-recommendations-card.tsx:73).

ST · Настройки клиники, пользователи, филиалы, кабинеты, права

ST-01 P0 · КРИТИЧНО бар

Цена услуги в «Настройки → Услуги» показывается и сохраняется в тийинах под подписью «Цена (UZS)» — цены становятся в 100 раз ниже

ГДЕ

src/app/[locale]/crm/settings/services/_components/services-settings-client.tsx:294, src/app/[locale]/crm/settings/services/_components/services-settings-client.tsx:301, src/app/[locale]/crm/settings/services/_components/services-settings-client.tsx:418, src/app/[locale]/crm/settings/services/_components/services-settings-client.tsx:510, src/messages/ru.json:3731, src/server/onboarding/apply-playbook.ts:79, src/app/api/kiosk/doctors/route.ts:54, src/lib/format.ts:51, src/app/[locale]/crm/settings/services/_components/services-settings-client.tsx:508, prisma/seed.ts:185, src/server/appointments/book.ts:245

ТАКЖЕ НАШЛИ ЗОНЫ

Управление врачами (CRM)

СЦЕНАРИЙ

Админ открывает Настройки → Услуги: у «Консультации невролога» в колонке «Цена (UZS)» стоит 15000000. Решив, что это опечатка, вводит 150000 и уходит с поля — сохраняется 150 000 тийин = 1 500 сум. На ресепшене, в мини-аппе и на киоске приём теперь стоит 1 500 сум. Новая услуга, созданная с ценой «200000», стоит 2 000 сум.

ПОСЛЕДСТВИЯ

Прямая потеря выручки: каждая услуга, созданная или поправленная через этот экран, дешевле в 100 раз; цены на разных экранах расходятся.

ЧТО СДЕЛАТЬ

В ServicesSettingsClient показывать цену в суммах (priceBase/100, формат formatMoney) и при сохранении умножать на 100 (как в карточке врача). Покрыть round-trip тестом. По аудиту service.create/service.update найти услуги, изменённые через этот экран в проде, и исправить цены.

КРИТЕРИЙ ПРИЁМКИ

Услуга с priceBase=15 000 000 показывается в настройках как «150 000»; ввод 200 000 сохраняет priceBase=20 000 000; цена совпадает на экранах настроек, карточки врача, киоска и мини-аппа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Service.priceBase хранится в тийинах: apply-playbook.ts:77-79 («`Service.priceBase` is Int, in tiins»), formatMoney делит на 100 (format.ts:50-51), киоск делит на 100 (kiosk/doctors/route.ts:54), doctor-services.tsx:46 «priceBase in tiins (×100)». В ServicesSettingsClient строка таблицы рендерит `

ST-02 P2 · СРЕДНИЙ бар

«Секреты и токены» в настройках клиники: стёртое поле обнуляет токен/секрет бота, смена без переустановки webhook глушит бот, а уведомления продолжают числиться отправленными

ГДЕ

src/messages/ru.json:3636, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:682, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:703, src/app/api/crm/clinic/secrets/route.ts:37, src/app/api/crm/clinic/secrets/route.ts:45, src/app/api/telegram/webhook/[clinicSlug]/route.ts:356, src/server/notifications/adapters/tg-log-only.ts:15

СЦЕНАРИЙ

Админ хотел поправить username бота, по ошибке набрал и стёр символ в поле «Webhook secret», нажал «Сохранить секреты», ввёл пароль — секрет обнулён, все сообщения пациентов в бот получают 401 и теряются. Или вставил новый токен с опечаткой — напоминания в CRM «отправлены», но никому не приходят, вход в мини-апп (НМАС по токenu) перестаёт работать.

ПОСЛЕДСТВИЯ

Потеря входящих сообщений и напоминаний без видимой ошибки; мини-апп недоступен пациентам.

ЧТО СДЕЛАТЬ

Убрать дублирующий блок секретов (ботом управлять только мастером подключения/отключения) либо: не отправлять пустые значения, валидировать токен через `getMe`, после смены токена/секрета автоматически вызывать `setWebhook`, не давать вводить `webhook secret` вручную. `LogOnly`-адаптер в проде должен пометить отправку как неуспешную с причиной «бот не подключён».

КРИТЕРИЙ ПРИЁМКИ

Стирание поля не меняет сохранённое значение; неверный токен отклоняется понятной ошибкой; после смены токена бот сразу получает сообщения; без токена отправки получают статус «не доставлено» с причиной.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Подсказка раздела: «Пустое поле — не менять» (`ru.json:3636`). Но `draft` заполняется `onChange` любым значением, включая "" после стирания (`clinic-settings-client.tsx:660, 682, 703`), а сервер делает ``writeTgBotToken(body.tgBotToken || null)`` и ``tgWebhookSecret || null`` (`secrets/route.ts:37, 45`) — т.е. стирает. Нет проверки токена через `getMe`, проверки, что бот не занят другой клиникой, и `setWebhook` — в отличие от мастера (`integrations/tg/connect/route.ts:87-124`). Вебхук отвечает 401 при пустом/несовпадающем секрете (`webhook route.ts:355-358`), а Telegram шлёт прежний `secret_token` до ручного «Переустановить webhook». При `tgBotToken=null` адаптер уходит в `LogOnlyTgAdapter`, который возвращает фиктивный `messageId` (`tg-log-only.ts:15-23`) → отправки записываются как отправленные.

ST-03 P2 · СРЕДНИЙ мёртвая механика

Администратор клиники не может сбросить 2FA сотруднику — потеря телефона означает блокировку до вмешательства разработчика

ГДЕ

`src/app/api/crm/me/totp/disable/route.ts:68`, `src/server/auth/security-policy.ts:16`, `src/app/api/crm/users/[id]/reset-password/route.ts:47`, `src/app/api/crm/me/totp/disable/route.ts:39`, `src/app/api/crm/users/[id]/route.ts:91`, `src/app/api/platform/users/[id]/route.ts:85`

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

Врач в клинике с обязательной 2FA или единственный администратор теряет телефон и коды восстановления. Админ делает «Сбросить пароль» — сотрудник всё равно не входит (нужен код), кнопки «Сбросить 2FA» нет.

ПОСЛЕДСТВИЯ

Сотрудник или вся администрация клиники выпадает из работы до правки БД.

ЧТО СДЕЛАТЬ

ADMIN-действие «Сбросить 2FA» с повторным вводом пароля админа, аудитом, удалением сессий пользователя и принудительной повторной регистрацией TOTP при входе; статус 2FA в таблице; для единственного админа — процедура через платформу.

КРИТЕРИЙ ПРИЁМКИ

Админ сбрасывает 2FA сотрудника, тот входит по паролю и сразу проходит регистрацию TOTP; действие видно в аудите.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Единственное место, обнуляющее `totpSecret/totpEnabledAt`, — `self-service /api/crm/me/totp/disable (:68-69)`; ни в `/api/crm/users`, ни в `/api/platform` сброса нет (`grep` по `totp`). ADMIN и SUPER_ADMIN — обязательная 2FA (`MANDATORY_2FA_ROLES`, `security-policy.ts:16-19`). `reset-password` меняет только пароль (:47-50), таблица пользователей не показывает статус 2FA.

ST-04 P2 · СРЕДНИЙ баг

Жизненный цикл логина врача ломает привязку к карточке: после повторной активации — бесконечный редирект, после смены роли карточку нельзя перепривязать

ГДЕ

`src/app/api/crm/users/[id]/route.ts:76`, `src/app/api/crm/users/[id]/route.ts:159`, `src/app/[locale]/crm/settings/users/_components/users-settings-client.tsx:778`, `src/app/[locale]/doctor/layout.tsx:65`, `src/app/[locale]/crm/layout.tsx:65`, `src/app/api/crm/users/route.ts:84`

СЦЕНАРИЙ

Врач уходит в отпуск — админ нажимает «Деактивировать». Через месяц включает тумблер «Активен». Врач входит — браузер «слишком много перенаправлений». Админ пробует создать новый логин с той же почтой —

«conflict». Врача временно перевели в регистратуру — вернуть роль DOCTOR через интерфейс невозможно.

ПОСЛЕДСТВИЯ

Врач не может работать в кабинете; восстановление только правкой БД разработчиком.

ЧТО СДЕЛАТЬ

Единая логика деактивации (PATCH active=false ведёт себя как DELETE: отвязка карточки, запрет деактивировать себя); при реактивации/назначении DOCTOR требовать выбор карточки; разрешить PATCH doctorId для роли DOCTOR; при уходе с роли DOCTOR отвязывать карточку; в doctor/layout вместо редиректа в /crm показывать экран «карточка не привязана».

КРИТЕРИЙ ПРИЁМКИ

Деактивация → реактивация врача с выбором карточки ведёт в рабочий кабинет; врач без карточки видит понятную страницу без цикла; после DOCTOR→RECEPTIONIST карточка снова в списке «врачи без логина».

ДОКАЗАТЕЛЬСТВО В КОДЕ

DELETE отвязывает карточку (``tx.doctor.updateMany({ where: { userId: id }, data: { userId: null } })``, :159-162). Повторное включение через «Редактировать» (PATCH active=true) привязку не восстанавливает: ``promotingToDoctor = body.role === "DOCTOR" && before.role !== "DOCTOR" (:76)`, для роли DOCTOR doctorId игнорируется; UI скрывает DOCTOR у не-врачей (users-settings-client.tsx:776-779). Врач без карточки: doctor/layout.tsx:65 → ``/crm?error=doctor_profile_missing``, а CRM-layout при DOCTOR_CABINET_ENABLED=1 безусловно редиректит DOCTOR на /doctor (crm/layout.tsx:63-66) → цикл. Новый логин с той же почтой не создать: email глобально уникален и занят деактивированной записью (users/route.ts:84-89). Обратно: PATCH роли DOCTOR→другая или active=false через «Редактировать» карточку не отвязывает (в отличие от DELETE), карточка пропадает из списка «врачи без логина» (фильтр `userId===null`), а запрет само-деактивации есть только в DELETE (:146-148).

ST-05 P2 · СРЕДНИЙ мокап / заглушка

Интеграции «Платежи», «Телефония» и «Настроить» у Telegram сохраняют ключи, которые никто не читает, но показывают «Подключено»

ГДЕ

src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:194, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:208, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:269, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:170, src/server/notifications/adapters/index.ts:43, src/server/telephony/index.ts:63, src/app/api/calls/sip/event/route.ts:331, src/messages/ru.json:3898, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:76, src/server/notifications/adapters/index.ts:58

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Админ вводит merchant ID и ключ Payme, подтверждает паролем — карточка «Платежи» зелёная «Подключено», но онлайн-оплаты у пациентов нет. Настраивает SIP — «Подключено», звонки не логируются. Пытается сменить токен бота через «Настроить» — «Сохранено», бот работает со старым токеном.

ПОСЛЕДСТВИЯ

Руководство и персонал уверены, что интеграции работают; платёжные ключи хранятся без пользы.

ЧТО СДЕЛАТЬ

Скрыть карточки Платежи/Телефония (или пометить «в разработке» без статуса «Подключено») до реальной интеграции; для Telegram убрать ProviderEditDialog — управление только мастером подключения/отключения; для SIP добавить/генерировать webhookSecret; обновить тексты ru/uz.

КРИТЕРИЙ ПРИЁМКИ

Ни одна интеграция без рабочего потребителя не показывает «Подключено»; каждое сохранение на странице реально меняет поведение системы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/crm/integrations пишет ProviderConnection (kind PAYME/OTHER/TELEGRAM, secretCipher, config). Потребители: TG-адаптер выбирает реальный бот по clinic.tgBotToken (``if (hasBotToken) return new TelegramClinicAdapter``, adapters/index.ts:43), ProviderConnection игнорирует; телефония возвращает ``getTelephony()`` (LogOnly) в обеих ветках (telephony/index.ts:55, 63); SIP-вебхук читает config.webhookSecret, которого форма не содержит (поля OTHER — только server/username), в проде без него 401 (sip/event/route.ts:331-333). PAYME/CLICK/UZUM не читает ни один модуль (grep providerConnection). Статус «ok», если ``conn.active && conn.hasSecret`` (integrations-client.tsx:269). Для подключённого бота «Настроить»

открывает тот же ProviderEditDialog TELEGRAM (:170) — новый «секрет» не влияет на бота. Карточка в индексе настроек обещает «SMS, Telegram, платежи и телефония» (ru.json:3898), хотя SMS удалены.

ST-06 P2 · СРЕДНИЙ бар

Отключение филиала «запирает» сотрудников в пустом филиале; филиал по умолчанию можно отключить, выбор филиала переживает выход и смену пользователя

ГДЕ

src/app/api/crm/branches/[id]/route.ts:41, src/app/api/crm/branches/[id]/route.ts:93, src/server/branches/resolve-branch.ts:52, src/components/layout/branch-switcher.tsx:143, src/components/layout/branch-switcher.tsx:148, src/lib/api-handler.ts:151, src/server/platform/branch-cookie.ts:54, src/app/api/crm/branches/active/route.ts:34, src/lib/prisma.ts:157, src/components/layout/crm-topbar.tsx:390

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

В клинике 2 филиала, регистратор выбрал «Филиал 2». Админ его отключает. У регистратора пустые очередь, расписание и список врачей, переключатель исчез (остался один филиал), подпись «Все филиалы» — сбросить выбор можно только очисткой cookies. Отключён дефолтный филиал — новые кабинеты и врачи создаются без филиала и пропадают из отфильтрованных экранов. На общем ПК следующий сотрудник наследует филиал предыдущего.

ПОСЛЕДСТВИЯ

Сотрудники видят пустые экраны и думают, что данные пропали; новые сущности без филиала.

ЧТО СДЕЛАТЬ

Валидировать branchId из cookie при каждом запросе (существует, активен, принадлежит клинике) и игнорировать иначе; показывать переключатель, если выбран неактивный филиал; очищать cookie при выходе; запретить отключать isDefault без назначения нового; предупреждать о врачах, кабинетах и будущих записях филиала.

КРИТЕРИЙ ПРИЁМКИ

После отключения филиала сотрудник с его cookie видит всю клинику; отключить дефолтный филиал без нового дефолта нельзя; после выхода cookie филиала удалён.

ДОКАЗАТЕЛЬСТВО В КОДЕ

При isActive=false проверяется только «не последний активный филиал» (branches/[id]/route.ts:39-50, 93-102); isDefault, привязанные врачи/кабинеты/будущие записи не проверяются. Cookie active_branch_id (30 дней, HttpOnly, не привязан к пользователю, в коде нигде не очищается при выходе) читается api-handler без повторной проверки (151-153) и добавляет фильтр branchId к Doctor/Cabinet/Appointment/DoctorSchedule/DoctorTimeOff (prisma.ts:242-245). Переключатель грузит только активные филиалы и прячется при ≤1 филиале (branch-switcher.tsx:73, 143); если текущий филиал не найден, подпись «Все филиалы» (148-149). resolveEffectiveBranchId ищет `isDefault: true, isActive: true` (resolve-branch.ts:52-56) — после отключения дефолтного вернёт null.

ST-07 P2 · СРЕДНИЙ безопасность

Переключатель «Клиника активна» у админа клиники: выключает мини-апп и онлайн-запись без подтверждения и снимает блокировку, поставленную платформой

ГДЕ

src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:184, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:303, src/server/schemas/settings.ts:36, src/app/api/crm/clinic/route.ts:81, src/server/clinic-public/resolve.ts:67, src/server/miniapp/handler.ts:127, src/app/api/platform/clinics/[id]/route.ts:113

СЦЕНАРИЙ

(а) Админ случайно снимает тумблер «Клиника активна» рядом с адресом и жмёт «Сохранить» — у всех пациентов мини-апп «не найдено», онлайн-запись и ТВ в холле гаснут, а CRM работает как обычно, и никто не замечает. (б) Платформа отключила клинику за неуплату; у админа открыта вкладка настроек со старым active=true — любое сохранение (например, телефона) молча включает клинику обратно.

ПОСЛЕДСТВИЯ

Простой пациентского канала записи; арендатор обходит платформенную блокировку.

ЧТО СДЕЛАТЬ

Убрать active из UpdateClinicSettingsSchema и формы (управление только из /admin платформы); если нужен

«режим паузы» — отдельное поле с подтверждением и баннером в CRM. Сохранять форму диффом (только изменённые поля).

КРИТЕРИЙ ПРИЁМКИ

PATCH /api/crm/clinic с {active:false|true} от ADMIN отклоняется или игнорируется; сохранение настроек после платформенной деактивации не меняет active; тумблера в UI нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

UpdateClinicSettingsSchema принимает active (settings.ts:36), PATCH /api/crm/clinic пишет `data: body as never` (clinic/route.ts:81-84). Клиент кладёт active в payload при каждом «Сохранить» из формы, загруженной один раз (clinic-settings-client.tsx:184, тумблер :300-310, без подтверждения). active=false приводит к 404 в clinic-public/resolve.ts:67, miniapp/handler.ts:127, api/miniapp/clinic/route.ts:36 и tv/d/[token]/route.ts:81. Платформа деактивирует клинику тем же флагом (platform/clinics/[id] DELETE → `data: { active: false }`, :111-114). Вход персонала в CRM флаг не проверяет (auth.ts authorize проверяет только user.active).

ST-08 P2 · СРЕДНИЙ переводы

Приветствие и авто-сообщения бота: плейсхолдеры утекают пациентам, узбекский текст не редактируется, приветствие захардкожено «Neurofax»

ГДЕ

src/app/api/crm/settings/notifications/templates/[id]/route.ts:63, src/server/notifications/rules.ts:98, src/server/notifications/auto-messages.ts:249, src/server/telegram/state.ts:134, src/app/api/crm/settings/auto-messages/route.ts:89, src/server/notifications/auto-messages.ts:42

СЦЕНАРИЙ

Админ в «Шаблонах уведомлений» добавляет имя пациента в приветствие — новые пациенты получают «Здравствуйте, {{patient.firstName}}!». Меняет в виджете текст напоминания (новый адрес) — узбекоязычные пациенты продолжают получать старый адрес.

ПОСЛЕДСТВИЯ

Непрофессиональные сообщения пациентам и устаревшая информация для узбекоязычной аудитории.

ЧТО СДЕЛАТЬ

Для ключа patient.welcome — пустой whitelist и в редакторе настроек, UZ-вкладку скрыть или отправлять по языку; в виджете авто-сообщений редактировать RU и UZ; дефолтный текст строить из названия клиники.

КРИТЕРИЙ ПРИЁМКИ

Сохранение приветствия с {{...}} в любом редакторе отклоняется (400); правка напоминания в виджете меняет и bodyUz (или UI явно даёт два поля).

ДОКАЗАТЕЛЬСТВО В КОДЕ

Шаблон patient.welcome имеет trigger MANUAL → logicalTriggerKey = "manual" → allowedKeysFor возвращает объединение всех плейсхолдеров (rules.ts:98-104), поэтому редактор в «Настройки → Уведомления» пропускает «{{patient.firstName}}», а бот шлёт приветствие дословно (state.ts:134; readWelcomeConfig возвращает bodyRu без рендера, auto-messages.ts:249). Виджет авто-сообщений это запрещает (allowedKeysForKind welcome → []), редактор настроек — нет; UZ-вкладка приветствия в настройках ни на что не влияет. PATCH авто-сообщений пишет только bodyRu (auto-messages/route.ts:89) — у «Напоминания за 1 день» и «Спасибо за визит» узбекский текст остаётся старым. Дефолтное приветствие для любой клиники: «Это клиника Neurofax.» (auto-messages.ts:42-55).

ST-09 P2 · СРЕДНИЙ баг

Фильтр журнала аудита по датам теряет весь последний день и сдвигает границы на 5 часов

ГДЕ

src/server/schemas/audit.ts:8, src/app/api/crm/audit/route.ts:26, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:305, src/app/api/crm/audit/patient-views/route.ts:45

СЦЕНАРИЙ

Админ выясняет, кто открывал карту пациента 23.09: фильтр «с 23.09 по 23.09» — пусто; «с 22.09 по 23.09» — события 22.09 после 05:00 и 23.09 до 05:00.

ПОСЛЕДСТВИЯ

Неверные результаты расследований доступа к медданным.

ЧТО СДЕЛАТЬ

Интерпретировать даты как границы суток по Ташкенту (tashkentDayBoundsForDateString): from — начало дня, to

— строго меньше начала следующего дня.

КРИТЕРИЙ ПРИЁМКИ

Фильтр «с 23.09 по 23.09» возвращает все события 23.09 с 00:00 до 23:59 по Ташкенту (тест).

ДОКАЗАТЕЛЬСТВО В КОДЕ

UI передаёт from/to из `<input type="date">` строкой YYYY-MM-DD (audit-log-client.tsx:302-318, 234-235); схема `z.coerce.date()` (audit.ts:8-9) превращает её в полночь UTC; фильтр `createdAt: { gte: from, lte: to }` (route.ts:26-31). `to="2026-09-23" → lte 2026-09-23T00:00Z (05:00 Ташкента)` — выбранный последний день исключён целиком; from начинается в 05:00 Ташкента. То же в журнале просмотров карт пациентов (patient-views/route.ts:27-28, 45-48).

ST-10 РЗ · НИЗКИЙ UX

/crm/services и /crm/rooms открывают админские редакторы для всех ролей

ГДЕ

src/app/[locale]/crm/services/page.tsx:1, src/app/[locale]/crm/rooms/page.tsx:1, src/app/[locale]/crm/settings/layout.tsx:24, src/app/[locale]/crm/rooms/page.tsx:4

ТАКЖЕ НАШЛИ ЗОНЫ

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония

СЦЕНАРИЙ

Регистратор по ссылке открывает «Кабинеты», меняет этаж — тост «Forbidden».

ПОСЛЕДСТВИЯ

Путаница, лишние попытки правок.

ЧТО СДЕЛАТЬ

Проверка роли на этих страницах (redirect) или режим только для чтения.

КРИТЕРИЙ ПРИЁМКИ

Не-админ на /crm/rooms и /crm/services видит только чтение или получает редирект.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Страницы рендерят ServicesSettingsClient/CabinetsSettingsClient вне settings-layout, где стоит проверка ADMIN (settings/layout.tsx:24-26); сами страницы роль не проверяют. API вернёт 403, но полноценный UI редактирования показан.

ST-11 РЗ · НИЗКИЙ безопасность

API пользователей отдаёт в браузер и записывает в журнал аудита TOTP-секреты и хэши кодов восстановления сотрудников

ГДЕ

src/app/api/crm/users/[id]/route.ts:17, src/app/api/crm/users/[id]/route.ts:168, src/app/api/crm/users/route.ts:20, src/app/api/crm/users/route.ts:66, src/app/api/crm/users/route.ts:148, src/app/api/crm/users/[id]/route.ts:32, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:382

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

Любой администратор в DevTools на странице «Пользователи» или в журнале аудита после деактивации видит TOTP-секреты и хэши кодов коллег; при legacy-plaintext или утечке ключа может клонировать второй фактор другого админа/врача и вместе со сбросом пароля подписывать заключения от его имени.

ПОСЛЕДСТВИЯ

Ослабление 2FA; бессрочное хранение секретов в журнале.

ЧТО СДЕЛАТЬ

Явный allow-list публичных полей (id, email, name, role, phone, active, createdAt, lastLoginAt, totpEnabled: boolean) во всех ответах users-API и в аудите; миграцией вычистить секреты из уже записанных meta.

КРИТЕРИЙ ПРИЁМКИ

Ответы /api/crm/users* не содержат totpSecret/pendingTotpSecret/recoveryCodesHash; новые записи user.deactivate без этих полей; тест.

ДОКАЗАТЕЛЬСТВО В КОДЕ

redactUser удаляет только passwordHash (users/route.ts:20-26, users/[id]/route.ts:17-21), а модель User содержит totpSecret, pendingTotpSecret, recoveryCodesHash, lastSessionRotatedAt. Эти поля возвращаются из GET

/api/crm/users (:66), POST (:148), GET/PATCH /api/crm/users/[id] (:32, :122). DELETE пишет в AuditLog `meta: { before: redactUser(before) }` (:164-169) — полная строка с секретами навсегда в журнале, доступном всем ADMIN на /crm/settings/audit. Секрет зашифрован AES-GCM, но auth.ts допускает legacy plaintext.

ST-12 P3 · НИЗКИЙ безопасность

GET авто-сообщений создаёт шаблоны в БД: просмотр включает новые рассылки и обходит режим «только просмотр»

ГДЕ

src/app/api/crm/settings/auto-messages/route.ts:39, src/server/notifications/auto-messages.ts:157, src/lib/view-only.ts:21

СЦЕНАРИЙ

Сотрудник поддержки платформы в режиме «только просмотр» (или админ, просто открывший виджет) открывает авто-сообщения клиники, у которой их не было, — появляются 3 активных шаблона, пациентам начинают приходить «Спасибо за визит».

ПОСЛЕДСТВИЯ

Изменение поведения рассылок клиники без явного действия и в режиме, обещающем только чтение.

ЧТО СДЕЛАТЬ

Провижининг шаблонов перенести в миграцию/онбординг или в PATCH; новые шаблоны создавать выключенными; GET — только чтение.

КРИТЕРИЙ ПРИЁМКИ

GET не пишет в БД (тест с моком prisma); новые авто-сообщения создаются выключенными.

ДОКАЗАТЕЛЬСТВО В КОДЕ

VIEW_ONLY-имперсонация блокирует только не-GET методы (view-only.ts:9, 20-21). GET /api/crm/settings/auto-messages вызывает getAutoMessages → ensureAutoMessageTemplates → createMany с isActive: true (auto-messages.ts:145-173), включая «Спасибо за визит» (APPOINTMENT_COMPLETED), который после этого начнёт уходить пациентам.

ST-13 P3 · НИЗКИЙ целостность данных

PATCH кабинета принимает любой branchId без проверки и не переносит врача; проверка «кабинет занят» зависит от выбранного филиала

ГДЕ

src/app/api/crm/cabinets/[id]/route.ts:53, src/server/schemas/cabinet.ts:18, src/app/api/crm/cabinets/[id]/route.ts:41, src/lib/prisma.ts:242

СЦЕНАРИЙ

С выбранным «Филиалом 1» админ деактивирует кабинет, в котором сидит врач с branchId=null — кабинет отключён, врач указывает на неактивный кабинет.

ПОСЛЕДСТВИЯ

Рассогласование врач ↔ кабинет ↔ филиал.

ЧТО СДЕЛАТЬ

В PATCH валидировать branchId через resolveEffectiveBranchId и запрещать перенос при наличии врача (или переносить обоих); проверку занятости делать без branch-фильтра.

КРИТЕРИЙ ПРИЁМКИ

PATCH с чужим/неактивным branchId → 422; деактивация занятого кабинета невозможна при любом выбранном филиале.

ДОКАЗАТЕЛЬСТВО В КОДЕ

UpdateCabinetSchema = CreateCabinetSchema.partial() включает branchId (cabinet.ts:15, 18); PATCH пишет `data: body as never` (:53) без resolveEffectiveBranchId (в отличие от POST) — филиал не проверяется на принадлежность клинике и активность, привязанный врач остаётся в старом филиале. Проверка занятости `prisma.doctor.findUnique({ where: { cabinetId: id } })` (:41-44, :74-77) при выбранном филиале получает фильтр branchId (prisma.ts:242-245): врач из другого филиала или без филиала не найдётся, и занятый кабинет можно деактивировать.

«Тариф и счета»: оплата Click/Payme — заглушка, «Сменить тариф» плодит неоплачиваемые счета, заголовки на английском

ГДЕ

src/app/[locale]/crm/settings/billing/page.tsx:95, src/app/[locale]/crm/settings/billing/pay/[id]/_components/pay-stub-client.tsx:103, src/app/api/crm/billing/upgrade/route.ts:70, src/server/billing/invoice.ts:90, src/server/billing/payments/click.ts:102

СЦЕНАРИЙ

Админ трижды жмёт «Перейти на Pro», затем «Оплатить через Click» — ошибка; в истории три неоплачиваемых счёта и надпись «Ожидаем оплату».

ПОСЛЕДСТВИЯ

Путаница с биллингом, мусорные счета, съеденная нумерация.

ЧТО СДЕЛАТЬ

Скрыть смену тарифа/оплату до подключения провайдеров или показывать реквизиты для ручной оплаты; переиспользовать открытый DRAFT-счёт на тот же тариф; перевести строки через i18n.

КРИТЕРИЙ ПРИЁМКИ

Повторный апгрейд на тот же тариф не создаёт новый счёт; без провайдеров кнопки оплаты скрыты; строки из ru/uz.json.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Без CLICK_SERVICE_ID/CLICK_MERCHANT_ID (их нет в .env.example) адаптер возвращает isStub (click.ts:102-113), клиент показывает «провайдер не настроен» (pay-stub-client.tsx:103-106). Каждое нажатие «Перейти на ...» вызывает createUpgradeInvoice → новый DRAFT-счёт с новым номером и pendingPlanId (upgrade/route.ts:70-76, invoice.ts:88-112) без переиспользования открытого. Без подписки страница показывает хардкод «Billing» / «No subscription found for this clinic.» (billing/page.tsx:92-100).

Вход в систему чувствителен к регистру email

ГДЕ

src/lib/auth.ts:96, src/app/api/crm/users/route.ts:84, src/app/[locale]/crm/settings/users/_components/users-settings-client.tsx:493

СЦЕНАРИЙ

Врач вводит «Nodira@neurofax.uz» с заглавной (автозамена на планшете) — «Неверный email или пароль», идёт к админу за сбросом.

ПОСЛЕДСТВИЯ

Лишние обращения и сбросы паролей.

ЧТО СДЕЛАТЬ

Нормализовать email (trim + lowercase) при входе, создании и изменении; миграция существующих; уникальный индекс по lower(email).

КРИТЕРИЙ ПРИЁМКИ

Вход с любым регистром успешен; нельзя создать двух пользователей, различающихся только регистром.

ДОКАЗАТЕЛЬСТВО В КОДЕ

authorize ищет `prisma.user.findUnique({ where: { email } })` (auth.ts:96) без нормализации, форма входа регистр не приводит; UI настроек приводит email к нижнему регистру (users-settings-client.tsx:493, 760), но API (users/route.ts:84-86) и другие пути создания (платформа, саморегистрация) — нет; уникальность email в Postgres регистрозависима.

Лимиты тарифа (пользователи, филиалы, пациенты, записи) и часть платных функций нигде не применяются

ГДЕ

src/server/billing/plan-limits.ts:222, src/app/api/crm/users/route.ts:73, src/app/api/crm/branches/route.ts:43, src/lib/feature-flags.ts:15, src/app/[locale]/crm/telegram/page.tsx:27, src/app/api/crm/settings/billing/route.ts:240, src/app/[locale]/crm/analytics/_components/analytics-hub-cards.tsx:24, src/app/api/crm/analytics/cohorts/route.ts:18, src/components/layout/crm-sidebar.tsx:127

ТАКЖЕ НАШЛИ ЗОНЫ

Аналитика, выручка, оплаты, биллинг, экспорты

СЦЕНАРИЙ

Клиника на basic (5 пользователей, 1 филиал, 50 пациентов) создаёт 30 пользователей и 3 филиала — страница «Тариф» показывает использование, ничего не блокирует. Клиника на Pro настраивает «свой поддомен» — он не работает.

ПОСЛЕДСТВИЯ

Биллинговая модель платформы не работает; платная опция «свой поддомен» — пустышка.

ЧТО СДЕЛАТЬ

Вызывать ensureQuotaForApi в создании пациентов/записей; проверки maxUsers/maxBranches в POST users/branches; гейтить API телеграм-инбокса; реализовать резолв клиники по customSubdomain или скрыть поле.

КРИТЕРИЙ ПРИЁМКИ

На basic 6-й пользователь и 2-й филиал получают понятный отказ (402); поддомен клиники открывает её публичные страницы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ensureQuotaForApi/ensurePatientLimit/ensureAppointmentLimit (plan-limits.ts:222) нигде не вызываются (grep: только определение). POST /api/crm/users (:73-149) и POST /api/crm/branches (:43-101) не читают maxUsers/maxBranches — эти флаги используются только в /admin UI. hasTelegramInbox гейтит только страницу (telegram/page.tsx:27), API /api/crm/conversations флаг не проверяет. customSubdomain сохраняется (branding/route.ts:240-243), но нигде не используется для маршрутизации (grep вне настроек пуст).

ST-17 РЗ · НИЗКИЙ мёртвая механика

Настройки клиники «Шаг сетки», «Начало/конец дня», «Часовой пояс» и часовой пояс филиала сохраняются, но не влияют на запись

ГДЕ

src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:378, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:354, src/server/services/appointments.ts:170, src/server/services/appointments.ts:210, src/server/notifications/triggers.ts:247, src/app/[locale]/crm/settings/branches/_components/branches-settings-client.tsx:257

СЦЕНАРИЙ

Админ ставит «Шаг сетки» 30 минут и «Начало дня» 08:00 — сетка записи остаётся по 20 минут, врачи без расписания доступны с 09:00. Смена часового пояса на Asia/Samarkand меняет время только в тексте уведомлений.

ПОСЛЕДСТВИЯ

Админ считает, что настроил расписание клиники; жалобы «настройки не сохраняются».

ЧТО СДЕЛАТЬ

Использовать clinic.slotMin и workdayStart/End в findAvailableSlots (и часовой пояс клиники вместо жёсткого Ташкента) либо убрать поля из UI / пометить, что они только отображаются пациентам.

КРИТЕРИЙ ПРИЁМКИ

Изменение «Шага сетки» меняет интервалы в выборе слота; либо полей нет в интерфейсе.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Сетка слотов: DEFAULT_SLOT_STEP_MIN = 20 (appointments.ts:170), окно для врача без расписания захардкожено [{ start: "09:00", end: "19:00" }] (:210); slots/available и miniapp/slots передают только длительность услуг. clinic.slotMin/workdayStart/workdayEnd в расчёте не читаются (grep: только отображение часов в мини-аппе). Часовой пояс клиники используют лишь triggers.ts:247 (текст уведомлений) и risk-today; остальное — жёстко Asia/Tashkent (tashkentDayBounds). Branch.timezone нигде не читается.

Ошибки в настройках показываются сырыми кодами, переключатели не откатываются при отказе сервера

ГДЕ

src/app/[locale]/crm/settings/_hooks/use-settings-api.ts:42, src/app/[locale]/crm/settings/users/_components/users-settings-client.tsx:463, src/app/[locale]/crm/settings/cabinets/_components/cabinets-settings-client.tsx:80, src/app/[locale]/crm/settings/cabinets/_components/cabinets-settings-client.tsx:260, src/app/[locale]/crm/settings/_components/password-reentry-dialog.tsx:62, src/app/[locale]/crm/settings/integrations/_components/tg-connect-wizard.tsx:149, src/server/schemas/settings.ts:18

СЦЕНАРИЙ

Админ создаёт пользователя с занятой почтой — тост «conflict»; отключает занятый кабинет — «CabinetOccupied», а тумблер показывает «Неактивен», хотя кабинет активен.

ПОСЛЕДСТВИЯ

Непонятные сообщения; интерфейс показывает неправду до перезагрузки.

ЧТО СДЕЛАТЬ

Карта reason → i18n для всех 4xx настроек; откат оптимистичного состояния в onError; trim токена перед connect; нормализация "" → null для email.

КРИТЕРИЙ ПРИЁМКИ

Перечисленные ошибки показываются по-русски/по-узбекски; после отказа сервера переключатель возвращается в исходное положение.

ДОКАЗАТЕЛЬСТВО В КОДЕ

settingsFetch кладёт в message поле error («conflict», «Forbidden», «CabinetOccupied», «ValidationError») (use-settings-api.ts:42-47); диалоги пользователей делают toast.error(e.message) (users-settings-client.tsx:463, 723, 870, 922) без перевода reason (email_taken, doctor_taken, last_admin, cannot_deactivate_self). Перэксп /cabinet_occupied/i сравнивается с message «CabinetOccupied» и не срабатывает никогда (cabinets:80). Тумблеры активности кабинета/филиала сначала setLocal и при ошибке не откатываются (cabinets:258-262, branches:288-293). Неверный пароль в диалоге подтверждения — «Forbidden» (password-reentry-dialog.tsx:61-62). Мастер Telegram валидирует token.trim() (:198), а в connect шлёт неурезанный token (:149) — вставка из BotFather с пробелом/переводом строки падает «ValidationError». Email клиники нельзя очистить: "" не проходит z.string().email() (settings.ts:18).

Экран «Роли и права» утверждает, что отражает реализацию, но показывает ограничения, которых в коде нет

ГДЕ

src/messages/ru.json:3814, src/lib/permissions/matrix.ts:113, src/lib/permissions/matrix.ts:151, src/lib/permissions/matrix.ts:161, src/lib/permissions/matrix.ts:211, src/app/api/crm/appointments/route.ts:63, src/app/api/crm/payments/route.ts:33, src/app/api/crm/cases/route.ts:35

СЦЕНАРИЙ

Руководитель по экрану «Роли» убеждается, что медсёстры видят только сегодняшние записи, а врачи — только свои случаи, и выдаёт доступ стажёрам; фактически им открыта вся история клиники.

ПОСЛЕДСТВИЯ

Неверные решения о доступе к медданным; вводящий в заблуждение документ при проверках.

ЧТО СДЕЛАТЬ

Либо привести API к матрице (NURSE — только сегодня, DOCTOR — свои случаи/платежи), либо исправить матрицу и убрать утверждение «отражает реализацию»; автотест, сверяющий матрицу с ролями в роутах.

КРИТЕРИЙ ПРИЁМКИ

Каждая ячейка матрицы подтверждена автотестом соответствующего API; подпись экрана не утверждает непроверенного.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Подзаголовок «Источник: код. Эта таблица отражает текущую реализацию.» (ru.json:3814), тогда как matrix.ts:4-13: «documentation, not enforcement... Keep it in sync by hand». Расхождения: NURSE→Appointment read "today" (:113) — GET /api/crm/appointments ограничивает только DOCTOR (:62-63), медсестра видит все записи; DOCTOR→Payment "own" (:151) — payments GET пускает врача к платежам любого пациента при указании patientId (:33-39); DOCTOR→MedicalCase "own" (:161) — GET /api/crm/cases без фильтра по врачу

(:35-45); Settings read "all" для не-админов (:208-215) — settings/layout.tsx:24-26 их редиректит.

DR · Управление врачами (CRM)

DR-01 P1 · ВЫСОКИЙ баг

Страница «Врачи» и вкладки профиля врача всегда получают 400: запрос записей с limit=500 при максимуме 200, вся аналитика тихо показывает нули

ГДЕ

src/app/[locale]/crm/doctors/_hooks/use-doctors-stats.ts:73, src/app/[locale]/crm/doctors/[id]/_hooks/use-doctor-appointments.ts:44, src/server/schemas/appointment.ts:98, src/app/api/crm/appointments/route.ts:22, src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:131, src/app/[locale]/crm/doctors/[id]/_components/doctor-finances.tsx:46, src/app/[locale]/crm/doctors/_components/doctors-tiles.tsx:91, src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:39, src/app/[locale]/crm/doctors/[id]/_components/doctor-finances.tsx:49

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Администратор или ресепшн открывает «Врачи»: плитки «Доход», «Записей сегодня», «Средняя загрузка» по нулям, у всех врачей 0% загрузки и статус «Свободен», «Ближайшее окно 09:00», тепловая карта пустая. В профиле врача тепловая сетка недели пустая, «Средний чек» 0, вкладка «Пациенты» не грузится.

ПОСЛЕДСТВИЯ

Весь дашборд врачей и половина профиля не работают в проде, при этом выглядят рабочими (нули вместо ошибки) и вводят руководство в заблуждение о загрузке врачей.

ЧТО СДЕЛАТЬ

Не тянуть сырые записи на клиент: сделать серверный агрегирующий эндпоинт (например GET /api/crm/doctors/stats?from&to и /api/crm/doctors/[id]/appointments-aggr) с groupBy по doctorId/часу/статусу. Как минимум — привести limit к ≤ 200 и дочитывать страницы по nextCursor. Ошибки запросов показывать явно, а не нулями.

КРИТЕРИЙ ПРИЁМКИ

Открытие /crm/doctors не порождает 400 в сети; при наличии завершённых визитов за период плитки и карточки показывают ненулевые значения, совпадающие с отчётом /crm/analytics; тепловая сетка профиля отражает записи недели; вкладка «Пациенты» показывает список.

ДОКАЗАТЕЛЬСТВО В КОДЕ

useDoctorsAppointmentsAggr отправляет `limit: "500"` (use-doctors-stats.ts:73), useDoctorAppointments — `limit: "500"` (use-doctor-appointments.ts:44). QueryAppointmentSchema: `limit: z.coerce.number().int().min(1).max(200)` (appointment.ts:98); GET /api/crm/appointments при ошибке parseQuery возвращает 400 ValidationError (route.ts:21-23, http.ts:67-71). Проверено: `safeParse({limit:"500"}).success === false`. Хуки бросают `HTTP 400`, а потребители берут `query.data ?? []`: doctors-page-client.tsx:143,148 (все агрегаты пустые), doctor-heat-grid.tsx:126 (пустая сетка), doctor-finances.tsx:48-71 (средний чек 0, no-show 0%), doctor-patients-list.tsx:37-38.

DR-02 P2 · СРЕДНИЙ мёртвая механика

«Особая цена» и «Длительность» услуги у врача — мёртвая настройка: запись берёт базовую цену/длительность, киоск показывает другую цену, единицы ввода не определены

ГДЕ

src/app/[locale]/crm/doctors/[id]/_components/doctor-services.tsx:372, src/app/[locale]/crm/doctors/_components/new-doctor-dialog.tsx:574, src/server/schemas/doctor-services.ts:5, src/server/appointments/book.ts:236, src/app/api/kiosk/doctors/route.ts:54, src/app/api/crm/services/[id]/route.ts:72

СЦЕНАРИЙ

Админ ставит главврачу «Особая цена» 300000 на «Консультацию» (базовая 200 000 сум) и длительность 45 мин. Ресепшн записывает пациента к главврачу: счёт 200 000 сум, слот 30 мин. На киоске та же услуга показана как «3 000 сум». Если админ ввёл 30000000 (тийины), киоск покажет 300 000, а касса всё равно 200 000.

ПОСЛЕДСТВИЯ

Клиника считает, что берёт повышенную цену за старшего врача, а фактически теряет разницу; пациент видит на киоске одну цену, в кассе другую; длительные приёмы накладываются друг на друга.

ЧТО СДЕЛАТЬ

Либо реализовать: в book.ts и в расчёте слотов/длительности брать priceOverride/durationMinOverride связи

ServiceOnDoctor для выбранного врача (с приоритетом над каталогом), зафиксировать единицы как тийины в схеме и вводить в UI в сумах $\times 100$; либо убрать поля из UI и API. В PATCHN услуги при замене doctorIds сохранять override у оставшихся врачей (upsert/deleteMany только удалённых).

КРИТЕРИЙ ПРИЁМКИ

При override 300 000 сум у врача запись к нему на эту услугу получает priceBase/priceFinal 30000000 тийин и длительность 45 мин; киоск показывает «300 000»; изменение списка врачей услуги не сбрасывает override у врачей, оставшихся в списке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ServiceOnDoctor.priceOverride/durationMinOverride нигде не читаются при записи: book.ts:236-252 берёт priceBase/durationMin только из Service, стр. 373-386 priceSnap = `s.priceOverride ?? priceMap.get(...)` где s — строка запроса, а не ServiceOnDoctor; NewAppointmentDialog.tsx:380-386 считает длительность из `svc?.durationMin` каталога. Единственный потребитель — киоск: `price: Math.round((s.priceOverride ?? s.service.priceBase) / 100)` (трактует как тийины). При этом схема говорит «priceOverride is in UZS (integer, tiin-free)» (doctor-services.ts:5-6), а поле ввода в CRM принимает сырое число с плейсхолдером `String(s.priceBase)` в тийинах (doctor-services.tsx:372, new-doctor-dialog.tsx:574), рядом отформатированная базовая цена в сумах. Дополнительно PATCHN /api/crm/services/[id] с doctorIds удаляет все связи и создаёт новые с `priceOverride: null, durationMinOverride: null` (стр. 72-80) — введенные override молча стираются.

DR-03 P2 · СРЕДНИЙ баг

«Цена приёма (UZS)» при создании врача сохраняется без $\times 100$: пациенты живой очереди этого врача оплачивают сумму в 100 раз меньше

ГДЕ

src/app/[locale]/crm/doctors/_components/new-doctor-dialog.tsx:247, src/app/[locale]/crm/doctors/_components/new-doctor-dialog.tsx:480, src/messages/ru.json:2405, src/app/api/crm/doctors/route.ts:102, src/server/appointments/walkin.ts:224

СЦЕНАРИЙ

Админ заводит нового невролога и в «Цена приёма (UZS)» пишет 150000. Ресепшн регистрирует пациента в живую очередь (walk-in) к этому врачу: у записи priceFinal = 150000 тийин, в кассе к оплате «1 500 сум».

ПОСЛЕДСТВИЯ

Потеря денег по каждому walk-in-визиту врача; заниженная выручка и премия врача; исправить можно только через БД.

ЧТО СДЕЛАТЬ

В диалоге создания (и в будущей форме редактирования врача) вводить цену в сумах и умножать на 100 перед отправкой; подпись «Цена приёма, сум». Разово проверить существующие Doctor.pricePerVisit на проданных (значения < 100000 почти наверняка введены в сумах) и мигрировать.

КРИТЕРИЙ ПРИЁМКИ

Создание врача с «Цена приёма» = 150000 сохраняет pricePerVisit=15000000; регистрация walk-in к нему создаёт запись с priceFinal=15000000 и в кассе «150 000 сум».

ДОКАЗАТЕЛЬСТВО В КОДЕ

new-doctor-dialog.tsx:247-249 `const ppv = pricePerVisit.trim() ? Math.max(0, Number.parseInt(pricePerVisit, 10)) : null;` и `pricePerVisit: ppv` (стр. 259) — число уходит как ввели. Подпись ru.json:2405 «Цена приёма (UZS)», подсказка 2407 «Используется как базовая цена визита». API сохраняет `pricePerVisit: body.pricePerVisit ?? null` (route.ts:102). walkin.ts:224-225 пишет в запись живой очереди `priceBase: doctor.pricePerVisit ?? null, priceFinal: doctor.pricePerVisit ?? null` — это тийины (empty-slot-tomorrow.ts:242 тоже трактует pricePerVisit как тийины). Исправить потом через UI нельзя: PATCHN pricePerVisit нигде в CRM не вызывается.

DR-04 P2 · СРЕДНИЙ мёртвая механика

В CRM нет формы редактирования врача: ФИО, специализацию, цену приёма, процент зарплаты, цвет, фото и привязку к логину после создания изменить нельзя

ГДЕ

src/app/[locale]/crm/doctors/[id]/_components/doctor-header.tsx:127, src/app/api/crm/doctors/[id]/route.ts:55, src/app/[locale]/crm/doctors/[id]/_hooks/use-doctor.ts:120

СЦЕНАРИЙ

Админ опечатался в фамилии врача или ввёл цену приёма в сумах (см. находку про $\times 100$) либо договорились о новом проценте зарплаты. Исправить в CRM негде: остаётся только деактивировать и заводить врача заново

(теряя историю и кабинет) или править БД.

ПОСЛЕДСТВИЯ

Ошибки в карточке врача (включая деньги и зарплату) остаются навсегда; публичный сайт показывает неправильные данные.

ЧТО СДЕЛАТЬ

Добавить в профиле врача диалог «Редактировать» для ADMIN: имена RU/UZ, специализации, био, фото, цвет, slug, цена приёма (в сумах ×100), процент зарплаты, с отображением ошибок slug_taken; привязку к пользователю оставить в модуле пользователей.

КРИТЕРИЙ ПРИЁМКИ

Админ меняет фамилию и цену приёма врача в профиле, после сохранения изменения видны в списке, на публичном сайте и в новых walk-in записях; в аудит-логе есть doctor.update с diff.

ДОКАЗАТЕЛЬСТВО В КОДЕ

API PATCH /api/crm/doctors/[id] принимает весь UpdateDoctorSchema, но из UI он вызывается только с `{ isActive }` (doctor-header.tsx:148-149) и `{ cabinetId }` (cabinet-picker-dialog.tsx:52). Поиск по src не находит ни одного вызова PATCH с nameRu/specialization/pricePerVisit/salaryPercent/photoUrl; форм редактирования врача нет (grep EditDoctor/doctor-edit пуст).

DR-05 P2 · СРЕДНИЙ мокап / заглушка

Виджет «Быстрая запись к врачу» — муляж: кнопка «Создать запись» ничего не делает, услуги и время захардкожены

ГДЕ

src/app/[locale]/crm/doctors/_components/doctors-quick-book.tsx:83, src/app/[locale]/crm/doctors/_components/doctors-quick-book.tsx:29, src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:261, src/app/[locale]/crm/doctors/_components/doctors-quick-book.tsx:82

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Ресепшн на странице «Врачи» выбирает врача, «Первичная консультация», дату и 10:30, жмёт «Создать запись». Ничего не происходит; сотрудник может решить, что запись создана, и сказать пациенту «вы записаны».

ПОСЛЕДСТВИЯ

Потерянные записи и конфликт с пациентом; главный виджет страницы — декорация.

ЧТО СДЕЛАТЬ

Либо удалить виджет, либо связать: по кнопке открывать NewAppointmentDialog с предзаполненными doctorId/date/time и реальными услугами врача (из /api/crm/doctors/[id]) и свободными слотами из /api/crm/appointments/slots/available.

КРИТЕРИЙ ПРИЁМКИ

Нажатие «Создать запись» открывает полноценный диалог записи с выбранным врачом/датой/временем и после сохранения запись видна в календаре; либо виджета на странице нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

handleSubmit вызывает только `onCreate?.({...})` (стр. 83-91), а страница рендерит `

DR-06 P2 · СРЕДНИЙ баг

Добавление отпуска не предупреждает о уже записанных пациентах в этот период и не рассылает событие обновления слотов

ГДЕ

src/app/api/crm/doctors/[id]/time-off/route.ts:54, src/server/doctors/update-schedule.ts:135

СЦЕНАРИЙ

Админ ставит врачу отпуск на 10–14 октября. У врача на эти дни 25 записей: они остаются, пациентам уходят напоминания, пациенты приходят; админ об этом не узнаёт.

ПОСЛЕДСТВИЯ

Сорванные визиты и конфликт с пациентами.

ЧТО СДЕЛАТЬ

В POST возвращать число и список активных записей врача, пересекающих период, и показывать громкое предупреждение с переходом к переносу (bulk-reschedule); публиковать doctor.scheduleChanged через outbox.

КРИТЕРИЙ ПРИЁМКИ

При создании отпуска поверх существующих записей ответ содержит их количество и UI показывает предупреждение; открытый мини-апп перестаёт показывать слоты этого периода без перезагрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST time-off просто создаёт DoctorTimeOff и пишет аудит (стр. 54-68): нет подсчёта записей внутри [startAt,endAt] (аналог countStrandedAppointments есть только для деактивации), нет publishViaOutbox. Для расписания событие `doctor.scheduleChanged` публикуется (update-schedule.ts:135), для отпуска — нет, поэтому открытые мини-аппы и календарь продолжают показывать слоты.

DR-07 P2 · СРЕДНИЙ целостность данных

Инвариант «у активной услуги есть хотя бы один активный врач» обходится через редактор услуг врача, PATCH врача и повторную активацию услуги

ГДЕ

src/app/api/crm/doctors/[id]/services/route.ts:99, src/app/api/crm/doctors/[id]/route.ts:150, src/app/api/crm/services/[id]/route.ts:66, src/server/doctors/deactivation.ts:22

СЦЕНАРИЙ

У «ЭхоКГ» единственный врач. Админ в профиле врача снимает галочку «ЭхоКГ» и сохраняет. Услуга остаётся активной, ресепшн выбирает её в диалоге записи и не находит ни одного врача; в мини-аппе услуга висит без исполнителя.

ПОСЛЕДСТВИЯ

Тупики в записи и путаница у ресепшн/пациентов.

ЧТО СДЕЛАТЬ

Вынести проверку в общий хелпер и вызывать при замене набора услуг врача, при PATCH врача с services и при активации услуги; возвращать 409 service_orphaned со списком услуг, UI показывает названия.

КРИТЕРИЙ ПРИЁМКИ

Снятие последней активной услуги с единственного врача возвращает 409 с названием услуги; активация услуги без активных врачей возвращает 409.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Правило проверяется только при деактивации врача (findServicesOrphanedByDeactivating, deactivation.ts:22-51) и при создании/смене doctorIds услуги. PUT /doctors/[id]/services делает deleteMany+createMany без проверки сирот (стр. 99-109); PATCH врача с services — так же (route.ts:150-162); PATCH услуги с isActive:true не проверяет, есть ли у неё активные врачи (services/[id]/route.ts:66-70).

DR-08 P2 · СРЕДНИЙ мокап / заглушка

Показатели страницы «Врачи» выдуманы: ёмкость 10 записей/день и часы 9–18 захардкожены, «Выручка сегодня» показывает месяц, статус «Обед» и «Ближайшее окно» не связаны с реальностью, потери завышены в 100 раз

ГДЕ

src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:39, src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:76, src/app/[locale]/crm/doctors/_components/doctor-card.tsx:205, src/app/[locale]/crm/doctors/_components/doctors-tiles.tsx:91, src/app/[locale]/crm/doctors/_components/doctors-tiles.tsx:136, src/app/[locale]/crm/doctors/_components/doctors-heatmap.tsx:60, src/app/[locale]/crm/doctors/_hooks/use-doctors-stats.ts:40

СЦЕНАРИЙ

Главврач смотрит «Врачи» в 16:00: у врача «Ближайшее окно 09:00», статус «Обед», «Выручка сегодня 45 000 000 сум» (это месяц), «Потери сегодня ~3 000 000к» при реальных 30 млн; при этом врач по расписанию сегодня не работает.

ПОСЛЕДСТВИЯ

Управленческие решения (перераспределить пациентов, добавить смены) принимаются по фиктивным цифрам.

ЧТО СДЕЛАТЬ

Считать показатели на сервере от DoctorSchedule/DoctorTimeOff и реальных длительностей записей, исключая CANCELLED/NO_SHOW и неактивных врачей; разделить метрики «сегодня» и «за период» и подписать честно; убрать «Обед» и «Потери», если нет источника; ближайшее окно брать из findAvailableSlots начиная с текущего времени по Ташкенту; перевести суммы через formatMoney.

КРИТЕРИЙ ПРИЁМКИ

Для врача с расписанием Пн–Пт в субботу карточка не показывает свободных окон; «Выручка сегодня» совпадает с суммой priceFinal завершённых сегодня визитов; ближайшее окно не раньше текущего времени; потери (если оставлены) совпадают с /crm/analytics/loss.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`DAY\_CAPACITY = 10`, `WORKING\_HOURS = [9..18]` (doctors-page-client.tsx:39-40) вместо DoctorSchedule. deriveStatus считает каждую запись 30-минутной и учитывает все статусы, включая CANCELLED/NO_SHOW (стр. 76-86); freeSlots — часы 9–18 без записи, включая уже прошедшие (стр. 88-92), и это «Ближайшее окно» карточки (doctor-card.tsx:139,215). Статус «idle» подписан «Обед» (doctor-card.tsx:124-129, ru card.statusLunch). Карточка: подпись «Выручка сегодня» (стр. 205), значение agg.revenue за период (по умолчанию месяц). Плитки: «Доход сегодня» = totalRevenue периода; «Потери» = (10 × число всех врачей, включая деактивированных – записи сегодня + no-show за месяц) × avgCheck с фолбэком 150_000 (стр. 91-103); подстрока `(stats.emptyToday \* avgCheck) / 1\_000` берёт тийины и пишет «~Nк» — в 100 раз больше реального (стр. 136-153). «Конверсия в запись» = completed/(completed+noShow). Тепловая карта: `perHourCapacity = 2` и первые 5 врачей по алфавиту, в т.ч. неактивные (heatmap:60, 99). todayKey = UTC-дата (use-doctors-stats.ts:40). nowMs заморожен при монтировании (doctors-page-client.tsx:134), агрегаты не обновляются realtime. Даже после починки limit клиентская агрегация по 200 строкам молча обрежет месяц.

DR-09 P2 · СРЕДНИЙ безопасность

Процент зарплаты, цена приёма, userId и токен ТВ всех врачей отдаются любой роли (ресепшн, медсестра, колл-центр)

ГДЕ

src/app/api/crm/doctors/route.ts:42, src/app/api/crm/doctors/[id]/route.ts:41, src/app/api/crm/services/[id]/route.ts:29

СЦЕНАРИЙ

Оператор колл-центра открывает devtools на странице «Врачи» и видит процент зарплаты каждого врача и причины их отпусков («больничный»).

ПОСЛЕДСТВИЯ

Утечка конфиденциальных кадровых данных внутри клиники.

ЧТО СДЕЛАТЬ

Для не-ADMIN возвращать явный select без salaryPercent/userId/tvToken/причин отпуска; для services/[id] выбирать только id и имена врачей.

КРИТЕРИЙ ПРИЁМКИ

Ответ GET /api/crm/doctors под ролью RECEPTIONIST не содержит полей salaryPercent, userId, tvToken; под ADMIN содержит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET /api/crm/doctors для ролей ADMIN, RECEPTIONIST, DOCTOR, NURSE, CALL_OPERATOR делает findMany без select (`include: { cabinet: true }`, стр. 42-48) — в ответе salaryPercent, pricePerVisit, userId, tvToken. GET /api/crm/doctors/[id] — то же плюс timeOffs с reason (стр. 41-49). GET /api/crm/services/[id] — `include: { doctors: { include: { doctor: true } } }` (стр. 29).

DR-10 P2 · СРЕДНИЙ баг

Редактор услуг врача молча снимает услугу с врача, если в поле длительности ввели значение вне 5–600, и теряет несохранённые правки при фоновом обновлении

ГДЕ

src/app/[locale]/crm/doctors/[id]/_components/doctor-services.tsx:254, src/app/[locale]/crm/doctors/[id]/_components/doctor-services.tsx:141, src/app/api/crm/doctors/[id]/services/route.ts:99

СЦЕНАРИЙ

Админ в профиле врача ставит у «ЭЭГ» длительность «3» (хотел 30) и жмёт «Сохранить» — видит «Сохранено», а ЭЭГ исчезает из услуг врача; ресепшн больше не может записать к нему на ЭЭГ (NewAppointmentDialog фильтрует услуги по врачу). Или админ переключился в другое окно посреди правок —

все изменения цен сброшены.

ПОСЛЕДСТВИЯ

Скрытая потеря услуг у врача и срыв записи; потерянный труд админа.

ЧТО СДЕЛАТЬ

Не пропускать некорректные строки, а блокировать сохранение с подсветкой поля; защитить локальное состояние от перезаписи при dirty (как в ScheduleEditor); привести лимит к схеме (5..480 в DoctorServiceLinkSchema vs 5..600 в doctor-services.ts).

КРИТЕРИЙ ПРИЁМКИ

Ввод длительности «3» делает кнопку «Сохранить» недоступной и подсвечивает поле; после сохранения корректных данных набор услуг врача совпадает с отмеченными галочками; переключение окна не сбрасывает несохранённые правки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

handleSave: `if (duration !== null && (duration < 5 || duration > 600)) continue;` (стр. 254) — назначение просто пропускается, а PUT заменяет весь набор (deleteMany → createMany, route.ts:99-109), поэтому услуга отвязывается; затем toast «Сохранено». Поле допускает любые цифры (`/^\\d+\$/`, стр. 225). `React.useEffect(() => { setState(baseline); }, [baseline]);` (стр. 141-143) перезаписывает локальные правки при любом рефетче (фокус окна, staleTime 30с/5мин), в отличие от ScheduleEditor с dirtyRef.

DR-11 P2 · СРЕДНИЙ целостность данных

Смена кабинета врача не переносит кабинет в уже созданных будущих записях: напоминания и очередь отправляют пациента в старый кабинет, новый хозяин кабинета получает ложное «кабинет занят»

ГДЕ

src/app/api/crm/doctors/[id]/route.ts:97, src/server/appointments/book.ts:222, src/server/appointments/walkin.ts:208, src/server/notifications/triggers.ts:263, src/app/[locale]/crm/reception/_components/doctor-queue-card.tsx:83, src/server/services/appointments.ts:95

СЦЕНАРИЙ

Врача А переводят из 101 в 205 (кнопка «Сменить кабинет»). Его 40 записей на следующую неделю остаются с кабинетом 101: пациентам в Telegram уходит «ждём вас в кабинете 101», в очереди и на талоне тоже 101. Врач Б, которого посадили в 101, не может принять запись на 10:00, потому что там «занято» записью врача А.

ПОСЛЕДСТВИЯ

Пациенты идут не в тот кабинет, путаница в очереди; новый врач не может заполнить своё расписание (ложные конфликты кабинета).

ЧТО СДЕЛАТЬ

В PATCH при смене cabinetId в той же транзакции обновить cabinetId у будущих активных записей врача (date >= начало сегодняшнего дня по Ташкенту, status не CANCELLED/NO_SHOW/COMPLETED), проверив конфликты в новом кабинете; вернуть число перенесённых записей и опубликовать событие для обновления очереди/календаря. Альтернатива — отображать и проверять кабинет через doctor.cabinet, а не снимок.

КРИТЕРИЙ ПРИЁМКИ

После смены кабинета врача с 101 на 205 все его будущие записи имеют cabinetId кабинета 205; напоминание на завтра содержит «205»; другой врач, назначенный в 101, может записать пациента на время, где у первого врача были записи.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH /api/crm/doctors/[id] валидирует новый cabinetId и обновляет только строку Doctor (route.ts:97-122, 146-149); Appointment.cabinetId не трогается. При создании записи кабинет снимается снимком: book.ts:222 `const cabinetId = doctor.cabinetId;` и пишется в запись (стр. 343), walkin.ts:208 `cabinetId: doctor.cabinetId`. Напоминания берут кабинет из записи: triggers.ts:226 `cabinet: { select: { number: true } }`, стр. 263 `cabinet: appt.cabinet?.number`. Очередь ресепшн: doctor-queue-card.tsx:83-84 `...?.cabinet?.number`. detectConflicts ищет пересечения по `cabinetId: args.cabinetId` (appointments.ts:95-106), плюс EXCLUDE-ограничение по cabinetId в миграции 20260429_appointment_no_overlap.

serviceld в списке услуг при создании/правке врача не проверяется на принадлежность клинике: возможна межклиничная связь врача с чужой услугой

ГДЕ

src/app/api/crm/doctors/route.ts:112, src/app/api/crm/doctors/[id]/route.ts:150, src/lib/tenant-allowlist.ts:25, src/app/api/crm/doctors/[id]/route.ts:45

СЦЕНАРИЙ

Админ клиники А отправляет PATCH врача с serviceld услуги клиники В. В карточке врача А появляется услуга клиники В с её ценой; у клиники В в карточке услуги виден врач клиники А (ФИО, % зарплаты), и В может деактивировать своего последнего врача этой услуги, т.к. проверка «услуга без врача» считает врача А.

ПОСЛЕДСТВИЯ

Утечка данных между клиниками и порча инвариантов каталога (требует прав ADMIN и id).

ЧТО СДЕЛАТЬ

В POST/PATCH врача проверять все serviceld через `prisma.service.findMany({ where: { id: { in } } })` под тенантом (как в PUT /services) и отклонять 422; в `findServicesOrphanedByDeactivating` добавить `doctor.clinicId` фильтр.

КРИТЕРИЙ ПРИЁМКИ

POST/PATCH врача с чужим serviceld возвращает 422 и не создаёт ServiceOnDoctor.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST создаёт ServiceOnDoctor из ``body.services.map((s) => ({ doctorId, serviceld: s.serviceld, ... }))`` (route.ts:112-121) без проверки сервиса; PATCH так же (стр. 150-162). ServiceOnDoctor в MODELS_WITHOUT_TENANT (tenant-allowlist.ts:25) — расширение не фильтрует; FK проверяет лишь существование. Отдельный эндпоинт PUT /doctors/[id]/services проверяет через tenant-scoped `service.findMany`, а эти два пути — нет. GET врача отдаёт ``services: { include: { service: true } }`` (стр. 45) — вложенный include не скоупится, вернёт строку чужой услуги; GET /api/crm/services/[id] другой клиники вернёт ``doctors: { include: { doctor: true } }`` с полной карточкой нашего врача; `findServicesOrphanedByDeactivating` у чужой клиники засчитает нашего врача как покрытие.

userId врача в POST/PATCH не проверяется: админ может привязать врача к любому пользователю (в т.ч. другой клиники), а «Удалить навсегда» деактивирует этого пользователя в обход всех проверок

ГДЕ

src/server/schemas/doctor.ts:24, src/app/api/crm/doctors/route.ts:97, src/app/api/crm/doctors/[id]/route.ts:74, src/app/api/crm/doctors/[id]/route.ts:241, src/lib/tenant-allowlist.ts:17

СЦЕНАРИЙ

Админ клиники (или скрипт с его сессией) делает PATCH врача с userId администратора другой клиники либо своего последнего админа, затем деактивирует и «удаляет навсегда» этого врача — чужой/последний админ-аккаунт отключается, проверка «last_admin» из модуля пользователей обходится.

ПОСЛЕДСТВИЯ

Межтенантное отключение учётных записей и самоблокировка клиники; нарушение изоляции арендаторов (требует прав ADMIN и знания id).

ЧТО СДЕЛАТЬ

Убрать userId из CreateDoctorSchema/UpdateDoctorSchema (связь создаётся только через /api/crm/users) либо валидировать: пользователь существует в `ctx.clinicId, role=DOCTOR`, не привязан. В purge деактивировать пользователя с явным `where { id, clinicId: ctx.clinicId, role: "DOCTOR" }`.

КРИТЕРИЙ ПРИЁМКИ

PATCH /api/crm/doctors/[id] с userId пользователя другой клиники или не-DOCTOR возвращает 422; purge врача никогда не меняет пользователя другой клиники или с ролью ADMIN.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CreateDoctorSchema ``userId: z.string().optional().nullable()`` (doctor.ts:24); POST пишет ``userId: body.userId ?? null`` (route.ts:97), PATCH для ADMIN передаёт userId как есть (route.ts:74-82 удаляет его только для DOCTOR). Нет проверки, что пользователь из этой клиники, с ролью DOCTOR и активен (в отличие от /api/crm/users, который проверяет doctor_taken и создаёт связь сам). Purge: ``tx.user.update({ where: { id: userId }, data: { active: false } })`` (route.ts:241-246); модель User в MODELS_WITHOUT_TENANT (tenant-allowlist.ts:17), т.е. фильтр clinicId не

подставляется.

DR-14 РЗ · НИЗКИЙ бар

«Повторные визиты» в карточке случаев врача считают будущие и отменённые записи

ГДЕ

src/app/api/crm/doctors/[id]/case-stats/route.ts:76

СЦЕНАРИЙ

У врача много записей на следующий месяц и отмен — «Доля повторных» скачет без связи с реальными повторными визитами.

ПОСЛЕДСТВИЯ

Искажённый клинический показатель.

ЧТО СДЕЛАТЬ

Ограничить `date < now` и `status COMPLETED` (или исключить `CANCELLED/NO_SHOW`) для выборки и для определения первого визита случая.

КРИТЕРИЙ ПРИЁМКИ

Отменённые и будущие записи не меняют `repeatRatePct`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

``prisma.appointment.findMany({ where: { doctorId, date: { gte: ninetyDaysAgo } })`` (стр. 76-87) — нет верхней границы по дате и фильтра статуса; то же для `allSiblings` (стр. 130-138). Отменённые/no-show и будущие записи входят и в числитель, и в знаменатель `repeatRatePct`.

DR-15 РЗ · НИЗКИЙ UX

Вкладка «Обзор» профиля врача показывает нули вместо «нет доступа» для ресепшн и медсестры; кнопки редактирования видны ролям без права

ГДЕ

src/app/[locale]/crm/doctors/[id]/_components/doctor-profile-client.tsx:201, src/app/api/crm/doctors/[id]/finance/route.ts:17, src/app/api/crm/doctors/[id]/case-stats/route.ts:35, src/app/[locale]/crm/doctors/[id]/_components/doctor-cases.tsx:34, src/app/[locale]/crm/doctors/_components/doctors-page-client.tsx:248

СЦЕНАРИЙ

Ресепшн открывает профиль врача: «Выручка 0 сум, премия 0, открытых случаев 0» — выглядит как реальные данные. Меняет расписание, жмёт «Сохранить» — ошибка `Forbidden`.

ПОСЛЕДСТВИЯ

Вводящие в заблуждение нули и тупиковые действия.

ЧТО СДЕЛАТЬ

Скрывать финансы/случаи и кнопки редактирования для ролей без доступа (по `useCurrentRole`) и показывать ошибку запроса явно.

КРИТЕРИЙ ПРИЁМКИ

Под ролью `RECEPTIONIST` блоков финансов/случаев и кнопок сохранения расписания нет; под `ADMIN` всё видно и работает.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`Overview` рендерит `DoctorFinances` и `DoctorCases` для всех полей (`profile-client.tsx:201-205`), а `API finance` и `case-stats` разрешены только `ADMIN/DOCTOR` → 403; компоненты берут ``data?.x ?? 0`` (`doctor-finances.tsx:73-75`, `doctor-cases.tsx:34-37`) и показывают «0 сум», «0 случаев». `ScheduleEditor/DoctorTimeOff`/кнопка «Новый врач» (`doctors-page-client.tsx:248`) доступны всем, сохранение даёт 403.

DR-16 РЗ · НИЗКИЙ безопасность

Врач через `PATCH /api/crm/doctors/[id]` может сам себя активировать после деактивации, сменить ФИО, slug и фото на публичном сайте

ГДЕ

src/app/api/crm/doctors/[id]/route.ts:75

СЦЕНАРИЙ

Админ деактивировал врача, чтобы к нему не записывали (он в декрете). Врач из своей сессии отправляет `PATCH { isActive: true }` — снова доступен для записи в мини-аппе, пациенты записываются к отсутствующему врачу. Либо врач меняет своё фото/ФИО на публичном сайте без согласования.

ПОСЛЕДСТВИЯ

Обход административного решения о выводе врача из работы; неконтролируемые изменения публичных данных клиники.

ЧТО СДЕЛАТЬ

Для DOCTOR разрешить в этом маршруте только поля профиля, которые разрешены в `/api/crm/doctors/me/profile` (или запретить PATCH для DOCTOR вовсе и оставить `/me/profile`); `isActive`, `slug`, имена — только ADMIN.

КРИТЕРИЙ ПРИЁМКИ

PATCH { `isActive: true` } от роли DOCTOR на свою карточку возвращает 403 или игнорирует поле; `isActive` в БД не меняется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Для DOCTOR удаляются только `cabinetId`, `services`, `branchId`, `userId`, `salaryPercent`, `pricePerVisit` (стр. 75-82); `isActive`, `slug`, `nameRu/nameUz`, `specialization*`, `photoUrl`, `color` проходят в ``tx.doctor.update({ data })``. UI CRM врачу недоступен (редирект в кабинет), но API открыт его сессии.

DR-17 РЗ · НИЗКИЙ мокап / заглушка

Панель «AI рекомендации» содержит выдуманные тексты с фиктивными числами, кнопка «Настроить вид» ничего не делает

ГДЕ

`src/messages/ru.json:2427`, `src/app/[locale]/crm/doctors/_components/doctors-ai-recommendations.tsx:183`, `src/app/[locale]/crm/doctors/_components/doctors-kpi-tabs.tsx:105`

СЦЕНАРИЙ

Админ видит под плашкой «в разработке» «Перенаправьте 3 пациента к Каримовой в 11:20»; при включении `AI_ENABLED` это станет «рекомендацией» без данных. Клик «Настроить вид» — ничего.

ПОСЛЕДСТВИЯ

Фиктивные подсказки о реальных сотрудниках; мёртвая кнопка.

ЧТО СДЕЛАТЬ

Убрать хардкод-числа из `i18n` и генерировать рекомендации только из реальных данных (`reassign`-движок), исключать неактивных врачей; спрятать «Настроить вид» до реализации.

КРИТЕРИЙ ПРИЁМКИ

В `ru/uz` нет строк с фиксированным временем/количеством пациентов; кнопки «Настроить вид» нет или она открывает настройку.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Тексты: «Обновлено 2 мин назад» (`ru.json:2427`), «Перенаправьте 3 пациента к {name} в 11:20» (2429), «с 12:00 до 14:00», «перегружена после 14:00», «Есть спрос после 18:00» — числа не вычисляются. Рекомендация «evening» всегда берёт первого врача по алфавиту, даже неактивного (`ai-recommendations.tsx:183-193`). Сейчас панель затемнена `InDevelopment` (`AI_ENABLED=false`), но текст с реальными ФИО виден. `DoctorsKpiTabs`: кнопка «Настроить вид» вызывает ``onConfigureView`` (стр. 105-113), который страница не передаёт.

DR-18 РЗ · НИЗКИЙ мёртвая механика

Поля расписания `validFrom/validTo/isActive` принимаются API, но игнорируются движком записи, а CRM-редактор при сохранении их сбрасывает; время «99:99» проходит валидацию

ГДЕ

`src/server/schemas/doctor.ts:72`, `src/server/services/appointments.ts:140`, `src/server/services/appointment.s.ts:202`, `src/app/[locale]/crm/doctors/[id]/_hooks/use-doctor-schedule.ts:93`

СЦЕНАРИЙ

Интеграция или будущий UI задаёт летнее расписание с `validTo=31.08`: после 31.08 слоты по нему всё равно выдаются; админ открывает расписание в CRM и сохраняет — окна пропадают.

ПОСЛЕДСТВИЯ

Латентные расхождения расписания и записи.

ЧТО СДЕЛАТЬ

Либо учитывать `validFrom/validTo` (по дате Ташкента) в обоих движках и сохранять их в редакторе, либо убрать поля из схемы; валидировать время как 00:00–23:59.

КРИТЕРИЙ ПРИЁМКИ

Строка с validTo в прошлом не даёт слотов; PUT с startTime «99:99» возвращает 400.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ScheduleEntrySchema: `startTime: z.string().regex(/^d{2}:d{2}\$/)`, validFrom/validTo/isActive (doctor.ts:72-76). detectConflicts и findAvailableSlots выбирают строки по weekday и isActive без учёта validFrom/validTo (appointments.ts:140-147, 202-205), тогда как детектор LOW_DOCTOR_SCHEDULE их учитывает. CRM-редактор отправляет только weekday/startTime/endTime (use-doctor-schedule.ts:93-99) → неактивные строки становятся активными, окна действия теряются.

DR-19 РЗ · НИЗКИЙ мёртвая механика

Рейтинг врача (Doctor.rating, reviewCount) нигде не пересчитывается: отзывы NPS собираются, а в шапке профиля, статистике и мини-аппе рейтинга нет

ГДЕ

prisma/schema.prisma:850, src/app/[locale]/crm/doctors/[id]/_components/doctor-header.tsx:100, src/app/[locale]/crm/doctors/_components/doctors-stats-panel.tsx:41, src/app/api/miniapp/doctors/route.ts:32

СЦЕНАРИЙ

Пациенты оставили врачу 30 оценок NPS. В шапке профиля и в мини-аппе при выборе врача рейтинга нет («Нет отзывов»), «Средний рейтинг» в статистике «—».

ПОСЛЕДСТВИЯ

Функция рейтинга выглядит сделанной, но не работает; пациенты в мини-аппе не видят социального доказательства.

ЧТО СДЕЛАТЬ

При сохранении PatientReview (и ночным пересчётом) обновлять Doctor.rating (среднее, приведённое к нужной шкале) и reviewCount; либо читать агрегат из PatientReview напрямую.

КРИТЕРИЙ ПРИЁМКИ

После добавления отзыва врачу его reviewCount увеличивается, rating отражает среднее по PatientReview, шапка профиля и мини-апп показывают значение.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поля `rating Decimal?`, `reviewCount Int @default(0)` (schema.prisma:850-851) читаются в doctor-header.tsx:44,100-110, doctors-stats-panel avgRating, api/miniapp/doctors:32-33 и мини-апп doctor-picker, но записи в них нет ни в src, ни в сидах (grep по reviewCount/rating: только чтения). Отзывы при этом лежат в PatientReview и показываются во вкладке «Отзывы» (reviews/route.ts).

DR-20 РЗ · НИЗКИЙ безопасность

Удаление отпуска не проверяет, что период принадлежит врачу из URL: врач может удалить отпуск коллеги; несуществующий id даёт 500

ГДЕ

src/app/api/crm/doctors/[id]/time-off/route.ts:87

СЦЕНАРИЙ

Врач отправляет DELETE /api/crm/doctors/<свой id>/time-off?entryId=<id отпуска коллеги>. Отпуск коллеги исчезает, его дни снова открыты в мини-аппе, пациенты записываются к врачу, который в отпуске.

ПОСЛЕДСТВИЯ

IDOR внутри клиники: записи на время отпуска; нет следа в аудите по врачу-владельцу.

ЧТО СДЕЛАТЬ

Удалять через deleteMany({ where: { id: entryId, doctorId } }) и возвращать 404 при count=0; в аудит писать doctorId.

КРИТЕРИЙ ПРИЁМКИ

DELETE с entryId отпуска другого врача возвращает 404 и не удаляет запись; с несуществующим id — 404, не 500.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Проверка прав выполняется для doctorId из URL (стр. 78-86), затем `prisma.doctorTimeOff.delete({ where: { id: entryId } })` (стр. 87) — без условия doctorId. Для несуществующего entryId Prisma бросает P2025 → необработанное исключение → 500 из createApiHandler.

Фильтры API врачей/услуг: isActive=false превращается в true, а поиск по имени объединяется со специализацией через ИЛИ

ГДЕ

src/server/schemas/doctor.ts:58, src/server/schemas/service.ts:35, src/app/api/crm/doctors/route.ts:34

СЦЕНАРИЙ

Любой будущий экран «Неактивные врачи» (?isActive=false) покажет активных; поиск «Иванов» в специализации «Невролог» вернёт всех неврологов плюс всех Ивановых.

ПОСЛЕДСТВИЯ

Латентная ошибка фильтрации, всплывёт при подключении фильтров в UI.

ЧТО СДЕЛАТЬ

Парсить isActive как z.enum(["true","false"]).transform(v => v === "true"); объединять фильтры через AND: [{OR: спец}, {OR: name}].

КРИТЕРИЙ ПРИЁМКИ

GET /api/crm/doctors?isActive=false возвращает только неактивных; ?q=Иванов&specialization=Невролог — только Ивановых-неврологов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

isActive: z.coerce.boolean().optional() — проверено: safeParse({isActive:"false"}).data.isActive === true (Boolean("false")). В GET /api/crm/doctors при q и specialization: `where.OR = [...specialization OR..., nameRu, nameUz]` (стр. 34-40) — условие становится «специализация ИЛИ имя» вместо И.

TG · Telegram-бот, переписки, рассылки, уведомления, воркеры

TG-01 P1 · ВЫСОКИЙ бар

Голосовые, кружки, аудио, стикеры и геолокации пациентов теряются: в CRM видно только «Без текста»

ГДЕ

src/server/telegram/inbound-media.ts:72, src/app/api/telegram/webhook/[clinicSlug]/route.ts:188, src/app/api/telegram/webhook/[clinicSlug]/route.ts:393, src/app/[locale]/crm/telegram/_components/message-bubble.tsx:230

СЦЕНАРИЙ

Пожилый пациент надиктовывает боту голосовое «у меня после вашего препарата сильное головокружение». Регистратор видит пустое сообщение «Без текста», прослушать нельзя, file_id не сохранён, через час ссылка Telegram всё равно истекает.

ПОСЛЕДСТВИЯ

В Узбекистане голосовые сообщения — основной формат для многих пациентов; клиника теряет жалобы и вопросы, в том числе клинически значимые.

ЧТО СДЕЛАТЬ

Расширить pickMedia на voice (audio/ogg), audio, video_note, sticker (как изображение или подпись «стикер»), location (текстовое представление с координатами). Для голосовых хранить файл и показывать аудиоплеер в пузыре CRM и мини-аппа, в превью писать «Голосовое».

КРИТЕРИЙ ПРИЁМКИ

Апдейт с voice от пациента создаёт Message с вложением kind file/audio, в CRM воспроизводится; video_note и location отображаются осмысленно; превью диалога не пустое.

ДОКАЗАТЕЛЬСТВО В КОДЕ

pickMedia обрабатывает только photo, document, video, animation (inbound-media.ts:72-105); voice, audio, video_note, sticker, location не скачиваются. textBody = text ?? caption ?? contact.phone ?? "" (route.ts:188-191), поэтому Message создаётся с body null и без вложений. Голос обрабатывается только если отправитель — врач (route.ts:393-417); для пациента handleDoctorVoice возвращает not-doctor и сообщение уходит в общий поток пустым. В пузыре рисуется `t("message.noText")` = «Без текста» (message-bubble.tsx:230-236), превью в списке пустое.

TG-02 P1 · ВЫСОКИЙ бар

Любое изменение времени напоминания в настройках и шаблоны онбординга дают сообщения с пустыми полями, только на русском, а смещения больше 72 часов вообще не срабатывают

ГДЕ

src/server/workers/notifications-scheduler.ts:103, src/server/workers/notifications-scheduler.ts:255, src/server/workers/notifications-scheduler.ts:62, src/server/notifications/rules.ts:220, src/server/onboarding/playbooks/index.ts:109, src/server/onboarding/playbooks/index.ts:512, src/server/workers/notifications-scheduler.ts:108, src/server/workers/notifications-scheduler.ts:264, src/app/[locale]/crm/settings/notifications/_components/notifications-client.tsx:613, src/server/notifications/default-templates.ts:89, src/server/workers/notifications-scheduler.ts:214, src/server/onboarding/playbooks/index.ts:515, src/server/onboarding/playbooks/index.ts:110, src/server/onboarding/playbooks/index.ts:105, src/server/onboarding/apply-playbook.ts:105, src/server/workers/notifications-scheduler.ts:263, src/server/workers/notifications-scheduler.ts:173, src/server/workers/notifications-scheduler.ts:304, src/server/notifications/triggers.ts:256, prisma/schema.prisma:1

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы, Настройки клиники, пользователи, филиалы, кабинеты, права

СЦЕНАРИЙ

Админ в «Настройках уведомлений» меняет напоминание «за 1 день» на «за 20 часов». Пациенты получают «Иванов, напоминаем: завтра в вы записаны к в . Если планы изменились — позвоните .». Админ ставит «за 4 дня» — напоминание перестаёт уходить совсем. В новой клинике каждый пациент получает «Через 2 часа ваш приём в (). Если не сможете — позвоните: . Чтобы подтвердить, ответьте YES», отвечает «ДА», но запись не подтверждается.

ПОСЛЕДСТВИЯ

Пациенты получают бессмысленные сообщения без времени и врача (выглядит как сбой клиники), настройка времени напоминаний фактически ломает функцию, ложные инструкции «ответьте YES».

ЧТО СДЕЛАТЬ

Динамический проход должен использовать тот же `loadAppointment + buildContext`, что и канонический (время, врач, услуга, клиника, язык пациента). Горизонт выборки брать по максимальному смещению активных шаблонов (или ограничить редактор 72 часами). Убрать из шаблонов онбординга текст про ответ YES/ДА (или реализовать разбор ответа). `PATIENT_NO_CHANNEL` создавать только в момент срабатывания.

КРИТЕРИЙ ПРИЁМКИ

Шаблон со смещением -1200 рендерит время, врача, название и телефон клиники на языке пациента. Шаблон со смещением -5760 создаёт строку за 4 дня. Новая клиника после онбординга не содержит шаблонов с «ответьте YES».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Шаблон `APPOINTMENT_BEFORE` со смещением не из `{-7200,-4320,-1440,-180}` уходит в «динамический» проход (`scheduler.ts:92-110`). Там тело рендерится с контекстом только ``patient{name,firstName,phone}`, `appointment: {date}`` и ``clinic: { name: "", phone: "", address: "" }`` (255-265), всегда `bodyRu`. То есть `{{appointment.time}}`, `{{appointment.doctor}}`, `{{appointment.service}}`, `{{clinic.*}}` становятся пустыми. Горизонт выборки записей 72 часа (62), а редактор разрешает до 168 часов (`rules.ts:219-221`, `notifications-client.tsx:613`) — смещение 4-7 дней всегда «уже прошло» и пропускается (`scheduler.ts:214-217`). Кроме того, для пациентов без Telegram `recordPatientNoChannel` вызывается на каждом минутном тике до наступления времени (224-254). Онбординг новой клиники создаёт `reminder.2h` со смещением -120 (`playbooks/index.ts:512-517`), то есть сразу динамический, с текстом «Через 2 часа ваш приём в `{{clinic.name}}` (`{{appointment.doctor}}`)... ответьте YES (или ДА / НА)» (109-112), а текстовые ответы вебхук не обрабатывает.

TG-03 P1 · ВЫСОКИЙ баг

Пациенты с подтверждённой записью (все записи по телефону и киоску, а также нажавшие «Подтверждаю») не получают напоминаний за 1 день и за 3 часа

ГДЕ

`src/server/workers/notifications-send.ts:105`, `src/server/appointments/book.ts:351`, `src/app/api/crm/appointments/route.ts:157`, `src/server/workers/notifications-scheduler.ts:8`, `src/server/notifications/default-templates.ts:101`, `src/components/appointments/NewAppointmentDialog.tsx:140`, `src/app/api/crm/appointments/route.ts:205`, `src/server/appointments/book.ts:365`, `src/server/workers/notifications-send.ts:106`, `src/server/notifications/triggers.ts:1012`

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

Пациент звонит 1 сентября и записывается на 8 сентября. Запись создаётся со статусом `CONFIRMED`. 7-го и 8-го утром напоминания материализованы, но воркер помечает их `CANCELLED`. Пациент забывает про визит. Аналогично пациент, нажавший «Подтверждаю» в 5-дневном напоминании, больше ничего не получает.

ПОСЛЕДСТВИЯ

Большинство записей регистратуры (по телефону) остаются без напоминаний: рост неявок и простоев врачей, при этом в «Уведомлениях» видно, что напоминания якобы обработаны.

ЧТО СДЕЛАТЬ

Гасить при `confirmedAt` только полосу, которая просит подтверждения (T-3d / шаблоны с кнопкой подтверждения), а 1д и 3ч отправлять всегда, пока запись не отменена/не завершена; кнопку «Подтверждаю» не прикреплять к уже подтверждённым. Сделать правило явным полем шаблона (например `triggerConfig.skipIfConfirmed`).

КРИТЕРИЙ ПРИЁМКИ

Тест: запись `PHONE` (`confirmedAt` при создании) → строки 24h и 3h доходят до `SENT`, строка 3d отменяется. Запись, подтверждённая кнопкой на 5-дневном напоминании, получает 24h и 3h без кнопки подтверждения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Воркер отменяет ЛЮБОЕ напоминание с `trigger APPOINTMENT_BEFORE`, если у записи ``confirmedAt !== null`` (`notifications-send.ts:105-131`, `failedReason «patient already confirmed»`). Записи с каналом `PHONE` и `KIOSK` создаются сразу подтверждёнными: ``AUTO_CONFIRM_CHANNELS = new Set(["PHONE", "KIOSK"])`` (`appointments/route.ts:157, 205`) → ``status: "CONFIRMED", confirmedAt: now`` (`book.ts:351-369`). Комментарии самого проекта говорят обратное: только полоса T-3d должна зависеть от `confirmedAt` (`notifications-scheduler.ts:8-10`), «`CONFIRMED` rows still need ordinary reminders» (138-140). Текст 3-часового

шаблона — обычное напоминание «через 3 часа ждём вас» (default-templates.ts:100-101), а не просьба подтвердить.

TG-04 P1 · ВЫСОКИЙ баг

Сообщения сотрудников в «новый» диалог с пациентом не уходят в Telegram, но в CRM показываются как доставленные

ГДЕ

src/server/conversations/find-or-create.ts:136, src/app/api/crm/conversations/[id]/messages/route.ts:139, src/app/api/crm/conversations/find-or-create/route.ts:48, src/app/[locale]/crm/telegram/_components/message-bubble.tsx:282

СЦЕНАРИЙ

Регистратор с карточки пациента нажимает «Написать в Telegram», пишет «Ваши анализы готовы, подойдите завтра к 10:00». В CRM сообщение с двумя галочками. Пациент не открывает Mini App и ничего не получает в Telegram, на приём не приходит. Так же работает кнопка врача «Написать пациенту» (тот же kernel).

ПОСЛЕДСТВИЯ

Сотрудники уверены, что пациент получил важное сообщение, а оно лежит только внутри мини-аппа. Прямой риск пропущенных визитов и жалоб.

ЧТО СДЕЛАТЬ

При cold-start проставлять externalId = patient.telegramId (в личке chat_id = user id) и отправлять через Bot API, как обычный тред; либо, если оставлять in-band, слать в Telegram короткое уведомление «У вас новое сообщение от клиники» с web_app-кнопкой и ставить статус SENT только по факту отправки. Статус DELIVERED не выставлять без подтверждения. В UI показывать, что тред только внутри приложения.

КРИТЕРИЙ ПРИЁМКИ

Создание треда через find-or-create для пациента с telegramId и отправка сообщения: в Telegram-чате пациента появляется сообщение (или уведомление), статус SENT с externalId. Для пациента, заблокировавшего бота, статус FAILED с причиной.

ДОКАЗАТЕЛЬСТВО В КОДЕ

find-or-create для пациента без существующего треда создаёт Conversation с `patientId`, `mode: "takeover"` и externalId = null (find-or-create.ts:136-151, комментарий 146-148), хотя перед этим требует `patient.telegramId` (118-120), то есть chat_id известен. Роут отправки для `channel === "TG" && !conv.externalId` ничего не отправляет в Telegram и сразу ставит `status: "DELIVERED"` (messages/route.ts:139-143). В пузыре DELIVERED рисуется двойной галочкой (message-bubble.tsx:282-283). Никакого пуша в Telegram о новом сообщении в приложении нет (поиск по коду не нашёл).

TG-05 P1 · ВЫСОКИЙ безопасность

Хранимый XSS в CRM: любой пользователь Telegram может прислать боту SVG/HTML-файл, который открывается в origin neurofax.uz с сессией сотрудника

ГДЕ

src/server/telegram/inbound-media.ts:86, src/server/telegram/inbound-media.ts:154, src/app/api/crm/conversations/[id]/attachments/file/route.ts:71, src/app/[locale]/crm/telegram/_components/message-bubble.tsx:186, next.config.ts:22

СЦЕНАРИЙ

Злоумышленник (не пациент, просто любой человек, нашедший бота клиники) отправляет боту файл photo.svg со скриптом внутри. В инбоксе регистратора появляется «фото»; регистратор кликает, чтобы увеличить, — открывается новая вкладка на neurofax.uz, скрипт с cookie сотрудника вызывает /api/crm/patients, /api/crm/campaigns/broadcast (если админ) и выводит данные через location.href на внешний сайт или картинку api.qrserver.com (разрешена в img-src).

ПОСЛЕДСТВИЯ

Утечка персональных и медицинских данных пациентов клиники, действия от имени сотрудника (рассылки всем пациентам, изменения записей). Эксплуатация не требует учётной записи.

ЧТО СДЕЛАТЬ

Для входящих медиа применять тот же белый список, что и для исходящих (CHAT_ALLOWED_MIME), SVG/HTML/XML принудительно сохранять как application/octet-stream и kind "file". В роуте file всегда отдавать `Content-Disposition: attachment` для не-растровых типов, добавить `X-Content-Type-Options: nosniff` и `Content-Security-Policy: sandbox; default-src 'none'` на ответ. Рассмотреть отдачу вложений с отдельного

cookieless-домена.

КРИТЕРИЙ ПРИЁМКИ

Отправка боту файла .svg с ``<script>`` и .html: в CRM они отображаются как файлы, при открытии браузер скачивает файл, скрипт не выполняется; ответ роута file содержит CSP sandbox. Юнит-тест на ingestTelegramMedia: mime image/svg+xml даёт kind file и безопасный content-type.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Входящий документ берёт MIME из Telegram-апдейта, который задаёт отправитель: `mime: doc.mime\_type || "application/octet-stream"` (inbound-media.ts:90), без белого списка (в отличие от исходящей загрузки, где есть `CHAT\_ALLOWED\_MIME` — attachments/route.ts:79-82). Если MIME начинается с image/, вложение становится kind "image" (inbound-media.ts:154-156), объект сохраняется с этим content-type (172). Прокси-роут без авторизации отдаёт `Content-Type: obj.contentType` и `Content-Disposition: inline` (file/route.ts:70-80) с того же домена, что CRM. В пузыре CRM картинка обёрнута в `

TG-06 P2 · СРЕДНИЙ мокап / заглушка

KPI центра уведомлений искажены: ошибки за сегодня почти не считаются, «Отправлено» удвоено INAPP-дублями, «Доставлено» — только внутренние баннеры, у каждой успешной отправки «1 попытка повтора»

ГДЕ

src/app/api/crm/notifications/stats/route.ts:40, src/app/api/crm/notifications/stats/route.ts:31, src/server/notifications/record-delivery.ts:105, src/app/[locale]/crm/notifications/_components/notifications-details-rail.tsx:248

СЦЕНАРИЙ

Утром Telegram был недоступен, 40 напоминаний упали. Админ видит на плитке «Ошибки: 0», «Отправлено: 180» при 90 реальных сообщениях, «Доставлено: 90» (это баннеры в приложении), «В очереди: 700».

ПОСЛЕДСТВИЯ

Администратор принимает решения по ложным цифрам и не замечает сбоев доставки.

ЧТО СДЕЛАТЬ

Добавить failedAt/updatedAt и считать ошибки по нему; KPI считать только по внешним каналам (без INAPP-зеркал) или показывать их отдельно; «В очереди» — только scheduledFor <= сейчас; не увеличивать retryCount при успехе.

КРИТЕРИЙ ПРИЁМКИ

Искусственный сбой отправки сегодняшнего напоминания, созданного вчера, увеличивает «Ошибки сегодня»; одно TG-напоминание даёт +1 к «Отправлено»; успешная отправка показывает 0 повторов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

«Ошибки сегодня» считаются по `createdAt: { gte: startOfToday }, status: "FAILED"` (stats/route.ts:40-42), а напоминания каскада создаются в момент записи, за дни до отправки, — их сегодняшние сбои не попадают в счётчик (колонки времени сбоя нет). «Отправлено сегодня» включает статусы SENT/DELIVERED/READ (31-33), а для каждого TG-напоминания рядом создаётся INAPP-зеркало, которое сразу DELIVERED (triggers.ts:681-697, notifications-send.ts:173-197) — двойной счёт. «Доставлено» = только INAPP, потому что TG-строки никогда не переходят в DELIVERED. «В очереди» — все будущие напоминания на 5 дней вперёд. record-delivery при успехе делает `retryCount: { increment: 1 }` (105), и панель показывает «1 попытка повтора» для каждой успешной отправки (details-rail.tsx:248-252).

TG-07 P2 · СРЕДНИЙ мёртвая механика

QR «Подключить Telegram» из заключения и кнопка врача «Привязать Telegram» не работают, если автоответ бота выключен или тред в режиме оператора

ГДЕ

src/app/api/telegram/webhook/[clinicSlug]/route.ts:443, src/app/api/telegram/webhook/[clinicSlug]/route.ts:477, src/server/telegram/invite-token.ts:156, src/app/[locale]/doctor/_components/telegram-send-panel.tsx:26

СЦЕНАРИЙ

Врач в кабинете открывает «Привязать Telegram», пациент сканирует QR, жмёт «Старт». Если на сервере не выставлен TG_BOT_AUTOREPLY=1 или у пациента уже был тред, который оператор перевёл на себя, токен не

погашается, Patient.telegramId не проставляется, панель врача бесконечно ждёт. Бумажный QR на заключении тоже ничего не привязывает.

ПОСЛЕДСТВИЯ

Главный механизм подключения пациентов к боту (бумажное заключение и кабинет врача) может быть полностью мёртв; врачи и пациенты тратят время, напоминания и документы в Telegram не доходят.

ЧТО СДЕЛАТЬ

Выполнять consumeInviteToken для `/start <payload>` всегда, до проверки режима и флага автоответа (флаг должен управлять только отправкой приветствия FSM). После успешного погашения связывать текущий Conversation с пациентом.

КРИТЕРИЙ ПРИЁМКИ

При TG_BOT_AUTOREPLY не заданном и при mode=takeover отправка `/start <валидный токен>` проставляет Patient.telegramId, consumedAt и audit-строку; панель врача переключается на «Отправить в Telegram». Тест вебхука покрывает оба режима.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Разбор `/start <token>` и вызов consumeInviteToken находятся после раннего выхода: `const autoReplyEnabled = process.env.TG_BOT_AUTOREPLY === "1"; if (recorded.mode === "takeover" || !autoReplyEnabled) { ...; return jsonResponse({ ok: true }); }` (route.ts:443-454), а погашение токена только ниже (477-496). TG_BOT_AUTOREPLY отсутствует в .env.example, в docs/architecture/NOTIFICATIONS-TELEGRAM.md:320 описан как опциональный. mintOrReuseInviteUrl печатается в заключении (visit-notes print route) и используется в панели врача, которая ждёт флипа статуса «linked» (telegram-send-panel.tsx:26-31, опрос каждые 3 с).

TG-08 P2 · СРЕДНИЙ баг

«Повторить» и «Отправить повторно» для напоминаний о приёме всегда тихо превращаются в «Отменено»; retry API не проверяет статус и может дублировать уже отправленное

ГДЕ

src/app/api/crm/notifications/sends/[id]/retry/route.ts:22, src/app/api/crm/notifications/sends/[id]/resend/route.ts:44, src/server/workers/notifications-send.ts:147

СЦЕНАРИЙ

Напоминание за день упало из-за сбоя Telegram. Регистратор в «Уведомлениях» жмёт «Повторить», видит тост «Поставлено в очередь», через 5 секунд строка становится «Отменено». Через API повтор уже SENT-строки заново отправляет пациенту то же сообщение.

ПОСЛЕДСТВИЯ

Инструмент ручного восстановления доставки не работает для самого важного типа уведомлений; персонал думает, что напоминание ушло.

ЧТО СДЕЛАТЬ

Retry разрешать только для FAILED (и зависших SENDING), при ручном повторе пометать строку флагом/причиной, чтобы drift-guard проверял не scheduledFor, а актуальность даты записи (например, хранить appointmentDateSnapshot в строке и сравнивать его с appointment.date).

КРИТЕРИЙ ПРИЁМКИ

Повтор FAILED-напоминания для неперенесённой записи доходит до SENT. Повтор SENT-строки через API возвращает 409. Напоминание для перенесённой записи по-прежнему отменяется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

retry ставит `status: "QUEUED"`, `scheduledFor: new Date()` для любой строки без проверки текущего статуса (retry/route.ts:20-30, хотя комментарий «`requeue a failed send`»); resend клонирует с `scheduledFor: new Date()` (resend/route.ts:32-46). Воркер для APPOINTMENT_BEFORE считает `expectedAt = appt.date + offsetMin` и сравнивает с scheduledFor: `if (driftMs > 60_000) → CANCELLED "appointment time changed after reminder was queued"` (notifications-send.ts:145-164). После retry/resend scheduledFor = «сейчас», дрейф всегда больше минуты.

Анкета перед визитом и запрос NPS никогда не отправляются (шаблоны не создаются), но в записях проставляется «уведомлено»

ГДЕ

src/server/workers/pre-visit-questionnaire.ts:111, src/server/workers/post-visit-nps.ts:114, src/server/notifications/triggers.ts:403

СЦЕНАРИЙ

Клиника рассчитывает, что пациенты заполняют анкету жалоб до приёма и оценивают визит; врачи видят пустые анкеты, NPS-дашборд пустой, в записях при этом отмечено, что уведомление было.

ПОСЛЕДСТВИЯ

Две функции опыта пациента фактически не работают, а флаги в БД создают видимость работы.

ЧТО СДЕЛАТЬ

Провизинить эти шаблоны по умолчанию (RU/UZ); ставить флаг только после успешной материализации; включить CONFIRMED в выборку анкеты.

КРИТЕРИЙ ПРИЁМКИ

Для клиники без ручных шаблонов запись через 24 часа получает анкету (NotificationSend TG+INAPP), завершённый визит через 4 часа — запрос NPS; при отсутствии шаблона флаг не проставляется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Воркеры сначала ставят `preVisitNotifiedAt: now` / `npsRequestedAt: now` (pre-visit-questionnaire.ts:111-114, post-visit-nps.ts:114-117), затем вызывают materializeForAppointment, который ищет шаблоны только по ключам appointment.pre-visit-questionnaire / appointment.nps-request (triggers.ts:403-411). Шаблонов с этими ключами не создаёт ни один сид, онбординг или автопровизининг (поиск по src, scripts, prisma). При отсутствии шаблона materialize тихо возвращает skipped (723-724). Кроме того, анкета выбирает только BOOKED/WAITING (pre-visit-questionnaire.ts:66), то есть записи по телефону (CONFIRMED) её никогда не получают.

Аудитория рассылки обрезается 10 000 пациентов до фильтра по Telegram; запуск кампании не защищён от двойного запуска

ГДЕ

src/server/campaigns/audience.ts:139, src/server/campaigns/launch.ts:259

СЦЕНАРИЙ

В клинике 25 000 карточек, 4 000 с Telegram. Рассылка «всем» берёт 10 000 карточек (сначала никогда не приходившие), из них 900 с Telegram; остальные 3 100 пациентов не получают сообщение, хотя превью показывает «получат 900», и админ считает это полным охватом. Два админа одновременно запускают одну кампанию — пациенты получают её дважды.

ПОСЛЕДСТВИЯ

Неполный охват рассылок без предупреждения, возможны дубли сообщений.

ЧТО СДЕЛАТЬ

Перенести фильтр `telegramId not null, tgBlockedAt null, marketingOptOut false` в SQL до лимита; при превышении лимита явно сообщать. Переход DRAFT→SENDING делать условным `updateMany({ where: { id, status: "DRAFT" } })` и вставлять строки только при count=1.

КРИТЕРИЙ ПРИЁМКИ

На тестовых данных с >10 000 карточек все пациенты с Telegram попадают в аудиторию; два параллельных запуска создают один набор NotificationSend.

ДОКАЗАТЕЛЬСТВО В КОДЕ

resolveAudience сначала выбирает `take: MAX\_AUDIENCE` (10 000) всех не удалённых пациентов с сортировкой `lastVisitAt: "desc"` (в Postgres NULL идут первыми), и только потом в памяти отсекает без telegramId/заблокировавших (audience.ts:139-155, filterEligible 68-98). Для dormant — `take: 5000` до исключений (dormant-audience.ts:98-112). В launchCampaign «защита от параллельного клика» — findUnique статуса и затем безусловный update в транзакции READ COMMITTED (launch.ts:257-283): две параллельные транзакции обе видят DRAFT и обе вставляют строки.

Диалоги из бота никогда не привязываются к карточке пациента, а ручная привязка не записывает Telegram в карточку: дубли пациентов, напоминания не доходят, врачи видят все переписки

ГДЕ

src/app/api/telegram/webhook/[clinicSlug]/route.ts:201, src/app/api/telegram/webhook/[clinicSlug]/route.ts:687, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1237, src/server/conversations/doctor-scope.ts:27, src/server/workers/data-deletion.ts:95

СЦЕНАРИЙ

Пациентка, уже авторизованная в мини-аппе (telegramId в карточке), пишет боту «болит голова после препарата». В инбоксе это «неизвестный контакт» без карточки, панель предлагает создать пациента — регистратор создаёт дубль. Другой пациент пишет боту впервые, регистратор привязывает тред к карточке по телефону, но в карточке telegramId пуст: напоминания за день и за 3 часа для него уходят в Action Center как «нет канала», в рассылки он не попадает. Каждый врач клиники видит все эти непривязанные переписки с жалобами.

ПОСЛЕДСТВИЯ

Дубли в базе пациентов, потеря напоминаний у пациентов, которые реально общаются с ботом, разрыв истории на два треда, утечка переписок всем врачам, неполная анонимизация по DSAR.

ЧТО СДЕЛАТЬ

В webhook при upsert искать Patient по (clinicId, telegramId = from.id) и проставлять patientId при создании/если пусто. При ручной привязке треда из панели записывать Patient.telegramId (и telegramLinkedAt), если он пуст, иначе предупреждать о конфликте. find-or-create должен сначала искать тред по externalId = patient.telegramId. Скоуп врача не должен включать все непривязанные треда без явного назначения.

КРИТЕРИЙ ПРИЁМКИ

Пациент с telegramId пишет боту — тред сразу связан с карточкой, в мини-апп приходит событие с patientId. После привязки из панели у пациента заполнен telegramId и ему создаются TG-напоминания. find-or-create для такого пациента возвращает существующий бот-тред. Врач не видит треда чужих пациентов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

recordIncoming делает upsert Conversation по (clinicId, externalId=chatId) и нигде не ищет Patient по telegramId (route.ts:201-224), поэтому patientId у бот-треда всегда null, хотя тот же файл умеет найти пациента `prisma.patient.findFirst({ where: { clinicId, telegramId: chatId } })` для my_chat_member (687-690). Событие для мини-аппа уходит с patientId null (436-440). Форма в правой панели создаёт/находит пациента по телефону и делает PATCH только `{ patientId }` (chat-right-rail.tsx:1237-1245), Patient.telegramId не заполняется. find-or-create ищет существующий тред только по patientId (find-or-create.ts:100-106), поэтому для такого пациента создаётся второй «холодный» тред. Скоуп врача включает `{ patientId: null }` (doctor-scope.ts:27). DSAR-анонимизация чистит только треда с patientId пациента (data-deletion.ts:95-113).

Диспетчер уведомлений игнорирует баскофф ретраев и отсрочку лимита, плодит дубли задач в BullMQ; зависшие в SENDING строки не восстанавливаются

ГДЕ

src/server/workers/notifications-scheduler.ts:319, src/server/workers/notifications-send.ts:329, src/server/workers/notifications-send.ts:225, src/server/queue/bullmq-adapter.ts:99, src/app/[locale]/crm/notifications/_components/notifications-details-rail.tsx:191, src/server/workers/notifications-send.ts:337, src/server/workers/notifications-scheduler.ts:321, src/server/workers/notifications-scheduler.ts:349, src/server/workers/notifications-send.ts:58, src/server/workers/notifications-send.ts:90, src/server/workers/start.ts:192, src/app/api/crm/notifications/sends/[id]/retry/route.ts:22, src/server/notifications/record-delivery.ts:188, src/server/workers/notifications-scheduler.ts:327, src/server/workers/notifications-send.ts:221

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Кратковременный сбой Telegram на 2 минуты: напоминания исчерпывают 3 попытки почти подряд и становятся FAILED. Во время рассылки на 3000 пациентов в Redis копяты десятки тысяч дублирующих задач, реальные отправки ждут за ними. Деплой воркера посреди отправки оставляет строки в SENDING — ни отправлены, ни

ошибка.

ПОСЛЕДСТВИЯ

Потеря напоминаний при коротких сбоях, замедление рассылок, «висящие» уведомления.

ЧТО СДЕЛАТЬ

При ретрае/отсрочке сдвигать `scheduledFor` на время `backoff`; использовать `jobId = sendId` для дедуна в BullMQ; добавить свип `SENDING` старше `N` минут → `QUEUED/FAILED`; разрешить «Повторить» для `SENDING`.

КРИТЕРИЙ ПРИЁМКИ

Ретрай сдвигает `scheduledFor` на 60 с и не отправляется раньше; повторные `dispatch` не создают дублей задач для одной строки; строка `SENDING` старше 10 минут автоматически возвращается в работу.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`dispatchDue` каждые 5 с ставит в очередь все `QUEUED` с ``scheduledFor <= now`` (до 500) без `jobId` (`scheduler.ts:317-330`; `bullmq-adapter.ts:99-102` передаёт `jobId` только если он есть). Ретрай возвращает строку в `QUEUED` с тем же `scheduledFor` и ставит отложенную задачу (`notifications-send.ts:329-343`) — но диспетчер подхватит строку через ≤ 5 с, `backoff 60/300` с не соблюдается. Отсрочка по лимиту (225) аналогично обходится. Воркер BullMQ — одна задача за раз, поэтому при большой рассылке каждые 5 с добавляются сотни дублей, каждая делает запрос в БД. Строка, у которой воркер упал между `claimForDispatch` и записью результата, остаётся `SENDING` навсегда (67-75): автоматического свипа нет, а в UI «Повторить» доступна только для `FAILED` (`details-rail.tsx:191`).

TG-13 P2 · СРЕДНИЙ производительность

Минутный планировщик сканирует всю базу без фильтров и порядка с жёсткими лимитами: при росте клиники дни рождения, долги и повторные визиты молча пропускаются

ГДЕ

`src/server/notifications/triggers.ts:1094`, `src/server/notifications/triggers.ts:1216`, `src/server/notifications/triggers.ts:1334`, `src/server/notifications/triggers.ts:1008`, `src/server/notifications/triggers.ts:664`

СЦЕНАРИЙ

В клинике 6000 пациентов с датой рождения — поздравление получают только те, кто случайно попал в первые 2000 строк. После 500 завершённых визитов напоминание о долге за вчерашний визит почти никогда не материализуется, а если материализуется — «сумма к оплате: » пустая.

ПОСЛЕДСТВИЯ

Тихие пропуски уведомлений и постоянная лишняя нагрузка на БД каждую минуту.

ЧТО СДЕЛАТЬ

Перенести фильтры в SQL (дата рождения по месяцу/дню в часовом поясе клиники, неоплаченные визиты за окно, случаи с открытым окном повторного визита), добавить сортировку/курсор, запускать дневные задачи раз в сутки в нужный локальный час; передавать сумму долга (в сумах, `formatMoney`) в контекст.

КРИТЕРИЙ ПРИЁМКИ

На тестовой базе с 10 000 пациентов все именинники дня получают строку; неоплаченный вчерашний визит даёт `payment.due` с суммой; запросы тика используют индексы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Каждую минуту по всем клиникам: `runBirthdays` грузит ``take: 2000`` пациентов с любой датой рождения и фильтрует сегодняшних в памяти (`triggers.ts:1094-1108`, `1114-1121`); `runPaymentsDue` грузит ``take: 500`` всех `COMPLETED` с ценой без сортировки и без фильтра неоплаченных, с вложенными платежами (`1216-1230`); `runCaseRepeatReminders` — ``take: 2000`` открытых случаев со всеми визитами (`1334-1344`); полосы каскада — ``take: 500`` без `orderBy` (`1008-1016`). Кроме того, `payment.due` рендерится через `buildContext` без `extras`, поэтому `{{payment.amount}}` всегда пустой (`664-666` против `244-277`).

TG-14 P2 · СРЕДНИЙ баг

Напоминание о бесплатном повторном визите уходит с пустыми названием и телефоном клиники

ГДЕ

src/server/notifications/triggers.ts:1453, prisma/seed.ts:215, scripts/seed-prod-demo.ts:170

СЦЕНАРИЙ

Пациент получает: «Здравствуйте, Иванов! У вас осталось 2 дн. на бесплатный повторный приём в . Запишитесь до 25 сентября 2026 г.. Тел: .» — не знает, куда звонить.

ПОСЛЕДСТВИЯ

Потеря повторных визитов (выручка и качество лечения), сообщение выглядит как ошибка.

ЧТО СДЕЛАТЬ

Загружать клинику (nameRu/nameUz, phone, address) и язык пациента для контекста, как в buildContext.

КРИТЕРИЙ ПРИЁМКИ

Материализованное case.repeat-due содержит название и телефон клиники; дата без двойной точки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

runCaseRepeatReminders рендерит `render(tpl.bodyRu, { patient, case, clinic: { name: "", phone: "", address: "" } })` (triggers.ts:1443-1454). Сидовый шаблон case.repeat-due (prisma/seed.ts:215, scripts/seed-prod-demo.ts:164-172) использует `{{clinic.name}}` и `{{clinic.phone}}`. Дата дедлайна форматируется как «25 сентября 2026 г.», за ней в шаблоне точка — «г..».

TG-15 P2 · СРЕДНИЙ мёртвая механика

Напоминания о приёме лекарств в Telegram не отправляются: шаблон medication.reminder нигде не создаётся, хотя врач включает «Напоминать пациенту в Telegram»

ГДЕ

src/server/workers/medication-reminder.ts:156, src/server/workers/medication-reminder.ts:213, src/message s/ru.json:1658

СЦЕНАРИЙ

Невролог назначает курс противосудорожного препарата с напоминаниями 08:00 и 20:00. Пациент ждёт напоминаний в Telegram, но они не приходят никогда; врач считает, что приверженность поддерживается.

ПОСЛЕДСТВИЯ

Функция, влияющая на соблюдение лечения, выглядит включённой, но не работает.

ЧТО СДЕЛАТЬ

Автоматически провижинить шаблон medication.reminder (RU/UZ) для клиники при включении medicationRemindersEnabled или при первом тике (как ensureAutoMessageTemplates); при отсутствии шаблона всё равно создавать INAPP-строку и использовать дефолтный текст. Обрабатывать все времена в часе.

КРИТЕРИЙ ПРИЁМКИ

Для клиники без ручных шаблонов рецепт с remindersEnabled в нужный час создаёт TG и INAPP NotificationSend и сообщение приходит; два времени в одном часе дают два напоминания.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Воркер ищет шаблон строго по ключу `key: "medication.reminder"` (medication-reminder.ts:156-161). Если шаблона нет — `if (!tpl) { created += 1; continue; }` (213-217): не создаются ни TG-сообщение, ни даже INAPP-баннер. Поиск по репозиторию (prisma/seed.ts, scripts/seed-*, onboarding playbooks, ensureAutoMessageTemplates) не находит ни одного места, где создаётся шаблон с этим ключом. В UI рецепта переключатель подписан «Напоминать пациенту в Telegram» (ru.json:1658), в настройках клиники «рассылает push-уведомления по графику приёма» (ru.json:3629). Кроме того, если в schedule.times два времени в одном часе (08:00 и 08:30), `find` берёт только первое (medication-schedule.ts `schedule.times.find`).

TG-16 P2 · СРЕДНИЙ мёртвая механика

Новая клиника после онбординга не получает шаблоны отмены, переноса, неявки, опоздания и полос 5д/3ч; готовый набор default-templates не используется

ГДЕ

src/server/onboarding/playbooks/index.ts:114, src/server/notifications/default-templates.ts:193, src/server/onboarding/apply-playbook.ts:97

СЦЕНАРИЙ

Подключается вторая клиника. Регистратор отменяет запись — пациент не получает уведомление; переносит — тоже тишина; автоматический NO_SHOW — без сообщения.

ПОСЛЕДСТВИЯ

Для каждой новой клиники ключевые транзакционные уведомления отсутствуют без каких-либо предупреждений.

ЧТО СДЕЛАТЬ

При создании клиники/применении плейбука upsert-ить DEFAULT_APPOINTMENT_TEMPLATES (с языковыми версиями); в «Настройках уведомлений» подсвечивать события без шаблона.

КРИТЕРИЙ ПРИЁМКИ

После онбординга в новой клинике есть активные шаблоны для created, 5д/3д/1д/3ч, cancelled by-staff/by-patient, rescheduled, running-late, no-show; отмена записи создаёт NotificationSend.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Плейбук создаёт только trio: appointment.created, reminder-3d, reminder-24h, reminder-2h (playbooks/index.ts:114-141). Функция defaultAppointmentTemplatesForClinic, содержащая 5д/3д/1д/3ч, отмену by-staff/by-patient, перенос, опоздание, неявку (default-templates.ts:50-197), нигде не вызывается (rg находит только определение). Для отмены/переноса/неявки materializeForAppointment при отсутствии шаблона тихо возвращает skipped (triggers.ts:723-724).

TG-17 P2 · СРЕДНИЙ баг

Отправка из CRM может висеть до ~2 минут: nginx отдаёт 504, оператор отправляет повторно и пациент получает дубли; FAILED возвращается как успех без кнопки «повторить»

ГДЕ

src/app/api/crm/conversations/[id]/messages/route.ts:193, src/server/telegram/send.ts:134, nginx/nginx.conf:168, src/app/[locale]/crm/telegram/_hooks/use-send-message.ts:102

СЦЕНАРИЙ

Telegram отвечает медленно. Регистратор отправляет «Ждём вас в 15:00», через 60 с видит «Send failed», отправляет ещё раз. В итоге пациент получает 2-3 одинаковых сообщения. В другой раз отправка реально не удалась, но в интерфейсе лишь маленький красный значок, который легко не заметить.

ПОСЛЕДСТВИЯ

Дубли сообщений пациентам, незамеченные доставки.

ЧТО СДЕЛАТЬ

Ставить исходящее в очередь (QUEUED) и отправлять в воркере с идемпотентностью, отвечать клиенту сразу; не ретраить таймауты для sendMessage без проверки; при FAILED показывать заметный статус и кнопку «Повторить».

КРИТЕРИЙ ПРИЁМКИ

При искусственной задержке Telegram 90 с POST отвечает быстро, сообщение доставляется один раз; FAILED отображается с кнопкой повтора.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST синхронно ждёт sendMessage/sendPhoto (messages/route.ts:168-202), а tgCallWithBackoff делает до 12 попыток по 8 с плюс backoff и ретраит даже таймауты, когда Telegram мог уже принять сообщение (send.ts:83-86, 134-147). nginx для / имеет `proxy\_read\_timeout 60s` (nginx.conf:168). Клиент при ошибке откатывает оптимистичное сообщение и показывает тост (use-send-message.ts:96-100), хотя сервер продолжает отправку. При неудаче роут возвращает 201 со status FAILED (216-219, 260) — хук считает это успехом (102-109), кнопки повтора для FAILED в пузыре нет.

TG-18 P2 · СРЕДНИЙ баг

Перенос записи самим пациентом в мини-аппе оставляет его без напоминаний и без подтверждения нового времени

ГДЕ

src/app/api/miniapp/appointments/[id]/route.ts:232, src/server/notifications/triggers.ts:1734, src/server/workers/notifications-send.ts:145

СЦЕНАРИЙ

Пациент в мини-аппе переносит приём со среды 10:00 на пятницу 16:00. Все ранее созданные напоминания (5д/3д/1д/3ч) в момент отправки отменяются как устаревшие, новых нет, уведомления «перенесено» тоже нет. Пациент забывает про пятницу.

ПОСЛЕДСТВИЯ

Самостоятельные переносы через приложение (основной сценарий мини-аппа) гарантированно лишают пациента напоминаний, растут неявки.

ЧТО СДЕЛАТЬ

В мини-апп PATCH при изменении startAt вызывать appointment.rescheduled (как в CRM, с проверкой, что дата действительно изменилась). Дополнительно appointment.updated не должен молча оставлять устаревшие QUEUED строки.

КРИТЕРИЙ ПРИЁМКИ

Тест: перенос через мини-апп отменяет старые QUEUED-напоминания и создаёт новые с scheduledFor от новой даты; строка appointment.rescheduled создаётся (если шаблон активен).

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH мини-аппа меняет startAt, но вызывает `fireTrigger({ kind: "appointment.updated", appointmentId: id })` (miniapp route.ts:232), тогда как CRM для сдвига времени вызывает appointment.rescheduled. Ветка appointment.updated только вызывает scheduleAppointmentReminders (triggers.ts:1734-1740) — старые QUEUED строки не отменяются, поэтому alreadyScheduled для каждой полосы возвращает true и новые не создаются. При отправке старые строки режет drift-guard: `if (driftMs > 60\_000) { status: "CANCELLED", failedReason: "appointment time changed..." }` (notifications-send.ts:145-164).

TG-19 P2 · СРЕДНИЙ безопасность

Письмо врачу о заявке с сайта: HTML-инъекция из публичной формы, битая ссылка и обходимый rate-limit

ГДЕ

src/lib/email.ts:33, src/lib/email.ts:39, src/app/api/leads/route.ts:82, src/lib/email.ts:35, src/app/api/leads/route.ts:19, src/app/api/leads/route.ts:154

ТАКЖЕ НАШЛИ ЗОНЫ

Публичный лендинг, запись с сайта, SEO

СЦЕНАРИЙ

Злоумышленник отправляет заявку с именем `

ПОСЛЕДСТВИЯ

Фишинг сотрудников с доверенного адреса клиники, спам заявок в CRM.

ЧТО СДЕЛАТЬ

Экранировать все значения в HTML письма, ссылку вести на /ru/crm, бренд брать из клиники; rate-limit считать по \$remote_addr/последнему доверенному IP, чистить Map.

КРИТЕРИЙ ПРИЁМКИ

Заявка с HTML в имени приходит в письме как текст; ссылка открывает CRM; смена X-Forwarded-For не обходит лимит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

sendNewLeadEmail вставляет `\${data.patientName}`, `\${data.service}`, `\${data.date}` прямо в HTML письма без экранирования (email.ts:33-37); значения приходят из анонимной формы (leads/route.ts LeadSchema: name до 100, service до 200 символов). Ссылка в письме `https://neurofax.uz/ru/dashboard` (email.ts:39) ведёт на несуществующий маршрут (в src/app/[locale] нет dashboard), бренд «NeuroFax» захардкожен для всех клиник. Лимит на форму — по строке заголовка `x-forwarded-for` целиком (leads/route.ts:82), а nginx дописывает

реальный IP к присланному клиентом значению, поэтому меняя префикс, можно обойти лимит; Мар лимитера не очищается (rate-limit.ts:1-18).

TG-20 P2 · СРЕДНИЙ баг

Поздравление с днём рождения приходит пациенту один раз за всю жизнь, в 05:00 утра и без названия клиники

ГДЕ

src/server/notifications/triggers.ts:1145, src/server/notifications/triggers.ts:1085, src/server/notifications/triggers.ts:1185, src/app/[locale]/crm/notifications/_components/triggers-panel.tsx:21

СЦЕНАРИЙ

Пациента поздравили в 2026 году. В 2027 году поздравления уже не будет. Поздравление в 2026-м пришло в 5 утра с текстом «Команда поздравляет вас...».

ПОСЛЕДСТВИЯ

Маркетинговая функция работает один раз, будит пациентов и выглядит небрежно.

ЧТО СДЕЛАТЬ

Дедуп по (patient, template, год) или по createdAt за последние 300 дней; вычислять день рождения в часовом поясе клиники и ставить scheduledFor на 09:00 местного времени; заполнять clinic.* как в buildContext.

КРИТЕРИЙ ПРИЁМКИ

Тест: пациент с SENT-поздравлением прошлого года получает новое в этом году; scheduledFor = 09:00 Asia/Tashkent; текст содержит название клиники.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Идемпотентность по (patientId, templateId, appointmentId null) со статусами QUEUED/SENT/DELIVERED/READ без ограничения по году (triggers.ts:1138-1152) — прошлогодняя SENT-строка блокирует все будущие. «Сегодня» определяется по UTC (now.getUTCMonth(), `getUTCDate()`, 1085-1086), первый тик нового UTC-дня — 05:00 по Ташкенту, scheduledFor = new Date(). Контекст `clinic: { name: "", phone: "", address: "" }` (1185). Панель триггеров обещает «09:00 clinic TZ» (triggers-panel.tsx:21).

TG-21 P2 · СРЕДНИЙ баг

При втором переносе записи пациент не получает уведомление о новом времени

ГДЕ

src/server/notifications/triggers.ts:465, src/server/notifications/triggers.ts:940, src/server/notifications/triggers.ts:970

СЦЕНАРИЙ

Запись на понедельник 10:00. В пятницу регистратура переносит на вторник 12:00 — пациент получает «приём перенесён: вторник 12:00». В субботу врач заболел, регистратура переносит на среду 15:00 — alreadyScheduled находит SENT-строку, уведомления нет; напоминание «за день» для вторника уже ушло и больше не пересоздаётся. Пациент приходит во вторник в 12:00.

ПОСЛЕДСТВИЯ

Пациент приходит в неверное время, клиника теряет слот, конфликт на ресепшн.

ЧТО СДЕЛАТЬ

Для событийных уведомлений (rescheduled, cancelled) не применять вечную идемпотентность: ключевать по (appointmentId, templateId, новая дата) или разрешать повтор, если appointment.date изменился с момента предыдущей отправки. При переносе пересоздавать все будущие полосы каскада независимо от уже отправленных для старого времени.

КРИТЕРИЙ ПРИЁМКИ

Тест: два последовательных вызова onAppointmentRescheduled с разными датами создают две строки rescheduled с разными телами; полосы 24h/3h для новой даты создаются даже если для старой они уже SENT.

ДОКАЗАТЕЛЬСТВО В КОДЕ

onAppointmentRescheduled материализует шаблон appointment.rescheduled через materializeForAppointment (triggers.ts:970-981), где стоит идемпотентность alreadyScheduled по (patient, appointment, template) со статусами `["QUEUED", "SENT", "DELIVERED", "READ"]` (465-482). cancelPendingAppointmentReminders снимает только QUEUED строки шаблонов APPOINTMENT_BEFORE и APPOINTMENT_CREATED (940-962). После первого переноса строка «перенесён» в статусе SENT навсегда блокирует следующее уведомление. Уже отправленные полосы каскада (например 24h) тоже не пересоздаются, потому что их SENT-строки проходят тот же фильтр.

TG-22 P2 · СРЕДНИЙ баг

При нескольких шаблонах на одно событие выбирается случайный: выключатели и тексты «Авто-сообщений» могут не действовать

ГДЕ

src/server/notifications/triggers.ts:437, src/server/notifications/auto-messages.ts:143, src/server/onboarding/playbooks/index.ts:500

СЦЕНАРИЙ

Админ в «Авто-сообщениях» выключает «Напоминание за 24 часа», потому что клиника звонит сама. Пациенты продолжают получать напоминание — от шаблона reminder.24h с текстом «ответьте YES». Админ правит текст «Спасибо за визит», а пациентам уходит старый «Будем благодарны за отзыв».

ПОСЛЕДСТВИЯ

Настройки администратора не соответствуют реальным рассылкам, непредсказуемые тексты.

ЧТО СДЕЛАТЬ

Гарантировать один активный шаблон на (clinicId, trigger, offsetMin/audience): частичный уникальный индекс или деактивация дублей при сохранении; findFirst с детерминированным порядком; виджет должен управлять тем шаблоном, который реально выбирается.

КРИТЕРИЙ ПРИЁМКИ

При двух активных шаблонах с -1440 сохранение одного из них деактивирует другой (или выдаёт ошибку); выключение в виджете останавливает отправку напоминания за 24 часа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

findTemplateFor делает `notificationTemplate.findFirst({ where: { clinicId, isActive: true, ...where } })` без orderBy (triggers.ts:437-446). Онбординг создаёт reminder.24h с offsetMin -1440 (playbooks/index.ts:500-505), а виджет «Авто-сообщения» автосоздаёт appointment.reminder-24h с тем же -1440 (auto-messages.ts:143-172, reminderSpec). Для «Спасибо за визит» match `OR [{ trigger: APPOINTMENT\_COMPLETED }, { key: "appointment.thank-you" }]` (triggers.ts:302-308) захватывает и reminder.feedback (APPOINTMENT_COMPLETED в prisma/seed.ts и scripts/seed-prod-demo.ts:151-161).

TG-23 P2 · СРЕДНИЙ переводы

Узбекский текст шаблонов никогда не отправляется: все автоматические уведомления уходят на русском

ГДЕ

src/server/notifications/triggers.ts:539, src/server/notifications/triggers.ts:722, src/server/notifications/triggers.ts:1125, src/server/workers/notifications-scheduler.ts:255, src/server/workers/medication-reminder.ts:221

СЦЕНАРИЙ

Пациентка выбрала узбекский язык в мини-аппе. Напоминание «за день», уведомление об отмене и поздравление приходят по-русски, хотя администратор старательно заполнил узбекскую версию.

ПОСЛЕДСТВИЯ

Узбекоязычные пациенты (значительная часть аудитории) получают сообщения на неродном языке; работа администратора над bodyUz бессмысленна.

ЧТО СДЕЛАТЬ

Во всех материализаторах выбирать тело по patient.preferredLang (RU/UZ) и передавать lang в buildContext (имена врачей, услуг, клиники на нужном языке).

КРИТЕРИЙ ПРИЁМКИ

Для пациента с preferredLang=UZ все автоматические уведомления создаются с bodyUz и узбекскими названиями врача/услуги.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В каскаде `const lang = "ru";` (triggers.ts:539) и `const lang = "ru"; // MVP: always Russian; lang per patient → Phase 4` (722), день рождения `findTemplateFor(cid, "birthday", "ru")` (1125), повторный визит `render(tpl.bodyRu, ...)` (1443), динамический проход `render(tpl.bodyRu, ...)` (scheduler.ts:255), лекарства `render(tpl.bodyRu, ...)` (medication-reminder.ts:221). У пациента есть `preferredLang` (schema.prisma:1756), а редактор шаблонов и дефолтные шаблоны содержат bodyUz. Используется он только в кампаниях (launch.ts:66-68) и call-notice.

TG-24 P2 · СРЕДНИЙ баг

Шаблоны и рассылки с символами «<» или «&» не доставляются: текст сотрудника уходит в Telegram с parse_mode HTML без экранирования

ГДЕ

src/server/notifications/adapters/tg-clinic.ts:46, src/server/notifications/template.ts:59, src/server/campaigns/launch.ts:212

СЦЕНАРИЙ

Админ отправляет рассылку «Детям <14 лет консультация бесплатно» на 2000 пациентов — все строки FAILED после трёх попыток. Шаблон «Скидка на МРТ & ЭЭГ» не доходит ни до кого.

ПОСЛЕДСТВИЯ

Массовые недоставки маркетинговых и сервисных сообщений из-за обычной пунктуации, ретраи впустую нагружают очередь.

ЧТО СДЕЛАТЬ

Либо отправлять без parse_mode (plain text), либо экранировать текст шаблона/рассылки и разрешать только белый список тегов, валидируя при сохранении; превью в редакторе показывать так же, как увидит пациент.

КРИТЕРИЙ ПРИЁМКИ

Рассылка и шаблон с «<14», «А & В» доходят до SENT, текст отображается корректно.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Все уведомления и рассылки отправляются с `parse\_mode: "HTML"` (tg-clinic.ts:46-51). render экранирует только подставляемые значения, сам текст шаблона/рассылки остаётся сырым (template.ts:59-64). Тело рассылки из диалога (BroadcastBodySchema, schemas/campaign.ts:65) проходит в buildBody без экранирования (launch.ts:212-219). По правилам Bot API все «<», «>» и «&», не являющиеся частью тега/сущности, должны быть экранированы, иначе 400 «can't parse entities», которое воркер ретраит и затем помечает FAILED.

TG-25 P2 · СРЕДНИЙ мёртвая механика

Шаблоны из редактора не срабатывают (всегда trigger MANUAL), канал «Email» ничего не доставляет, панель «Триггеры» показывает связи по ключу, а не по реальному правилу

ГДЕ

src/app/[locale]/crm/notifications/_components/template-editor.tsx:57, src/app/[locale]/crm/notifications/_components/template-editor.tsx:289, src/server/notifications/triggers.ts:295, src/app/api/crm/notifications/triggers/route.ts:22, src/app/[locale]/crm/notifications/_components/triggers-panel.tsx:16

СЦЕНАРИЙ

Админ создаёт в редакторе шаблон «Напоминание за день», выбирает ключ appointment.reminder-24h, канал Email, сохраняет — ни одного письма и ни одного сообщения. На странице «Триггеры» переключатель для appointment.cancelled неактивен с подсказкой «нужен шаблон», хотя отмены реально отправляются.

ПОСЛЕДСТВИЯ

Администратор не может управлять уведомлениями через интерфейс; видимость настройки при фактическом отсутствии эффекта.

ЧТО СДЕЛАТЬ

Добавить в редактор выбор триггера и параметров (или создавать шаблоны только через «Настройки уведомлений»), убрать Email из каналов до появления адаптера, панель «Триггеры» строить по реальному правилу выбора шаблона (enum+offset/audience), метки брать из данных.

КРИТЕРИЙ ПРИЁМКИ

Созданный в редакторе шаблон с триггером «за 24 часа» отправляется; канала Email в списке нет; панель триггеров показывает фактически используемые шаблоны для каждого события.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Форма редактора (FormState, template-editor.tsx:57-66) не содержит trigger/triggerConfig, поэтому новый шаблон создаётся с `trigger` по умолчанию MANUAL (schemas/notification.ts:54). Редактор подсказывает выбрать ключ из TRIGGER_KEYS (265-274), но диспетчер ищет шаблоны по enum trigger + offsetMin (whereForTrigger, triggers.ts:295-420), а не по ключу — созданный «appointment.reminder-24h» не сработает никогда. Селект канала предлагает Email (289); для EMAIL pickRecipient возвращает телефон (triggers.ts:486-491), а воркер бросает `Channel EMAIL not dispatchable` (notifications-send.ts:261-267). Страница «Триггеры» ищет шаблоны `where: { key: { in: TRIGGER\_KEYS } }` (triggers/route.ts:22-38), поэтому, например, реальные шаблоны отмены с ключами

by-staff/by-patient отображаются как «нужен шаблон», а метки задержек захардкожены (triggers-panel.tsx:16-24: «09:00 clinic TZ» для дня рождения, «-2h» для неканонического 2h).

TG-26 РЗ · НИЗКИЙ мокап / заглушка

Inline-кнопки в сообщениях — нерабочая функция: нажатия пациента нигде не видны, а кнопка без callback_data ломает отправку

ГДЕ

src/app/[locale]/crm/telegram/_components/message-composer.tsx:1134, src/app/[locale]/crm/telegram/_components/message-composer.tsx:270, src/app/api/telegram/webhook/[clinicSlug]/route.ts:648

СЦЕНАРИЙ

Оператор добавляет к сообщению кнопки «Утро» / «Вечер», заполняет только текст — сообщение не уходит. Заполняет данные — пациент нажимает «Вечер», а оператор этого не видит и ждёт ответа.

ПОСЛЕДСТВИЯ

Потерянные ответы пациентов, ощущение, что функция работает.

ЧТО СДЕЛАТЬ

Либо убрать редактор кнопок, либо записывать нажатие как входящее сообщение в тред («Пациент нажал: Вечер») и валидировать кнопки перед отправкой (текст и callback_data обязательны).

КРИТЕРИЙ ПРИЁМКИ

Нажатие inline-кнопки появляется в переписке CRM; попытка отправить кнопку без данных блокируется валидацией в UI.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Редактор кнопок создаёт кнопки с `callback\_data: ""` (message-composer.tsx:1134, 1147) и отправляет строки как есть (270). Telegram требует callback_data 1-64 байта, иначе 400 и сообщение FAILED. Если данные заполнены, при нажатии webhook лишь отвечает answerCallbackQuery и публикует tg.takeover.incoming с callbackData (route.ts:616-661); Message не создаётся, в UI callbackData нигде не используется (поиск по src/app и src/components).

TG-27 РЗ · НИЗКИЙ безопасность

POST /api/crm/notifications/sends позволяет колл-оператору отправить любой текст с HTML-ссылками от имени бота клиники на любой chat_id, в обход инбокса

ГДЕ

src/app/api/crm/notifications/sends/route.ts:56, src/server/schemas/notification.ts:71, src/server/notifications/adapters/tg-clinic.ts:46

СЦЕНАРИЙ

Колл-оператор отправляет через API сообщение «Клиника: оплатите по ссылке» со ссылкой на свой кошелёк на chat_id пациентов, взятые из карточек. В переписке клиники этого не видно.

ПОСЛЕДСТВИЯ

Фишинг и мошенничество от имени клиники низкоправными сотрудниками, без следов в инбоксе.

ЧТО СДЕЛАТЬ

Ограничить ручное создание отправок ADMIN; recipient вычислять на сервере из Patient.telegramId (проверяя clinicId пациента), тело брать из шаблона или экранировать; записывать ручные отправки в тред пациента.

КРИТЕРИЙ ПРИЁМКИ

CALL_OPERATOR получает 403; для ADMIN запрос с recipient, не совпадающим с telegramId пациента клиники, отклоняется; ручная отправка видна в переписке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роут доступен ролям ADMIN, RECEPTIONIST, CALL_OPERATOR и создаёт QUEUED-строку с полями из тела как есть: `recipient: body.recipient, body: body.body, patientId: body.patientId` (sends/route.ts:56-73). Схема: recipient — любая строка до 200, body до 10000, patientId не проверяется на принадлежность клинике (schemas/notification.ts:71-79). Воркер отправляет с `parse\_mode: "HTML"` (tg-clinic.ts:46-51), то есть работают `

Redis для BullMQ запущен с политикой вытеснения allkeys-lru: при нехватке памяти пропадают задачи и расписания воркеров

ГДЕ

docker-compose.yml:43, src/server/queue/bullmq-adapter.ts:145, src/server/queue/bullmq-adapter.ts:42, src/server/workers/notifications-scheduler.ts:327

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Большая рассылка плюс дубли задач (см. предыдущую находку) и SSE-трафик заполняют 256 МБ; Redis вытесняет ключ расписания notifications:scheduler — напоминания перестают материализоваться и отправляться до перезапуска воркера, никто не замечает.

ПОСЛЕДСТВИЯ

Тихая остановка всех фоновых процессов уведомлений.

ЧТО СДЕЛАТЬ

Для Redis под BullMQ установить `maxmemory-policy noeviction` (при необходимости отдельный инстанс для кеша/pub-sub), добавить мониторинг памяти и живости расписаний.

КРИТЕРИЙ ПРИЁМКИ

redis-cli CONFIG GET maxmemory-policy в проде возвращает noeviction; воркер не пишет предупреждение BullMQ про eviction policy.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`command: ["redis-server", "--appendonly", "yes", "--maxmemory", "256mb", "--maxmemory-policy", "allkeys-lru"]` (docker-compose.yml:43). В проде задан REDIS_URL, поэтому очереди и повторяющиеся расписания (upsertJobScheduler, bullmq-adapter.ts:145-156) живут в этом Redis. BullMQ требует `noeviction`: при allkeys-lru Redis может вытеснить ключи задач и job schedulers.

{{patient.firstName}} подставляет фамилию: «Каримов, спасибо, что были у нас»

ГДЕ

src/server/notifications/triggers.ts:142, src/server/workers/notifications-scheduler.ts:258, src/server/workers/medication-reminder.ts:69, src/server/campaigns/launch.ts:78, src/messages/ru.json:865

СЦЕНАРИЙ

Пациент «Каримов Алишер Бахтиёрович» получает «Каримов, напоминаем: завтра в 10:00...», «Каримов, спасибо, что были у нас сегодня!».

ПОСЛЕДСТВИЯ

Непрофессиональное, неуважительное обращение во всех автоматических сообщениях клиники.

ЧТО СДЕЛАТЬ

Вынести единый helper givenName(fullName) (второй токен при 2+ словах) и использовать во всех рендерах; в перспективе хранить имя отдельным полем.

КРИТЕРИЙ ПРИЁМКИ

Для «Каримов Алишер Бахтиёрович» во всех триггерах, напоминаниях о лекарствах и кампаниях подставляется «Алишер».

ДОКАЗАТЕЛЬСТВО В КОДЕ

firstName берёт первый токен ФИО: `trimmed.split(/\s+/)[0]` (triggers.ts:142-146, scheduler.ts:258, medication-reminder.ts:69-73). ФИО в CRM вводится в порядке «Фамилия Имя Отчество» (плейсхолдер «Иванов Иван Иванович», ru.json:865; «Фамилия Имя 1969», ru.json:6935). При этом в кампаниях сделано правильно — второй токен (launch.ts:78-85), то есть реализации расходятся.

Быстрое действие «Подтвердить запись» только вставляет текст «Подтверждаю вашу запись», саму запись не подтверждает

ГДЕ

src/app/[locale]/crm/telegram/_components/message-composer.tsx:665, src/messages/ru.json:3355

СЦЕНАРИЙ

Пациент пишет «приду завтра», оператор жмёт «Подтвердить запись», пациенту уходит «Подтверждаю вашу запись». В CRM запись остаётся неподтверждённой: колл-центр получает задачу «не подтверждено за 24 ч» и звонит пациенту, каскад продолжает спрашивать подтверждение.

ПОСЛЕДСТВИЯ

Лишние звонки и сообщения пациенту, недостоверный статус подтверждения.

ЧТО СДЕЛАТЬ

Действие должно показывать ближайшие записи пациента и вызывать confirmAppointment (via MANUAL_CRM), затем вставлять текст; без записи — неактивно.

КРИТЕРИЙ ПРИЁМКИ

После «Подтвердить запись» у выбранной записи стоит confirmedAt/confirmedVia=MANUAL_CRM, в трее отправлен текст подтверждения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

QuickCard «Подтвердить запись» (ru.json:3351) вызывает `insert(t("confirmText"))` (message-composer.tsx:662-666), confirmText = «Подтверждаю вашу запись. Если планы изменятся — напишите...» (ru.json:3355). confirmAppointment не вызывается, confirmedAt не ставится.

Воронка рассылок показывает «Доставлено 0 · Прочитано 0» у каждой рассылки — метрики, которые система не собирает

ГДЕ

src/app/api/crm/campaigns/broadcasts/route.ts:97, src/app/[locale]/crm/telegram/_components/broadcast-history.tsx:199, src/server/campaigns/launch.ts:220

СЦЕНАРИЙ

Маркетолог отправил акцию 1500 пациентам и видит «Отправлено 1480 · Доставлено 0 · Прочитано 0», делает вывод, что Telegram-рассылки не работают.

ПОСЛЕДСТВИЯ

Вводящая в заблуждение аналитика рассылок.

ЧТО СДЕЛАТЬ

Убрать «Доставлено/Прочитано» для TG или заменить реальными сигналами (переходы по кнопке, ответы, блокировки); подписать «Отправлено» как фактическую метрику.

КРИТЕРИЙ ПРИЁМКИ

В истории рассылок нет метрик, которые всегда равны нулю; показаны только собираемые показатели.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Рассылка создаёт только TG-строки (launch.ts:220-230, INAPP не зеркалится). TG-строка максимум SENT (record-delivery.ts:99-107), статусы DELIVERED/READ ставятся только для INAPP в мини-аппе (api/miniapp/inbox/[id]/route.ts:46). Тем не менее история рассылок всегда рисует «Доставлено» и «Прочитано» (broadcast-history.tsx:196-205) из групп DELIVERED/READ (broadcasts/route.ts:97-113).

Врач (и любой сотрудник) читает, пишет и меняет любой диалог по id в обход скоупа; PATCH принимает patientId и assignedTold без проверки клиники

ГДЕ

src/app/api/crm/conversations/[id]/route.ts:17, src/app/api/crm/conversations/[id]/messages/route.ts:28, src/app/api/crm/conversations/route.ts:45, src/server/schemas/conversation.ts:17, src/app/api/crm/conversations/[id]/messages/route.ts:36, src/app/api/crm/conversations/[id]/messages/route.ts:69, src/app/api/crm/conversations/[id]/route.ts:52, src/app/[locale]/doctor/messages/_hooks/use-conversations.ts:53

ТАКЖЕ НАШЛИ ЗОНЫ

Остальной кабинет врача

СЦЕНАРИЙ

Врач, зная id диалога (из уведомления, ссылки коллеги или перебора списка с doctorId коллеги), читает переписку чужого пациента о диагнозе. Сотрудник, знающий suid пациента другой клиники, привязывает к нему свой тред и через GET видит его ФИО и телефон.

ПОСЛЕДСТВИЯ

Нарушение разграничения доступа к медицинской переписке внутри клиники и потенциальная межтенантная утечка при известном id.

ЧТО СДЕЛАТЬ

Вынести проверку доступа к треду в общий guard (для DOCTOR — doctorConversationScope), игнорировать doctorId от роли DOCTOR, валидировать patientId/assignedTold на принадлежность clinicId.

КРИТЕРИЙ ПРИЁМКИ

Врач получает 404 на тред вне своего скоупа и на список с чужим doctorId; PATCH с patientId другой клиники возвращает 400.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Скоуп врача применяется только в списке (conversations/route.ts:34-66), при этом параметр `doctorId` принимается от любого вызывающего, включая врача (45-46), что позволяет посмотреть кейслоад коллеги. GET/PATCH /conversations/[id] и GET/POST /messages проверяют только clinicId (route.ts:17-37, 39-60; messages/route.ts:28-44, 62-87). UpdateConversationSchema принимает `patientId` и `assignedTold` любыми строками (schemas/conversation.ts:13-21), updateMany пишет их как есть, а GET затем делает include patient { fullName, phone } без фильтра клиники.

TG-33 РЗ · НИЗКИЙ UX

Врач, медсестра и колл-оператор видят в шапке Telegram-инбокса нули: API статистики им запрещён, ошибка не показывается

ГДЕ

src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:120, src/app/api/crm/telegram/stats/route.ts:13, src/app/[locale]/crm/telegram/_components/telegram-stats-bar.tsx:74

СЦЕНАРИЙ

Врач открывает раздел Telegram и видит «0 в Telegram, 0 доступны», решает, что бот не работает.

ПОСЛЕДСТВИЯ

Ложные цифры и лишние запросы.

ЧТО СДЕЛАТЬ

Не рендерить бар для ролей без доступа или открыть им чтение агрегатов; при ошибке показывать прочерк.

КРИТЕРИЙ ПРИЁМКИ

Для роли DOCTOR бар скрыт или показывает реальные значения; 403 в логах нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

TelegramStatsBar рендерится для всех ролей (telegram-page-client.tsx:120), а /api/crm/telegram/stats разрешён только ADMIN и RECEPTIONIST (stats/route.ts:13). При 403 хук бросает ошибку, а бар показывает `data?.totalInTelegram ?? 0` и т.д. (telegram-stats-bar.tsx:74-99), опрос каждые 60 с продолжает получать 403.

TG-34 РЗ · НИЗКИЙ UX

Кнопка «✓ Подтверждаю» в напоминании стирает сам текст напоминания: у пациента пропадают дата, время и врач

ГДЕ

src/app/api/telegram/webhook/[clinicSlug]/route.ts:588, src/app/api/telegram/webhook/[clinicSlug]/route.ts:600

СЦЕНАРИЙ

Пациент нажимает «Подтверждаю» в сообщении «завтра в 14:30 к неврологу Каримовой в кабинет 12».

Сообщение превращается в «✓ Подтверждено · спасибо!», и назавтра пациент не может посмотреть время и кабинет.

ПОСЛЕДСТВИЯ

Пациенты теряют информацию о визите, звонят в регистратуру или опаздывают.

ЧТО СДЕЛАТЬ

Использовать editMessageReplyMarkup (убрать клавиатуру) и дописывать строку «✓ Подтверждено» к исходному тексту, сохраняя его.

КРИТЕРИЙ ПРИЁМКИ

После нажатия кнопки исходный текст напоминания сохраняется, клавиатура исчезает, добавлена отметка о подтверждении.

ДОКАЗАТЕЛЬСТВО В КОДЕ

После успешного подтверждения `editTo = "✓ Подтверждено · спасибо!"` и `editMessageText(clinicMin, chatId, sq.message.message\_id, editTo)` (route.ts:588, 598-605) — заменяется весь текст сообщения, хотя цель по комментарию только убрать клавиатуру (581-582).

TG-35 РЗ · НИЗКИЙ UX

Лента «Уведомления» показывает в основном будущие напоминания: 200 строк по scheduledFor по убыванию, свежие отправки и ошибки вытесняются

ГДЕ

src/app/[locale]/crm/notifications/_hooks/use-queue.ts:47, src/app/api/crm/notifications/sends/route.ts:39

СЦЕНАРИЙ

Админ открывает «Уведомления», чтобы проверить, ушли ли сегодняшние напоминания, и видит только запланированные на следующую неделю; сегодняшние ошибки видны лишь через фильтр «Ошибки».

ПОСЛЕДСТВИЯ

Центр уведомлений неудобен для контроля доставки.

ЧТО СДЕЛАТЬ

По умолчанию показывать прошедшие/текущие (scheduledFor <= now) по убыванию, будущие — отдельной вкладкой; поддержать пагинацию; счётчики брать из API.

КРИТЕРИЙ ПРИЁМКИ

Открытие ленты показывает последние отправки и ошибки; будущие напоминания во вкладке «Запланировано».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Лента запрашивает `limit=200` (use-queue.ts:44-50), API сортирует `orderBy: { scheduledFor: "desc" }` (sends/route.ts:37-41). Каскад создаёт строки на 5 дней вперёд, плюс INAPP-зеркала, поэтому первые 200 — будущие QUEUED; nextCursor в UI не используется. Счётчики по каналам в сайдбаре считаются по этим же 200 строкам (notifications-types-sidebar.tsx:47-56).

TG-36 РЗ · НИЗКИЙ UX

На каждое входящее сообщение оператору показываются два тоста, второй — с безымянным «Пациент»

ГДЕ

src/app/api/telegram/webhook/[clinicSlug]/route.ts:446, src/app/[locale]/crm/telegram/_hooks/use-tg-inbox-alerts.ts:55

СЦЕНАРИЙ

В час пик регистратор получает по два всплывающих уведомления на каждое сообщение, половина без имени и текста.

ПОСЛЕДСТВИЯ

Шум в интерфейсе, реальные уведомления теряются.

ЧТО СДЕЛАТЬ

Тостить только tg.message.new (takeover.incoming использовать для invalidation), либо не публиковать takeover.incoming для обычных входящих.

КРИТЕРИЙ ПРИЁМКИ

Одно входящее сообщение даёт ровно один тост с именем и превью.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Webhook публикует tg.message.new (route.ts:428-441) и сразу tg.takeover.incoming для каждого входящего при выключенном автоответе или в режиме оператора (443-452). useTgInboxAlerts показывает тост и для одного, и для другого события (use-tg-inbox-alerts.ts:55-104); у takeover.incoming нет contactName и preview, поэтому второй тост «Новое сообщение в Telegram: Пациент».

Приветствие бота повторяется после каждой паузы в 30 минут и после каждого рестарта; в запасном тексте захардкожено «клиника Neurofax»

ГДЕ

src/server/telegram/state.ts:114, src/server/telegram/state.ts:156, src/server/telegram/state.ts:80

СЦЕНАРИЙ

Пациент переписывается с регистратором, отходит на час и пишет «а во сколько приходите?» — бот снова присылает большое двуязычное приветствие с кнопкой записи. У второй клиники-клиента бот представляется как Neurofax.

ПОСЛЕДСТВИЯ

Спам в переписке, путаница пациентов, чужой бренд у других клиник.

ЧТО СДЕЛАТЬ

Хранить факт приветствия в БД (например, Conversation.welcomedAt) и не повторять; дефолтный текст строить из названия клиники.

КРИТЕРИЙ ПРИЁМКИ

Повторное сообщение после паузы и после рестарта не вызывает приветствие; у клиники с другим названием в тексте её название.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Состояние FSM хранится в памяти процесса с TTL 30 минут (state.ts:156-189); при отсутствии снапшота состояние start и `if (isStartCommand || prev.state === "start") return enterWelcome(...)` (114-116). Запасной текст начинается «Это клиника Neurofax» (80, дублируется в auto-messages.ts:42-56) независимо от клиники. Актуально при TG_BOT_AUTOREPLY=1.

Режим long-poll (TG_USE_POLLING=true) безвозвратно теряет апдейты во время рестарта приложения и не видит новые клиники

ГДЕ

src/server/telegram/poll.ts:143, src/server/telegram/poll.ts:167, src/server/telegram/poll.ts:133

СЦЕНАРИЙ

Во время деплоя приложение недоступно 30 секунд, воркер получает три сообщения пациентов, форвард падает с ECONNREFUSED, offset сдвигается — сообщения потеряны навсегда. Подключённый сегодня бот новой клиники не опрашивается до перезапуска воркера.

ПОСЛЕДСТВИЯ

Потеря сообщений пациентов в режиме polling.

ЧТО СДЕЛАТЬ

Сдвигать offset только до последнего успешно обработанного апдейта, ретраить форвард с backoff; периодически перечитывать список клиник; обрабатывать апдейты одного чата последовательно.

КРИТЕРИЙ ПРИЁМКИ

При недоступном приложении апдейты повторяются после восстановления; новая клиника подхватывается без рестарта.

ДОКАЗАТЕЛЬСТВО В КОДЕ

offset сдвигается на maxId+1 «regardless of whether forwarding succeeded» (poll.ts:143-147), ошибки форварда только логируются (135-139). Список клиник загружается один раз при старте (167-177). Апдейты одного чата форвардятся параллельно (133-141), порядок сообщений может нарушиться. Режим включается только флагом TG_USE_POLLING (start.ts:164-166).

Режим «Бот» подписан «Бот сам ведёт переписку с пациентом», но бот максимум отправляет одно приветствие, а без TG_BOT_AUTOREPLY=1 молчит полностью

ГДЕ

src/messages/ru.json:2990, src/server/telegram/state.ts:118, src/app/api/telegram/webhook/[clinicSlug]/route.ts:443

СЦЕНАРИЙ

Новый оператор видит тред с меткой «Бот сам ведёт переписку» и не отвечает пациенту, спрашивающему о стоимости МРТ. Пациент ждёт ответа сутки.

ПОСЛЕДСТВИЯ

Пропущенные обращения пациентов из-за ложного обещания автоматизации.

ЧТО СДЕЛАТЬ

Переименовать режимы в «Новый / не взят» и «Оператор», убрать формулировку про ведение переписки ботом; по умолчанию все входящие должны требовать ответа оператора.

КРИТЕРИЙ ПРИЁМКИ

В UI нет утверждений о том, что бот ведёт переписку; непрочитанные треды в режиме «бот» явно помечены как требующие ответа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Все новые треды создаются в mode "bot" (route.ts:208), в UI режим подписан «Бот отвечает» и «Бот сам ведёт переписку с пациентом» (ru.json:2988-2990, mode-switch.tsx). FSM после приветствия всегда молчит: `// Already welcomed: stay silent — operator handles it. return { next: prev, outgoing: null }` (state.ts:118-119), а при отсутствии TG_BOT_AUTOREPLY=1 не запускается вовсе (route.ts:443-454).

МА · Мини-апп пациента и публичные страницы клиники

МА-01 P0 · КРИТИЧНО безопасность

Захват чужой медкарты через /api/miniapp/auth: номер телефона из тела запроса привязывает любой Telegram к существующему пациенту

ГДЕ

src/app/api/miniapp/auth/route.ts:56, src/app/api/miniapp/auth/route.ts:66, src/app/api/miniapp/auth/route.ts:74, src/server/miniapp/handler.ts:219, src/app/api/miniapp/auth/route.ts:21, src/app/c/[slug]/my/_components/miniapp-auth-provider.tsx:126, src/server/telegram/invite-token.ts:92

ТАКЖЕ НАШЛИ ЗОНЫ

Пациенты и медицинские случаи в CRM

СЦЕНАРИЙ

Злоумышленник знает номер пациентки клиники (соседка, бывший муж). Он заводит новый Telegram-аккаунт, открывает бота клиники в Telegram Web, блокирует первый вызов /api/miniapp/auth и копирует initData. Затем сам шлёт POST /api/miniapp/auth?clinicSlug=neurofax с телом {"phone":"+998901234567"}. Строка пациентки, заведённая на ресепшене, получает его telegramId. После этого он открывает мини-апп и видит её записи, заключения невролога, диагнозы, анализы и назначения, скачивает PDF-заключения, запрашивает экспорт всех данных и может поставить её карту на анонимизацию (подтверждение — тот же номер телефона). Настоящая пациентка теряет доступ: при следующем входе ей создаётся пустая карта.

ПОСЛЕДСТВИЯ

Полная утечка медицинской карты любого пациента, чей номер известен (а номера пациентов неврологии знают родственники, коллеги, коллекторы). Кроме того, можно отменять записи жертвы и запустить удаление её данных. Критично для клиники с живыми пациентами.

ЧТО СДЕЛАТЬ

Убрать поле phone из /api/miniapp/auth и никогда не привязывать telegramId по номеру, который прислал клиент. Привязка к существующей карте допустима только через (а) invite-токен с ресепшена (уже есть в invite-token.ts) или (б) Telegram contact sharing в боте с проверкой `message.contact.user\_id === message.from.id`, после чего в Patient пишется подтверждённый номер. Если у строки уже есть другой telegramId, не перезаписывать его, а писать аудит и уводить в ручное разрешение. Проверить прод-БД на перепривязки: `telegramLinkedAt` не null и `source != TELEGRAM`, сверить с аудитом.

КРИТЕРИЙ ПРИЁМКИ

POST /api/miniapp/auth с валидным initData нового TG-аккаунта и телом {phone: номер существующего пациента} не меняет telegramId у этой карты (проверка в БД) и возвращает новую пустую карту либо отказ. Юнит-тест на auth route: телефон в теле игнорируется. Привязать карту можно только через invite-ссылку или подтверждённый контакт.

ДОКАЗАТЕЛЬСТВО В КОДЕ

auth/route.ts:21-26 принимает в теле `phone: z.string().optional()`. Стр. 56-58: `normalizedPhone = normalizePhone(parsedBody.phone)`. Стр. 63-83: если по telegramId пациента нет и телефон передан, то `prisma.patient.findFirst({ where: { clinicId, phoneNormalized: normalizedPhone } })`, и найденной строке делают `update({ data: { telegramId: tgIdStr, ... } })`. Телефон ничем не подтверждён (Telegram contact-sharing не используется, в вебхуке бота привязка идёт только через invite-токен, invite-token.ts). Проверки `patient.telegramId` уже занят нет, поэтому у жертвы telegramId просто перезаписывается. Дальше каждый запрос мини-аппа (handler.ts:219-233) находит пациента по telegramId атакующего, и все эндпоинты (appointments, visit-summary, documents/file, labs, medications, account/export в Telegram атакующего, account/delete) работают с картой жертвы. Штатный клиент шлёт `body: {}` (miniapp-auth-provider.tsx:130), так что поле phone оставлено только для атаки.

МА-02 P1 · ВЫСОКИЙ целостность данных

Запись «за родственника» создаётся на владельца: мастер записи теряет ?onBehalfOf при каждом переходе

ГДЕ

src/app/c/[slug]/my/_hooks/use-active-context.ts:24, src/app/c/[slug]/my/_components/miniapp-home.tsx:249, src/app/c/[slug]/my/_components/book/service-picker.tsx:94, src/app/c/[slug]/my/_components/book/doctor-picker.tsx:73, src/app/c/[slug]/my/_components/book/slot-picker.tsx:119, src/app/c/[slug]/my/_components/book/book-confirm.tsx:45

СЦЕНАРИЙ

Сын, связанный на ресепшене с мамой, на главной выбирает «Мама» и нажимает «Записаться», выбирает невролога и время и подтверждает. Запись создаётся на сына. Врач открывает карту сына, пишет в неё осмотр мамы и назначения, заключение уходит на сына.

ПОСЛЕДСТВИЯ

Медицинские данные попадают не в ту карту: осмотр, диагноз и назначения записываются другому человеку. Мама при этом не записана.

ЧТО СДЕЛАТЬ

Хранить активного пациента не в query, а в общем состоянии: context, sessionStorage внутри useBookingDraft (поле onBehalfOf в черновике) или сохранять query при router.push и Link. На экране подтверждения явно показывать «Запись для: <ФИО>» и брать имя и телефон активного пациента, а не владельца. При несовпадении draft.onBehalfOf и текущего контекста блокировать отправку.

КРИТЕРИЙ ПРИЁМКИ

E2E-сценарий: выбрать родственника, пройти 4 шага мастера, в POST /api/miniapp/appointments присутствует onBehalfOf, в БД appointment.patientId = id родственника. На экране подтверждения виден родственник.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Контекст «от чьего имени» хранится только в URL: use-active-context.ts:24 `onBehalfOf = params.get("onBehalfOf")`. Все переходы в мастер и внутри него строят URL без query: miniapp-home.tsx:249 `href=/c/\${slug}/my/book/service`, service-picker.tsx:94 `router.push(.../book/doctor)`, doctor-picker.tsx:73 `.../book/slot`, slot-picker.tsx:119 `.../book/confirm`. treatment-plan-card.tsx:85 передаёт onBehalfOf только на первый шаг, дальше он теряется. На экране подтверждения book-confirm.tsx:45 `useActiveContext()` возвращает null, и POST уходит без onBehalfOf. Сервер (appointments/route.ts:151-158) создаёт запись на ctx.patientId, то есть на владельца. Форма к тому же подставляет имя и телефон владельца (стр. 54-58).

МА-03 Р1 · ВЫСОКИЙ мокап / заглушка

Самостоятельная регистрация клиник — макет: «подтверждение по email» не отправляется, токен приходит прямо в ответе, любой создаёт клинику и ADMIN на проде

ГДЕ

src/app/api/public/signup/route.ts:82, src/app/api/public/signup/route.ts:107, src/app/api/public/signup/confirm/route.ts:142, src/app/[locale]/signup/_components/signup-form.tsx:107, src/app/api/public/signup/route.ts:61, src/app/api/public/signup/route.ts:86, src/app/api/public/signup/confirm/route.ts:224, src/app/[locale]/signup/_components/signup-form.tsx:126, src/app/api/public/signup/confirm/route.ts:124, src/app/[locale]/signup/_components/signup-form.tsx:125, src/app/[locale]/signup/page.tsx:33

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа, Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Кто угодно открывает neurofax.uz/signup, вводит «Клиника X» и чужой email (например, почту главврача конкурента) и сразу получает ссылку-подтверждение, а по ней логин ADMIN и временный пароль. Скрипт создаёт тысячи клиник-тенантов в прод-базе, где живёт реальная клиника. Настоящий владелец email потом не сможет зарегистрироваться (email_taken).

ПОСЛЕДСТВИЯ

Засорение прод-БД мультитенантной медсистемы, злоупотребление триалом, захват email-адресов. Функция выглядит готовой («проверьте почту»), но проверка почты не существует.

ЧТО СДЕЛАТЬ

До подключения реальной почты выключить /signup и /api/public/signup* в проде (feature-flag или env). Когда почта появится: не возвращать token в ответе, отправлять ссылку письмом, rate-limit по IP и email, captcha (Turnstile), модерация новых тенантов SUPER_ADMIN'ом.

КРИТЕРИЙ ПРИЁМКИ

В проде GET /signup отдаёт 404, а POST /api/public/signup отдаёт 404/403. После включения ответ POST не содержит поля token, а подтвердить регистрацию можно только по ссылке из письма.

ДОКАЗАТЕЛЬСТВО В КОДЕ

signup/route.ts:14-16 и 82-88: «Email delivery is NOT in scope... we just console.info the confirm-link». Стр. 103-107: `return ok({ ok: true, token, expiresAt })`, то есть токен отдаётся тому, кто прислал запрос. signup-form.tsx:107-108 сразу показывает confirmUrl в интерфейсе. confirm/route.ts:142-191 по токenu создаёт Clinic(active: true), User(role ADMIN), Subscription TRIAL и возвращает tempPassword. Rate-limit, captcha и проверки владения email нет.

МА-04 P1 · ВЫСОКИЙ целостность данных

Существующий пациент клиники, открывший бота без invite, получает дубль-карту; запись со своим номером падает с 500, а после invite у двух карт один telegramId

ГДЕ

src/app/api/miniapp/auth/route.ts:84, src/app/api/miniapp/appointments/route.ts:174, src/app/api/miniapp/profile/route.ts:160, src/server/telegram/invite-token.ts:93, src/server/miniapp/handler.ts:222, prisma/schema.prisma:1856

СЦЕНАРИЙ

Пациентка месяц назад была на приёме (карта заведена на ресепшене с её номером). Сегодня она открывает бота и пытается записаться повторно, вводит свой номер и получает «Не удалось записаться: HTTP 500» при каждой попытке. В профиле ей пишут, что номер «используется другим пациентом». Позже врач печатает заключение с QR-приглашением, она сканирует, и теперь у неё две карты на один Telegram, а мини-апп показывает то пустую, то настоящую.

ПОСЛЕДСТВИЯ

Самый частый сценарий (повторный пациент впервые в боте) ломает онлайн-запись. Плодятся дубли карт, и история визитов пациенту не видна.

ЧТО СДЕЛАТЬ

(1) В POST booking ловить P2002: не менять телефон, а вернуть 409 с понятной причиной «номер уже в карте клиники, привяжите через ресепшене/Qr», либо не синхронизировать телефон из формы вообще. (2) При consume invite-токена, если у этого telegramId уже есть авто-карта (source TELEGRAM, phone tg:*, без визитов), снять с неё telegramId или слить её в карту ресепшена. (3) Сделать частичный уникальный индекс (clinicId, telegramId) WHERE telegramId IS NOT NULL. (4) В handler и auth добавить детерминированный orderBy. (5) Дать пациенту путь «у меня уже есть карта» через подтверждённый контакт.

КРИТЕРИЙ ПРИЁМКИ

Бронь из мини-аппа с номером, который уже есть в другой карте, не даёт 500 (юнит-тест). В БД нет двух пациентов одной клиники с одинаковым telegramId (запрос GROUP BY clinicId, telegramId HAVING count>1 пуст). После invite мини-апп стабильно открывает карту с историей.

ДОКАЗАТЕЛЬСТВО В КОДЕ

auth/route.ts:84-105: если по telegramId никого нет (клиент всегда шлёт body {}), создаётся новая карта с `phone = "tg:<id>". На экране подтверждения записи пациент вводит свой настоящий номер. appointments/route.ts:174-189 делает `prisma.patient.update({ phoneNormalized })` без try/catch, а номер уже занят картой с ресепшена (@@unique([clinicId, phoneNormalized])). Prisma P2002 пробрасывается наружу (catch на стр. 276-279 делает rethrow), в ответе 500, и запись не создаётся. В профиле тот же случай даёт 409 и текст «Этот номер уже используется другим пациентом» (ru.ts:290). Если потом пациент сканирует invite-QR из заключения, invite-token.ts:93-108 ставит telegramId на карту с ресепшена и не трогает дубль. telegramId не уникален (schema.prisma:1856, только @@index), а handler.ts:222-224 и auth/route.ts:63-65 делают `findFirst({ clinicId, telegramId })` без orderBy, так что мини-апп открывает то одну карту, то другую.

МА-05 P1 · ВЫСОКИЙ безопасность

Чужую карту можно «добавить в семью» по ФИО и телефону и читать всю медицину через onBehalfOf

ГДЕ

src/app/api/miniapp/family/route.ts:111, src/app/api/miniapp/family/route.ts:149, src/server/miniapp/active-patient.ts:51, src/app/c/[slug]/my/family/add/page.tsx:1

СЦЕНАРИЙ

Муж, который живёт отдельно, знает ФИО и номер жены. В мини-аппе бота клиники он шлёт POST /api/miniapp/family с {fullName: "Каримова Дилноза Рустамовна", phone: "+99890...", relationship: "spouse"} (или вводит это на /my/family/add). Сервер находит её карту и привязывает к нему. Теперь в переключателе семьи он выбирает её и видит визиты к неврологу/психиатру, диагнозы, назначенные препараты и анкеты перед визитом.

ПОСЛЕДСТВИЯ

Утечка диагнозов и назначений любого пациента, чьи ФИО и телефон известны. Нарушение врачебной тайны. Кроме того, от имени жертвы можно записывать, переносить и отменять приёмы и оставлять отзывы.

ЧТО СДЕЛАТЬ

Убрать автоматический claim существующей карты. Если карта с таким телефоном уже есть, не связывать её, а создать заявку «запрос на доступ», которую подтверждает ресепшен или сам владелец карты (TG-подтверждение владельцу, если у карты есть telegramId). Если карта взрослого уже привязана к своему TG, связь только с его явным согласием. На всякий случай запретить claim карт, у которых есть telegramId. Аудит всех существующих PatientFamily, созданных через мини-апп с createdNew=false (outbox-событие patient.familyLinked с payload.createdNew=false).

КРИТЕРИЙ ПРИЁМКИ

POST /api/miniapp/family с ФИО и телефоном существующего пациента не создаёт PatientFamily к этой карте без подтверждения (проверка в БД). Вызов GET /api/miniapp/visit-summary/<id>?onBehalfOf=<чужой id> возвращает 403. Юнит-тест на claim-ветку.

ДОКАЗАТЕЛЬСТВО В КОДЕ

family/route.ts:108-122 («claim path»): если в клинике есть пациент с таким же `fullName` и `phoneNormalized`, то `claimCandidateld = match.id`. Стр. 149-150: `linkedPatientId = claimCandidateld`, и создаётся PatientFamily(owner = ctx.patientId, linked = чужой пациент). Согласия второй стороны, подтверждения по SMS или invite нет. Проверки, что у claimed-пациента свой telegramId или что он взрослый, тоже нет. resolveActivePatient (active-patient.ts:51-61) считает такую связь достаточной для onBehalfOf. Через неё открываются /api/miniapp/appointments?onBehalfOf=, visit-summary (диагноз, памятка), medications (препараты, диагноз визита), treatment-plan (diagnosisText), pre-visit (жалобы, аллергии), nps, ics, отмена приёма через PATCH. Страница /c/[slug]/my/family/add в интерфейсе нигде не связана ссылкой, но существует, а API работает.

МА-06 Р2 · СРЕДНИЙ мёртвая механика

QR-коды на бумаге не открываются: /v/<token> (подлинность заключения) и /t/<code> (талон) перехватываются next-intl; /v к тому же падает на fail-closed тенанте

ГДЕ

src/proxy.ts:270, src/app/v/[token]/route.ts:31, src/lib/prisma.ts:204, src/app/c/[slug]/my/_components/book/book-done.tsx:78, src/app/api/crm/visit-notes/[id]/print/route.ts:598, src/proxy.ts:269, src/server/workers/visit-note-handout.ts:168, src/server/workers/referral-document.ts:97, src/app/api/crm/visit-notes/[id]/print/route.ts:599

ТАКЖЕ НАШЛИ ЗОНЫ

Клинические документы, больничные, рецепты, анализы, направления, файлы

СЦЕНАРИЙ

Пациент показывает заключение невролога в другой клинике или работодателю. Тот сканирует QR «проверка подлинности» и получает «страница не найдена» или ошибку сервера, и документ выглядит поддельным. Пациент на ресепшене показывает QR талона из мини-аппа, и сканер открывает 404.

ПОСЛЕДСТВИЯ

Функция проверки подлинности документов, заявленная на каждом печатном заключении, не работает. Талон-QR из мини-аппа тоже. Это бьёт по доверию к документам клиники.

ЧТО СДЕЛАТЬ

Добавить `vv` и `tv` в исключения matcher в proxy.ts. В v/[token]/route.ts обернуть запрос в runUnscoped("public document verify by unguessable verifyToken", ...), как в verify/recipe. Добавить e2e/интеграционный тест на GET /v/<token> и /t/<code>.

КРИТЕРИЙ ПРИЁМКИ

`curl -i https://neurofax.uz/v/<реальный verifyToken>` возвращает 200 и HTML «ПОДЛИННЫЙ ДОКУМЕНТ». `curl -i https://neurofax.uz/t/<ticketCode>` возвращает 307 на /q/<id>. Тест в CI.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Matcher proxy.ts:270 `/(?!(?!api|\_next|vercel|login|admin|kiosk|tv|receptionist|ticket|cV|qV|.\*\\.)\*.\*)` исключает c/, q/ и ticket, но не v/ и t/. Такие запросы уходят в `intlMiddleware` (стр. 265), а next-intl 4.9 при localePrefix 'as-needed' переписывает путь без префикса в `/ru/v/...` (node_modules/next-intl/.../middleware.js: `response = next(internalHref)` → `NextResponse.rewrite`) или редиректит на /uz/.... Маршрутов /[locale]/v и /[locale]/t нет, значит 404. Независимо от этого v/[token]/route.ts:31 вызывает `prisma.document.findFirst` вне runWithTenant/runUnscoped. Document тенантная модель, а prisma.ts:204-207 без контекста бросает MissingTenantContextError, то есть 500. В соседних verify/recipe и verify/sick-leave обёртка runUnscoped есть. QR с `\${baseUrl}/v/\${token}` печатается на каждом заключении и направлении (print/route.ts:598-599, 1482), QR `/t/<ticketCode>` есть на экране «Готово» (book-done.tsx:78) и в талоне (ticket-sheet.tsx:110).

МА-07 P2 · СРЕДНИЙ безопасность

initData (ключ ко всей карте на 24 часа) передаётся в URL, пишется в access-лог nginx и принимается любым эндпоинтом мини-аппа

ГДЕ

src/server/miniapp/handler.ts:95, nginx/nginx.conf:31, src/app/c/[slug]/my/_components/documents-screen.tsx:37, src/app/c/[slug]/my/_components/appointments/appointment-detail-dialog.tsx:51, src/app/c/[slug]/my/_hooks/use-miniapp-live-events.tsx:219, src/server/miniapp/handler.ts:96, nginx/nginx.conf:32, src/server/telegram/auth.ts:40

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Пациент пересылает родственнику «ссылку на заключение» из браузера. По ней получатель сутки может вызывать любые API от имени пациента: список визитов, отмена записи, добавление родственников. Любой с доступом к `docker logs` nginx видит initData сотен пациентов.

ПОСЛЕДСТВИЯ

Утечка учётных данных пациентов через логи и пересылаемые ссылки, область действия шире необходимой.

ЧТО СДЕЛАТЬ

Принимать ?initData только в /api/miniapp/events и */file, */ics (GET, только чтение). Для ссылок выдавать короткоживущий подписанный токен на конкретный документ (5 минут, одноразовый) вместо initData. В nginx логировать \$uri без query для /api/miniapp.

КРИТЕРИЙ ПРИЁМКИ

POST или DELETE на /api/miniapp/* с initData только в query отвечает 401. Ссылки на документы содержат одноразовый токен, а не initData. В access-логе нет строки initData=.

ДОКАЗАТЕЛЬСТВО В КОДЕ

handler.ts:95-97 `queryInit = searchParams.get("initData")` принимается для ЛЮБОГО /api/miniapp/* (в том числе POST family, DELETE appointments, account/delete), хотя нужен только для EventSource и ссылок на файлы. Клиент кладёт initData в URL SSE (use-miniapp-live-events), ссылок на документы (documents-screen.tsx:37-39), заключений (detail-dialog.tsx:51-53) и ICS (стр. 135-141), причём часть открывается через Telegram.WebApp.openLink во внешнем браузере (история и синхронизация браузера). nginx.conf:31-36 логирует "\$request" с query-строкой в stdout docker. initData валиден 24 часа (auth.ts DEFAULT_MAX_AGE_SEC).

МА-08 P2 · СРЕДНИЙ баг

Автовыбор услуги в мастере: берутся неактивные услуги, у врача без услуг кнопка «Записаться» заблокирована навсегда, из нескольких консультаций выбирается случайная

ГДЕ

src/app/api/miniapp/doctors/route.ts:35, src/app/c/[slug]/my/_hooks/use-doctors.ts:64, src/app/c/[slug]/my/_components/book/doctor-picker.tsx:66, src/app/c/[slug]/my/_components/book/book-confirm.tsx:95, src/server/appointments/book.ts:234

СЦЕНАРИЙ

Администратор архивировал старую услугу «Консультация невролога (2025)», но она осталась привязана к врачу. Пациент выбирает этого врача и время, нажимает «Записаться» и получает ошибку. Другому пациенту на первичный приём проставляется «Повторная консультация» с другой ценой.

ПОСЛЕДСТВИЯ

Запись к части врачей невозможна или создаётся с неправильной услугой и ценой.

ЧТО СДЕЛАТЬ

В doctors route фильтровать `service: { isActive: true }` и сортировать. Явно помечать услугу по умолчанию для онлайн-записи (флаг на ServiceOnDoctor или Service), а не угадывать по категории и цене. Если у врача нет онлайн-услуги, не показывать его в мини-аппе или показывать с пояснением.

КРИТЕРИЙ ПРИЁМКИ

Врач с архивной услугой-«консультацией» и активной успешно бронируется с активной. Врач без активных услуг не показывается в мастере. У врача с помеченной услугой по умолчанию бронь всегда с ней.

ДОКАЗАТЕЛЬСТВО В КОДЕ

doctors/route.ts:35-45 отдаёт `services.select.service` без фильтра isActive и без orderBy. pickDefaultService

(use-doctors.ts:64-81) берёт первую услугу с категорией, содержащей «консульт», иначе самую дешёвую. Это может оказаться архивная услуга, и тогда book.ts:234-244 (isActive: true) возвращает service_not_found, а пациент видит «Не удалось записаться: service_not_found». Если у врача нет услуг, serviceIds: [] (doctor-picker.tsx:68-70), и на подтверждении canSubmit требует draft.serviceIds.length > 0 (book-confirm.tsx:95-101): кнопка серая без объяснений. Если у врача и «Первичная консультация», и «Повторная консультация», выбор зависит от порядка строк в БД. minDoctorPrice «от X сум» тоже учитывает неактивные услуги.

МА-09 P2 · СРЕДНИЙ баг

Анкету перед визитом нельзя заполнить для подтверждённых записей (CONFIRMED): не отправляется и отклоняется с текстом «запись уже завершена»

ГДЕ

src/app/api/miniapp/pre-visit/[appointmentId]/route.ts:133, src/lib/patient-experience/pre-visit.ts:60, src/app/api/crm/appointments/route.ts:157, src/app/c/[slug]/my/_messages/ru.ts:353

СЦЕНАРИЙ

Пациента записали по телефону на завтра (CONFIRMED). Напоминание с анкетой не приходит. Если он сам откроет анкету и нажмёт «Отправить», ему напишут, что «запись уже завершена», хотя приём завтра.

ПОСЛЕДСТВИЯ

Врач не получает жалобы, аллергии и текущие препараты до приёма для значительной части пациентов (все телефонные брони и все подтвердившие). Пациенту показывается ложное сообщение.

ЧТО СДЕЛАТЬ

Разрешить CONFIRMED и в isPreVisitEligible, и в POST (и в UI canSubmit). Для прочих неоткрытых статусов показывать корректный текст («запись отменена» и т.п.).

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест isPreVisitEligible возвращает true для CONFIRMED в окне 23–25ч. POST анкеты для CONFIRMED-записи отвечает 200.

ДОКАЗАТЕЛЬСТВО В КОДЕ

pre-visit route.ts:133-141 принимает анкету только при status === "BOOKED" || "WAITING". isPreVisitEligible (pre-visit.ts:60) исключает CONFIRMED из рассылки. Но телефонные брони с ресепшена и колл-центра создаются сразу CONFIRMED (crm/appointments/route.ts:157 AUTO_CONFIRM_CHANNELS = [PHONE, KIOSK], стр. 205 autoConfirm), и в CONFIRMED переходят брони, подтверждённые по напоминанию. Для них анкета не приходит, а при открытии ссылки отправка даёт 409 и текст ru.ts:353 «Эта запись уже завершена — анкету заполнять не нужно».

МА-10 P2 · СРЕДНИЙ безопасность

Внутренние заметки ресепшена по записи («Заметки» в CRM) и служебные поля уходят пациенту в API мини-аппа

ГДЕ

src/app/api/miniapp/appointments/route.ts:74, src/app/api/miniapp/appointments/route.ts:113, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:154

СЦЕНАРИЙ

Администратор пишет в заметке записи «конфликтный, долг 400 000, подозрение на алкогольную энцефалопатию». Пациент открывает мини-апп в Telegram Desktop, смотрит ответ /api/miniapp/appointments в DevTools и читает это.

ПОСЛЕДСТВИЯ

Раскрытие служебной и медицинской информации пациенту, репутационный и юридический риск.

ЧТО СДЕЛАТЬ

Заменить include на явный select только нужных полей (id, date, endDate, time, ticketCode, durationMin, status, channel, priceFinal, arrivedAt, doctor, cabinet, primaryService, services, payments.status). Разделить пациентский комментарий при записи и служебные заметки на разные колонки.

КРИТЕРИЙ ПРИЁМКИ

Ответ GET /api/miniapp/appointments не содержит ключей comments, notes, cancelReason, createdById, leadId (снимок-тест схемы ответа).

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET /api/miniapp/appointments делает findMany({ include: ... }) без select и отдаёт ...row, то есть все скалярные

колонки Appointment: comments, notes, cancelReason, createdById, leadId, confirmedBy, preVisitData, priceBase, discount* и т.д. (стр. 74-125). В CRM-шторке записи поле «Заметки» сохраняется именно в `comments` (appointment-drawer.tsx:145-154 `patch.mutate({ comments: notesLocal })`). Комментарий visit-summary route.ts:12-14 прямо говорит, что внутренние заметки пациенту отдавать нельзя, но здесь их отдают.

МА-11 Р2 · СРЕДНИЙ мокап / заглушка

Карточка «План лечения» пишет «Лечение завершено» после первого визита: знаменатель выдуман, подтверждённые записи не учитываются

ГДЕ

src/app/api/miniapp/treatment-plan/route.ts:68, src/server/services/treatment-plan.ts:52, src/app/c/[slug]/my/_components/treatment-plan-card.tsx:127, src/app/c/[slug]/my/_components/treatment-plan-card.tsx:85

СЦЕНАРИЙ

Пациенту с мигренью невролог назначил курс, случай OPEN. После первого визита пациент открывает мини-апп и видит «План лечения: Лечение завершено ✓». Он решает, что больше ходить не нужно. Другой пациент подтвердил контрольный визит (статус CONFIRMED), а карточка пишет «Лечение завершено» и прячет кнопку записи.

ПОСЛЕДСТВИЯ

Пациенту показывается неверная медицинская информация о ходе лечения. Это ведёт к прерыванию курса, и прогресс «N из M визитов» — фиктивное число.

ЧТО СДЕЛАТЬ

Не показывать «завершено», пока случай в статусе OPEN. Завершённость брать из MedicalCase.status (CLOSED). Если нет запланированного числа визитов, не показывать «N из M» и прогресс-бар, только «Визитов: N» и следующую запись. nextBooked искать по статусам BOOKED, CONFIRMED, WAITING. Прокидывать caseId из ссылки в черновик записи и в POST (medicalCaseId), чтобы визит прикреплялся к случаю.

КРИТЕРИЙ ПРИЁМКИ

Для OPEN-случая с 1 завершённым визитом карточка не содержит «Лечение завершено». При CONFIRMED-записи в случае показывается «следующий <дата>». Бронь, начатая с кнопки плана лечения, прикрепляется к этому случаю.

ДОКАЗАТЕЛЬСТВО В КОДЕ

treatment-plan/route.ts:81-84 вызывает computeProgress без plannedVisits (в модели MedicalCase такого поля нет). treatment-plan.ts:52-60: `projectedTotal = completed + (next ? 1 : 0)`, `total = max(0, projectedTotal, 1)`, `completedAll = completed >= total && !next`. При 1 завершённом визите и без следующей брони выходит total=1 и completed=true. «Следующая запись» ищется только со `status: "BOOKED"` (route.ts:68-78), поэтому CONFIRMED (подтверждённые по напоминанию, телефонные брони с autoConfirm) и WAITING не видны. Карточка (card.tsx:105, 127-128) показывает «Лечение завершено» с галочкой и 100%-прогрессом, а кнопка «Записаться» скрывается (стр. 159). Ссылка «Записаться» с `?caseId=` (стр. 85) мастером игнорируется: caseId нигде в book/* не читается.

МА-12 Р2 · СРЕДНИЙ мёртвая механика

Кнопки «Скачать мои данные», «Удалить аккаунт», «Отменить удаление» всегда дают ошибку: запросы без clinicSlug

ГДЕ

src/app/c/[slug]/my/_components/profile-screen.tsx:201, src/app/c/[slug]/my/_components/account-delete-screen.tsx:82, src/app/c/[slug]/my/_components/account-delete-screen.tsx:124, src/server/miniapp/handler.ts:112, src/app/c/[slug]/my/_components/account-delete-screen.tsx:63

СЦЕНАРИЙ

Пациент в профиле нажимает «Скачать мои данные» и видит «Не удалось запросить экспорт». Пациентка хочет удалить аккаунт, вводит номер, нажимает и получает «Ошибка». Функции выглядят готовыми, но ни разу не срабатывали.

ПОСЛЕДСТВИЯ

Права пациента на выгрузку и удаление данных не исполняются, хотя интерфейс их обещает. Юридический риск.

ЧТО СДЕЛАТЬ

Перевести все три вызова на useMiniAppFetch (он добавляет clinicSlug и заголовки). Добавить GET-эндпоинт статуса удаления и показывать pending-состояние при входе на экран. Для пациентов без телефона

подтверждать другим способом (например, вводом слова «УДАЛИТЬ»).

КРИТЕРИЙ ПРИЁМКИ

Нажатие «Скачать мои данные» создаёт DataExportJob (проверка в БД) и показывает success. Удаление создаёт DataDeletionJob. При повторном входе на экран видно «Удаление запланировано на <дата>» с рабочей кнопкой отмены.

ДОКАЗАТЕЛЬСТВО В КОДЕ

profile-screen.tsx:201 `fetch("/api/miniapp/account/export", ...)` , account-delete-screen.tsx:82 `fetch("/api/miniapp/account/delete")` и :124 `fetch("/api/miniapp/account/cancel-deletion")` идут без `?clinicSlug=` и мимо useMiniAppFetch. handler.ts:73-82 readSlug берёт slug только из query или из сегмента `clinic` в пути. Ни того, ни другого нет, поэтому стр. 112-121 возвращают 400 missing_clinic_slug, а UI показывает exportError или deleteError. Состояние «удаление запланировано» с сервера не загружается: комментарий на стр. 63-67 обещает «probing the delete endpoint», но кода нет, поэтому после выхода с экрана отменить удаление нельзя. Для TG-пациентов без телефона profile.phone = "" и `confirmationOk` (стр. 75-76) никогда не станет true, при этом сервер (account/delete/route.ts:59) сравнивает с "tg:<id>".

МА-13 P2 · СРЕДНИЙ мёртвая механика

Напоминания о лекарствах: «Отложить» больше не напомнит, неотвеченные никогда не истекают и копят, главная показывает недельной давности дозу как текущую

ГДЕ

src/app/api/miniapp/medications/[reminderSendId]/route.ts:79, src/app/api/miniapp/medications/route.ts:117, src/server/workers/medication-reminder.ts:1, src/app/c/[slug]/my/_components/home-hero.tsx:707

СЦЕНАРИЙ

Пациент получает пуши в Telegram, но отмечает приём не в мини-аппе. Через 10 дней при 3 приёмах в день в базе 30+ PENDING. Он открывает мини-апп, и главная говорит «Пора принять Карбамазепин 08:00» за позавчерашнюю неделю, а в списке сегодняшних доз нет. «Отложить на 30 минут» ничего не присылает.

ПОСЛЕДСТВИЯ

Вводящая в заблуждение информация о приёме препаратов (риск двойной дозы). Функция «отложить» — пустышка.

ЧТО СДЕЛАТЬ

В воркере: помечать EXPIRED PENDING старше N часов, переотправлять SNOOZED после snoozeUntil (новая отправка с той же строкой). В GET сортировать по scheduledFor desc и ограничивать окном «последние 24ч». В TG-сообщении дать inline-кнопки «Принял/Пропустил» с обработчиком callback.

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест воркера: PENDING старше 24ч становится EXPIRED, SNOOZED с прошедшим snoozeUntil переотправляется. GET /api/miniapp/medications не возвращает напоминания старше 24ч.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роут отметки (стр. 1-15) обещает «SNOOZED bumps snoozeUntil... The worker re-surfaces the row once the snooze elapses», а список (medications/route.ts:113-116) — «the worker will already have stamped them with status EXPIRED». Но единственный писатель MedicationReminderSend — medication-reminder.ts, и в нём нет ни SNOOZED, ни EXPIRED (grep пуст). Повторной отправки после snooze и истечения нет, из бота отметить приём тоже нельзя (кроме мини-аппа никто статус не меняет). GET берёт `orderBy: { scheduledFor: "asc" }, take: 30`, то есть 30 самых старых PENDING, а свежие отрезаются. home-hero.tsx:707-724 выбирает самый ранний PENDING как «пора принять» и показывает только время (formatTimeISO), без даты.

МА-14 P2 · СРЕДНИЙ безопасность

Нет лимитов на онлайн-записи: один Telegram-аккаунт может занять все слоты врачей, время вне сетки, любая услуга у любого врача

ГДЕ

src/app/api/miniapp/appointments/route.ts:28, src/server/appointments/book.ts:233, src/server/services/appointments.ts:67

СЦЕНАРИЙ

Конкурент или недовольный человек скриптом с одного TG-аккаунта бронирует все свободные слоты всех неврологов на 3 недели вперёд (или одной бронью с 10 услугами закрывает весь день врача). Реальные пациенты видят «Нет свободного времени».

ПОСЛЕДСТВИЯ

Онлайн-запись клиники можно парализовать. Возможны записи с услугами, которых врач не оказывает.

ЧТО СДЕЛАТЬ

Ограничить число активных будущих броней на пациента (например, 3) и на пару пациент-врач (1). Ограничить горизонт (N дней из настроек), кратность сетке и длину `servicelds`. Проверять `ServiceOnDoctor`. Добавить `rate-limit` на `POST /api/miniapp/appointments`.

КРИТЕРИЙ ПРИЁМКИ

4-я активная бронь одного пациента получает 409 limit. `startAt` вне сетки или дальше горизонта даёт 400. Услуга, не привязанная к врачу, даёт 404.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`BookBody` (стр. 28-41) принимает произвольный `startAt`, а `servicelds` массив без ограничения длины.

`bookAppointment` не проверяет: количество будущих броней пациента, горизонт записи (в UI 14 дней, API — любой год), попадание в 20-минутную сетку, связь услуги с врачом (`ServiceOnDoctor`), что длительность — сумма всех переданных услуг (можно передать 10 услуг и занять весь день). `Rate-limit` на `/api/miniapp` нет.

МА-15 P2 · СРЕДНИЙ баг

Пациент может отменить уже идущий приём (IN_PROGRESS): DELETE не проверяет статус

ГДЕ

`src/app/api/miniapp/appointments/[id]/route.ts:237`, `src/server/appointments/cancel.ts:81`, `src/app/c/[slug]/my/_hooks/use-appointments.ts:200`

СЦЕНАРИЙ

Пациент зашёл к врачу, врач нажал «Начать приём» и пишет осмотр. У пациента на телефоне остался открытым список со старым статусом «Ожидает», и он (или родственник) нажимает X «Отменить». Идущий приём становится CANCELLED, из очереди врача пропадает текущий пациент, а начатый осмотр висит на отменённой записи.

ПОСЛЕДСТВИЯ

Ломается поток врача и кассы (отменённая запись с осмотром и неоплаченной услугой).

ЧТО СДЕЛАТЬ

В DELETE, как в PATCH, отказывать для IN_PROGRESS (и для COMPLETED, NO_SHOW). Лучше добавить охрану в `cancelAppointment` для `actorRole` PATIENT: разрешать только BOOKED, CONFIRMED и, по решению, WAITING.

КРИТЕРИЙ ПРИЁМКИ

DELETE `/api/miniapp/appointments/<id>` для записи в IN_PROGRESS возвращает 409, статус в БД не меняется. Юнит-тест.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH-ветка `cancel` проверяет IN_PROGRESS (стр. 58-64), а DELETE (стр. 237-279), которым пользуется клиент (`use-appointments.ts:193-201`, `method DELETE`), сразу вызывает `cancelAppointment`. `cancel.ts:81-98` отказывает только для COMPLETED и ставит `status: CANCELLED`, `queueStatus: CANCELLED` для любого другого статуса, включая IN_PROGRESS. Кнопка X в списке прячется по статусу из кэша клиента, и при отвалившемся SSE статус в кэше устаревают.

МА-16 P2 · СРЕДНИЙ баг

Перенос записи из мини-аппа обнуляет скидки и бесплатный повтор: `priceFinal = priceBase`, оплаченная запись тоже переоценивается

ГДЕ

`src/app/api/miniapp/appointments/[id]/route.ts:98`, `src/app/api/miniapp/appointments/[id]/route.ts:164`, `src/server/pricing/recompute-appointment-price.ts:43`

СЦЕНАРИЙ

Пациенту повторный визит в рамках случая оценён в 0 (бесплатный повтор), либо ресепшен дал 20% скидки. Пациент в мини-аппе переносит визит на час позже. В записи теперь полная цена, и на кассе с него берут 300 000 сум вместо 0, а в отчётах о скидках запись показывает «скидка есть, но цена полная».

ПОСЛЕДСТВИЯ

Пациенту выставляют неверную сумму, возникают конфликты на кассе и искажаются финансовые отчёты и комиссия врача.

ЧТО СДЕЛАТЬ

При переносе без смены услуг не трогать поля цены. При смене услуг считать цену тем же ядром, что и при создании (priceBase – скидки), затем вызывать recomputeAppointmentPrice и recomputeCaseAppointments в той же транзакции. Если есть PAID-платёж, перенос не должен менять цену (или запрещать смену услуг). Лучше вынести перенос в общий kernel с CRM PATCH.

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест: запись с discountAmount и с free_repeat (priceFinal 0) после PATCH только startAt сохраняет priceFinal. Запись с PAID-платежом после PATCH не меняет цену.

ДОКАЗАТЕЛЬСТВО В КОДЕ

[id]/route.ts:101 `let priceBase = before.priceBase ?? 0`. При переносе только времени (servicelds не переданы) стр. 164-176 пишут `priceBase, priceService: priceBase, priceFinal: priceBase`. discountPct и discountAmount при этом остаются в строке, но в priceFinal уже не учтены. Реферальная скидка, ручная скидка ресепшена и цена 0 по бесплатному повтору (recompute-appointment-price) стираются. recomputeAppointmentPrice не вызывается, хотя CRM PATCH его вызывает. PAID-замок из recompute-appointment-price.ts:43-45 («an appointment that already carries a PAID Payment is frozen») игнорируется. priceService ставится равным сумме всех услуг, а не цене первичной услуги.

МА-17 P2 · СРЕДНИЙ баг

Перенос из мини-аппа: время считается в часовом поясе телефона, переносятся живая очередь, WAITING и NO_SHOW, при смене врача остаётся старый кабинет

ГДЕ

src/app/c/[slug]/my/_components/appointments/appointment-detail-dialog.tsx:30, src/app/c/[slug]/my/_components/appointments/appointment-detail-dialog.tsx:117, src/app/api/miniapp/appointments/[id]/route.ts:58, src/app/api/miniapp/appointments/[id]/route.ts:127

СЦЕНАРИЙ

Дочь в Москве (UTC+3) переносит маме визит на «10:00», а запись встаёт на 12:00 по Ташкенту. Пациент, которого ресепшен поставил в живую очередь (запись в «Прошедших» со статусом «В очереди»), жмёт «Перенести» на завтра. Сегодня он исчезает из очереди, а завтра стоит в живой очереди с сегодняшним номером талона.

ПОСЛЕДСТВИЯ

Неверное время визита и поломка модели «двух полос» (живая очередь и брони), путаница в очереди у врача.

ЧТО СДЕЛАТЬ

В переносе строить время как `\${date}T\${time}:00+05:00`, как в book-confirm. Дни — по ташкентской дате. На сервере разрешать перенос только BOOKED и CONFIRMED с channel != WALKIN, проверять in_past. При смене врача брать doctor.cabinetId и проверять услуги. При переносе сбрасывать arrivedAt и напоминания. Переводить коды ошибок в тексты.

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест PATCH: WALKIN, WAITING и NO_SHOW дают 409, прошлое время даёт 409. Клиентский тест: при TZ=Europe/Moscow перенос на слот 10:00 отправляет 05:00Z.

ДОКАЗАТЕЛЬСТВО В КОДЕ

detail-dialog.tsx:30-34 `new Date(y, m-1, d, h, min).toISOString()` берёт локальную зону устройства, а слоты — это ташкентское «HH:mm». В book-confirm.tsx:25-32 это уже исправлено через `+05:00`, в переносе нет. Серверный PATCH (стр. 58-64) блокирует только COMPLETED, IN_PROGRESS и CANCELLED. Поэтому переносятся строки живой очереди (channel WALKIN остаётся, слот не резервируется), WAITING с queueOrder/ticketSeq/queuedAt (появляются в «живой очереди» другого дня как уже ожидающие) и NO_SHOW (переезжают в будущее с NO_SHOW и не видны в «Предстоящих»). В клиенте `editable` (стр. 117) тоже пускает WAITING и NO_SHOW. При смене врача (API) cabinetId остаётся `before.cabinetId` (стр. 127-133), а проверка пересечений идёт по чужому кабинету. Проверки «не в прошлом» при переносе нет (excludeld отключает in_past в detectConflicts). Ошибки 409 показываются пациенту сырыми кодами (`tg.showAlert((e as Error).message)` → «doctor_busy»).

Режим родственника наполовину сломан: отмена, перенос, ICS, выбор случая и заключение для записей родственника дают 404/403, а анализы и документы показывают данные владельца

ГДЕ

src/app/api/miniapp/appointments/[id]/route.ts:54, src/app/api/miniapp/appointments/[id]/route.ts:239, src/app/c/[slug]/my/_hooks/use-appointments.ts:189, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:45, src/app/api/miniapp/documents/[id]/file/route.ts:46, src/app/c/[slug]/my/_components/home-hero.tsx:684, src/app/c/[slug]/my/_components/appointments/appointment-detail-dialog.tsx:135

СЦЕНАРИЙ

Владелец в контексте «Мама» открывает её запись и нажимает «Отменить»: крестик сначала оптимистично гасит запись, потом ошибка «NotFound», и запись остаётся. «Добавить в календарь» открывает ошибку. На главной в контексте мамы висит «У вас новые анализы», а по нажатию открываются анализы сына.

ПОСЛЕДСТВИЯ

Родственник не может отменить или перенести запись мамы, и слот остаётся занятым (неявки). Анализы владельца показываются под именем другого человека.

ЧТО СДЕЛАТЬ

Единообразно поддерживать onBehalfOf (через resolveActivePatient) во всех мутациях: PATCH/DELETE appointments, attach-case, documents list/file, labs, conclusion-ссылки. Либо явно скрывать эти разделы в контексте родственника. Все клиентские мутации и ссылки должны передавать onBehalfOf.

КРИТЕРИЙ ПРИЁМКИ

В контексте родственника отмена, перенос, ICS и «Открыть заключение» работают (200), в БД изменена запись родственника. Экран анализов показывает анализы родственника или заглушку «недоступно для родственника», но не данные владельца.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Список записей поддерживает onBehalfOf (appointments/route.ts GET), а PATCH и DELETE ищут запись строго `{ id, clinicId, patientId: ctx.patientId }` (стр. 54-56 и 239-241), и клиентские мутации onBehalfOf не передают (use-appointments.ts:189-201, 279-286). attach-case/route.ts:45-50 тоже скоупит по ctx.patientId, хотя booking для родственника возвращает needs_choice. documents/[id]/file:46 скоупит по ctx.patientId, поэтому conclusionUrl в visit-summary и списке записей родственника даёт 404. ICS (detail-dialog.tsx:135-141) без onBehalfOf даёт 403 (ics/route.ts:68). labs (labs/route.ts:29-31) и documents (documents/route.ts:75-76) всегда возвращают данные владельца, при этом home-hero.tsx:684 `useLabs()` в контексте «Мама» показывает «Новые анализы» владельца. Ссылки home-hero (/my/visit/..., /my/appointments, /my/labs) тоже теряют onBehalfOf. book-done.tsx:50 `useAppointments("upcoming")` без onBehalfOf не находит запись родственника, и QR не рисуется.

Реферальная программа — мёртвая функция: коды никто не погашает, настройка «% вознаграждения» ни на что не влияет

ГДЕ

src/server/patient-experience/referral-mint.ts:50, src/app/api/miniapp/referral/route.ts:82, src/app/api/miniapp/appointments/route.ts:204, src/app/[locale]/crm/settings/clinic/_components/clinic-settings-client.tsx:187, src/app/api/miniapp/referral/route.ts:84, src/app/[locale]/crm/patients/[id]/_components/patient-card-client.tsx:222

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Администратор ставит «Скидка за приведённого друга 15%» и рассказывает пациентам. Пациенту в мини-аппе негде взять код, друг негде его ввести, скидки никому не начисляются.

ПОСЛЕДСТВИЯ

Настройка и карточки в CRM создают ложное впечатление работающей программы лояльности.

ЧТО СДЕЛАТЬ

Либо доделать: экран «Пригласить друга» в мини-аппе, приём кода через start_param или поле при первой записи, запись Lead.referrerPatientId. Либо скрыть настройку и реферальную карточку в CRM и удалить неиспользуемый API до реализации.

КРИТЕРИЙ ПРИЁМКИ

Либо сквозной сценарий: код → бронь друга → завершение визита → ReferralReward PENDING → скидка на следующую бронь (интеграционный тест). Либо поле скрыто в настройках и роут удалён.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Вознаграждение создаётся только если есть `Lead.referrerPatientId` (referral-mint.ts:48-56), а в src/ нет ни одного места, которое пишет referrerPatientId (grep находит только чтения). Коды генерирует лишь GET /api/miniapp/referral (стр. 82-87), но ни один экран мини-аппа его не вызывает (в src/app/c/[slug] нет вызова /api/miniapp/referral; use-tg-buttons.ts упоминает «referral screen», которого нет). `applyReferralReward: true` в брони (appointments/route.ts:204) всегда ничего не находит. В CRM настройках клиники есть поле referralRewardPercent (clinic-settings-client.tsx:187), и CRM-карточка пациента показывает реферальную статистику.

МА-20 P2 · СРЕДНИЙ баг

Сегодняшняя запись и живая очередь пропадают из мини-аппа: фильтр «предстоящие» = date >= now

ГДЕ

src/app/api/miniapp/appointments/route.ts:65, src/server/appointments/walkin.ts:146, src/app/c/[slug]/my/_components/home-hero.tsx:693

СЦЕНАРИЙ

Пациента на ресепшене ставят в живую очередь (талон С-005). Он открывает мини-апп, чтобы видеть свою позицию, а там «Всё спокойно», а во вкладке «Прошедшие» висит запись со статусом «В очереди». Другой пациент записан на 10:00, опаздывает на 5 минут, открывает мини-апп, чтобы нажать «Я на месте», а записи на главной уже нет.

ПОСЛЕДСТВИЯ

Главная функция мини-аппа в день визита (позиция в очереди, «Я на месте», талон) не работает для живой очереди вообще и для брони после времени начала. Пациенты дёргают ресепшен.

ЧТО СДЕЛАТЬ

Для upcoming считать активными все записи со статусом не из (CANCELLED, COMPLETED, NO_SHOW) и датой >= начала сегодняшнего дня в Ташкенте (tashkentDayBounds().dayStart), либо дополнительно все сегодняшние WAITING и IN_PROGRESS. «Прошедшие» — дата < dayStart или терминальный статус. Проверить home-hero с живой очередью.

КРИТЕРИЙ ПРИЁМКИ

Запись живой очереди, созданная на ресепшене, сразу видна в «Предстоящих», и на главной показывается QueueHero с позицией. Бронь на прошедшее сегодня время со статусом BOOKED остаётся на главной с кнопкой «Я на месте» до конца дня.

ДОКАЗАТЕЛЬСТВО В КОДЕ

appointments/route.ts:65-73: для scope=upcoming `where.date = { gte: now }`, для past `{ date: { lt: now } }`. У живой очереди дата создания равна «сейчас»: walkin.ts:146 `const start = new Date()` и стр. 209 `date: start`. Поэтому запись живой очереди через секунду после регистрации уже в «прошедших». home-hero.tsx:693-705 ищет queueAppt и todayAppt только в `upcoming.data`, значит QueueHero («перед вами N человек») для живой очереди не появляется никогда. Бронь на 10:00 после 10:00 тоже переезжает в «Прошедшие», хотя статус BOOKED/WAITING, и с главной исчезают карточка «Сегодня» и кнопка «Я на месте».

МА-21 P3 · НИЗКИЙ UX

Кнопка «Я на месте» видна для записей, которые ресепшен уже поставил в очередь (WAITING), и нажатие даёт «Ошибка»

ГДЕ

src/app/c/[slug]/my/_components/home-hero.tsx:402, src/app/api/miniapp/appointments/[id]/checkin/route.ts:31

СЦЕНАРИЙ

Ресепшен уже отметил приход пациента с бронью (WAITING, lane schedule). Пациент открывает мини-апп, видит «Я на месте», нажимает и получает «Произошла ошибка».

ПОСЛЕДСТВИЯ

Мелкая путаница, пациент идёт к стойке уточнять.

ЧТО СДЕЛАТЬ

Показывать кнопку только для BOOKED/CONFIRMED без arrivedAt. Для WAITING — плашку «Вы в очереди».

КРИТЕРИЙ ПРИЁМКИ

Для WAITING-записи кнопка «Я на месте» не рендерится (компонентный тест).

ДОКАЗАТЕЛЬСТВО В КОДЕ

AppointmentHero рендерится и для queueAppt (status WAITING/IN_PROGRESS, home-hero.tsx:763-769) и показывает кнопку при `isToday && !arrived` (стр. 402-435). Сервер разрешает check-in только для BOOKED/CONFIRMED (checkin/route.ts:31, 65-67) и возвращает 409 not_checkinable, а клиент показывает общий t.common.error.

МА-22 Р3 · НИЗКИЙ мёртвая механика

Мёртвые и недостижимые части мини-аппа: API чата без экрана, /my/family/add без ссылки, экран выбора языка недостижим, событие doctor.scheduleChanged не доходит

ГДЕ

src/app/api/miniapp/conversations/[id]/messages/route.ts:1, src/app/api/miniapp/conversations/find-or-create/route.ts:20, src/app/c/[slug]/my/_components/miniapp-home.tsx:56, src/app/api/miniapp/events/route.ts:112

СЦЕНАРИЙ

Патч, открывающий эти эндпоинты, никто не тестирует. Messages POST без rate-limit позволяет засыпать входящие CRM сообщениями «из мини-аппа».

ПОСЛЕДСТВИЯ

Поверхность атаки и поддержки без пользы, путаница при доработках.

ЧТО СДЕЛАТЬ

Удалить неиспользуемые роуты (или закрыть feature-flag'ом) и недостижимый экран. Для doctor.scheduleChanged инвалидировать слоты иначе (poll или refetchOnFocus уже есть), убрать из списка. Перевести коды ошибок авторизации в понятные тексты.

КРИТЕРИЙ ПРИЁМКИ

греп по src/app/c не находит обращений к удалённым роутам, а роуты отвечают 404. Экран ошибки авторизации показывает человекочитаемый текст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Эндпоинты /api/miniapp/conversations, /find-or-create и /[id]/messages (POST пишет входящее сообщение и будит CRM) не вызываются ни одним компонентом в src/app/c/[slug]. Страница /my/family/add существует, но ссылки на неё нет (family-switcher.tsx:19 «adding relatives is no longer offered»). miniapp-home.tsx:56-58 показывает LanguagePickerScreen при preferredLang не RU/UZ, а auth всегда ставит RU или UZ. `doctor.scheduleChanged` в MINIAPP_DELIVERABLE_TYPES (events/route.ts:112) никогда не проходит фильтр по patientId, так что инвалидация слотов по нему мертва. Сообщения об ошибке авторизации показываются пациенту сырыми кодами (miniapp-home.tsx:40-49: state.message = "missing_init_data" и т.п.).

МА-23 Р3 · НИЗКИЙ целостность данных

Оценку NPS можно поставить будущей или отменённой записи, двойной тап создаёт два отзыва

ГДЕ

src/app/api/miniapp/nps/[appointmentId]/route.ts:180, prisma/schema.prisma:1

СЦЕНАРИЙ

Пациент по ошибке открывает ссылку NPS заранее и ставит «2» врачу, к которому ещё не ходил. Рейтинг врача падает, и админу приходит «низкая оценка».

ПОСЛЕДСТВИЯ

Искажение рейтингов врачей и ложные алерты.

ЧТО СДЕЛАТЬ

Принимать NPS только для COMPLETED (или с completedAt). Добавить @@unique([appointmentId, patientId]) и ловить P2002 как already_submitted.

КРИТЕРИЙ ПРИЁМКИ

POST NPS для BOOKED или CANCELLED даёт 409. Два параллельных POST дают один отзыв в БД.

ДОКАЗАТЕЛЬСТВО В КОДЕ

nps route.ts:180-182: «We accept submissions for any appointment status». Дубль проверяется через findFirst (стр.

183-196) без уникального ограничения. У PatientReview есть только @@index([appointmentId]), unique нет. Два одновременных POST создают два отзыва и две эмиссии. В Action Center patientName для onBehalfOf берётся от владельца (стр. 273-278), а patientId от родственника.

МА-24 РЗ · НИЗКИЙ баг

Проверка больничного: «действует сегодня» считается по дате UTC, с 00:00 до 05:00 по Ташкенту ответ неверный

ГДЕ

src/app/api/verify/sick-leave/[token]/route.ts:43

СЦЕНАРИЙ

Работодатель в 01:30 по Ташкенту сканирует больничный с периодом, который начинается сегодня, и видит «не действует». В последний день больничного после полуночи видит «действует».

ПОСЛЕДСТВИЯ

Редкая, но неверная юридически значимая информация.

ЧТО СДЕЛАТЬ

Считать «сегодня» через tashkentDayBounds или tashkentComponents(new Date()).date. Не отдавать cancelReason публично, только факт аннулирования.

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест: при now=2026-09-23T20:30Z (01:30 24.09 Ташкент) больничный с periodFrom=24.09 возвращает inEffectToday=true.

ДОКАЗАТЕЛЬСТВО В КОДЕ

sick-leave route.ts:43-46: `todayUtc = Date.UTC(today.getUTCFullYear(), ...)` и `inEffect = todayUtc >= periodFrom && todayUtc <= periodTo`. Сервер работает в UTC, а клиника в Asia/Tashkent (+5). В публичном ответе ещё и cancelReason (свободный текст врача).

AN · Аналитика, выручка, оплаты, биллинг, экспорты

AN-01 P1 · ВЫСОКИЙ баг

Две несовместимые конвенции курса USD: после ввода курса «12600» в настройках приём оплат падает с 500, LTV по USD считается неверно

ГДЕ

src/app/api/crm/payments/route.ts:124, src/app/api/crm/payments/route.ts:131, src/server/services/ltv.ts:46, src/app/[locale]/crm/settings/exchange-rates/_components/exchange-rates-client.tsx:101, prisma/seed.ts:331, prisma/schema.prisma:503, prisma/schema.prisma:2294, src/messages/ru.json:3808, prisma/seed.ts:336, src/server/services/ltv.ts:43, src/server/services/ltv.ts:34

ТАКЖЕ НАШЛИ ЗОНЫ

Настройки клиники, пользователи, филиалы, кабинеты, права, Управление врачами (CRM)

СЦЕНАРИЙ

Администратор клиники заходит в «Настройки → Курсы валют» и, как подсказывает поле, вводит сегодняшний курс 12600. Через минуту регистратор открывает карточку пациента, жмёт «Добавить оплату», вводит 150 000 — получает ошибку «Не удалось добавить оплату». Все следующие оплаты тоже не проходят, пока кто-то не удалит курс из базы.

ПОСЛЕДСТВИЯ

Полная остановка регистрации оплат в клинике после штатного действия администратора; выручка за день не попадает ни в дашборды, ни в LTV. До этого момента amountUsdSnap и LTV по USD уже искажены на 27% или в тысячи раз.

ЧТО СДЕЛАТЬ

Зафиксировать одну конвенцию: rateUsd = сумов за 1 USD (как в UI). Пересчитать: amountUsdSnap(центы) = round(amount_тийин / rateUsd); тийины из центов = cents × rateUsd. Исправить payments/route.ts и services/ltv.ts, сид (12700 вместо 1/12700), написать миграцию данных для существующих строк ExchangeRate < 1 (инвертировать) и пересчёт amountUsdSnap/LTV. Добавить валидацию диапазона курса в CreateExchangeRateSchema (например 1000..100000).

КРИТЕРИЙ ПРИЁМКИ

Юнит-тест: при курсе 12600 платёж 150 000 сум даёт amountUsdSnap ≈ 1190 центов и создаётся без ошибки; USD-платёж \$100 даёт LTV +1 260 000 сум. Ввод курса через UI и последующая оплата из карточки пациента проходят успешно.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/crm/payments для UZS-платежа берёт последний ExchangeRate и пишет `data.amountUsdSnap = Math.round(body.amount \* Number(rate.rateUsd))` (стр. 131-133) — т.е. считает rateUsd как «USD за 1 тийин». Сид (prisma/seed.ts:331-337) действительно пишет `rateUsd: 1 / 12700`, но колонка `Decimal(12, 4)` (schema:503) округляет это до 0.0001 (ошибка ~27%). При этом единственный UI ввода курса (Настройки → Курсы валют) предлагает `placeholder="12600"` (сумов за доллар), и doctor-finances.tsx:29-33 тоже ожидает «тийин за цент». Если админ введёт 12600: 150 000 сум = 15 000 000 тийин × 12600 = 1.89e11, а `amountUsdSnap Int?` (schema:2294) — int4 (макс 2 147 483 647). Любой платёж больше ~1 704 сум даст ошибку записи Prisma/Postgres → 500. recalcltv (ltv.ts:43-46) для USD делает `ltv += Math.round(p.amount / rate)` — при 12600 доллары превращаются почти в 0, при 0.0001 — в ×10000.

AN-02 P1 · ВЫСОКИЙ баг

Оплаты из UI никогда не привязываются к визиту: «Топ врачей по выручке» пуст, у врача выручка 0, в карточке визита «Нет оплат», блокировка цены оплаченного визита не срабатывает

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/tabs/payments-tab.tsx:296, src/app/api/crm/analytics/route.ts:125, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:463, src/server/pricing/recalculate-appointment-price.ts:113, src/app/api/crm/analytics/cases/route.ts:105, src/app/api/crm/appointments/route.ts:37

СЦЕНАРИЙ

Регистратор принимает 200 000 сум за консультацию и вносит оплату в карточке пациента. Администратор открывает «Аналитику» — в «Топ врачей» пусто (или только старые сид-данные), в панели записи «Нет оплат», фильтр «Неоплаченные» показывает этот визит как долг; позже врач меняет услугу — цена оплаченного визита

пересчитывается.

ПОСЛЕДСТВИЯ

Ключевые финансовые метрики по врачам и визитам не отражают реальные деньги; контроль долгов по визитам невозможен; риск расхождения цены и оплаты.

ЧТО СДЕЛАТЬ

В диалоге оплаты (и в идеале в панели визита/очереди) выбирать визит пациента (по умолчанию — последний/сегодняшний незакрытый) и передавать `appointmentId`; на сервере проверять, что визит принадлежит тому же пациенту и клинике. Для исторических платежей — скрипт привязки по пациенту+дате.

КРИТЕРИЙ ПРИЁМКИ

Оплата, внесённая из UI, имеет `appointmentId`; после неё визит в панели показывает оплату, врач появляется в «Топ врачей», фильтр «Неоплаченные» его не показывает, `recomputeAppointmentPrice` возвращает `PAID-locked`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Единственный UI создания `Payment` — диалог во вкладке «Оплаты» карточки пациента: ``create.mutate({ patientId, amount: parsed, method, status: "PAID" })`` — `appointmentId` не передаётся никогда (`grep`: других вызовов `POST /api/crm/payments` нет, `nested `payments: { create`` нет). Все метрики, завязанные на визит, ломаются: `analytics/route.ts:125-130` берёт ``p.appointment?.doctorId`` и пропускает платежи без визита → `topDoctors` пуст; для `DOCTOR` фильтр ``appointment: { doctorId`` → выручка 0; `cases/route.ts:105-111` ``appointment: { medicalCaseId: { in`` } }` → `avgRevenuePerCase` 0; `appointment-drawer.tsx:463` показывает ``appt.payments`` → всегда «Нет оплат»; фильтр «Неоплаченные» (`appointments/route.ts:37-41`) отмечает все визиты как неоплаченные; `recompute-appointment-price.ts:113-116/138` «`PAID-locked`» `guard` никогда не срабатывает — цену уже оплаченного визита можно пересчитать.

AN-03 P2 · СРЕДНИЙ баг

KPI врачей за «30 дней / 90 дней / с начала года» никогда не включает текущий месяц

ГДЕ

`src/lib/analytics/dashboard-math.ts:42`, `src/server/analytics/doctor-performance-resolver.ts:95`, `src/app/[locale]/crm/analytics/doctors/page.tsx:36`

СЦЕНАРИЙ

Главврач 20 сентября открывает «Врачи (KPI)» → «30 дней», видит визиты и выручку — это цифры за август целиком; работа сентября не видна, хотя подпись «30 дней».

ПОСЛЕДСТВИЯ

Рейтинг врачей по выручке/неявкам/NPS систематически показывает прошлый месяц под видом текущего периода.

ЧТО СДЕЛАТЬ

Либо строить MV по дням и фильтровать точными датами, либо округлять `monthTo` вверх (начало месяца, следующего за `to`), и явно подписывать период как «календарные месяцы».

КРИТЕРИЙ ПРИЁМКИ

В сентябре пресет «30 дней» включает сентябрьские визиты; тест на `resolveDoctorPerformance` с датой середины месяца.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`resolveDoctorPerfRange('30d')` возвращает `to` = завтрашняя полночь. Резолвер делает ``monthTo: startOfMonthUtc(opts.monthTo)`` и фильтр ``"month" < $3``. Сегодня 23.09: `from=25.08→01.08`, `to=24.09→01.09` → выборка `[01.08, 01.09)`: только август. Текущий месяц попадает только в последний день месяца (когда «завтра» = 1-е число). То же для 90d (июнь–август), YTD и `custom`.

AN-04 P2 · СРЕДНИЙ баг

KPI врачей: при возврате на «30 дней» таблица не перезагружается и показывает данные предыдущего диапазона

ГДЕ

`src/app/[locale]/crm/analytics/doctors/_components/doctor-performance-client.tsx:159`

СЦЕНАРИЙ

Админ смотрит «С начала года», затем нажимает «30 дней» — подсветка кнопки сменилась, а в таблице годовые цифры.

ПОСЛЕДСТВИЯ

Неверные данные под неверной подписью в рейтинге врачей.

ЧТО СДЕЛАТЬ

Хранить начальные строки 30d отдельно и восстанавливать их, либо всегда вызывать fetchRange при смене rangeKind.

КРИТЕРИЙ ПРИЁМКИ

Последовательность 30d → YTD → 30d возвращает исходные 30-дневные значения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

useEffect: `if (rangeKind === "30d") return; // already loaded` — после переключения на 90d/YTD строки rows заменены, а при обратном выборе «30 дней» запрос не выполняется, rows остаются от прошлого диапазона.

AN-05 P2 · СРЕДНИЙ мокап / заглушка

«Средний LTV» на странице аналитики — выдуманное число: всегда 1 500 000 сум

ГДЕ

src/app/[locale]/crm/analytics/_components/analytics-charts.tsx:286, src/app/api/crm/analytics/route.ts:250

СЦЕНАРИЙ

Руководитель смотрит карточку «LTV» — «1 500 000 сум, средний LTV» при любом периоде и любой клинике, даже если большинство пациентов ничего не платили.

ПОСЛЕДСТВИЯ

Ключевой финансовый KPI показывается как реальный, но является константой — управленческие решения принимаются по фейку.

ЧТО СДЕЛАТЬ

Считать средний LTV на сервере (AVG(ltv) по пациентам клиники, опционально без ltv=0) и отдавать в ответе; убрать клиентскую эвристику по середине бакетов.

КРИТЕРИЙ ПРИЁМКИ

Средний LTV совпадает с SELECT AVG(ltv) FROM Patient WHERE clinicId=...; меняется при добавлении оплат.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Клиент усредняет по словарию midpoints с ключами "0-300k", "300k-600k", "600k-1M", "1M-2M", "2M-3M", "3M+", а API возвращает бакеты "0", "<500k", "500k-1m", "1m-3m", "3m-10m", "10m+". Ни один ключ не совпадает, поэтому для каждого бакета берётся fallback `midpoints[b.bucket] ?? 1\_500\_000\_00`, включая пациентов с LTV=0. Результат `sum/count` всегда равен 150 000 000 тийин.

AN-06 P2 · СРЕДНИЙ безопасность

Врач видит выручку всей клиники и коллег: фильтр по врачу в /api/crm/analytics «открывается» при отсутствии Doctor-записи или чужом branch-cookie

ГДЕ

src/app/api/crm/analytics/route.ts:45, src/app/api/crm/analytics/route.ts:58, src/app/api/crm/analytics/route.ts:208, src/app/api/crm/analytics/route.ts:236, src/lib/tenant-allowlist.ts:105, src/server/platform/branch-cookie.ts:8, src/app/api/crm/analytics/funnels/route.ts:59, src/app/api/crm/analytics/cases/route.ts:57

СЦЕНАРИЙ

Врач-невролог в DevTools добавляет cookie active_branch_id=abc и открывает /api/crm/analytics?period=quarter: видит выручку клиники по дням и рейтинг «Топ врачей по выручке» с суммами коллег. То же происходит без всяких манипуляций, если у пользователя-врача не создана карточка Doctor или она привязана к другому филиалу, чем выбран в переключателе.

ПОСЛЕДСТВИЯ

Утечка коммерчески чувствительных данных (выручка клиники, доход каждого врача) пользователю с ролью DOCTOR — прямое нарушение модели прав, которую код сам декларирует.

ЧТО СДЕЛАТЬ

Для DOCTOR: если Doctor-строка не найдена — возвращать 403 (fail-closed), как в doctors/me/analytics. Искать Doctor без branch-фильтра (runWithTenant без branchId или явный where по clinicId). Отфильтровать sources/ltvBuckets для врача (либо не отдавать эти секции врачу). Применить то же в funnels и cases. Валидировать branch-cookie на сервере (ветка должна принадлежать клинике).

КРИТЕРИЙ ПРИЁМКИ

Запрос врача с поддельным active_branch_id и врача без Doctor-записи получает 403/пустые данные только своего среза; тест на fail-closed для всех трёх эндпоинтов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Для поли DOCTOR: `doctorFilter = await prisma.doctor.findFirst({ where: { userId } })`, затем `const doctorId = doctorFilter?.id ?? null;` и все фильтры вида `...(doctorId ? { appointment: { doctorId } } : {})`. Если строка не найдена — фильтр просто пропадает (fail-open), и врач получает revenueDaily/topDoctors по всей клинике. Doctor входит в MODELS_BRANCH_SCOPED (tenant-allowlist.ts:105-111), а branch-cookie не подписан (branch-cookie.ts:4-10) и подставляется в ctx без проверки (api-handler.ts:102-104): врач выставляет `active\_branch\_id=x` → `findFirst({userId, branchId:x}) = null` → полная аналитика клиники (Payment не branch-scoped, поэтому платежи не отфильтруются вовсе). Кроме того, sources (стр. 208) и LTV-гистограмма (стр. 236-249) не фильтруются по врачу даже в штатном режиме. То же fail-open в funnels (стр. 59-65) и cases (стр. 57-65). Для сравнения payments GET явно запрещает врачу выгрузку кассы клиники (payments/route.ts:28-39), а /api/crm/doctors/me/analytics корректно отдаёт 403 DoctorProfileMissing.

AN-07 P2 · СРЕДНИЙ баг

Индикатор роста выручки на аналитике завышен: неделя делится на 3 и 4 дня, неявки считаются от всех записей

ГДЕ

src/app/[locale]/crm/analytics/_components/analytics-charts.tsx:236, src/app/[locale]/crm/analytics/_components/analytics-page-client.tsx:122, src/app/api/crm/analytics/route.ts:101

СЦЕНАРИЙ

Выручка каждый день одинакова, но на главной аналитике зелёный чип «+33,3%»; процент неявок днём занижен, потому что в знаменателе ещё не пришедшие сегодняшние пациенты.

ПОСЛЕДСТВИЯ

Систематически оптимистичная картина динамики на экране, который открывают первым.

ЧТО СДЕЛАТЬ

Сравнивать с предыдущим периодом такой же длины (запрашивать его на сервере) либо сравнивать средние за день; для неявок знаменатель = COMPLETED+NO_SHOW.

КРИТЕРИЙ ПРИЁМКИ

При одинаковой дневной выручке чип показывает 0%; тест на revenueDelta для 7 дней.

ДОКАЗАТЕЛЬСТВО В КОДЕ

revenueDelta: `half = floor(len/2)`; prev = сумма первых `half` дней, curr = сумма остальных. Для периода «Неделя» (он выбран по умолчанию) len=7 → 3 дня против 4 дней → при равной выручке показывается «+33,3%». Сравниваются половины текущего периода, а не предыдущий период. Процент неявок = NO_SHOW / все записи дня, включая CANCELLED и ещё не наступившие записи сегодняшнего дня.

AN-08 P2 · СРЕДНИЙ целостность данных

Каждая оплата перезаписывает счётчик визитов пациента количеством платежей

ГДЕ

src/server/services/ltv.ts:55, src/app/api/crm/payments/route.ts:171, src/app/api/crm/payments/[id]/route.ts:62, src/server/patient/last-contacted.ts:82, src/server/services/ltv.ts:33, src/server/services/ltv.ts:51, src/app/api/crm/patients/[id]/ltv/route.ts:21, src/app/api/crm/doctors/me/today/route.ts:141, src/app/api/crm/doctors/me/schedule/route.ts:97

ТАКЖЕ НАШЛИ ЗОНЫ

Пациенты и медицинские случаи в CRM

СЦЕНАРИЙ

Пациент был на 3 приёмах (visitsCount=3, «постоянный»). Регистратор вносит одну оплату за пакет — visitsCount становится 1, пациент в карточке и в тегах врача выглядит как «первичный» (first_visit при visitsCount===1), сегментация и детектор «спящих» считают его заново.

ПОСЛЕДСТВИЯ

Неверные данные в карточке пациента («Визитов»), в тегах на экране врача, в сегментах/кампаниях и в AI-приоритизации очереди.

ЧТО СДЕЛАТЬ

Убрать запись visitsCount из recalcltv (оставить только ltv); если нужно число оплат — отдельное поле. После выкладки прогнать refreshPatientVisitStats по всем пациентам.

КРИТЕРИЙ ПРИЁМКИ

После создания оплаты visitsCount пациента не меняется и равен числу COMPLETED-визитов; тест на recalcltv

не трогает visitsCount.

ДОКАЗАТЕЛЬСТВО В КОДЕ

recalcLtv считает `visits += 1` на каждый PAID-платёж и делает `prisma.patient.update({ data: { ltv, visitsCount: visits } })`. При этом канонический писатель visitsCount — refreshPatientVisitStats (last-contacted.ts:73-100) пересчитывает число COMPLETED-визитов. Два писателя с разной семантикой: значение зависит от того, кто отработал последним.

AN-09 P2 · СРЕДНИЙ UX

Конструктор отчётов: вместо врачей и филиалов — технические ID, заголовки на английском с «(tiins)», сортировка игнорируется

ГДЕ

src/server/analytics/dimensions.ts:71, src/server/analytics/measures.ts:55, src/app/[locale]/crm/analytic
s/reports/_components/report-builder-client.tsx:635, src/server/analytics/report-config.ts:77, src/server
/analytics/query-builder.ts:138

СЦЕНАРИЙ

Админ строит «Выручка по врачам» — в таблице колонка Doctor со значениями «cm3x9...», колонка «Revenue (tiins)» с суммами в суммах; экспорт в Excel бесполезен без ручной расшифровки ID.

ПОСЛЕДСТВИЯ

Отчёты формально работают, но непригодны для не-технического пользователя; риск неверного прочтения единиц.

ЧТО СДЕЛАТЬ

Джойнить имена (d.nameRu/nameUz, b.name) или маппить на клиенте; локализовать заголовки через i18n; убрать «tiins» из подписей; форматировать дату; применить ordering в query-builder (по белому списку алиасов).

КРИТЕРИЙ ПРИЁМКИ

Отчёт по врачам показывает ФИО, заголовки на языке интерфейса, дата в формате ДД.ММ.ГГГГ, сортировка по выбранной мере работает.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Измерение doctor → `a."doctorId"`, branch → `a."branchId"`; UI и CSV/PDF выводят значения как есть (cuid). Заголовки берутся из `c.label` = "Day", "Doctor", "Revenue (tiins)", "Avg. ticket (tiins)" — не локализованы, при этом значения уже переведены в суммы. Дата выводится ISO-строкой "2026-09-22T00:00:00.000Z". Поле ordering принимается в схеме, но runner/query-builder его не используют (всегда ORDER BY по измерениям).

AN-10 P2 · СРЕДНИЙ баг

Мера LTV в отчётах суммирует уникальные ЗНАЧЕНИЯ LTV, а не пациентов

ГДЕ

src/server/analytics/measures.ts:95

СЦЕНАРИЙ

Отчёт «LTV по врачам»: у врача 20 пациентов, каждый заплатил по одной консультации 150 000 — отчёт показывает LTV 150 000 сум.

ПОСЛЕДСТВИЯ

LTV в отчётах занижен кратно.

ЧТО СДЕЛАТЬ

Считать через подзапрос по DISTINCT пациентам группы: SUM(ltv) FROM (SELECT DISTINCT patientId, ltv ...) или агрегировать отдельно CTE.

КРИТЕРИЙ ПРИЁМКИ

Для двух пациентов с одинаковым LTV мера возвращает удвоенную сумму.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`sql: SUM(DISTINCT p."ltv")::bigint` — DISTINCT применяется к значению. Два пациента с одинаковым LTV (типично при фиксированной цене консультации, например оба по 150 000 сум) дают 150 000, а не 300 000.

AN-11 P2 · СРЕДНИЙ мёртвая механика

Нет способа исправить или вернуть оплату из интерфейса; изменение суммы не пересчитывает LTV, частичный возврат игнорируется в выручке

ГДЕ

src/app/api/crm/payments/[id]/route.ts:43, src/app/api/crm/payments/[id]/route.ts:57, src/app/api/crm/analytics/route.ts:56

СЦЕНАРИЙ

Регистратор ошиблся и внёс 1 500 000 вместо 150 000 — исправить нельзя, отчёты за день и LTV пациента навсегда завышены. При возврате денег пациенту фиксировать это негде.

ПОСЛЕДСТВИЯ

Ошибки кассы необратимо искажают финансовую аналитику; нет учёта возвратов.

ЧТО СДЕЛАТЬ

Добавить в карточку пациента действия «Исправить сумму» (ADMIN) и «Возврат» (с суммой и датой возврата); при любом изменении amount/refundedAmount пересчитывать LTV; в агрегатах выручки вычитать refundedAmount (или вести возврат отдельной строкой с датой); ограничить допустимые переходы статусов и роли.

КРИТЕРИЙ ПРИЁМКИ

Из UI можно оформить возврат; выручка дня возврата уменьшается, исходного дня — нет; LTV пересчитывается.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH /api/crm/payments/[id] существует, но ни один компонент его не вызывает (grep: вызовов нет). Внутри: LTV пересчитывается только при смене статуса (`before.status !== after.status`), не при смене amount/refundedAmount; нет машины статусов (REFUNDED→PAID разрешено). Вся выручка (analytics, dashboard, MV) фильтрует `status: "PAID"` и суммирует amount без вычета refundedAmount; перевод в REFUNDED задним числом убирает выручку из исходного дня.

AN-12 P2 · СРЕДНИЙ баг

Номер счёта уникален глобально, а нумерация — по клинике: вторая клиника не может выставить первый счёт

ГДЕ

src/server/billing/invoice-number.ts:58, prisma/schema.prisma:610, src/server/billing/invoice.ts:88

СЦЕНАРИЙ

Вторая клиника на платформе (или демо-клиника) нажимает «Апгрейд тарифа» — ошибка 500 при каждой попытке.

ПОСЛЕДСТВИЯ

Биллинг ломается при появлении второго арендатора.

ЧТО СДЕЛАТЬ

Сделать уникальность составной (clinicId, number) либо включить в номер код клиники; добавить ретрай/атомарный счётчик (DocumentCounter).

КРИТЕРИЙ ПРИЁМКИ

Две клиники последовательно создают первый счёт года без ошибок.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий: «two clinics can both have INV-2026-0001», nextInvoiceNumber ищет максимум `where: { clinicId, number: { startsWith: prefix } }`. Но `number String @unique` (глобальный индекс Invoice_number_key). Для новой клиники всегда вычисляется INV-2026-0001, уже занятый другой клиникой → P2002 → createUpgradeInvoice падает; ретраев нет, повторная попытка вычисляет тот же номер.

Онлайн-оплата подписки через Payme/Click не может завершиться: вебхуки не соответствуют протоколам провайдеров

ГДЕ

src/app/api/webhooks/billing/payme/route.ts:57, src/server/billing/payments/payme.ts:142, src/app/api/webhooks/billing/click/route.ts:20, src/server/billing/payments/click.ts:222, src/app/api/webhooks/billing/click/route.ts:21, src/app/api/webhooks/billing/click/route.ts:52, src/server/billing/payments/click.ts:225, src/server/billing/payments/payme.ts:147

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

После заведения ключей Payme админ клиники жмёт «Перейти на Pro» → оплачивает на checkout.paycom.uz → Payme отклоняет транзакцию на шаге проверки или инвойс остаётся DRAFT, тариф не меняется.

ПОСЛЕДСТВИЯ

Платный апгрейд тарифа нельзя провести онлайн (потеря выручки платформы); каждый клик «Апгрейд» плодит новые DRAFT-инвойсы и вешает pendingPlanId.

ЧТО СДЕЛАТЬ

Реализовать полный Merchant API Payme (хранение транзакций, Check/Create/Perform/Cancel/CheckTransaction с корректными ответами и HTTP 200) и Click Prepare/Complete (form-urlencoded, подпись с merchant_prepare_id, корректные ответы); до этого скрыть кнопки онлайн-оплаты.

КРИТЕРИЙ ПРИЁМКИ

Сквозной тест в песочнице Payme/Click переводит инвойс в PAID и меняет тариф.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Payme: инвойс помечается оплаченным только если ``method === "PerformTransaction" && result.invoiceId``, а `invoiceId` берётся из `params.account`; в протоколе Payme `PerformTransaction` передаёт только `id` транзакции (`account` приходит в `Check/CreateTransaction`), поэтому `markInvoicePaid` не вызывается. На все методы отдаётся ``{result:{ok,stub,method}}`` вместо обязательных полей (`allow / create_time, transaction, state`), ошибки — с HTTP 400/500. Click: тело читается ``request.json()``, тогда как Click шлёт `form-urlencoded`; подпись `computeClickSignature` не включает `merchant_prepare_id`, обязательный для `action=1`; ответ не содержит `merchant_prepare_id/merchant_confirm_id`. Комментарии прямо помечают роуты как «LogOnly», handshake «punt to Wave 4».

Отчёты конструктора теряют последний день периода и считают границы в UTC

ГДЕ

src/server/analytics/report-config.ts:156, src/server/analytics/report-config.ts:51, src/app/[locale]/crm/analytics/reports/_components/report-builder-client.tsx:508, src/server/analytics/query-builder.ts:94

СЦЕНАРИЙ

Админ строит отчёт «с 01.09 по 30.09» — визиты 30 сентября (весь рабочий день после 05:00) не попадают. Отчёт «за 15.09 по 15.09» всегда пустой.

ПОСЛЕДСТВИЯ

Суммы выручки/визитов в отчётах и рассылках систематически занижены на последний день.

ЧТО СДЕЛАТЬ

Интерпретировать даты как календарные дни Ташкента: `from = tashkentDayBoundsForDateString(dateFrom).dayStart`, `to = tashkentDayBoundsForDateString(dateTo).dayEnd` (включительно).

КРИТЕРИЙ ПРИЁМКИ

Отчёт за один день возвращает визиты этого дня; отчёт по 30.09 включает визиты 30.09 в 17:00.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поля дат в билдере — ``<input type="date">`` → строка "YYYY-MM-DD". `resolveDateRange` делает ``new Date(f.dateTo)`` = 00:00 UTC = 05:00 Ташкента выбранного дня и использует как ИСКЛЮЧАЮЩУЮ границу ``a.date < $3``. Валидация разрешает `dateFrom == dateTo`, что даёт пустой интервал [05:00, 05:00).

Полоса «Путь пациента» считает новых пациентов, первичные и повторные визиты по выдуманным коэффициентам

ГДЕ

src/app/[locale]/crm/analytics/_components/cases-section.tsx:81, src/app/[locale]/crm/analytics/_components/cases-section.tsx:92, src/app/api/crm/analytics/cases/route.ts:188

СЦЕНАРИЙ

За неделю пришло 5 новых пациентов, но карточка «Новые пациенты» показывает 38 — максимум из «всех открытых кейсов за всё время» и 76% от «первичных», которые сами получены вычитанием.

ПОСЛЕДСТВИЯ

Шесть KPI на главной аналитике выглядят реальными, но являются производными фикциями; руководство неверно оценивает приток пациентов.

ЧТО СДЕЛАТЬ

Считать на сервере: новые пациенты = Patient.createdAt в периоде (или первый COMPLETED-визит в периоде); первичные/повторные визиты — по порядковому номеру визита пациента; убрать магические 0.62/0.76. Вывести реально посчитанные метрики кейсов или удалить их из API.

КРИТЕРИЙ ПРИЁМКИ

Каждое число полосы сверяется SQL-запросом; в коде нет коэффициентов 0.62 и 0.76.

ДОКАЗАТЕЛЬСТВО В КОДЕ

``completedTotal = ...find(COMPLETED)?.count ?? Math.round(totalAppts * 0.62)``; ``repeatVisits = completedTotal * repeatConvPct / 100`` (а `repeatConvPct` — доля КЕЙСОВ с >1 визитом, не доля визитов); ``firstConsult = completed - repeatVisits``; ``newPatients = Math.max(cases.kpis.openCasesTotal, Math.round(firstConsult * 0.76))``. Реальное число новых пациентов уже есть в ответе analytics (sources — пациенты, созданные в периоде), но не используется. Метрики, которые API cases реально считает (avgDurationDays, avgRevenuePerCase, topComplaints, durationBuckets), в UI не выводятся.

Потери от пустых слотов не учитывают отпуска врачей и считают час занятым/пустым грубо

ГДЕ

src/server/revenue/empty-slot.ts:283, src/server/revenue/empty-slot.ts:380

СЦЕНАРИЙ

Врач в двухнедельном отпуске: дашборд «Потери» показывает ~80 пустых часов × средний чек как недополученную выручку.

ПОСЛЕДСТВИЯ

Завышенные потери, неверная приоритизация (врач «с наибольшими потерями» в топе таблицы).

ЧТО СДЕЛАТЬ

Исключать интервалы DoctorTimeOff из workingHours; добавить тест.

КРИТЕРИЙ ПРИЁМКИ

Для врача с отпуском на дату снимот не создаёт строк.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Рабочие часы берутся из DoctorSchedule по дню недели (стр. 283-299); DoctorTimeOff (модель есть, branch-scored) не читается. Значит все часы расписания врача в отпуске/на больничном записываются в EmptySlotSnapshot как потери по средней цене услуги.

Признак «спящий» никогда не снимается: потери от спящих пациентов растут навсегда и выводятся всплеском в первый день периода

ГДЕ

src/server/revenue/reactivation.ts:291, src/server/revenue/loss-data.ts:153, src/server/revenue/loss-data.ts:169, src/server/revenue/loss-data.ts:272

СЦЕНАРИЙ

Пациент 5 месяцев не приходил, получил реактивацию и вернулся — но на дашборде «Потери» он по-прежнему

«спящий», его ценность считается потерей; на графике за неделю в понедельник огромный пик «спящие пациенты», сравнимый с месячной выручкой.

ПОСЛЕДСТВИЯ

Дашборд потерь завышает итог и искажает тренд; решение о маркетинге принимается на неверной базе.

ЧТО СДЕЛАТЬ

Сбрасывать dormantSince=null в refreshPatientVisitStats при новом COMPLETED-визите; в loss-data брать только пациентов с lastVisitAt старше 90 дней; показывать «спящих» отдельной метрикой (сток), а не частью суммы потерь периода/графика.

КРИТЕРИЙ ПРИЁМКИ

После завершённого визита dormantSince пациента = null; сумма потерь за неделю не содержит стоимости всей базы спящих.

ДОКАЗАТЕЛЬСТВО В КОДЕ

dormantSince выставляется в reactivation (стр. 291-303) и нигде в кодовой базе не очищается (grep dormantSince вне revenue/ — только комментариев). Потери: `dormant.length \* averageVisitValueUzs`, где dormant = все с dormantSince != null, а activePatientCount = только dormantSince == null. Вся сумма записывается одной записью на `dateKey: fromKey`, т.е. на первый день любого выбранного периода (неделя/месяц/квартал).

AN-18 P2 · СРЕДНИЙ баг

Рассылаемые по расписанию отчёты не соответствуют периодичности: «ежедневный» шлёт скользящие 30 дней или один и тот же застывший период

ГДЕ

src/server/workers/scheduled-reports.ts:224, src/server/workers/scheduled-reports.ts:273, src/server/analytics/report-config.ts:148

СЦЕНАРИЙ

Директор подписался на ежедневный отчёт по выручке — каждое утро получает PDF за последние 30 дней с темой «Выручка — отчёт за —...—» и не может понять, сколько клиника заработала вчера; при заданных датах сентября в ноябре продолжает получать сентябрь.

ПОСЛЕДСТВИЯ

Функция рассылки выглядит рабочей, но присылает не то, что ожидают.

ЧТО СДЕЛАТЬ

Для расписаний вычислять окно от cadence: DAILY — вчера, WEEKLY — прошлая неделя, MONTHLY — прошлый календарный месяц (Ташкент), переопределяя даты в config; писать реальный период в тему и PDF.

КРИТЕРИЙ ПРИЁМКИ

DAILY-рассылка 24.09 содержит данные только за 23.09 и тему с этой датой.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Воркер вызывает `runReport(reportClient, row.clinicId, config)` с сохранённым config без учёта cadence. Если в отчёте нет дат — resolveDateRange всегда даёт последние 30 дней; если даты заданы — каждый раз отправляется тот же фиксированный период. Тема письма: `отчёт за \${dateFrom ?? "—").slice(0,10)}...` → «отчёт за —...—».

AN-19 P2 · СРЕДНИЙ баг

Реактивация шлёт «вернитесь к нам» пациентам с подтверждённой будущей записью, с пустыми данными клиники и всегда по-русски

ГДЕ

src/server/revenue/reactivation.ts:121, src/server/revenue/reactivation.ts:328, src/server/notifications/template.ts:224

СЦЕНАРИЙ

Пациент 4 месяца не был, вчера записался и подтвердил визит на пятницу. В 07:00 ему в Telegram приходит «Мы скучаем! Запишитесь в по телефону.» — на русском, хотя он выбрал узбекский.

ПОСЛЕДСТВИЯ

Маркетинговые сообщения, противоречащие реальности и с «дырами» в тексте, репутационный ущерб клиники; расход квоты «раз в квартал» на уже вернувшегося пациента.

ЧТО СДЕЛАТЬ

Добавить CONFIRMED в activeApptStatuses; загружать Clinic (nameRu/nameUz/phone/address) и передавать в

render; выбирать bodyUz/bodyRu по preferredLang.

КРИТЕРИЙ ПРИЁМКИ

Пациент с CONFIRMED будущей записью не попадает в кандидаты; отрендеренное сообщение содержит название и телефон клиники на языке пациента.

ДОКАЗАТЕЛЬСТВО В КОДЕ

activeApptStatuses() = ["BOOKED", "WAITING", "IN_PROGRESS"] — нет CONFIRMED, поэтому пациент, подтвердивший будущую запись, не исключается. Тело рендерится `render(tpl.bodyRu, { ..., clinic: { name: "", phone: "", address: "" } })` — хотя шаблону разрешены переменные clinic.name/phone/address (template.ts:224-230), они всегда пустые; bodyUz и Patient.preferredLang игнорируются (в triggers.ts:454 язык учитывается).

AN-20 P2 · СРЕДНИЙ безопасность

Сводка /api/crm/dashboard отдаёт выручку клиники врачу и колл-оператору; при выбранном филиале выручка остаётся общеклинической

ГДЕ

src/app/api/crm/dashboard/route.ts:74, src/app/api/crm/dashboard/route.ts:55, src/app/api/crm/payments/route.ts:28, src/lib/tenant-allowlist.ts:93

СЦЕНАРИЙ

Колл-оператор вызывает /api/crm/dashboard и видит месячную выручку клиники. Администратор филиала «Юнусабад» видит выручку всей сети рядом с записями только своего филиала.

ПОСЛЕДСТВИЯ

Раскрытие финансовых данных ролям, которым это не положено; несопоставимые цифры в мультифилиальном режиме.

ЧТО СДЕЛАТЬ

Отдавать revenue только ADMIN/RECEPTIONIST; для филиального режима фильтровать платежи через appointment.branchId (после привязки оплат к визитам).

КРИТЕРИЙ ПРИЁМКИ

Для DOCTOR/CALL_OPERATOR поле revenue отсутствует/0; при выбранном филиале выручка = платежи визитов этого филиала.

ДОКАЗАТЕЛЬСТВО В КОДЕ

roles: ["ADMIN", "RECEPTIONIST", "DOCTOR", "CALL_OPERATOR"], ответ содержит today/week/month.revenue — сумма всех PAID-платежей клиники. В payments GET та же информация для DOCTOR/CALL_OPERATOR явно запрещена («a curious doctor cannot dump the whole cashflow»). Payment не входит в MODELS_BRANCH_SCOPED, поэтому при выбранном филиале записи считаются по филиалу, а выручка — по всей клинике (то же в /api/crm/analytics).

AN-21 P2 · СРЕДНИЙ мокап / заглушка

Слайдеры «что если» в прогнозе: «снизить неявки» и «заполнить пустые слоты» не меняют итоговые KPI

ГДЕ

src/lib/revenue/forecast.ts:82, src/app/[locale]/crm/analytics/forecast/_components/forecast-page-client.tsx:81, src/server/revenue/forecast-data.ts:95

СЦЕНАРИЙ

Руководитель двигает «Снизить неявки на 30%» — цифры «Скорректированный прогноз» и «Прирост» не меняются; «Заполнить 50% пустых слотов» даёт +2,5%.

ПОСЛЕДСТВИЯ

Инструмент планирования показывает бессмысленные результаты для двух из трёх рычагов.

ЧТО СДЕЛАТЬ

Строить baseline с учётом исторического no-show (ожидаемая выручка), считать эффект снижения неявок и заполнения слотов от реальных EmptySlotSnapshot; либо убрать неработающие слайдеры.

КРИТЕРИЙ ПРИЁМКИ

Сдвиг «Снизить неявки» меняет KPI «Скорректированный прогноз» пропорционально исторической доле неявок.

ДОКАЗАТЕЛЬСТВО В КОДЕ

applyWhatIfSliders меняет только low (reduceNoShow) и high (fillEmpty); `adjustedBaseline = p.baseline` умножается лишь на priceMult. KPI «Скорректированный прогноз» и «Δ» считаются `baselineRevenue(adjusted)` — т.е. от baseline. Верхняя граница = baseline × 1.05 (константа emptySlotUpliftRate), поэтому «заполнить 50% пустых слотов» даёт +2.5% только к потолку.

AN-22 P2 · СРЕДНИЙ баг

Статус CONFIRMED забыт в прогнозе, движении пустых слотов, загрузке в сайдбаре и фильтре конструктора отчётов

ГДЕ

src/server/revenue/forecast-data.ts:52, src/server/revenue/empty-slot.ts:176, src/app/api/crm/shell-summary/route.ts:66, src/server/analytics/report-config.ts:18

СЦЕНАРИЙ

Колл-центр обзвонил и подтвердил 40 записей на следующую неделю — прогноз выручки на эти дни падает, загрузка в сайдбаре уменьшается; в отчёт «только подтверждённые» построить нельзя.

ПОСЛЕДСТВИЯ

Прогноз и загрузка занижаются ровно тогда, когда клиника работает лучше; ошибки в оценке потерь.

ЧТО СДЕЛАТЬ

Добавить CONFIRMED во все четыре списка; в shell-summary фильтровать расписания по validFrom/validTo и отпускам.

КРИТЕРИЙ ПРИЁМКИ

Подтверждение записи не меняет прогноз и загрузку в меньшую сторону; в фильтре отчёта доступен статус «Подтверждена».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Прогноз выручки: `status: { in: ["BOOKED","WAITING","IN\_PROGRESS"] }` — подтверждённые записи (самые надёжные) не входят в базовую линию. Пустые слоты: SLOT_OCCUPYING_STATUSES без CONFIRMED — час с записью, застрявшей в CONFIRMED, считается пустым и оценивается как потеря. Сайдбар: bookedMinutes по `["BOOKED","WAITING","IN\_PROGRESS","COMPLETED"]` — подтверждённые минуты не входят в процент загрузки (к тому же расписания берутся без учёта validFrom/validTo). Конструктор отчётов: APPOINTMENT_STATUS_VALUES без CONFIRMED — выбрать подтверждённые записи в фильтре невозможно, zod отклонит.

AN-23 P2 · СРЕДНИЙ баг

Сумма оплаты «150.000» записывается как 150 сум

ГДЕ

src/app/[locale]/crm/patients/[id]/_components/tabs/payments-tab.tsx:234

СЦЕНАРИЙ

Регистратор набирает «150.000» по привычке — в систему уходит оплата 150 сум со статусом PAID, пациент уходит «оплатившим».

ПОСЛЕДСТВИЯ

Искажение выручки и LTV в 1000 раз; ошибку нельзя исправить из UI (см. отсутствие редактирования).

ЧТО СДЕЛАТЬ

Разрешать только цифры и пробелы (или трактовать . и , как разделители тысяч для сумов), форматировать поле при вводе, показывать итоговую сумму прописью/в формате «150 000 сум» перед сохранением.

КРИТЕРИЙ ПРИЁМКИ

Ввод «150.000», «150,000», «150 000» даёт 150 000 сум; ввод нечисловых символов подсвечивается ошибкой.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`const parsed = Math.round(Number(amount.replace(/s/g, "")) \* 100);` — удаляются только пробелы. Ввод с точкой как разделителем тысяч ("150.000", распространённый формат) даёт $150 \times 100 = 15\,000$ тийин = 150 сум; ввод с запятой («150,000») даёт NaN и кнопка просто неактивна без пояснения. Подтверждения суммы перед сохранением нет.

AN-24 P2 · СРЕДНИЙ баг

Тепловая карта расписания смещена на 5 часов (часы в UTC), а «свободно» всегда равно числу записей

ГДЕ

prisma/migrations/20260507130000_phase18_w1_analytics_foundation/migration.sql:343, prisma/migrations/20260507130000_phase18_w1_analytics_foundation/migration.sql:346, src/app/[locale]/crm/analytics/schedule-heatmap/_components/schedule-heatmap-client.tsx:158, src/messages/ru.json:4736, prisma/migrations/20260507130000_phase18_w1_analytics_foundation/migration.sql:339, prisma/migrations/20260507130000_phase18_w1_analytics_foundation/migration.sql:266, prisma/migrations/20260507130000_phase18_w1_analytics_foundation/migration.sql:127

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Приём с 09:00 до 18:00 по Ташкенту на карте отображается в колонках 04–13; админ решает, что утром в 5 утра пик, и двигает смены. Наведение на ячейку показывает «5 запис. (свободно 5)».

ПОСЛЕДСТВИЯ

Дашборд, по которому планируют расписание, показывает неверные часы и фиктивные «свободные слоты».

ЧТО СДЕЛАТЬ

В MV использовать `(a."date" AT TIME ZONE 'UTC') AT TIME ZONE 'Asia/Tashkent'` для hour/ISODOW (и для day/month в остальных MV); availableSlotCount считать из DoctorSchedule либо убрать из подсказки. Новая миграция с пересозданием MV.

КРИТЕРИЙ ПРИЁМКИ

Запись на 09:30 Ташкента попадает в колонку 09; подсказка не показывает «свободно N» при N=записям.

ДОКАЗАТЕЛЬСТВО В КОДЕ

mv_schedule_heatmap: `EXTRACT(ISODOW FROM a."date")`, `EXTRACT(HOUR FROM a."date")` — колонка date это TIMESTAMP без зоны, хранящий UTC, поэтому часы UTC. Клиент рисует 0..23 как есть, без сдвига. `COUNT(\*) AS "availableSlotCount"` — буквально то же число, что appointmentCount (комментарий миграции это признаёт), а подсказка ячейки: "{appts} запис. (свободно {slots})". Аналогично mv_financial_pace/mv_doctor_performance группируют по UTC-дню/месяцу (date_trunc без AT TIME ZONE), а financial_pace-resolver берёт «сегодня» по UTC.

AN-25 P2 · СРЕДНИЙ баг

Финансовый дашборд: через минуту 90-дневный график сжимается до текущего месяца, «Обновлено» показывает время запроса, а не данных

ГДЕ

src/app/[locale]/crm/analytics/financial/_components/financial-dashboard-client.tsx:45, src/app/[locale]/crm/analytics/financial/page.tsx:44, src/server/analytics/financial-pace-resolver.ts:89, src/server/analytics/financial-pace-resolver.ts:160, src/server/workers/analytics-refresh.ts:169

СЦЕНАРИЙ

Главбух открывает «Финансы», видит тренд за 3 месяца, отвлекается — через минуту график показывает только 23 дня сентября; надпись «Обновлено 14:05:10» при этом сегодняшние оплаты за последние 50 минут в цифрах отсутствуют.

ПОСЛЕДСТВИЯ

Пользователь видит «живые» данные, которые на деле до часа устаревшие, а обещанный тренд пропадает.

ЧТО СДЕЛАТЬ

Передавать в API тот же dayFrom/dayTo (или отдельный параметр days=90); отдавать время последнего REFRESH MV (pg_stat или таблица метаданных) как «Данные на»; считать «сегодня» по Ташкенту; для «Получено сегодня» читать Payment напрямую, а не MV.

КРИТЕРИЙ ПРИЁМКИ

Через 5 минут на странице по-прежнему 90 точек; «Данные на» совпадает с последним обновлением MV; оплата, внесённая сейчас, видна в «Получено сегодня» без ожидания часа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

SSR берёт окно 90 дней (dayFrom = сегодня-89), а автообновление раз в 60 с дергает `/api/crm/analytics/financial` без параметров → резолвер по умолчанию `from = monthStart` → `setSnapshot(json.data)` заменяет daily на дни текущего месяца; 1-го числа график превращается в «пусто»

(filtered.length < 2). generatedAt = `new Date().toISOString()` в момент запроса, хотя MV обновляется раз в час (HOURLY_MS), кнопки ручного обновления нет. «Сегодня»/MTD считаются по UTC-дню.

AN-26 P2 · СРЕДНИЙ баг

Экспорт отчёта в CSV/PDF падает с 500, если в названии отчёта кириллица

ГДЕ

src/server/analytics/csv.ts:104, src/server/analytics/pdf.ts:349, src/app/api/crm/analytics/reports/[id]/run/route.ts:110, src/app/api/crm/analytics/reports/run/route.ts:112

СЦЕНАРИЙ

Администратор сохраняет отчёт «Выручка по врачам» и нажимает «Экспорт CSV» или «Экспорт PDF» — всегда ошибка. С латинским названием работает.

ПОСЛЕДСТВИЯ

Экспорт сохранённых отчётов фактически не работает для русско/узбекоязычных пользователей (узбекская латиница с 'I' тоже вне latin1).

ЧТО СДЕЛАТЬ

Формировать `filename="<ascii-fallback>"; filename\*=UTF-8"<percent-encoded>"` (RFC 5987) или транслитерировать имя.

КРИТЕРИЙ ПРИЁМКИ

Экспорт отчёта с названием «Выручка по врачам» и «Oʻrtacha chek» скачивается, имя файла корректно в браузере.

ДОКАЗАТЕЛЬСТВО В КОДЕ

csvFilename/pdfFilename сохраняют буквы `p{L}` (кириллицу), а имя кладётся в заголовок `content-disposition: attachment; filename="\${filename}"`. Заголовки Response должны быть ByteString; проверено в Node 22: `new Response('x',{headers:{'content-disposition':'attachment; filename="Выручка-2026.csv"'}})` → `TypeError «Cannot convert argument to a ByteString... value of 1042»`. Исключение ловится и возвращается `err("ReportRunFailed", 500)`; клиент показывает «Не удалось экспортировать».

AN-27 P2 · СРЕДНИЙ баг

Экспорт пациентов/записей: кнопка видна всем ролям, но работает только у ADMIN; ошибки молчат; фильтры и формат файла неверны

ГДЕ

src/app/[locale]/crm/patients/_components/export-button.tsx:41, src/app/api/crm/exports/route.ts:34, src/hooks/use-async-export.ts:73, src/server/workers/exports.ts:150, src/server/workers/exports.ts:188, src/app/[locale]/crm/patients/_components/export-button.tsx:40, src/app/[locale]/crm/appointments/_components/export-button.tsx:35, src/app/api/crm/exports/route.ts:36, src/hooks/use-async-export.ts:59, src/server/workers/exports.ts:63

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Регистратор нажимает «Экспорт» в списке пациентов — видит «Экспорт поставлен в очередь», файл так и не скачивается. Админ выгружает записи «по 30.09» — в файле нет 30 сентября, вместо ФИО — идентификаторы, цена 15000000 вместо 150 000.

ПОСЛЕДСТВИЯ

Функция вводит в заблуждение не-админов; для админа файл почти непригоден и неполон.

ЧТО СДЕЛАТЬ

Скрывать кнопку не-ADMIN; показывать ошибки и таймаут опроса; учитывать q и deletedAt=null; даты как дни Ташкента включительно; в CSV выводить ФИО пациента/врача, название услуги, сумму в сумах и локальную дату.

КРИТЕРИЙ ПРИЁМКИ

Регистратор кнопку не видит; админ получает файл за полный последний день с ФИО и суммами в сумах; при ошибке — видимый toast.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Кнопка «Экспорт» рендерится без проверки роли на страницах пациентов и записей, сразу показывает toast «поставлено в очередь»; API `roles: ["ADMIN"]` → регистратор получает 403, хук ставит status=failed, но кнопку ошибку не показывает. Опрос `if (!r.ok) return;` — при 404 (реестр задач в памяти потерян после рестарта)

опрашивает каждые 1,5 с бесконечно, кнопка висит в спиннере. exportPatients игнорирует поиск q и не фильтрует deletedAt (анонимизированные DSAR-пациенты попадают в файл). exportAppointments: `range.lte = new Date(dateTo)` — UTC-полночь, последний день теряется; в CSV только doctorId/patientId/serviceId (ID без имён), priceFinal в тийинах, дата в ISO UTC.

AN-28 РЗ · НИЗКИЙ баг

CSV «Скачать отчёт» на главной аналитике выгружает выручку в тийинах

ГДЕ

src/app/[locale]/crm/analytics/_components/analytics-page-client.tsx:200, src/app/[locale]/crm/analytics/_components/analytics-page-client.tsx:208

СЦЕНАРИЙ

Руководитель открывает выгрузку — выручка за неделю «1 250 000 000» вместо 12 500 000 сум, имена врачей нечитаемы.

ПОСЛЕДСТВИЯ

Неверное прочтение финансовых данных при передаче наружу (бухгалтерии).

ЧТО СДЕЛАТЬ

Делить на 100, добавить BOM, локализовать заголовки.

КРИТЕРИЙ ПРИЁМКИ

CSV открывается в Excel с корректной кириллицей и суммами в сумах.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`["kpi","revenue\_total",String(totalRevenue)]` и `[{"topDoctors",d.name,String(d.revenue)}]` — сырые тийины без деления на 100; файл без BOM, поэтому Excel на Windows показывает кириллицу кракозябрами.

AN-29 РЗ · НИЗКИЙ баг

PDF счёта показывает не тот тариф, за который выставлен счёт

ГДЕ

src/app/api/crm/billing/invoices/[id]/pdf/route.ts:66

СЦЕНАРИЙ

Клиника оплатила счёт на Pro, затем запросила Enterprise — скачанный PDF старого оплаченного счёта теперь указывает «Enterprise».

ПОСЛЕДСТВИЯ

Некорректные финансовые документы.

ЧТО СДЕЛАТЬ

Брать план по invoice.targetPlanId.

КРИТЕРИЙ ПРИЁМКИ

PDF любого счёта показывает тариф из targetPlanId независимо от текущей подписки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

План для PDF берётся из `sub.pendingPlanId` (последний запрошенный апгрейд) либо текущего `sub.plan`, а не из `invoice.targetPlanId`, который специально хранится на счёте.

AN-30 РЗ · НИЗКИЙ мёртвая механика

«Среднее время ожидания» всегда 0 секунд: calledAt и startedAt ставятся одним и тем же моментом

ГДЕ

src/server/analytics/funnels.ts:341, src/app/api/crm/appointments/[id]/route.ts:381, src/app/api/crm/analytics/funnels/route.ts:226

СЦЕНАРИЙ

Администратор хочет понять, у кого из врачей пациенты дольше сидят в коридоре — карточка показывает «0 сек» у всех врачей.

ПОСЛЕДСТВИЯ

Метрика ожидания мёртвая, реальное ожидание (arrivedAt/queuedAt → calledAt) не измеряется.

ЧТО СДЕЛАТЬ

Считать ожидание как calledAt – COALESCE(arrivedAt, queuedAt) (для записей — от max(arrivedAt, времени слота)); переименовать метрику соответствующим образом.

КРИТЕРИЙ ПРИЁМКИ

Для визита, где пациент отмечен пришедшим в 10:00 и вызван в 10:25, метрика даёт ~25 мин.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Метрика = `startedAt - calledAt`. При вызове пациента врачом: ``const calledAt = new Date(); callData = { calledAt, status: "IN_PROGRESS", queueStatus: "IN_PROGRESS", startedAt: calledAt }`` — один и тот же объект. `queue-status` route (стр. ~269) `calledAt` не пишет. Значит для всех визитов `delta = 0`, а визиты без `calledAt` исключаются.

AN-31 РЗ · НИЗКИЙ переводы

В аналитике показываются сырые коды: статусы «comp/book», источники «WEBSITE/OTHER»; валюта платежа игнорируется в суммах

ГДЕ

`src/app/[locale]/crm/analytics/_components/analytics-charts.tsx:399`, `src/app/[locale]/crm/analytics/_components/analytics-charts.tsx:549`, `src/app/api/crm/analytics/route.ts:74`, `src/app/api/crm/dashboard/route.ts:59`

СЦЕНАРИЙ

Узбекоязычный администратор видит на графике подписи «comp», «canc», «no_s» и «WEBSITE», «OTHER».

ПОСЛЕДСТВИЯ

Непрофессиональный вид дашборда; потенциальное расхождение сумм.

ЧТО СДЕЛАТЬ

Локализовать статусы и источники через `i18n`; в денежных агрегатах конвертировать USD в тийины по `amountUsdSnap/курсу` или фильтровать единообразно.

КРИТЕРИЙ ПРИЁМКИ

Подписи на графиках переведены на `ru/uz`; суммы на дашборде и аналитике совпадают при наличии USD-платежа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ось статусов: ``String(v).slice(0, 4).toLowerCase()``; легенда источников выводит ``{s.source}`` (enum `LeadSource`) без перевода. Суммы: `analytics/route.ts` и `mv_financial_pace` складывают `amount` всех валют (центы USD как тийины), а `dashboard` фильтрует ``currency: "UZS"`` — при появлении USD-платежей цифры на двух экранах разойдутся.

AN-32 РЗ · НИЗКИЙ баг

После прочтения чата в Telegram-инбоксе счётчик в шапке не обновляется (неверный ключ кэша)

ГДЕ

`src/app/[locale]/crm/telegram/_hooks/use-mark-read.ts:48`, `src/hooks/use-shell-summary.ts:23`

СЦЕНАРИЙ

Оператор прочитал все чаты, а бейдж Telegram в сайдбаре продолжает показывать «3».

ПОСЛЕДСТВИЯ

Ложные непрочитанные, лишние переходы.

ЧТО СДЕЛАТЬ

Использовать экспортируемый `shellSummaryKey`.

КРИТЕРИЙ ПРИЁМКИ

После `markRead` бейдж обновляется сразу.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Инвализация ``queryKey: ["shell-summary"]``, а реальный ключ ``["crm","shell-summary"]``; префиксное сравнение `TanStack` не совпадает, бейдж обновится только по `staleTime`/фокусу окна.

Раздел «Аналитика» виден регистратору/медсестре/оператору, но открывается с ошибкой; плитка «Выручка» на ресепшене ведёт на 404

ГДЕ

src/components/layout/crm-sidebar.tsx:120, src/app/api/crm/analytics/route.ts:35, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:141, src/app/[locale]/crm/analytics/financial/page.tsx:36

СЦЕНАРИЙ

Регистратор кликает «Аналитика» в меню — ошибка загрузки; кликает плитку «Выручка» — страница 404.

ПОСЛЕДСТВИЯ

Сломанные пути навигации для основной роли пользователей ресепшена.

ЧТО СДЕЛАТЬ

Скрыть «Аналитику» для ролей без доступа (requiredRole), плитку выручки делать некликабельной или вести на доступную страницу.

КРИТЕРИЙ ПРИЁМКИ

У регистратора нет пункта «Аналитика», плитка выручки не ведёт на 404.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Пункт analytics в сайдбаре без requiredRole, страница /crm/analytics без проверки роли, а API разрешает только ADMIN/DOCTOR → EmptyState «Не удалось загрузить аналитику». Плитка «Выручка» в KPI-полосе ресепшена ссылается на /crm/analytics/financial, где для не-ADMIN вызывается notFound().

Роуты отчётов и биллинга обходят createApiHandler: нет MFA-гейта, SUPER_ADMIN в режиме «войти как» получает 403

ГДЕ

src/app/api/crm/analytics/reports/run/route.ts:32, src/app/api/crm/analytics/reports/[id]/schedules/route.ts:80, src/app/api/crm/billing/upgrade/route.ts:25, src/lib/api-handler.ts:201

СЦЕНАРИЙ

Новый администратор, ещё не настроивший 2FA, скриптом создаёт расписание отправки отчётов на произвольный Telegram-чат. Платформенный админ в режиме «войти как» открывает отчёт — «Run» всегда даёт 403.

ПОСЛЕДСТВИЯ

Точечный обход политики обязательной 2FA; сломанный сценарий поддержки.

ЧТО СДЕЛАТЬ

Перевести роуты на createApiHandler/createApiListHandler с roles:["ADMIN"].

КРИТЕРИЙ ПРИЁМКИ

Эти роуты возвращают 403 MFA_REQUIRED для пользователя без TOTP и работают для SUPER_ADMIN в режиме WRITE-имперсонации.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Семь роутов (reports/run, reports/[id]/run, reports/[id]/schedules, schedules/[scheduleId], billing/upgrade, invoices/[id]/pdf, simulate-pay) вызывают `auth()` напрямую и проверяют `role !== "ADMIN"`. В api-handler.ts:201-215 описано, что именно такой обход позволяет пользователю без обязательной TOTP-регистрации работать через API — здесь гейт не применяется (как и блок VIEW_ONLY и branch-контекст). Страницы отчётов пускают SUPER_ADMIN, а эти API — нет.

Создание оплаты доверяет appointmentId/patientId из тела запроса (в т.ч. чужой клиники и несовпадающих пациентов)

ГДЕ

src/app/api/crm/payments/route.ts:105, src/app/api/crm/payments/route.ts:155

СЦЕНАРИЙ

Регистратор (или скрипт) создаёт оплату с patientId пациента Иванова и appointmentId визита Петрова — LTV начисляется Иванову, визит Петрова выглядит оплаченным.

ПОСЛЕДСТВИЯ

Нарушение целостности финансовых данных; потенциальное межклиничное влияние при мультитенантности.

ЧТО СДЕЛАТЬ

Перед созданием проверять findFirst визита и пациента в текущей клинике, и что appointment.patientId === patientId (или выводить patientId из визита).

КРИТЕРИЙ ПРИЁМКИ

POST с чужим/несовпадающим appointmentId возвращает 422; тест на межклиничный ID.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`appointmentId: body.appointmentId ?? null, patientId: body.patientId ?? null` пишутся без проверки принадлежности клинике и друг другу; tenant-extension не проверяет внешние ключи. Проверка appointment.findUnique (стр. 155-160) выполняется только если patientId не передан и лишь для подстановки. Include-связи (`appointment.payments`, фильтр `payments: { none: ... }`) tenant-extension не фильтрует, поэтому платёж клиники А, привязанный к визиту клиники В, будет виден/влиять в клинике В.

АС · Центр действий, действия, AI, база знаний

АС-01 Р1 · ВЫСОКИЙ баг

«Отложить» навсегда убирает задачу: отложенные задачи не возвращаются ни в Центр действий, ни в брифинг ресепшн, ни в виджет колл-центра

ГДЕ

src/app/[locale]/crm/action-center/_components/action-center-client.tsx:98, src/app/[locale]/crm/reception/_components/action-briefing.tsx:27, src/app/[locale]/crm/call-center/_hooks/use-unconfirmed.ts:37, src/app/api/crm/actions/route.ts:59, src/app/api/crm/actions/[id]/snooze/route.ts:36, src/server/actions/repository.ts:164, src/server/actions/handler-utils.ts:27, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:881

СЦЕНАРИЙ

Администратор в Центре действий на карточке «Каримов: задолженность 450 000 сум» жмёт «... → Отложить» (или в брифинге ресепшн кнопку-часы → «1 час»). Тост «Отложено до 1 час». Через час, день, неделю задача не появляется ни в Центре действий, ни на экране ресепшн: она SNOOZED, а экраны читают только OPEN. Долг забыт.

ПОСЛЕДСТВИЯ

Ресепшн и админ теряют задачи (долги, неподтверждённые записи, контроль, низкие NPS) после любого «Отложить». Функция выглядит рабочей, а по факту это скрытое удаление.

ЧТО СДЕЛАТЬ

Выбрать единую модель: либо (а) все списки запрашивают status=[OPEN,SNOOZED] и полагаются на серверный фильтр snoozeUntil<=now (action-center-client, action-briefing, use-unconfirmed), либо (б) движок/запрос при чтении переводит SNOOZED с истёкшим snoozeUntil в OPEN. expireStaleActions не должен экспайрить SNOOZED-строки, у которых snoozeUntil в будущем (TTL считать от max(updatedAt, snoozeUntil)). resolveSnoozePreset('tomorrow') считать как 09:00 Asia/Tashkent следующего клинического дня (через tashkentComponents/toTashkentDate). В ActionMenu обернуть snooze/dismiss в try/catch с тостом ошибки.

КРИТЕРИЙ ПРИЁМКИ

Отложить задачу на 1 час → через час (после ближайшего чтения списка) она снова в Центре действий и в брифинге ресепшн. Отложить «Завтра» → snoozeUntil = следующий день 09:00 по Ташкенту (04:00Z). Отложенная на неделю задача, которую детектор больше не обновляет, не становится EXPIRED до истечения snoozeUntil. Юнит-тест на resolveSnoozePreset с TZ Asia/Tashkent.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Snooze-роут ставит status='SNOOZED' + snoozeUntil (snooze/route.ts:36-42). Ничто в коде не переводит SNOOZED обратно в OPEN: upsertAction оставляет existing.status для нетерминальных строк (repository.ts:164 `newStatus = wasTerminal ? "OPEN" : existing.status`, комментарий 191 «Snooze stays untouched»), grep по "SNOOZED" не находит ни одного перевода статуса. Список API по умолчанию берёт [OPEN,SNOOZED] и показывает SNOOZED с истёкшим таймером (route.ts:59, 88-96), но все три потребителя явно передают status=["OPEN"]: action-center-client.tsx:98-101 `useActionsPaged({ status: ["OPEN"], limit: 50 })`, action-briefing.tsx:27 `useActionsList({ status: ["OPEN"], limit: 5 })`, use-unconfirmed.ts:37 `sp.append("status", "OPEN")`. Итог: отложенная строка остаётся SNOOZED и её нигде не видно (кроме риск-листа, который обрабатывает только сегодняшние записи). Если детектор перестал её обновлять — через 48ч expireStaleActions (repository.ts:248-256, фильтр status IN [OPEN,SNOOZED] и updatedAt<=cutoff) ставит EXPIRED, даже если пользователь отложил «на неделю». Дополнительно пресет «Завтра» = setUTCHours(9) (handler-utils.ts:27-32) = 14:00 по Ташкенту, а не 09:00 как написано в комментарии. В ActionMenu основного списка (action-center-client.tsx:881, 891) snooze/dismiss вызываются `await ...mutateAsync` без try/catch — при ошибке строка молча исчезает и возвращается, тоста нет.

АС-02 Р1 · ВЫСОКИЙ баг

Время записи/слота в карточках Центра действий и брифинга показывается в UTC — на 5 часов раньше реального; «запись завтра» пишется и для сегодняшних

ГДЕ

src/lib/actions/format.ts:40, src/lib/actions/format.ts:89, src/lib/actions/format.ts:96, src/messages/ru.json:5182, src/server/actions/detectors/unconfirmed-24h.ts:51, tests/unit/action-payload-formatter.test.ts:178

СЦЕНАРИЙ

Запись Иванова на 14:00. В Центре действий и в брифинге на экране ресепшн: «Иванов — запись завтра в 09:00 не подтверждена». Регистратор звонит и называет пациенту 09:00. Для записи на сегодня 16:00 карточка говорит «завтра в 11:00».

ПОСЛЕДСТВИЯ

Неправильное время в основном рабочем списке — пациенты приходят не вовремя или путаются, ресепшн не доверяет экрану.

ЧТО СДЕЛАТЬ

В `format.ts` форматировать время и дату через `Intl.DateTimeFormat` с `timeZone 'Asia/Tashkent'` (или `clinic.timezone`), как в `formatTimeInClinic`. Для `UNCONFIRMED_24H` выбирать «сегодня/завтра/дата» по клиническому дню, а не хардкодить «завтра» (`ICU select + slotDate`). Обновить фикстуры теста на ташкентское время.

КРИТЕРИЙ ПРИЁМКИ

Запись с `date=09:00Z` отображается «14:00» во всех карточках (Центр действий, брифинг ресепшн, риск-лист). Для записи на сегодня текст не содержит «завтра». Тест `formatter` проверяет `10:00Z` → «15:00».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`formatHM: `const h = String(d.getUTCHours())...`` (`format.ts:40-46`), используется для `slotTime` в `EMPTY_SLOT_TOMORROW` (75), `UNCONFIRMED_24H` (89), `NO_SHOW_RISK_HIGH` (96), `PATIENT_NO_CHANNEL` (143). В `payload` лежат реальные UTC-инстанты: `unconfirmed-24h.ts:89 `appointmentAt: r.date.toISOString()``, `empty-slot-tomorrow.ts:69-72` строит слот через `toTashkentDate`. Для сравнения риск-лист на той же странице форматирует правильно с `timeZone 'Asia/Tashkent'` (`risk-today-section.tsx:1029-1040`), так что одна и та же запись показывается «14:00» в риск-листе и «09:00» в списке задач. Тест фиксирует ошибку: фикстура `slotStart '2026-05-07T10:00:00.000Z'` ожидает '10:00' (`test:178`). Заголовок `UNCONFIRMED_24H` жёстко «запись завтра в {slotTime}» (`ru.json:5182`), а детектор берёт горизонт 72ч, включая сегодня (`unconfirmed-24h.ts:51, 73`).

АС-03 P1 · ВЫСОКИЙ мёртвая механика

Задача «Контрольный визит» (`VISIT_FOLLOW_UP_DUE`) и алерт «Низкая оценка» (`LOW_NPS_RECEIVED`) стираются через 48 часов — задолго до даты контроля

ГДЕ

`src/server/workers/visit-note-handout.ts:632`, `src/server/workers/visit-note-handout.ts:653`, `src/server/actions/repository.ts:248`, `src/server/actions/engine.ts:237`, `src/app/api/miniapp/nps/[appointmentId]/route.ts:310`

СЦЕНАРИЙ

Невролог ставит «Контроль через 30 дней», финализирует. Задача «Иванова: контроль ~23.10» появляется у ресепшн сегодня и через 2 дня исчезает (`EXPIRED`). 23.10 никто пациентке не звонит. Пациент поставил 3/10 в пятницу вечером — в понедельник утром алерта уже нет.

ПОСЛЕДСТВИЯ

Ключевая функция Ф6 «позвать на контроль» фактически не работает: пациенты не возвращаются на контроль (клинический риск для неврологических больных и потеря выручки). Недовольные пациенты теряются.

ЧТО СДЕЛАТЬ

В `expireStaleActions` не применять `updatedAt-TTL` к строкам с `expiresAt` в будущем (TTL только для строк с `expiresAt=null`), либо исключить событийные типы (`VISIT_FOLLOW_UP_DUE`, `LOW_NPS_RECEIVED`, `PATIENT_NO_CHANNEL`) из `updatedAt-sweep`. Для `VISIT_FOLLOW_UP_DUE` дополнительно показывать задачу с разумного опережения (например, за N дней до `dueDate`), чтобы она не висела месяц.

КРИТЕРИЙ ПРИЁМКИ

Финализировать заметку с `followUpDays=30` → через 3 суток (после многих тиков движка) задача всё ещё `OPEN`; становится `EXPIRED` только после `dueDate+7д`. `LOW_NPS` не экспайрится через 48ч. Юнит-тест `expireStaleActions`: строка с `expiresAt` в будущем и старым `updatedAt` не трогается.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`VISIT_FOLLOW_UP_DUE` создаётся один раз при бридже финализированной заметки (`visit-note-handout.ts:632-656`) с ``expiresAt = due + 7 дней`` и комментарием «Keep the card around for a week past due». После этого ставится `medicationsBridgedAt` (661) и строку больше никто не `upsert`-ит (типа нет в `specs` движка, `engine.ts:106-175`). Но `expireStaleActions`, вызываемый движком каждые 15 минут для всех типов клиники (`engine.ts:237`), экспайрит строки по ``updatedAt <= now - 48h`` (`repository.ts:248-256`), игнорируя будущий `expiresAt`. То же для `LOW_NPS_RECEIVED` — создаётся один раз при отправке оценки (`nps route:310`). Итог: задача живёт

48 часов, а не до due+7д.

АС-04 Р1 · ВЫСОКИЙ баг

Исход звонка для строк риск-листа «Нет связи» никуда не сохраняется: «Отказался» не отменяет запись, «Подтвердил» не подтверждает; «Не дозвонился» отмечает пациента как «на связи»

ГДЕ

src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:411, src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:420, src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:425, src/app/api/crm/action-center/risk-today/route.ts:342

СЦЕНАРИЙ

В риск-листе «Не на связи 30 дней» у Каримовой (запись сегодня 15:00). Регистратор дозвонилась, пациентка отказалась, причина «уехала в Самарканд» → «Отказался». Тост «Исход записан». Запись остаётся BOOKED, врач ждёт в 15:00, слот не освобождён, причина не сохранена нигде. Другой пациент не взял трубку → «Не дозвонился» → пациент помечен «на связи сейчас», строка исчезла на 14 дней, в карточке пациента «последний контакт — сегодня».

ПОСЛЕДСТВИЯ

Потерянные отказы (пустые слоты, врач ждёт), неверные данные о контакте в карточке пациента, повторный недозвон не планируется.

ЧТО СДЕЛАТЬ

Для строк без Action создавать/использовать Action по appointmentId (например, серверный эндпоинт outcome по appointmentId), чтобы CONFIRMED вызывал confirmAppointment, REFUSED — cancelAppointment, CALLBACK/RETURN_LATER — сохранялись с датой. mark-contacted вызывать только для исходов с реальным разговором (не для NO_ANSWER).

КРИТЕРИЙ ПРИЁМКИ

Строка только с no_contact: «Отказался» с причиной → запись CANCELLED с cancelReason; «Подтвердил» → confirmedAt заполнен; «Не дозвонился» → lastContactedAt не меняется, строка возвращается позже. Исход виден в «Обработано сегодня» после рефетча.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Строка риск-листа может иметь только причину no_contact (risk-today route.ts:338-355) и тогда actionIds=[]. onOutcome: `if (row.actionIds.length > 0) { recordOutcome... } else { dropRiskRowFromCache(...) }` (risk-today-section.tsx:411-421) — для таких строк исход (REFUSED/CONFIRMED/CALLBACK/RETURN_LATER с датой и заметкой) не отправляется на сервер вообще, только mark-contacted. Затем `if (hasNoContactReason) markContacted.mutateAsync(...)` (425-431) вызывается для ЛЮБОГО исхода, включая NO_ANSWER («Не дозвонился»), что ставит Patient.lastContactedAt = now (mark-contacted/route.ts:46). Тост «Исход записан: Отказался» показывается в любом случае.

АС-05 Р2 · СРЕДНИЙ баг

CASE_REPEAT_DUE напоминает о повторном визите пациентам, которые уже пришли на повтор или подтвердили его

ГДЕ

src/server/actions/detectors/case-repeat-due.ts:71, src/server/actions/detectors/case-repeat-due.ts:41, src/server/actions/engine.ts:146

СЦЕНАРИЙ

Пациент пришёл на бесплатный повторный приём позавчера (COMPLETED), но в Центре действий «Повторный визит для Юсуповой до 25.09» — ресепшн звонит и зовёт повторно. Пациент уже подтвердил запись по кнопке в Telegram — всё равно звонок.

ПОСЛЕДСТВИЯ

Лишние звонки, раздражение пациентов, недоверие к задачам.

ЧТО СДЕЛАТЬ

Считать повтор состоявшимся/запланированным при любой последующей записи в случае со статусом не CANCELLED/NO_SHOW (BOOKED, CONFIRMED, WAITING, IN_PROGRESS, COMPLETED). Ограничить выборку случаями, у которых окно бесплатного повтора пересекает [now, now+lead]. Deeplink на /crm/cases/<caseId>.

КРИТЕРИЙ ПРИЁМКИ

Случай с COMPLETED или CONFIRMED повторной записью не даёт CASE_REPEAT_DUE. Ссылка открывает

карточку случая.

ДОКАЗАТЕЛЬСТВО В КОДЕ

hasFutureBooked учитывает только статусы BOOKED и WAITING (case-repeat-due.ts:71-76). Подтверждённая запись имеет status CONFIRMED (confirm.ts флипает BOOKED→CONFIRMED), завершённый повторный визит — COMPLETED; ни то, ни другое не гасит задачу. Детектор каждые 15 минут грузит все OPEN-случаи со всеми их записями без ограничений (41-54). Deeplink по умолчанию '/crm/cases' — страницы нет (см. отдельную находку); комментарий обещает severity medium, но engine.ts:146-148 не передаёт severityFor → «high».

АС-06 P2 · СРЕДНИЙ производительность

PAYMENT_OVERDUE сканирует всю историю визитов каждые 15 минут и заваливает список карточками по старым визитам

ГДЕ

src/server/actions/detectors/payment-overdue.ts:40, src/server/actions/config.ts:57, src/server/actions/repository.ts:177

СЦЕНАРИЙ

После импорта/сида истории за год в Центре действий сотни «задолженностей» по визитам прошлого года; реальные сегодняшние долги теряются (список обрезан до 50 новейших). Воркер каждые 15 минут поднимает десятки тысяч строк.

ПОСЛЕДСТВИЯ

Нагрузка на БД растёт линейно с историей, шум в задачах, раздувание AuditLog.

ЧТО СДЕЛАТЬ

Ограничить окно (например, последние 90 дней) или вести явный флаг/баланс долга по визиту; группировать долги по пациенту; не писать ACTION_UPDATED при изменении только производных полей (daysOverdue). Конвертировать платежи в валюту priceFinal.

КРИТЕРИЙ ПРИЁМКИ

Запрос детектора ограничен окном и индексом; количество ACTION_UPDATED аудит-строк в сутки не зависит от числа старых долгов; визиты старше окна не создают задач.

ДОКАЗАТЕЛЬСТВО В КОДЕ

findMany по всем COMPLETED с priceFinal>0 и `date <= now` без нижней границы, с вложенными payments (payment-overdue.ts:40-55), для каждой активной клиники каждые 15 минут. На каждый исторический визит, где сумма PAID-платежей < priceFinal, создаётся отдельный Action (платежи в USD суммируются в тийинах без конвертации, как и в остальном приложении). daysOverdue меняется каждые сутки → на каждую такую строку ежедневно пишется ACTION_UPDATED в AuditLog и SSE (repository.ts:177-217). Прод = демо-данные (сиды), плюс возможный импорт истории без платежей.

АС-07 P2 · СРЕДНИЙ баг

«Высокий риск неявки 60%» получает каждый новый пациент и даже пациент, уже сидящий в очереди

ГДЕ

src/lib/ai/no-show-risk.ts:122, src/server/actions/config.ts:51, src/server/actions/detectors/no-show-risk-high.ts:55, src/server/actions/detectors/no-show-risk-high.ts:116, src/app/api/crm/action-center/risk-today/route.ts:174

СЦЕНАРИЙ

Все первичные пациенты на ближайшие 4 часа помечаются «Высокий риск no-show 60–70%», в KPI «Риск пропуска» и «потери». Пациент пришёл заранее и сидит в холле (WAITING) — ему предлагают позвонить как «рисковому».

ПОСЛЕДСТВИЯ

Шумовой псевдо-AI показатель: ресепшн тратит время на звонки новым пациентам, реальные риски тонут; «потери» в деньгах завышены.

ЧТО СДЕЛАТЬ

Для пациентов без истории не опираться на априорные 0.5 (либо порог выше, либо требовать минимум N визитов/confidence≠low для NO_SHOW_RISK_HIGH). Исключить WAITING/IN_PROGRESS из детектора и из риск-листа (или хотя бы из причин no_contact/high_risk).

КРИТЕРИЙ ПРИЁМКИ

Первичный пациент без других факторов не получает NO_SHOW_RISK_HIGH. Пациент в статусе

WAITING/IN_PROGRESS не появляется в риск-листе. Тест детектора на эти случаи.

ДОКАЗАТЕЛЬСТВО В КОДЕ

historyRisk=(noShows+1)/(total+2): при 0 визитах = 0.5, плюс firstVisitBump 0.1 = 0.6 (no-show-risk.ts:122-134; node: 0.5+0.1 === 0.6). Порог noShowRiskThreshold: 0.6 (config.ts:51), фильтр `if (risk < threshold) continue` (detector:116) → 0.6 проходит. С отправленным напоминанием +0.1 → 0.7. Детектор берёт статусы BOOKED и WAITING (detector:55) — WAITING значит пациент уже отметился в клинике. Риск-лист включает WAITING/IN_PROGRESS записи (risk-today route:174), и причина no_contact добавляется даже пациенту в кабинете врача (338-355).

АС-08 Р2 · СРЕДНИЙ баг

«Отклонить» и «Готово» не работают: движок каждые 15 минут воскрешает закрытую задачу в OPEN

ГДЕ

src/server/actions/repository.ts:159, src/server/actions/repository.ts:188, src/app/api/crm/actions/[id]/dismiss/route.ts:29, src/app/api/crm/actions/[id]/done/route.ts:28, src/server/actions/scheduler.ts:27, src/messages/ru.json:5138, src/server/workers/visit-note-handout.ts:637

СЦЕНАРИЙ

Админ отклоняет «Dr. Юсупова: 3 слота на ближайшую неделю» (врач сознательно работает 2 дня) или «Отклонить» на PAYMENT_OVERDUE, который погасили наличными вне системы. Через ≤15 минут задача снова в списке с тем же текстом. Ресепшн жмёт «Готово» на «Иванов — запись не подтверждена» (дозвонились, но в системе не подтвердили) — через 15 минут задача вернулась. Регистратор закрыл задачу «контрольный визит», врач поправил заметку — задача снова открыта.

ПОСЛЕДСТВИЯ

Список невозможно разгрести, «шум» не гасится, персонал перестаёт доверять Центру действий. Кнопки выглядят рабочими, но фактически ничего не делают дольше 15 минут.

ЧТО СДЕЛАТЬ

Ввести подавление: DISMISSED — терминальный статус, который upsertAction не воскрешает (или воскрешает только при изменении значимых полей payload/severity, либо после явного suppressUntil). Для DONE без outcome — не воскрешать до изменения входных данных детектора (сравнивать payload) или до suppressUntil (например, конец клинического дня). Текст диалога привести в соответствие с поведением.

КРИТЕРИЙ ПРИЁМКИ

Отклонённая задача не возвращается после ручного «Пересчитать сейчас» и после 2 циклов планировщика, пока payload не изменился. Тест repository: upsert по DISMISSED-строке с тем же payload оставляет DISMISSED. Правка заметки после закрытия задачи контроля не открывает её заново.

ДОКАЗАТЕЛЬСТВО В КОДЕ

upsertAction: `wasTerminal = !outcomeLocked && (DONE || DISMISSED || EXPIRED)` → `newStatus = wasTerminal ? "OPEN"`, и `doneAt/dismisssedAt` обнуляются (repository.ts:159-164, 188-190). outcomeLocked срабатывает только для DONE с outcome и expiresAt (только риск-исходы). dismiss/done-роуты просто ставят статус (dismiss 29-35, done 28-34) без какого-либо «подавления». Движок запускается каждые 15 минут (scheduler.ts:27) и вызывает upsertAction для всех ещё срабатывающих сигналов. Текст диалога: «Задача исчезнет из списка открытых. Администратор сможет вернуть её при необходимости.» (ru.json:5138). Та же логика воскрешает VISIT_FOLLOW_UP_DUE при повторном бридже заметки (visit-note-handout.ts:637 upsertAction после правки заметки в 24ч-окне) и PATIENT_NO_CHANNEL при следующем пропущенном напоминании того же дня.

АС-09 Р2 · СРЕДНИЙ баг

«Перезвонить позже» и «Хочет прийти позже» не всплывают в назначенный день; запись пациента при этом остаётся в расписании

ГДЕ

src/app/api/crm/actions/[id]/outcome/route.ts:99, src/server/actions/engine.ts:139, src/server/actions/repository.ts:248, src/app/api/crm/action-center/risk-today/route.ts:171, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:98

СЦЕНАРИЙ

Пациент по записи на сегодня 16:00 говорит «хочу прийти 10 октября». Регистратор выбирает «Хочет прийти позже», дата 10.10. Строка исчезает. Сегодняшняя запись остаётся BOOKED, в 16:00 пациент не приходит → NO_SHOW (портит его историю и будущий риск). 10 октября никакого напоминания позвонить нет.

ПОСЛЕДСТВИЯ

Пациенты, желающие перезаписаться, теряются; слоты занимают впусую; растёт статистика no-show; функция из утверждённого ТЗ не работает.

ЧТО СДЕЛАТЬ

RETURN_LATER: отменять/освобождать текущую запись (с причиной) или предлагать перенос, и создавать отдельную задачу (например, тип RETURN_CALLBACK с expiresAt после callbackAt), не зависящую от времени исходного приёма. CALLBACK после времени приёма — аналогично. expireStaleActions не должен экспайрить строки со snoozeUntil в будущем. Основной список должен показывать SNOOZED с истёкшим таймером.

КРИТЕРИЙ ПРИЁМКИ

«Хочет прийти позже» на 10.10 → текущая запись отменена/освобождена, 10.10 в Центре действий появляется задача «перезвонить: хотел вернуться» с заметкой. «Перезвонить» на завтра 11:00 для сегодняшней записи → завтра в 11:00 задача видна.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CALLBACK/RETURN_LATER только ставят status=SNOOZED, snoozeUntil=callbackAt (outcome route:99-106); запись не отменяется и не переносится. Возврат строки невозможен: (1) NO_SHOW_RISK_HIGH имеет expiresAt = время приёма (engine.ts:139-143), и expireStaleActions экспайрит SNOOZED-строки по expiresAt<=now (repository.ts:248-256) — сразу после сегодняшнего приёма; (2) UNCONFIRMED_24H после прохождения времени приёма перестаёт детектироваться (date>=now) и через 48ч по TTL становится EXPIRED; (3) риск-лист показывает только записи сегодняшнего дня (risk-today route:171-175), а основной список — только OPEN (action-center-client.tsx:98-101), так что SNOOZED с истёкшим таймером там не видна. TZ-risk-outcomes §1 обещает «вернётся в callbackAt» / «всплывёт как хотел вернуться».

АС-10 Р2 · СРЕДНИЙ баг

«Перенести» фиксирует исход RESCHEDULED и закрывает строку ещё до того, как запись перенесена

ГДЕ

src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:443, src/app/api/crm/actions/[id]/outcome/route.ts:92, src/server/actions/repository.ts:154

СЦЕНАРИЙ

Регистратор жмёт «Перенести», открывается список записей, её отвлекли звонком, вкладку закрыла. Запись осталась на сегодня 15:00, в «Обработано сегодня» висит «Перенести», строка из риск-листа ушла и до 15:00 не вернётся.

ПОСЛЕДСТВИЯ

Ложная отметка о переносе, запись с риском неявки выпадает из контроля.

ЧТО СДЕЛАТЬ

Записывать outcome=RESCHEDULED только после успешного сохранения новой даты (callback из диалога переноса или серверная связка: PATCH даты записи закрывает связанные Action с outcome=RESCHEDULED).

КРИТЕРИЙ ПРИЁМКИ

Нажать «Перенести» и закрыть диалог без сохранения → строка остаётся в риск-листе, outcome не записан. Сохранить новую дату → строка уходит, в «Обработано» исход «Перенести».

ДОКАЗАТЕЛЬСТВО В КОДЕ

onOutcome сначала отправляет outcome=RESCHEDULED (DONE) для всех actionIds, и только потом делает router.push на /crm/appointments?ap=... (risk-today-section.tsx:411-447). Outcome-роут для RESCHEDULED просто ставит DONE+doneAt (route:92-98). Для NO_SHOW_RISK_HIGH (expiresAt = время приёма) outcomeLocked блокирует воскрешение до времени приёма (repository.ts:154-158). TZ-risk-outcomes §5: «Перенести открывает reschedule-диалог; на успехе постит outcome=RESCHEDULED».

АС-11 Р2 · СРЕДНИЙ баг

«Свободный слот завтра» и «потери» считаются для врача в отпуске: детектор игнорирует DoctorTimeOff и сроки действия расписания

ГДЕ

src/server/actions/detectors/empty-slot-tomorrow.ts:101, src/server/actions/detectors/empty-slot-tomorrow.ts:118

СЦЕНАРИЙ

Врач в отпуске завтра, в расписании обычная пятница 09:00–18:00. Центр действий: «Свободный слот завтра в 09:00 — Dr. Каримов, возможные потери 2 700 000 сум». Ресепшн обзванивает пациентов, чтобы записать к

отсутствующему врачу.

ПОСЛЕДСТВИЯ

Запись пациентов к врачу, которого не будет; завышенные «потери».

ЧТО СДЕЛАТЬ

Вычитать интервалы DoctorTimeOff и учитывать validFrom/validTo расписания так же, как в low-doctor-schedule / validateBooking.

КРИТЕРИЙ ПРИЁМКИ

Врач с отпуском на завтра не даёт EMPTY_SLOT_TOMORROW; расписание с validTo в прошлом не учитывается. Юнит-тест детектора.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Детектор читает doctorSchedule по weekday и isActive (empty-slot-tomorrow.ts:101-113) и appointment (118-125), но не запрашивает doctorTimeOff и не проверяет validFrom/validTo (в отличие от low-doctor-schedule.ts, где они учитываются). Итоговый estimatedRevenueLossUzs = средний чек × часы (246) попадает в KPI «Свободные слоты», «Потери сегодня» и AI-рекомендацию.

АС-12 P2 · СРЕДНИЙ безопасность

Выключатель AI действует только на интерфейс: AI-эндпоинты живы, NL-ассистент отправляет ФИО пациентов во внешний LLM без редактирования, без ключа отдаёт заглушки как ответ

ГДЕ

src/lib/ai-enabled.ts:11, src/app/api/crm/ai/ask/route.ts:32, src/server/ai/tool-loop.ts:131, src/server/ai/tools/find-patient.ts:92, src/server/ai/tools/get-appointments-today.ts:110, src/server/ai/llm.ts:249

СЦЕНАРИЙ

Любой сотрудник с ролью NURSE может вызвать POST /api/crm/ai/ask «найди Каримову» — при настроенном ключе имя и данные пациента уходят в Anthropic без маскировки, хотя AI официально «на паузе». Без ключа — ответы-заглушки и расход дневного лимита LLMUsage.

ПОСЛЕДСТВИЯ

Неконтролируемая передача персональных медицинских данных внешнему провайдеру в период, когда функция считается выключенной; мусорные ответы.

ЧТО СДЕЛАТЬ

Серверный флаг (env) проверять в callLLM/transcribe и во всех /api/crm/ai/* и summary-роутах (503 при выключенном AI). В tool-loop собирать knownNames из данных инструментов (имена пациентов/врачей из результатов) до передачи в LLM. В production запретить mock-фолбэк.

КРИТЕРИЙ ПРИЁМКИ

При выключенном AI все /api/crm/ai/* возвращают 503 и не создают LLMUsage. Тест: ответ инструмента с ФИО после redaction не содержит ФИО в запросе к провайдеру.

ДОКАЗАТЕЛЬСТВО В КОДЕ

AI_ENABLED используется только в клиентских компонентах (grep: ни одного серверного использования). /api/crm/ai/ask (поли ADMIN/DOCTOR/RECEPTIONIST/NURSE), clarifying-questions, build-conclusion, icd10-suggest, marketing-copy, patients/[id]/summary остаются доступными. Tool-loop передаёт `knownNames: []` (tool-loop.ts:131), хотя результаты инструментов, которые возвращаются в LLM как текст, содержат ФИО: find-patient «Первый: \${fullName}» (find-patient.ts:92-99), get-appointments-today «Ближайшая: \${patientName} → \${doctorName}» (110-117); редактор без списка имён вырезает только телефоны/паспорта/email (redact.ts заголовок). Контракт llm.ts: «pass [] only if you really have no names». Без ключа resolveProvider молча включает mock (llm.ts:249-265), и эндпоинты возвращают «[mock-llm: mock] ...» как настоящий ответ.

АС-13 P2 · СРЕДНИЙ целостность данных

Голос→SOAP работает в проде при выключенном AI: без ключей пишет в медицинский случай фейковый текст «Пациент жалуется на головную боль», с ключами — в последний открытый случай врача, не обязательно того пациента

ГДЕ

src/app/api/telegram/webhook/[clinicSlug]/route.ts:393, src/server/telegram/voice-handler.ts:92, src/server/ai/transcribe.ts:184, src/server/ai/llm.ts:255, src/server/ai/llm.ts:431, src/server/ai/soap.ts:230, src/server/workers/voice-soap.ts:144, src/lib/ai-enabled.ts:11, src/server/telegram/voice-handler.ts:86, src/server/telegram/voice-handler.ts:152, src/server/workers/voice-soap.ts:142

ТАКЖЕ НАШЛИ ЗОНЫ

Telegram-бот, переписки, рассылки, уведомления, воркеры

СЦЕНАРИЙ

Невролог, у которого привязан Telegram, надиктовывает голосовое боту клиники. Бот отвечает «Получил, расшифровываю...». В медицинский случай последнего пациента, которого он открывал, записывается «### Subjective [mock-llm: mock] Расшифровка: [mock-transcript ru ~40s] Пац...», затирая прежний черновик. Если ключи будут добавлены — реальная диктовка о пациенте А ляжет в случай пациента Б.

ПОСЛЕДСТВИЯ

Выдуманные/чужие клинические данные в медицинской документации пациента, потеря реального черновика, попадание в выгрузку по запросу пациента.

ЧТО СДЕЛАТЬ

Гейтить весь голосовой пайплайн серверным флагом (AI выключен → бот отвечает, что функция недоступна, job не ставится). Запретить mock-провайдеры в production (NODE_ENV=production без ключа → явная ошибка, а не заглушка). Не перезаписывать непустой soapDraft без подтверждения. Выбор случая — по текущему активному приёму врача (IN_PROGRESS appointment → ero medicalCaseId), а не по updatedAt.

КРИТЕРИЙ ПРИЁМКИ

При AI выключенном голосовое от врача не создаёт job и не меняет soapDraft. В production без ключа transcribe/callLLM бросают ошибку, запись в БД не происходит. Голосовое во время приёма пациента А пишет только в случай пациента А.

ДОКАЗАТЕЛЬСТВО В КОДЕ

AI_ENABLED=false (ai-enabled.ts:11) гасит только UI; TG-вебхук без проверок вызывает handleDoctorVoice для любого voice/audio от врача (webhook route:389-417), worker зарегистрирован всегда (workers/start.ts:81). Без OPENAI_API_KEY transcribe падает в mock и возвращает «[mock-transcript ru ~Ns] Пациент жалуется на головную боль.» (transcribe.ts:136-151, 175-186). Без ANTHROPIC_API_KEY callLLM падает в mock: текст `[mock-llm: mock] <первые 50 символов>` (llm.ts:249-265, 427-434). parseSoapSections не находит заголовков → `subjective: raw.trim()` (soap.ts:227-236), raw непустой → worker перезаписывает MedicalCase.soapDraft (voice-soap.ts:125-145, «we always overwrite»). Ключей нет ни в .env.example, ни в docker-compose. Случай выбирается как последний обновлённый OPEN-кейс врача (voice-handler.ts:81-96 `orderBy: { updatedAt: "desc" }`), а не пациент на приёме. Карточка SOAP в UI обёрнута в InDevelopment (inert), врач не видит, что туда записано; soapDraft попадает в DSAR-выгрузку (data-export.ts:349-356).

АС-14 Р2 · СРЕДНИЙ мёртвая механика

Кнопки-переходы из Центра действий ведут на несуществующие страницы (404) или теряют контекст пациента

ГДЕ

src/lib/actions/types.ts:375, src/lib/actions/types.ts:383, src/app/[locale]/crm/action-center/_component s/action-center-client.tsx:1176, src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:39 7, src/app/[locale]/crm/action-center/_components/risk-today-section.tsx:395, src/app/[locale]/crm/call-c enter/_hooks/use-active-call.ts:19, src/app/[locale]/crm/action-center/_components/action-center-client.t sx:298, src/server/ai/tools/search-actions.ts:124

СЦЕНАРИЙ

Админ жмёт «Перезвонить» на «Каримов: задолженность» → 404. «Открыть запись» в риск-листе → 404. «Звонок» → пустой колл-центр, номер надо искать заново. «Перезвонить» на низкой оценке → перезагрузка той же страницы.

ПОСЛЕДСТВИЯ

Основные СТА не выполняют действие, ресепшн теряет время и доверие к экрану.

ЧТО СДЕЛАТЬ

Для каждого типа формировать deeplink с идентификатором сущности: PAYMENT_OVERDUE → карточка пациента/вкладка оплат или /crm/appointments?ap=<id>; CASE_REPEAT_DUE → /crm/cases/<caseId>; UNCONFIRMED/NO_SHOW → /crm/appointments?ap=<id>; LOW_NPS → /crm/patients/<id>. «Открыть запись» → /crm/appointments?ap=<id>. Колл-центр должен принимать patientId/phone и открывать карточку звонка. Удалить или реализовать параметры intent/compose; убрать ссылку на online-requests или создать страницу.

КРИТЕРИЙ ПРИЁМКИ

Ни одна ссылка из Центра действий/риск-листа/KPI не даёт 404 (е2е-проверка всех href). «Звонок» открывает колл-центр с выбранным пациентом и номером. «Перезвонить» по долгу открывает конкретного пациента/запись.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Страниц нет: `src/app/[locale]/crm/payments/page.tsx`, `crm/online-requests/page.tsx`, `crm/cases/page.tsx` (есть только cases/[id]), `crm/appointments/[id]` (проверено find; редиректов в proxy/next.config нет). При этом: PAYMENT_OVERDUE → '/crm/payments' (types.ts:383), CASE_REPEAT_DUE → '/crm/cases' (375, движок не переопределяет), «Пропущенные заявки» → '/crm/online-requests' (client:1176), «Открыть запись» в риск-листе → '/crm/appointments/\${id}` (risk-today-section.tsx:397, 687). Кнопка «Звонок» в риск-листе передаёт patientId/phone в колл-центр (395), но колл-центр читает только `active` (use-active-call.ts:18-19). Параметры intent=unconfirmed/fill-slots/missed-calls и compose=telegram (client:298,309,1018-1034,1091,1164) нигде не читаются. LOW_NPS_RECEIVED ведёт на сам Центр действий (types.ts:386-389). UNCONFIRMED_24H/NO_SHOW → общий список записей без id. KPI «Риск пропуска» ведёт на bucket=no_show — уже неявившихся. focus=<id> из AI-инструмента (search-actions.ts:124) страница не читает.

АС-15 Р2 · СРЕДНИЙ мокап / заглушка

Мокапы на экране Центра действий: «Среднее время ответа», «Загрузка врачей», «Потери сегодня» и AI-рекомендации показывают выдуманные или подменённые цифры

ГДЕ

src/app/api/crm/actions/sla/route.ts:31, src/app/api/crm/actions/sla/route.ts:47, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1243, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1239, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1161, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:996, src/messages/ru.json:5400

СЦЕНАРИЙ

Директор видит «Среднее время ответа 0 мин 42 сек» и считает, что ресепшн отвечает мгновенно. «Dr. Алиева — Перегружен 125%» при 20 записях, из которых 6 отменены. «Потери сегодня» включают свободные слоты на завтра.

ПОСЛЕДСТВИЯ

Управленческие решения по фиктивным метрикам.

ЧТО СДЕЛАТЬ

SLA: считать реальное время ответа (например, от входящего сообщения/заявки до первого ответа оператора) или убрать плитку; не показывать строки каналов без данных. «Загрузка врачей»: ёмкость из DoctorSchedule на сегодня, исключить CANCELLED/NO_SHOW, показывать всех врачей или с пагинацией. «Потери сегодня»: не смешивать завтрашние слоты или переименовать. AI-блок: убрать выдуманные проценты/пороги, не подставлять случайного врача.

КРИТЕРИЙ ПРИЁМКИ

Плитка времени ответа либо удалена, либо совпадает с ручным расчётом по журналу диалогов. Загрузка врача = записи без отменённых / часы по расписанию. В интерфейсе нет цифр без источника в данных.

ДОКАЗАТЕЛЬСТВО В КОДЕ

«Среднее время ответа» = среднее (sentAt – scheduledFor) по NotificationSend (sla/route.ts:27-49) — это задержка планировщика рассылок, а не время ответа клиники пациенту; строки «Отзывы» (EMAIL) и «Звонки» (CALL) берутся из NotificationSend, куда никто не пишет каналы EMAIL/CALL (grep: нет создания NotificationSend с этими каналами) → всегда «—»; отрицательные дельты не суммируются, но входят в знаменатель (47). «Загрузка врачей»: `const capacity = 16` захардкожено (client:1243), берутся только первые 5 врачей (1239), считаются все записи дня включая CANCELLED/NO_SHOW (1240; /api/crm/appointments без фильтра статуса). «Потери сегодня» включает «Пустые слоты» из EMPTY_SLOT_TOMORROW — это завтрашние слоты (1161). AI-рекомендации (затемнены, но видны): «Заполните свободные слоты у {doctorName}» подставляет перегруженного или просто первого врача (996-999) с суммой по всем врачам; тексты «Быстрый ответ увеличивает конверсию на 35%», «без записи более 60 дней» (ru.json:5400-5402) — выдуманная статистика и порог 60 вместо фактических 90 дней. KPI «Неподтверждённые» показывает зелёное «+X сум» с подписью «потенциальная потеря» (client:294 + KpiCard).

АС-16 Р2 · СРЕДНИЙ баг

Операторы колл-центра и медсёстры видят «Нет приоритетных действий»: API Центра действий отвечает им 403, ошибка глотается, виджет подтверждений в колл-центре скрывается

ГДЕ

src/app/api/crm/actions/route.ts:40, src/app/api/crm/action-center/risk-today/route.ts:158, src/app/api/crm/actions/[id]/snooze/route.ts:23, src/components/layout/crm-sidebar.tsx:83, src/app/[locale]/crm/call-center/_components/unconfirmed-widget.tsx:67, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:98

СЦЕНАРИЙ

Оператор колл-центра открывает Центр действий — «Нет приоритетных действий», риск-лист «Не удалось загрузить». В колл-центре блока «К подтверждению» нет. Оператор думает, что звонить некому.

ПОСЛЕДСТВИЯ

Роль, для которой задуман обзвон, не получает задач; ложное «всё под контролем».

ЧТО СДЕЛАТЬ

Добавить CALL_OPERATOR (и при необходимости NURSE) в роли GET /actions, risk-today, snooze/outcome/mark-contacted либо скрыть пункт меню и виджет для ролей без доступа. В клиентах показывать состояние ошибки/нет доступа вместо пустого списка.

КРИТЕРИЙ ПРИЁМКИ

Под CALL_OPERATOR Центр действий показывает задачи и риск-лист; виджет «К подтверждению» виден. При искусственном 500 от API на экране явная ошибка, а не «нет задач».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роли: список задач ['ADMIN','RECEPTIONIST','DOCTOR'] (actions/route.ts:40), risk-today то же (route:158), snooze ['ADMIN','RECEPTIONIST'] (snooze:23). Пункт меню «Центр действий» без requiredRole (crm-sidebar.tsx:83), CRM-лейаут отсекает только DOCTOR. Клиент берёт `{ rows, isLoading }` и игнорирует error (action-center-client.tsx:98) → при 403 показывается «Нет приоритетных действий». UnconfirmedWidget: `if (isLoading && rows.length === 0) return null` (unconfirmed-widget.tsx:67-70) — при 403 виджет просто исчезает у CALL_OPERATOR, чья работа как раз подтверждения.

АС-17 Р2 · СРЕДНИЙ целостность данных

Решённые проблемы висят до 48 часов: оплаченный визит остаётся «задолженностью», отменённая запись — «не подтверждена», занятый слот — «свободен завтра»

ГДЕ

src/server/actions/engine.ts:106, src/server/actions/repository.ts:99, src/server/actions/repository.ts:248, src/server/actions/config.ts:57, src/server/actions/detectors/payment-overdue.ts:40, src/server/actions/detectors/unconfirmed-24h.ts:26, src/server/appointments/cancel.ts:119, src/app/api/crm/payments/route.ts:138

СЦЕНАРИЙ

Пациент закончил приём в 10:00, в 10:07 тик движка создаёт «Каримов: задолженность 300 000 сум». В 10:10 он платит в кассе. До 10:07 послезавтра карточка висит в «Оплаты», админ звонит пациенту требовать уже оплаченные деньги. Пациент отменил запись в Telegram — 2 дня висит «запись не подтверждена», ресепшн звонит отменившему. Слот на завтра заняли — KPI «Свободные слоты» и «потенциальная выручка» продолжают его считать.

ПОСЛЕДСТВИЯ

Ложные долги и лишние звонки пациентам (репутационный ущерб), завышенные KPI «потери/выручка», недоверие к экрану.

ЧТО СДЕЛАТЬ

Для каждого детектора ввести явное закрытие при исчезновении сигнала: в конце runActionEngine для типов, которые движок пересчитывает целиком, переводить в DONE/EXPIRED все OPEN/SNOOZED строки этого типа, чьих dedupeKey нет в текущем выводе (с учётом outcome-lock). Дополнительно: закрывать PAYMENT_OVERDUE при создании PAID-платежа, закрывать UNCONFIRMED_24H/NO_SHOW_RISK_HIGH в cancelAppointment и при переносе. EMPTY_SLOT_TOMORROW: expiresAt = slotStart. UNCONFIRMED_24H: expiresAt = appointmentAt.

КРИТЕРИЙ ПРИЁМКИ

Создать неоплаченный COMPLETED визит → после тика появилась задача; провести оплату → задача закрыта

сразу (или на ближайшем тике). Отменить запись → её UNCONFIRMED/NO_SHOW задачи закрыты. Слот, занятый записью, пропадает из «Свободные слоты» на ближайшем тике. Интеграционный тест engine: сигнал исчез → строка не OPEN.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Только NO_SHOW_RISK_HIGH, DOCTOR_OVERLOAD, IDLE_ROOM имеют expiresAtFor (engine.ts:139-143, 156, 161). Для остальных upsertAction пишет expiresAt=null (repository.ts:99). Когда сигнал пропадает, детектор просто перестаёт эмитить строку, никто её не закрывает, и она живёт OPEN до TTL `updatedAt <= now-48h` (repository.ts:248-256). Заккрытие есть только в confirmAppointment для UNCONFIRMED_24H (confirm.ts closeOpenConfirmActions); cancelAppointment (cancel.ts:119-200) и создание платежа (payments/route.ts:138+) Action не трогают. PAYMENT_OVERDUE срабатывает уже через 0 дней (config.ts:57 `paymentOverdueMinDays: 0`, payment-overdue.ts:38-55), т.е. на любой только что завершённый неоплаченный визит. unconfirmed-24h.ts:26-28 прямо полагается на «48h updatedAt sweep covers stragglers». EMPTY_SLOT_TOMORROW после полуночи продолжает показываться с текстом «Свободный слот завтра» для уже сегодняшних/занятых слотов. KPI и «Потери сегодня» (action-center-client.tsx bucketActions) суммируют эти устаревшие строки.

АС-18 P2 · СРЕДНИЙ баг

Список задач и брифинг ресепшн показывают не самые срочные, а самые новые задачи (обрезка до 50/5/30 по createdAt); KPI считаются по урезанной выборке

ГДЕ

src/app/api/crm/actions/route.ts:103, src/app/api/crm/actions/route.ts:117, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:98, src/app/[locale]/crm/reception/_components/action-briefing.tsx:17, src/app/[locale]/crm/call-center/_hooks/use-unconfirmed.ts:31

СЦЕНАРИЙ

В клинике 120 открытых задач (много PAYMENT_OVERDUE по старым визитам + неподтверждённые на 3 дня). Критичный долг 30+ дней, созданный неделю назад, и неподтверждённая запись через 1 час не попадают ни в Центр действий, ни в брифинг; наверху — свежие «low» задачи на послезавтра. KPI «Неподтверждённые» показывает не все записи.

ПОСЛЕДСТВИЯ

Самые срочные задачи не видны; цифры KPI занижены.

ЧТО СДЕЛАТЬ

Сортировать в SQL по рангу severity (CASE или числовая колонка severityRank) + createdAt, курсор по этой паре. Для колл-центра сортировать по appointmentAt (payload или отдельная колонка dueAt). В Центре действий либо подгружать все страницы, либо считать KPI отдельным агрегирующим эндпоинтом (groupBy по type/severity).

КРИТЕРИЙ ПРИЁМКИ

При 200 открытых задачах первая страница содержит все critical раньше high. Брифинг показывает 5 задач с наивысшим severity. Виджет подтверждений всегда содержит запись, до которой меньше 2 часов. KPI равны агрегату по всей таблице.

ДОКАЗАТЕЛЬСТВО В КОДЕ

API берёт `orderBy: [{createdAt:'desc'}, {id:'desc'}]`, take: limit+1` (route.ts:103-108) и только потом сортирует по severity внутри страницы (117-125), хотя шапка файла обещает сортировку severity DESC. Клиент Центра действий берёт одну страницу limit=50 и не вызывает loadMore (action-center-client.tsx:98-101, loadMore/hasMore не используются). Брифинг ресепшн: комментарий «top 5 slot we fetch is guaranteed to be the highest-severity open work» (action-briefing.tsx:17-22), а по факту это 5 новейших. Виджет «К подтверждению» в колл-центре берёт 30 новейших (use-unconfirmed.ts:31-40): при горизонте 72ч раньше всех созданы строки по ближайшим приёмам — именно они и отрезаются. KPI-плитки, «Потери сегодня» и AI-блоки считаются по этим 50 строкам.

АС-19 P2 · СРЕДНИЙ безопасность

Эндпоинт исхода звонка позволяет врачу отменять и подтверждать любые записи клиники, не проверяет тип задачи и игнорирует результат доменной операции

ГДЕ

src/app/api/crm/actions/[id]/outcome/route.ts:39, src/app/api/crm/actions/[id]/outcome/route.ts:79, src/app/api/crm/actions/[id]/outcome/route.ts:121, src/app/api/crm/appointments/[id]/route.ts:915, src/app/[locale]/crm/action-center/_hooks/use-risk-today.ts:139, src/server/notifications/default-templates.ts:117

СЦЕНАРИЙ

Врач (UI ему Центр действий не показывает, но API доступен) отправляет POST /api/crm/actions/<id>/outcome

{outcome:'REFUSED', note:'x'} по задаче чужого пациента — запись коллеги отменяется, пациенту приходит сообщение об отмене. Регистратор жмёт «Подтвердил» по записи, которую пациент только что отменил в Telegram — тост «Исход записан: Подтвердил», запись остаётся отменённой.

ПОСЛЕДСТВИЯ

Обход ролевой модели на отмену записей, недостоверные исходы в отчётах, дублирующиеся события, некорректное сообщение пациенту.

ЧТО СДЕЛАТЬ

Убрать DOCTOR из ролей outcome (или ограничить его своими записями). Разрешать outcome только для типов NO_SHOW_RISK_HIGH/UNCONFIRMED_24H. Проверять canTransitionAt и результат доменной функции; при ok:false возвращать 409 и не менять Action. Выполнять доменное действие и обновление всех Action по appointmentId в одной транзакции одним запросом (сервер закрывает все связанные open Action). Для REFUSED использовать вариант уведомления «по инициативе пациента».

КРИТЕРИЙ ПРИЁМКИ

Вызов outcome REFUSED под ролью DOCTOR → 403. REFUSED на задаче PATIENT_NO_CHANNEL → 400. «Подтвердил» по отменённой записи → 409, Action остаётся OPEN. Строка с двумя Action → один запрос, один audit APPOINTMENT_CANCELLED. Пациенту уходит текст «вы отменили запись», а не извинения клиники.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роли outcome: ['ADMIN','RECEPTIONIST','DOCTOR'] (route:39), при REFUSED вызывается cancelAppointment по payload.appointmentId любой задачи (route:49-50, 79-91). Штатная отмена DELETE /appointments/[id] разрешена только ADMIN/RECEPTIONIST (appointments/[id]/route.ts:915) и проходит через canTransitionAt. Тип Action не проверяется: REFUSED на PATIENT_NO_CHANNEL или LOW_NPS тоже вызывает отмену по их appointmentId. Результат confirmAppointment/cancelAppointment ({ok:false,...}) не проверяется — Action всё равно DONE с outcome CONFIRMED/REFUSED (route:66-91, 121). Доменное действие и update Action не в одной транзакции (TZ §4 требует одну). Клиент шлёт исход параллельно на каждый actionId (use-risk-today.ts:139-154) → две параллельные отмены/подтверждения одной записи (двойной аудит и outbox-события). Пациенту при «Отказался» уходит шаблон «приём отменён... Извините за неудобство» от клиники (default-templates.ts:111-117), хотя отказался сам пациент.

АС-20 РЗ · НИЗКИЙ баг

LOW_DOCTOR_SCHEDULE считает день недели и часы смен в UTC вокруг ташкентской полуночи — вычитание отпусков смещено

ГДЕ

src/server/actions/detectors/low-doctor-schedule.ts:129, src/server/actions/detectors/low-doctor-schedule.ts:141

СЦЕНАРИЙ

Врач в отпуске со среды по пятницу: вычитается не тот набор часов, задача «мало слотов» появляется или не появляется неверно.

ПОСЛЕДСТВИЯ

Неточные задачи для админа по расписанию.

ЧТО СДЕЛАТЬ

Строить интервалы смен через tashkentComponents/toTashkentDate, как в empty-slot-tomorrow.

КРИТЕРИЙ ПРИЁМКИ

Тест: отпуск на конкретные ташкентские дни вычитает ровно часы смен этих дней.

ДОКАЗАТЕЛЬСТВО В КОДЕ

windowStart = начало клинического дня = 19:00Z предыдущих суток (low-doctor-schedule.ts:52). `weekday = dayStart.getUTCDay()` (129) даёт день недели предыдущих суток, `start.setUTCHours(s.h, s.m)` (141-143) ставит смену в UTC-часах предыдущей даты, т.е. интервал смещён на -1 день +5 часов относительно реального. Сумма часов за 7 дней случайно совпадает (цикл по всем дням недели), но пересечение с DoctorTimeOff и границы validFrom/validTo считаются по неверным интервалам.

OVERDUE_FOLLOW_UP работает наоборот (показывает визиты 1–7 дней назад и исчезает, когда follow-up реально просрочен) и не называет пациента

ГДЕ

src/server/actions/detectors/overdue-follow-up.ts:35, src/server/actions/config.ts:32, src/lib/actions/types.ts:133, src/messages/ru.json:5197, src/lib/actions/types.ts:377

СЦЕНАРИЙ

Админ видит десяток одинаковых карточек «Follow-up не выполнен 3 дней» без фамилий, кнопка ведёт на общий список записей. Через неделю, когда follow-up действительно просрочен, карточка исчезает.

ПОСЛЕДСТВИЯ

Задача неисполнима и логически инвертирована — follow-up пациентов не контролируется.

ЧТО СДЕЛАТЬ

Окно: визиты старше followUpStaleDays (lt: now – staleDays) с разумной нижней границей. Добавить patientName в payload, deeplink на карточку пациента/запись. Исправить склонение в i18n (plural).

КРИТЕРИЙ ПРИЁМКИ

Визит 10 дней назад в открытом случае без последующей записи даёт задачу с ФИО пациента и ссылкой на него; визит 3 дня назад — не даёт. Текст «10 дней»/«3 дня» склоняется правильно.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Конфиг: «OVERDUE_FOLLOW_UP fires when the visit completed at least this many days ago» (config.ts:32-33, followUpStaleDays: 7). Детектор: `upper = now-1d; lower = now-7d; date: { gte: lower, lt: upper }` (overdue-follow-up.ts:35-41) — ловит визиты 1–7 дней назад и перестаёт на 7-й день. Payload содержит только appointmentId/patientId/daysSinceVisit, без имени (types.ts:133-138); заголовок «Follow-up не выполнен {daysSinceVisit} дней» (ru.json:5197), deeplink — общий '/crm/appointments' (types.ts:377).

«Обработано сегодня» в риск-листе завышено: учитываются исходы прошлых дней и записи не на сегодня

ГДЕ

src/app/api/crm/action-center/risk-today/route.ts:279, src/server/actions/repository.ts:177

СЦЕНАРИЙ

В понедельник отметили «Не дозвонился» по записи на среду. Во вторник прогресс «Обработано 5 из 12» включает этот понедельничный звонок с понедельничным исполнителем.

ПОСЛЕДСТВИЯ

Неверная отчётность о проделанной работе за день.

ЧТО СДЕЛАТЬ

Хранить время фиксации исхода (resolvedAt) и фильтровать по нему; учитывать только записи текущего клинического дня; в upsertAction не делать update, если ничего не изменилось.

КРИТЕРИЙ ПРИЁМКИ

Исход, записанный вчера, не отображается в «Обработано сегодня». Прогресс = исходы, записанные сегодня по сегодняшним записям.

ДОКАЗАТЕЛЬСТВО В КОДЕ

resolvedToday = outcome != null && (doneAt >= dayStart || (status==='SNOOZED' && updatedAt >= dayStart)) (risk-today route:279-282), по всем Action типов риска, без фильтра по appointmentId из сегодняшнего списка. upsertAction при каждом тике делает prisma.action.update даже без изменений (repository.ts:177-193), и @updatedAt сдвигается. Поэтому SNOOZED-строка с исходом, записанным вчера (например, NO_ANSWER/CALLBACK по записи на послезавтра — горизонт 72ч), каждый день снова попадает в «Обработано сегодня», а totals.total = open + handled смешивает дни.

Глобальный поиск: пациенты возвращаются без сортировки (случайные 5 из совпадений), поиск стартует с 1 символа и делает ILIKE по заметкам всех записей

ГДЕ

src/app/api/crm/search/route.ts:49, src/app/api/crm/search/route.ts:84, src/components/layout/global-search.tsx:268

СЦЕНАРИЙ

Регистратор ищет «Каримов» — в выдаче 5 случайных Каримовых, нужного (с записью сегодня) нет. Ввод одной буквы запускает 4 полнотабличных ILIKE.

ПОСЛЕДСТВИЯ

Не находится нужный пациент; лишняя нагрузка на БД при росте базы.

ЧТО СДЕЛАТЬ

Сортировать пациентов по lastVisitAt/точности совпадения, минимальная длина запроса 2–3 символа, trigram-индексы или ограничить поиск по заметкам недавним периодом.

КРИТЕРИЙ ПРИЁМКИ

Поиск «Каримов» стабильно возвращает первыми недавних пациентов; 1 символ не отправляет запрос.

ДОКАЗАТЕЛЬСТВО В КОДЕ

patient.findMany с OR по fullName/phone и `take: 5` без orderBy (search/route.ts:49-64) — при распространённой фамилии возвращается произвольная пятёрка, «показать ещё» нет. Запросы по appointment.notes/comments и conversation.lastMessageText через contains/insensitive без индекса (84-121). Клиент шлёт запрос с 1 символа (global-search.tsx:268) с дебаунсом 200 мс.

Нет экрана истории задач: вкладки «Отложенные/Отклонённые/Сделано», «Вернуть в работу» и диалог причины отклонения не подключены

ГДЕ

src/app/[locale]/crm/action-center/_components/action-card.tsx:233, src/app/[locale]/crm/action-center/_components/dismiss-dialog.tsx:1, src/app/[locale]/crm/action-center/_hooks/use-actions.ts:285, src/messages/ru.json:5138

СЦЕНАРИЙ

Регистратор по ошибке отклонил задачу — админу негде её найти и вернуть; причина отклонения не собирается.

ПОСЛЕДСТВИЯ

Нет аудита и отката действий в UI.

ЧТО СДЕЛАТЬ

Добавить вкладки статусов с кнопкой «Вернуть в работу» (ADMIN) и запрашивать причину при отклонении, либо убрать мёртвый код и обещание из текста.

КРИТЕРИЙ ПРИЁМКИ

Админ видит отклонённые/сделанные задачи и возвращает любую в OPEN; причина отклонения сохраняется в audit.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ActionCard с showReopen и полным вариантом (DismissDialog с полем причины, SnoozePopover, «Вернуть в работу») нигде не рендерится: единственный потребитель — брифинг ресепшн в compact-варианте (grep по импортам). useReopenAction не вызывается нигде, кроме action-card. i18n содержит tabs OPEN/SNOOZED/DISMISSED/DONE и loadMore, но UI вкладок нет. Основное меню «…» отклоняет без причины (action-center-client.tsx:891). Диалог обещает «Администратор сможет вернуть её» (ru.json:5138).

Ошибки детекторов и действия пользователей не видны: сбойный детектор тихо перестаёт создавать задачи, чужие закрытия не приходят по SSE

ГДЕ

src/server/actions/scheduler.ts:77, src/app/api/crm/actions/[id]/done/route.ts:36, src/app/[locale]/crm/action-center/_hooks/use-actions.ts:129

СЦЕНАРИЙ

После миграции один детектор падает с ошибкой Prisma — неделями нет задач этого типа, в логе только «errors=1». Два регистратора звонят одному и тому же пациенту.

ПОСЛЕДСТВИЯ

Скрытые отказы функциональности, дублирующая работа.

ЧТО СДЕЛАТЬ

Логировать тип и текст ошибки каждого детектора (и алертить); публиковать action.updated из пользовательских роутов (publishEventSafe).

КРИТЕРИЙ ПРИЁМКИ

При искусственной ошибке детектора в логе воркера есть тип и сообщение. Закрытие задачи на одном экране отражается на втором без перезагрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Tick суммирует только количество ошибок (`totalErrors += res.errors.length`, scheduler.ts:77) и логирует счётчик (83-85); тексты ошибок детекторов (engine.ts:190-193) в фоне теряются. Роуты done/dismiss/snooze/outcome пишут audit, но не публикуют action.updated, а список задач не имеет refetchInterval (use-actions.ts:129-141, staleTime 15s) — у второго регистратора закрытая коллегой задача висит до смены фокуса окна или следующего события движка.

Прогноз времени приёма для табло/киоска: общая выборка истории на всех врачей, у менее загруженных врачей подставляется дефолт

ГДЕ

src/server/ai/per-visit-eta.ts:33, src/server/ai/per-visit-eta.ts:42, src/server/appointments/queue-projection.ts:128

СЦЕНАРИЙ

В клинике 5 врачей, один принимает по 25 пациентов в день. Бюджет 150 строк целиком уходит на него; у невролога с 6 приёмами в день прогноз «~30 мин» вместо реальных 50, пациенты в очереди видят заниженное ожидание.

ПОСЛЕДСТВИЯ

Неверное ожидаемое время на табло и в талоне пациента.

ЧТО СДЕЛАТЬ

Брать историю по каждому врачу отдельно (window-функция ROW_NUMBER() OVER (PARTITION BY doctorId) или N запросов с take:30), ограничить давностью.

КРИТЕРИЙ ПРИЁМКИ

Тест: при 150 свежих визитах врача А и 20 визитах врача В прогноз В строится по его 20 визитам (confidence high/med), а не по fallback.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Один запрос по всем doctorIds: `orderBy: { completedAt: 'desc' }, take: doctorIds.length * 30`` (per-visit-eta.ts:33-43), затем раскладка по врачам с лимитом 30 на врача. Если один врач за последние дни завершил больше визитов, он забирает весь бюджет, а у остальных < 4 выборов → predictETA возвращает fallback с confidence 'low' (eta-predictor.ts:83-88). Используется в живой очереди (queue-projection.ts:128) — табло, киоск, талон пациента — независимо от AI-флага.

Уникальный INN препарата глобален для всех клиник: клиника не может добавить свой препарат, если такой же INN завела другая клиника; удалённый препарат нельзя ни вернуть, ни создать заново

ГДЕ

prisma/schema.prisma:948, src/app/api/crm/knowledge/drugs/route.ts:45, src/app/api/crm/knowledge/drugs/route.ts:77, src/app/api/crm/knowledge/drugs/[id]/route.ts:93

СЦЕНАРИЙ

Клиника В пытается добавить местный препарат «Citicoline» — 409 «INN занят, переопределите глобальный», но глобального нет (его завела клиника А). Админ клиники А по ошибке удалил свой препарат — ни в списке, ни пересоздать.

ПОСЛЕДСТВИЯ

Межклиническая коллизия и утечка факта существования данных другой клиники; невозможность исправить ошибку удаления.

ЧТО СДЕЛАТЬ

Уникальность (clinicId, inn) с отдельной уникальностью для глобальных (partial unique index WHERE clinicId IS NULL). В настройках показывать неактивные собственные строки с кнопкой «Восстановить» (для препаратов, гайдов, памяток).

КРИТЕРИЙ ПРИЁМКИ

Две клиники могут создать локальный препарат с одинаковым INN. Удалённый локальный препарат виден в настройках как неактивный и восстанавливается одной кнопкой.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`inn String @unique` (schema.prisma:948) при том что Drug кросс-тенантный (clinicId null для глобальных, иначе клиника; Drug в MODELS_WITHOUT_TENANT). POST создаёт строку с clinicId и при P2002 отвечает 409 inn_taken с указанием «переопределить глобальный» (drugs/route.ts:45-80), хотя конфликтующая строка может принадлежать другой клинике и быть ей невидима. DELETE — мягкое active=false (drugs/[id]/route.ts:93); список в настройках идёт через /api/crm/catalogs/drugs с фильтром `active: q.active ?? true`, так что удалённый препарат пропадает из UI, а создать заново нельзя — INN занят. Аналогично гайды/памятки: /api/crm/guides фильтрует active:true, восстановить удалённое через UI нельзя.

Эскалация после 3 недозвонов живёт до 15 минут: движок перезаписывает severity

ГДЕ

src/app/api/crm/actions/[id]/outcome/route.ts:114, src/server/actions/engine.ts:132, src/server/actions/repository.ts:182

СЦЕНАРИЙ

Третий раз не дозвонились — задача становится «Высокий», через ≤15 минут снова «Средний».

ПОСЛЕДСТВИЯ

Эскалация фактически не работает.

ЧТО СДЕЛАТЬ

В upsertAction брать max(severity детектора, эскалированная severity) при callAttempts>=MAX или хранить escalatedSeverity отдельно.

КРИТЕРИЙ ПРИЁМКИ

После 3 NO_ANSWER severity остаётся high после нескольких тиков движка.

ДОКАЗАТЕЛЬСТВО В КОДЕ

NO_ANSWER при callAttempts>=3 ставит severity='high' (outcome route:114-116). На ближайшем тике upsertAction записывает severity из детектора (engine.ts:132-137 severityForNoShowRisk → medium при risk<0.8; для UNCONFIRMED — по часам) в `data.severity` (repository.ts:177-182). TZ-risk-outcomes §1 требует эскалацию после N попыток.

SEC · Аутентификация, мультитенантность, безопасность, платформа

SEC-01 P0 · КРИТИЧНО безопасность

Анонимные «киосочные» API доступны из интернета: ФИО и записи пациента по номеру телефона, создание и отметка прибытия в живой очереди без какой-либо аутентификации

ГДЕ

src/app/api/c/[slug]/queue/lookup/route.ts:42, src/app/api/c/[slug]/queue/lookup/route.ts:81, src/app/api/kiosk/checkin/route.ts:99, src/app/api/c/[slug]/queue/walkin/route.ts:29, src/app/api/c/[slug]/queue/checkin/route.ts:27, src/server/clinic-public/resolve.ts:9, src/server/appointments/walkin.ts:272, src/app/api/c/[slug]/queue/lookup/route.ts:40, src/server/clinic-public/resolve.ts:41, src/proxy.ts:270, src/app/api/c/[slug]/queue/walkin/route.ts:20, src/app/api/c/[slug]/queue/walkin/route.ts:59, src/server/appointments/walkin.ts:106, src/server/appointments/walkin.ts:124, src/lib/phone.ts:13, src/app/api/kiosk/checkin/route.ts:10, src/app/api/kiosk/checkin/route.ts:22, src/app/api/kiosk/checkin/route.ts:98, src/lib/rate-limit.ts:1, nginx/nginx.conf:165, src/app/api/c/[slug]/queue/lookup/route.ts:41, src/app/api/c/[slug]/queue/lookup/route.ts:82, src/server/appointments/walkin.ts:111, src/server/clinic-public/resolve.ts:10, src/app/api/kiosk/checkin/route.ts:12, nginx/nginx.conf:123, src/app/api/c/[slug]/queue/checkin/route.ts:125, src/app/api/c/[slug]/queue/board/route.ts:95, src/app/api/c/[slug]/queue/walkin/route.ts:42, src/server/clinic-public/resolve.ts:7

ТАКЖЕ НАШЛИ ЗОНЫ

Живая очередь, киоск, ТВ-табло, талоны, Записи, календарь, ресепшн, слоты, цены визита, Мини-апп пациента и публичные страницы клиники

СЦЕНАРИЙ

Посторонний через curl вводит номер соседа или коллеги и получает его ФИО и то, что тот сегодня записан к неврологу/детскому неврологу, к какому врачу и во сколько; скриптом прогоняет диапазон номеров. Шутник шлёт сотню POST на /walkin с реальными телефонами: у врача в живой очереди и на ТВ-табло появляются «пациенты», которых нет; или «отмечает прибытие» всех записанных, и ресепшн видит ложное «ждёт с 09:02».

ПОСЛЕДСТВИЯ

Утечка факта обращения к неврологу вместе с ФИО (чувствительные медданные), срыв живой очереди и табло, засорение базы пациентов фейковыми карточками.

ЧТО СДЕЛАТЬ

Ввести аутентификацию устройства киоска: токен, выдаваемый в CRM (по аналогии с Doctor.tvToken) и хранимый на планшете, обязателен для /api/c/[slug]/queue/{lookup,walkin,checkin} и /api/kiosk/*. Ответ lookup/kiosk сократить до инициалов и времени (как /api/queue/status). Rate limit по реальному IP (X-Real-IP от nginx) и по токenu устройства; при возможности ограничить эти пути IP клиники в nginx.

КРИТЕРИЙ ПРИЁМКИ

POST /api/c/neurofax/queue/lookup без токена киоска → 401; с токеном ответ не содержит полного ФИО и телефона; 20 запросов подряд с разными X-Forwarded-For режутся лимитом; walkin/checkin без токена → 401.

ДОКАЗАТЕЛЬСТВО В КОДЕ

resolve.ts:8-10 прямо формулирует модель доверия «physically present at the clinic: the slug is the bearer», но slug 'neurofax' публичен (лендинг, мини-апп), а nginx (nginx/nginx.conf, location /) не ограничивает /api/c/ по IP. lookup/route.ts: POST без сессии, без токена устройства и БЕЗ rateLimit; по любому телефону возвращает patient { id, fullName, phone, preferredLang } (стр.42, 81) и сегодняшние записи с врачом и специализацией. kiosk/checkin GET: то же, плюс записи на 7 дней вперёд (стр.99 — fullName, phone), лимит 10/мин по первому значению X-Forwarded-For, который задаёт клиент. walkin POST: без аутентификации создаёт пациента и WALKIN-запись в живой очереди; для существующего телефона возвращает его полное ФИО (walkin.ts:272). queue/checkin POST: любую сегодняшнюю запись (appointmentId берётся из ответа lookup) переводит BOOKED→WAITING и выдаёт талон.

SEC-02 P1 · ВЫСОКИЙ безопасность

POST /api/crm/auth/totp-required — анонимный оракул пароля без лимита, позволяющий перебор в обход ограничения на вход

ГДЕ

src/app/api/crm/auth/totp-required/route.ts:66, src/app/api/crm/auth/totp-required/route.ts:70, src/app/api/crm/auth/totp-required/route.ts:94, src/app/api/auth/[...nextauth]/route.ts:37, src/app/login/page.tsx:40

СЦЕНАРИЙ

Злоумышленник берёт фамилии врачей с публичной страницы /doctors, строит логины вида фамилия@neurofax.uz, по времени ответа выясняет, какие существуют, затем перебирает словарь паролей через этот эндпоинт с неограниченной скоростью. Найденный пароль сразу даёт вход в кабинет врача (2FA на проде, по заметкам эксплуатации, отключена через DISABLE_2FA).

ПОСЛЕДСТВИЯ

Подбор паролей персонала, включая ADMIN, и доступ к медкартам.

ЧТО СДЕЛАТЬ

Повесить на эндпоинт общий с входом лимит неудачных попыток по IP (исправленному, см. находку про X-Forwarded-For) и по email (например 5 неудач за 15 мин → блок), считая неудачи вместе с /api/auth/callback/credentials. Выравнивать время: для несуществующего пользователя выполнять bcrypt.compare с фиктивным хэшем. Лучше отказаться от отдельного pre-flight и сигнализировать «нужен второй фактор» из authorize через кастомный код CredentialsSignin.

КРИТЕРИЙ ПРИЁМКИ

6-я неверная попытка для одного email за 15 минут → 429 и на totp-required, и на signIn; время ответа для несуществующего и существующего email с неверным паролем совпадает в пределах ±20%.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Лимит 5/мин повешен только на POST /api/auth/* ([...nextauth]/route.ts:37). totp-required — отдельный анонимный роут без rateLimit: делает bcrypt.compare и отвечает 401 при неверном пароле и 200 {requiresTotp} при верном (стр.66-94). Для несуществующего email отвечает сразу без bcrypt (стр.66) — по времени ответа видно, существует ли логин. 200 подтверждает пароль даже у пользователей с включённой 2FA. Логин-форма сама вызывает его первым (login/page.tsx:40).

SEC-03 P1 · ВЫСОКИЙ безопасность

Rate-limit по подменяемому X-Forwarded-For: злоумышленник обходит лимит, а клиника за одним IP блокируется; при 429 вход зависает, а «Выйти» молча не разлогинивает

ГДЕ

src/lib/rate-limit.ts:1, src/app/api/auth/[...nextauth]/route.ts:19, src/app/api/leads/route.ts:82, src/app/api/kiosk/checkin/route.ts:10, nginx/nginx.conf:165, src/app/login/page.tsx:81, src/lib/audit.ts:19, src/lib/rate-limit.ts:8

ТАКЖЕ НАШЛИ ЗОНЫ

Публичный лендинг, запись с сайта, SEO

СЦЕНАРИЙ

Утром 6 сотрудников (ресепшн, врачи) входят с одного офисного IP в течение минуты — у шестого вечное «Входим...». Вечером администратор на общем ПК ресепшна нажимает «Выйти» в момент исчерпанного лимита, видит форму входа и уходит; следующий человек открывает /crm и работает под её учёткой. Злоумышленник же добавляет случайный X-Forwarded-For к каждому запросу и перебирает пароли без ограничений, а миллионом уникальных заголовков (до 8 КБ на запрос к /api/leads) раздувает память Node до OOM — CRM падает. IP в аудит-журнале тоже подделывается тем же заголовком.

ПОСЛЕДСТВИЯ

Блокировка входа персонала, ложный выход на общем ПК (доступ к медданным под чужим именем), лимиты не защищают от брутфорса, возможен DoS процесса, недостоверный IP в аудите.

ЧТО СДЕЛАТЬ

Брать IP из X-Real-IP, который nginx выставляет из \$remote_addr (или последний элемент XFF); в nginx можно перезаписывать X-Forwarded-For на \$remote_addr. Перенести лимитер в Redis (уже есть для BullMQ) с TTL либо чистить Map. Лимитировать неудачные попытки входа по email+IP, а не все POST на /api/auth (signin и обновление сессии не лимитировать). В login и 2FA-формах обернуть signIn в try/catch и показывать «Слишком много попыток, подождите минуту».

КРИТЕРИЙ ПРИЁМКИ

Запрос с подменённым X-Forwarded-For попадает в тот же бакет, что и без него; 10 успешных входов с одного IP за минуту проходят; 6 неудачных для одного email → понятное сообщение и разблокированная кнопка; signOut никогда не получает 429; память процесса не растёт при 100k уникальных XFF.

ДОКАЗАТЕЛЬСТВО В КОДЕ

nginx ставит 'X-Forwarded-For \$proxy_add_x_forwarded_for' (nginx.conf:165), то есть значение клиента сохраняется ПЕРВЫМ; все лимитеры и аудит берут xff.split(',')[0] ([...nextauth]/route.ts:19-26, kiosk/checkin:10-14, pin.ts, audit.ts:19-23), а leads/route.ts:82 — весь заголовок целиком. Ключ лимита задаёт клиент. rate-limit.ts хранит ключи в Map без удаления — каждый новый ключ живёт до рестарта процесса. Лимит /api/auth — 5 POST в минуту на IP, туда попадают вход (callback/credentials), выход (signout) и обновление сессии. При 429 next-auth/react signIn делает new URL(data.url) от undefined и бросает исключение; в login/page.tsx:81-86 нет try/catch, setPending(false) не вызывается, кнопка «Входим...» (стр.138) заблокирована навсегда. signOut при 429 берёт data.url ?? redirectTo и уводит на /login, но ответ 429 не очищает cookie сессии.

SEC-04 P1 · ВЫСОКИЙ безопасность

В сид-скриптах, рассчитанных на прод, защиты известные пароли: SUPER_ADMIN «super», ADMIN 1@1.uz/«1», реальные врачи NeuroFax — «doctor»

ГДЕ

prisma/seed.ts:234, prisma/seed.ts:242, prisma/seed.ts:363, scripts/seed-neurofax-real.ts:245, scripts/seed-neurofax-real.ts:321, scripts/upsert-dev-admin.ts:14, src/lib/auth.ts:98

СЦЕНАРИЙ

Любой, кто видел репозиторий или просто угадал, вводит на neurofax.uz/login super@neurofax.uz / super и получает SUPER_ADMIN, затем «входит в клинику» и видит всех пациентов. Или busakov@neurofax.uz / doctor — кабинет врача со всеми заключениями. Если кто-то повторно прогонит seed-neurofax-real.ts (например, чтобы обновить услуги), пароли всех 7 врачей молча сбросятся обратно на «doctor».

ПОСЛЕДСТВИЯ

Полный захват аккаунтов и утечка медицинских данных всех пациентов неврологической клиники; SUPER_ADMIN даёт доступ ко всем клиникам платформы.

ЧТО СДЕЛАТЬ

Срочно: на проде проверить скриптом всех активных пользователей против списка известных паролей и сменить/деактивировать совпавшие (super@, admin@, recept@, 1@1.uz, врачи из seed-neurofax-real). В коде: убрать литеральные пароли из сидов (генерация/ENV, вывод один раз, mustChangePassword:true), в ветке update upsert не трогать passwordHash; сиды с учётками должны отказываться работать при NODE_ENV=production без явного флага; добавить ops-скрипт аудита «нет пользователей с паролями из списка известных».

КРИТЕРИЙ ПРИЁМКИ

Проверочный скрипт по всем активным пользователям прода против ['super','admin','doctor','recept','1'] находит 0 совпадений; grep по prisma/ и scripts/ не находит bcrypt.hash со строковым литералом; повторный прогон seed-neurofax-real.ts не меняет passwordHash существующих пользователей.

ДОКАЗАТЕЛЬСТВО В КОДЕ

prisma/seed.ts:234-238 хэширует литералы 'super','admin','doctor','recept','1'. :242-255 upsert SUPER_ADMIN super@neurofax.uz с паролем 'super', причём ветка update ПЕРЕЗАПИСЫВАЕТ passwordHash при каждом прогоне. :363-379 ADMIN 1@1.uz с паролем '1' и mustChangePassword:false; там же admin@neurofax.uz/'admin', recept@neurofax.uz/'recept'. scripts/seed-neurofax-real.ts назван «the real production line-up» (7 боевых врачей: busakov@, tyncherova@, muhitdinova@, rahmanova@, sultanov@, israilova@, vazirova@neurofax.uz, стр.93-222), требует, чтобы prisma/seed.ts уже был прогнан на этой же БД, и делает `bcrypt.hash("doctor", 10)` (стр.245) + upsert User с этим паролем и в create, и в update (стр.321-336), mustChangePassword не ставится (default false). scripts/upsert-dev-admin.ts:14 снова создаёт 1@1.uz/'1'. Нигде нет защиты от запуска на проде и нет проверки известных хэшей; authorize (auth.ts:98-104) пускает любого active-пользователя с верным паролем, а 2FA глушится env DISABLE_2FA (auth.ts:111) — по заметкам эксплуатации на проде он включён.

SEC-05 P1 · ВЫСОКИЙ безопасность

Деактивированный, пониженный в роли или перенесённый в другую клинику сотрудник сохраняет прежний доступ до 24 часов

ГДЕ

src/lib/auth.ts:182, src/lib/auth.ts:224, src/app/api/crm/users/[id]/route.ts:155, src/app/api/platform/users/[id]/route.ts:85, src/app/api/events/route.ts:83, src/app/[locale]/crm/me/change-password/_components/change-password-client.tsx:54, src/app/api/crm/users/[id]/route.ts:154, src/app/api/crm/users/[id]/reset-password/route.ts:47, src/lib/auth.ts:56, src/lib/api-handler.ts:156, src/proxy.ts:270

ТАКЖЕ НАШЛИ ЗОНЫ

Настройки клиники, пользователи, филиалы, кабинеты, права

СЦЕНАРИЙ

Администратор увольняет ресепшаниста и в 10:00 деактивирует аккаунт. Уволенный с домашнего ноутбука до 24 часов продолжает открывать /crm/patients, выгружать данные и в реальном времени видеть чат пациентов. Сотрудник, пониженный из ADMIN в RECEPTIONIST, ещё сутки может сбрасывать пароли и менять настройки клиники.

ПОСЛЕДСТВИЯ

Утечка медданных через бывших сотрудников; процедура отзыва доступа не работает.

ЧТО СДЕЛАТЬ

В createApiHandler/createApiListHandler, /api/events и прокси сверять с БД (кэш 30–60 с) active, role и clinicId пользователя; при расхождении — 401 и очистка cookie. При деактивации/смене роли/переносе удалять все UserSession пользователя и ставить sessionsRevokedAt, отвергая JWT с более ранним iat. Исправить обновление сессии (передавать csrfToken или обновлять на сервере через unstable_update).

КРИТЕРИЙ ПРИЁМКИ

После деактивации любой следующий API-запрос пользователя → 401 не позже чем через 60 с, SSE-поток закрывается; после понижения роли ADMIN-эндпоинты отвечают 403 без перелога.

ДОКАЗАТЕЛЬСТВО В КОДЕ

role, clinicId и mustChangePassword записываются в JWT только при входе (auth.ts:182-185); active проверяется только в authorize (стр.98) и в ветке trigger==='update' (стр.224-240). Единственный вызов обновления — POST /api/auth/session с телом {} без csrfToken (change-password-client.tsx:54-58); Auth.js для POST action 'session' вызывает validateCSRF и бросает MissingCSRF (@auth/core lib/index.js), поэтому ветка никогда не исполняется. DELETE /api/crm/users/[id] (стр.155-161) ставит active:false, но не удаляет UserSession и не инвалидирует JWT; PATCH роли — тоже. Прокси и api-handler берут role/clinicId из JWT и не проверяют user.active. SSE /api/events (стр.76-83) держит поток до часа без перепроверки пользователя и без проверки обязательной 2FA. Перенос пользователя в другую клинику (platform/users/[id]:85) не меняет clinicId в уже выданном JWT.

SEC-06 P1 · ВЫСОКИЙ безопасность

Контроль сессий (idle-таймаут, 8-часовая ротация, «одна сессия на пользователя») фактически не работает, а активных сотрудников выкидывает на логин

ГДЕ

src/proxy.ts:157, src/proxy.ts:167, src/proxy.ts:209, src/proxy.ts:269, src/server/auth/user-session.ts:27, src/server/auth/session-security.ts:18, src/app/[locale]/doctor/layout.tsx:25

СЦЕНАРИЙ

Ресепшн отошла от ПК на час; idle-таймаут «сработал», но любой, кто нажмёт «Назад» или откроет закладку /crm, попадает в CRM под её учёткой без пароля. Врач вошёл на втором ПК — «кик» первого ПК на кабинет врача не влияет вовсе. При этом ресепшн, 30+ минут работающую на одном экране очереди (данные обновляются опросом и SSE), при следующем клике по меню выкидывает на логин посреди приёма.

ПОСЛЕДСТВИЯ

Настройка клиники «Таймаут неактивности» и политика одной сессии не защищают от доступа с оставленного ПК, но мешают работе активным пользователям.

ЧТО СДЕЛАТЬ

Отсутствие cookie при наличии JWT трактовать как недействительную сессию. При кике гасить и JWT-cookie next-auth. Проверку UserSession вынести в общую функцию и вызывать в createApiHandler/createApiListHandler, /api/events и layout кабинета врача (или расширить прокси на /doctor). lastActivityAt бампить из API-обёртки с троттлингом раз в минуту. maxAge cookie сделать больше окна ротации (например 24h). signOut → удалять строку UserSession.

КРИТЕРИЙ ПРИЁМКИ

После idle-кика повторный заход на /crm и /ru/doctor и вызов /api/crm/patients требуют входа (редирект/401); через 8ч+1мин после входа любой запрос требует повторного входа; пользователь, 40 минут работающий на странице очереди без навигации, не выкидывается; после входа на втором устройстве API-запросы с первого → 401.

ДОКАЗАТЕЛЬСТВО В КОДЕ

(1) proxy.ts:157-161 — если cookie crm_user_session ОТСУТСТВУЕТ, запрос пропускается («legacy one-time pass»), причём проверка не одноразовая. (2) При кике (idle/forced/expired) прокси обнуляет только crm_user_session (стр.167-173) и удаляет строку UserSession, JWT next-auth остаётся валидным — следующий заход на /crm идёт без cookie и пропускается по п.1. (3) Cookie выдаётся с maxAge 8h (user-session.ts:27) — ровно FORCED_REROTATE_MS (session-security.ts:18); браузер удаляет её раньше, чем сработала бы ротация, и 8-часовой потолок не срабатывает никогда, реальный срок — 24h JWT (auth.ts:56). (4) matcher (proxy.ts:269-272) исключает /api, а проверка идёт только для CRM_PATH (/crm) — API, SSE /api/events и весь кабинет врача /ru/doctor UserSession не проверяют (doctor/layout.tsx проверяет лишь auth()). (5) lastActivityAt бампится только при навигации по /crm-страницам (стр.209-218), не при API-вызовах. (6) signOut не удаляет строку UserSession; хелперы findSessionByCookie/bumpSessionActivity/deleteUserSession/clearSessionCookie из user-session.ts нигде не вызываются.

SEC-07 P1 · ВЫСОКИЙ безопасность

Пароль меняется без знания текущего при mustChangePassword, а сброс/смена пароля не отзывают активные сессии — сброс не вытесняет злоумышленника

ГДЕ

src/app/api/crm/me/password/route.ts:53, src/app/api/crm/users/[id]/reset-password/route.ts:49, src/app/api/platform/clinics/[id]/reset-owner-password/route.ts:49

СЦЕНАРИЙ

Админ подозревает утечку пароля врача и жмёт «Сбросить пароль». Злоумышленник с уже открытой сессией продолжает работать (JWT до 24 ч) и, более того, отправляет POST /api/crm/me/password {newPassword} без старого пароля — ставит свой и забирает аккаунт насовсем. Так же любой, кто подошёл к незаблокированному ПК врача (у которого флаг висит всегда), меняет ему пароль одним запросом.

ПОСЛЕДСТВИЯ

Захват учёток персонала; сброс пароля не помогает вытеснить нарушителя.

ЧТО СДЕЛАТЬ

Требовать currentPassword всегда, кроме сессии, выпущенной входом по временному паролю и не старше N минут (флаг в JWT/UserSession). При смене и сбросе пароля удалять все UserSession пользователя, ставить passwordChangedAt и отвергать JWT с iat раньше него.

КРИТЕРИЙ ПРИЁМКИ

POST /api/crm/me/password без currentPassword от сессии, выпущенной до сброса, → 400/401; после сброса пароля админом старая сессия пользователя получает 401 на первом же запросе.

ДОКАЗАТЕЛЬСТВО В КОДЕ

me/password пропускает проверку currentPassword, если user.mustChangePassword=true (стр.53). Флаг ставится при создании пользователя с паролем и при каждом сбросе (reset-password:49, reset-owner-password:49), а у врачей он никогда не снимается (см. находку про кабинет врача). Ни сброс, ни смена пароля не удаляют UserSession и не инвалидируют JWT — в этих роутах нет ни userSession.deleteMany, ни отметки времени отрыва.

SEC-08 P2 · СРЕДНИЙ безопасность

SUPER_ADMIN не обязан иметь 2FA для /admin, /api/platform и /api/admin, а для impersonation проверка 2FA пропускается

ГДЕ

src/app/admin/layout.tsx:30, src/server/platform/handler.ts:58, src/lib/api-handler.ts:220, src/server/auth/security-policy.ts:16, src/proxy.ts:269

СЦЕНАРИЙ

Пароль суперадмина утёк или подобран — злоумышленник без второго фактора открывает /admin, делает «сброс пароля владельца» любой клиники, входит в клинику через switch-clinic в режиме WRITE и через API читает и меняет медданные: проверка 2FA для impersonation не срабатывает.

ПОСЛЕДСТВИЯ

Самая привилегированная межклиничная учётка защищена только паролем.

ЧТО СДЕЛАТЬ

Проверять `totpEnabledAt` `SUPER_ADMIN` в `admin/layout` (и страницах), в `createPlatformHandler/createPlatformListHandler`, во всех `requireSuper` в `/api/admin/*` и `/api/platform/*`, включая `switch-clinic`; для `impersonation` проверять 2FA самого суперадмина вместо пропуска.

КРИТЕРИЙ ПРИЁМКИ

`SUPER_ADMIN` без `totpEnabledAt` получает редирект на запись 2FA на `/admin` и 403 `MFA_REQUIRED` на `/api/platform/*`, `/api/admin/*` и `/api/platform/session/switch-clinic`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`security-policy.ts:16-19` объявляет `SUPER_ADMIN` ролью с обязательной 2FA, но прокси (`matcher` исключает `admin` и `api`) `/admin` не проверяет; `admin/layout.tsx:30` проверяет только роль; `requireSuperAdmin` (`handler.ts:58-68`) и `requireSuper` в `/api/admin/*` и `/api/platform/users/[id]` проверяют только роль. `enforceTotpEnrollment` (`api-handler.ts:220`) явно пропускает `impersonation` со ссылкой на «2FA на уровне `platform-login/grant`», которой в коде нет: `grep` по `totp/2fa` в `src/app/admin`, `src/server/platform`, `src/app/api/platform`, `src/app/api/admin` пуст.

SEC-09 P2 · СРЕДНИЙ целостность данных

Аудит-журнал хранит расшифрованные паспорт и заметки пациента, а при DSAR-удалении/анонимизации — полную личность пациента

ГДЕ

`src/app/api/crm/patients/[id]/route.ts:81`, `src/app/api/crm/patients/[id]/route.ts:136`, `src/server/dsar/anonymize.ts:95`, `src/server/workers/data-deletion.ts:158`, `src/server/workers/data-deletion.ts:175`, `src/app/api/crm/patients/route.ts:209`, `src/app/api/crm/patients/[id]/route.ts:82`, `src/app/api/crm/patients/[id]/route.ts:132`, `src/app/api/crm/cases/route.ts:124`

ТАКЖЕ НАШЛИ ЗОНЫ

Пациенты и медицинские случаи в CRM

СЦЕНАРИЙ

Пациент просит удалить его данные, клиника выполняет анонимизацию, но ФИО, телефон и паспорт остаются в «Настройки → Аудит» и видны любому ADMIN. При утечке дампа БД раскрываются все паспорта, несмотря на шифрование `Patient.passport`.

ПОСЛЕДСТВИЯ

Шифрование PII и «право на удаление» фактически фиктивны; утечка паспортных данных через ADMIN или дампы.

ЧТО СДЕЛАТЬ

Для шифруемых колонок писать в аудит только имена изменённых полей (или шифровать `meta` тем же `field-cipher`); `forensic`-снимок при DSAR хранить зашифрованным отдельным ключом с доступом только суперадмина либо не хранить; при анонимизации вычищать PII из прошлых записей аудита по `entityId`.

КРИТЕРИЙ ПРИЁМКИ

После PATCH паспорта в `AuditLog.meta` нет значения паспорта; после анонимизации поиск по ФИО и телефону пациента в `AuditLog.meta` ничего не находит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH пациента строит `diff` из `hydratePatientForRead(before/after)` (`patients/[id]/route.ts:81-95`), поэтому `passport` и `notes` попадают в `AuditLog.meta` открытым текстом; при удалении комментариев прямо говорит «the audit row should carry plaintext» (стр.136-138). DSAR `HARD_DELETE` и `ANONYMIZE` кладут `snapshotForensicFields` (ФИО, телефон, `telegramId`, расшифрованный паспорт; `anonymize.ts:95-117`) в `meta.before` (`data-deletion.ts:158-170`, `175`). `/api/crm/audit` возвращает `meta` администратору, UI выводит JSON.

SEC-10 P2 · СРЕДНИЙ мёртвая механика

Лимиты тарифов не применяются нигде; «Приостановить клинику» и `Clinic.active=false` не блокируют вход и работу персонала

ГДЕ

`src/server/billing/plan-limits.ts:184`, `src/server/platform/get-feature-flags.ts:54`, `src/app/api/admin/clinics/[id]/lifecycle/route.ts:94`, `src/lib/auth.ts:98`, `src/app/admin/clinics/_components/clinics-page-client.tsx:372`

СЦЕНАРИЙ

Суперадмин приостанавливает клинику за неоплату или выключает тумблер «активна» — персонал продолжает входить и принимать пациентов. Самозарегистрированная клиника на тарифе basic заводит тысячи пациентов, лимит 50 не срабатывает.

ПОСЛЕДСТВИЯ

Кнопки управления платформой вводят в заблуждение; блокировка тенанта и монетизация не работают.

ЧТО СДЕЛАТЬ

Вызывать `ensure*Limit` при создании пациентов и записей; в `authorize` и `api-handler` отказывать при `Clinic.active=false` (и, по решению продукта, при `CANCELLED`); переименовать «Приостановить» или описать фактическое поведение; ввести срок `grace-периода` для `PAST_DUE`.

КРИТЕРИЙ ПРИЁМКИ

При `Clinic.active=false` вход сотрудника клиники отклоняется; создание 51-го пациента на `basic` → понятная ошибка лимита.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`ensurePatientLimit/ensureAppointmentLimit/ensureQuotaForApi` (`plan-limits.ts:184-230`) нигде не вызываются (`grep` по `src` — только определения); `maxUsers/maxBranches` только отображаются в админке. «Приостановить» (`lifecycle/route.ts:94-110`, кнопка с подтверждением в `clinics-page-client.tsx:372-384`) лишь ставит `Subscription.status=CANCELLED`, а `getFeatureFlags` возвращает `DEFAULT_FLAGS` (скрывает `pro`-разделы). `authorize` проверяет только `user.active` (`auth.ts:98`); `Clinic.active` не проверяется ни в `auth`, ни в `проху`, ни в `api-handler`. `PAST_DUE` даёт полный набор функций бессрочно (`get-feature-flags.ts:54`) — перехода `PAST_DUE→CANCELLED` нет.

SEC-11 РЗ · НИЗКИЙ безопасность

Tenant-расширение пропускает любые неизвестные операции без скоупинга (fail-open), например `updateManyAndReturn`

ГДЕ

`src/lib/prisma.ts:285`, `src/lib/tenant-allowlist.ts:126`

СЦЕНАРИЙ

Разработчик пишет `prisma.appointment.updateManyAndReturn({ where: { status: 'BOOKED' }, ... })` в роуте ресепшна — обновлены записи всех клиник.

ПОСЛЕДСТВИЯ

Латентная межклиничная запись данных.

ЧТО СДЕЛАТЬ

Для моделей с `clinicId` в `TENANT`-контексте бросать ошибку на любой неподдержанной операции; добавить `updateManyAndReturn` в `MUTATE_BY_WHERE_OPERATIONS`.

КРИТЕРИЙ ПРИЁМКИ

Unit-тест: неизвестная операция на тенантной модели под `TENANT` → исключение; `updateManyAndReturn` получает `clinicId` в `where`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Если операция не входит в `READ_OPERATIONS/MUTATE_BY_WHERE_OPERATIONS/CREATE_OPERATIONS`, запрос уходит как есть (`prisma.ts:285`, «Any other operation — pass through»). В Prisma 7 есть `updateManyAndReturn`, которого нет в `MUTATE_BY_WHERE_OPERATIONS` (`tenant-allowlist.ts:126`). Сейчас не используется (`grep` пуст), дефект латентный.

SEC-12 РЗ · НИЗКИЙ безопасность

Подписанный cookie `tfa_pending` нигде не проверяется, а пароль на время 2FA хранится открытым текстом в `sessionStorage`

ГДЕ

`src/app/api/crm/auth/totp-required/route.ts:85`, `src/server/auth/totp-pending.ts:45`, `src/app/login/page.tsx:65`, `src/app/login/2fa/_components/two-fa-form.tsx:104`

СЦЕНАРИЙ

Сотрудник ввёл пароль на общем ПК, не довёл 2FA и ушёл — пароль лежит в `sessionStorage` вкладки; любой XSS на домене читает его.

ПОСЛЕДСТВИЯ

Лишняя поверхность для кражи пароля; мёртвый механизм создаёт ложное ощущение защиты.

ЧТО СДЕЛАТЬ

Хранить в `sessionStorage` только email; второй шаг принимать по `tfa_pending (userId + TTL)` без повторной передачи пароля — или удалить мёртвый cookie.

КРИТЕРИЙ ПРИЁМКИ

После первого шага `sessionStorage` не содержит пароля; второй шаг работает по `tfa_pending`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`totp-required` ставит подписанный cookie `tfa_pending` (стр.85), но `verifyPending` (`totp-pending.ts:45`) не вызывается нигде (`grep`). Вместо этого логин кладёт `{email, password}` открытым текстом в `sessionStorage` (`login/page.tsx:63-69`); 2FA-форма очищает его только при успешном входе (`two-fa-form.tsx:104`) — при уходе со страницы пароль остаётся во вкладке.

SEC-13 Р3 · НИЗКИЙ переводы

Редирект на `/${locale}/login` даёт 404 для узбекской локали

ГДЕ

`src/app/[locale]/doctor/layout.tsx:29`, `src/app/[locale]/crm/me/security/page.tsx:27`

СЦЕНАРИЙ

Врач с узбекским интерфейсом, у которого истекла сессия, открывает закладку `/uz/doctor` и видит 404 вместо формы входа.

ПОСЛЕДСТВИЯ

Непонятная ошибка вместо логина.

ЧТО СДЕЛАТЬ

Редиректить на `/login?callbackUrl=...` без префикса локали.

КРИТЕРИЙ ПРИЁМКИ

`/uz/doctor` без сессии открывает `/login`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Страница входа существует только как `src/app/login`; под `[locale]` маршрута `login` нет. `/ru/login` `next-intl (localePrefix 'as-needed', src/i18n/routing.ts)` переводит на `/login`, а `/uz/login` разрешается в `[locale]=uz/login` и отдаёт `not-found`. `doctor/layout.tsx:29` и `me/security/page.tsx:27` делают `redirect(`${locale}/login`)`.

SEC-14 Р3 · НИЗКИЙ безопасность

Страница `/admin/clinics/[id]/billing` полагается только на проверку в `layout`: рендерится с правами `SUPER_ADMIN` для любого пользователя и создаёт подписку при открытии

ГДЕ

`src/app/admin/clinics/[id]/billing/page.tsx:73`, `src/app/admin/clinics/[id]/billing/page.tsx:47`, `src/app/admin/layout.tsx:30`

СЦЕНАРИЙ

Ресепшенист открывает `/admin/clinics/<id>/billing` — видит «403», но в RSC-ответе приходят данные подписки и тарифов, а у клиники без подписки создаётся 30-дневный про-триал.

ПОСЛЕДСТВИЯ

Мелкая утечка платформенных данных и запись в БД от непривилегированного пользователя.

ЧТО СДЕЛАТЬ

Проверять `role === 'SUPER_ADMIN'` в самой `page.tsx` до загрузки данных; не создавать подписку на GET-рендере.

КРИТЕРИЙ ПРИЁМКИ

Открытие страницы не-суперадмином не создаёт `Subscription` и не отдаёт данные клиники в RSC-ответе.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`page.tsx` не проверяет роль: ``const userId = session?.user?.id ?? "anonymous" (стр.73)` и `runWithTenant({kind:'SUPER_ADMIN'}) → loadInitialState`, который при отсутствии подписки СОЗДАЁТ TRIAL на про (стр.47). `admin/layout.tsx:30` для не-SA возвращает экран 403, но в документации Next 16 (`node_modules/next/dist/docs/01-app/02-guides/authentication.md:1354`) сказано: `layout`, который прячет `children`, «does not stop them from running or from appearing in the RSC Payload».

LD · Публичный лендинг, запись с сайта, SEO

LD-01 P1 · ВЫСОКИЙ мёртвая механика

Заявки с сайта уходят в никуда: Lead пишется в БД, но ни один экран CRM его не читает и никто не получает уведомление

ГДЕ

src/app/api/leads/route.ts:137, src/app/api/leads/route.ts:152, src/app/api/leads/route.ts:31, src/lib/email.ts:23, src/lib/email.ts:39, src/components/sections/lead-form.tsx:185, src/app/api/crm/online-request/route.ts:35, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1176, scripts/seed-mega-neurofax.ts:175, src/components/sections/lead-form.tsx:172, src/app/api/leads/route.ts:138, src/app/api/leads/route.ts:36, src/app/api/crm/dashboard/route.ts:101

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Мама ребёнка вечером открывает neurofax.uz, жмёт «Записаться на приём», выбирает врача, дату, оставляет имя и телефон. Видит «Спасибо! Мы перезвоним в ближайшее время». Заявка лежит в таблице Lead, но ни ресепшн, ни call-центр, ни админ её не видят ни в одном экране, уведомления нет. Никто не перезванивает. Если владелец пересидит прод демо-данными, заявка вообще удаляется.

ПОСЛЕДСТВИЯ

Все онлайн-заявки с главного СТА сайта (hero, шапка, блок контактов, нижняя панель на телефоне, карточки врачей) теряются. Клиника теряет пациентов и деньги, пациенты получают ложное обещание перезвона и уходят к конкурентам.

ЧТО СДЕЛАТЬ

Довести флоу TZ §7.2 до конца: 1) экран «Заявки» в CRM для ADMIN/RECEPTIONIST/CALL_OPERATOR (список NEW сверху, смена статуса CONTACTED/CONVERTED/CANCELLED, кнопка «Конвертировать» → upsert Patient по нормализованному телефону + Appointment channel=WEBSITE), бейдж счётчика NEW в сайдбаре; 2) при создании Lead публиковать событие через publishEventSafe и/или создавать Action в action-center + Telegram-алерт в рабочий чат клиники, не полагаясь на SMTP; 3) решить судьбу дубля OnlineRequest (либо писать туда, либо удалить модель и чинить ссылку action-center на реальный экран); 4) убрать Lead из wipeOrder прод-сида или пометить сидовые лиды, чтобы реальные заявки не стирались и не смешивались с фейковыми номерами; 5) исправить ссылку в письме на реальный путь CRM.

КРИТЕРИЙ ПРИЁМКИ

Отправить заявку с сайта → в течение нескольких секунд у ресепшн/call-центра появляется уведомление и строка в экране «Заявки» со статусом NEW; кнопка конвертации создаёт пациента и запись; после прогона прод-сида реальные заявки остаются на месте; e2e-тест «форма → CRM-список» зелёный.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/leads (route.ts:137-150) создаёт строку prisma.lead.create(... source: "WEBSITE") и возвращает 201. Единственная реакция на новую заявку: sendNewLeadEmail (route.ts:153-162), и только если у выбранного врача есть email; внутри email.ts:23 `if (!process.env.SMTP\_USER) return;`, а SMTP_* нет ни в .env.example, ни в .env (проверено по именам переменных), то есть письмо молча не уходит. publishEventSafe/Telegram-алерта/Action нет (rg по lead.created/NEW_LEAD пуст). Чтение: GET /api/leads (route.ts:31-78) существует, но `rg "api/leads"` находит единственного вызывающего, саму форму lead-form.tsx:172 (POST). В src/app/[locale]/crm нет страницы заявок; ключи dashboard.leads/«Заявки» нигде не используются в .tsx. Параллельная модель OnlineRequest читается /api/crm/online-requests (route.ts:35), но её никто не создаёт (rg onlineRequest.create пуст), а ссылка action-center-client.tsx:1176 ведёт на /crm/online-requests, где страницы нет (ls: No such file). Ссылка в письме `https://neurofax.uz/ru/dashboard` (email.ts:39) ведёт в несуществующий маршрут. TZ §7.2 (docs/TZ.md:1937-1948) требует: уведомление всем CALL_OPERATOR, конвертацию Lead→Patient+Appointment; не реализовано. Вдобавок прод-ресид seed-mega-neurofax.ts удаляет таблицу Lead клиники (wipeOrder, строка 175, `DELETE FROM "Lead" WHERE "clinicId"`) и досыпает 40 фейковых лидов со случайными +998-номерами (строки 577-593).

LD-02 P1 · ВЫСОКИЙ безопасность

Хранимый XSS на публичной странице врача: имя/специальность из профиля врача вставляются в JSON-LD без экранирования </script>

ГДЕ

```
src/app/[locale]/(site)/doctors/[id]/page.tsx:87, src/app/[locale]/(site)/doctors/[id]/page.tsx:68, src/app/api/crm/doctors/me/profile/route.ts:35, src/app/api/crm/doctors/me/profile/route.ts:112, next.config.ts:22
```

СЦЕНАРИЙ

Учётка врача (скомпрометированная или недобросовестный сотрудник) в «Профиле» меняет специальность на `Невролог`</script><script>fetch('/api/crm/users',{method:'POST',...})</script>. Админ клиники открывает публичную страницу врача /doctors/<id>, чтобы проверить, как она выглядит. Скрипт от имени админа создаёт новую админ-учётку или выгружает список пациентов через /api/crm/*.

ПОСЛЕДСТВИЯ

Повышение прав от DOCTOR до ADMIN/SUPER_ADMIN и доступ ко всей медкарте клиники. Страница публичная и индексируется, так что скрипт получает и каждый посетитель сайта (подмена телефона клиники, фишинг).

ЧТО СДЕЛАТЬ

Сериализовать JSON-LD безопасно: после `JSON.stringify` заменять ``<`` на ``<`` (и ``>`` на ``>`` и ``/`` на ``/U+2028/U+2029``), вынести это в общий хелпер и применить во всех ``application/ld+json`` (`doctors/[id]/page.tsx`, `(site)/page.tsx`, `[locale]/layout.tsx`). Дополнительно ограничить имя и специальность врача разрешёнными символами (буквы, пробел, дефис, точка, скобки, апостроф) в схемах `profile PATCH` и `src/server/schemas/doctor.ts`. В перспективе перейти на `nonce-CSP` вместо `'unsafe-inline'`.

КРИТЕРИЙ ПРИЁМКИ

Врач сохраняет специальность со строкой `</script><script>alert(1)</script>` → API отвечает 400, либо (если записать напрямую в БД) страница `/doctors/<id>` показывает текст как есть, alert не срабатывает, в HTML внутри `Id+json` стоит `</script>`. Юнит-тест на хелпер сериализации.

ДОКАЗАТЕЛЬСТВО В КОДЕ

page.tsx:65-81 собирает jsonLd с `name: doctor.name[loc]` и `medicalSpecialty: doctor.specialty[loc]` (Doctor.nameRu/nameUz/specializationRu/specializationUz из БД) и выводит `

LD-03 Р2 · СРЕДНИЙ баг

canonical, hreflang и sitemap указывают на /ru-адреса, которые next-intl редиректит на корень; юридические страницы объявляют каноническим адресом главную

ГДЕ

```
src/app/[locale]/layout.tsx:28, src/app/[locale]/layout.tsx:36, src/app/[locale]/(site)/doctors/[id]/page
.tsx:41, src/app/sitemap.ts:11, src/i18n/routing.ts:16, src/app/[locale]/(site)/privacy/page.tsx:13
```

СЦЕНАРИЙ

Google заходит на <https://neurofax.uz/>, видит canonical на /ru, переходит по нему, получает 307 обратно на /. Sitemap отдаёт /ru и /ru/doctors/..., которые тоже редиректят. /privacy сообщает, что её каноническая версия это главная.

ПОСЛЕДСТВИЯ

Русская версия сайта (основная аудитория) индексируется плохо: «страница с перенаправлением», поисковик сам выбирает канонический адрес, страницы врачей хуже ранжируются. Клиника недополучает органический трафик.

ЧТО СДЕЛАТЬ

Строить абсолютные URL через хелпер next-intl (getPathname / createNavigation) с учётом as-needed: для ru без префикса, для uz с /uz. Применить в canonical, languages (+ x-default), openGraph.url и sitemap. privacy/terms задают свой canonical и languages.

КРИТЕРИЙ ПРИЁМКИ

HTML главной: canonical `https://neurofax.uz/`, hreflang `ru→https://neurofax.uz/`, `uz→https://neurofax.uz/uz`, x-default задан; /privacy указывает canonical на себя; ни один URL в sitemap.xml не отдаёт 3xx.

ДОКАЗАТЕЛЬСТВО В КОДЕ

routing.ts:16 ``localePrefix: "as-needed"```: русский отдаётся с корня. В next-intl 4.9 middleware (node_modules/next-intl/dist/esm/development/middleware/middleware.js:127-129) при ``hasMatchedDefaultLocale && isUnprefixedRouting`` запрос /ru... получает redirect на адрес без префикса (307). При этом canonical = ``https://${SITE_DOMAIN}/${locale}``, то есть `https://neurofax.uz/ru` (layout.tsx:28, 35), hreflang ``ru: "/ru"``` (стр. 36), у врача canonical ``https://neurofax.uz/ru/doctors/<id>`` (doctors/[id]/page.tsx:41-42, og url стр. 48), в sitemap ``${baseUrl}/${locale}`` (sitemap.ts:11, 20). privacy/terms в generateMetadata возвращают только title (privacy/page.tsx:13, terms/page.tsx:13), поэтому наследуют из layout canonical главной страницы и её hreflang. x-default не задан.

LD-04 P2 · СРЕДНИЙ баг · требует проверки на живых данных

privacy/terms с force-static замораживают список врачей в форме заявки (и год в футере) до следующего деплоя

ГДЕ

src/app/[locale]/(site)/privacy/page.tsx:4, src/app/[locale]/(site)/terms/page.tsx:4, src/app/[locale]/(site)/layout.tsx:10, src/app/[locale]/(site)/layout.tsx:17

СЦЕНАРИЙ

Админ активирует нового невролога. На главной он в форме есть, а на /privacy в диалоге «Записаться» его нет. После неудачного старта БД форма на /privacy и /terms вообще не отправляется.

ПОСЛЕДСТВИЯ

Мелкая рассинхронизация, иногда неработающая форма на юридических страницах.

ЧТО СДЕЛАТЬ

Убрать force-static с privacy/terms (или поставить revalidate, например 3600) либо вынести загрузку врачей в клиентский запрос при открытии диалога.

КРИТЕРИЙ ПРИЁМКИ

После активации врача он появляется в форме на /privacy без деплоя.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Layout группы (site) объявляет ``dynamic = "force-dynamic"``` и на каждый рендер вызывает getDoctors() для формы заявки в шапке (layout.tsx:10, 17-20). privacy/terms объявляют ``dynamic = "force-static"``` (стр. 4). Next берёт значение ближайшего сегмента (reduceAppConfig в node_modules/next/dist/build/utils.js:839-869: последний сегмент перезаписывает dynamic), поэтому страницы рендерятся один раз и кешируются без revalidate. Вместе с ними застывают список врачей в DoctorsProvider и ``new Date().getFullYear()``` футера. Если в момент первого рендера после деплоя БД была недоступна, getDoctors вернул [] и форма на этих страницах не отправляется до следующего деплоя (select врача required).

LD-05 P2 · СРЕДНИЙ баг

sitemap.xml кешируется на этапе сборки без БД и в проде никогда не содержит страниц врачей; lastModified всегда равен дате сборки

ГДЕ

src/app/sitemap.ts:6, src/app/sitemap.ts:8, src/lib/doctors.ts:80, src/app/[locale]/(site)/layout.tsx:7

СЦЕНАРИЙ

Владелец ожидает, что страницы врачей попадут в Google через sitemap. В прод-sitemap.xml их нет ни после одного деплоя, а /ru из sitemap ещё и редиректит.

ПОСЛЕДСТВИЯ

Страницы врачей находятся поисковиками только случайно, запросы вида «невролог <фамилия> Ташкент» не приводят на сайт.

ЧТО СДЕЛАТЬ

Сделать sitemap динамическим (``export const dynamic = "force-dynamic"``` или ``revalidate = 3600```), чтобы он строился в рантайме с БД; lastModified брать из Doctor.updatedAt, для главной из даты контента; URL строить по правилу из находки про canonical.

КРИТЕРИЙ ПРИЁМКИ

curl `https://neurofax.uz/sitemap.xml` в проде содержит /doctors/<id> и /uz/doctors/<id> для каждого врача,

выведенного на сайт; lastmod отличается у разных врачей; после добавления врача он появляется в sitemap без пересборки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

sitemap.ts не использует ни dynamic-конфиг, ни request-time API. По node_modules/next/dist/docs/01-app/03-api-reference/03-file-conventions/01-metadata/sitemap.md:44 такой sitemap «cached by default», то есть пререндерится при `next build`. Сборка идёт в Docker-builder без БД ((site)/layout.tsx:7-9: «inside the Docker builder where no database exists»), а getDoctors при ошибке возвращает [] (doctors.ts:80-83, 106-109, комментарий прямо говорит «sitemap.ts, which runs inside `next build` where no database exists, falls back to the base pages»). Итог: в прод-sitemap только /ru и /uz, а `lastModified: new Date()` (стр. 12, 21) застывает на момент сборки.

LD-06 P2 · СРЕДНИЙ баг

Календарь формы записи сохраняет дату на день раньше выбранной (toISOString в поясе UTC+5)

ГДЕ

src/components/sections/lead-form.tsx:78, src/components/sections/lead-form.tsx:79, src/app/api/leads/route.ts:132

СЦЕНАРИЙ

Пациент выбирает в календаре понедельник 28 сентября. В БД сохраняется 27 сентября (воскресенье), врачу в письме приходит «Дата: 2026-09-27». Администратор, перезванивая, предлагает неверный день или считает заявку ошибочной.

ПОСЛЕДСТВИЯ

Каждая заявка с датой хранит неверный день. Пациенты приходят не в тот день либо записываются заново. Как только экран заявок появится, ошибка сразу станет видна персоналу.

ЧТО СДЕЛАТЬ

Формировать строку даты из локальных компонентов (`\${y}-\${pad(m+1)}-\${pad(d)}`), а не через toISOString. Лучше взять общий Tashkent-хелпер (tashkentComponents/toTashkentDate из src/lib/booking-validation). На сервере проверять формат YYYY-MM-DD строгим regex, диапазон «сегодня...+30 дней по Ташкенту» и не-воскресенье, хранить дату как ташкентский день.

КРИТЕРИЙ ПРИЁМКИ

В браузере с поясом Asia/Tashkent выбрать 28.09 → в запросе и в Lead.date стоит 2026-09-28. Юнит-тест MiniCalendar/хелпера под TZ=Asia/Tashkent и TZ=UTC; сервер отклоняет прошлую дату и воскресенье с 400.

ДОКАЗАТЕЛЬСТВО В КОДЕ

MiniCalendar: `const date = new Date(viewYear, viewMonth, day); const dateStr = date.toISOString().split("T")[0];` (lead-form.tsx:78-79). Локальная полночь в Ташкенте (UTC+5) это 19:00 UTC предыдущих суток, поэтому toISOString даёт вчерашнюю дату. Проверено: `TZ=Asia/Tashkent node -e 'new Date(2026,8,28).toISOString()'` → Mon Sep 28 → "2026-09-27" (воскресенье, клиника закрыта). Подсветка выбранного дня не выдаёт ошибку, потому что сравнивается та же сдвинутая строка (стр. 84). Сервер без проверки делает `new Date(parsed.data.date)` (route.ts:131-135) и пишет в Lead.date, та же строка уходит врачу в письме (route.ts:160). Серверной проверки диапазона нет: Date.parse примет и прошлую дату, и воскресенье.

LD-07 P2 · СРЕДНИЙ мокап / заглушка

Прайс на сайте захардкожен в i18n-файлах и не связан с каталогом услуг CRM

ГДЕ

src/components/sections/services.tsx:25, src/messages/ru.json:2119, prisma/schema.prisma:1631, prisma/schema.prisma:1652

СЦЕНАРИЙ

Админ в CRM поднимает цену ЭЭГ со 150 000 до 180 000 сум. На сайте ещё месяцами висит 150 000. Пациент приходит и на кассе спорит из-за цены.

ПОСЛЕДСТВИЯ

Публичный прайс расходится с тем, что берёт касса: конфликты на ресепшн, жалобы, риск претензий по защите прав потребителей.

ЧТО СДЕЛАТЬ

Рендерить прайс из Service (isActive) с учётом priceOverride по кабинетам (formatMoney, тийины → суммы), группировать по category; SYSTEM-контекст с явным clinicId, как в getDoctors; подпись «цены актуальны на»

брать из `max(updatedAt)`.

КРИТЕРИЙ ПРИЁМКИ

Изменение `priceBase` в CRM сразу отражается на `/#services` в обеих локалях; в `messages` больше нет цен; тест, что сумма в тийинах 15000000 выводится как «150 000 сум».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`Services` читает позиции и цены строками из переводов: ``t.raw('groups.${groupKey}.items') as Priceltem[]`` (`services.tsx:25`), в `ru.json/uz.json` цены вида "300 000" продублированы по языкам, подзаголовок «Прейскурант от 18.05.2026» (`ru.json:2119`). Реальные цены, по которым ресепшн выставляет счёт, живут в `Service.priceBase` (тийины, `schema.prisma:1631`) и `ServiceOnDoctor.priceOverride` (`schema.prisma:1652`) и редактируются в CRM. Связи между ними нет. Совпадение сейчас держится только на том, что `scripts/seed-neurofax-real.ts` засеян теми же суммами.

LD-08 P2 · СРЕДНИЙ целостность данных

Ушедшего врача нельзя убрать с публичного сайта: `getDoctors` показывает и неактивных, а удалить врача с историей нельзя

ГДЕ

`src/lib/doctors.ts:13`, `src/lib/doctors.ts:89`, `src/app/api/crm/doctors/[id]/route.ts:214`, `src/app/api/crm/doctors/[id]/route.ts:221`, `src/app/[locale]/(site)/doctors/[id]/page.tsx:70`, `src/lib/doctors.ts:88`, `src/app/api/crm/doctors/[id]/route.ts:219`

ТАКЖЕ НАШЛИ ЗОНЫ

Управление врачами (CRM)

СЦЕНАРИЙ

Кардиолог уволилась. Админ нажимает «Удалить», получает `DoctorHasHistory` и деактивирует. На `neurofax.uz` она остаётся в «Наших специалистах», у неё своя страница с «работает в NeuroFax». Пациенты звонят и просят записать к ней.

ПОСЛЕДСТВИЯ

Публичный сайт показывает неверный состав врачей. Растёт нагрузка на ресепшн, пациенты недовольны, репутация клиники страдает.

ЧТО СДЕЛАТЬ

Добавить в `Doctor` поле `listedOnSite` (по умолчанию `true`) с переключателем в карточке врача в CRM; `getDoctors/getDoctorByld` фильтруют по нему; страница непериодического врача отдаёт 404 (или 410) и выпадает из `sitemap`.

КРИТЕРИЙ ПРИЁМКИ

Админ снимает галочку «показывать на сайте» → врач пропадает с главной, из формы и из `sitemap`, `/doctors/<id>` отдаёт 404; деактивированный, но оставленный на сайте врач показывается без кнопки записи, как сейчас.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`getDoctors` выбирает ``where: { clinicId }`` без `isActive` (`doctors.ts:89-103`). Комментарий `doctors.ts:13-18`: «If a doctor actually leaves, delete the row or we add a dedicated "listed on site" flag». Но `DELETE /api/crm/doctors/[id]` по умолчанию только деактивирует (`isActive: false``, стр. 278), а `purge` отказывает при любой клинической истории: ``return err("DoctorHasHistory", 409...)`` (стр. 214-224). Флага «показывать на сайте» в модели нет. Страница врача при этом публикует JSON-LD Physician с ``worksFor: NeuroFax`` (`page.tsx:65-81`).

LD-09 P2 · СРЕДНИЙ UX

Форма заявки заставляет выбрать врача из списка «записываемых». Без активных врачей её невозможно отправить, остальные направления приходится записывать на чужого врача

ГДЕ

`src/components/sections/lead-form.tsx:129`, `src/components/sections/lead-form.tsx:221`, `src/components/sections/lead-form.tsx:175`, `src/app/api/leads/route.ts:21`, `src/lib/doctors.ts:13`

СЦЕНАРИЙ

Родитель хочет к детскому неврологу или на ЭЭГ. В списке только один взрослый невролог. Приходится либо указать его (заявка уходит не тому врачу), либо закрыть форму. При кратком сбое БД форма на главной не отправляется совсем: браузер пишет «Выберите элемент в списке», а выбирать нечего.

ПОСЛЕДСТВИЯ

Заявки приписываются не тому врачу или теряются. Направления из преискуранта (кардиолог, педиатр, УЗИ, ЭЭГ) нельзя запросить с сайта.

ЧТО СДЕЛАТЬ

Сделать выбор врача необязательным с вариантом «Не знаю, подберите», добавить выбор направления или услуги (из каталога Service) и отправлять service. Если записываемых врачей нет, скрывать select, а не блокировать отправку.

КРИТЕРИЙ ПРИЁМКИ

Заявку можно отправить без врача (Lead.doctorId = null, service заполнен); с пустым списком врачей форма отправляется; выбор направления виден в Lead.service.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Список врачей в форме: ``useDoctors().filter((d) => d.bookable)`` (lead-form.tsx:129), bookable = Doctor.isActive (doctors.ts:75). В doctors.ts:13-16 прямо сказано, что сейчас системой пользуется один врач, остальных деактивировали. `<select id="lead-doctor" required ...><option value="">` (стр. 219-226): без выбора браузер не даст отправить. При этом API считает doctorId необязательным (``doctorId: z.string().max(50).optional()``, route.ts:21), а комментарий route.ts:115-119 предполагает, что лиды без врача разбирает ресепшн. Поле «услуга» в форме отсутствует, хотя API и письмо его поддерживают (route.ts:22, email.ts:35), ключ leadForm.service есть в переводах. Если getDoctors при сбое БД вернул [] (doctors.ts:106-109), в select остаётся только заглушка, и форма не отправляется вообще, без понятной ошибки.

LD-10 P2 · СРЕДНИЙ баг

Форма заявки не принимает номера операторов 33, 88, 77, 50, 20 и показывает «Произошла ошибка»

ГДЕ

src/components/sections/lead-form.tsx:161, src/components/sections/lead-form.tsx:276, src/app/api/leads/route.ts:12, src/lib/phone.ts:18

СЦЕНАРИЙ

Пациент с номером +998 33 412-55-67 заполняет форму и нажимает «Отправить заявку». Появляется «Произошла ошибка. Попробуйте ещё раз.». Он пробует ещё несколько раз и уходит.

ПОСЛЕДСТВИЯ

Заметная доля пациентов (особенно молодые, на Humans/Mobiuz 88) физически не может оставить заявку, а текст ошибки подсказывает, что сломан сайт.

ЧТО СДЕЛАТЬ

Принимать все мобильные коды Узбекистана: 9 местных цифр с кодом из списка операторов (20, 33, 50, 55, 77, 88, 90, 91, 93, 94, 95, 97, 98, 99) или 12 цифр с 998 + тот же список. Вынести в общий хелпер src/lib/phone.ts (isValidUzMobile) и применять и на клиенте, и в /api/leads (400 с полем phone). normalizePhone дополнять +998 для любых 9-значных местных номеров. На клиенте показывать отдельное сообщение «Проверьте номер телефона» под полем.

КРИТЕРИЙ ПРИЁМКИ

Заявки с номерами 33 412 55 67, +998 88 123 45 67, 77 123 45 67 проходят и сохраняются как +99833.../+99888.../+99877...; «12345» и «+7 999...» отклоняются с понятным текстом у поля телефона; юнит-тесты на хелпер.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Клиентская проверка: ``uzValid = (phoneDigits.length === 9 && phoneDigits.startsWith("9")) || (phoneDigits.length === 12 && phoneDigits.startsWith("9989"))`` (lead-form.tsx:161-163). Любой узбекский мобильный с кодом не на 9 (Humans 33, Mobiuz 88, Uzmobil 77, Ucell 50, OQ 20) отклоняется: ``setError(true); return;``, и показывается общий текст leadForm.error «Произошла ошибка. Попробуйте ещё раз.» (стр. 276-278), без указания на телефон. Сервер наоборот слишком мягкий: PhoneInput проверяет только ``[+\\d\\s()-]`` и длину 9-20 (route.ts:12-16), а normalizePhone для 9 цифр не на «9» просто дописывает «+» (phone.ts:18-21), так что при прямом вызове API «33 123 45 67» сохранится как «+331234567».

GET /api/leads отдаёт заявки (имена и телефоны) любой роли, включая NURSE и DOCTOR, в обход матрицы прав

ГДЕ

src/app/api/leads/route.ts:36, src/app/api/leads/route.ts:70, src/lib/permissions/matrix.ts:178

СЦЕНАРИЙ

Медсестра под своей учёткой открывает в браузере /api/leads?limit=200 и получает список всех, кто оставлял заявки: имена, телефоны, к какому неврологу и на какую дату просились.

ПОСЛЕДСТВИЯ

Утечка контактов потенциальных пациентов внутри клиники ролям, которым это запрещено. Матрица прав в UI вводит админа в заблуждение.

ЧТО СДЕЛАТЬ

Перевести GET на createApiListHandler({ roles: ["ADMIN", "RECEPTIONIST", "CALL_OPERATOR"] }) в соответствии с matrix.ts, заодно получить общий аудит и tenant-контекст. При создании экрана заявок использовать этот же эндпоинт.

КРИТЕРИЙ ПРИЁМКИ

Запрос GET /api/leads от NURSE и DOCTOR → 403; от RECEPTIONIST/CALL_OPERATOR/ADMIN → 200 со списком своей клиники; тест на роли.

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET проверяет только наличие сессии и clinicId: `const session = await auth(); if (!session?.user) ... 401` (route.ts:36-44), ролей нет, и дальше `prisma.lead.findMany(... take: limit)` до 200 строк (route.ts:70-74). Матрица прав, которую админ видит в «Настройки → Роли», для Lead задаёт `DOCTOR: NONE`, `NURSE: NONE` (matrix.ts:178-185). Маршрут не использует createApiHandler с roles, в отличие от остальных CRM-API.

SEO-мелочи: дублируется «| NeuroFax» в title врача, нет og:image при summary_large_image, SSR отдаёт lang="ru" на узбекских страницах, ссылка на врача относительная

ГДЕ

src/app/[locale]/layout.tsx:31, src/app/[locale]/(site)/doctors/[id]/page.tsx:30, src/app/[locale]/layout.tsx:46, src/app/layout.tsx:32, src/components/sections/doctors.tsx:43

СЦЕНАРИЙ

Пациент пересылает ссылку на клинику в Telegram: превью без картинки. Поисковик видит узбекские страницы как русские и дублированный бренд в заголовке.

ПОСЛЕДСТВИЯ

Ниже CTR в поиске и мессенджерах, хуже индексация узбекской версии.

ЧТО СДЕЛАТЬ

Убрать «| NeuroFax» из metaTitle; добавить.opengraph-image (ru/uz) или openGraph.images; выставлять lang на <html> на сервере (root layout читает локаль через getLocale); ссылки на врачей через next-intl Link с локалью.

КРИТЕРИЙ ПРИЁМКИ

Title врача: «Имя | Специальность | NeuroFax» без повтора; в HTML есть og:image; view-source /uz содержит <html lang="uz">; ссылка карточки с /uz ведёт на /uz/doctors/<id>.

ДОКАЗАТЕЛЬСТВО В КОДЕ

layout задаёт `title: { template: `%s | \${SITE_NAME}` }` (стр. 31), а doctorPage.metaTitle = "{name} | {specialty} | NeuroFax" (ru.json/uz.json), и страница врача получает «... | NeuroFax | NeuroFax». twitter.card "summary_large_image" (layout.tsx:46-50), но ни в openGraph, ни в app/ нет изображения (.opengraph-image не найден), так что превью в Telegram без картинки. Корневой `<html lang="ru">` (app/layout.tsx:32) исправляется только на клиенте через useEffect в LocaleHtmlLang, в SSR-HTML /uz остаётся ru. Карточка врача `href={`doctors/\${doc.id}`}` относительная (doctors.tsx:43): с /uz ведёт на /doctors/<id>, и краулер без cookie попадает на русскую версию.

app/robots.ts мёртвый: его перекрывает public/robots.txt, правки robots.ts на прод не попадут

ГДЕ

src/app/robots.ts:4, public/robots.txt:1

СЦЕНАРИЙ

Разработчик добавляет Disallow в robots.ts, деплоит, а поисковики продолжают получать старый public/robots.txt.

ПОСЛЕДСТВИЯ

Правила индексации расходятся с кодом, а служебные пути мини-аппа и тикетов открыты для обхода.

ЧТО СДЕЛАТЬ

Удалить public/robots.txt и оставить единственный источник app/robots.ts; дополнить disallow: /c/, /t/, /v/, /crm, /doctor, /signup, /uz/crm, /uz/doctor; убрать несуществующий /dashboard/.

КРИТЕРИЙ ПРИЁМКИ

curl https://neurofax.uz/robots.txt совпадает с выводом robots.ts, служебные пути закрыты.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В репозитории одновременно отслеживаются public/robots.txt (git ls-files) и src/app/robots.ts. В роутере Next (node_modules/next/dist/server/lib/router-utils/filesystem.js:413-437) publicFolder проверяется раньше appFile, а build-проверка конфликтов (build/index.js:859-871) смотрит только pages-роутер. Отдаётся статический файл. В обоих вариантах нет /c/, /t/, /v/, /crm, /doctor, /signup; /dashboard/ указан, хотя такого маршрута нет.

Заголовки frame-ancestors 'self' и X-Frame-Options SAMEORIGIN на всех путях блокируют Telegram Mini App в Telegram Web

ГДЕ

next.config.ts:29, next.config.ts:39, next.config.ts:84, nginx/nginx.conf:113, next.config.ts:83

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

СЦЕНАРИЙ

Пациент пользуется Telegram в браузере на рабочем компьютере, открывает @neurofaxbot и жмёт «Открыть приложение». Вместо мини-аппа пустое окно или «refused to connect».

ПОСЛЕДСТВИЯ

Пациенты на Telegram Web не могут записаться, посмотреть заключения и чат. Мобильные клиенты не затронуты.

ЧТО СДЕЛАТЬ

Для путей /c/:path* задать отдельный CSP с `frame-ancestors 'self' https://web.telegram.org` и не отдавать X-Frame-Options (в next.config headers отдельным правилом, в nginx убрать глобальный XFO или переопределить в location для /c/). Для остальных путей оставить запрет.

КРИТЕРИЙ ПРИЁМКИ

curl -I https://neurofax.uz/c/neurofax/my: frame-ancestors содержит web.telegram.org, X-Frame-Options отсутствует; /crm по-прежнему SAMEORIGIN; мини-апп открывается в web.telegram.org/k.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CSP содержит `frame-ancestors 'self'` (next.config.ts:29), а securityHeaders добавляет `X-Frame-Options: SAMEORIGIN` (стр. 39). Оба применяются к `source: "/:path\*"` (стр. 83-85), то есть и к мини-аппу /c/[slug]. nginx дополнительно ставит `add\_header X-Frame-Options "SAMEORIGIN" always` на весь vhost (nginx.conf:113). Telegram Web (web.telegram.org/k и /a) открывает Mini App во <iframe> с origin web.telegram.org, и браузер откажется его рендерить. Исключений для /c/ нет (rg frame-ancestors находит только next.config.ts).

Пользовательское соглашение обещает SMS-подтверждения, онлайн-оплату и удержание за позднюю отмену, которых в системе нет

ГДЕ

src/messages/ru.json:5761, src/messages/ru.json:5765, src/messages/ru.json:5769, src/messages/ru.json:5745, src/lib/constants.ts:16

СЦЕНАРИЙ

Пациент ждёт SMS с подтверждением, не получает (Telegram не привязан) и не приходит. Или ищет онлайн-оплату по соглашению и не находит.

ПОСЛЕДСТВИЯ

Юридический документ клиники описывает несуществующие услуги. Пациенты путаются, клиника не может опереться на такие условия в споре.

ЧТО СДЕЛАТЬ

Переписать legal.terms (ru/uz) по факту: подтверждение только через Telegram-бот/звонок администратора, оплата на ресепшн (наличные, карты, Payme/Click по QR), без удержаний. Единый контактный e-mail взять из CONTACT.

КРИТЕРИЙ ПРИЁМКИ

В /terms и /privacy нет упоминаний SMS и онлайн-оплаты, e-mail совпадает с CONTACT.email; владелец утвердил текст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

legal.terms.booking: «Подтверждение записи приходит по SMS или Telegram» (ru.json:5761). По docs/architecture/NOTIFICATIONS-TELEGRAM.md SMS-канал «X удалён» (адаптеры удалены). legal.terms.payment: «Оплата производится на ресепшн или онлайн» (5765), при этом мини-апп пишет «Оплата — у ресепшн» (src/app/c/[slug]/my/_messages/ru.ts:158), онлайн-оплаты нет. legal.terms.cancellation: «клиника может удержать частичную стоимость» (5769), хотя предоплаты нет и удерживать нечего. Контакт в политике и соглашении support@neurofax.uz (5745, 5781), а на сайте везде info@neurofax.uz (constants.ts:16).

Сайт рекламирует Telegram, но нигде не даёт на него ссылку: CONTACT.telegram = "#", бот показан текстом в макете

ГДЕ

src/lib/constants.ts:17, src/components/layout/footer.tsx:30, src/components/sections/telegram-showcase.tsx:51, src/messages/ru.json:2220, src/messages/ru.json:7761

СЦЕНАРИЙ

Пациент читает «Заключение врача придёт в Telegram» и FAQ «напишите в Telegram», ищет на сайте кнопку Telegram и не находит.

ПОСЛЕДСТВИЯ

Ключевое отличие клиники не конвертируется: пациенты не подписываются на бота, заключения и напоминания до них не доходят, в FAQ указан канал, которого нет.

ЧТО СДЕЛАТЬ

Брать tgBotUsername клиники из БД (или задать реальную ссылку в CONTACT), добавить кнопку «Открыть бота» (https://t.me/<bot>) в TelegramShowcase, контакты, футер и мобильную панель; убрать instagram, если его нет; FAQ согласовать с реальными каналами.

КРИТЕРИЙ ПРИЁМКИ

На главной есть рабочая ссылка на @neurofaxbot в блоке Telegram и в контактах; при смене бота в CRM ссылка меняется без правки кода; в DOM нет ссылок с href="#".

ДОКАЗАТЕЛЬСТВО В КОДЕ

`telegram: "#", instagram: "#" (constants.ts:17-18), поэтому футер прячет обе иконки и пункт «Telegram» (`CONTACT.telegram !== "#" &&`, footer.tsx:30, 41, 84). Первый вопрос FAQ: «Позвоните нам, напишите в Telegram или оставьте заявку...» (ru.json:2220). Блок TelegramShowcase (главная фишка сайта «Заключение придёт в Telegram») показывает "@neurofaxbot" (ru.json:7761) простым текстом внутри макета телефона (telegram-showcase.tsx:48-53), без ссылки t.me и без инструкции, как привязаться. Реальное имя бота хранится в Clinic.tgBotUsername (src/app/api/miniapp/clinic/route.ts:32).

Тёмная тема сотрудников протекает на публичный сайт: белый текст на белом фоне

ГДЕ

src/app/layout.tsx:23, src/components/sections/hero.tsx:19, src/components/layout/header.tsx:16, src/components/sections/lead-form.tsx:224, src/app/globals.css:240

СЦЕНАРИЙ

Администратор с тёмной темой в CRM на компьютере ресепшн открывает neurofax.uz, чтобы показать пациенту цены: заголовки и прайс почти не видны.

ПОСЛЕДСТВИЯ

На компьютерах персонала сайт нечитаем, а там его как раз показывают пациентам и проверяют.

ЧТО СДЕЛАТЬ

На публичном сайте принудительно светлая тема: обёртка .site-brand переопределяет токены светлой палитры или (site)-layout снимает класс dark; альтернатива: хранить тему CRM под отдельным ключом и применять только в /crm и /doctor.

КРИТЕРИЙ ПРИЁМКИ

С localStorage.theme='dark' главная, страница врача и диалог заявки выглядят так же, как в светлой теме.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Корневой themeInitScript читает localStorage 'theme' и вешает класс dark на <html> для любой страницы origin (layout.tsx:23, 37), а тему переключают CRM и кабинет врача (crm-topbar.tsx:363, doctor-topbar.tsx:209). В .dark `--foreground: #e7ecf3`, `--muted-foreground: #9ba4b5` (globals.css:240-266). Секции сайта жёстко задают светлый фон: `bg-white` (hero.tsx:19, header.tsx:16, visit/services/directions `bg-[#f4f8fc]`), а текст через text-foreground/text-muted-foreground. Select формы `bg-white` при тёмном тексте диалога (lead-form.tsx:224).

CD · Клинические документы, больничные, рецепты, анализы, направления, файлы

CD-01 P0 · КРИТИЧНО безопасность

Хранимый XSS через файлы документов: SVG от пациента из Mini App (и любой HTML от сотрудника) исполняется на neurofax.uz с сессией сотрудника

ГДЕ

src/app/api/miniapp/documents/route.ts:37, src/app/api/miniapp/documents/route.ts:149, src/app/api/miniapp/documents/route.ts:172, src/app/api/crm/documents/upload/route.ts:55, src/app/api/crm/documents/file/route.ts:57, src/app/api/crm/documents/file/route.ts:62, next.config.ts:22, src/app/[locale]/crm/patients/[id]/_components/document-preview-dialog.tsx:111, src/app/api/crm/documents/file/route.ts:59, next.config.ts:21, src/app/api/crm/documents/file/route.ts:58, src/app/[locale]/crm/patients/[id]/_components/document-preview-dialog.tsx:112

ТАКЖЕ НАШЛИ ЗОНЫ

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония, Мини-апп пациента и публичные страницы клиники

СЦЕНАРИЙ

Любой пациент, зарегистрированный в боте клиники, загружает в Mini App «фото анализа» — SVG со встроенным `<script>`. Регистратор или админ открывает карточку пациента → Документы → превью (картинка нормальная) → «Открыть во вкладке», чтобы увеличить. Скрипт выполняется на neurofax.uz с cookie сотрудника: читает `/api/crm/patients`, `/api/crm/documents`, создаёт пользователя-админа и отправляет данные на `api.telegram.org/bot<токен злоумышленника>`. Вариант изнутри: регистратор загружает `.html` через «Загрузить», админ открывает — эскалация привилегий.

ПОСЛЕДСТВИЯ

Утечка всей базы пациентов (ПДн, диагнозы, документы) и захват учётки сотрудника/админа руками анонимного пользователя Telegram. Максимальный риск для медорганизации.

ЧТО СДЕЛАТЬ

1) Белый список MIME на обоих загрузчиках (`application/pdf`, `image/jpeg`, `image/png`, `image/webp`, `image/heic`) с проверкой по сигнатуре байтов, а не по `file.type`; SVG и HTML запретить. 2) В `/api/crm/documents/file`, `/api/miniapp/documents/[id]/file` (и в прокси чат-вложений) отдавать `Content-Type` только из белого списка, всё прочее — `application/octet-stream + attachment`; добавить к ответам с файлами заголовок ``Content-Security-Policy: sandbox; default-src 'none'; img-src 'self' data:; style-src 'unsafe-inline'``. 3) Скриптом найти существующие Document с `contentType` вне белого списка (`image/svg+xml`, `text/html` и т.п.) и перевести на `attachment` либо удалить после проверки. 4) Рассмотреть отдачу пользовательских файлов с отдельного домена без cookie.

КРИТЕРИЙ ПРИЁМКИ

Загрузка SVG/HTML через Mini App и CRM возвращает 415; HTML с поддельным `file.type=image/png` отклоняется по сигнатуре (unit-тест). Для уже существующего SVG GET `/api/crm/documents/file` отдаёт `attachment/octet-stream` с CSP `sandbox`; при «Открыть во вкладке» скрипт не выполняется (проверка в браузере).

ДОКАЗАТЕЛЬСТВО В КОДЕ

Mini App POST: ``ALLOWED_MIME_PREFIXES = ["image/"]``, проверка ``mime.startsWith(p)`` пропускает ``image/svg+xml``; расширение берётся из имени файла (`extFromMime fallback → `.svg``); ``uploadObject(undefined, objectKey, buffer, mime)`` сохраняет `Content-Type`, присланный клиентом. Staff upload (`/api/crm/documents/upload`, роли ADMIN/RECEPTIONIST/DOCTOR/NURSE): ``const contentType = file.type || "application/octet-stream"`` без белого списка → можно ``text/html``. GET `/api/crm/documents/file` отдаёт ``Content-Type: fetched.contentType`` и ``Content-Disposition: inline`` по умолчанию, без `sandbox-CSP`. Глобальная CSP (`next.config.ts`, `source "/*:path*"`, применяется и к `/api`): ``script-src 'self' 'unsafe-inline'``, ``connect-src 'self' https://api.telegram.org`` — `inline-скрипт` в SVG/HTML разрешён, канал эксфильтрации на `api.telegram.org` открыт. `nosniff` не спасает — тип объявлен явно. В карточке пациента `DocumentPreviewDialog` всегда показывает «Открыть во вкладке» (``href={target.previewUrl}`` = ``/api/crm/documents/file?key=...``) → top-level навигация на SVG/HTML, где скрипт выполняется (в `<img>`-превью — нет, поэтому файл выглядит безобидно).

Документы, подпись врача, бланк/логотип и фото упаковок открываются по «голому» URL MinIO → 403 AccessDenied в кабинете врача, библиотеке CRM и на печати

ГДЕ

src/server/storage/minio.ts:161, src/app/api/crm/documents/upload/route.ts:68, src/server/workers/visit-note-handout.ts:208, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:281, src/app/[locale]/doctor/documents/_components/documents-table.tsx:219, src/app/[locale]/doctor/documents/_components/documents-table.tsx:231, src/app/api/crm/doctors/me/patients/[patientId]/visits/route.ts:237, src/app/[locale]/doctor/patients/[id]/_components/visits-section.tsx:135, src/app/[locale]/doctor/patients/[id]/_components/visits-section.tsx:327, src/app/api/crm/visit-notes/[id]/print/route.ts:401, src/app/api/crm/visit-notes/[id]/print/route.ts:833, src/app/api/crm/e-prescriptions/[id]/print/route.ts:270, src/app/api/crm/sick-leaves/[id]/print/route.ts:260, src/app/[locale]/doctor/settings/_components/signature-tab.tsx:150, src/app/api/crm/documents/upload/route.ts:69, src/server/storage/minio.ts:162, src/app/[locale]/crm/patients/[id]/_hooks/use-patient-documents.ts:35, src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:127, src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:129, src/app/[locale]/doctor/_components/drug-detail.tsx:159, src/app/api/crm/documents/file/route.ts:31, src/app/api/crm/settings/letterhead/route.ts:128, src/app/api/crm/settings/branding/route.ts:174, docs/architecture/SECURITY.md:501, src/app/api/miniapp/documents/route.ts:93, src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:128, src/server/storage/minio.ts:160, src/app/api/crm/dsar/exports/[id]/download/route.ts:47, src/server/workers/data-export.ts:394, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:280, src/app/[locale]/crm/patients/[id]/_hooks/use-patient-documents.ts:34

ТАКЖЕ НАШЛИ ЗОНЫ

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы, Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония, Настройки клиники, пользователи, филиалы, кабинеты, права, Остальной кабинет врача

СЦЕНАРИЙ

Врач в кабинете открывает «Документы» или ленту визитов пациента, кликает заключение или MPT → новая вкладка с XML «AccessDenied». Регистратор в «Документах» CRM нажимает «Открыть»/«Скачать» → то же. На печатном заключении вместо фирменного бланка битая картинка, в памятке пациенту — битые фото упаковок, в настройках врача не видно загруженной подписи.

ПОСЛЕДСТВИЯ

Врач не может открыть документы пациента из собственного кабинета (основной сценарий); печатные документы выглядят сломанными.

ЧТО СДЕЛАТЬ

Нормализовать на сервере: все API, отдающие `fileUrl` (`GET /api/crm/documents/[id]`, `visits` врача и т.п.), должны возвращать прокси-URL ``/api/crm/documents/file?key=...`` (логика `documentDownloadHref` перенесена в общий серверный helper), а лучше хранить в БД `storageKey`. Картинки в печати (бланк, логотип, подпись, фото упаковок) встраивать как `data: URI` через `fetchObject` на сервере либо отдавать через аутентифицированный прокси с ключом, прижатый к префиксу своей клиники.

КРИТЕРИЙ ПРИЁМКИ

В проде: `/doctor/documents` — клик по названию и «Скачать» открывают файл; ссылки в ленте визитов врача открываются; `/crm/documents` «Открыть»/«Скачать» работают; печать заключения показывает бланк/логотип клиники; превью подписи в настройках врача видно. Ни одна ссылка в UI не указывает на `/files/<bucket>/...`

ДОКАЗАТЕЛЬСТВО В КОДЕ

`uploadObject` возвращает ``${MINIO_PUBLIC_URL}/${bucket}/${key}`` (minio.ts:161-162); `upload`-путь в MinIO-режиме отдаёт его как `fileUrl` (`fileUrl = stored.url`), воркеры пишут `fileUrl: uploaded.url`. Бакет приватный — это прямо зафиксировано в коде: `src/app/api/miniapp/documents/route.ts:93-99` («direct GET returns MinIO's AccessDenied XML»), `documents/file/route.ts:4-8`. На прокси URL переписывают только карточка пациента CRM (`documentDownloadHref`, `use-patient-documents.ts:41-47`) и Mini App. Остальное использует `fileUrl` как есть: `/crm/documents` (`href={d.fileUrl}` для «Открыть» и «Скачать»), `/doctor/documents` (`window.open(doc.fileUrl)`) и `<a href={doc.fileUrl}>`), лента визитов врача (`visits` API отдаёт `fileUrl: d.fileUrl`, `visits-section` рендерит `href={d.fileUrl}`). `Doctor.signatureUrl` сохраняется тем же `upload`-путём → `<img src={signatureUrl}>` в настройках и в печати рецепта/больничного; `letterheadUrl/logoUrl` (`settings/letterhead: letterheadUrl = uploaded.url`) и `drug.photoUrl` вставляются в печать заключения как `<img src>`. Если `MINIO_PUBLIC_URL` на другом хосте (`.env.example: https://files.neurofax.uz`), картинки дополнительно режет CSP `img-src 'self'`.

CD-03 P2 · СРЕДНИЙ баг

Время и даты на печатных документах в UTC: «Дата финализации», время исправлений и «Документ сформирован» на заключении сдвинуты на 5 часов

ГДЕ

src/lib/format.ts:126, src/lib/format.ts:142, src/app/api/crm/visit-notes/[id]/print/route.ts:1083, src/app/api/crm/visit-notes/[id]/print/route.ts:558, src/app/api/crm/visit-notes/[id]/print/route.ts:884, src/server/workers/visit-note-handout.ts:114, src/server/workers/visit-note-handout.ts:212, src/app/v/[token]/route.ts:98, src/app/api/verify/sick-leave/[token]/route.ts:41, src/server/workers/referral-document.ts:88

СЦЕНАРИЙ

Врач подписал заключение в 15:10 по Ташкенту — на бумаге «Дата финализации 23.09.2026 10:10». Исправление внесено в 01:30 24.09 — на бумаге «23.09.2026 20:30». Работодатель в 02:00 проверяет больничный, закончившийся вчера, и видит «ДЕЙСТВУЕТ СЕГОДНЯ».

ПОСЛЕДСТВИЯ

Неверные временные отметки на юридически значимых медицинских документах (24-часовое окно правок и поправки отсчитываются от них) — почва для споров с пациентом и проверяющими.

ЧТО СДЕЛАТЬ

Добавить timeZone: "Asia/Tashkent" (или часовой пояс клиники) во все ветки formatDate либо завести серверные formatClinicDate/formatClinicTime и использовать их во всех печатных, PDF и verify-шаблонах; «сегодня» в verify считать через tashkentDayBounds.

КРИТЕРИЙ ПРИЁМКИ

Unit-тест в процессе с TZ=UTC: formatDate(new Date("2026-09-23T10:10:00Z"), "ru", "time") → "15:10". Печать заключения, финализированного в 15:10 по Ташкенту, показывает 15:10; PDF с поправкой показывает местное время поправки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

formatDate для short/long/time/dayMonthTime создаёт Intl.DateTimeFormat без timeZone → используется TZ процесса; в Dockerfile, Dockerfile.worker и docker-compose.yml TZ не задан (сервер в UTC). Печать заключения: `formatDate(note.finalizedAt, locale, "short")` `\${formatDate(note.finalizedAt, locale, "time")}` (1083), время исправлений (558), «сформирован» (884, 1172). PDF-воркер: buildPdfAmendments (114) и заголовок `Заключение от \${formatDate(visitDate...)}` (212-213). /v: dateFmt без timeZone. Проверка больничного считает «сегодня» через `Date.UTC(today.getUTCFullYear(...))`. В том же print/route.ts есть корректный formatTimeHm с timeZone "Asia/Tashkent" — проблема решена точно, но не везде.

CD-04 P2 · СРЕДНИЙ эксплуатация

Загрузка документов из Mini App без лимитов частоты и объёма: один пациент может заполнить диск общего сервера

ГДЕ

src/app/api/miniapp/documents/route.ts:35, src/app/api/miniapp/documents/route.ts:108, nginx/nginx.conf:28

СЦЕНАРИЙ

Скрипт с валидным initData пациента в цикле грузит 10-МБ картинки — десятки ГБ за час; диск заполняется, падают MinIO, Postgres и соседние проекты на VPS; в CRM появляются тысячи записей «Фото от пациента».

ПОСЛЕДСТВИЯ

Отказ в обслуживании клиники и соседних сервисов, засорение медкарты.

ЧТО СДЕЛАТЬ

Rate limit на пациента (например 20 загрузок в час и 200 МБ в сутки) через Redis; лимит суммарного объёма на пациента; limit_req на /api/miniapp/documents в nginx; алерт на заполнение диска.

КРИТЕРИЙ ПРИЁМКИ

21-я загрузка за час → 429; превышение суточного объёма → 429 с понятным сообщением в Mini App.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST принимает до 10 МБ за запрос; нет rate limit, дневной квоты или ограничения числа документов на пациента; достаточно зарегистрированного пациента (resolveMiniAppContext). В репозиторном nginx.conf нет limit_req (есть только client_max_body_size 25m). MinIO работает на общем VPS.

Кнопка «Подпись» (планшет подписи) в карточке пациента никогда не сохраняет: data:URL длиннее лимита baseUrl в 1000 символов

ГДЕ

src/server/schemas/document.ts:18, src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:258, src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:438, src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:515, src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:579

СЦЕНАРИЙ

Регистратор даёт пациенту расписаться на планшете в карточке пациента → «Сохранить» → ошибка; подпись не сохраняется ни разу.

ПОСЛЕДСТВИЯ

Функция сбора подписи/согласия — макет: выглядит рабочей, но не работает никогда; клиника может считать, что согласия собраны.

ЧТО СДЕЛАТЬ

Загружать подпись как файл: canvas.toBlob → POST /api/crm/documents/upload → сохранить baseUrl/mimeType/sizeBytes. Привязывать подпись к конкретному согласию (ставить signedAt нужному CONSENT/CONTRACT), а не создавать отдельный CONSENT «ожидает подписи». Canvas 1x вместо 2x. Обработать ошибку в onSave (catch + понятный toast).

КРИТЕРИЙ ПРИЁМКИ

Нарисовать подпись → «Сохранить» → документ появляется в списке, превью PNG открывается; в /crm/documents он не висит в «ожидают подписи»; тест onSave с canvas 900×440 проходит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

SignaturePadDialog делает canvas `c.width = c.offsetWidth \* 2; c.height = c.offsetHeight \* 2` (h-[220px] → ≈900×440 px), на сохранение `c.toDataURL("image/png")`, onSave создаёт документ `{ baseUrl: dataUrl, type: "CONSENT", mimeType: "image/png" }` через POST /api/crm/documents. CreateDocumentSchema: `baseUrl: z.string().min(1).max(1000)`. PNG такого размера с росчерком — десятки КБ, в base64 десятки тысяч символов → 400 на валидации всегда. В onClick только try/finally — диалог остаётся открытым, toast показывает сырой код ошибки.

Происхождение документа неразличимо: заключения и направления системы помечены «От пациента», а файлы пациента выглядят как клинические «Результат/Направление/Согласие»

ГДЕ

src/app/api/miniapp/documents/route.ts:43, src/app/api/miniapp/documents/route.ts:162, src/app/api/miniapp/documents/route.ts:194, src/server/workers/visit-note-handout.ts:233, src/server/workers/referral-document.ts:141, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:222, src/app/api/crm/documents/route.ts:93, src/app/api/miniapp/documents/route.ts:161, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:246

ТАКЖЕ НАШЛИ ЗОНЫ

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония, Мини-апп пациента и публичные страницы клиники

СЦЕНАРИЙ

Пациент загружает фото МРТ из другой клиники как «Результат» — врач в кабинете видит его как обычный клинический результат. Регистратор в библиотеке видит у каждого заключения врача бейдж «От пациента».

ПОСЛЕДСТВИЯ

Врач может принять непроверенный документ пациента за клинический; сотрудники перестают доверять бейджам; очередь «ожидают подписи» засоряется.

ЧТО СДЕЛАТЬ

Добавить явное поле источника (enum STAFF | PATIENT | SYSTEM) миграцией с бэкфиллом (visitNoted/referralId → SYSTEM; uploadedById null без них → PATIENT). Бейдж и фильтры строить по нему во всех списках (CRM, карточка пациента, кабинет врача, лента визитов). Пациенту разрешить только RESULT/OTHER; CONSENT/CONTRACT/RESCRIPTION/REFERRAL — запретить.

КРИТЕРИЙ ПРИЁМКИ

Заключение от воркера в /crm/documents без бейджа «От пациента»; документ из Mini App помечен во всех трёх интерфейсах; POST из Mini App с type=CONSENT → 400 либо сохраняется как OTHER.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Mini App POST ставит `uploadedById: null` и принимает type из формы среди REFERRAL/PRESCRIPTION/RESULT/CONSENT/CONTRACT/RECEIPT/OTHER; комментарий в файле прямо говорит, что CRM считает null признаком «от пациента». Воркеры заключений и направлений тоже пишут `uploadedById: null`. /crm/documents рисует бейдж «От пациента» при `d.uploadedBy === null` → все авто-заключения/направления помечены как загрузки пациента. В карточке пациента (documents-tab) и в кабинете врача бейджа нет — загруженный пациентом «Результат» не отличить от клинического. Фильтр «ожидают подписи» (CONSENT/CONTRACT, signedAt null) включает и файлы пациента, которые регистратор может «Отметить подписанным».

CD-07 P2 · СРЕДНИЙ мёртвая механика

Рецепт, больничный, анализы и направление к врачу: UI удалён 15.07 (1622b12), а бэкэнд, печать, публичная проверка и воркер живы; выданные ранее документы нельзя найти, перепечатать или аннулировать

ГДЕ

src/app/[locale]/doctor/reception/_components/e-prescription-dialog.tsx:65, src/app/[locale]/doctor/reception/_components/sick-leave-dialog.tsx:53, src/app/[locale]/doctor/reception/_components/lab-order-dialog.tsx:70, src/app/[locale]/doctor/reception/_components/referral-dialog.tsx:46, src/app/[locale]/doctor/my-day/_hooks/use-doctor-referrals.ts:31, src/app/api/crm/referrals/route.ts:105, src/app/api/crm/sick-leaves/[id]/route.ts:79, src/app/api/crm/e-prescriptions/[id]/route.ts:82, src/app/api/crm/lab-orders/[id]/route.ts:119, src/server/workers/referral-document.ts:236, src/app/[locale]/doctor/settings/_components/signature-tab.tsx:57, src/app/api/crm/visit-notes/[id]/print/route.ts:1396, src/messages/ru.json:6454

СЦЕНАРИЙ

Врач в июне выписал больничный с ошибкой в датах — аннулировать нечем, а публичная проверка по QR показывает «ДЕЙСТВУЕТ». Врач загружает подпись в настройках, ожидая увидеть её на документах, — её нет нигде. Новый рецепт или больничный в системе оформить нельзя.

ПОСЛЕДСТВИЯ

Мёртвая подсистема: вводит в заблуждение (настройка подписи, тексты, пакетная печать), держит открытые API и фоновую задачу; уже выданные документы нельзя сопровождать.

ЧТО СДЕЛАТЬ

Принять решение и зафиксировать в docs. Вариант А — вернуть осознанно: экран «Выданные документы пациента» (список Rx/SL/направлений/анализов, перепечатать, аннулировать с причиной), инбокс входящих направлений со сменой статусов; перед этим закрыть отдельные дефекты (нумерация, пропуск строк рецепта, переходы статусов анализов). Вариант Б — вывести из эксплуатации: скрыть вкладку «Подпись», POST-роуты вернуть 410, выключить воркер referral-document, оставить ADMIN read-only список и аннулирование уже выданных. Минимум сейчас — админский экран с выданными больничными/рецептами и кнопкой «Аннулировать».

КРИТЕРИЙ ПРИЁМКИ

В UI нет настроек и кнопок, которые ничего не делают; для любого ранее выданного больничного или рецепта админ находит его по пациенту, перепечатывает и аннулирует, после чего /api/verify/... показывает «АННУЛИРОВАН».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Коммит 1622b12 убрал ряд кнопок «Анализы / Рецепт / Больничный / Направление» и монтирование диалогов; сейчас поиск `

Сервер доверяет `fileUrl` из тела запроса: можно привязать чужой файл, удалить любой объект хранилища и отправить пациенту в Telegram файл по произвольному `bucket/key`

ГДЕ

`src/server/schemas/document.ts:18`, `src/app/api/crm/documents/route.ts:164`, `src/app/api/crm/documents/[id]/route.ts:29`, `src/app/api/crm/documents/[id]/route.ts:117`, `src/app/api/crm/documents/[id]/route.ts:161`, `src/app/api/crm/visit-notes/[id]/send-telegram/route.ts:38`, `src/app/[locale]/crm/documents/_components/upload-dialog.tsx:409`, `src/app/[locale]/doctor/documents/_components/documents-table.tsx:219`, `src/app/api/crm/visit-notes/[id]/send-telegram/route.ts:147`, `src/app/api/crm/visit-notes/[id]/send-telegram/route.ts:180`, `src/app/api/crm/documents/route.ts:168`, `src/app/api/crm/documents/file/route.ts:31`

ТАКЖЕ НАШЛИ ЗОНЫ

Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

СЦЕНАРИЙ

Врач через API создаёт документ своему пациенту с `fileUrl`, скопированным из списка (там видны `fileUrl` всех документов пациентов, включая файлы коллег), и удаляет «свой» документ → стирается файл чужого документа, строка остаётся, файл — 404 навсегда. Регистратор в режиме «URL» прикрепляет к пациенту А файл пациента Б → «Отправить в Telegram» шлёт пациенту А чужие медицинские документы. Зная ключ, то же можно сделать с файлами другой клиники.

ПОСЛЕДСТВИЯ

Необратимое уничтожение медицинских файлов инсайдером, смешивание документов разных пациентов, утечка чужих ПДн пациенту в Telegram; аудит фиксирует лишь удаление «своего» документа.

ЧТО СДЕЛАТЬ

Хранить на `Document storageKey`, выдаваемый только `upload`-роутом (`upload` возвращает одноразовый `uploadToken/id` объекта, `POST/PATCH` принимают его вместо `fileUrl`). Режим «ссылка», если нужен, — отдельное поле `externalUrl` только со схемой `https:` и без удаления из хранилища. Везде, где ключ извлекается из URL (`DELETE`, `PATCH`, `send-telegram`, `miniapp file`), требовать префикс ``clinics/<ctx.clinicId>/'` и фиксированный бакет. Проверять, что `appointmentId` принадлежит `patientId` и клинике. В `window.open` пропускать только относительные `/api/...` и `https:`.

КРИТЕРИЙ ПРИЁМКИ

`POST /api/crm/documents` с `fileUrl`, не выданным `upload`-роутом, → 400. `DELETE` документа, чей `fileUrl` указывает на ключ другого документа или клиники, не удаляет чужой объект (unit-тест). `send-telegram` не читает объекты вне `clinics/<clinicId>/'` основного бакета. `appointmentId` чужого пациента → 400.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`Create/UpdateDocumentSchema: `fileUrl: z.string().min(1).max(1000)`` — любая строка (в CRM есть режим «URL»); `POST` сохраняет её как есть, `patientId` и `appointmentId` из тела не сверяются друг с другом и с клиникой. `DELETE` и `PATCH` «замена файла» берут ключ ``extractStorageKey(before.fileUrl)`` регэкспом ``clinicsV[^]+VdocumentsV...`` без сравнения с `ctx.clinicId` и без проверки, что объект загружен для этого документа, затем ``deleteObject(undefined, key)`` внутренним клиентом с полными правами. `send-telegram `storageRefFromFileUrl`` берёт `bucket` и `key` прямо из пути ``/files/<bucket>/<key>`` и делает ``fetchObject(ref.bucket, ref.key)`` — любой бакет и ключ. В кабинете врача ``window.open(doc.fileUrl, "_blank", "noopener")`` без проверки схемы (React 19 saniрует только `href/src`).

Юридически значимые документы можно удалить или подменить: `DELETE` не защищает заключения/направления/подписанные согласия, «Заменить файл» сохраняет «подписано» и стирает оригинал

ГДЕ

`src/app/api/crm/documents/[id]/route.ts:145`, `src/app/api/crm/documents/[id]/route.ts:96`, `src/app/api/crm/documents/[id]/route.ts:117`, `prisma/schema.prisma:2344`, `src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:406`, `src/server/workers/visit-note-handout.ts:297`

СЦЕНАРИЙ

Админ по ошибке жмёт корзину на «Заключение от 01.09» — у пациента в Telegram заключение пропадает; через 30 с воркер создаёт новое с другим QR, и напечатанное ранее заключение больше не проверяется. Врач заменяет файл подписанного согласия — в системе оно по-прежнему «Подписано», оригинальный скан уничтожен.

ПОСЛЕДСТВИЯ

Потеря и подмена медицинских и юридических документов без возможности восстановления; ломается проверка уже выданных бумаг.

ЧТО СДЕЛАТЬ

DELETE: 409 для CONCLUSION, документов с visitNoteld/referralld и CONSENT/CONTRACT с signedAt; вместо hard delete — soft delete с сохранением объекта. «Заменить файл»: запрет при signedAt либо сброс signedAt и архив старой версии. Скрыть корзину в UI для таких строк. Публиковать document.deleted/updated. Воркер не должен пересоздавать документ, удалённый вручную, или должен сохранять прежний verifyToken.

КРИТЕРИЙ ПРИЁМКИ

DELETE заключения или подписанного согласия → 409, корзина в UI не показывается; замена файла у подписанного согласия → 409 (или signedAt=null и старая версия доступна); после удаления обычного документа Mini App обновляет список без перезагрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH блокирует только `type === "CONCLUSION" || visitNoteld || referralld`; signedAt не проверяется; после замены fileUrl старый объект удаляется `deleteObject(undefined, oldKey)` без версии. DELETE для ADMIN без защит: удаляет CONCLUSION, REFERRAL, подписанные CONSENT/CONTRACT (схема называет их legal records, onDelete: Restrict для пациента, но API удаляет). В карточке пациента корзина есть на каждой строке. Воркер visit-note-handout в пределах 14 дней (BACKFILL_WINDOW_MS) пересоздаёт удалённое заключение с НОВЫМ verifyToken, позже — не пересоздаёт вовсе. События document.deleted/updated не публикуются, Mini App держит удалённый документ до перезагрузки.

CD-10 РЗ · НИЗКИЙ целостность данных

Двойные записи аудита при выдаче и отмене рецепта и больничного

ГДЕ

src/server/realtime/envelope.ts:149, src/server/realtime/envelope.ts:156, src/server/workers/outbox-pumper.ts:133, src/app/api/crm/sick-leaves/route.ts:141, src/app/api/crm/e-prescriptions/route.ts:142

СЦЕНАРИЙ

В журнале аудита у одного больничного две записи о выдаче с разными action.

ПОСЛЕДСТВИЯ

Шум и искажение отчётов аудита.

ЧТО СДЕЛАТЬ

Оставить один источник, как для referral.created: убрать auditable для этих событий либо убрать явный audit().

КРИТЕРИЙ ПРИЁМКИ

Выдача одного больничного создаёт ровно одну запись аудита о выдаче.

ДОКАЗАТЕЛЬСТВО В КОДЕ

eprescription.issued/cancelled и sickleave.issued/cancelled помечены auditable: true — outbox-pumper пишет AuditLog (`if (meta.auditable) await writeAuditLog(envelope)`); одновременно роуты вызывают audit() с AUDIT_ACTION.*. Для referral.created это специально исключено (комментарий «Sole audit source»), здесь — нет.

CD-11 РЗ · НИЗКИЙ баг

Диалог рецепта молча выбрасывает незаполненные препараты (латентно: диалог сейчас не смонтирован)

ГДЕ

src/app/[locale]/doctor/reception/_components/e-prescription-dialog.tsx:95, src/app/[locale]/doctor/reception/_components/e-prescription-dialog.tsx:124

СЦЕНАРИЙ

При возврате функции врач выписывает 3 препарата и забывает кратность у третьего — пациент получает рецепт на 2 препарата.

ПОСЛЕДСТВИЯ

Неполный рецепт, риск для лечения. Сейчас не проявляется, потому что диалог не смонтирован (см. находку о мёртвой подсистеме).

ЧТО СДЕЛАТЬ

Блокировать отправку при частично заполненных строках с подсветкой полей; полностью пустые строки игнорировать.

КРИТЕРИЙ ПРИЁМКИ

При частично заполненной строке кнопка «Выписать» неактивна и поле подсвечено; тест компонента.

ДОКАЗАТЕЛЬСТВО В КОДЕ

handleSubmit: `items.filter((it) => it.drugName.trim() && it.dose.trim() && it.frequency.trim())`, a canSubmit = `items.some(...)`; если хотя бы одна строка заполнена, рецепт уходит без остальных, без предупреждения и без подсветки полей; предзаполнение seedItems даёт строки только с названием.

CD-12 РЗ · НИЗКИЙ бар

Направление на анализы: PATCH допускает любые переходы статуса, отменённое печатается без пометки, подготовка к анализам из панелей теряется

ГДЕ

src/app/api/crm/lab-orders/[id]/route.ts:7, src/app/api/crm/lab-orders/[id]/route.ts:135, src/app/api/crm/lab-orders/[id]/route.ts:147, src/app/api/crm/lab-orders/[id]/print/route.ts:65, src/app/api/crm/lab-orders/[id]/print/route.ts:297, src/app/api/crm/lab-orders/[id]/print/route.ts:371

СЦЕНАРИЙ

Пациенту назначена панель «Биохимия» (сдавать натошак) — на бланке нет «натошак». Медсестра через API возвращает отменённое направление в ORDERED, в аудите следа нет.

ПОСЛЕДСТВИЯ

Неверные инструкции пациенту и недостоверная история направлений. Новые направления из UI сейчас не создаются, затронуты прямые URL и старые записи.

ЧТО СДЕЛАТЬ

Таблица допустимых переходов с 409 на недопустимые; аудит каждой смены статуса; printedAt ставить только сервером; баннер «ОТМЕНЕНО» на печати; в выборку тестов панелей добавить patientPrep и turnaroundHours и включать их в блок подготовки; при вводе LabResult привязывать его к LabOrder.

КРИТЕРИЙ ПРИЁМКИ

PATCH COMPLETED→ORDERED→409; печать отменённого направления с баннером; бланк панели с тестом «натошак» содержит блок подготовки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий обещает «ORDERED ↔ COLLECTED ↔ COMPLETED, → CANCELLED до завершения», а код просто пишет `patch.status = body.status`: допустимы COMPLETED→ORDERED, CANCELLED→ORDERED; аудит только для CANCELLED и printedAt; printedAt приходит от клиента (можно задним числом). LabResult не связан с LabOrder, так что статусы не двигаются при вводе результатов. Печать не проверяет status (отменённое печатается как действующее). renderPrepBlock(tests) собирает подготовку только по отдельно заказанным тестам; для тестов из панелей выбираются лишь code/nameRu/biomaterial, без patientPrep и turnaroundHours.

CD-13 РЗ · НИЗКИЙ целостность данных

Номера RX/SL/LO уникальны глобально, а считаются по клинике и без повтора: вторая клиника и параллельные выписки получают 500

ГДЕ

src/server/clinical-forms/numbering.ts:39, src/app/api/crm/lab-orders/route.ts:10, src/app/api/crm/lab-orders/route.ts:186, prisma/migrations/20260518140000_e_prescription_sick_leave/migration.sql:69, prisma/migrations/20260518140000_e_prescription_sick_leave/migration.sql:76, prisma/migrations/20260518100000_lab_catalog/migration.sql:87, src/app/api/crm/sick-leaves/route.ts:89

СЦЕНАРИЙ

Клиника А сегодня выписала SL-20260923-0001. Клиника Б (новый арендатор через signup) выписывает первый больничный за день: её счётчик 0 → тот же номер → нарушение уникальности → 500, и так весь день, потому что счётчик Б не растёт. Внутри одной клиники два врача одновременно выписывают рецепт — один получает 500. Сейчас достижимо через API; станет массовым при возврате UI.

ПОСЛЕДСТВИЯ

В многоклиничном режиме выписка документов блокируется; при конкуренции — «internal_error» у врача с сырым текстом Prisma.

ЧТО СДЕЛАТЬ

Перейти на DocumentCounter с атомарным UPDATE ... SET value = value + 1 RETURNING в той же транзакции, что и create; уникальность сделать составной (clinicId, number) миграцией; дату в номере брать по Ташкенту; убрать ложный комментарий.

КРИТЕРИЙ ПРИЁМКИ

Тест: две клиники выписывают больничный в один день — обе 201; 20 параллельных POST в одной клинике — все 201, номера уникальны.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`nextNumber: `count = countToday(startOfDay)` с where `{ clinicId, createdAt >= UTC-полночь }` → `${prefix}-${YYYYMMDD}-${count+1}`. Уникальные индексы EPrescription_rxNumber_key, SickLeave_certNumber_key, LabOrder_orderNumber_key — по одному столбцу, без clinicId. Номер считается вне транзакции, P2002 не перехватывается и не повторяется; комментарий lab-orders/route.ts:10-12 «a collision retries with N+1» коду не соответствует. Уже есть правильный механизм DocumentCounter (@@unique([clinicId, year, kind])).`

CD-14 P3 · НИЗКИЙ производительность

Нумерация #N в списках документов делает коррелированный подсчёт без clinicId: проход по таблице на каждую строку

ГДЕ

`src/app/api/crm/documents/route.ts:35, prisma/schema.prisma:2379`

СЦЕНАРИЙ

По мере роста таблицы Document (все клиники платформы) открытие вкладки «Документы» замедляется линейно.

ПОСЛЕДСТВИЯ

Деградация производительности со временем.

ЧТО СДЕЛАТЬ

Добавить ``AND d2."clinicId" = d."clinicId"``` в подзапрос или считать seq окном `ROW_NUMBER() OVER (PARTITION BY patientId) /` хранить seq в колонке при создании.

КРИТЕРИЙ ПРИЁМКИ

EXPLAIN показывает Index (Only) Scan по индексу (clinicId, patientId, createdAt); время ответа на 50 строк стабильно при 100k документов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`attachSeq: `SELECT COUNT(*) FROM "Document" d2 WHERE d2."patientId" = d."patientId" AND (...)`` для каждой из возвращаемых строк (до 200). Подходящий индекс один — (clinicId, patientId, createdAt), но в подзапросе нет условия по clinicId, поэтому ведущий столбец не используется. Вызывается при каждом открытии вкладки «Документы» карточки (limit=50), библиотеки CRM и кабинета врача.

CD-15 P3 · НИЗКИЙ безопасность

Ограничение «врач видит только своих пациентов» обходится через /documents/[id], /documents/file и /sign; врач без профиля видит все документы клиники

ГДЕ

`src/app/api/crm/documents/route.ts:100, src/app/api/crm/documents/[id]/route.ts:49, src/app/api/crm/documents/file/route.ts:31, src/app/api/crm/documents/[id]/sign/route.ts:19, src/app/api/crm/documents/file/route.ts:21`

ТАКЖЕ НАШЛИ ЗОНЫ

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония

СЦЕНАРИЙ

Новому пользователю с ролью DOCTOR ещё не создали профиль врача — он открывает /doctor/documents и видит документы всех пациентов клиники. Врач, зная id заметки коллеги, скачивает чужое заключение по предсказуемому ключу.

ПОСЛЕДСТВИЯ

Нарушение минимально необходимого доступа к врачебной тайне внутри клиники; список обещает одно, а соседние эндпоинты разрешают другое.

ЧТО СДЕЛАТЬ

Общий helper «врач имеет доступ к пациенту» применять в GET [id], sign и file (для file — найти Document по ключу и проверить patientId); DOCTOR без профиля → 403. Для заключений — непредсказуемые ключи или доступ только через Document.

КРИТЕРИЙ ПРИЁМКИ

DOCTOR без Doctor-строки получает 403 на GET /api/crm/documents; DOCTOR без записей с пациентом

получает 403 на /documents/[id] и /documents/file?key=<ключ документа этого пациента>.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Список фильтрует DOCTOR по appointment/patient.appointments только `if (doc)`; если у пользователя с ролью DOCTOR нет строки Doctor, фильтр не добавляется и возвращаются все документы клиники (fail open). GET /api/crm/documents/[id] и POST ../sign не проверяют связь врача с пациентом. /api/crm/documents/file проверяет лишь префикс `clinics/<clinicId>` — отдаётся любой ключ клиники, включая `clinics/<id>/conclusions/<visitNotelId>.pdf` (ключ выводится из id заметки) и чат-вложения.

CD-16 РЗ · НИЗКИЙ переводы

Печатные шаблоны: рецепт, больничный и бланк анализов только по-русски; PDF направления без номера и строк подписи/печати; публичная проверка больничного показывает текст причины отмены

ГДЕ

src/app/api/crm/e-prescriptions/[id]/print/route.ts:168, src/app/api/crm/sick-leaves/[id]/print/route.ts:180, src/app/api/crm/lab-orders/[id]/print/route.ts:193, src/server/referrals/referral-pdf.ts:218, src/server/workers/referral-document.ts:131, src/app/api/verify/sick-leave/[token]/route.ts:58, src/app/api/verify/sick-leave/[token]/route.ts:154

СЦЕНАРИЙ

Узбекоязычный пациент получает рецепт на русском; внешняя клиника не принимает направление без подписи и печати; работодатель, сканируя QR аннулированного больничного, читает «Причина отмены: неверный диагноз G40.1».

ПОСЛЕДСТВИЯ

Юридическая неполноценность бумаг, неудобство для пациентов, утечка медданных через публичную страницу.

ЧТО СДЕЛАТЬ

Локализовать шаблоны по preferredLang с переключателем, как у заключения; в PDF направления добавить номер (через DocumentCounter) и строки подписи/печати; в публичном verify не показывать cancelReason, только статус «АННУЛИРОВАН».

КРИТЕРИЙ ПРИЁМКИ

Рецепт пациента с preferredLang=UZ печатается по-узбекски; PDF направления содержит номер и строки подписи; ответ verify больничного (HTML и JSON) не содержит cancelReason.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Шаблоны Rx/SL/LO захардкожены на русском (`<html lang="ru">`, все подписи), preferredLang пациента игнорируется (заключение уже умеет RU/UZ); возраст «\${n} лет» без склонения. genderReferralPdf не рисует строк «Подпись врача» и «Печать», Document.number для REFERRAL не заполняется (create без number), поэтому /v показывает направление без номера. Публичный verify больничного отдаёт cancelReason (свободный текст врача) анонимно, хотя шапка файла декларирует «No diagnosis is exposed».

CD-17 РЗ · НИЗКИЙ переводы

Тип «Заключение» не поддержан в UI и API-фильтре: вместо названия сырой ключ или «CONCLUSION», заключения нельзя отфильтровать

ГДЕ

src/app/[locale]/crm/documents/_components/documents-page-client.tsx:41, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:246, src/messages/ru.json:5014, src/server/schemas/document.ts:49, src/app/[locale]/crm/patients/[id]/_components/tabs/documents-tab.tsx:62, src/app/[locale]/doctor/document/s/_components/documents-header.tsx:13, src/server/workers/visit-note-handout.ts:226, src/messages/ru.json:5017

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Регистратор видит у заключений тип «docsLibrary.types.CONCLUSION» (в карточке — «CONCLUSION») и не может показать только заключения.

ПОСЛЕДСТВИЯ

Косметика и неудобный поиск главного типа документа.

ЧТО СДЕЛАТЬ

Добавить CONCLUSION в словари ru/uz (docsLibrary.types, patientCard.documents.types), в фильтры CRM и вкладки врача; в QueryDocumentSchema разрешить CONCLUSION для чтения (отдельный enum для запросов, не для создания).

КРИТЕРИЙ ПРИЁМКИ

В обоих языках заключение подписано «Заключение»/«Хулоса»; фильтр «Заключения» возвращает только их; GET ?type=CONCLUSION → 200.

ДОКАЗАТЕЛЬСТВО В КОДЕ

docsLibrary.types в ru/uz не содержит CONCLUSION (есть неиспользуемые ANALYSIS и INVOICE) → ``t("types.CONCLUSION")`` в /crm/documents выводит ключ сообщения. Карточка пациента для типов вне DOC_TYPES выводит ``doc.type`` латиницей. QueryDocumentSchema.type = DocumentTypeEnum без CONCLUSION → ?type=CONCLUSION даёт 400; ни в CRM, ни у врача нет вкладки «Заключения», хотя это самый частый тип.

СТ · Справочники: препараты, МКБ-10, услуги, оверлеи клиники, избранное

СТ-01 P2 · СРЕДНИЙ баг

«Чем заменить»: клик по аналогу в справочнике ничего не делает, а в ящике назначения открывает ДРУГОЙ препарат

ГДЕ

src/app/[locale]/doctor/references/_components/drug-similar.tsx:101, src/app/[locale]/doctor/references/_components/drug-browser.tsx:404, src/app/[locale]/doctor/reception/_components/catalog-drawer.tsx:101, src/app/api/crm/catalogs/drugs/[id]/similar/route.ts:63

СЦЕНАРИЙ

Врач в ящике назначения смотрит «Кеторолак», в блоке «Тот же класс» кликает «Диклофенак». Карточка переключается на первый результат поиска («Дифенгидрамин + кеторолак»). Врач читает противопоказания, думая, что это диклофенак.

ПОСЛЕДСТВИЯ

Врач может прочитать противопоказания и дозировку не того препарата. В справочнике кнопка просто мёртвая. Предлагаются препараты, которые клиника скрыла.

ЧТО СДЕЛАТЬ

При клике по аналогу догружать препарат по id (GET /api/crm/catalogs/drugs?ids=<id>) и открывать его карточку независимо от текущего списка. В ящике не сбрасывать выбор на rows[0], если выбран внешний id. В роуте similar применить loadClinicOverlays: отфильтровать hidden и наложить overrides. Ранжировать курируемые строки (defaultDosing не null) выше.

КРИТЕРИЙ ПРИЁМКИ

Клик по аналогу в справочнике и в ящике всегда открывает карточку именно этого аналога. Скрытый админом препарат не появляется в «Тот же класс».

ДОКАЗАТЕЛЬСТВО В КОДЕ

DrugSimilar отдаёт только id аналога через onOpenDrug. В справочнике обработчик ищет препарат среди загруженных строк: 'const next = rows.find((r) => r.id === id); if (next) setSelected(next);'. Аналоги по АТС почти никогда не входят в текущую страницу или фильтр, и клик молча не срабатывает, хотя кнопка выглядит активной. В ящике назначения onOpenDrug={({id} => setSelectedId(id)), а эффект на строках 101-107 при отсутствии id среди rows сбрасывает выбор на rows[0]. В итоге после клика по «Ибупрофен» открывается первая строка поиска, другой препарат. Роут similar при этом не учитывает скрытые клиникой препараты (нет loadClinicOverlays) и её переименования. Комментарий 'Curated rows first' не соответствует orderBy [{ nameRu: 'asc' }].

СТ-02 P2 · СРЕДНИЙ целостность данных

В каталоге МКБ нет подрубрик сахарного диабета E10–E14 (.0–.9), нет главы U (COVID-19), есть мусорная запись «K91.4, — N99.5»

ГДЕ

scripts/build-icd10-catalog.mjs:58, scripts/build-icd10-catalog.mjs:45, src/server/icd10/data.json:1

СЦЕНАРИЙ

Невролог ставит диабетическую полинейропатию и должен закодировать E11.4 + G63.2*. E11.4 в каталоге нет, в заключение уходит неполный E11. Пациенту с постковидным синдромом код U09.9 выбрать нельзя. В подсказках по «N99.5» висит строка «K91.4, — N99.5».

ПОСЛЕДСТВИЯ

Для частых сочетанных неврологических диагнозов (диабет, постковид) нет корректных кодов, статистика и выписки получают неполные коды. Мусорная строка портит доверие к справочнику.

ЧТО СДЕЛАТЬ

В генераторе для категорий с общим четвёртым знаком (E10–E14 и аналогичные) генерировать подрубрики .0–.9 с полными названиями. Добавить главу U (U07.1, U07.2, U09.9 и др.) вручную или из актуального источника. Валидировать коды регуляркой '[A-Z][0-9]{2}(\.[0-9]{1,2})?[*]?\$' и падать на мусоре. Добавить юнит-тест на формат всех кодов.

КРИТЕРИЙ ПРИЁМКИ

В data.json есть E11.4, E10.4, E11.9, U07.1, U09.9. Все коды проходят регулярку формата. searchIcd10('e11.4')

возвращает E11.4. Записи 'K91.4,' нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В data.json коды E10, E11, E12, E13, E14 присутствуют только трёхзначными листьями, ни одного E11.x. В исходнике подрубрики заданы общим четвёртым знаком на уровне блока, и фильтр node_count=0 их не порождает. При этом в названиях G63.2*, G59.0* прямо написано 'E10-E14+ с общим четвёртым знаком .4'. searchIcd10('e11.4') → []. Кодов на букву U нет совсем (подсчёт по первой букве: U отсутствует), значит нет U07.1, U09.9. Разбор SQL регулярным выражением ROW (строка 45) дал битую запись { code: 'K91.4,', nameRu: 'N99.5' }; она выходит в поиске 'k91' и 'n99.5'.

СТ-03 P2 · СРЕДНИЙ целостность данных

Импорт госреестра склеивает разные вещества по общему бренду: инъекции «толперизон + лидокаин» попадают в карточку монопрепарата «Толперизон»

ГДЕ

scripts/import-uzpharm-registry.ts:57, scripts/import-uzpharm-registry.ts:96, scripts/import-uzpharm-registry.ts:105

СЦЕНАРИЙ

Врач набирает «Миоспан» (толперизон с лидокаином, ампулы). Справочник показывает «Толперизон», и назначение уходит как «Миоспан (толперизон)», без упоминания лидокаина. У пациента в карте аллергия на лидокаин, но CDS-проверка (drug-check сверяет inn/nameRu/бренды с веществом) предупреждения не даёт. Во втором случае врач по бренду «Гексикон» видит карточку с бензокаином и АТС R02AA20 (пастилки для горла).

ПОСЛЕДСТВИЯ

Врач видит неверный состав препарата. Пропускается аллергия на местный анестетик. Для хлоргексидина в карточке показано чужое вещество и чужие формы выпуска.

ЧТО СДЕЛАТЬ

Сопоставлять сущности реестра только по одному веществу: по нормализованному МНН или названию, а по бренду лишь тогда, когда у бренда ровно один владелец в реестре и составы совпадают. Бренды, принадлежащие нескольким сущностям, не использовать как ключ склейки. Исключить clinicId != null из existingDrugs. Добавить в скрипт отчёт о конфликтах. Для уже импортированных данных сделать скрипт-ревизию: найти бренды, пришитые к препарату с другим МНН, и перенести их в корректные строки (создать недостающие сущности 'лидокаин + толперизон', 'хлоргексидин').

КРИТЕРИЙ ПРИЁМКИ

Сухой прогон импорта на текущем JSON показывает 0 склеек между сущностями с разным составом. В БД бренд «Миоспан» принадлежит строке с составом «лидокаин + толперизон», а «Гексикон» — строке «хлоргексидин». Аллергия «лидокаин» даёт CDS-предупреждение при назначении «Миоспан».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Импорт ищет «дом» для сущности реестра сначала по имени, а если не нашёл, по ЛЮБОМУ бренду (строки 91-103): 'for (const b of e.brands) { const hit = handleToDrug.get(norm(b.name)); if (hit) { drugId = hit; break; } }'. После этого все бренды сущности пришиваются к найденному препарату, а её формы выпуска отбрасываются (continue на строке 119). Прогнал ту же логику на prisma/uzpharm-registry.json: 18 сущностей склеиваются с другим веществом. Среди них: 'лидокаин + толперизон' [M03BX, INJ_IM] уходит в 'толперизон' по бренду ТОЛКИМАДО, и вместе с ним переезжают бренды 'Токката рапид, СЕВИПРОКС, МИОСПАН, МИОФЛЕКС, ТОЛПЕЗОН, Лионотол'; 'хлоргексидин' (Гексидин, Гексикон, Септум) уходит в 'бензокаин + хлоргексидин + эноксон' по бренду АНЗИБЕЛ; 'ФЕРОМАКС' [B03AB, железо] уходит в 'фолиевая кислота'. Кроме того, existingDrugs (строка 57) выбирает BCE Drug, включая собственные строки клиник (clinicId не null). Сущность реестра, совпавшая по имени с препаратом одной клиники, не создаётся глобально, а её бренды пишутся в клиническую строку.

СТ-04 P2 · СРЕДНИЙ баг

Каталог МКБ в приёме: глава G (по умолчанию) не листается дальше 200 кодов, третий клик «Ещё» возвращает 400

ГДЕ

src/app/api/crm/icd10/search/route.ts:30, src/app/[locale]/doctor/reception/_components/icd-catalog-drawer.tsx:87

СЦЕНАРИЙ

Невролог открывает «Каталог МКБ» из заключения, глава «Болезни нервной системы». Дважды жмёт «Ещё», на

третий раз список ломается или пропадает. Найти G90.9 или G93.4 просмотром главы невозможно.

ПОСЛЕДСТВИЯ

Основной инструмент выбора диагноза у невролога не показывает треть неврологической главы. Врач вынужден угадывать формулировку для поиска.

ЧТО СДЕЛАТЬ

Либо перевести ящик на offset/limit-пагинацию (роут уже поддерживает offset) с фиксированным limit=100 и склейкой страниц, либо поднять max limit для range-режима до размера самой большой главы. Лучше первое: useInfiniteQuery с offset.

КРИТЕРИЙ ПРИЁМКИ

В ящике глава G00-G99 листается до G99.8 без ошибок. В Network нет запросов с limit больше допустимого. Глава S00-T98 долистывается до конца.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ящик МКБ запрашивает главу так: `fetchIcd('range=' + chapter + '&limit=' + (PAGE * pages))`, где `PAGE = 100`, а `pages` растёт на каждый «Ещё». Схема роута ограничивает limit: `z.coerce.number().int().min(1).max(200)`. При `pages=3` уходит limit=300, `parseQuery` возвращает 400 `ValidationError`, `fetchIcd` бросает 'ICD 400'. В главе G (открывается по умолчанию, `chapter='G00-G99'`) 331 код: 200-й код G57.2, 201-й G57.3. Коды G57.3...G99.x (131 шт., включая G80–G83, G90, G93, G96–G99) через просмотр главы недоступны. Главы M (544), S–T (1278), V–Y (1356), Q (624) страдают так же.

СТ-05 P2 · СРЕДНИЙ целостность данных

Клинический «самообучаемый» каталог диагнозов ставит формулировки без кода выше кодов МКБ, и удалить их нельзя

ГДЕ

`src/server/icd10/clinic-catalog.ts:44`, `src/server/icd10/clinic-catalog.ts:105`, `src/app/api/crm/icd10/search/route.ts:99`, `src/app/[locale]/doctor/_components/diagnosis-follow-up-cards.tsx:288`

СЦЕНАРИЙ

Один врач однажды подписал заключение с текстом «мигрень» через «Использовать как написано». Теперь у всех врачей по запросу «мигр» первой строкой идёт «мигрень» с бейджем «клиника» и без кода. Врачи кликают её, и заключения массово уходят без кода МКБ. Опечатка вроде «остеохондроз» тоже навсегда остаётся в подсказках.

ПОСЛЕДСТВИЯ

Системно снижается доля кодированных диагнозов (статистика, отчёты, страховые выписки). Ошибки одного врача разносятся на всю клинику без возможности исправления.

ЧТО СДЕЛАТЬ

Не выучивать свободный текст, если он совпадает (после нормализации) со статической формулировкой; при совпадении подставлять её код. Записи без кода ранжировать ниже кодированных статических совпадений того же запроса. Добавить админ-экран или API для просмотра, правки кода и удаления `ClinicDiagnosis`. В пикере использовать ключ `code + nameRu`.

КРИТЕРИЙ ПРИЁМКИ

Подписание заключения с текстом «Мигрень без ауры [простая мигрень]» без кода не создаёт `ClinicDiagnosis` (или создаёт его с кодом G43.0). По запросу «мигр» первыми идут G43.x. Админ может удалить клиническую запись, и она исчезает из подсказок. В консоли пикера нет предупреждений React о дублирующихся ключах.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`learnClinicDiagnosis` запоминает каждый подписанный диагноз, код которого не входит в статический каталог, в том числе любой свободный текст без кода. Комментарий на строке 47 обещает 'Free text only counts when it is NOT already a static wording', но проверки совпадения со статической формулировкой нет: `normalized` только вычисляется. В роуте поиска `custom`-записи стоят ПЕРВЫМИ (`[...custom, ...stat].slice(0, limit)`), а дедупликация идёт по ключу `code|name`. У записи без кода ключ 'мигрень без ауры ...' никогда не совпадёт с 'g43.0|...', поэтому дубли не отсекаются. Если в клинике накопилось хотя бы limit (25) похожих формулировок, кодированные рубрики вытесняются из выдачи полностью. `searchClinicCatalog` возвращает `code: ''` для записей без кода, а пикер рендерит '`<li key={r.code}>`', и у нескольких таких строк одинаковый `key` ". Роутов и экранов для просмотра или удаления `ClinicDiagnosis` нет (`grep` по `clinicDiagnosis` находит только `clinic-catalog.ts`).

Названия диагнозов МКБ оторваны от родительской рубрики: «D33.0 Головного мозга над мозговым наметом» и D43.0 с тем же текстом

ГДЕ

scripts/build-icd10-catalog.mjs:58, scripts/build-icd10-catalog.mjs:63, src/server/icd10/data.json:1

СЦЕНАРИЙ

Невролог по МРТ ставит менингиому. Набирает «менингиома», получает менингиты. Листает главу, видит два одинаковых пункта «Головного мозга над мозговым наметом» (D33.0 и D43.0), выбирает наугад. В подписанном заключении и в печати стоит «D33.0 Головного мозга над мозговым наметом», без слова «новообразование».

ПОСЛЕДСТВИЯ

В юридически значимом документе появляется бессмысленная формулировка диагноза. Врач не может отличить доброкачественную опухоль от опухоли неопределённого характера, отсюда риск неверного кода в статистике и в выписке для пациента.

ЧТО СДЕЛАТЬ

В build-icd10-catalog.mjs для листьев, чьё имя не является самостоятельным диагнозом, строить полное название: имя родительской рубрики плюс уточнение листа (например, «Доброкачественное новообразование головного мозга над мозговым наметом»). Имя родителя индексировать и для поиска. Исправить обрезанные переносы. Перегенерировать data.json, пересмотреть diff и добавить юнит-тест, что у разных кодов нет одинаковых nameRu.

КРИТЕРИЙ ПРИЁМКИ

В data.json нет двух кодов с одинаковым nameRu. D33.0 и D43.0 различаются и содержат слово «новообразование». searchIcd10('опухоль головного мозга') и searchIcd10('менингиома') в топ-5 возвращают коды из C71/D32/D33/D43.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Генератор берёт только листья (node_count = 0) и сохраняет name листа как есть, без имени родительской рубрики (строки 57-72). Во многих рубриках МКБ текст листа — лишь уточнение к родителю. В data.json из 740 кодов C00–D48 примерно 548 имеют такие обрывки, например: 'C71.6 Мозжечка', 'C71.0 Большого мозга, кроме долей и желудочков', 'D32.0 Оболочек головного мозга', 'D33.0 Головного мозга над мозговым наметом' и 'D43.0 Головного мозга над мозговым наметом'. У двух разных кодов (доброкачественное новообразование и новообразование неопределённого характера) дословно одинаковый текст. Так же выглядят T42.1 'Иминостильбенами' (отравление карбамазепином), T51.0 'Этанола', 'C71.8 Поражение, выходящее за пределы одной и более вышешка-' (обрезано с переносом). Поиск тоже ломается: searchIcd10('опухоль головного мозга') выдаёт 'C83.7 Опухоль Беркитта', 'O34.1 Опухоль тела матки...', и ни одного C71/D33/D43. searchIcd10('менингиома') выдаёт туберкулёзный менингит.

Поиск МКБ не находит частые неврологические формулировки и выдаёт мусор: «ТИА» → тиамин, «боль в шее» → рак, «полинейропатия» → пусто

ГДЕ

src/server/icd10/search.ts:52, src/server/icd10/search.ts:51, src/server/icd10/search.ts:125, src/server/icd10/search.ts:172

СЦЕНАРИЙ

Невролог набирает «ТИА», получает авитаминоз и легионеллёз. Набирает «полинейропатия» — ничего. Набирает «боль в шее» — злокачественные опухоли слюнной железы. В итоге берёт «Использовать как написано», и диагноз уходит без кода МКБ.

ПОСЛЕДСТВИЯ

Поиск не находит самые частые диагнозы профильной клиники. Растёт число заключений без кода, падает качество статистики, врач тратит время на приёме.

ЧТО СДЕЛАТЬ

Починить синоним ТИА (матчить 'транзиторн'+ 'ишемическ' или напрямую коды G45.x). Добавить синонимы: полинейропатия/нейропатия → невропатия/полиневропатия (включая орфографический вариант «-нейро-» ↔ «-невро-»), боль в шее → цервикалгия (M54.2), люмбалгия → M54.5, ХИМ/хроническая ишемия мозга → I67.8, вертиго → головокружение, невроз → невротические, туннельный/карпальный → G56.0, неврит/нейропатия лицевого нерва → G51.0, ОНМК → I60–I64. Для стемминга запретить совпадение стема короче исходного слова,

когда стем является префиксом другого корня («бол» ≠ «больш»): например, требовать совпадения стемов целиком, а префикс разрешать только при длине стема от 5 символов. Расширить тесты на список частых неврологических запросов.

КРИТЕРИЙ ПРИЁМКИ

В топ-3 выдачи: 'тиа' → G45.9; 'полинейропатия' → G62.9 или G63.2; 'боль в шее' → M54.2; 'хроническая ишемия мозга' → I67.8; 'онмк' содержит I61/I64; 'грыжа диска' содержит M51.1. Ни один запрос из этого списка не возвращает коды C00–C97 в топ-5.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Прогон searchIcd10 на реальных запросах. 'тиа' возвращает 'E51.8 ... недостаточности тиамин', 'A48.2 ... Понтиак', и ни одного G45: синоним 'тиа' → 'преходящие транзиторные церебральные ишемические' требует, чтобы ВСЕ слова были в названии (строки 274-277), а у листьев G45.x слова «преходящие» нет (у G45.9 название «Транзиторная церебральная ишемическая атака неуточненная»), поэтому расширение не совпадает ни с одной строкой. 'боль в шее' возвращает 'C08.9 Большой слюнной железы', 'C16.6 Большой кривизны желудка': stemRu('боль') даёт 'бол', а wordMatches/scoreOne принимают любой стем, начинающийся с него («больш...», «болезн...»); M54.2 «Цервикалгия» не находится. 'полинейропатия' и 'нейропатия' дают [] (в каталоге пишется «полиневропатия»). 'хроническая ишемия мозга' первым выдаёт 'I25.9 Хроническая ишемическая болезнь сердца'. Пусто также по 'люмбалгия', 'вертиго', 'невроз', 'карпальный'. 'онмк' раскрывается только в 'инфаркт мозга' (I63), без I61/I64. 'грыжа диска' не поднимает M51.1 (самый частый код: название во множественном числе «Поражения межпозвоночных дисков...»).

СТ-08 Р2 · СРЕДНИЙ баг

Поиск МКБ ставит противоположный или более тяжёлый диагноз первым: «мигрень с аурой» → G43.0 «без ауры», «сотрясение мозга» → S06.7 «с продолжительной комой»

ГДЕ

src/server/icd10/search.ts:85, src/server/icd10/search.ts:236, src/server/icd10/search.ts:59, src/server/icd10/search.ts:263

СЦЕНАРИЙ

Невролог набирает «мигрень с аурой» и берёт первую строку: в заключение уходит G43.0 (без ауры). Врач приёмного набирает «сотрясение мозга», первым видит S06.7 (травма с продолжительной комой), кликает. В подписанном документе стоит тяжёлая ЧМТ вместо сотрясения.

ПОСЛЕДСТВИЯ

В подписанное заключение и статистику попадает неверный диагноз при самом частом сценарии (выбор первой строки подсказки).

ЧТО СДЕЛАТЬ

Не выбрасывать отрицания и предлоги, меняющие смысл («без», «с»): учитывать их как обязательные токены (фраза «без X» не должна совпадать с названием, где X стоит без «без», и наоборот). Для синонимов прямой литеральный полный матч по всем словам должен стоять выше синонимного расширения. Добавить регрессионные тесты на пары «с/без ауры», «сотрясение мозга».

КРИТЕРИЙ ПРИЁМКИ

searchIcd10('мигрень с аурой')[0].code === 'G43.1', searchIcd10('мигрень без ауры')[0].code === 'G43.0', searchIcd10('сотрясение мозга')[0].code === 'S06.0'. Тесты в tests/unit/icd10-spoken-search.test.ts.

ДОКАЗАТЕЛЬСТВО В КОДЕ

(1) Слова «с» и «без» входят в STOP_WORDS (строки 85-88) и выбрасываются, поэтому запросы «мигрень с аурой» и «мигрень без ауры» становятся одинаковыми. Оба кода полностью совпадают, базовый балл считается только по первому слову: base = scoreOne(row, words[0]) (строка 236), это nameStarts=60 у обоих. Ничья разрешается по коду, и G43.0 «Мигрень без ауры» идёт первым. Запуск searchIcd10('мигрень с аурой') вернул ['G43.0 Мигрень без ауры', 'G43.1 Мигрень с аурой']. (2) Синоним 'сотрясение мозга' → 'внутричерепная травма' (строка 59) при прямом совпадении даёт synonymDirect=70 (строки 262-287). Буквальное совпадение S06.0 «Сотрясение головного мозга» получает 60+2=62. searchIcd10('сотрясение мозга') вернул первыми 'S06.7 Внутричерепная травма с продолжительным коматозным состоянием', 'S06.9', и только третьим S06.0.

Поиск препарата в конструкторе назначений не находит сам препарат («Парацетамол») при большом числе совпадений

ГДЕ

src/app/api/crm/catalogs/drugs/route.ts:110, src/app/api/crm/catalogs/drugs/route.ts:147, src/app/[locale]/doctor/reception/_hooks/use-drug-search.ts:56

СЦЕНАРИЙ

Врач на приёме в конструкторе назначений набирает «парацетамол». В выпадающем списке 12 комбинированных препаратов («Аскорбиновая кислота + парацетамол + ...»), самого «Парацетамола» нет. Врач выбирает комбинацию либо тратит время на поиск по бренду.

ПОСЛЕДСТВИЯ

Самые назначаемые МНН не находятся по собственному названию в основном потоке приёма. Есть риск назначить комбинированный препарат вместо монопрепарата.

ЧТО СДЕЛАТЬ

Ранжировать до пагинации. Либо сначала выбирать кандидатов с приоритетом (точное совпадение по nameRu/inn/бренду → префикс → подстрока) несколькими запросами или SQL-выражением CASE в ORDER BY через \$queryRaw с параметрами, либо брать увеличенное окно кандидатов (например, 200), ранжировать его и отдавать limit. Применять ко всем потребителям (конструктор, каталог-ящик, справочник).

КРИТЕРИЙ ПРИЁМКИ

GET /api/crm/catalogs/drugs?q=парацетамол&limit=12 первой строкой возвращает «Парацетамол». То же для «лидокаин», «цитиколин», «дексаметазон». Есть юнит-тест на ранжирование при числе совпадений больше limit.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Роут берёт из БД первые q.limit совпадений в алфавитном порядке: prisma.drug.findMany({ where, orderBy: { nameRu: 'asc' }, skip, take: q.limit }). Только ПОСЛЕ этого он переранжирует страницу функцией rank(), где точное совпадение INN/названия даёт 100. Конструктор назначений запрашивает limit=12 (use-drug-search.ts:56). После импорта госреестра поиск по подстроке в nameRu/inn/id/brands даёт много комбинированных препаратов. Смоделировал на prisma/uzpharm-registry.json: по «парацетамол» 26 совпадений, а сам «Парацетамол» стоит 18-м по алфавиту, после «Аскорбиновая кислота + лоратадин + парацетамол + ...». Курируемые строки добавляют ещё совпадений. В выборку из 12 строк он не попадает, и rank() поднимать нечего. Похожая картина у «цитиколин»: точное совпадение 6-е из 6, запас минимальный.

Сохранение клинического переопределения препарата молча стирает дозировку для пожилых

ГДЕ

src/app/api/crm/clinic-catalog-overlays/route.ts:98, src/server/catalog/clinic-overlay.ts:130, src/app/[locale]/crm/settings/knowledge/_components/drugs-tab.tsx:346, src/app/[locale]/crm/settings/knowledge/_components/drugs-tab.tsx:353, src/app/[locale]/crm/settings/knowledge/_components/drugs-tab.tsx:403, src/app/[locale]/doctor/_components/drug-detail.tsx:244

СЦЕНАРИЙ

Админ открывает «Настройки → Знания → Препараты», у «Бисопролола» меняет только название (например, добавляет бренд) и жмёт «Сохранить переопределение». С этого момента у всех врачей клиники в карточке «Бисопролола» нет строки о дозировке для пожилых. Врач назначает 75-летнему пациенту стандартную стартовую дозу, не увидев предупреждения о медленной титрации.

ПОСЛЕДСТВИЯ

Из клинического справочника пропадает информация о безопасности дозирования у пожилых (бета-блокаторы, варфарин, антидепрессанты). Об этом никто не узнаёт: бейдж «переопределено» не говорит, что именно стёрто.

ЧТО СДЕЛАТЬ

Сделать переопределение по-настоящему частичным. Отправлять на сервер только поля, которые админ реально изменил (diff с глобальной строкой), а defaultDosing сливать по подполям (adult, pediatric, elderly, renal), а не заменять целиком. Добавить поле elderly в форму (и для оверлея, и для edit собственных препаратов). На сервере в sanitizeOverrides отбрасывать null для полей, где null означает «стереть медицинскую информацию», либо требовать явного подтверждения.

КРИТЕРИЙ ПРИЁМКИ

У bisoprolol задаём оверлей только с новым nameRu: в карточке врача остаются adult и elderly из глобальной строки. В форме переопределения есть поле «Пожилым», оно предзаполнено глобальным значением и сохраняется. Сохранение формы без изменений дозировки не меняет defaultDosing в выдаче /api/crm/catalogs/drugs.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Оверлей работает как поверхностная подмена: applyClinicOverlay возвращает { ...row, ...clean }, поэтому объект defaultDosing из оверлея целиком заменяет глобальный. POST /api/crm/clinic-catalog-overlays при переданном overrides полностью перезаписывает overridesJson. Форма переопределения в настройках знаний инициализирует только dosingAdult, dosingPediatric и dosingRenal (drugs-tab.tsx:344-346), и buildDosing() собирает только эти три поля (353-359). saveOverride (403-418) всегда отправляет defaultDosing: buildDosing() вместе с остальными полями. Поле elderly формой не читается и не отправляется. При этом в курируемых данных elderly заполнено у 9 препаратов, например у bisoprolol: 'Стартовая доза 1,25–2,5 мг, медленная титрация' (prisma/_drug-data.ts:467), у варфарина: 'Стартовать с меньших доз, чаще контролировать МНО' (1948). Карточка врача показывает drug.defaultDosing.elderly (drug-detail.tsx:224, 244). Тот же buildDosing используется в режиме edit для собственных препаратов клиники, поэтому elderly теряется и там. Кроме того, если все поля дозировки пусты, buildDosing() возвращает null, а sanitizeOverrides сохраняет null (отбрасывает только undefined), и тогда глобальная дозировка обнуляется целиком.

СТ-11 Р2 · СРЕДНИЙ баг

Справочник МКБ врача: 2315 кодов (главы P, Q, V–Y) недоступны, висит постоянное жёлтое предупреждение, а в браузер уходит 1,2 МБ JSON

ГДЕ

```
src/app/[locale]/doctor/references/_components/icd10-chapters.ts:10, src/app/[locale]/doctor/references/_components/icd10-browser.tsx:16, src/app/[locale]/doctor/references/_components/icd10-browser.tsx:80, src/app/[locale]/doctor/references/_components/icd10-browser.tsx:205, src/app/[locale]/doctor/references/_components/icd10-browser.tsx:84, src/server/icd10/data.ts:17
```

ТАКЖЕ НАШЛИ ЗОНЫ

Остальной кабинет врача

СЦЕНАРИЙ

Невролог хочет посмотреть врождённые аномалии (Q03 гидроцефалия, Q28.2 АВМ сосудов мозга): главы нет. На странице постоянно висит жёлтая плашка про 2315 неклассифицированных кодов. На слабом клиническом ПК страница открывается долго и сразу рендерит главу травм.

ПОСЛЕДСТВИЯ

Раздел справочника неполон и выглядит сломанным. Лишние мегабайт трафика и тяжёлый первый рендер на каждом заходе.

ЧТО СДЕЛАТЬ

Добавить главы P00-P96, Q00-Q99, V01-Y98 (и U, когда появятся коды) в ICD10_CHAPTERS, chapterIdFor и i18n ru/uz. Перевести браузер на серверный API (?range= с пагинацией) вместо импорта data.json в клиент; в data.ts добавить import 'server-only'. По умолчанию открывать G00-G99 или ни одной главы.

КРИТЕРИЙ ПРИЁМКИ

Плашки «Не классифицированы» нет. Главы Q и V–Y открываются. В клиентском бандле страницы /doctor/references нет data.json (в build-анализе чанк страницы меньше 100 КБ).

ДОКАЗАТЕЛЬСТВО В КОДЕ

В ICD10_CHAPTERS 18 глав, нет P00-P96, Q00-Q99, V01-Y98, а chapterIdFor для P, Q, V, W, X, Y возвращает null. В data.json P=335, Q=624, V=768, W=87, X=97, Y=404, то есть 2315 кодов не попадают ни в одну главу. Блок на строках 205-215 показывает врачу предупреждение «Не классифицированы по главам: 2315 кодов». Ящик МКБ в приёме (icd-catalog-drawer.tsx:29-50) при этом знает все 21 главу, так что поведение расходится. icd10-browser.tsx — клиентский компонент ('use client'), и он импортирует ICD10_ENTRIES из '@/server/icd10/data', то есть 1,2 МБ data.json целиком попадает в клиентский бандл (src/lib/icd10-query.ts прямо называет это абсурдом). По умолчанию раскрывается самая большая глава (строки 80-91): S00-T98, 1278 кнопок сразу.

Фильтр «Без рецепта» в справочнике показывает рецептурные препараты (z.coerce.boolean превращает «false» в true)

ГДЕ

src/server/schemas/drug.ts:20, src/app/[locale]/doctor/references/_hooks/use-drug-catalog.ts:71, src/app/api/crm/catalogs/drugs/route.ts:73

СЦЕНАРИЙ

Врач в «Справочники → Препараты» жмёт чип «Без рецепта», чтобы подобрать пациенту что-то безрецептурное. Список содержит только рецептурные препараты с бейджем Rx, ровно противоположное запрошенному.

ПОСЛЕДСТВИЯ

Фильтр справочника перевёрнут. Врач не может быстро найти безрецептурные средства (811 позиций в реестре).

ЧТО СДЕЛАТЬ

Заменить z.coerce.boolean() на z.stringbool() (zod 4) или на z.enum(['true', 'false']).transform(v => v === 'true') для rxOnly, active, withDosing, noPhoto в QueryDrugSchema и в других схемах query-параметров (например, active в QueryLabCatalogSchema).

КРИТЕРИЙ ПРИЁМКИ

GET /api/crm/catalogs/drugs?rxOnly=false возвращает только rxOnly=false. Чип «Без рецепта» показывает препараты без бейджа Rx. Есть юнит-тест схемы на 'false'.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Клиент для ОТС отправляет url.searchParams.set('rxOnly', String(query.rx === 'rx')), то есть rxOnly=false. Схема объявляет rxOnly: z.coerce.boolean().optional(). В zod 4.3.6 это Boolean(input), и Boolean('false') === true. Проверил: z.object({rxOnly: z.coerce.boolean()}).parse({rxOnly:'false'}) даёт { rxOnly: true }. Поэт ставит where.rxOnly = q.rxOnly, то есть true. Та же ловушка у active: z.coerce.boolean() (строка 15) и у withDosing/noPhoto (со значением 'false' они включились бы).

Фото упаковки для препаратов общего справочника не работает: первая загрузка падает с 500, а сохранённая ссылка ведёт в закрытый MiniIO (403)

ГДЕ

src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:70, src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:128, src/app/api/crm/catalogs/drugs/[id]/photo/route.ts:135, prisma/schema.prisma:1279, prisma/schema.prisma:1283, src/server/storage/minio.ts:161

СЦЕНАРИЙ

Врач открывает «Справочники → Препараты», карточку «Толперизон» (общий справочник), жмёт «Добавить фото» и выбирает снимок коробки. Сервер отвечает 500, врач видит тост «Не удалось сохранить фото». Файл при этом уже лежит в бакете. Для препарата, который клиника добавила сама, фото «сохраняется», но в списке и карточке вместо него битая картинка.

ПОСЛЕДСТВИЯ

Функция «фото как в аптеке» в проде только выглядит готовой: кнопка есть, результата нет. В бакете копяся сиротские файлы. Попытка починить её одной строкой (добавить createdById) скроет препараты от врачей.

ЧТО СДЕЛАТЬ

В setOverlayPhoto при create передавать createdById: ctx.userId и явно hideGlobal: false; делать это атомарно через upsert по уникальному ключу clinicId_entityType_entityCode, чтобы не было гонки findFirst→create. Не хранить в photoUrl bare uploadObject().url: хранить ключ объекта (или внутренний путь) и отдавать изображение через сессионный стриминговый прокси (по образцу /api/crm/documents/file с fetchObject), причём ключ жёстко ограничить префиксом drugs/<clinicId>/. Проверять формат по сигнатуре файла (JPEG/PNG/WEBP), а не только по заявленному file.type. Если запись в БД упала, удалять уже загруженный объект.

КРИТЕРИЙ ПРИЁМКИ

Врач загружает фото для препарата общего справочника без оверлея: ответ 200, в ClinicCatalogOverlay появляется строка с hideGlobal=false и createdById врача, препарат остаётся в поиске у всех врачей клиники. Картинка реально отображается в списке, в карточке и в конструкторе назначений (запрос изображения отдаёт 200 с image/*). После неудачной записи в БД новых объектов в бакете не остаётся.

ДОКАЗАТЕЛЬСТВО В КОДЕ

setOverlayPhoto() создаёт оверлей так: `prisma.clinicCatalogOverlay.create({ data: { clinicId, entityType: 'DRUG', entityId: drugId, overridesJson: next } as never })`. В схеме поле 'createdById String' обязательное и без default (schema.prisma:1283; в миграции 20260518130000 это 'createdById TEXT NOT NULL'). Приведение 'as never' прячет ошибку типов. Проверил офлайн на сгенерированном клиенте с недоступной БД: валидация срабатывает до подключения и выдаёт 'PrismaClientValidationError: Argument createdById is missing.'. Через эту ветку (строка 135) идёт весь общий справочник (~2,7 тыс. препаратов с clinicId null), а оверлея у препарата обычно ещё нет. Значит, первая загрузка фото почти для любого препарата заканчивается 500. Файл к этому моменту уже лежит в MinIO (строка 128) и остаётся сиротой, запись в audit не делается. Если просто добавить createdById, всплывает вторая ловушка: hideGlobal не передаётся, а default у него true (schema.prisma:1279), и загрузка фото СКРОЕТ препарат у всей клиники. Третья проблема: даже когда запись проходит (препарат самой клиники или уже существующий оверлей), в photoUrl пишется uploaded.url = MINIO_PUBLIC_URL/bucket/key (minio.ts:161). Это прямой адрес закрытого бакета: nginx /files/ проксирует в MinIO без учётных данных и получает 403 AccessDenied. Для документов и чата это уже подтверждено, там заведены стриминговые прокси-роуты. Комментарий в схеме у Drug.photoUrl обещает внутренний путь /files/..., а не хотлинк; фактически хранится именно хотлинк.

СТ-14 РЗ · НИЗКИЙ бар

Избранное: ошибки POST/DELETE глотаются, при сбое GET звёзды молча пропадают

ГДЕ

src/app/[locale]/doctor/reception/_hooks/use-doctor-favorites.ts:40, src/app/[locale]/doctor/reception/_hooks/use-doctor-favorites.ts:49, src/app/[locale]/doctor/reception/_hooks/use-doctor-favorites.ts:87

СЦЕНАРИЙ

Во время кратковременного сбоя API врач открывает ящик препаратов: все его звёзды исчезли, он решает, что избранное потерялось, и начинает отмечать заново.

ПОСЛЕДСТВИЯ

Сбивает с толку, но данные не теряются.

ЧТО СДЕЛАТЬ

В fetchFavorites бросать ошибку при !res.ok, чтобы TanStack показал ошибку и сохранил кэш. В post/delete бросать при !res.ok. Сериализовать мутации по entityId (например, mutationKey плюс scope) или заблокировать кнопку на время запроса.

КРИТЕРИЙ ПРИЁМКИ

При 500 от /api/crm/doctor-favorites звёзды остаются из кэша и показывается ошибка. При 500 на POST звезда откатывается.

ДОКАЗАТЕЛЬСТВО В КОДЕ

fetchFavorites при !res.ok возвращает [], поэтому 401/500 отображается как «избранного нет». postFavorite и deleteFavorite не проверяют res.ok, поэтому onError (откат оптимистичного апдейта) при 4xx/5xx не вызывается. mutationFn выбирает POST или DELETE по замыканию pinned, и быстрый двойной клик до завершения первого запроса может отправить DELETE раньше, чем закоммитится POST. Сервер на DELETE ответит removed:false, а звезда будет мигать до рефетча.

СТ-15 РЗ · НИЗКИЙ мокап / заглушка

Карточки ~2,5 тыс. препаратов из госреестра показывают технический мусор: «МНН» вида uzr:glyukozamin, бейдж UNKNOWN, инсулин в категории «ЖКТ»

ГДЕ

src/app/[locale]/doctor/_components/drug-detail.tsx:175, src/app/[locale]/doctor/_components/drug-detail.tsx:195, src/app/[locale]/doctor/references/_components/drug-browser.tsx:638, scripts/import-uzpharm-registry.ts:156

СЦЕНАРИЙ

Врач открывает карточку «Глюкозамин» и видит под названием «uzr:glyukozamin», рядом бейдж «UNKNOWN». У «Инсулина аспарт» категория «ЖКТ».

ПОСЛЕДСТВИЯ

Справочник выглядит недоделанным, врачи теряют доверие к данным. Неверная категория вводит в заблуждение при фильтрации и чтении карточки.

ЧТО СДЕЛАТЬ

Не показывать inn с префиксом uzr: нигде (DrugDetailView, tooltip в prescription-constructor, админская таблица);

лучше хранить реальное латинское МНН или null в отдельном поле. Локализовать бейдж беременности, для UNKNOWN показывать «нет данных» или скрывать. Исправить маппинг ATC → категория (A10 → ENDOCRINE, M03 → NEUROLOGICAL или отдельная категория) и перезаписать category у строк uzr-.*.

КРИТЕРИЙ ПРИЁМКИ

Ни в одной карточке нет строки, начинающейся с 'uzr:'. Бейдж беременности локализован на ru и uz. У метформина и инсулинов категория «Эндокринология».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Импорт пишет inn: e.inn, а в реестре это синтетические хэндлы 'uzr:glyukozamin', 'uzr:risperidon' (prisma/uzpharm-registry.json). В списке справочника они скрыты (drug-browser.tsx:571-575, проверка startsWith('uzr:')), но DrugDetailView выводит drug.inn курсивом под названием, если он не равен nameRu (drug-detail.tsx:175-176). Так в карточке и справочника, и ящика назначения появляется «uzr:glyukozamin». В строке списка и в карточке категория беременности выводится сырым enum ({drug.pregnancyCat}, drug-browser.tsx:638, drug-detail.tsx:195), и у всех строк реестра это «UNKNOWN» латиницей. Маппинг категорий в JSON относит ATC A10 (метформин, инсулин аспарт, эмпаглифлозин) к GI, хотя в enum есть ENDOCRINE, а миорелаксанты M03 (толперизон) к OTHER.

СТ-16 РЗ · НИЗКИЙ баг

Код МКБ, набранный кириллицей (M54.5, C06.0), ничего не находит

ГДЕ

src/server/icd10/search.ts:96, src/server/icd10/search.ts:197, src/lib/icd10-query.ts:18

СЦЕНАРИЙ

Врач на русской раскладке набирает «M54.5» (буква М кириллическая). Список пуст, врач решает, что кода нет, и вводит диагноз свободным текстом без кода.

ПОСЛЕДСТВИЯ

Поиск по коду, самый быстрый путь для опытного врача, для половины букв молча не работает. Это ещё один источник диагнозов без кода.

ЧТО СДЕЛАТЬ

В normalizeIcdTerm (или отдельно в ветке кодового запроса) транслитерировать кириллические двойники в латиницу, если строка похожа на код (буква + 2 цифры). Дополнительно поддержать раскладочную подмену (П43 → G43). То же сделать в parseCodeNameQuery и looksLikeIcdCode, чтобы кириллический код не выучивался как новый «клинический» код.

КРИТЕРИЙ ПРИЁМКИ

searchIcd10('м54.5')[0].code === 'M54.5', searchIcd10('C06')[0].code начинается с 'S06'.

parseCodeNameQuery('M54.5 Люмбаго') возвращает code 'M54.5' латиницей.

ДОКАЗАТЕЛЬСТВО В КОДЕ

normalizeIcdTerm только приводит к нижнему регистру и меняет ё на е. scoreOne сравнивает row.code (латиница, 'm54.5') с термином. Кириллические М, С, Е, Т, Н, К, Р, А, В, О, Х визуально неотличимы от латинских, а на русской раскладке врач набирает именно их. Прогон: searchIcd10('м54.5') → [], searchIcd10('M51') → []. parseCodeNameQuery требует [A-Za-z] в первом символе, поэтому опция «код + название» для 'M54.5 Люмбаго' тоже не появляется.

СТ-17 РЗ · НИЗКИЙ баг

Оверлей каталога принимает переопределения без проверки типов, и пустой патч при создании скрывает запись

ГДЕ

src/app/api/crm/clinic-catalog-overlays/route.ts:46, src/app/api/crm/clinic-catalog-overlays/route.ts:153, src/server/catalog/clinic-overlay.ts:79

СЦЕНАРИЙ

Интеграция или ручной запрос админа отправляет contraindications одной строкой. У всех врачей карточка этого препарата падает с ошибкой рендера.

ПОСЛЕДСТВИЯ

Одной некорректной правкой можно сломать карточку препарата для всей клиники или случайно скрыть препарат.

ЧТО СДЕЛАТЬ

Для каждого entityType описать zod-схему переопределений с типами (строки, массивы строк, объект дозировки

с известными ключами, photoUrl только внутреннего формата) и валидировать на входе. При create с overrides, но пустым sanitized возвращать 400, а не создавать скрытую запись.

КРИТЕРИЙ ПРИЁМКИ

POST с contraindications строкой возвращает 400. POST с overrides {} на новый код возвращает 400 и не создаёт hideGlobal=true.

ДОКАЗАТЕЛЬСТВО В КОДЕ

overrides задан как z.record(z.string(), z.unknown()). sanitizeOverrides отбирает ключи по whitelist, но не проверяет типы. contraindications строкой, defaultDosing.adult объектом или photoUrl на внешний хост сохраняются как есть. DrugDetailView делает BulletList items.map по contraindications, и строка вместо массива роняет карточку (React error). При создании: hideGlobal: body.hideGlobal ?? sanitized == null. Если прислать overrides {} или только неизвестные ключи, sanitized будет null, и запись создастся СКРЫТОЙ, хотя вызывающий хотел переопределение, а не скрытие.

СТ-18 РЗ · НИЗКИЙ баг

Поиск по справочникам не видит клинические переименования, а фильтр Rx игнорирует переопределённый rxOnly

ГДЕ

src/app/api/crm/catalogs/drugs/route.ts:96, src/app/api/crm/catalogs/handouts/route.ts:37, src/server/catalog/clinic-overlay.ts:120

СЦЕНАРИЙ

Админ переименовал памятку «HTN_LIFESTYLE» в «Давление: образ жизни». Врач ищет «давление» в ящике памяток и ничего не находит.

ПОСЛЕДСТВИЯ

Клинические правки справочника работают только частично, врачи их не находят.

ЧТО СДЕЛАТЬ

Перед SQL-выборкой находить коды оверлеев, у которых нужное поле (название, rxOnly) совпадает с запросом, и добавлять их в OR по id/code; либо для небольших каталогов (памятки) фильтровать после наложения оверлея.

КРИТЕРИЙ ПРИЁМКИ

Поиск по новому названию переопределённого препарата или памятки находит его. Препарат с оверлеем rxOnly=false находится фильтром «Без рецепта».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поиск q и фильтр rxOnly применяются в SQL к исходным колонкам глобальной строки (nameRu, nameUz, titleRu, summaryRu, rxOnly), а оверлей накладывается уже после выборки (applyClinicOverlay). Препарат или памятку, которую клиника переименовала через overrides, по новому названию не найти. Препарат с переопределённым rxOnly=false не попадает в фильтр «Без рецепта», хотя в карточке помечен как безрецептурный.

СТ-19 РЗ · НИЗКИЙ баг

Режим «Без фото» никогда не убывает, счётчики справочника расходятся со списком

ГДЕ

src/app/api/crm/catalogs/drugs/route.ts:81, src/app/api/crm/catalogs/drugs/facets/route.ts:20, src/app/[locale]/doctor/references/_components/drug-browser.tsx:257

СЦЕНАРИЙ

Медсестра или врач фотографирует коробки по списку «Без фото». Уже сфотографированные препараты остаются в списке, прогресс не виден, конца у работы нет.

ПОСЛЕДСТВИЯ

Рабочий режим заполнения фото не выполняет свою задачу, счётчики вводят в заблуждение.

ЧТО СДЕЛАТЬ

Для noPhoto исключать и глобальные строки, у которых в оверлее клиники есть photoUrl (фильтр по id из loadClinicOverlays), либо фильтровать на клиенте. В facets применять тот же where, что в списке (active: true, минус hidden). Убрать или вывести photoCount.

КРИТЕРИЙ ПРИЁМКИ

После загрузки фото препарат исчезает из режима «Без фото» после инвалидации. Сумма по рельсу АТС плюс «без АТС» равна числу строк, которое можно пролистать в «Все».

ДОКАЗАТЕЛЬСТВО В КОДЕ

noPhoto фильтрует только глобальную колонку where.photoUrl = null. Комментарий обещает, что строка с фото из оверлея «drops out of the list once the page renders it as done», но в DrugBrowser клиентской фильтрации нет: строки с наложенным photoUrl остаются в списке. Facets считает total, byGroup, rxCount и photoCount по всем строкам без active: true и без скрытых оверлеев, а список показывает только active и нескрытые. Поэтому цифры в рельсе АТС и «Все N» не совпадают с тем, что реально листается. photoCount считает только глобальную колонку и в UI нигде не используется. total в списке включает скрытые строки, отсюда «Показано X из Y» с завышенным Y.

СТ-20 РЗ · НИЗКИЙ целостность данных

Сохранение или сброс переопределения админом стирает фото упаковки, загруженное врачом

ГДЕ

src/app/api/crm/clinic-catalog-overlays/route.ts:105, src/app/[locale]/crm/settings/knowledge/_components/drugs-tab.tsx:403, src/app/[locale]/crm/settings/knowledge/_components/drugs-tab.tsx:420, src/server/catalog/clinic-overlay.ts:35

СЦЕНАРИЙ

Врач сфотографировал коробку «Мидокалма» (после починки загрузки). Админ через неделю исправляет у этого препарата название или жмёт «Сбросить переопределение», и фото пропадает у всей клиники без предупреждения.

ПОСЛЕДСТВИЯ

Молча теряется контент, который врачи вносили вручную. Бейдж «Переопределено» вводит админа в заблуждение.

ЧТО СДЕЛАТЬ

Хранить фото отдельно от текстовых переопределений (отдельная колонка или таблица), либо в POST сливать новый патч с существующим overridesJson и сохранять photoUrl. Сброс переопределения не должен трогать photoUrl. Флаг clinicOverridden считать без учёта photoUrl.

КРИТЕРИЙ ПРИЁМКИ

У препарата с фото админ сохраняет и сбрасывает переопределение: photoUrl в выдаче /api/crm/catalogs/drugs сохраняется. Препарат только с фото не помечен clinicOverridden.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Фото упаковки для глобального препарата хранится в том же overridesJson (whitelist DRUG включает photoUrl, clinic-overlay.ts:35; запись идёт через setOverlayPhoto). POST /api/crm/clinic-catalog-overlays при наличии overrides целиком заменяет колонку: overridesJson: sanitized ?? Prisma.JsonNull (строки 105-111). Админская форма (saveOverride, drugs-tab.tsx:403-418) photoUrl не отправляет, а resetOverride (420-428) шлёт overrides: null. Кроме того, applyClinicOverlay помечает строку clinicOverridden=true, даже если в патче есть только photoUrl, и админ видит «Переопределено» и кнопку «Сбросить» у препарата, который он не трогал.

INF · Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

INF-01 P2 · СРЕДНИЙ мокап / заглушка

/api/health всегда отвечает workers: ok (заглушка): сторож не видит упавший воркер, Sentry не установлен

ГДЕ

src/app/api/health/route.ts:122, ops/watchdog.sh:58, ops/deploy.sh:47, src/instrumentation.ts:38, src/app/api/internal/metrics/route.ts:29, src/app/api/health/route.ts:77

СЦЕНАРИЙ

Воркер уходит в рестарт-цикл: не хватает env после правки .env, падает при старте, ловит OOM. Сторож каждые 5 минут получает от /api/health status=ok, workers=ok и молчит. Пациенты перестают получать напоминания, заключения в Mini App не появляются, на ресепшне не срабатывает живое обновление по подтверждениям. Клиника узнаёт о проблеме от пациентов через несколько дней.

ПОСЛЕДСТВИЯ

Весь фоновый контур клиники (напоминания, выдача документов, авто-неявки, realtime через outbox) может молча лежать днями. Мониторинг создаёт ложное ощущение, что всё в порядке.

ЧТО СДЕЛАТЬ

Сделать реальный пульс воркера: каждый тик планировщиков и outbox-pumper пишет в Redis ключ worker:heartbeat с TTL, например 120 с. В health читать возраст пульса, возраст самой старой PENDING-строки EventOutbox и число DEAD, возраст самого старого QUEUED NotificationSend с scheduledFor<now. По ним выставлять workers=down/degraded. Добавить healthcheck контейнеру worker. Установить @sentry/nextjs и задать DSN либо убрать мёртвый код. Для checkRedis переиспользовать один клиент. Не отдавать текст ошибок наружу.

КРИТЕРИЙ ПРИЁМКИ

Остановить контейнер worker: в течение 2 минут /api/health показывает workers.status != ok и общий status=degraded, сторож присылает алерт в Telegram. После запуска воркера статус возвращается в ok. При PENDING-строке outbox старше 1 минуты health тоже degraded.

ДОКАЗАТЕЛЬСТВО В КОДЕ

checkWorkers() (health/route.ts:122-133) ничего не проверяет и жёстко возвращает `{ status: "ok", queues: ["notifications:send", "notifications:scheduler", "exports"] }`. Комментарий в том же месте признаёт, что реальную живость воркера надо проверять иначе. ops/watchdog.sh:58-62 считает систему здоровой, если в JSON есть `workers":{"status":"ok"`, а это условие выполняется всегда. При этом ops/deploy.sh:47-48 прямо пишет: «the live worker container is in a known restart loop». В контейнере worker (docker-compose.yml:98-116) нет healthcheck. Все фоновые механики живут только в воркере: outbox-pumper (без него не доходит ни одно v2-событие: подтверждение записи, visit-note.finalized, patient.arrived), напоминания, авто-NO_SHOW, выдача заключений пациенту, напоминания о лекарствах. Sentry отключён фактически: instrumentation.ts:38 динамически импортирует @sentry/nextjs, а этого пакета нет в package.json. /api/internal/metrics в проде без METRICS_TOKEN отвечает 503 (route.ts:29-32), а в .env.example такой переменной нет. Сами метрики (metrics.ts:208-258) покрывают только mini-app: нет ни возраста очереди, ни DEAD-строк outbox, ни пульса воркера. Попутно: checkRedis (health/route.ts:77) на КАЖДЫЙ публичный вызов без авторизации открывает новое TCP-соединение к Redis, а в поле error наружу уходит текст ошибок БД.

INF-02 P2 · СРЕДНИЙ баг

CSV-экспорт отдаёт неверные данные: суммы в тийинах, строки теряются и задваиваются при пагинации, фильтры экрана игнорируются

ГДЕ

src/server/workers/exports.ts:130, src/server/workers/exports.ts:199, src/server/workers/exports.ts:147, src/server/workers/exports.ts:61, src/app/[locale]/crm/appointments/_components/export-button.tsx:25, src/app/[locale]/crm/appointments/_components/export-button.tsx:21, src/app/[locale]/crm/appointments/_components/export-button.tsx:35, src/app/api/crm/exports/route.ts:34, src/server/workers/exports.ts:185

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

Бухгалтер выгружает платежи за месяц и видит «15000000» вместо 150 000 сум. В сводке сумма в 100 раз больше. Админ фильтрует «Записи → Сегодня» и жмёт «Экспорт», а получает всю базу за всё время, где на стыках страниц часть визитов в 09:00 отсутствует, а часть повторяется.

ПОСЛЕДСТВИЯ

Финансовые и операционные выгрузки неверны: деньги ×100, пропуски и дубли строк, не тот набор данных. PHI-файлы копятя в контейнере.

ЧТО СДЕЛАТЬ

Денежные поля делить на 100 (или назвать колонки *_tiyin и добавить *_sum). orderBy [{date:'desc'}, {id:'desc'}] (и для createdAt тоже). Применять q, исключать deletedAt, передавать из кнопки те же фильтры, что у списка (включая dateMode через tashkentDayBounds), валидировать даты в Zod-схеме маршрута. Хранить задачи в БД и файлы в MinIO с TTL (как DataExportJob) или удалять файл после скачивания или через час.

КРИТЕРИЙ ПРИЁМКИ

Платёж 150 000 сум в CSV выглядит как 150000.00. Тест на 1200 записях с одинаковым временем: в экспорте ровно 1200 уникальных id. Экспорт при фильтре «Сегодня» содержит только сегодняшние записи. /tmp/exports очищается.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Колонки amount (стр. 130), priceFinal (стр. 122), ltv и balance (стр. 106-107) пишутся как есть. Это Int в тийнах, а formatMoney в UI делит на 100. Заголовок про единицы ничего не говорит. Пагинация: `orderBy: { date: "desc" }, take: 500, cursor: { id }, skip: 1` (стр. 197-201). date не уникален: записи на 09:00 к разным врачам совпадают. Курсорная пагинация Prisma по неуникальному полю без вторичного ключа теряет или дублирует строки на границе страниц (у пациентов и платежей createdAt, стр. 163 и 236). В ExportFilters есть q (стр. 31), но exportPatients его не применяет, а мягко удалённых (deletedAt) не исключает (стр. 147-176). Кнопка экспорта записей передаёт только doctorId/status/from/to (export-button.tsx:25-34), игнорируя dateMode (сегодня/завтра), bucket, канал и поиск. «from» с маркером атрибуции (`?from=ai-rec`) превращается в new Date('ai-rec') → Invalid Date → экспорт падает. Реестр задач это in-memory Map (стр. 64), файлы с PHI пишутся в /tmp/exports (стр. 61, 283-286) и никогда не удаляются, а после деплоя задача отдаёт 404.

INF-03 P2 · СРЕДНИЙ эксплуатация

Certbot обновляет сертификат, но nginx его не перечитывает (обещанного reload нет)

ГДЕ

docker-compose.yml:138, ops/crontab.example:11

СЦЕНАРИЙ

Месяц без деплоев (праздники, заморозка). Certbot за 30 дней до истечения обновил файлы, но nginx продолжает отдавать старый сертификат. В день истечения neurofax.uz и все соседние сайты за этим nginx показывают ошибку TLS. Mini App и CRM недоступны.

ПОСЛЕДСТВИЯ

Периодически гарантированный полный простой клиники и соседей при паузе в деплоях.

ЧТО СДЕЛАТЬ

Добавить на хосте cron `docker exec medbook-nginx-1 nginx -s reload` раз в сутки, либо deploy-hook, который пишет флаг, и отдельный watcher. Мониторить срок сертификата в watchdog (openssl s_client, алерт за 14 дней).

КРИТЕРИЙ ПРИЁМКИ

После `certbot renew --force-renewal` в течение суток `openssl s\_client -connect neurofax.uz:443` показывает новый notAfter без ручного деплоя. Сторож предупреждает о сертификате, который истекает меньше чем через 14 дней.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий «Renewal loop: try every 12h; reload nginx on success» (docker-compose.yml:138), а entrypoint выполняет только `certbot renew --webroot -w /var/www/certbot --quiet; sleep 12h` (стр. 139-144). deploy-hook нет, доступа к docker у контейнера certbot нет. В crontab.example (стр. 11) только бэкап, reload nginx нет. nginx держит старый сертификат в памяти до reload или рестарта. Сейчас это маскируется тем, что _deploy.sh делает `nginx -s reload` при каждом деплое.

INF-04 P2 · СРЕДНИЙ производительность

EventOutbox растёт бесконечно: воркер каждые 200 мс сканирует всю таблицу, каждый автосейв врача пишет строку, PHI хранится вечно

ГДЕ

src/server/workers/outbox-pumper.ts:69, prisma/schema.prisma:2790, src/app/api/crm/visit-notes/[id]/route.ts:239, src/app/api/miniapp/appointments/[id]/checkin/route.ts:101, src/server/workers/data-deletion.ts:80, src/server/workers/outbox-pumper.ts:149, src/server/workers/outbox-pumper.ts:70, prisma/schema.prisma:2804

ТАКЖЕ НАШЛИ ЗОНЫ

Telegram-бот, переписки, рассылки, уведомления, воркеры

СЦЕНАРИЙ

Через год работы в EventOutbox сотни тысяч строк, большинство из них автосейвы черновиков. Общий VPS с десятком соседних проектов 5 раз в секунду сканирует эту таблицу, и CPU Postgres постоянно занят. Пациент просит удалить его данные: после анонимизации его ФИО остаётся в envelope событий «Я на месте» и в AuditLog.

ПОСЛЕДСТВИЯ

Постоянно растущая нагрузка на общую БД, задержка всех живых событий ≥ 1 с. Нарушение «права на забвение»: PHI остаётся в служебных таблицах бессрочно.

ЧТО СДЕЛАТЬ

Частичный индекс `CREATE INDEX ON "EventOutbox"("createdAt") WHERE status IN ('PENDING','FAILED')`. Ретеншн-тик: удалять DELIVERED старше 7 дней, DEAD старше 30 дней. Не писать visit-note.draftSaved в outbox (или слать через publishEventSafe без хранения). Для attempts=0 без задержки. Транзакцию только на захват строк, отметку DELIVERED делать отдельно по строке. В DSAR-скраб добавить EventOutbox (удалить по patientId в tenantScope) и маскирование имени в AuditLog.meta.

КРИТЕРИЙ ПРИЁМКИ

EXPLAIN запроса pumper использует частичный индекс. После ретеншн-тика в таблице нет DELIVERED старше 7 дней. Автосейв не создаёт строк EventOutbox. Задержка v2-события до клиента <300 мс. После анонимизации поиск ФИО пациента по envelope пуст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

lockBatch: ``WHERE status IN ('PENDING','FAILED') AND ("createdAt" + ((1 <= attempts) * INTERVAL '1 second')) <= NOW() ORDER BY "createdAt" LIMIT 100 FOR UPDATE SKIP LOCKED`` без фильтра по clinicId (стр. 69-79). Индексы EventOutbox начинаются с clinicId (schema.prisma:2804-2807), поэтому каждые 200 мс идёт полный скан таблицы или индекса. Удаления старых строк нет: grep не находит eventOutbox.delete*. На каждый debounced-автосейв заметки (~1,5 с при наборе) пишется строка visit-note.draftSaved (visit-notes/[id]/route.ts:239-266), при этом ни один клиент это событие не слушает (mini-app его отфильтровывает, в CRM подписок нет). В envelope лежит PHI: например, patient.arrived с полным patientName (checkin/route.ts:101). scrubPatientPhiCarriers при DSAR-анонимизации outbox и AuditLog.meta не чистит (data-deletion.ts:80-115). При attempts=0 окно `1<0` секунда означает минимальную задержку каждого v2-события ≥ 1 с, хотя комментарий в start.ts обещает «well under 1s». Весь батч с broadcast и audit-записями через отдельное соединение идёт в одной интерактивной транзакции с дефолтным таймаутом Prisma 5 с (стр. 149-186). При медленном Redis транзакция истекает, строки откатываются в PENDING и перерассылаются снова.

INF-05 P2 · СРЕДНИЙ безопасность

Postgres/Redis/MinIO медицинской системы в одной docker-сети с десятком чужих проектов; Redis без пароля; общие имена сервисов

ГДЕ

docker-compose.yml:43, docker-compose.yml:80, nginx/conf.d/orientatravel.conf:5, nginx/nginx.conf:59, docs/operations/DEPLOY.md:118

СЦЕНАРИЙ

У стороннего сайта турагентства на том же сервере RCE-уязвимость в Next.js. Из его контейнера атакующий подключается к redis:6379 без пароля. Он делает PUBLISH events:<clinicId> с поддельными tg.message.new и patient.arrived, и эти события получают все экраны ресепшна и табло. FLUSHALL стирает планировщики BullMQ, и напоминания пациентам прекращаются. Отдельный сценарий: сосед поднимает сервис с именем app или redis, и часть запросов neurofax.uz nginx отправляет в чужой контейнер.

ПОСЛЕДСТВИЯ

Компрометация любого из ~10 посторонних проектов даёт прямой сетевой доступ к очередям и шине событий клиники, а при слабых паролях и к БД с PHI. Коллизия имён способна увести трафик пациентов в чужое приложение.

ЧТО СДЕЛАТЬ

Выделить внутреннюю сеть `medbook_internal` (postgres, redis, minio, app, worker) с `internal: true`. nginx подключить к ней и к отдельной edge-сети, соседей держать только в edge. Включить `requirepass` (или ACL) в Redis и передавать пароль в `REDIS_URL`. Использовать уникальные алиасы (`medbook-app`, `medbook-redis`). Убрать дефолтные пароли из `compose` (обязательные переменные через `${VAR:?}`).

КРИТЕРИЙ ПРИЁМКИ

Из контейнера соседнего проекта ``redis-cli -h redis ping`` и ``nc postgres 5432`` не проходят. ``redis-cli`` без пароля внутри `medbook`-сети возвращает `NOAUTH`. `docker compose config` падает без `POSTGRES_PASSWORD`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В `docker-compose.yml` нет собственных сетей, все сервисы сидят в `medbook_default`. Redis запущен без `--requirepass` (стр. 43), приложение ходит к нему как `REDIS_URL: redis://redis:6379` (стр. 80). Postgres и MinIO имеют дефолты паролей ``${POSTGRES_PASSWORD:-medbook}`` и ``${MINIO_SECRET_KEY:-medbook-secret-min-8}`` (стр. 28, 60). Соседние проекты подключаются к этой же сети: `orientatravel.conf:5` («The container joins `medbook\_default` so name-based DNS works»), а `DEPLOY.md:118-121` перечисляет `rtxshop`, `orientatravel`, `natus`, `tizim`, `termogrom`, `travel-crm`, `tcn-bot` и других за тем же nginx. Upstream nginx и приложения адресуются общими именами `app:3000`, `redis`, `postgres`, `minio` (`nginx.conf:59-66`). Если у соседа в этой сети сервис с таким же именем, Docker DNS начинает раздавать оба адреса по кругу.

INF-06 P2 · СРЕДНИЙ мёртвая механика

Replay SSE в CRM мёртвый: после любого обрыва события за время разрыва теряются, и данные ничем не обновляются

ГДЕ

`src/hooks/use-live-events.ts:129`, `src/hooks/use-live-events.ts:160`, `src/app/api/events/route.ts:103`, `src/app/api/events/route.ts:155`, `src/components/providers/query-provider.tsx:31`, `src/app/[locale]/doctor/my-day/_hooks/use-doctor-today.ts:174`

СЦЕНАРИЙ

Деплой: app пересоздаётся, у всех вкладок CRM SSE рвётся на 30–60 с. В это время администратор отмечает пациента «Пришёл». Кабинет врача переподключается без догонки и продолжает показывать пациента как «ожидается», пока не придёт следующее событие по этому врачу. Врач не вызывает пациента, тот ждёт.

ПОСЛЕДСТВИЯ

После каждого деплоя, моргания Wi-Fi или сна ноутбука экраны врача и ресепшна показывают устаревшие статусы. Реализованная серверная догонка создаёт видимость надёжности, которой нет.

ЧТО СДЕЛАТЬ

Хранить последний `eventId` в общем `SharedSource` и переподключаться с `?since=<id>`. В CRM-маршруте отправлять ``event: cursor-too-old``, клиент по нему (и по любому переподключению после разрыва) делает `qs.invalidateQueries` для живых ключей. Добавить в маршрут сигнал об усечении (`REPLAY_LIMIT`).

КРИТЕРИЙ ПРИЁМКИ

Разорвать SSE (перезапустить app), за время разрыва изменить статус записи. После переподключения экран врача обновляется сам в пределах 5 с. В network виден запрос `/api/events?since=<id>`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Сервер `/api/events` умеет догонять пропущенное по `Last-Event-ID/?since` (`route.ts:103-106`, `145-177`). Но CRM-клиент на `onerror` закрывает `EventSource` и через бэкофф 1–30 с создаёт НОВЫЙ ``new EventSource("/api/events")`` без `?since` (`use-live-events.ts:129`, `160-176`). Новый объект `EventSource` не шлёт `Last-Event-ID`, а в `src/hooks`, `src/app/[locale]` и `src/components` нет ни одного `since/lastEventId`. На `onopen` кэш не инвалидируется. `QueryClient` в CRM: `refetchOnWindowFocus` и `refetchOnReconnect` выключены (`query-provider.tsx:31-32`, «data the SSE stream already pushes»). «Мой день» врача (`use-doctor-today.ts:174`) опирается только на SSE, без `refetchInterval`. Сигнал ``cursor-too-old`` в CRM-маршруте отправляется SSE-комментарием (`route.ts:155`), а JS такие строки не видит. В mini-app маршруте это уже исправлено на именованное событие.

S3/admin API MinIO публично открыт на `https://neurofax.uz/files/`, хотя приложение этот путь больше не использует

ГДЕ

`nginx/nginx.conf:144`, `docker-compose.yml:59`, `.env.example:40`

СЦЕНАРИЙ

Атакующий из интернета подбирает ключи root-учётки MinIO через `https://neurofax.uz/files/` (стандартный S3-клиент, endpoint с путём). Если в `.env` остался предсказуемый ключ, он скачивает весь бакет: заключения, направления, вложения чатов, паспорта.

ПОСЛЕДСТВИЯ

Публичная поверхность атаки на хранилище всех медицинских документов при нулевой пользе для приложения.

ЧТО СДЕЛАТЬ

Удалить location `/files/` (или оставить только конкретные нужные пути с `allow/deny`). Сменить root-ключи MinIO и завести для приложения отдельного пользователя с политикой только на нужные бакеты. Убрать дефолты из `compose`.

КРИТЕРИЙ ПРИЁМКИ

``curl -s -o /dev/null -w '%{http_code}' https://neurofax.uz/files/minio/health/live`` возвращает 404. Приложение продолжает отдавать документы через `/api*/file`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

``location /files/ { proxy_pass http://medbook_minio/; ... client_max_body_size 100m; }`` (`nginx.conf:144-157`) проксирует весь корень MinIO: S3 API, `/minio/admin/v3/*` и `/minio/health/*`. Приложение `/files/` не использует: комментарии в `api/crm/documents/file/route.ts:5-8`, `api/crm/conversations/[id]/attachments/file/route.ts:12-14` и `miniapp/documents/[id]/file/route.ts:5` прямо говорят, что `presigned URL` через `/files/` ломаются (`SignatureDoesNotMatch`) и файлы отдаются через потоковые прокси приложения. Root-учётка MinIO одна на всё, с дефолтами ``${MINIO_ACCESS_KEY:-medbook}`` и ``${MINIO_SECRET_KEY:-medbook-secret-min-8}`` (`docker-compose.yml:59-60`). В `.env.example` `MINIO_ACCESS_KEY=medbook` (стр. 40). На `/files/` нет ни `rate-limit`, ни ограничения по IP.

Бэкап не содержит ключей шифрования и конфигов: после потери сервера зашифрованные поля не восстановит

ГДЕ

`ops/backup.sh:53`, `ops/backup.sh:98`, `src/server/crypto/field-cipher.ts:108`, `src/server/crypto/secrets.ts:37`, `docs/operations/DEPLOY.md:124`

СЦЕНАРИЙ

Диск на Hetzner умирает. Дамп с ноутбука владельца разворачивается на новом сервере, но `.env` не сохранён. Паспорта, заметки о пациентах, SOAP-черновики и заметки к назначениям не читаются, врачам с 2FA не войти, боты клиник не работают. Воссоздать инфраструктуру (`compose`, `nginx` с `vhost`'ами соседей, `_deploy.sh`) тоже не из чего.

ПОСЛЕДСТВИЯ

При катастрофе безвозвратно теряется часть медицинских данных и растягивается простой клиники. Незашифрованные дампы с PHI лежат на диске и уходят на внешние хосты.

ЧТО СДЕЛАТЬ

Сделать `BACKUP_REMOTE` обязательным (без него алерт или `exit≠0`). Отдельно, зашифрованным офлайн-ключом (`age/gpg`), сохранять `.env`, `prod-compose`, `nginx/conf.d` и `_deploy.sh`. Шифровать дампы и `tar` с файлами перед `rsync`. Задokumentировать эскроу ключей (кто и где хранит `FIELD_ENCRYPTION_KEY`).

КРИТЕРИЙ ПРИЁМКИ

Учения: чистый сервер, последний off-box бэкап, ключ из эскроу → прод поднимается, `passport` и `soapDraft` расшифровываются. `backup.sh` без `BACKUP_REMOTE` шлёт алерт.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`backup.sh` сохраняет только `pg_dump` (стр. 53-55) и зеркало бакета MinIO (стр. 74-79). Копия вне сервера включается лишь при заданном `BACKUP_REMOTE`, иначе только лог «backups exist only on this disk» (стр. 98-117). По RUNBOOK §4 копия лежит на том же сервере, наружу её забирают вручную через `rsync`. В бэкап не

падают .env и ключи: FIELD_ENCRYPTION_KEY(_V<n>) (field-cipher.ts:92-114, этим ключом шифруются Patient.passport/notes, MedicalCase.soapDraft, Prescription.notes, TOTP-секреты) и APP_SECRET (secrets.ts:37, токены ботов клиник). Не попадают также неотслеживаемый _deploy.sh и skip-worktree прод-версии docker-compose.yml/nginx.conf (DEPLOY.md:124-126, 152-160, 347-349). Шифрования самого дампа нет: PHI лежит в открытом gzip на диске и так же уезжает по rsync.

INF-09 P2 · СРЕДНИЙ баг

Напоминания о лекарствах перестанут приходить новым пациентам: выборка 500 рецептов без сортировки, а рецепты никогда не завершаются

ГДЕ

src/server/workers/medication-reminder.ts:113, src/server/workers/medication-reminder.ts:148, prisma/schema.prisma:3085, src/lib/patient-experience/medication-schedule.ts:162

СЦЕНАРИЙ

Через несколько месяцев в базе больше 500 ACTIVE-рецептов с напоминаниями, большинство уже с закончившимся курсом. Врач сегодня назначает пациенту курс «карбамазепин 2 раза в день». Тик берёт первые 500 старых строк, нового рецепта среди них нет, и напоминания не приходят вообще. Ошибок в логах нет.

ПОСЛЕДСТВИЯ

Пациенты молча перестают получать напоминания о приёме препаратов (медицинский риск пропуска доз), причём именно самые свежие назначения.

ЧТО СДЕЛАТЬ

Хранить дату окончания курса (endsAt) и по её наступлении переводить рецепт в COMPLETED (отдельный тик или прямо в этом). Фильтровать в SQL только действующие (endsAt IS NULL OR endsAt > now). Проходить все строки курсором по id, а не take 500. Добавить метрику «просканировано/создано».

КРИТЕРИЙ ПРИЁМКИ

Тест: 600 ACTIVE-рецептов с истёкшим курсом и 1 новый. Тик создаёт MedicationReminderSend для нового. Истёкшие переходят в COMPLETED и в следующих тиках не сканируются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

runMedicationReminderTick выбирает `prescription.findMany({ where: { status: "ACTIVE", remindersEnabled: true, clinic: { medicationRemindersEnabled: true }, patient: { deletedAt: null } }, take: 500 })` БЕЗ orderBy и без пагинации (стр. 113-148). Запрос идёт в SYSTEM-контексте, то есть по всем клиникам. Prescription.status это строка с default "ACTIVE" (schema.prisma:3085). В коде нет пути, который переводит рецепт в COMPLETED по окончании курса: isPrescriptionDueInWindow (medication-schedule.ts:162-167) просто возвращает null после startsAt+days, а строка остаётся ACTIVE. Мост визитов (visit-note-handout.ts, runMedicationBridgeTick) создаёт Prescription на каждое назначение с remindPatient=true по каждому финализированному визиту. В проде уже 441 VisitNote (RUNBOOK), так что пул ACTIVE растёт монотонно. Postgres без ORDER BY отдаёт строки в порядке кучи, то есть в основном старые.

INF-10 P2 · СРЕДНИЙ безопасность

Публичный SSE табло раздаёт appointmentId всех записей, а /api/queue/status/:id по этому id отдаёт данные пациента кому угодно

ГДЕ

src/server/realtime/board-stream.ts:47, src/app/api/c/[slug]/queue/events/route.ts:72, src/app/api/queue/status/[id]/route.ts:17, src/app/api/queue/status/[id]/route.ts:83, src/server/clinic-public/resolve.ts:1, src/app/q/[id]/page.tsx:100, src/app/api/c/[slug]/queue/board/route.ts:95, src/lib/format.ts:328, src/app/api/queue/status/[id]/route.ts:20, src/app/ticket/[id]/page.tsx:25

ТАКЖЕ НАШЛИ ЗОНЫ

Живая очередь, киоск, ТВ-табло, талоны

СЦЕНАРИЙ

Посторонний знает slug neurofax (он есть в ссылке Mini App) и открывает в браузере <https://neurofax.uz/api/c/neurofax/queue/events>. Ресепшн или Mini App создаёт запись, в поток падает appointment.created с appointmentId. GET /api/queue/status/<id> возвращает: «А. К., врач Иванов, услуга: ЭЭГ, 14:30, BOOKED». Так за день собирается журнал всех визитов в неврологическую клинику с инициалами, врачом и услугой.

ПОСЛЕДСТВИЯ

Утечка медицинских сведений (факт обращения к неврологу, услуга, время, статус, инициалы) любому анониму

в интернете. Плюс вектор DoS через неограниченные SSE-соединения.

ЧТО СДЕЛАТЬ

Убрать appointmentId (и лишние поля) из публичной проекции для appointment.*. Табло хватает сигнала «обнови» с doctorId. /api/queue/status перевести на отдельный неугадываемый токен талона (ticketCode+HMAC или отдельная колонка), не равный первичному ключу, ограничить сегодняшним днём и не отдавать название услуги. Поставить rate-limit и лимит соединений на IP для /api/c/*queue/events. Для табло в идеале требовать TV-токен, как /api/tv/d/[token].

КРИТЕРИЙ ПРИЁМКИ

При подписке на /api/c/<slug>/queue/events и создании брони в payload нет appointmentId. GET /api/queue/status/<appointment.id> возвращает 404, работает только /q/<ticket-token>. Одиннадцатое соединение с одного IP отклоняется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

/api/c/[slug]/queue/events не требует авторизации: достаточно slug, resolvePublicClinic проверяет только clinic.active. Поток пропускает appointment.created/statusChanged/cancelled/moved по BСЕМ записям клиники, включая будущие брони из CRM и Mini App. projectBoardEvent оставляет ключ appointmentId (SAFE_PAYLOAD_KEYS, board-stream.ts:47-58). При этом /api/queue/status/[id] прямо считает этот id секретом: «The unguessable CUID is the authorization» (route.ts:17-21). Он отдаёт без авторизации, ограничения по дате и rate-limit: patientName (инициалы), doctorName, service (название услуги), slotTime, status, clinicName, ticketNumber (стр. 83-99). Страница /q/[id] каждого пациента сама подписана на этот клинкоширокий поток (page.tsx:100), поэтому любой обладатель QR-талона видит id чужих записей в DevTools. Отдельная проблема: число долгоживущих анонимных соединений ничем не ограничено.

INF-11 P2 · СРЕДНИЙ переводы

Тексты пациенту, которые генерирует воркер, только на русском: кнопка «Подтверждаю», напоминания о лекарствах, DSAR-сообщения

ГДЕ

src/server/workers/notifications-send.ts:246, src/server/workers/medication-reminder.ts:221, src/server/workers/medication-reminder.ts:93, src/server/workers/data-export.ts:454

СЦЕНАРИЙ

Пожилый пациент читает только по-узбекски и получает напоминание «Время принять препарат...» и кнопку «Подтверждаю» на русском. Он не понимает, что нужно нажать, и визит остаётся неподтверждённым.

ПОСЛЕДСТВИЯ

Хуже конверсия подтверждений и соблюдение режима приёма у узбекоязычных пациентов, непоследовательность с остальным двуязычным продуктом.

ЧТО СДЕЛАТЬ

Выбирать тело и подписи кнопок по patient.preferredLang (bodyUz/nameUz), вынести строки воркеров в словари ru/uz. Для EMAIL брать email, а при его отсутствии не создавать отправку.

КРИТЕРИЙ ПРИЁМКИ

Для пациента с preferredLang=uz напоминание о лекарстве и кнопка приходят на узбекском. i18n-проверка в CI ловит кириллицу в строках воркеров.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Inline-кнопка подтверждения жёстко задана `text: "✓ Подтверждаю"` (notifications-send.ts:246) для всех пациентов. Напоминание о лекарстве рендерится `render(tpl.bodyRu, ..., clinic: { name: rx.clinic.nameRu })` (medication-reminder.ts:221-230): bodyUz выбирается, но не используется, preferredLang не читается. pickRecipient для EMAIL возвращает patient.phone (стр. 93). Сообщение с паролем DSAR-архива только на русском (data-export.ts:454). Для сравнения, штатные триггеры выбирают bodyUz по языку (triggers.ts:454), но общий материализатор тоже зашит на `const lang = "ru"` (triggers.ts:722).

INF-12 P2 · СРЕДНИЙ баг

Часовой тик напоминаний о лекарствах идёт не в начале часа: опоздание до 59 минут, задержанный тик теряет целый час

ГДЕ

src/server/workers/medication-reminder.ts:301, src/server/queue/bullmq-adapter.ts:145, src/lib/patient-experience/medication-schedule.ts:168, src/server/workers/post-visit-nps.ts:65

СЦЕНАРИЙ

Планировщик впервые создан в 14:37. Пациенту назначено 08:00 и 20:00, пуш «Время принять препарат (08:00)» приходит в 08:37. В день, когда тик в 08:59 задержался на 3 секунды из-за деплоя, утренняя доза вообще без напоминания. У NPS похожая история: все, кто завершил визит в минуты простоя воркера во время деплоя, не получают опрос.

ПОСЛЕДСТВИЯ

Напоминания о лекарствах систематически приходят с опозданием до часа и иногда теряются. NPS недосчитывает ответы.

ЧТО СДЕЛАТЬ

Для часовых задач использовать pattern-cron '0 * * * *' с tz 'Asia/Tashkent' или частый тик (каждые 5 минут) с окном (lastSuccessfulRun, now]. Идемпотентность уже есть через уникальный ключ (prescriptionId, scheduledFor). NPS считать по окну [now-24h, now-4h] с дедупом по npsRequestedAt.

КРИТЕРИЙ ПРИЁМКИ

Тик напоминаний срабатывает в HH:00:0x по Ташкенту. Тест: тик в 09:00:01 без тика в 08:xx создаёт напоминания и за 08:00 (догонка). Доза 08:00 при штатной работе уходит не позже 08:05.

ДОКАЗАТЕЛЬСТВО В КОДЕ

repeat() вызывает upsertJobScheduler(jobName, { every: intervalMs }) (bullmq-adapter.ts:145-150). В BullMQ 5.79 (getJobSchedulerEveryNextMillis) первый запуск идёт в момент создания планировщика, offset = now - floor(now/every)*every, дальше тики каждые every с тем же смещением. После рестартов смещение сохраняется, потому что берётся prevMillis. Тик напоминаний (medication-reminder.ts:40, 301) поэтому идёт в HH:MM, где MM это минута первого деплоя. isPrescriptionDueInWindow сравнивает только текущий час (medication-schedule.ts:168-175): при тике в 08:37 доза на 08:00 получает scheduledFor=08:00 (уже прошло) и отправляется сразу, с опозданием 37 минут. Если тик задержался через границу часа (08:59:58 → 09:00:01), час 08 не обрабатывается никогда. Так же хрупок NPS: окно ровно [now-5h, now-4h] (post-visit-nps.ts:65-66) без догонки после задержки или простоя воркера.

INF-13 P3 · НИЗКИЙ эксплуатация

.env.example неполон и местами вводит в заблуждение: без FIELD_ENCRYPTION_KEY прод не стартует, сторож и почта молча выключены

ГДЕ

.env.example:36, src/server/crypto/field-cipher.ts:108, ops/watchdog.sh:40, src/server/analytics/delivery.ts:70

СЦЕНАРИЙ

При переезде или восстановлении админ заполняет .env по образцу. App и worker падают на старте из-за FIELD_ENCRYPTION_KEY. После исправления сторож «работает», но алерты не приходят, а отчёты на почту отключаются сами.

ПОСЛЕДСТВИЯ

Затягивается восстановление после сбоя, мониторинг и функции тихо выключены.

ЧТО СДЕЛАТЬ

Дополнить .env.example всеми переменными с пояснениями и пометкой обязательности, удалить устаревшие. Добавить проверку обязательных env при старте воркера и app с понятным сообщением.

КРИТЕРИЙ ПРИЁМКИ

Скрипт сверки `process.env.\*` в src и ops с .env.example в CI проходит без расхождений.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В коде используются, но в .env.example отсутствуют: FIELD_ENCRYPTION_KEY (без него field-cipher.ts:108-114 в production кидает «Refusing to boot»), METRICS_TOKEN, SMTP_HOST/PORT/USER/PASS (без них delivery.ts:70-73 валит EMAIL-доставку отчётов, и после 3 неудач расписание отключается), WATCHDOG_TG_CHAT_ID и TELEGRAM_BOT_TOKEN (без них watchdog.sh:40 молча не шлёт алерты; при этом

.env.example:49 утверждает «there is no global bot token»), ALERT_TG_TOKEN/ALERT_TG_CHAT_ID, BACKUP_REMOTE/BACKUP_DIR, MINIO_EXPORTS_BUCKET, TG_USE_POLLING. Устаревшее: BACKUP_BUCKET (backup.sh его не читает), MINIO_PUBLIC_URL=https://files.neurofax.uz, хотя nginx проксирует /files/ на основном домене.

INF-14 P3 · НИЗКИЙ безопасность

SSE-поток: уволенный сотрудник продолжает получать события, утечка подписки при уходе клиента во время replay, набор родственников в Mini App заморожен

ГДЕ

src/app/api/events/route.ts:77, src/app/api/events/route.ts:203, src/app/api/miniapp/events/route.ts:186, src/app/api/miniapp/events/route.ts:338

СЦЕНАРИЙ

Администратор увольняет регистратора и деактивирует его учётную запись. Вкладка CRM на его домашнем ноутбуке остаётся открытой и дальше показывает всплывающие сообщения пациентов и прибытия. Пациент отвязывает бывшего супруга в Mini App, а у того открытая Mini App продолжает получать события о его записях.

ПОСЛЕДСТВИЯ

Продолжающийся доступ к PHI после отзыва прав и медленная утечка ресурсов процесса.

ЧТО СДЕЛАТЬ

Периодически (раз в 5 минут) перепроверять пользователя (active, роль, clinicId) и связи семьи, при отзыве закрывать поток. Сразу после addEventListener проверять `if (request.signal.aborted) cleanup()`, а подписку на abort регистрировать до await replay. При familyUnlinked пересчитывать allow-set.

КРИТЕРИЙ ПРИЁМКИ

Деактивация пользователя закрывает его SSE в течение 5 минут. Тест: abort во время replay не оставляет подписчиков (bus.size(channel) = 0). После familyUnlinked события отвязанного пациента не доставляются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

auth() проверяется один раз при подключении (events/route.ts:77-84). Heartbeat каждые 20 с держит поток бесконечно (nginx proxy_read_timeout 1h считается между чтениями), поэтому деактивированный пользователь (User.active=false) продолжает получать все события клиники: превью сообщений пациентов в tg.message.new, ФИО в patient.arrived. Слушатель abort вешается ПОСЛЕ await replay (events/route.ts:145-177 → 203; miniapp/events/route.ts:274-311 → 338). Если клиент ушёл во время replay, событие abort уже прошло, cleanup не вызывается: подписка на шину и setInterval остаются навсегда, а метрика sseConnectionsActive не уменьшается. allowedIds (родственники) считаются один раз при подключении (miniapp/events/route.ts:186-192): после patient.familyUnlinked бывший «родственник» продолжает получать события и превью переписки другого пациента до переподключения.

INF-15 P3 · НИЗКИЙ эксплуатация

restore.sh (и его DRY_RUN) сообщает об успехе при частично проваленном восстановлении

ГДЕ

ops/restore.sh:77, ops/restore.sh:120

СЦЕНАРИЙ

Дамп сделан с новым расширением или типом, которого нет в целевой базе, либо обрезан посреди COPY. DRY_RUN пишет «restorable». При реальной аварии восстановление «успешно», но таблица VisitNote пустая, а FK не созданы. Ошибку замечают через дни.

ПОСЛЕДСТВИЯ

Ложная уверенность в бэкапах, риск частичного восстановления медицинских данных в проде.

ЧТО СДЕЛАТЬ

Запускать `psql -v ON\_ERROR\_STOP=1 --single-transaction`. После загрузки сверять число строк ключевых таблиц с метаданными дампа (сохранять counts при бэкапе) и выходить с ошибкой при расхождении или если /tmp/restore-check.err не пуст.

КРИТЕРИЙ ПРИЁМКИ

Искусственно испорченный дамп (удалена строка CREATE TABLE) → DRY_RUN завершается с кодом ≠0 и сообщением об ошибке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Проверка DRY_RUN: `gunzip -c "\$DUMP" | docker compose exec -T postgres psql -q -U ... -d "\$CHECK_DB"

>/dev/null 2>/tmp/restore-check.err` (стр. 77-82). Реальное восстановление: `gunzip -c "\$DUMP" | ... psql -U ... -d "\$POSTGRES_DB"` (стр. 120). В обоих случаях нет `ON_ERROR_STOP=1` и `--single-transaction`. psql при SQL-ошибках в скрипте продолжает работу и возвращает 0, поэтому скрипт печатает «dry run OK — this dump is restorable» и «done», даже если часть таблиц или ограничений не загрузилась. На этот вывод опирается RUNBOOK §4 («0 ошибок»).

INF-16 РЗ · НИЗКИЙ баг

Выдача заключений и направлений пациенту может навсегда застрять: 25 постоянно падающих записей блокируют все новые

ГДЕ

src/server/workers/visit-note-handout.ts:300, src/server/workers/visit-note-handout.ts:340, src/server/workers/workers/visit-note-handout.ts:374, src/server/workers/visit-note-handout.ts:706, src/server/workers/referral-document.ts:206

СЦЕНАРИЙ

У нескольких заметок рендер PDF постоянно падает (редкий символ в тексте памятки, битое изменение после поправки). Когда таких набирается 25, каждый тик раз в 30 перебирает только их. Новые заключения всех пациентов перестают появляться в Mini App, и врач узнаёт об этом от пациента, который «не видит заключение».

ПОСЛЕДСТВИЯ

Пациенты не получают заключения, направления и перенос курса препаратов в Mini App, причём тихо и без алерта.

ЧТО СДЕЛАТЬ

Добавить handoutAttempts, handoutLastError, handoutNextAttemptAt (аналогично для Referral и моста препаратов). Выбирать по nextAttemptAt, бэкофф экспоненциальный, после N неудач создавать Action врачу или ресепшну «заключение не доставлено» и выводить в health.

КРИТЕРИЙ ПРИЁМКИ

Тест: 30 заметок, у которых рендер кидает ошибку, и 1 нормальная. Нормальная получает документ на первом же тике, падающие откладываются по бэкоффу, после 5 попыток создаётся Action.

ДОКАЗАТЕЛЬСТВО В КОДЕ

runVisitNoteHandoutTick выбирает FINALIZED-заметки без документа CONCLUSION или с handoutStaleAt, `orderBy: { finalizedAt: "asc" }, take: BATCH` (25) (стр. 300, 340-341). При ошибке generateConclusion только console.error (стр. 374). Счётчика попыток, lastError и бэкоффа нет, поэтому упавшая заметка остаётся в выборке. Ветка handoutStaleAt специально не ограничена окном 14 дней (стр. 298-300), то есть вечно падающие старые заметки навсегда встают в голову сортировки. Тот же шаблон у runMedicationBridgeTick (стр. 706-707) и runReferralDocumentTick (referral-document.ts:206-216). Сотрудники и пациент о сбое не узнают.

INF-17 РЗ · НИЗКИЙ баг

Гарантия доставки через outbox ломается на переходе воркер→app: сбой публикации в Redis проглатывается, а строка помечается DELIVERED

ГДЕ

src/server/realtime/redis-adapter.ts:152, src/server/realtime/redis-adapter.ts:169, src/server/workers/outbox-pumper.ts:130, src/server/workers/outbox-pumper.ts:156, src/server/realtime/redis-adapter.ts:96

СЦЕНАРИЙ

Redis перезапускается (обновление образа, OOM). В эту секунду пациент подтверждает запись кнопкой в Telegram. Событие appointment.statusChanged помечено DELIVERED, но ни одна вкладка ресепшна его не получила. Запись на ресепшне остаётся «не подтверждена», и администратор звонит пациенту зря.

ПОСЛЕДСТВИЯ

Outbox, задуманный как «at-least-once», на практике даёт at-most-once без сигнала о потере. Экраны персонала молча расходятся с базой.

ЧТО СДЕЛАТЬ

В воркере считать неуспешный publish в Redis ошибкой доставки (throw → FAILED с бэкоффом). Помечать DELIVERED отдельно по строке после успешной публикации. Подписчик: при ошибке unsubscribe сбрасывать started и повторять с бэкоффом. В health проверять, что подписка активна (например, ping-канал).

КРИТЕРИЙ ПРИЁМКИ

Тест: publish в Redis кидает ошибку, строка остаётся FAILED с attempts=1 и доставляется на следующем окне.

Остановить Redis на 5 с во время подтверждения: после восстановления событие приходит в CRM. Старт app при недоступном Redis: после его подъёма события воркера доходят без рестарта app.

ДОКАЗАТЕЛЬСТВО В КОДЕ

OutboxPumper работает только в процессе воркера (start.ts:52), где нет ни одного SSE-подписчика. «Локальная доставка» getEventBus().publish там бесполезна, и единственный путь до CRM и Mini App это Redis. publishEnvelopeToRedis ловит любую ошибку publish, пишет warn и `return true` (redis-adapter.ts:152-169). У клиента publisher стоит maxRetriesPerRequest: 1, поэтому при моргании Redis команда быстро отклоняется. deliverOne не бросает, и строка получает `status: "DELIVERED"` (outbox-pumper.ts:156-159). Повторов нет. Replay в /api/miniapp/events читает только DELIVERED, но broadcast идёт до коммита DELIVERED (весь батч в одной транзакции, стр. 149-186). Клиент, переподключающийся посреди батча, не получает событие ни из replay, ни вживую. ensureRedisSubscriber ставит started=true до успешного psubscribe (стр. 96-100). Если первый psubscribe упал (Redis недоступен при старте app), подписка не повторяется до рестарта процесса, и все события воркера перестают доходить до экранов, при этом health показывает redis ok.

INF-18 РЗ · НИЗКИЙ эксплуатация

Деплой-контур не воспроизводим из репозитория: реальный _deploy.sh не в git, прод-конфиги в skip-worktree, ops/deploy.sh в репо ошибочен

ГДЕ

ops/deploy.sh:28, ops/deploy.sh:54, ops/crontab.example:11, docs/operations/DEPLOY.md:152, docs/operations/DEPLOY.md:315

СЦЕНАРИЙ

При переезде на новый сервер или по ошибке кто-то запускает ops/deploy.sh «как в репо». App стартует раньше миграции, миграция падает, скрипт пишет done, и клиника получает 500 на всех экранах с новой колонкой. Правки compose и nginx, закоммиченные в репо (например, Redis noeviction), на прод не попадают.

ПОСЛЕДСТВИЯ

Высокий риск неудачного деплоя или восстановления и дрейф конфигурации. Исправления безопасности в compose/nginx не доезжают до прода.

ЧТО СДЕЛАТЬ

Закоммитить реальный пайплайн (build → migrate → recreate → nginx reload, set -e, маркеры) как ops/deploy.sh, а старый удалить. Прод-специфику вынести в трекаемый docker-compose.prod.yml, секреты в .env, vhost'ы соседей в отдельный репозиторий или каталог. Снять skip-worktree. Исправить crontab.example (путь, watchdog, reload nginx) и противоречие в документации.

КРИТЕРИЙ ПРИЁМКИ

Чистый клон + .env + `ops/deploy.sh` поднимает прод-эквивалент. `git ls-files -v | grep "^S"` на сервере пуст. Неудачная миграция даёт exit#0 и не пересоздаёт app.

ДОКАЗАТЕЛЬСТВО В КОДЕ

По DEPLOY.md:12-14 и 124-150 прод катится неотслеживаемым /opt/neurofax/_deploy.sh, а docker-compose.yml, nginx/nginx.conf и два vhost'a на сервере помечены skip-worktree (стр. 152-160). То есть то, что в репозитории, не равно тому, что работает. ops/deploy.sh в репо («продом не используется») делает `docker compose up -d` (стр. 28) до миграций (стр. 54): новый код стартует на старой схеме, и Prisma, выбирающая все колонки, падает на каждой модели с новой колонкой. Провал миграции скрипт глотает: `if ! ... migrate deploy; then log "WARN..."` (стр. 54-56), и деплой «успешен». crontab.example:11 указывает /opt/medbook (на сервере /opt/neurofax) и не содержит watchdog. DEPLOY.md:315 утверждает «ночной бэкап не настроен», а RUNBOOK:307 «включён и проверен».

INF-19 РЗ · НИЗКИЙ мёртвая механика

Мёртвые realtime-механики: события без слушателей, недостижимые фильтры, заявленная задержка не соответствует факту

ГДЕ

src/app/api/miniapp/events/route.ts:112, src/app/api/miniapp/events/route.ts:142, src/app/api/events/route.ts:155, src/server/workers/start.ts:49, src/server/realtime/events.ts:83, src/app/api/crm/visit-notes/[id]/route.ts:240, src/app/api/miniapp/events/route.ts:127

ТАКЖЕ НАШЛИ ЗОНЫ

Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

СЦЕНАРИЙ

Врач меняет график. Пациент с открытой Mini App видит старые свободные слоты и выбирает уже недоступное время до ручного обновления. Разработчики опираются на документированные контракты событий, которые на деле не работают.

ПОСЛЕДСТВИЯ

Лишняя нагрузка (outbox и SSE на каждое нажатие клавиши врача) и ложные ожидания от realtime, устаревшие слоты в Mini App.

ЧТО СДЕЛАТЬ

Для клинкоширокий событий (doctor.scheduleChanged) сделать отдельную ветку доставки в Mini App без patientId (только инвалидация слотов). Удалить или не публиковать события без потребителей либо подключить их к экранам (лабы врача, больничные в карточке). Удалить payment.due из union или начать публиковать. Исправить комментарии.

КРИТЕРИЙ ПРИЁМКИ

После изменения графика Mini App пациента обновляет слоты без перезагрузки. Для каждого EVENT_TYPE есть хотя бы один издатель и один потребитель (скрипт-проверка в CI).

ДОКАЗАТЕЛЬСТВО В КОДЕ

doctor.scheduleChanged включён в MINIAPP_DELIVERABLE_TYPES (miniapp/events/route.ts:112), но фильтр пропускает событие только при patientId (стр. 134-147), а у этого события patientId нет. До Mini App оно не доходит никогда, хотя events.ts обещает «drives mini-app slot-picker invalidation». Публикуются, но нигде в клиентах не слушаются: visit-note.draftSaved (на каждый автосейв!), lab.result.received, lab.order.created, sickleave.issued/cancelled, cds.override.recorded, conversation.created (grep по src/app, src/hooks и src/components пуст). Тип payment.due объявлен, но ни разу не публикуется. `: cursor-too-old` в CRM-маршруте это SSE-комментарий, невидимый JS (стр. 155). start.ts:49-51 обещает «200ms poll keeps in-flight latency well under 1s», а lockBatch при attempts=0 ждёт минимум 1 с.

СМ · Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония

СМ-01 Р2 · СРЕДНИЙ баг

SIP-вебхук теряет события: любая ошибка БД возвращается как 200, operatorId жёстко FK на User, нет TTL «звонящих», неоднозначные timestamp

ГДЕ

src/app/api/calls/sip/event/route.ts:470, src/app/api/calls/sip/event/route.ts:165, src/app/api/calls/sip/event/route.ts:214, src/app/api/calls/sip/event/route.ts:56, src/app/api/calls/sip/event/route.ts:323

СЦЕНАРИЙ

АТС шлёт ringing с operatorId="101" — запрос падает, в ответ 200, в очереди колл-центра звонка нет. Или hangup потерялся — «призрачный» звонок часами висит первым в очереди и открывается в центральной колонке.

ПОСЛЕДСТВИЯ

Недоверенная очередь и статистика звонков при подключении реальной АТС.

ЧТО СДЕЛАТЬ

Возвращать 5xx на ошибки БД (чтобы провайдер ретраил) и логировать; operatorId сопоставлять через таблицу внутренних номеров (User.sipExtension) и не падать при неизвестном; игнорировать answered для уже завершённого звонка; автоматически закрывать RINGING старше N минут (воркер); явно принимать ISO с TZ или unix-секунды; секрет только в заголовке, сравнение через crypto.timingSafeEqual.

КРИТЕРИЙ ПРИЁМКИ

Событие с неизвестным operatorId создаёт звонок без оператора; ошибка БД даёт 500; зависший RINGING закрывается как MISSED через N минут; unix-секунды корректно парсятся.

ДОКАЗАТЕЛЬСТВО В КОДЕ

catch (470-475) отвечает 200 {ok:false} «to keep retrying providers quiet» — АТС не повторит, событие потеряно. operatorId из тела пишется в Call.operatorId (165, 202, 220) — это FK на User (schema.prisma:2640); АТС присылает внутренние номера ("101") → FK violation → звонок не создаётся. handleAnswered после hangup (out-of-order) перезаписывает status=ANSWERED у уже завершённого звонка (214-222). Если hangup/misled потерян, звонок с endedAt=null вечно висит в очереди и авто-выбирается как «самый старый» (call-center-page-client.tsx:48-56). `timestamp: z.coerce.date()` (56) принимает число как миллисекунды — unix-секунды дают 1970 год. Секрет принимается и из query `?secret=` (323-326) — попадает в access-логи nginx; safeEqual раскрывает длину секрета.

СМ-02 Р2 · СРЕДНИЙ мёртвая механика

«Создать карточку» из колл-центра и «Создать пациента» в топбаре открывают только список пациентов: параметры ?new=true&phone= игнорируются

ГДЕ

src/app/[locale]/crm/call-center/_components/active-call.tsx:414, src/components/layout/crm-topbar.tsx:247, src/app/[locale]/crm/patients/_components/patients-page-client.tsx:67

СЦЕНАРИЙ

Звонит новый пациент; оператор жмёт «Создать карточку» — открывается список пациентов без формы и без номера, звонок продолжается, пока он ищет кнопку.

ПОСЛЕДСТВИЯ

Лишние действия в самый нагруженный момент; пункт меню топбара выглядит сломанным.

ЧТО СДЕЛАТЬ

В patients-page-client читать ?new=true и ?phone=, открывать NewPatientDialog с предзаполненным телефоном и чистить параметры после открытия.

КРИТЕРИЙ ПРИЁМКИ

Переход по обеим ссылкам открывает диалог нового пациента; из колл-центра телефон звонящего уже подставлен.

ДОКАЗАТЕЛЬСТВО В КОДЕ

active-call.tsx:414 `href=/crm/patients?new=true&phone=...`, crm-topbar.tsx:246-250
`intlRouter.push("/crm/patients?new=true")`. patients-page-client.tsx держит `const [dialogOpen, setDialogOpen] = useState(false)` и не читает searchParams (grep по patients/ — useSearchParams только в export-button).

Внутренние направления к коллеге никуда не доходят: входящие направления не показываются, статус никогда не меняется, регистратура их не видит

ГДЕ

src/app/api/crm/referrals/route.ts:156, src/app/[locale]/doctor/my-day/_hooks/use-doctor-referrals.ts:31, src/app/api/crm/referrals/route.ts:105

СЦЕНАРИЙ

Невролог направляет пациента к кардиологу клиники; диалог обещает «Направьте пациента к коллеге». Кардиолог нигде не видит направления, регистратура тоже; пациент приходит с PDF, а в системе никто не ждёт.

ПОСЛЕДСТВИЯ

Потеря клинической передачи пациента между врачами; ложное ощущение, что направление передано.

ЧТО СДЕЛАТЬ

Смонтировать карточку входящих направлений в «Моём дне» врача и в ресепшн; добавить PATCH статуса (SCHEDULED при записи с привязкой scheduledAppointmentId, COMPLETED/CANCELLED); открыть GET для RECEPTIONIST.

КРИТЕРИЙ ПРИЁМКИ

Созданное направление появляется у целевого врача и в регистратуре; после записи пациента к целевому врачу статус становится SCHEDULED.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Врач создаёт направление с toDoctorId (POST, status PENDING). Хук useIncomingReferrals (use-doctor-referrals.ts:31-49) не импортируется ни одним компонентом (grep); ключ i18n doctor.myDay.referrals.subtitle «Пациенты, направленные ко мне коллегами» не используется. Эндпоинтов изменения статуса нет (grep referral.update/scheduledAppointmentId — только select) — PENDING навсегда, scheduledAppointmentId не заполняется. GET роли [ADMIN, DOCTOR, NURSE] (156-158) — RECEPTIONIST, который должен записать пациента к коллеге, список не видит. `total: rows.length` (202) — не общее число.

Глобальный поиск прячет найденное сервером: cmdk повторно фильтрует результаты по строке value

ГДЕ

src/components/layout/global-search.tsx:438, src/components/layout/global-search.tsx:483, src/components/ui/command.tsx:159, src/app/api/crm/search/route.ts:88

СЦЕНАРИЙ

Регистратор вводит в «К номер пациента так, как его диктуют — «90 123 45 67» — и получает «Ничего не найдено», хотя пациент есть.

ПОСЛЕДСТВИЯ

Основной поиск CRM ненадёжен по телефону — самому частому ключу поиска.

ЧТО СДЕЛАТЬ

Передать shouldFilter={false} в Command для глобального поиска (фильтрация уже серверная) или включить в value/keywords все поля, по которым ищет сервер.

КРИТЕРИЙ ПРИЁМКИ

Поиск по телефону с пробелами/дефисами показывает пациента и его записи; поиск по тексту комментария показывает запись.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CommandDialog рендерит `` без shouldFilter={false} (command.tsx:159-163); cmdk 1.1.1 по умолчанию скрывает элементы с commandScore=0. value пациента = `patient-\${id}-\${fullName}-\${phone}` (438) — запрос «90 123 45 67» нормализуется cmdk в строку с пробелами, которых нет в «+998901234567» → скрыт, хотя сервер нашёл по phoneDigits. value записи = `appointment-\${id}-\${primary}-\${status}` (483) — без телефона и комментариев, а сервер ищет записи по телефону и notes/comments (search/route.ts:88-94) → такие записи никогда не видны. Врач ищется по nameUz, а value в gu-локали содержит nameRu (458).

Загрузка документа в библиотеке: нужно вручную вводить внутренний ID пациента, mimeType и размер теряются, файл остаётся сиротой при ошибке

ГДЕ

src/app/[locale]/crm/documents/_components/upload-dialog.tsx:252, src/app/[locale]/crm/documents/_components/upload-dialog.tsx:198, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:324, src/app/[locale]/crm/documents/_components/upload-dialog.tsx:251, src/app/[locale]/crm/documents/_components/upload-dialog.tsx:197, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:63, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:190, src/app/[locale]/crm/patients/[id]/_components/document-preview-dialog.tsx:187

ТАКЖЕ НАШЛИ ЗОНЫ

Клинические документы, больничные, рецепты, анализы, направления, файлы

СЦЕНАРИЙ

Регистратор хочет прикрепить скан анализа: открывает «Загрузить», видит поле «ID смXXX...», не знает что вводить. Если всё же вставил ID из адресной строки карточки — документ создаётся, но в колонке «Размер» «—», а в карточке пациента предпросмотр PDF не работает (document-preview-dialog выбирает режим по mimeType).

ПОСЛЕДСТВИЯ

Функция загрузки в библиотеке фактически недоступна обычному персоналу; загруженные документы не превьюются.

ЧТО СДЕЛАТЬ

Заменить поле ID на поиск пациента (ФИО/телефон, как в NewAppointmentDialog), предзаполнять из ?patientId; передавать mimeType и sizeBytes из ответа upload; при ошибке создания метаданных удалять загруженный объект (или создавать запись в одной серверной операции).

КРИТЕРИЙ ПРИЁМКИ

Документ загружается выбором пациента из поиска; в списке виден размер, в карточке пациента PDF/фото открываются в предпросмотре; при ошибке сохранения в бакете не остаётся объекта.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Поле пациента — `<Input id="up-patient" placeholder="смXXX...">` с подписью «Пациент (ID)» (upload-dialog.tsx:252-260): сотрудник должен знать cuid. После загрузки uploaded возвращает mimeType/sizeBytes, но в CreateDocumentSchema.safeParse передаются только {patientId,title,type,fileUri} (198-203) → документ сохраняется с mimeType=null, sizeBytes=null. Файл заливается в хранилище до создания метаданных (189-196); если POST /api/crm/documents упал (неверный ID → FK), байты остаются в бакете. Диалог не подставляет patientId из ?patientId= фильтра страницы.

Заметки к звонку теряют набранный текст: ответ автосохранения перезаписывает поле ввода

ГДЕ

src/app/[locale]/crm/call-center/_hooks/use-call-notes.ts:27, src/app/[locale]/crm/call-center/_hooks/use-call-notes.ts:44

СЦЕНАРИЙ

Оператор пишет «Пациент просит перенести», пауза, продолжает «на пятницу после 15:00». Ответ сервера приходит посреди ввода — поле откатывается к «Пациент просит перенести», оператор допечатывает и итоговая заметка без «на пятницу».

ПОСЛЕДСТВИЯ

Искажённые или неполные записи разговоров с пациентами.

ЧТО СДЕЛАТЬ

Не синхронизировать буфер из серверного summary, пока поле в фокусе/есть несохранённые изменения; сбрасывать буфер только при смене call.id; в onSuccess не трогать локальное значение, если оно уже отличается от отправленного.

КРИТЕРИЙ ПРИЁМКИ

Непрерывный набор текста с паузами >800 мс не теряет ни одного символа; при переключении на другой звонок показывается его заметка.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Эффект `useEffect(() => { setValue(call?.summary ?? ''), [call?.id, call?.summary] })` (27-30) сбрасывает локальный буфер при любом изменении summary в кеше. onSuccess PATCH делает qc.setQueryData(active, {...prev, summary: row.summary})` (44-50) со значением, отправленным 800 мс назад. Если оператор продолжил печатать во время запроса, буфер откатывается к старому тексту; следующий ввод поверх старого текста перезапускает таймер с новым значением, и пропущенный фрагмент теряется навсегда.`

СМ-07 P2 · СРЕДНИЙ баг

Кнопки «Завершить» и «Пропуск» в колл-центре не меняют статус звонка: звонок остаётся «Звонит», пропуски не считаются, другие операторы не узнают

ГДЕ

`src/app/[locale]/crm/call-center/_components/call-actions-rail.tsx:45`, `src/app/[locale]/crm/call-center/_hooks/types.ts:50`, `src/app/api/crm/calls/[id]/route.ts:37`, `src/server/schemas/call.ts:20`

СЦЕНАРИЙ

Оператор нажимает «Пропуск» на брошенном звонке — тост «Звонок помечен как пропущенный», но в сайдбаре счётчик пропущенных не растёт, в карточке звонка статус «Звонит», у соседнего оператора звонок ещё минуту в очереди входящих.

ПОСЛЕДСТВИЯ

Статистика пропущенных и конверсии звонков неверна, операторы работают с устаревшей очередью.

ЧТО СДЕЛАТЬ

Серверные действия `hangup/mark-missed`: выставлять `status (ENDED/MISSED)`, `direction=MISSED` для пропуска, `durationSec` (от `answeredAt`), публиковать `call.ended/call.missed`; расширить `UpdateCallSchema` или сделать отдельные `POST /calls/[id]/hangup|missed`.

КРИТЕРИЙ ПРИЁМКИ

После «Завершить» статус «Завершён», кнопка неактивна; после «Пропуск» звонок входит в счётчик пропущенных за день и исчезает из очереди у всех операторов в течение секунды.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`onHangup` шлёт `PATCH {endedAt}`; `onMarkMissed` — `{endedAt, tags:[...,'missed']}` (`call-actions-rail.tsx:45-72`).

`UpdateCallSchema` (`call.ts:20-28`) не содержит `status/direction`, `route [id]` `PATCH` не выставляет их и не пишет `durationSec`. `deriveStatus` (`types.ts:53-64`) в первую очередь смотрит колонку `status` — у звонков из `webhook` она `RINGING/ANSWERED` → после «Завершить» пилюля показывает «Звонит», `canEnd` остаётся `true`. Тер `'missed'` нигде не читается: счётчики пропусков считают `direction='MISSED'` (`shell-summary:79-84`, `dashboard:95-100`), воронка — `durationSec>0` (`analytics/funnels:151`). `PATCH` не публикует `publishEventSafe` → у других операторов звонок висит в очереди до 60-секундного поллинга. Последующий `hangup-вебхук` видит `endedAt` и выходит (`sip/event:246`), статус в БД остаётся `RINGING` навсегда.

СМ-08 P2 · СРЕДНИЙ баг

Колл-центр не работает для роли CALL_OPERATOR: подтверждение, запись, создание пациента и виджет «К подтверждению» закрыты 403

ГДЕ

`src/app/[locale]/crm/call-center/_components/unconfirmed-widget.tsx:150`, `src/app/[locale]/crm/call-center/_hooks/use-unconfirmed.ts:39`, `src/app/api/crm/appointments/[id]/queue-status/route.ts:37`, `src/app/api/crm/actions/route.ts:40`, `src/app/[locale]/crm/call-center/_components/active-call.tsx:115`, `src/app/api/crm/appointments/route.ts:161`, `src/app/api/crm/patients/route.ts:138`, `src/lib/permissions/matrix.ts:114`, `src/lib/permissions/matrix.ts:2`, `src/app/api/crm/appointments/[id]/queue-status/route.ts:38`

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита, Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Клиника нанимает оператора колл-центра. Он открывает колл-центр: блока «К подтверждению» нет; при звонке пациента жмёт «Записать» — ошибка; «Создать карточку» — ошибка.

ПОСЛЕДСТВИЯ

Роль, для которой построен колл-центр, не может выполнить ни одного целевого действия.

ЧТО СДЕЛАТЬ

Привести роли API к матрице прав: добавить `CALL_OPERATOR` в `POST appointments`, `POST patients` (или отдельный эндпоинт быстрой карточки), `GET actions` (с фильтром типов), `snooze` и в `canMutateStatus` для

перехода в CONFIRMED; на странице колл-центра показывать явную ошибку доступа при 403.

КРИТЕРИЙ ПРИЁМКИ

Пользователь CALL_OPERATOR видит виджет «К подтверждению», подтверждает и откладывает записи, записывает пациента и создаёт карточку из колл-центра; e2e на роль CALL_OPERATOR.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Кнопка «Подтвердить» → PATCH /api/crm/appointments/[id]/queue-status, roles [ADMIN,RECEPTIONIST,DOCTOR,NURSE] (queue-status/route.ts:37-39) — CALL_OPERATOR нет. Виджет читает GET /api/crm/actions, roles [ADMIN,RECEPTIONIST,DOCTOR] (actions/route.ts:40): на 403 queryFn бросает ошибку, data=[] и виджет `return null` (unconfirmed-widget.tsx:70) — молча исчезает. «Отложить» → snooze roles [ADMIN,RECEPTIONIST]. «Записать на приём» (NewAppointmentDialog) → POST /api/crm/appointments roles [ADMIN,RECEPTIONIST,DOCTOR] (appointments/route.ts:161), создание пациента POST /api/crm/patients roles [ADMIN,RECEPTIONIST,DOCTOR] (patients/route.ts:138). При этом src/lib/permissions/matrix.ts даёт CALL_OPERATOR write/update на Appointment. Страница /crm/call-center вообще не проверяет роль — NURSE видит «Сейчас тихо» вместо ошибки доступа.

СМ-09 P2 · СРЕДНИЙ безопасность

Межклиничная подмена ID: calls/online-requests/documents принимают patientId/operatorId/appointmentId из тела без проверки клиники, а вложенный include отдаёт ФИО и телефон чужого пациента

ГДЕ

src/app/api/crm/calls/route.ts:69, src/app/api/crm/calls/[id]/route.ts:45, src/app/api/crm/online-request s/[id]/route.ts:38, src/app/api/crm/documents/route.ts:163, src/lib/prisma.ts:200

СЦЕНАРИЙ

Сотрудник клиники А, зная suid пациента клиники В (например, из общего чата/скриншота), PATCH-ит свой звонок с этим patientId и в ответе получает ФИО, телефон и сегмент пациента клиники В; bumpPatientLastContact пытается трогать чужого пациента.

ПОСЛЕДСТВИЯ

Утечка ПДн между арендаторами SaaS; нарушение изоляции, на которой строится мультитенантность.

ЧТО СДЕЛАТЬ

Перед записью любого FK из тела проверять принадлежность клинике (findFirst {id, clinicId}); лучше — составные FK (clinicId, id) в схеме; общий хелпер assertSameClinic.

КРИТЕРИЙ ПРИЁМКИ

POST/PATCH с patientId/operatorId/appointmentId другой клиники возвращает 400/404; тест на изоляцию для calls, online-requests, documents.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/crm/calls пишет `patientId: body.patientId, operatorId: body.operatorId, appointmentId: body.appointmentId` (calls/route.ts:69-84), PATCH [id] — `data: body as never` с теми же полями (calls/[id]/route.ts:45-52). FK Call.patientId → Patient.id без clinicId (schema.prisma:2637-2640). Tenant-расширение (prisma.ts \$allOperations) скоупит только верхнеуровневую операцию; вложенный `include: { patient: { select: {fullName, phone, segment} } }` (calls GET 50-53) читается без clinicId. То же: PATCH online-requests (patientId, include patient.fullName), POST documents (patientId, appointmentId; include patient.fullName, appointment.doctor). Для сравнения referrals/route.ts:53-56 проверяет `patient.findFirst({id, clinicId})`.

СМ-10 P2 · СРЕДНИЙ баг

Неотвеченный звонок, закрытый событием hangup, не считается пропущенным и засчитывается воронкой как состоявшийся разговор

ГДЕ

src/app/api/calls/sip/event/route.ts:247, src/app/api/crm/shell-summary/route.ts:79, src/app/api/crm/analytics/funnels/route.ts:151, src/app/api/crm/dashboard/route.ts:95

СЦЕНАРИЙ

Пациент звонит, 40 секунд гудков, кладёт трубку; АТС шлёт ringing → hangup (типичный сценарий без отдельного missed). В CRM бейдж пропущенных = 0, в аналитике воронки этот звонок — «успешный разговор без записи».

ПОСЛЕДСТВИЯ

Руководитель не видит потерянных пациентов; конверсия колл-центра занижена ложными «разговорами».

ЧТО СДЕЛАТЬ

В handleHangup при !wasAnswered выставлять direction=MISSED (или перевести все счётчики на status=MISSED), durationSec считать от answeredAt (null для неотвеченных); миграцией исправить исторические строки.

КРИТЕРИЙ ПРИЁМКИ

Последовательность ringing→hangup без answered увеличивает бейдж пропущенных и не попадает в «состоявшиеся» воронки; длительность разговора = hangup – answered.

ДОКАЗАТЕЛЬСТВО В КОДЕ

handleHangup (sip/event:247-265) при !wasAnswered ставит `status: "MISSED"`, но direction оставляет IN, а durationSec = endedAt – startedAt, т.е. время гудков (>0). Все счётчики пропущенных фильтруют `direction: "MISSED" (shell-summary:79-84 — бейдж сайдбара/топбара, dashboard:95-100 — KPI и «потери» в action-center). Воронка считает `completed: c.direction !== "MISSED" && (c.durationSec ?? 0) > 0` (funnels:151) → звонок, на который никто не ответил, считается разговором. Для отвеченных звонков durationSec тоже включает время ожидания ответа.

СМ-11 Р2 · СРЕДНИЙ баг

Панель активного звонка показывает неверную «Следующую запись», средний чек и историю; ссылка «Открыть» ведёт на 404

ГДЕ

src/app/[locale]/crm/call-center/_components/active-call.tsx:190, src/app/[locale]/crm/call-center/_components/active-call.tsx:311, src/app/api/crm/patients/[id]/route.ts:34, src/app/[locale]/crm/call-center/_components/unconfirmed-widget.tsx:178

СЦЕНАРИЙ

Пациент звонит уточнить время. У него запись завтра (подтверждённая, CONFIRMED) и контроль через месяц (BOOKED). Оператор видит «Следующая запись: через месяц» и говорит это пациенту; жмёт «Открыть» — 404.

ПОСЛЕДСТВИЯ

Оператор сообщает пациенту неверную информацию о записи; ложные финансовые показатели.

ЧТО СДЕЛАТЬ

Брать ближайшую будущую запись со статусами BOOKED/CONFIRMED/WAITING и датой ≥ сегодня (ташкентские сутки) отдельным запросом или сортировкой asc; средний чек считать по COMPLETED с оплатой; ссылку делать `/crm/appointments?ap=<id>`.

КРИТЕРИЙ ПРИЁМКИ

Для пациента с записями завтра (CONFIRMED) и через месяц показывается завтрашняя; «Открыть» открывает drawer записи; NO_SHOW не влияет на средний чек.

ДОКАЗАТЕЛЬСТВО В КОДЕ

API отдаёт appointments `orderBy: {date:"desc"}, take: 10` (patients/[id]/route.ts:34-36). active-call.tsx:193-195: `upcoming = appointments.find(a => BOOKED||WAITING)` — при desc-порядке это самая дальняя будущая запись (или просроченная BOOKED в прошлом), статус CONFIRMED (есть в enum AppointmentStatus) игнорируется. avgCheck (196-201) усредняет priceFinal в т.ч. по NO_SHOW; «История визитов» и её счётчик ограничены теми же 10 строками. Ссылка «Открыть» — `/crm/appointments/\${upcoming.id}` (312), но маршрута /crm/appointments/[id] нет (в папке только page.tsx; страница открывает запись по ?ap=). В виджете «К подтверждению» ссылка `/crm/appointments?id=` (unconfirmed-widget.tsx:178) — параметр id страница не читает.

СМ-12 Р2 · СРЕДНИЙ баг

Принудительная смена пароля заикливается: после успешной смены сотрудника снова возвращает на форму, а вторая попытка падает с «введите текущий пароль» без поля ввода

ГДЕ

src/app/[locale]/crm/me/change-password/_components/change-password-client.tsx:54, src/lib/auth.ts:224, src/proxy.ts:220, src/app/api/crm/me/password/route.ts:53, src/app/[locale]/crm/me/change-password/page.tsx:10, src/proxy.ts:222

ТАКЖЕ НАШЛИ ЗОНЫ

Аутентификация, мультитенантность, безопасность, платформа

СЦЕНАРИЙ

Админ создаёт аккаунт регистратора с временным паролем. Регистратор входит, вводит новый пароль, видит

«Пароль обновлён», его перебрасывает на /crm → снова форма смены пароля. Он вводит пароль ещё раз — тост «Введите текущий пароль», но поля для него нет. Выйти из цикла можно только догадавшись разлогиниться и войти заново.

ПОСЛЕДСТВИЯ

Каждый новый сотрудник и каждый сброс пароля админом упирается в тупик; поддержка получает «не могу войти».

ЧТО СДЕЛАТЬ

Обновлять JWT корректно: либо получать csrfToken (GET /api/auth/csrf) и слать `{csrfToken}` в POST /api/auth/session, либо использовать `unstable\_update` / update() из next-auth на сервере в самом /api/crm/me/password, либо в jwt-callback перечитывать mustChangePassword из БД при каждом refresh. Дополнительно: страница change-password должна определять forced по БД, а не по JWT.

КРИТЕРИЙ ПРИЁМКИ

Сценарий «вход с временным паролем → смена → /crm» завершается на /crm/reception без повторного показа формы; e2e-тест на этот поток проходит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

После POST /api/crm/me/password клиент делает `fetch("/api/auth/session", {method:"POST", body: JSON.stringify({}})` без csrfToken и глотает ошибку `.catch(()=>{})`. В @auth/core (node_modules/@auth/core/lib/index.js:57-59) POST action `session` вызывает `validateCSRF(action, csrfTokenVerified)`; skipCSRFCheck в auth.ts не задан → MissingCSRF, jwt-callback с trigger==='update' (auth.ts:224-234, единственное место, где перечитывается mustChangePassword) не вызывается. JWT сохраняет mustChangePassword=true, proxy.ts:220-226 снова редиректит на /crm/me/change-password; страница рендерится с forced=true (поле текущего пароля скрыто), а сервер уже видит mustChangePassword=false и требует currentPassword (route.ts:53-56) → 400 current_required.

СМ-13 Р2 · СРЕДНИЙ мёртвая механика

Пропущенные звонки: бейдж есть, списка для перезвона нет нигде

ГДЕ

src/components/layout/crm-sidebar.tsx:93, src/components/layout/crm-topbar.tsx:291, src/app/[locale]/crm/call-center/_hooks/use-incoming-calls.ts:23, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1179

СЦЕНАРИЙ

В сайдбаре «Колл-центр 5». Регистратор заходит перезвонить — видит «Сейчас тихо», номеров пропущенных нет.

ПОСЛЕДСТВИЯ

Потерянные пациенты не перезваниваются, хотя система их «посчитала».

ЧТО СДЕЛАТЬ

Добавить в колл-центр вкладку «История/Пропущенные» (GET /api/crm/calls с фильтром по status/direction и дате в ташкентских сутках) с кнопкой «Перезвонил» и привязкой к пациенту; обрабатывать intent=missed-calls.

КРИТЕРИЙ ПРИЁМКИ

Клик по бейджу открывает список пропущенных за сегодня с номерами и пациентами; отметка «перезвонили» убирает звонок из бейджа.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Сайдбар (crm-sidebar.tsx:93-100, badgeKey 'calls') и топбар (crm-topbar.tsx:291-298) показывают красный счётчик пропущенных за день и ведут на /crm/call-center. Колл-центр грузит только direction=IN без endedAt (use-incoming-calls.ts:23-35) — пропущенные (direction MISSED или с endedAt) не отображаются нигде; хуки инвалидируют ключ ["call-center", "history"], но такого запроса/компонента не существует. Ссылка action-center «Упущенные звонки» → /crm/call-center?from=losses&intent=missed-calls — параметр intent страница не читает.

СМ-14 P2 · СРЕДНИЙ баг**Публичный сайт: кнопка «Записаться» в мобильном меню ничего не делает; якорные ссылки меню мертвы на страницах врача/политики****ГДЕ**

src/components/layout/mobile-nav.tsx:40, src/components/layout/header.tsx:31, src/components/layout/footer.tsx:61, src/lib/constants.ts:34, src/components/layout/header.tsx:34, src/components/layout/mobile-nav.tsx:30

ТАКЖЕ НАШЛИ ЗОНЫ

Публичный лендинг, запись с сайта, SEO

СЦЕНАРИЙ

Пациент с телефона открывает бургер-меню и жмёт «Записаться на приём» — ничего не происходит. На странице врача жмёт «Врачи» в шапке — ничего.

ПОСЛЕДСТВИЯ

Потеря записей с мобильного трафика лендинга.

ЧТО СДЕЛАТЬ

Обернуть кнопку в LeadFormTrigger (и закрывать Sheet); ссылки делать ``/${locale}#doctors``.

КРИТЕРИЙ ПРИЁМКИ

На мобильном кнопка в меню открывает форму заявки; пункты меню с любой страницы ведут к секциям главной.

ДОКАЗАТЕЛЬСТВО В КОДЕ

mobile-nav.tsx:40-42 — `<Button ...>{t("bookAppointment")}</Button>` без onClick и без обёртки LeadFormTrigger (в header.tsx:52-56 для десктопа она есть). NAV_LINKS href="#doctors"/"#services"/... (constants.ts:34-39) используются в header/mobile-nav/footer на всех страницах (site)-лейаута, а секции с этими id есть только на главной.

СМ-15 P2 · СРЕДНИЙ безопасность**Смена пароля без аудита, без отзыва других сессий и без лимита попыток; отключение 2FA игнорирует «2FA для всех»****ГДЕ**

src/app/api/crm/me/password/route.ts:42, src/app/api/crm/me/totp/disable/route.ts:39

СЦЕНАРИЙ

Пароль регистратора утёк, злоумышленник залогинен. Регистратор меняет пароль — сессия злоумышленника продолжает работать, в журнале аудита следов смены нет.

ПОСЛЕДСТВИЯ

Смена пароля не выполняет свою защитную функцию; нет форензики.

ЧТО СДЕЛАТЬ

Добавить AUDIT_ACTION.PASSWORD_CHANGED, после смены удалять все UserSession пользователя кроме текущей и обновлять lastSessionRotatedAt; rateLimit по userId; в disable учитывать require2faForAll.

КРИТЕРИЙ ПРИЁМКИ

После смены пароля другие устройства разлогиниваются, в журнале аудита есть запись; 6-я неверная попытка за 15 минут даёт 429.

ДОКАЗАТЕЛЬСТВО В КОДЕ

password/route.ts:26-67: нет rateLimit на проверку currentPassword (в отличие от totp/* с rateLimit 5/15мин), нет audit() (в audit-actions.ts нет действия для смены пароля), не удаляются другие UserSession и не бампается lastSessionRotatedAt. totp/disable:39-41 блокирует только isMandatory2faRole (ADMIN/SUPER_ADMIN), не учитывая Clinic.require2faForAll, хотя страница (me/security/page.tsx:48-49) считает такую роль обязательной.

СМ-16 Р2 · СРЕДНИЙ баг

Фильтр документов по датам: конец периода исключается, выбор одного дня всегда пусто (UTC вместо Ташкента)

ГДЕ

src/app/api/crm/documents/route.ts:89, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:138, src/app/api/crm/documents/route.ts:87

ТАКЖЕ НАШЛИ ЗОНЫ

Клинические документы, больничные, рецепты, анализы, направления, файлы

СЦЕНАРИЙ

Администратор ищет документы за сегодня: ставит «с 23.09 по 23.09» — «Документов нет», хотя сегодня загружено 10 файлов. Диапазон «1–15 сентября» не показывает документы 15-го и документы 1-го, созданные до 05:00.

ПОСЛЕДСТВИЯ

Отчётность и поиск документов по периоду дают неверный результат.

ЧТО СДЕЛАТЬ

Интерпретировать даты как дни Asia/Tashkent: gte = tashkentDayBounds(from).dayStart, lt = tashkentDayBounds(to).dayEnd.

КРИТЕРИЙ ПРИЁМКИ

Фильтр с 23.09 по 23.09 возвращает все документы, созданные 23.09 по ташкентскому времени; unit-тест на границы суток.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Клиент шлёт from/to как `YYYY-MM-DD` из `<input type=date>`. Сервер: `range.gte = new Date(q.from)`, `range.lte = new Date(q.to)` (route.ts:89-90) — это полночь UTC (05:00 Ташкента), и `lte` полночи дня «по» отсекает весь этот день. При from=to=2026-09-23 условие createdAt ∈ [23.09 00:00Z; 23.09 00:00Z] — пустое.

СМ-17 Р3 · НИЗКИЙ мёртвая механика

«Онлайн-заявки» — мёртвая функция: API без страницы и без источника данных, ссылка из центра действий ведёт на 404

ГДЕ

src/app/api/crm/online-requests/route.ts:10, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1176, src/app/api/crm/dashboard/route.ts:101

СЦЕНАРИЙ

Руководитель в «Центре действий» видит строку «Упущенные заявки», кликает — 404. Заявки с сайта/бота на самом деле живут в других моделях и в эту метрику не попадают.

ПОСЛЕДСТВИЯ

Ложная метрика потерь и битая навигация; вводит в заблуждение при анализе.

ЧТО СДЕЛАТЬ

Либо удалить OnlineRequest-API, строку в action-center и KPI, либо свести заявки с лендинга/бота в эту модель и сделать страницу списка с обработкой.

КРИТЕРИЙ ПРИЁМКИ

В интерфейсе нет ссылок на несуществующие страницы; метрика «упущенные заявки» считает реальные заявки или удалена.

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET/PATCH /api/crm/online-requests существуют, но grep по src/scripts/prisma: OnlineRequest нигде не создаётся (нет create/upsert, нет сида), UI-потребителей нет. Страницы src/app/[locale]/crm/online-requests нет, а action-center ссылается на `/\${locale}/crm/online-requests?from=losses` (1176). Dashboard считает onlineRequest NEW за день (101-106) — всегда 0.

Бесконечный редирект /doctor ↔ /crm для врача без карточки Doctor или без clinicId**ГДЕ**

src/app/[locale]/crm/layout.tsx:63, src/app/[locale]/doctor/layout.tsx:64

СЦЕНАРИЙ

Админ удаляет карточку врача, пока тот залогинен, или привязка Doctor.userId потерялась — у врача браузер показывает ERR_TOO_MANY_REDIRECTS на любом URL до истечения сессии (до 24ч), без объяснения причины.

ПОСЛЕДСТВИЯ

Полная блокировка аккаунта с непонятной ошибкой вместо сообщения «профиль врача не настроен».

ЧТО СДЕЛАТЬ

В crm/layout.tsx не редиректить DOCTOR в кабинет, если есть searchParam error/notice или если профиль Doctor отсутствует (проверять тем же запросом, что doctor/layout); показать на /crm понятный экран «Профиль врача не привязан, обратитесь к администратору».

КРИТЕРИЙ ПРИЁМКИ

Пользователь DOCTOR без Doctor-строки видит страницу с объяснением, цикла редиректов нет; unit-тест на этот случай.

ДОКАЗАТЕЛЬСТВО В КОДЕ

doctor/layout.tsx:41-43 и 64-66 при отсутствии clinicId или Doctor-строки делают `redirect(/\${locale}/crm?error=no\_clinic|doctor\_profile\_missing)`, а crm/layout.tsx:63-66 для любого DOCTOR при включённом кабинете делает `redirect(/\${locale}/doctor)` без учёта параметра error. Тест tests/unit/doctor-cabinet-redirect.test.ts покрывает только kill-switch, не этот цикл. Удаление карточки врача (api/crm/doctors/[id] DELETE) деактивирует user, но живой JWT перечитывает active только при trigger==='update'.

Библиотека документов скрывает ошибки загрузки и имеет недоделанные элементы**ГДЕ**

src/app/[locale]/crm/documents/_components/documents-page-client.tsx:198, src/app/[locale]/crm/documents/_components/documents-page-client.tsx:319, src/app/[locale]/crm/documents/_hooks/use-documents.ts:61

СЦЕНАРИЙ

Оператор колл-центра открывает /crm/documents — видит «Документов нет» вместо «Нет доступа».

ПОСЛЕДСТВИЯ

Вводящие в заблуждение пустые состояния.

ЧТО СДЕЛАТЬ

Показывать ошибку/нет доступа, debounce поиска 300 мс, локализованная кнопка «Показать ещё», фильтр по врачу, сохранять signedById.

КРИТЕРИЙ ПРИЁМКИ

При 403 отображается сообщение об отсутствии доступа; набор в поиске даёт один запрос после паузы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

q.isError не обрабатывается: 403/500 рендерится как «Документов нет» (190-206). Кнопка догрузки подписана символом «+» (319), без текста/i18n. Поиск q отправляет запрос на каждое нажатие клавиши без debounce. Фильтр doctorId есть в state и API (use-documents.ts:61), но в UI его выставить нельзя. Кнопка «Отметить подписанным» не фиксирует, кто подписал (sign/route.ts пишет только signedAt).

Виджет «К подтверждению»: «Позвонить» не звонит, прошедшие записи подписаны «сегодня»**ГДЕ**

src/app/[locale]/crm/call-center/_components/unconfirmed-widget.tsx:207, src/app/[locale]/crm/call-center/_components/unconfirmed-widget.tsx:281

СЦЕНАРИЙ

Оператор жмёт «Позвонить» и ждёт набора — открывается карточка. Просроченная неподтверждённая запись выглядит как сегодняшняя.

ПОСЛЕДСТВИЯ

Мелкая путаница в приоритизации обзвона.

ЧТО СДЕЛАТЬ

Переименовать в «Карточка» или показывать номер с tel; для прошедших записей показывать «просрочено»; форматировать в Asia/Tashkent.

КРИТЕРИЙ ПРИЁМКИ

Прошедшая запись помечена как просроченная; подпись кнопки соответствует действию.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Иконка-кнопка с aria-label «Позвонить» — Link на карточку пациента (207-214). formatRelativeApptTime: `if (diffDays <= 0) return t("relative.today")` (281) — запись вчера/позавчера тоже «сегодня»; время считается в TZ браузера (getHours), не Asia/Tashkent.

СМ-21 РЗ · НИЗКИЙ безопасность

Вход SUPER_ADMIN в клинику: кнопка «Отмена» в confirm даёт режим записи (WRITE)

ГДЕ

src/components/layout/clinic-switcher.tsx:119

СЦЕНАРИЙ

Поддержка хочет только посмотреть проблему клиента, на втором диалоге передумывает и жмёт «Отмена» — входит в клинику с правом изменения данных.

ПОСЛЕДСТВИЯ

Непреднамеренные изменения в реальной клинике под админом платформы; опасный дефолт.

ЧТО СДЕЛАТЬ

Заменить prompt/confirm на модальное окно с явным выбором режима (по умолчанию VIEW_ONLY) и кнопкой отмены, которая прерывает вход; локализовать.

КРИТЕРИЙ ПРИЁМКИ

Отмена на любом шаге не отправляет switch-clinic; по умолчанию выбран «Только просмотр».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`const viewOnly = window.confirm("OK = VIEW\_ONLY (read-only).\nCancel = WRITE (mutations allowed).")` (119-122): отказ/закрытие диалога или блокировка браузером повторных диалогов (confirm → false) приводит к mode='WRITE'. Строки не локализованы (англ./рус. хардкод).

СМ-22 РЗ · НИЗКИЙ баг

Загрузка кабинетов в сайдбаре занижена (не учитывает CONFIRMED), «записей сегодня» включает отменённые

ГДЕ

src/app/api/crm/shell-summary/route.ts:66, src/app/api/crm/shell-summary/route.ts:58

СЦЕНАРИЙ

Колл-центр подтверждает завтрашние записи — завтра процент загрузки в сайдбаре падает по мере подтверждений; в счётчике «записей сегодня» учтены отменённые.

ПОСЛЕДСТВИЯ

Неверный индикатор загрузки для администратора.

ЧТО СДЕЛАТЬ

Добавить CONFIRMED в список; для счётчика исключить CANCELLED (и, по решению, NO_SHOW).

КРИТЕРИЙ ПРИЁМКИ

Подтверждение записи не меняет load%; отмена записи уменьшает счётчик.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Числитель load% — `status: { in: ["BOOKED","WAITING","IN\_PROGRESS","COMPLETED"] }` (63-69), без CONFIRMED (есть в enum AppointmentStatus). appointmentsCount (58-60) считает все статусы, включая CANCELLED/NO_SHOW.

СМ-23 РЗ · НИЗКИЙ баг

Смена филиала не сбрасывает клиентский кеш: списки остаются от прежнего филиала

ГДЕ

src/components/layout/branch-switcher.tsx:106

СЦЕНАРИЙ

Администратор сети переключается с филиала А на Б — очередь и записи на экране ещё до минуты показывают филиал А.

ПОСЛЕДСТВИЯ

Риск действий над данными не того филиала (актуально при >1 филиале).

ЧТО СДЕЛАТЬ

После успешного переключения вызывать `queryClient.clear()/invalidateQueries()` или делать `window.location.reload()`.

КРИТЕРИЙ ПРИЁМКИ

Сразу после смены филиала все списки перезагружаются с данными нового филиала.

ДОКАЗАТЕЛЬСТВО В КОДЕ

После POST `/api/crm/branches/active` вызывается только ``router.refresh()`` (105-106) — обновляет RSC, но данные ресепшена/записей/звонков живут в TanStack Query с `staleTime` и не инвалидируются.

СМ-24 РЗ · НИЗКИЙ переводы

Смена языка в топбаре CRM не сохраняется в профиле и откатывается при следующем входе

ГДЕ

src/components/layout/crm-topbar.tsx:130, src/components/layout/language-switcher.tsx:62, src/lib/auth.ts:191

СЦЕНАРИЙ

Регистратор-узбек переключает CRM на UZ, завтра входит — снова русский.

ПОСЛЕДСТВИЯ

Раздражающая мелочь для узбекоязычного персонала.

ЧТО СДЕЛАТЬ

В `switchLocale` топбара вызывать тот же PATCH `/api/me`, что и `LanguageSwitcher` (вынести в общий хелпер).

КРИТЕРИЙ ПРИЁМКИ

После выбора UZ в топбаре и повторного входа интерфейс на узбекском.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`switchLocale` в топбаре (130-134) пишет только cookie `NEXT_LOCALE`. `LanguageSwitcher` (62-66) дополнительно делает PATCH `/api/me {locale}`. При входе `jwt-callback` (`auth.ts:191-199`) перезаписывает cookie из `User.preferredLocale`.

СМ-25 РЗ · НИЗКИЙ мёртвая механика

Страница витрины компонентов доступна в проде (200 «Недоступно»), dev-хелпер `MissingKeyWarner` не используется

ГДЕ

src/app/[locale]/crm/(dev)/components/page.tsx:55, src/components/dev/missing-key-warner.tsx:53

СЦЕНАРИЙ

Любой сотрудник по `/crm/components` видит служебную страницу на русском.

ПОСЛЕДСТВИЯ

Мелкий мусор в проде.

ЧТО СДЕЛАТЬ

В production вызывать `notFound()`; удалить или начать использовать `missing-key-warner`.

КРИТЕРИЙ ПРИЁМКИ

`/crm/components` в проде отдаёт 404.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`(dev)/components/page.tsx:55-61` в production возвращает страницу с хардкодом «Недоступно / Витрина компонентов доступна только в dev.» и статусом 200 (не `notFound`), без перевода на uz. `useT/T` из

missing-key-warner.tsx нигде не импортируются (grep).

СМ-26 РЗ · НИЗКИЙ UX

Топбар и сайдбар не учитывают роль и тариф: кнопки «Выдать талон (F2)», «Новая запись» у медсестры/оператора, «Настройки» у всех, иконки Звонки/Telegram ведут на 404

ГДЕ

src/components/layout/crm-topbar.tsx:177, src/components/layout/crm-topbar.tsx:291, src/components/layout/crm-sidebar.tsx:166, src/components/layout/crm-topbar.tsx:57, src/components/layout/crm-topbar.tsx:297, src/app/[locale]/crm/call-center/page.tsx:22, src/app/[locale]/crm/telegram/page.tsx:27

ТАКЖЕ НАШЛИ ЗОНЫ

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

СЦЕНАРИЙ

Медсестра нажимает большую синюю «Выдать талон» — ошибка 403; клиника на базовом тарифе кликает иконку «Звонки» — 404; на «Центре действий» заголовок страницы «Ресепшн».

ПОСЛЕДСТВИЯ

Путаница и ложные ошибки у персонала.

ЧТО СДЕЛАТЬ

Передавать в топбар flags и роль; скрывать действия, недоступные роли; добавить requiredRole ADMIN для «Настроек»; дополнить SECTION_KEY.

КРИТЕРИЙ ПРИЁМКИ

У NURSE/CALL_OPERATOR нет кнопок, которые приводят к 403; на базовом тарифе нет иконок недоступных разделов; заголовок совпадает с разделом.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Главная кнопка и F2 (177-186, 218-253) открывают WalkinTicketDialog → POST /api/crm/appointments/walkin roles [ADMIN,RECEPTIONIST,DOCTOR] — у NURSE/CALL_OPERATOR 403. Иконки «Звонки»/«Telegram» (291-306) показываются без проверки hasCallCenter/hasTelegramInbox (топбар не получает flags), а страницы делают notFound(). Пункт «Настройки» (sidebar:166) без requiredRole — не-админа settings/layout.tsx редиректит на /crm. SECTION_KEY (57-71) не содержит action-center/cases/me — на этих страницах заголовок «Ресепшн», хотя ключ actionCenter в i18n есть. GlobalTgAlerts в layout пишит всем ролям.

СМ-27 РЗ · НИЗКИЙ баг

Тост «Входящий звонок» в очереди колл-центра практически никогда не показывается; подпись «обновляется каждые 5 секунд» ложная

ГДЕ

src/app/[locale]/crm/call-center/_components/incoming-queue.tsx:45, src/app/[locale]/crm/call-center/_hooks/use-incoming-calls.ts:21

СЦЕНАРИЙ

Оператор смотрит в карточку пациента в центральной колонке; приходит новый звонок — уведомления нет, звонок замечают через минуту или не замечают.

ПОСЛЕДСТВИЯ

Пропущенные входящие из-за отсутствия сигнала.

ЧТО СДЕЛАТЬ

Запоминать id первичной загрузки отдельным флагом (isInitialized) и тостить каждый новый id после неё; добавить звук как в GlobalTgAlerts; исправить текст подсказки.

КРИТЕРИЙ ПРИЁМКИ

При появлении нового звонка в очереди (SSE или поллинг) всегда показывается тост; при первичной загрузке — нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

incoming-queue.tsx:40-55: новый id добавляется в seenRef, тост только если `seenRef.current.size > rows.length`; в конце эффекта set очищается до текущих rows. Значит в начале каждого прогона set == предыдущие rows, и size > rows.length только если какой-то звонок одновременно ушёл из очереди. Пример: rows [A,B] → пришёл C, rows [C,A,B], size 3 > 3 — ложь, тоста нет. Подпись pollingHint «Обновляется каждые 5 секунд»/«Har 5 soniyada» при POLL_MS = 60_000 (use-incoming-calls.ts:21).

UX · Сквозной проход: мокапы, заглушки, фейковые данные, i18n

UX-01 P2 · СРЕДНИЙ целостность данных

AI «выключен» (AI_ENABLED=false), но сервер продолжает генерировать и сохранять AI/mock-текст в медкарту (summaryCache, soapDraft) и отправлять медданные провайдеру

ГДЕ

src/lib/ai-enabled.ts:11, src/app/[locale]/doctor/reception/_components/ai-summary-panel.tsx:49, src/server/ai/patient-summary-cache.ts:163, src/server/workers/patient-summary-refresh.ts:155, src/server/ai/llm.ts:258, src/server/ai/transcribe.ts:184, src/server/workers/voice-soap.ts:144, src/server/workers/patient-summary-refresh.ts:126, src/components/ui/in-development.tsx:38, src/app/[locale]/doctor/reception/_components/ai-summary-panel.tsx:47, src/app/[locale]/doctor/reception/_components/ai-summary-panel.tsx:70, src/app/[locale]/doctor/reception/_components/ai-summary-panel.tsx:94, src/app/[locale]/doctor/visits/[patientId]/page.tsx:184, src/lib/ai-enabled.ts:12

ТАКЖЕ НАШЛИ ЗОНЫ

Остальной кабинет врача, Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

СЦЕНАРИЙ

Врач открывает историю визитов пациента: в правой (приглушённой) панели «AI-резюме» появляется «[mock-llm: mock] Пациент: Иванова Мария, F, возраст 34, в кл...». Врач отправляет боту голосовое по пациенту с открытым случаем — в карточке случая SOAP-черновик «Пациент жалуется на головную боль», хотя пациент жаловался на другое. Пациент запрашивает выгрузку своих данных и получает этот мусор как «резюме».

ПОСЛЕДСТВИЯ

Фиктивный медицинский текст в медкарте и в DSAR-выгрузке; при включении флага AI сразу покажет заранее накопленные mock-резюме как настоящие (кэш «свежий» 24 ч). Если ключи есть — обработка медданных третьей стороной вопреки заявленному «AI выключен».

ЧТО СДЕЛАТЬ

Сделать серверный kill-switch (env/настройка клиники), который проверяется в /api/crm/patients/[id]/summary, /summary/refresh, voice-handler и воркерах patient-summary/voice-soap; не монтировать запросы в выключенных панелях (enabled: AI_ENABLED && ...). В production запретить fallback на mock (бросать ошибку, не писать в БД). Очистить уже записанные summaryCache/soapDraft с префиксами [mock-llm/[mock-transcript]]. Передавать locale пользователя вместо ru. Убрать primaryService из поля «назначения» (брать реальные назначения/VisitPrescription). Убрать хардкод confidence 92.

КРИТЕРИЙ ПРИЁМКИ

При AI_ENABLED=false открытие пациентов и голосовые врача не создают jobs ai:* и строк LLMUsage; в БД нет summaryCache/soapDraft начинающихся с «[mock-»»; в prod без ключа вызов LLM завершается ошибкой без записи; резюме строится на uz для uz-интерфейса.

ДОКАЗАТЕЛЬСТВО В КОДЕ

AI_ENABLED=false only dims UI. AISummaryPanel (rendered on /doctor/visits/[patientId], page.tsx:184) runs its query with `enabled: !!patientId` (ai-summary-panel.tsx:49) → GET /api/crm/patients/{id}/summary?locale=ru (hardcoded ru) → readOrRefreshPatientSummary enqueues an LLM job when cache is missing/stale (patient-summary-cache.ts:163) → worker (started unconditionally, start.ts:75) writes Patient.summaryCache (patient-summary-refresh.ts:155). callLLM silently falls back to provider «mock» when ANTHROPIC_API_KEY is missing (llm.ts:258; key absent from .env.example) and invokeMock returns `[mock-llm: mock] <first 50 chars of prompt>` (llm.ts:427-431), which is non-empty so it is persisted instead of the deterministic fallback (summary.ts:201-203). InDevelopment only sets opacity-40 (in-development.tsx:38), text stays readable; summaryCache is also exported to the patient in DSAR (data-export.ts:278). Voice path: a doctor's TG voice note → voice-soap worker (start.ts:81) → transcribe falls back to mock returning «[mock-transcript ru] Пациент жалуется на головную боль.» (transcribe.ts:143,184) → structureSoap puts raw text into subjective on parse miss (soap.ts:230) → overwrites MedicalCase.soapDraft (voice-soap.ts:144). If keys ARE set, pseudonymized diagnoses/notes are sent to Anthropic/OpenAI although the product says AI is paused. Prompt mislabels the visit's service as treatment: `prescriptions: v.primaryService?.nameRu` (patient-summary-refresh.ts:126) → summary will state «назначения: Консультация невролога». TG inbox AI card shows hardcoded `confidence = 92` and keyword recs (chat-right-rail.tsx:595, 669-690).

UX-02 P2 · СРЕДНИЙ баг

KPI ресепшена искажены: «В очереди сейчас» считает все непришедшие брони, «Прибыли сегодня» = завершённые, «сум сум», загрузка без подтверждённых

ГДЕ

src/app/[locale]/crm/reception/_components/kpi-strip.tsx:63, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:116, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:141, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:150, src/app/api/crm/shell-summary/route.ts:66, src/app/[locale]/crm/analytics/financial/page.tsx:36, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:62, src/app/[locale]/crm/reception/_components/kpi-strip.tsx:68, src/app/api/crm/dashboard/route.ts:111, src/app/[locale]/crm/reception/_hooks/use-reception-live.ts:443

ТАКЖЕ НАШЛИ ЗОНЫ

Записи, календарь, ресепшн, слоты, цены визита

СЦЕНАРИЙ

В 9:00 у регистратора «В очереди сейчас: 42 человека», хотя в холле 3. «Прибыли сегодня: 0» при 10 пациентах в клинике, пока ни один приём не завершён. Загрузка в сайдбаре падает, когда пациенты подтверждают запись в Telegram.

ПОСЛЕДСТВИЯ

Неверная оперативная картина на главном экране регистратуры.

ЧТО СДЕЛАТЬ

«В очереди» = только WAITING (живая очередь) либо отдельно «пришли/ждут» и «ожидаются по записи»; «Прибыли» = WAITING+IN_PROGRESS+COMPLETED; убрать unit у денежной плитки; ссылку выручки показывать только ADMIN; добавить CONFIRMED в числитель загрузки.

КРИТЕРИЙ ПРИЁМКИ

При 3 ожидающих и 20 будущих бронях плитка показывает 3; подтверждение записи в TG не уменьшает загрузку; строка выручки без дублирования валюты; регистратор не получает 404.

ДОКАЗАТЕЛЬСТВО В КОДЕ

waiting = WAITING + BOOKED + CONFIRMED queue buckets for the whole day (kpi-strip.tsx:63-66) labelled «В очереди сейчас / Ожидают приём» — includes bookings at 17:00 and people who never came. Tile «Прибыли сегодня» (checkedIn, line 116) shows `today.completed` (count of status COMPLETED). Revenue tile renders MoneyText («1 500 000 сум») plus unit «сум» (line 150; KpiTile renders value then unit, kpi-tile.tsx:64-71) → «сум сум»; it links to /crm/analytics/financial (141) which is ADMIN-only notFound for others (financial/page.tsx:36-38) → 404 for receptionists. Sidebar load % sums durationMin only for [BOOKED, WAITING, IN_PROGRESS, COMPLETED] (shell-summary/route.ts:66) — CONFIRMED (patient pressed «Подтверждаю» in TG) is excluded although the comment says «non-cancelled».

UX-03 P2 · СРЕДНИЙ мокап / загрузка

Аналитика показывает выдуманные данные: «Причины неявок» с фиксированными процентами, синтетическая «Динамика загрузки клиники», смещённые дельты

ГДЕ

src/app/[locale]/crm/analytics/_components/funnel-cards.tsx:155, src/app/[locale]/crm/analytics/_components/funnel-cards.tsx:367, src/app/[locale]/crm/analytics/_components/analytics-page-client.tsx:100, src/app/[locale]/crm/analytics/_components/analytics-charts.tsx:236, src/app/[locale]/crm/analytics/_components/funnel-cards.tsx:101, src/app/[locale]/crm/analytics/_components/funnel-cards.tsx:389, src/app/api/crm/analytics/funnels/route.ts:200, src/app/[locale]/crm/analytics/_components/funnel-cards.tsx:293

ТАКЖЕ НАШЛИ ЗОНЫ

Аналитика, выручка, оплаты, биллинг, экспорты

СЦЕНАРИЙ

Владелец клиники смотрит «Аналитику» за неделю: видит, что 22% неявок «пациент забыл», 16% «нет транспорта», загрузка клиники «84%» и выручка «+31%». Все эти числа не отражают реальности; при равной выручке неделя всегда «растёт».

ПОСЛЕДСТВИЯ

Управленческие решения (напоминания, штат, маркетинг) принимаются на основании сфабрикованных цифр; нарушено правило «ничего выдуманного».

ЧТО СДЕЛАТЬ

Удалить таблицу причин неявок или сделать сбор причины (enum/свободный текст при отметке NO_SHOW,

риск-исходы из TZ-risk-outcomes) и считать реальное распределение. Загрузку клиники считать как забронированные минуты / доступные минуты по DoctorSchedule (как в shell-summary). Дельты считать против предыдущего равного периода на сервере; при недостатке данных не показывать.

КРИТЕРИЙ ПРИЁМКИ

На пустой/новой клинике таблица причин пуста или скрыта; при равной выручке дельта $\approx 0\%$; загрузка клиники совпадает с расчётом по расписанию; в коде нет констант весов/90%.

ДОКАЗАТЕЛЬСТВО В КОДЕ

NoShowReasonsTable: `// Synthesize the 10-row distribution` with `NO\_SHOW\_WEIGHTS = [0.22, 0.16, 0.13, ...]` (funnel-cards.tsx:153-188) applied to hardcoded REASON_KEYS
patientForgot/noTransport/wrongTime/feltBetter/.../weather (analytics-page-client.tsx:100-111). Title «No-show: топ-10»; rows «Пациент забыл 22%, Нет транспорта 16% ... Погодные условия 3%» are the same for any clinic — no reason is recorded anywhere. ClinicLoadCard: `// Clinic-load series synthesized ... capacity baseline is the period max so the line lives in the 60–90% range like the target` → `load = round(d.total / max \* 90)` (funnel-cards.tsx:367-373) — the busiest day is always 90%. Deltas: revenue delta compares first vs second half of the period by SUM (analytics-charts.tsx:236-246); for «Неделя» (7 days) half=3 → 3 days vs 4 days → $\approx +33\%$ bias with flat revenue; funnel delta is also «synthesized from sparkline halves» (funnel-cards.tsx:101).

UX-04 P2 · СРЕДНИЙ мокап / заглушка

Политика конфиденциальности и условия на сайте содержат ложные утверждения (серверы в Узбекистане, шифрованные бэкапы 30 дней, никаких третьих лиц, SMS)

ГДЕ

src/messages/ru.json:5735, src/messages/ru.json:5731, src/messages/ru.json:5761, ops/backup.sh:36, ops/backup.sh:55, README.md:75, src/messages/ru.json:5737, src/messages/uz.json:5737, ops/backup.sh:54, docs/README.md:6, src/app/[locale]/(site)/privacy/page.tsx:23, src/components/sections/lead-form.tsx:255

ТАКЖЕ НАШЛИ ЗОНЫ

Публичный лендинг, запись с сайта, SEO

СЦЕНАРИЙ

Пациент (или проверяющий орган) читает политику на neurofax.uz: указано хранение в Узбекистане и шифрованные бэкапы. Фактически данные и незашифрованные копии лежат на сервере Hetzner, хранятся 14 дней.

ПОСЛЕДСТВИЯ

Юридический риск для клиники (закон РУз о персональных данных требует локализации; ложная публичная оферта), подрыв доверия пациентов.

ЧТО СДЕЛАТЬ

Привести тексты в соответствие с фактами (место хранения, срок и способ хранения бэкапов, перечень обработчиков: Telegram, облачные AI-провайдеры при включении, хостинг), убрать SMS; либо привести инфраструктуру к заявленному (локализация, шифрование бэкапов gpg/age, retention 30). Дата «Обновлено» должна меняться.

КРИТЕРИЙ ПРИЁМКИ

Каждое утверждение политики подтверждается конфигурацией (ops/backup.sh, место хостинга, список интеграций); в тексте нет SMS; юрист/владелец утвердил новую редакцию.

ДОКАЗАТЕЛЬСТВО В КОДЕ

legal.privacy.storage.body: «Данные хранятся на серверах в Узбекистане ... Резервные копии шифруются и хранятся 30 дней» (ru.json:5735-5738, same in uz). Deployment docs state prod is a Hetzner VPS (README.md:75, docs/operations/DEPLOY.md:111). ops/backup.sh writes plain `gzip -9` dumps and a plain tar of MinIO files (lines 55, 84) with `BACKUP\_RETENTION\_DAYS:=14` (line 36) — no encryption, 14 days. legal.privacy.share: «С третьими лицами — только по вашему письменному согласию» (5731) while medical content is sent to Telegram and (when configured) Anthropic/OpenAI (llm.ts, transcribe.ts). legal.terms.booking.body: «Подтверждение записи приходит по SMS или Telegram» (5761) although SMS was removed (docs/TZ-sms-removal.md). Pages are linked from the site footer (footer.tsx:113-122).

UX-05 P2 · СРЕДНИЙ баг

Просмотр подписанного визита у врача показывает время визита и подписи в UTC (–5 ч)

ГДЕ

src/app/[locale]/doctor/visits/[patientId]/[visitId]/_components/visit-note-readonly.tsx:41, src/app/[locale]/doctor/visits/[patientId]/[visitId]/_components/visit-note-readonly.tsx:46, src/app/[locale]/doctor/visits/[patientId]/[visitId]/page.tsx:142

СЦЕНАРИЙ

Врач открывает подписанное заключение визита, прошедшего в 10:00–10:30: видит «05:00–05:30», подписано «... · 05:12». Визит, подписанный ночью в 01:30, показывает предыдущую дату.

ПОСЛЕДСТВИЯ

Неверные метаданные медицинского документа в интерфейсе врача; путаница при разборе спорных случаев (24-часовое окно правки считается от firstFinalizedAt).

ЧТО СДЕЛАТЬ

Форматировать в Asia/Tashkent (tashkentComponents или Intl.DateTimeFormat с timeZone) и в локали пользователя (ru/uz) через next-intl formatter с глобальным timeZone в src/i18n/request.ts.

КРИТЕРИЙ ПРИЁМКИ

Для визита 10:00–10:30 по Ташкенту страница показывает 10:00–10:30 и корректное время подписи; в uz интерфейсе месяцы на узбекском.

ДОКАЗАТЕЛЬСТВО В КОДЕ

VisitNoteReadOnly is a server component (async, getTranslations from next-intl/server, no "use client"). It formats with `d.getDate()/getMonth()/getFullYear()` (ruDate, line 41-44) and `d.getHours()/getMinutes()` (hhmm, line 46-49) on the server, i.e. in UTC. Used for appointment date, «time from–to» and «finalizedAt» (lines 60-72). It is the only doctor-side server component doing local-time formatting (all others are client components). Month names are also hardcoded Russian (RU_MONTHS, line 26).

UX-06 P2 · СРЕДНИЙ переводы

Публичные экраны для пациентов только на русском: талон, страница очереди /q, ТВ-табло и голосовой вызов

ГДЕ

src/app/tv/_shared.tsx:119, src/app/tv/page.tsx:106, src/app/q/[id]/page.tsx:69, src/app/ticket/[id]/page.tsx:128, src/app/c/[slug]/my/_components/error-boundary.tsx:116

СЦЕНАРИЙ

Пожилый узбекоязычный пациент выбрал в киоске узбекский, получил талон на русском, а на табло его вызывают только по-русски — он не понимает, что вызвали его.

ПОСЛЕДСТВИЯ

Пропуски вызова, неявки в кабинет, недовольство пациентов в Ташкенте.

ЧТО СДЕЛАТЬ

Добавить uz-версии: язык талона — по выбору в киоске/preferredLang; табло — двуязычный текст и последовательный голосовой вызов ru + uz (uz-UZ voice или записанные фразы); /q и error boundary — по языку пациента.

КРИТЕРИЙ ПРИЁМКИ

Талон, /q и табло доступны на узбекском; голосовой вызов звучит на обоих языках.

ДОКАЗАТЕЛЬСТВО В КОДЕ

TV announcement: `u.lang = "ru-RU"` with text «Талон X, пройдите в кабинет N» (tv/_shared.tsx:114-119); TV labels «Ожидают», «На приёме», «Свободен», «Сегодня приёма нет» hardcoded (tv/page.tsx:106-327); /q status page and its browser notification hardcoded Russian (q/[id]/page.tsx:69 and UI); ticket page all Russian («Ваш номер», «Перед вами», «Спасибо за визит!»; ticket/[id]/page.tsx:128-190) even when the patient chose Uzbek in the kiosk (kiosk has a uz dictionary); mini-app error boundary Russian-only (error-boundary.tsx:116-129).

Сломанный ICU-синтаксис в 9 сообщениях (ru и uz): вместо текста показывается ключ — конфликт записи «Врач занят до...», карточки «Низкий NPS» и «Контрольный визит» в Центре действий

ГДЕ

src/messages/ru.json:756, src/messages/ru.json:873, src/messages/ru.json:947, src/messages/ru.json:5223, src/messages/ru.json:5233, src/messages/ru.json:2827, src/lib/actions/format.ts:191, src/components/appointments/NewAppointmentDialog.tsx:615, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:217, src/app/[locale]/crm/calendar/_components/calendar-view.tsx:368

СЦЕНАРИЙ

Регистратор перетаскивает запись в календаре на занятое время — видит тост «calendar.conflict.doctor_busy» вместо «Врач занят до 14:30». В Центре действий карточка «Контрольный визит» от врача показывает «actionCenter.types.VISIT_FOLLOW_UP_DUE.body» — комментарий врача, что и когда сделать, не виден.

ПОСЛЕДСТВИЯ

Регистратура не понимает причину отказа при записи; теряется инструкция врача по контрольному визиту и текст жалобы пациента из NPS.

ЧТО СДЕЛАТЬ

Переписать сообщения на валидный ICU: например передавать флаг hasUntil = yes/no и использовать {hasUntil, select, yes { до {until}} other {} }; аналогично для commentPreview/followUpNote; в bodyPlaceholder экранировать фигурные скобки через апострофы или использовать t.raw. Добавить unit-тест, который парсит все строки ru/uz через intl-messageformat и сверяет наборы аргументов.

КРИТЕРИЙ ПРИЁМКИ

Тест парсинга всех сообщений проходит (0 ошибок); при конфликте видно «Врач занят до HH:MM» (ru) и «Shifokor band HH:MM gacha» (uz); карточки NPS/контрольного визита показывают текст и комментарий.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Messages use an empty select case: «Врач занят{until, select, , {} other{ до {until}}}}» (ru.json:756-757, 873-874, 947-948, identical in uz.json), «{commentPreview, select, , {...} other{...}}» (5223) and «{followUpNote, select, , {...} other{...}}» (5233); notifications.editor.bodyPlaceholder contains «{{patient.firstName}}» (2827). Parsing with the project's @formatjs/icu-messageformat-parser and with intl-messageformat 11.2.0 (the runtime used by use-intl 4.9) throws EXPECT_SELECT_ARGUMENT_SELECTOR / MALFORMED_ARGUMENT for all 9 keys in both locales. next-intl then returns getMessageFallback = «namespace.key». Consumers: booking conflict alert (NewAppointmentDialog.tsx:615), drawer reschedule toast (appointment-drawer.tsx:217), calendar drag conflict toast (calendar-view.tsx:291,368), action card bodies via formatActionBody (format.ts:191) for LOW_NPS_RECEIVED and VISIT_FOLLOW_UP_DUE, template editor placeholder (template-editor.tsx:351).

Телефония — макет: «Call Center», виджет звонков на ресепшене и карточка «Телефония» в настройках выглядят рабочими, но реальной интеграции нет

ГДЕ

src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:90, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:208, src/app/api/calls/sip/event/route.ts:108, src/app/api/calls/sip/event/route.ts:331, src/server/telephony/index.ts:43, src/app/[locale]/crm/reception/_components/calls-widget.tsx:89, src/app/[locale]/crm/call-center/_components/call-actions-rail.tsx:118, src/app/api/calls/sip/event/route.ts:327, src/app/[locale]/crm/settings/integrations/_components/integrations-client.tsx:76, src/server/telephony/index.ts:32, src/server/telephony/log-only.ts:50

ТАКЖЕ НАШЛИ ЗОНЫ

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония

СЦЕНАРИЙ

Админ заполняет «Телефония»: сервер, логин, пароль — видит «Подключено». Звонки пациентов в клинику так и не появляются ни в Call Center, ни в виджете на ресепшене, пропущенные не считаются. Регистратор видит вечное «Нет активных звонков».

ПОСЛЕДСТВИЯ

Функция, продаваемая в тарифе (hasCallCenter), не работает; ложный статус «Подключено»; пропущенные звонки не учитываются в «Потерях».

ЧТО СДЕЛАТЬ

Либо скрыть Call Center/виджет/карточку до интеграции, либо довести: поле webhookSecret в UI клиники, адаптер конкретной АТС (OnlinePBX/Mango/UIS) с нормализацией событий, статус «Подключено» только после первого успешного события; виджет на ресепшене показывать только при hasCallCenter и настроенной телефонии; переименовать «Принять» в «Записать».

КРИТЕРИЙ ПРИЁМКИ

При настроенной АТС входящий звонок в течение секунд появляется в Call Center и в виджете ресепшена; без настроенной телефонии виджета/раздела нет, а карточка показывает «Не подключено».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Clinic settings card «Телефония» (kind OTHER, variants sip/custom) saves `config: {server, username}` and an encrypted secret into secretCipher (integrations-client.tsx:76-95, 206-213; integrations/route.ts POST). The SIP webhook only accepts `config.webhookSecret` from a ProviderConnection kind OTHER label sip (sip/event/route.ts:108-117) and rejects all events in production without it (331-334) — the clinic UI has no field for it and never writes it; the card turns green «Подключено» as soon as `active && hasSecret`. The webhook expects a canonical payload «normalized from real providers by adapter code» — no provider adapter exists; resolveTelephonyForClinic always returns LogOnly (telephony/index.ts:43-66, TODOs at 11-17) and has no callers. Reception always renders CallsWidget «CALL CENTER / Нет активных звонков» regardless of plan (reception-page-client.tsx:340); its «Принять» button just opens the booking dialog (calls-widget.tsx:89-94) and «Отклонить» only sets endedAt in DB. Call-center Transfer/Mute/Hold are permanently disabled (call-actions-rail.tsx:118-139).

UX-09 P2 · СРЕДНИЙ бар

Центр действий: «Пропущенные заявки» ведёт на 404 и всегда 0, «Запустить реактивацию» открывает список пациентов с ошибкой, «Telegram-рассылка» не открывает рассылку

ГДЕ

src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1176, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1112, src/app/[locale]/crm/action-center/_components/action-center-client.tsx:1091, src/app/[locale]/crm/patients/_hooks/use-patients-filters.ts:57, src/server/schemas/patient.ts:54

СЦЕНАРИЙ

Регистратор нажимает «Запустить реактивацию» — страница пациентов показывает ошибку загрузки. Нажимает «Пропущенные заявки» — 404. Нажимает «Telegram-рассылка» — попадает в журнал уведомлений без окна рассылки.

ПОСЛЕДСТВИЯ

Ключевые быстрые действия неработоспособны.

ЧТО СДЕЛАТЬ

Ссылку на заявки направить на реальный экран заявок (см. находку про Lead); реактивацию — `segment=DORMANT` или нормализация в toUpperCase в фильтрах; рассылку — на /crm/telegram с открытием BroadcastDialog по параметру; добавить локаль в href.

КРИТЕРИЙ ПРИЁМКИ

Все три действия открывают рабочие экраны без ошибок, в uz-интерфейсе язык сохраняется.

ДОКАЗАТЕЛЬСТВО В КОДЕ

TodayLosses row href `/\${locale}/crm/online-requests?from=losses` (1176) — no such page under src/app/[locale]/crm; its count is dashboard.missedToday.requests = onlineRequest.count (dashboard/route.ts:101), and OnlineRequest is never created anywhere (no onlineRequest.create/upsert in src/prisma/scripts). QuickActions «Запустить реактивацию» → `/crm/patients?segment=dormant` (1112, also AI rec at 1041): patients filters pass the raw lowercase value to the API (use-patients-filters.ts:57), QueryPatientSchema.segment is z.enum(["NEW", "ACTIVE", "DORMANT", ...]) (patient.ts:54) → 400 ValidationError. «Telegram-рассылка» → `/crm/notifications?compose=telegram` (1091) — `compose` is never read; the broadcast composer lives in /crm/telegram. QuickActions links also omit the locale prefix (uz user is switched to ru).

Шаблоны уведомлений: канал Email предлагается, но отправка всегда FAILED; «Тестовая отправка» всегда падает (patientId «dev-fake-patient»)

ГДЕ

src/app/[locale]/crm/notifications/_components/template-editor.tsx:289, src/app/[locale]/crm/notification s/_components/template-editor.tsx:202, src/app/api/crm/notifications/sends/route.ts:62, src/server/workers/notifications-send.ts:265, src/app/[locale]/crm/notifications/_components/template-editor.tsx:423

ТАКЖЕ НАШЛИ ЗОНЫ

Telegram-бот, переписки, рассылки, уведомления, воркеры

СЦЕНАРИЙ

Админ создаёт шаблон «Напоминание по email», включает — все отправки падают, в топбаре растёт красный счётчик. Жмёт «Тестовая отправка» у любого шаблона — ошибка 500 с текстом Prisma.

ПОСЛЕДСТВИЯ

Нерабочий канал выглядит доступным; тестирование шаблонов невозможно.

ЧТО СДЕЛАТЬ

Убрать EMAIL из выбора (или реализовать email-адаптер); тестовую отправку делать на текущего пользователя (его привязанный Telegram) через отдельный эндпоинт без записи в NotificationSend, либо на выбранного реального пациента.

КРИТЕРИЙ ПРИЁМКИ

В редакторе только работающие каналы; «Тестовая отправка» доставляет сообщение сотруднику в Telegram и показывает понятный результат.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Template editor offers channel select Telegram/Email (template-editor.tsx:288-289); the send worker dispatches only TG/INAPP and throws «Channel EMAIL not dispatchable» for everything else (notifications-send.ts:260-265) → every send becomes FAILED and inflates the red notifications badge (shell-summary counts FAILED). «Тестовая отправка» posts `patientId: "dev-fake-patient", `recipient: "+998000000000" (template-editor.tsx:196-205); NotificationSend.patientId is a required FK to Patient (schema.prisma ~2553-2554) and the route inserts it verbatim (sends/route.ts:62-73) → FK violation → 500, toast shows the raw error body.

Брендинг захардкожен под NeuroFax во всех арендаторах; собственный поддомен сохраняется, но не работает; логотип не показывается в CRM, хотя это обещано

ГДЕ

src/components/layout/crm-sidebar.tsx:287, src/app/[locale]/doctor/_components/doctor-sidebar.tsx:179, src/app/c/[slug]/my/_messages/ru.ts:135, src/app/q/[id]/page.tsx:175, src/app/[locale]/crm/settings/branding/_components/branding-page-client.tsx:194, src/lib/public-clinic.ts:26, src/app/[locale]/crm/layout.tsx:197

СЦЕНАРИЙ

Вторая клиника, зарегистрированная через /signup, видит в CRM и кабинете врача «Neurofax», её пациенты в мини-аппе видят «Neurofax Clinic», на табло очереди — логотип NeuroFax. Клиника на тарифе Enterprise задаёт поддомен my-clinic.neurofax.uz — он не открывается.

ПОСЛЕДСТВИЯ

Платная функция white-label не работает; чужой бренд у пациентов другой клиники.

ЧТО СДЕЛАТЬ

Передавать clinic.nameRu/nameUz и logoUrl в сайдбары CRM/врача и мини-апп вместо констант; tagline брать из настроек клиники; /q и талон — логотип клиники; реализовать маршрутизацию по customSubdomain (proxy + resolvePublicClinic по Host) или убрать поле.

КРИТЕРИЙ ПРИЁМКИ

Для клиники X в CRM, кабинете врача, мини-аппе, /q и талоне отображаются её название и логотип; запрос на x.neurofax.uz открывает публичные страницы клиники X.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CrmSidebar defaults `brand = "Neurofax"` (crm-sidebar.tsx:287) and crm/layout.tsx never passes brand (178-186), renders {brand} at 349; doctor sidebar hardcodes «Neurofax» (doctor-sidebar.tsx:168,179); mini-app booking screens show t.book.clinicTagline = «Neurofax Clinic · Забота о вашем здоровье» (ru.ts:135, uz.ts:135; used in

book-confirm/slot-picker/service-picker/doctor-picker); /q status page uses /logo.png (q/[id]/page.tsx:175); CRM layout falls back to userEmail «admin@neurofax.uz» (layout.tsx:197). Branding page (Pro/Enterprise) saves customSubdomain with suffix «.neurofax.uz» (branding-page-client.tsx:181-194) but no code resolves tenants by Host (resolvePublicClinic uses only ?c/?clinicSlug/DEFAULT, public-clinic.ts:26-30; proxy.ts has no host logic); branding.logo.hint says the logo is shown «в шапке CRM и Mini App» but logoUrl is only used in mini-app-shell.tsx.

UX-12 РЗ · НИЗКИЙ переводы

Мелкие i18n-дефекты: русские месяцы в кабинете врача для uz, английские подписи в RU, отсутствующий ключ

ГДЕ

src/app/[locale]/doctor/_components/doctor-topbar.tsx:27, src/app/[locale]/doctor/documents/_components/documents-table.tsx:50, src/app/[locale]/doctor/references/_components/drug-browser.tsx:394, src/messages/ru.json:1

ТАКЖЕ НАШЛИ ЗОНЫ

Справочники: препараты, МКБ-10, услуги, оверлеи клиники, избранное

СЦЕНАРИЙ

Врач с узбекским интерфейсом видит «23 сентября, вт» и «12 мая» в своих списках; админ на странице ролей видит «all / own / today».

ПОСЛЕДСТВИЯ

Непоследовательный интерфейс, низкое качество локализации.

ЧТО СДЕЛАТЬ

Заменить ручные массивы на useFormatter/Intl с локалью; исправить ключ detailsDescription; перевести английские значения; добавить скрипт проверки t()-ключей в CI.

КРИТЕРИЙ ПРИЁМКИ

В uz-интерфейсе врача месяцы на узбекском; скрипт проверки ключей не находит отсутствующих; в ru.json нет английских строк для UI-подписей.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Hardcoded RU_MONTHS/RU_WEEKDAYS used regardless of locale in 11 doctor files (doctor-topbar.tsx:27-51, documents-table.tsx:50, patient-header-live.tsx:43, visits-section.tsx:41, visit-note-readonly.tsx:43, visits-list.tsx:49-54, overview-section.tsx:37, last-diagnosis-card.tsx:30, selected-patient-card.tsx:42, patients-table.tsx:57, last-visit-card.tsx:32). drug-browser.tsx:394 calls t("drugs.detailsDescription") but the key is drugs.detailDescription (ru.json:7627) → key path rendered in the dialog description. English values in ru.json: settings.roles.scope.all/own/today = «all/own/today» (roles page), patients.tiles.noShowRisk = «No-show risk», doctor.settings.profile.emailLabel = «Email (readonly)». Key parity ru/uz is otherwise 100% (5913/5913).

UX-13 РЗ · НИЗКИЙ мокап / заглушка

Мёртвые кнопки на рабочих экранах (записи, карточка пациента, кабинет врача, ресепшен)

ГДЕ

src/app/[locale]/crm/appointments/_components/appointments-filters.tsx:323, src/app/[locale]/crm/patients/[id]/_components/patient-finance-card.tsx:108, src/app/[locale]/crm/patients/[id]/_components/patient-recommendations-card.tsx:132, src/app/[locale]/doctor/patients/_components/patients-header.tsx:69, src/app/[locale]/doctor/visits/[patientId]/_components/patient-meta-row-live.tsx:53, src/app/[locale]/doctor/visits/[patientId]/_components/visits-list.tsx:374, src/app/[locale]/crm/reception/_components/bottom-row.tsx:251

СЦЕНАРИЙ

Регистратор настраивает фильтр записей и жмёт «Сохранить» — ничего не сохраняется. На ресепшене жмёт «Применить» у «Перенаправить 3 пациентов из кабинета 2» — всплывает тот же текст, пациенты не перераспределены. Врач жмёт «Показать ещё» у аллергий — ничего.

ПОСЛЕДСТВИЯ

Потеря доверия к системе, персонал думает, что действие выполнено.

ЧТО СДЕЛАТЬ

Для каждой кнопки: реализовать действие или удалить. «Применить»/«Отправить» переименовать в «Открыть календарь»/«Перейти к напоминаниям» либо реализовать массовое действие. Добавить lint-правило/тест: Button без onClick/type=submit/asChild запрещён.

КРИТЕРИЙ ПРИЁМКИ

Поиск кнопок без обработчиков по src (кроме dev-витрины) пуст; каждая видимая кнопка выполняет заявленное действие.

ДОКАЗАТЕЛЬСТВО В КОДЕ

No onClick/href: /crm/appointments «Фильтры» and «Сохранить» (appointments-filters.tsx:323-330, type=button only); patient card finance «Изменить запись» (patient-finance-card.tsx:108); «Показать все рекомендации» (patient-recommendations-card.tsx:132); /doctor/patients «Настроить вид» (patients-header.tsx:69-75); doctor visits «Показать ещё» next to allergies/chronic (patient-meta-row-live.tsx:53-59); diagnosis info icon (visits-list.tsx:374-380). Reception «Умные рекомендации»: «Применить» on «Перераспределите очередь» only shows a toast repeating the text and navigates to calendar (bottom-row.tsx:251-256); «Отправить» on reminders just navigates to Action Center (284-286) without sending.

UX-14 РЗ · НИЗКИЙ мокап / заглушка

После удаления SMS интерфейс продолжает обещать SMS (правила напоминаний, кампании, настройки)

ГДЕ

src/messages/ru.json:4236, src/messages/ru.json:2930, src/messages/ru.json:3851, src/messages/ru.json:4018, src/app/[locale]/crm/settings/notifications/_components/notifications-client.tsx:723, src/app/[locale]/crm/notifications/campaigns/new/_client.tsx:195

СЦЕНАРИЙ

Админ настраивает напоминание за 24 ч и читает «иначе SMS» — считает, что пациенты без Telegram получают SMS. Они не получают ничего и не приходят.

ПОСЛЕДСТВИЯ

Неверные ожидания охвата напоминаний и кампаний → неявки пациентов без Telegram.

ЧТО СДЕЛАТЬ

Переписать тексты: «Только Telegram; пациентам без Telegram создаётся задача на звонок» (как в TZ); убрать SMS из подзаголовков; удалить неиспользуемые smsInbox.*, patientCard.smsDialog.* и др.

КРИТЕРИЙ ПРИЁМКИ

rg по активным ключам ru/uz не находит обещаний SMS-доставки; в правилах и кампаниях явно сказано, что охват — только пациенты с Telegram.

ДОКАЗАТЕЛЬСТВО В КОДЕ

SMS was removed (docs/TZ-sms-removal.md; send worker throws «Channel SMS not dispatchable», notifications-send.ts:260-265; campaign wizard hardcodes channel TG). Live UI still says: settings.notifications.rules.channelsDefault «По умолчанию: TG если есть telegramId пациента, иначе SMS.» (ru.json:4236, shown at notifications-client.tsx:723); notifications.campaignsNew.step2.subtitle «Telegram — бесплатно...; SMS — платно, но достанется всем с телефоном.» (2930, _client.tsx:195); settings.index.clinicManagementHint mentions SMS (3851, settings/page.tsx:121); settings.integrations.subtitle «SMS, Telegram, платежи и телефония» (4018). Same in uz.json.

UX-15 РЗ · НИЗКИЙ мокап / заглушка

Правая панель «Центр действий» на странице «Пациенты» — макет: карточки не кликаются, счётчики подменены, кнопки мёртвые

ГДЕ

src/app/[locale]/crm/patients/_components/patients-right-rail.tsx:121, src/app/[locale]/crm/patients/_components/patients-right-rail.tsx:160, src/app/[locale]/crm/patients/_components/patients-right-rail.tsx:201, src/app/[locale]/crm/patients/_components/patients-right-rail.tsx:249

СЦЕНАРИЙ

Регистратор видит «Написать в Telegram — 37 — не записаны после консультации», кликает — ничего. Число 37 — это просто все «новые» пациенты.

ПОСЛЕДСТВИЯ

Персонал тратит время и получает неверные ориентиры по работе с базой.

ЧТО СДЕЛАТЬ

Связать карточки с реальными списками (Action Center по типам действий или сегменты с фильтром) и считать счётчики по реальным критериям (например, нет будущей записи после консультации); кнопки превратить в ссылки на /crm/action-center и /crm/patients/segments; либо убрать блок.

КРИТЕРИЙ ПРИЁМКИ

Клик по каждой карточке открывает список ровно тех пациентов, число которых указано; кнопки ведут на существующие страницы.

ДОКАЗАТЕЛЬСТВО В КОДЕ

actions[] (lines 115-145): «Позвонить пациентам — Давно не были» count = segments.DORMANT; «Написать в Telegram — Не записаны после консультации» count = segments.NEW (not «not booked after consultation»); «Предложить запись — Подходят по триггерам» count = VIP + DORMANT (arbitrary). Each is an with cursor-pointer and a chevron but no onClick/Link (160-196). «Смотреть все действия» (201-207) and «Все сегменты» (249-255) are <button type=button> without handlers.

G1 · Журнал доступа к медданным и полнота аудита (кто смотрел, кто менял, сколько хранится)

G1-01 P1 · ВЫСОКИЙ целостность данных

Правка подписанного заключения в 24-часовом окне безвозвратно стирает подписанный вариант: нет снимка «до», PDF перезаписывается по тому же ключу

ГДЕ

src/app/api/crm/visit-notes/[id]/route.ts:85, src/app/api/crm/visit-notes/[id]/route.ts:171, src/app/api/crm/visit-notes/[id]/route.ts:227, src/app/api/crm/visit-notes/[id]/route.ts:271, src/server/workers/visit-note-handout.ts:207, src/server/workers/visit-note-handout.ts:234, src/app/api/crm/visit-notes/[id]/finalize/route.ts:305

СЦЕНАРИЙ

Врач подписал заключение с диагнозом G43.0 и назначениями, пациент распечатал его и ушёл. Через 3 часа врач в окне правки меняет диагноз и дозировку. При споре (жалоба, страховая, суд) клиника не может показать, что было подписано изначально. В БД, в PDF и в Mini App лежит только новая версия, а QR на бумажной копии пациента ведёт на документ с другим текстом. В журнале аудита есть только «visit_note.update, fields: [diagnosisCode, visitPrescriptions]».

ПОСЛЕДСТВИЯ

Юридически значимый медицинский документ можно переписать после подписи без следа исходного содержания. Бумажная копия пациента расходится с «проверенной» по QR версией, и клиника не может доказать, какая из них подлинная.

ЧТО СДЕЛАТЬ

В PATCH для заметки с firstFinalizedAt != null перед записью сохранять снимок подписанного состояния (все клинические поля и visitPrescriptions) в отдельную таблицу версий или в meta аудита с before/after. При первой финализации сохранять снимок содержимого. Для PDF заключения при перерендере после подписи писать новую версию объекта (ключ с номером ревизии) и хранить ссылку на исходный подписанный файл, либо включить versioning бакета. Показывать в карточке визита историю версий.

КРИТЕРИЙ ПРИЁМКИ

Подписать заключение, изменить диагноз в окне 24 ч. В БД или журнале доступны исходный и новый варианты всех изменённых полей. Исходный PDF остаётся доступен по отдельному ключу. В карточке визита видна история правок с автором и временем.

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH /api/crm/visit-notes/[id] допускает деструктивную правку FINALIZED-заметки, пока не истекло окно от firstFinalizedAt (строки 85-90). Жалобы, анамнез, осмотр, диагноз, назначения и visitPrescriptions перезаписываются через tx.visitNote.update и deleteMany/createMany (строки 197-236), снимок прежних значений нигде не сохраняется. Аудит пишет только meta: { fields: changedFields, correlationId } (строки 271-276), без самих значений. Финализация тоже не снимает содержимое: meta в finalize/route.ts:305-315 содержит только appointmentId, documentNumber и patientDiagnosisId. Затем handoutStaleAt запускает перерендер PDF, и visit-note-handout.ts:207 пишет его по стабильному ключу clinics/<clinic>/conclusions/<noted>.pdf, перезаписывая файл на месте (комментарий «overwrites in place»). Document.upsert обновляет ту же строку с тем же verifyToken (строки 218-240). Версионирование бакета MinIO нигде не включается: grep по versioning в docker-compose/ops/storage пуст.

G1-02 P2 · СРЕДНИЙ безопасность

IP в журнале аудита и журнале просмотров подделывается заголовком X-Forwarded-For

ГДЕ

src/lib/audit.ts:18, src/app/api/crm/patients/[id]/route.ts:54, src/app/api/crm/appointments/[id]/route.ts:123, src/server/auth/user-session.ts:72, nginx/nginx.conf:165

СЦЕНАРИЙ

Сотрудник, которого подозревают в сливе данных, ставит браузерное расширение, добавляющее X-Forwarded-For: 10.0.0.5. Все его просмотры карт и правки в журнале показывают внутренний адрес клиники, хотя он работал из дома.

ПОСЛЕДСТВИЯ

Криминалистическая ценность поля IP в AuditLog, PatientView и UserSession нулевая: его подделывает любой пользователь.

ЧТО СДЕЛАТЬ

В `audit.ts`, `patient-view`-вызовах и `user-session` брать `X-Real-IP`, который выставляет `nginx`, либо последний элемент `XFF`, добавленный доверенным прокси. Вынести это в общий `helper trustedClientIp(request)` и использовать его везде, включая `rate-limit`.

КРИТЕРИЙ ПРИЁМКИ

Запрос с заголовком `X-Forwarded-For: 1.2.3.4` создаёт строки `AuditLog` и `PatientView` с реальным адресом клиента, а не `1.2.3.4`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`clientIp()` в `audit.ts:18-22` берёт первый элемент `X-Forwarded-For` и только при его отсутствии `X-Real-IP`. `PatientView` берёт только `x-forwarded-for?.split(",")[0]` (`patients/[id]/route.ts:54-55`, `appointments/[id]/route.ts:123-124`), `UserSession` делает так же (`user-session.ts:72-75`). `nginx` выставляет `X-Forwarded-For $proxy_add_x_forwarded_for` (`nginx.conf:165, 123, 149`), то есть дописывает реальный адрес в конец присланного клиентом значения. Первый элемент полностью контролирует клиент. Корректный `X-Real-IP` (`$remote_addr`) `nginx` передаёт, но код предпочитает поддельный. `real_ip_module` не настроен (`grep set_real_ip_from` пуст).

G1-03 P2 · СРЕДНИЙ мёртвая механика

Все записи аудита из мини-аппа пишутся с `clinicId = NULL` и без автора, поэтому администратор клиники их никогда не видит

ГДЕ

`src/lib/audit.ts:31`, `src/server/miniapp/handler.ts:286`, `src/app/api/crm/audit/route.ts:21`, `src/app/api/miniapp/account/delete/route.ts:123`, `src/app/api/miniapp/account/export/route.ts:68`, `src/app/api/miniapp/documents/route.ts:227`, `src/app/api/miniapp/conversations/[id]/messages/route.ts:153`, `src/app/api/miniapp/profile/route.ts:140`

СЦЕНАРИЙ

Пациент через мини-апп запросил удаление аккаунта и выгрузку своих данных, загрузил фото МРТ, отписался от рассылок. Администратор открывает «Журнал аудита» и не видит ни одного из этих событий. Когда пациент потом утверждает «я не просил удалять», в журнале клиники нет следа запроса.

ПОСЛЕДСТВИЯ

Юридически значимые действия пациента (DSAR-запросы, согласия на рассылку, загрузка документов) пропадают из журнала клиники. Эти строки видит только платформенный `SUPER_ADMIN`, и то как действия «system».

ЧТО СДЕЛАТЬ

В `audit()` принимать явный `clinicId` и `actor` (например, `audit(request, input, { clinicId, actorLabel: `patient:<id>` })`) или добавить отдельный `auditMiniApp(ctx, input)` с `clinicId: ctx.clinicId` и `actorLabel: `patient:${ctx.patientId}``. Перевести все вызовы в `/api/miniapp/*` на него. Отдельным скриптом проставить `clinicId` уже записанным строкам из `meta.clinicId` или `meta.patientId`.

КРИТЕРИЙ ПРИЁМКИ

Пациент в мини-аппе запрашивает экспорт данных. В журнале аудита клиники появляется строка `PATIENT_DATA_EXPORT_REQUESTED` с `clinicId` клиники и актором `patient:<id>`. `SELECT` по `AuditLog`, где `clinicId` `IS NULL` и `action` из списка мини-аппа, возвращает 0 новых строк.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`audit()` определяет клинику так: ``ctx?.kind === "TENANT" ? ctx.clinicId : session?.user?.clinicId ?? null`` (`audit.ts:31-35`), автора берёт из `session?.user` (строки 42-44). Все роуты мини-аппа выполняются внутри `runWithTenant({ kind: "SYSTEM" })` (`handler.ts:11-19, 286, 307`), а `NextAuth`-сессии у пациента в `Telegram WebView` нет. Поэтому `clinicId = null`, `actorId`, `actorRole` и `actorLabel = null`. Так пишутся `PATIENT_DELETION_REQUESTED/APPROVED` (`account/delete:123,134`), `PATIENT_DATA_EXPORT_REQUESTED` (`account/export:68`), `MINIAPP_DOCUMENT_UPLOADED` (`documents:227`), `MINIAPP_MESSAGE_SENT` (`messages:153`), `MARKETING_OPT_OUT_CHANGED` (`profile:140`), `REFERRAL_CODE_GENERATED`, ответы на напоминания о лекарствах, отмена удаления аккаунта. Экран аудита клиники запрашивает `/api/crm/audit`, где для `ADMIN` стоит `where.clinicId = ctx.clinicId` (`audit/route.ts:21`), и строки с `NULL` не попадают в выборку никогда. `clinicId` внутри `meta` фильтром не используется.

Входы сотрудников (успешные и неудачные) и выходы нигде не пишутся в журнал аудита**ГДЕ**

src/lib/auth.ts:75, src/lib/auth.ts:98, src/server/auth/user-session.ts:84, src/app/api/auth/[...nextauth]/route.ts:35, scripts/_destructive-guard.ts:11

СЦЕНАРИЙ

Пароль врача утёк. Злоумышленник подбирает его, входит ночью с чужого IP и читает карты. Утром администратор хочет узнать, когда и откуда входили под этим аккаунтом и были ли неудачные попытки. В журнале аудита нет ни одной записи о входах. Видна только текущая сессия и время последнего входа, которое уже перезаписал сам врач утром.

ПОСЛЕДСТВИЯ

Невозможно расследовать компрометацию учётной записи и доказать, кто имел доступ к медданным в конкретный момент. Перебор паролей не оставляет следа.

ЧТО СДЕЛАТЬ

Добавить `AUDIT_ACTION.LOGIN_SUCCEEDED`, `LOGIN_FAILED` (с причиной: `bad_password`, `inactive`, `totp_required`, `bad_totp`, без пароля в `meta`), `LOGOUT`. Писать их из `authorize()` и из события `signOut NextAuth` (или из `/api/auth POST-обёртки`) с IP, UA и `clinicId` пользователя. Для `LOGIN_FAILED` по несуществующему email писать строку с `actorLabel` = введённый email, без `clinicId`. Исправить комментарий в `_destructive-guard.ts`.

КРИТЕРИЙ ПРИЁМКИ

Неверный пароль, затем верный вход и выход дают в журнале аудита три строки с IP и временем. Фильтр по `action=LOGIN_FAILED` показывает попытки перебора.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`authorize()` в `auth.ts:75-160` при неверном пароле, неактивном пользователе или неверном TOTP просто возвращает `null` (строки 98-100, 115-117, 148-154) и ничего не пишет. Успешный вход создаёт только строку `UserSession` и перезаписывает `User.lastLoginAt` (`user-session.ts:84-106`). `UserSession` удаляется при вытеснении или таймауте, `lastLoginAt` перезаписывается при каждом входе, так что истории входов не остаётся. В `audit-actions.ts` нет ни одной константы для `login`, `logout` или `failed login`, `grep` по `action: "auth|login"` пуст. Сам механизм защиты от разрушительных сид-скриптов опирается на ложное допущение: `_destructive-guard.ts:11-13` пишет «Real logins write AuditLog rows».

Доступ к чужой карте через «семью» в мини-аппе не оставляет следов по пострадавшему пациенту: событие привязки записано на владельца, чтения от имени родственника не пишутся**ГДЕ**

src/server/workers/outbox-pumper.ts:98, src/app/api/miniapp/family/route.ts:212, src/app/api/miniapp/family/[linkedPatientId]/route.ts:51, src/server/miniapp/active-patient.ts:35

СЦЕНАРИЙ

Посторонний, зная ФИО и телефон пациентки, «добавляет её в семью» (дыра из #258), неделю читает её заключения и анализы, затем отвязывает. Пациентка жалуется. Администратор ищет в журнале её id и не находит ничего: событие привязки записано на id злоумышленника, чтений нет вообще, связи в карточке уже нет.

ПОСЛЕДСТВИЯ

Эксплуатацию уже известной уязвимости привязки чужой карты невозможно обнаружить и доказать по пострадавшему. Объём прочитанных данных неизвестен.

ЧТО СДЕЛАТЬ

Для `patient.familyLinked` и `patient.familyUnlinked` писать аудит-строку и на `linkedPatientId` (вторая строка или `entityId` = `linkedPatientId` с `ownerPatientId` в `meta`). В роутах мини-аппа при `isOnBehalfOf=true` писать событие чтения (например, `AuditLog MINIAPP_ON_BEHALF_READ` с `owner` и `target`) с троттлингом. Отвязку делать мягкой (`unlinkedAt`) вместо удаления строки.

КРИТЕРИЙ ПРИЁМКИ

Привязать карту В к владельцу А, открыть документы В, отвязать. Фильтр журнала по пациенту В показывает привязку, чтения от имени и отвязку с id владельца А.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Привязка и отвязка аудируются только через `outbox`: `envelope.tenantScope = { clinicId, patientId: ctx.patientId } (family/route.ts:212-215, [linkedPatientId]/route.ts:51-54)`. `writeAuditLog` берёт `entityType "Patient"` и `entityId = tenantScope.patientId (outbox-pumper.ts:98-109)`, то есть `id` владельца Telegram-аккаунта. `Id` привязанного пациента, чья медкарта становится доступна, лежит только внутри `meta.payload`. Чтения от имени родственника (`resolveActivePatient/onBehalfOf`, `active-patient.ts:35-67`: документы, анализы, план лечения, итоги визитов) не пишут ни `PatientView`, ни `AuditLog`. После отвязки строка `PatientFamily` физически удаляется (`[linkedPatientId]/route.ts:39`), и CRM-панель «Семья» (`crm/patients/[id]/family`) перестаёт показывать связь.

G1-06 P2 · СРЕДНИЙ безопасность

Журнал просмотров медкарт не фиксирует врачей и большинство путей чтения: пишется только из трёх CRM-роутов, контекст «Экспорт» не пишется никогда

ГДЕ

`src/server/audit/patient-view.ts:4`, `src/server/audit/patient-view.ts:30`, `src/app/[locale]/crm/layout.tsx:63`, `src/app/api/crm/doctors/me/patients/[patientId]/summary/route.ts:43`, `src/app/api/crm/doctors/me/patients/[patientId]/visits/route.ts:69`, `src/app/api/crm/doctors/me/today/route.ts:152`, `src/app/api/crm/visit-notes/[id]/route.ts:23`, `src/app/[locale]/doctor/visits/[patientId]/[visitId]/page.tsx:43`, `src/app/api/crm/documents/file/route.ts:21`, `src/app/api/crm/patients/export/route.ts:41`, `src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:518`

СЦЕНАРИЙ

Пациентка жалуется, что о её диагнозе узнали посторонние. Администратор открывает «Настройки → Журнал аудита → Просмотры карточек» и фильтрует по пациентке. Видит только регистратора, открывавшего запись. Врач, три дня листавший её визиты, документы и анализы в кабинете врача, и медсестра, открывавшая сканы через файловый прокси, в журнале отсутствуют. Выгрузка всей базы через `/api/crm/patients/export` тоже нигде не отражена.

ПОСЛЕДСТВИЯ

Журнал, на котором держится соответствие клиники требованиям к медданным, показывает малую часть обращений и выдаёт себя за полный. Основной потребитель медданных (врач) не виден в нём вообще. Расследовать утечку невозможно, а неполный журнал хуже отсутствующего: он создаёт ложную уверенность.

ЧТО СДЕЛАТЬ

Вызывать `recordPatientView` во всех GET, отдающих медданные конкретного пациента: `doctors/me/patients/[patientId]/*` (контекст, например, `doctor.card`), `doctors/me/today (doctor.current)`, `visit-notes/[id]`, `/previous`, `/print (visit_note.print)`, `doctor/visits/[patientId]/[visitId]/page.tsx` (серверный вызов), `documents/file` и `documents/[id]` (`document.file`, `patientId` искать по ключу или `id` документа), `conversations/[id]` и файлы вложений. Для массовых чтений (`patients list`, `patients/export`, `exports worker`) писать `AuditLog` с фильтрами и числом строк, а для экспорта — контекст "export". Расширить `PatientViewContext` и `contextLabel` в `audit-log-client.tsx`. Добавить `contextRef` в ключ троттлинга. Обновить шапку `patient-view.ts` и `schema`-комментарий, чтобы они описывали реальное покрытие.

КРИТЕРИЙ ПРИЁМКИ

Врач открывает в кабинете карточку пациента, визит, документ и печать. В «Просмотрах карточек» по этому пациенту появляются строки с ролью DOCTOR и соответствующими контекстами. Выгрузка CSV пациентов даёт запись в журнале. `Grep recordPatientView` находит вызовы во всех перечисленных роутах. Тест на каждый роут проверяет, что создаётся строка `PatientView`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Шапка `patient-view.ts:4-10` утверждает, что журнал подключён к странице пациента и к воркерам экспорта. По факту `recordPatientView` вызывается только в GET `/api/crm/patients/[id]` (`route.ts:47`), `/api/crm/appointments/[id]` (`route.ts:116`) и `/api/crm/cases/[id]` (`route.ts:90`). Страница `crm/patients/[id]/page.tsx` — тонкая оболочка без вызова, а контекст "export" (тип `PatientViewContext`, строка 34) не пишет ни один код: `grep` по `recordPatientView` в `workers/exports.ts` и `data-export.ts` пусто. Кабинет врача вообще не ходит в CRM: `crm/layout.tsx:63` редиректит DOCTOR в `/doctor`, а там карточка пациента читает `doctors/me/patients/[patientId]/summary`, `visits`, `documents`, `labs`, `prescriptions`, `diagnoses` и `doctors/me/today`. Ни в одном из этих роутов нет ни `recordPatientView`, ни `audit()`. Серверная страница `doctor/visits/[patientId]/[visitId]/page.tsx` читает `VisitNote` целиком через `prisma` (строки 43-94) без записи. Без записи также GET `/api/crm/visit-notes/[id]` и `/previous`, файловые прокси `documents/file` и `conversations/[id]/attachments/file`, GET `/api/crm/conversations/[id]`, список `/api/crm/patients` (отдаёт расшифрованные `passport` и `notes` целой страницы пациентов, `patients/route.ts:127`) и потоковый CSV `/api/crm/patients/export` (вся база ФИО, телефонов и дат рождения). Печать заключения пишет `AuditLog` `visit_note.print` без `patientId` (`print/route.ts:1564`), то есть в «Просмотры карточек» она не попадает и по пациенту

не ищется. Троттлинг к тому же не учитывает contextRef: две разные записи одного пациента за 5 минут дают одну строку.

G1-07 P2 · СРЕДНИЙ целостность данных

Правки и удаления аллергий, диагнозов и хронических заболеваний в карте аудируются без прежних значений

ГДЕ

src/app/api/crm/patients/[id]/allergies/[allergyId]/route.ts:54, src/app/api/crm/patients/[id]/allergies/[allergyId]/route.ts:71, src/app/api/crm/patients/[id]/diagnoses/[diagnosisId]/route.ts:54, src/app/api/crm/patients/[id]/diagnoses/[diagnosisId]/route.ts:73, src/app/api/crm/patients/[id]/chronic-conditions/[conditionId]/route.ts:49

СЦЕНАРИЙ

У пациента была аллергия «пенициллин, анафилаксия (SEVERE)». Медсестра по ошибке меняет тяжесть на MILD или удаляет запись. Врач назначает амоксициллин. При разборе инцидента журнал показывает «patient.allergy.update, fields: [severity]» или «delete, substance: пенициллин». Какой была тяжесть и реакция до правки, восстановить невозможно.

ПОСЛЕДСТВИЯ

Исчезает история клинически критичных данных. Нельзя восстановить удалённую аллергию и доказать, кто и что изменил, при инциденте с лекарственной реакцией.

ЧТО СДЕЛАТЬ

Во всех трёх роутах писать в meta полный before и after (или diff(before, after), как у Patient). В DELETE сохранять всю удаляемую строку. Рассмотреть мягкое удаление (isActive=false, deletedAt) для аллергий вместо физического.

КРИТЕРИЙ ПРИЁМКИ

Изменить тяжесть аллергии и удалить её: в журнале аудита видны старое и новое значение severity и полная удалённая строка (substance, reaction, severity, notes, recordedAt).

ДОКАЗАТЕЛЬСТВО В КОДЕ

PATCH аллергии пишет meta: { patientId, fields: Object.keys(data) } (allergies/[allergyId]/route.ts:54-59), хотя строка before уже прочитана (строка 37). DELETE аллергии жёстко удаляет строку и сохраняет в meta только substance (строки 71-76), без reaction, severity и notes. То же у диагнозов (diagnoses/[diagnosisId]:54-57 только fields, 73-76 только label) и хронических заболеваний (chronic-conditions/[conditionId]:49-54 только fields, 68-73 только name). Для сравнения: PATCH пациента сохраняет полный diff before/after (patients/[id]/route.ts:86-95). Удалять аллергии может и NURSE (roles: ADMIN, DOCTOR, NURSE).

G1-08 P2 · СРЕДНИЙ баг

Сбой расшифровки поля пациента роняет весь список пациентов 500-й ошибкой без события ENCRYPTION_DECRYPT_FAILED; заметка, начинающаяся с «v1:», сохраняется незашифрованной и ломает чтение

ГДЕ

src/server/crypto/field-cipher.ts:183, src/server/crypto/field-cipher.ts:233, src/server/patient/cipher-fields.ts:91, src/app/api/crm/patients/route.ts:127, src/app/api/crm/patients/[id]/route.ts:59, src/lib/audit-actions.ts:350

СЦЕНАРИЙ

Регистратор пишет в заметке пациента «v1: первичный, v2: повтор». Строка ложится в БД незашифрованной. Список пациентов на странице, где он оказывается, и его карточка перестают открываться у всей клиники, отвечая «internal_error». Похожий эффект даёт ротация ключа с ранним удалением FIELD_ENCRYPTION_KEY_V1: весь список пациентов лежит, а в журнале нет ни одного сигнала о сбое расшифровки.

ПОСЛЕДСТВИЯ

Один пациент блокирует работу регистратуры со списком. Паспорт или заметка с таким префиксом хранятся без шифрования. Обещанный сигнал о подмене или несовпадении ключа не существует.

ЧТО СДЕЛАТЬ

В decryptIfEncrypted (и аналогах для MedicalCase и Prescription) ловить ошибку, возвращать null или маркер «не удалось расшифровать» и писать ENCRYPTION_DECRYPT_FAILED (entityType, entityId, field, versionPrefix, без открытого текста) с дедупликацией. Сделать формат шифротекста однозначным (строгая проверка 4 сегментов

и base64-длин в isEncryptedField) и в encryptIfPresent шифровать всё, что не проходит строгую проверку.

КРИТЕРИЙ ПРИЁМКИ

Сохранить пациенту заметку «v1: тест»: в БД лежит шифротекст, карточка и список открываются. Вручную испортить шифротекст одного пациента: список открывается, у пациента поле пустое или помечено, в журнале есть ENCRYPTION_DECRYPT_FAILED.

ДОКАЗАТЕЛЬСТВО В КОДЕ

decryptField бросает исключение при повреждённом шифротексте, неизвестной версии ключа или неверном теге (field-cipher.ts:188-226). Комментарий на строках 183-186 обещает, что вызывающие поймут его и выпустят ENCRYPTION_DECRYPT_FAILED, но константа (audit-actions.ts:350-355) нигде не используется. hydratePatientForRead и hydratePatientListForRead (cipher-fields.ts:65-86) не ловят ошибку. Одна «битая» строка в выдаче GET /api/crm/patients (patients/route.ts:127) превращает весь ответ в 500 internal_error, и то же с карточкой (patients/[id]/route.ts:59). В PATCH patients/[id] update успевает закоммититься до hydrate (строки 78-85), и пользователь видит ошибку при сохранённых данных. Кроме того, isEncryptedField считает шифротекстом любую строку с префиксом /^v\d+:/ (строки 233-239). encryptIfPresent такую строку не шифрует (cipher-fields.ts:88), а decryptIfEncrypted пытается расшифровать и падает на «malformed ciphertext». Заметка регистратора вида «v2: перезвонить после MPT» хранится открытым текстом, и дальше каждая страница списка, где встречается этот пациент, отдаёт 500.

G1-09 P2 · СРЕДНИЙ целостность данных

Удаление пациента из CRM каскадом стирает журнал просмотров, аллергии, диагнозы, курсы лекарств и DSAR-заявки; проверка «следов» неполная и даёт 500

ГДЕ

src/app/api/crm/patients/[id]/route.ts:116, src/app/api/crm/patients/[id]/route.ts:131, prisma/schema.prisma:2843, prisma/schema.prisma:3107, prisma/schema.prisma:3146, prisma/schema.prisma:3072, prisma/schema.prisma:3387, prisma/schema.prisma:2554, prisma/migrations/20260506160000_phase17_compliance_foundation/migration.sql:66

СЦЕНАРИЙ

Регистратор завёл пациента из Telegram-бота. Медсестра до первой записи внесла аллергию на пенициллин и хронический диагноз, пациент через мини-апп запросил выгрузку данных. Администратор, считая карточку дублем, удаляет её. Аллергия, диагноз, DSAR-заявка и вся история просмотров карты исчезают без следа. В аудите остаётся только снимок строки Patient. Другой пациент, которому ушла рассылка, не удаляется: администратор видит «HTTP 500».

ПОСЛЕДСТВИЯ

Потеря клинически значимых данных (аллергии) и уничтожение журнала доступа и DSAR-записей по пациенту. Для пациентов с рассылками удаление ломается 500-й ошибкой.

ЧТО СДЕЛАТЬ

Расширить проверку следа: allergies, chronic, diagnoses, prescriptions, labResults, labOrders, ePrescriptions, sickLeaves, referrals, notificationSends, conversations, dataExportJobs, dataDeletionJobs. При любом следе возвращать 409 с перечнем. Сменить onDelete для PatientView на Restrict или хранить PatientView без FK на Patient (как AuditLog), чтобы журнал доступа переживал удаление. Выполнять подсчёт, удаление и запись аудита в одной транзакции. В UI (delete-patient-dialog) на 409 показывать понятное сообщение со ссылкой на DSAR.

КРИТЕРИЙ ПРИЁМКИ

Пациент с аллергией или рассылкой без визитов: DELETE возвращает 409 с перечнем, данные на месте. Действительно пустой пациент удаляется, а его строки PatientView остаются в журнале просмотров.

ДОКАЗАТЕЛЬСТВО В КОДЕ

DELETE считает «клинический след» только по 5 таблицам: appointment, visitNote, document, payment, medicalCase (строки 116-123), и при нуле делает prisma.patient.delete (строка 131). Каскад onDelete: Cascade уносит PatientView (schema:2843, migration.sql:66-68, то есть журнал «кто смотрел этого пациента»), PatientAllergy (3107), PatientChronicCondition (3129), PatientDiagnosis (3146), Prescription (3072, курсы лекарств), MedicationReminderSend, DataExportJob (3348) и DataDeletionJob (3387), то есть записи о DSAR-запросах пациента. Модели с обязательной связью без onDelete (NotificationSend 2554, LabResult 3609, LabOrder, EPrescription, SickLeave, Referral, CdsOverride) по умолчанию Restrict. Для пациента, которому ушла хотя бы одна рассылка или пришёл анализ, delete падает FK-ошибкой, а api-handler отдаёт 500 internal_error с сырым текстом Prisma вместо 409 has_clinical_records. Подсчёт и удаление не в одной транзакции. Аудит пишется после удаления отдельным вызовом строкой "patient.delete" (строки 132-139).

G1-10 P2 · СРЕДНИЙ UX

Экран «Журнал аудита»: строки событий наезжают друг на друга, ошибка API показывается как «ничего не найдено», фильтровать можно только по внутренним id

ГДЕ

src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:248, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:346, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:383, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:329, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:69, src/app/[locale]/crm/settings/audit/_components/audit-log-client.tsx:532

СЦЕНАРИЙ

Администратор открывает журнал, чтобы понять, кто менял запись пациента Иванова. Строки наезжают друг на друга, JSON одной строки перекрывает имя автора следующей. Найти события по Иванову нельзя: нет поиска по пациенту, нужен внутренний id, которого админ не знает. При временной ошибке сервера экран спокойно пишет «ничего не найдено».

ПОСЛЕДСТВИЯ

Журнал аудита технически существует, но практически непригоден для расследования. Ошибка выдаётся за отсутствие событий, что прямо вводит в заблуждение.

ЧТО СДЕЛАТЬ

Включить динамическое измерение строк (ref={virtualizer.measureElement}, data-index) или сделать meta сворачиваемым с фиксированной высотой строки. Обработать isError явным сообщением и кнопкой «Повторить». Добавить фильтр по объекту (entityId) и выбор пациента или сотрудника по ФИО через поиск, а на карточку пациента — ссылку «Журнал по пациенту» (pv_patientId и события с meta.patientId или entityId). Дать раскрытие полного meta.

КРИТЕРИЙ ПРИЁМКИ

На журнале из 100 событий с meta строки не перекрываются. Отключение API показывает ошибку, а не «ничего не найдено». Из карточки пациента одним кликом открываются его просмотры и изменения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Вкладка «События» виртуализирована с фиксированным estimateSize: () => 72 (строки 248-253) без measureElement и ref на строке. Каждая строка абсолютно позиционирована на vi.start (строки 346-354) и не имеет фона, но содержит два текстовых ряда плюс <pre> с meta высотой до max-h-24 (строки 382-386), итого около 150 px в 72-пиксельном слоте. Meta есть почти у всех строк (diff пациента, fields заметки, целиком конверт события из outbox-rumper), поэтому текст соседних строк накладывается. Обработки query.isError нет ни на одной вкладке: при 403 или 500 rows=[] и выводится «По фильтру ничего не найдено» (строки 329-333, 597-601). Фильтры принимают только сырые cuid: actorId с placeholder "userId" (293-299), patientId и viewerUserId (532-551). Фильтра по entityId в UI нет вообще (EVENTS_KEYS, строка 69), хотя API его поддерживает (audit/route.ts:23), и из карточки пациента на журнал ссылки нет. Meta обрезается до 1000 символов без возможности раскрыть (строка 384). Подзаголовок обещает «Все изменения в клинике с фильтрами» (ru.json, settings.audit.subtitle).

G1-11 P3 · НИЗКИЙ эксплуатация

CSV-выгрузки всей базы пациентов бессрочно лежат в /tmp/exports контейнера, их скачивание не аудируется, а после рестарта файлы становятся сиротами

ГДЕ

src/server/workers/exports.ts:61, src/server/workers/exports.ts:285, src/app/api/crm/exports/[jobId]/download/route.ts:40, src/app/api/crm/exports/route.ts:46

СЦЕНАРИЙ

Администратор поставил выгрузку пациентов, файл готов. Через неделю в /tmp/exports контейнера лежат десятки полных копий базы пациентов. Кто их скачивал, по журналу установить нельзя.

ПОСЛЕДСТВИЯ

Неучтённые копии персональных данных всей клиники на диске приложения, нет журнала фактических скачиваний.

ЧТО СДЕЛАТЬ

Удалять файл после первого скачивания или по TTL (например, 1 час) плановой задачей и при старте чистить каталог. Писать аудит CRM_EXPORT_DOWNLOADED с jobId, kind и числом строк. Вынести хранение в приватный бакет с lifecycle-правилом, как и планировалось в «Phase 6».

КРИТЕРИЙ ПРИЁМКИ

Через час после готовности (или после первого скачивания) файла в /tmp/exports нет. Скачивание даёт строку аудита с автором и IP.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Воркер пишет полный CSV (ФИО, телефоны, даты рождения, суммы) в /tmp/exports/<jobId>.csv (exports.ts:61, 265-285). Удаления файлов нет: grep unlink/rm в exports.ts пуст. Реестр задач — Map в памяти процесса (строка 64), поэтому после рестарта приложения файл остаётся на диске контейнера, но уже недоступен и не учитывается. /tmp не вынесен в volume, так что файл живёт до пересоздания контейнера при следующем деплое. Аудируется только постанова в очередь CRM_EXPORT_REQUESTED (exports/route.ts:46-51). Скачивание готового файла (download/route.ts:40-47) не пишет ничего, поэтому неизвестно, скачал ли кто-то выгрузку и сколько раз. PatientView-контекст "export" не пишется ни здесь, ни в воркере.

G1-12 РЗ · НИЗКИЙ эксплуатация

Автосейв заключения пишет строку AuditLog на каждый PATCH, включая пустые; у AuditLog и PatientView нет срока хранения и архива

ГДЕ

src/app/api/crm/visit-notes/[id]/route.ts:240, src/app/api/crm/visit-notes/[id]/route.ts:271, src/server/realtime/envelope.ts:159, src/app/[locale]/doctor/reception/_components/notes-editor-panel.tsx:27, docs/TZ-cross-surface-sync.md:888

СЦЕНАРИЙ

Врач принимает 20 пациентов в день и на каждом делает десятки автосохранений. Журнал аудита, отсортированный по времени, на 90% состоит из visit_note.update с пустым или однополевым fields. События вроде смены роли или отмены записи тонут, таблица растёт на сотни тысяч строк в год без плана хранения.

ПОСЛЕДСТВИЯ

Журнал забит шумом, поиск значимых событий затруднён, таблица и индексы растут бесконечно. Срок хранения, обещанный в ТЗ, не обеспечен ни в одну сторону: нет ни гарантированного 5-летнего архива, ни очистки.

ЧТО СДЕЛАТЬ

Не писать audit при changedFields.length === 0. Для черновика (DRAFT без firstFinalizedAt) агрегировать: одна строка на сессию правки или только на финализацию. Правки после подписи писать всегда, с before и after. Определить политику хранения: партиционирование AuditLog и PatientView по месяцам, архив старше N месяцев в холодное хранилище, удаление после 5 лет, и оформить это воркером.

КРИТЕРИЙ ПРИЁМКИ

Пустой автосейв не создаёт строку AuditLog. Приём с 50 автосохранениями черновика даёт не более нескольких строк аудита. Есть задача ретеншна с тестом.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Редактор сохраняет каждое поле с дебаунсом 1,5 с (notes-editor-panel.tsx:27), а конструктор назначений шлёт replace-all даже на пустые действия вроде сворачивания строки (комментарий visit-notes/[id]/route.ts:136-139). Конверт события пропускается при changedFields.length === 0 (строка 240), но audit(request, { action: "visit_note.update", meta: { fields: changedFields } }) вызывается безусловно (строки 271-276), в том числе с fields: []. Это прямо противоречит решению в envelope.ts:159-160 («draftSaved is high-frequency autosave; skip audit»). Ретеншна нет ни для AuditLog, ни для PatientView: grep по retention/purge/prune в src и ops не находит задач, бэкап делает только pg_dump. В ТЗ записано «AuditLog 5 лет (отдельный архив)» (TZ-cross-surface-sync.md:888), но это не реализовано. Каждый вызов audit() ещё и заново вызывает auth().

G1-13 РЗ · НИЗКИЙ целостность данных

Двухшаговая загрузка документов оставляет в MinIO файлы с медданными без записи в БД: их не видно, не удалить по DSAR и не отследить

ГДЕ

src/app/api/crm/documents/upload/route.ts:52, src/app/[locale]/doctor/documents/_components/upload-document-dialog.tsx:118, src/app/[locale]/doctor/documents/_components/upload-document-dialog.tsx:140, src/app/api/crm/doctors/me/signature/route.ts:41

СЦЕНАРИЙ

Медсестра загружает скан выписки пациента, на втором шаге сессия истекает. Выписка лежит в MinIO без привязки к пациенту. Пациент потом просит удалить свои данные: DSAR-удаление работает по строкам Document и этот файл не находит.

ПОСЛЕДСТВИЯ

Медицинские сканы остаются в хранилище вне учёта: не видны в интерфейсе, не попадают под удаление по запросу пациента и под журнал доступа.

ЧТО СДЕЛАТЬ

Создавать строку Document (статус PENDING) в том же запросе, что и загрузку, или проводить загрузку во временный префикс tmp/ с правилом жизненного цикла MinIO и переносом при подтверждении. Писать аудит загрузки. При замене подписи удалять старый объект. Добавить периодическую сверку «объекты без строк» с отчётом.

КРИТЕРИЙ ПРИЁМКИ

Загрузка с намеренно упавшим вторым шагом не оставляет объекта в documents/ через сутки (или он виден в отчёте сиротских файлов). Замена подписи удаляет старый файл.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/crm/documents/upload сразу кладёт байты в clinics/<clinic>/documents/<uuid>-<name> (строки 52-58) и возвращает URL. Строки Document не создаётся, patientId из формы игнорируется, аудита нет. Строку создаёт второй запрос POST /api/crm/documents (upload-document-dialog.tsx:140-155). Если он падает (валидация, 403, обрыв сети, закрытие вкладки), диалог показывает ошибку, а загруженный файл остаётся в бакете навсегда. Повторная попытка загружает ещё одну копию. Подпись врача грузится тем же путём и при замене просто перезаписывает Doctor.signatureUrl (signature/route.ts:41) без удаления старого объекта. deleteObject вызывается только в documents/[id] и в expireStateExports DSAR. SUPER_ADMIN без клиники грузит в clinics/shared/ (upload/route.ts:35).

G1-14 P3 · НИЗКИЙ безопасность

Резервный код 2FA можно использовать дважды при параллельных входах, а при одновременном использовании двух кодов один «воскресает»

ГДЕ

src/lib/auth.ts:118, src/lib/auth.ts:124, src/server/auth/recovery-codes.ts:80

СЦЕНАРИЙ

У злоумышленника есть пароль и один резервный код сотрудника. Он запускает два входа одновременно: оба успешны, код формально «израсходован» один раз, а remaining в аудите показывает неверное число.

ПОСЛЕДСТВИЯ

Нарушается одноразовость резервных кодов, счётчик оставшихся кодов в аудите недостоверен. Практический риск невысок, так как нужны пароль и код.

ЧТО СДЕЛАТЬ

Обновлять recoveryCodesHash условно: updateMany({ where: { id, recoveryCodesHash: { equals: oldHashes } }, data: { recoveryCodesHash: remaining } }) и отклонять вход при count = 0, либо использовать SELECT ... FOR UPDATE в транзакции.

КРИТЕРИЙ ПРИЁМКИ

Тест: два параллельных authorize() с одним и тем же резервным кодом дают ровно один успешный вход. Два разных кода параллельно удаляют оба хэша.

ДОКАЗАТЕЛЬСТВО В КОДЕ

authorize() читает user.recoveryCodesHash в начале запоса (auth.ts:95-97). consumeRecoveryCode сравнивает код с этим массивом и возвращает remainingHashes = hashes без найденного (recovery-codes.ts:90-98). Затем prisma.user.update безусловно записывает этот массив (auth.ts:124-127): ни compare-and-swap по старому значению, ни блокировки строки. Два параллельных входа с одним кодом оба проходят проверку (около 10 bcrypt-сравнений дают широкое окно). Два параллельных входа с разными кодами записывают каждый свой остаток, и последняя запись возвращает в массив код, израсходованный первым. Запись RECOVERY_CODE_USED при этом делается (auth.ts:134-150), так что утверждение исходного брифа об отсутствии аудита неверно.

G2 · Операционные скрипты, сиды и демо-данные на живом проде

G2-01 P1 · ВЫСОКИЙ целостность данных

seed-prod-demo.ts вместо заявленных 30 создаёт 540 демо-пациентов и при каждом запуске добавляет до 540 будущих записей к реальным врачам на 14:00–22:00 по Ташкенту

ГДЕ

scripts/seed-prod-demo.ts:5, scripts/seed-prod-demo.ts:321, scripts/seed-prod-demo.ts:380, scripts/seed-prod-demo.ts:389, scripts/seed-prod-demo.ts:399, scripts/seed-prod-demo.ts:404, scripts/seed-prod-demo.ts:417, scripts/seed-prod-demo.ts:436

СЦЕНАРИЙ

Админ по шапке запускает seed-prod-demo «чтобы было 30 демо-пациентов». Появляются 540 пациентов и 540 будущих записей к реальным врачам. Вечерние слоты с 14:00 до окончания смены заняты, у части записей чужой кабинет и пустое время. В аналитике за месяц появляются 540 оплат. Через неделю запуск повторяют, и добавляется ещё несколько сотен записей.

ПОСЛЕДСТВИЯ

Реальные пациенты теряют доступные слоты, расписание и кабинеты врачей показывают мусор, выручка завышена на сотни фиктивных оплат. Демо-строки ничем не помечены, выборочно удалить их нельзя.

ЧТО СДЕЛАТЬ

Привести код в соответствие с описанием (30 пациентов) или удалить скрипт из прод-образа. Помечать пациентов, записи и оплаты демо-тегом. Считать время по Ташкенту через toTashkentDate и заполнять time. Брать кабинет врача (doctor.cabinetId), не использовать WALKIN для брони. Не создавать новые записи при каждом повторном запуске.

КРИТЕРИЙ ПРИЁМКИ

Повторный запуск не увеличивает число записей. Все созданные строки помечены, у записей время внутри расписания врача по Ташкенту, cabinetId равен кабинету врача, поле time заполнено.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В шапке написано: «Adds 30 demo patients in the +998999100XXXX phone range (so they're easy to spot)» (5), и комментарий на 328 говорит «0000..0029», но DEMO_COUNT = 540 (321). Скрипт предназначен для прода («Idempotent demo-data seed for prod neurofax clinic», запуск через docker compose exec worker), guard нет. Для каждого демо-пациента без будущей записи создаётся новая BOOKED-запись на 0-7 дней вперёд (380-381), поэтому каждый повторный запуск через неделю снова добавляет до 540 записей. Час выбирается как 9 + random(9) через atHour → r.setHours (39) в UTC-контейнере, то есть 14:00-22:00 по Ташкенту. Врач и кабинет выбираются независимо (389: pick(cabinets)), хотя Doctor.cabinetId уникален и привязан к врачу. В create (404-420) нет поля time. channel включает WALKIN (417), и такая BOOKED-запись невидима на обеих панелях ресепшна. Для прошлых COMPLETED создаётся Payment PAID на полную цену (436) без метки.

G2-02 P2 · СРЕДНИЙ целостность данных

Dev-сид seed-labs-reminders-dev.ts записывает выдуманные анализы (включая CRITICAL) и задачи реальным пациентам и врачам всех клиник

ГДЕ

scripts/seed-labs-reminders-dev.ts:51, scripts/seed-labs-reminders-dev.ts:57, scripts/seed-labs-reminders-dev.ts:68, scripts/seed-labs-reminders-dev.ts:87, scripts/seed-labs-reminders-dev.ts:46, Dockerfile.worker:43

СЦЕНАРИЙ

Разработчик, чтобы у врача «появились» экраны, запускает на проде docker compose exec worker npx tsx scripts/seed-labs-reminders-dev.ts. Врач Бусаков открывает уведомления и видит задачу «Перезвонить пациенту по результатам» по реальному пациенту Турматову. По эндпоинту анализов у Турматова теперь «Холестерин общий 9.2 ммоль/л, CRITICAL», хотя он ничего не сдавал. То же самое происходит у всех врачей всех клиник платформы.

ПОСЛЕДСТВИЯ

В картах реальных пациентов всех клиник появляются ложные медицинские данные: врач может принять решение по несуществующему критическому анализу. У врачей появляются мусорные задачи. Отличить эти

строки от настоящих невозможно, поэтому и безопасно удалить их нельзя.

ЧТО СДЕЛАТЬ

Исключить dev- и stress-скрипты из прод-образа: сделать в Dockerfile.worker явный allowlist вместо COPY всего scripts/. В самом скрипте отказываться работать при NODE_ENV=production. Ограничить его одной явно указанной демо-клиникой и пациентами с демо-меткой, а каждую создаваемую строку пометить (notes или meta), чтобы её можно было точно удалить.

КРИТЕРИЙ ПРИЁМКИ

Скрипта нет в образе worker, либо запуск с NODE_ENV=production падает до первой записи. При локальном запуске строки создаются только у пациентов с демо-меткой и помечены сид-маркером, а select по маркеру находит ровно их.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Скрипт в шапке назван «dev-only», но лежит в scripts/, который Dockerfile.worker:43 копирует в прод-образ воркера. Стр. 51: prisma.clinic.findMany() без фильтра, то есть все клиники. Стр. 53-61: все User с role DOCTOR и первые 50 пациентов клиники без какого-либо фильтра, то есть реальные. Для каждого врача без напоминаний (65-66) создаются 3 Reminder PENDING со сроком в ближайшие 22 часа и patientId реального пациента (68-76). Для каждого врача без LabResult (81-82) создаются 3-5 LabResult status RESULTED с патологическими значениями из labCatalog (стр. 46: «Холестерин общий 9.2 CRITICAL», 44: «Глюкоза 6.4 HIGH», 45: «Гемоглобин 108 LOW»), doctorId реального врача и patientId реального пациента (87-99). Строки ничем не помечены: нет ни тега, ни notes, ни meta. Условие «идемпотентности» — у врача ещё нет анализов, а после удаления UI анализов их нет почти ни у кого. Нет ни _destructive-guard, ни --force, ни проверки NODE_ENV. Где это читается: /api/crm/doctors/me/reminders (хук doctor/notifications/_hooks/use-doctor-reminders.ts), /api/crm/doctors/me/patients/[patientId]/labs, /labs/unread, аналитика врача (doctors/me/analytics:134).

G2-03 P2 · СРЕДНИЙ эксплуатация

RUNBOOK §5 утверждает, что на проде нет реальных пациентов, и предписывает регулярно запускать seed-today-live, который удаляет все сегодняшние записи с подписанными заключениями

ГДЕ

docs/operations/RUNBOOK.md:407, docs/operations/RUNBOOK.md:433, docs/operations/RUNBOOK.md:463, scripts/seed-today-live.ts:49, scripts/_live-queue-seed.ts:453, src/lib/patients/parse-identity.ts:4, docs/operations/RUNBOOK.md:470

СЦЕНАРИЙ

В воскресенье дежурный видит пустое табло и по ежедневному чек-листу идёт в §5. Guard просит --force, а при активности предлагает --i-know-there-is-real-data. Дежурный верит RUNBOOK, что реальных пациентов нет, и добавляет флаг. Все сегодняшние записи удалены вместе с подписанными утренними заключениями и оплатами, а реальные пациенты оказываются в выдуманной очереди с фиктивными визитами.

ПОСЛЕДСТВИЯ

Уничтожаются медицинские документы и финансовые записи, реальным пациентам приписываются фиктивные визиты. Регламент бэкапа проверяет не то место.

ЧТО СДЕЛАТЬ

Переписать §5 RUNBOOK: прод содержит реальные данные, демо-сиды на проде запрещены (или разрешены только для отдельной демо-клиники). Убрать из ежедневной проверки пункт «иначе §5». Исправить §6 на проверку /var/backups/medbook. В seed-today-live брать только пациентов с демо-меткой и удалять только демо-записи.

КРИТЕРИЙ ПРИЁМКИ

RUNBOOK не содержит утверждения «реальных пациентов нет» и инструкций запускать демо-сиды на neurofax. Недельная проверка бэкапа указывает на реальный каталог. seed-today-live не трогает записи и пациентов без демо-метки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

RUNBOOK.md:407: «Прод neurofax.uz сейчас — демо-окружение (реальных пациентов нет)». §5.2 (426-435) описывает seed-today-live как команду, которая «Прошлые/будущие дни не трогает. Идемпотентен, можно гонять перед каждым показом». Ежедневная проверка (463) требует «(пока прод демо) табло/календарь не пустые — иначе §5». Код говорит обратное: parse-identity.ts:4-9 фиксирует «Observed in production after three days of live use: 72 of 94 patients», а _destructive-guard.ts:4-6 пишет, что «a real doctor now runs consultations». При этом clearTodayAppointments (_live-queue-seed.ts:453-475) удаляет ВСЕ сегодняшние записи клиники вместе с

payment, visitNote, ePrescription, sickLeave, labOrder, labResult и conversation. seed-today-live.ts:49-53 берёт в пул пациентов всех пациентов клиники (where: { clinicId }, take 2000), то есть реальных, и раздаёт их в демо-очередь с COMPLETED-визитами и оплатами PAID. Команды в RUNBOOK (413-414, 429-430) даны без --force; guard в ответ сам печатает, что добавить. §6 (470-473) проверяет бэкап через mc ls x/medbook-backups/backups/, хотя backup.sh теперь пишет в /var/backups/medbook (RUNBOOK §4.1), поэтому еженедельная проверка всегда показывает пусто.

G2-04 P2 · СРЕДНИЙ эксплуатация

Runbook ротации ключа при компрометации велит сменить

APP_SECRET/AUTH_SECRET, что без механизма перешифрования ломает 2FA, Telegram-бота и интеграции; раздел «ключ потерян» описывает несуществующее поведение

ГДЕ

docs/runbooks/encryption-key-rotation.md:151, docs/runbooks/encryption-key-rotation.md:185, src/server/crypto/secrets.ts:102, src/server/crypto/secret-fields.ts:45, src/lib/auth.ts:115, src/server/crypto/field-cipher.ts:109

СЦЕНАРИЙ

После подозрения на утечку .env ops действует по runbook и меняет AUTH_SECRET и APP_SECRET. Утром ни один врач с 2FA не может войти, mini-app пациентов отвечает ошибкой проверки, бот молчит, а интеграции оплаты не работают.

ПОСЛЕДСТВИЯ

Полная остановка входа для 2FA-пользователей и всего пациентского Telegram-контур на время инцидента.

ЧТО СДЕЛАТЬ

Поправить runbook: APP_SECRET не ротировать, пока нет поддержки версий. Либо добавить в secrets.ts версионирование ключей (как в field-cipher) и скрипт перешифрования TOTP, tgBotToken и ProviderConnection. В разделе «ключ потерян» описать выпуск нового ключа под новой версией (v<n+1>) и замену нечитаемых ячеек.

КРИТЕРИЙ ПРИЁМКИ

Runbook не предписывает ротацию APP_SECRET без шага перешифрования. Если версионирование добавлено, тест подтверждает, что после ротации 2FA-вход и проверка initData работают.

ДОКАЗАТЕЛЬСТВО В КОДЕ

encryption-key-rotation.md:151-153 (Key-compromise, шаг 3): «also rotate every other secret ...: AUTH_SECRET, APP_SECRET, MinIO credentials, Telegram bot token». Но secrets.ts выводит ключ из APP_SECRET с фолбэком на AUTH_SECRET (36-44), знает только VERSION 'v1' (31, 102-104), и других версий или скрипта перешифрования нет. docs/architecture/SECURITY.md:717-720 сам признаёт: «Ротация APP_SECRET не поддерживается». После смены decrypt бросает исключение: readTotpSecret падает при входе любого пользователя с 2FA (auth.ts:115), readTgBotToken падает в вебхуке и в handler.ts, то есть проверка initData mini-app и отправка в Telegram перестают работать, а секреты ProviderConnection не читаются. Раздел «I lost the key» (184-189) утверждает «New writes still work (a new key gets generated as v1)», но field-cipher.ts:108-114 в production отказывается стартовать без ключа, ничего не генерируя. Если же вписать новый ключ под тем же ярлыком v1, старые v1-ячейки будут расшифровываться неверным ключом, и старый ключ уже не вернуть рядом, потому что слот версии занят.

G2-05 P2 · СРЕДНИЙ эксплуатация

_destructive-guard опирается на косвенный признак (≥20 строк AuditLog за 72 ч во всей БД), сам печатает команду обхода и подключён лишь к 3 из примерно 12 разрушительных скриптов

ГДЕ

scripts/_destructive-guard.ts:24, scripts/_destructive-guard.ts:57, scripts/_destructive-guard.ts:72, src/server/workers/outbox-pumper.ts:87, src/server/workers/appointment-lifecycle-sweep.ts:136, Dockerfile.worker:43

СЦЕНАРИЙ

После длинных праздников админ запускает wipe-neurofax-demo --force, думая, что стирает старое демо.

Активности за 72 часа нет, guard пропускает, и все реальные записи, заключения и оплаты клиники удалены.

ПОСЛЕДСТВИЯ

Защита от уничтожения медицинских данных срабатывает или не срабатывает случайно и легко обходится.

Большинство опасных скриптов она не прикрывает вовсе.

ЧТО СДЕЛАТЬ

Проверять наличие реальных данных, а не активность: например, отказываться, если есть FINALIZED VisitNote, оплаты или пациенты без демо-метки, и требовать ввести slug клиники и число удаляемых строк. Не печатать готовую команду обхода. Подключить guard ко всем скриптам, которые удаляют или меняют доменные данные. Сделать в Dockerfile.worker allowlist только эксплуатационных скриптов.

КРИТЕРИЙ ПРИЁМКИ

На копии прод-БД с подписанными заключениями любой разрушительный скрипт отказывает независимо от свежести аудита. Список скриптов в образе worker ограничен явным allowlist.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Решение принимается только по auditLog.count за 72 часа по всей БД (24-26, 57-59). Признак не различает людей и систему. outbox-pumper пишет строку AuditLog на каждое событие (writeAuditLog, 87-110, вызов 134), appointment-lifecycle-sweeper пишет appointment.auto-no-show (136). Поэтому guard срабатывает даже на чистом демо, и оператор привыкает добавлять флаг, который guard сам печатает готовой командой (72). В обратную сторону: после 3+ дней без работы (Навруз, Рамазан хайит) при сотнях подписанных заключений в базе хватает одного --force. Наличие реальных клинических данных (FINALIZED VisitNote, оплаты, непомеченные пациенты) guard не проверяет. wipe-neurofax-demo сам удаляет AuditLog клиники (стр. 62 wipeOrder), и следующий разрушительный запуск проходит guard. Guard подключён только к seed-mega-neurofax, seed-today-live и wipe-neurofax-demo. Без него остаются seed-demo-data, seed-clinical-life, seed-neurofax-real, seed-prod-demo, fix-double-inprogress, seed-labs-reminders-dev, cleanup-test-conversations, stress-* и prisma/seed*.ts, и все они по Dockerfile.worker:39-43 лежат в прод-образе.

G2-06 P2 · СРЕДНИЙ целостность данных

seed-clinical-life.ts от имени реальных врачей подписывает выдуманные заключения, выписывает e-рецепты и пишет 1500 поддельных записей аудита с их userId

ГДЕ

scripts/seed-clinical-life.ts:22, scripts/seed-clinical-life.ts:547, scripts/seed-clinical-life.ts:640, scripts/seed-clinical-life.ts:878, scripts/seed-clinical-life.ts:935, scripts/seed-clinical-life.ts:942, scripts/seed-clinical-life.ts:409

СЦЕНАРИЙ

Перед показом кто-то запускает цепочку seed-demo-data → seed-clinical-life на проде. У реального невролога в «Заключениях» появляются десятки подписанных им заключений, которых он не писал, и выданные от его имени рецепты с рабочими ссылками проверки. В журнале аудита видно, что он «входил» с 192.168.14.77 и «финализировал» визиты в прошлом году.

ПОСЛЕДСТВИЯ

Медицинские документы подделываются от имени реальных врачей, а юридически значимый журнал аудита фальсифицируется: действия приписываются реальным сотрудникам. KPI врача (подписанные заключения) искажены. При разборе инцидента аудиту нельзя доверять.

ЧТО СДЕЛАТЬ

Запретить скрипту работать с реальными врачами: использовать отдельных демо-врачей с явной меткой или отказываться, если у клиники есть непомеченные врачи или пациенты. Никогда не писать AuditLog с actorId реальных пользователей и не удалять строки аудита. Добавить _destructive-guard и отказ при NODE_ENV=production.

КРИТЕРИЙ ПРИЁМКИ

На базе с реальными врачами скрипт завершается отказом без записей. В демо-режиме у всех созданных VisitNote, EPrescription и Reminder doctorId указывает только на демо-врачей. Скрипт не создаёт и не удаляет строки AuditLog.

ДОКАЗАТЕЛЬСТВО В КОДЕ

SLUG по умолчанию равен neurofax (стр. 22), предохранителя нет. doctors — это все активные врачи клиники (стр. 977-988), то есть реальная линейка после seed-neurofax-real. seedVisitNotesAndLabs берёт COMPLETED-записи демо-пациентов, которые seed-demo-data раздал реальным врачам через pick(doctors), и создаёт VisitNote со status FINALIZED и doctorId = appt.doctorId (547-550) с шаблонным bodyMarkdown. Там же создаются LabOrder и LabResult от doc.userId и EPrescription со status ISSUED, doctorId реального врача и verifyToken вида vtok_<хвост id записи>_<n> (640), который проходит публичную проверку /api/verify/recipe/[token]. seedReminders создаёт каждому реальному врачу по 3-7 Reminder PENDING, в том числе «на сегодня» (849-880). seedAuditLog пишет 1500 строк AuditLog с actorId реальных врачей, action

user.signin, visitnote.finalize, payment.create, lab.result.review и фейковыми IP 192.168.x.x, с датами, разбросанными на год назад (893-945). wipeUltra при повторном запуске удаляет строки из AuditLog по meta.seed (409), то есть скрипт ещё и вычищает журнал аудита.

G2-07 P2 · СРЕДНИЙ целостность данных

seed-demo-data.ts без предохранителя занимает весь свободный день реальных врачей демо-записями (сдвиг UTC на 5 часов) и подмешивает демо-оплаты в выручку

ГДЕ

scripts/seed-demo-data.ts:24, scripts/seed-demo-data.ts:1293, scripts/seed-demo-data.ts:1406, scripts/seed-demo-data.ts:1454, scripts/seed-demo-data.ts:1507, scripts/seed-demo-data.ts:551, scripts/seed-demo-data.ts:293, src/lib/queue-ordering.ts:138

СЦЕНАРИЙ

В 10:00 ресепшн запускает seed-demo-data, чтобы «оживить» дашборд перед визитом владельца. Mini-app и онлайн-запись до конца дня показывают реальным пациентам «нет свободных слотов». В кабинете врача Султанова появляется «пациент в кресле» из демо. Касса за день показывает десятки оплат, которых не было. В списке записей стоит «08:00», а в календаре та же запись на 13:00.

ПОСЛЕДСТВИЯ

Реальные пациенты не могут записаться на сегодня, очередь врача засорена, выручка и KPI дня завышены. Удалить результат штатно нельзя: CLEAN падает посередине.

ЧТО СДЕЛАТЬ

Подключить _destructive-guard, запретить скрипт на базе с реальными пациентами и сделать slug обязательным без умолчания neurofax. Строить время через toTashkentDate/tashkentDayBounds, как _live-queue-seed. Не занимать слоты реальных врачей: использовать демо-врачей. Для будущих записей не использовать канал WALKIN. CLEAN выполнять в одной транзакции и удалять клинические дочерние сущности до пациентов.

КРИТЕРИЙ ПРИЁМКИ

Без флага и на базе с пометченными пациентами скрипт завершается отказом. В демо-БД время записей совпадает с расписанием по Ташкенту (date и time согласованы). CLEAN удаляет все демо-строки или ничего.

ДОКАЗАТЕЛЬСТВО В КОДЕ

CLINIC_SLUG по умолчанию равен neurofax (24), guard и --force нет. rebuildTodayStoryline берёт DoctorSchedule всех активных врачей на сегодняшний weekday и заполняет каждое окно приёма подряд, пропуская только обед и около 6% слотов. slotsTaken (1488) лишь не даёт наложиться на существующие записи, поэтому все свободные слоты реальных врачей оказываются заняты. Время считается в локали контейнера: dayStart.setHours(0,0,0,0) (1293) и startAt.setMinutes(cursorMin) (1406). В Dockerfile.worker и docker-compose.yml TZ не задан, контейнер живёт в UTC, поэтому расписание 08:00-17:00 превращается в записи на 13:00-22:00 по Ташкенту, а поле time при этом «08:00» (1454): список и календарь расходятся на 5 часов. Статусы IN_PROGRESS и WAITING считаются от UTC-now (1418-1428), так что демо-пациенты попадают «в кресло» и в очередь реального врача. Для COMPLETED создаются Payment PAID (1507), для истории ещё Payment PAID (497), всё это идёт в выручку дня. Будущие BOOKED получают channel из ['WALKIN','PHONE','TELEGRAM'] (551): WALKIN+BOOKED не попадает ни в live, ни в booked (queue-ordering.ts:138), то есть это невидимая запись, которая занимает слот. rebuildConversations, Calls и Leads добавляют непрочитанные демо-чаты, звонки и 16 лидов NEW. В режиме CLEAN (246-296) удаления идут без транзакции: сначала удаляются записи и оплаты, а patient.deleteMany (293) падает на RESTRICT-связях (MedicalCase, EPrescription, PatientAllergy и т.п. от seed-clinical-life), оставляя полуочищенные данные.

G2-08 P2 · СРЕДНИЙ целостность данных

seed-neurofax-real.ts без транзакции деактивирует всех врачей, услуги и кабинеты, откатывает цены и расписания к прайсу 18.05 и снова активировать уволенных врачей

ГДЕ

scripts/seed-neurofax-real.ts:248, scripts/seed-neurofax-real.ts:277, scripts/seed-neurofax-real.ts:308, scripts/seed-neurofax-real.ts:326, scripts/seed-neurofax-real.ts:347, scripts/seed-neurofax-real.ts:365, scripts/seed-neurofax-real.ts:380

СЦЕНАРИЙ

Через полгода кто-то по старой памяти запускает seed-neurofax-real, «чтобы починить каталог». Консультация у Бусакова снова стоит 300 000 вместо нового прайса. Новый врач и услуга «Массаж» исчезают из записи. Расписание Султанова, которое админ сократил, возвращается к Пн–Сб 08:00–17:00. Уволенная и отключённая врач снова может войти с известным паролем. Если скрипт падает на уникальности кабинета, у клиники не

остаётся ни одного активного врача.

ПОСЛЕДСТВИЯ

Неверные цены (а значит и деньги), неверное расписание, недоступность онлайн-записи, реактивация уволенных сотрудников с известным паролем.

ЧТО СДЕЛАТЬ

Удалить скрипт из прод-образа или превратить в строго аддитивный: без `updateMany isActive=false` по всей клинике, без сброса цен, расписаний и паролей. Не трогать `active` у `User`. Если оставлять, выполнять в одной транзакции и за `_destructive-guard`.

КРИТЕРИЙ ПРИЁМКИ

Запуск на базе с изменёнными в UI ценами, расписаниями и доп. врачами не меняет ни одного из этих значений. Искусственная ошибка посреди запуска не оставляет клинику без активных врачей.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Скрипт называет себя «Idempotent» и работает с реальной линейкой клиники. Последовательно, без `$transaction: cabinet.updateMany isActive=false` для ВСЕХ кабинетов (248), `service.updateMany isActive=false` для всех услуг (277), затем `upsert` только захардкоженных с `priceBase` из прайса «от 18.05.2026» (289/299), затем `doctor.updateMany isActive=false` для всех врачей (308). Дальше для 7 зашитых врачей: `user.upsert` с `active: true` и сбросом пароля (326-327; пароль уже отмечен в #354), `doctor.upsert` с `cabinetId` (347/359), `serviceOnDoctor.deleteMany` с пересозданием и `priceOverride` из кода (365), `doctorSchedule.deleteMany` с пересозданием недельной сетки (380). `Doctor.cabinetId` объявлен `@unique (schema.prisma:866)`: если админ через UI пересадил врача в другой кабинет, `upsert` следующего врача падает на P2002, когда все врачи, услуги и кабинеты уже деактивированы. Врачи, услуги и кабинеты, добавленные клиникой в UI после 18.05, остаются неактивными.

G2-09 P2 · СРЕДНИЙ бар

wipe-neurofax-demo и seed-mega не удаляют Referral: удаление пациентов молча падает, а сброс patientCounter в 0 навсегда ломает регистрацию новых пациентов

ГДЕ

`scripts/wipe-neurofax-demo.ts:64`, `scripts/wipe-neurofax-demo.ts:98`, `scripts/wipe-neurofax-demo.ts:105`, `scripts/seed-mega-neurofax.ts:208`, `prisma/migrations/20260609130000_clinical_referrals/migration.sql:66`, `src/app/api/crm/patients/route.ts:183`

СЦЕНАРИЙ

Админ прогоняет `wipe`, в клинике было направление к кардиологу. Все пациенты остались, но без визитов, а счётчик равен 0. Утром ресепшн пытается зарегистрировать нового пациента, киоск оформляет `walk-in`: каждый раз 500, и так бесконечно, пока кто-то вручную не поправит `Clinic.patientCounter`.

ПОСЛЕДСТВИЯ

Клиника не может регистрировать новых пациентов, а данные остаются в полуудалённом состоянии.

ЧТО СДЕЛАТЬ

Строить порядок удаления по FK из `information_schema` (или добавить `Referral` и все таблицы с `patientId`) и делать всю очистку в одной транзакции. Не глотать ошибки `DELETE`. Сбрасывать `patientCounter` как `max(patientNumber)` оставшихся пациентов, а не 0.

КРИТЕРИЙ ПРИЁМКИ

На тестовой БД с `Referral` `wipe` либо удаляет всё, либо откатывается без изменений. После `wipe` создание пациента через API и киоск проходит.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В ручном списке `wipeOrder` (`wipe-neurofax-demo.ts:25-65`, `seed-mega-neurofax.ts:144-184`) нет таблицы `Referral`, а `Referral_patientId_fkey` объявлен `ON DELETE RESTRICT (migration 20260609130000:66-67)`. Если в клинике есть хоть одно направление, `DELETE FROM "Patient"` падает целиком. Ошибка перехватывается и выводится только как предупреждение (`wipe:97-99`, `mega:202-205`), а записи, визиты и оплаты к этому моменту уже удалены. Затем `patientCounter` безусловно сбрасывается в 0 (`wipe:103-106`, `mega:208`), хотя пациенты с номерами 1..N остались. `allocatePatientNumber` делает `increment` внутри транзакции создания (`patients/route.ts:182-183`, `walkin.ts:124`). `Unique (clinicId, patientNumber)` даёт P2002, транзакция откатывается вместе со счётчиком, и следующая попытка получает тот же номер. `mega-сид` падает на создании первого пациента.

G2-10 P2 · СРЕДНИЙ баг

Скрипты шаблонов возвращают снятые напоминания за 5 и 2 часа: seed-prod-demo и backfill-new-templates (по NEW-CLINIC.md) включают их заново, а reminder-cadence вопреки описанию выключает кастомные напоминания админа

ГДЕ

scripts/seed-prod-demo.ts:274, scripts/backfill-new-templates.ts:11, scripts/backfill-new-templates.ts:86, docs/operations/NEW-CLINIC.md:115, scripts/reminder-cadence-5d3d1d3h.ts:17, scripts/reminder-cadence-5d3d1d3h.ts:202, src/server/workers/notifications-scheduler.ts:92, src/server/notifications/triggers.ts:437

СЦЕНАРИЙ

Новую клинику онбордингуют по NEW-CLINIC.md. Её пациенты получают 5 напоминаний на запись, причём «за 5 часов» и «за 3 часа» приходят почти подряд. В neurofax кто-то перезапускает seed-prod-demo, и вернулись напоминания за 5 и 2 часа с просьбой «ответьте YES». Админ настроил «напоминание за 1 час», после деплоя прогнали reminder-cadence, и оно молча выключилось.

ПОСЛЕДСТВИЯ

Пациенты получают дубли и лишние напоминания, раздражаются и отписываются от бота. Правки текстов админом теряются. Настроенные админом напоминания исчезают без следа.

ЧТО СДЕЛАТЬ

Убрать из seed-prod-demo блок шаблонов или создавать через него только отсутствующие канонические ключи без isActive: true в update. Удалить reminder.5h из backfill-new-templates и поправить NEW-CLINIC.md. В reminder-cadence не трогать шаблоны, которые админ создал или изменил (различать по ключу и признаку сид-строки), либо исправить шапку и предупреждать. В findTemplateFor задать детерминированный orderBy.

КРИТЕРИЙ ПРИЁМКИ

После прогона всех трёх скриптов на тестовой клинике активны ровно 4 канонических напоминания плюс созданные админом. Повторный запуск seed-prod-demo не меняет isActive и тексты существующих шаблонов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

reminder-cadence-5d3d1d3h.ts оставляет активными только смещения -7200, -4320, -1440 и -180, а остальные APPOINTMENT_BEFORE гасит, в том числе «older reminder.* seeds» (комментарий 49-52). Однако seed-prod-demo.ts:263-275 делает upsert шаблонов reminder.3d (-4320), reminder.24h (-1440), reminder.5h (-300) и reminder.2h (-120) с update: { ..., isActive: true } и перезаписью bodyRu и bodyUz. Тем самым включаются снятые шаблоны и затираются правки админа; тексты со «ответьте YES (или ДА / НА)» остались от эпохи SMS. backfill-new-templates.ts создаёт reminder.5h (offset -300, isActive: true, стр. 11-27, 86) во всех клиниках, где такого ключа нет, и NEW-CLINIC.md:112-119 велит запускать его при онбординге каждой клиники. Смещения -300 и -120 рассылает динамический проход планировщика (notifications-scheduler.ts:92-108). На канонических смещениях при дублях findTemplateFor делает findFirst без orderBy (triggers.ts:437), и выбор текста недетерминирован. В самом reminder-cadence шапка обещает «Rows whose offset an admin customised away from the seeded value are left untouched» (17), но цикл 170-205 выключает КАЖДЫЙ активный APPOINTMENT_BEFORE с неканоническим смещением.

G2-11 P2 · СРЕДНИЙ безопасность

Скрипты шифрования не проверяют, что ключ совпадает с ключом приложения: encrypt-auth-secrets берёт локальный .env, encrypt-existing-pii молча шифрует публичным dev-ключом

ГДЕ

scripts/encrypt-auth-secrets.ts:25, scripts/encrypt-auth-secrets.ts:34, scripts/encrypt-auth-secrets.ts:42, scripts/encrypt-existing-pii.ts:267, src/server/crypto/field-cipher.ts:116, docs/runbooks/encryption-key-rotation.md:76

СЦЕНАРИЙ

Инженер запускает encrypt-existing-pii с ноутбука, забыв экспортировать ключ. Паспорта и заметки всех пациентов теперь v1-шифротекст под публичным ключом: приложение не может их расшифровать, карточки пациентов падают с 500, а любой, у кого есть дампы и исходники, читает эти данные.

ПОСЛЕДСТВИЯ

ПДн оказываются зашифрованы общеизвестным ключом, карточки пациентов перестают открываться. В случае auth-секретов перестают работать 2FA-вход и Telegram-бот.

ЧТО СДЕЛАТЬ

Перед записью расшифровывать одну существующую ячейку текущей версии (или сверять fingerprint ключа с сохранённым в БД) и падать при несовпадении. В скриптах бэкфилла запрещать dev-фолбэк, если DATABASE_URL не локальный. Убрать dotenv из прод-скриптов или требовать явный флаг.

КРИТЕРИЙ ПРИЁМКИ

Запуск с неверным или отсутствующим ключом против базы с уже зашифрованными строками завершается ошибкой до первой записи. Unit-тест покрывает проверку fingerprint.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Шапка encrypt-auth-secrets.ts:25-27 обещает: «Running with a secret that differs from the app's would lock every user out of 2FA... hence the fail-fast guard». Фактический guard (242-246) проверяет только наличие APP_SECRET или AUTH_SECRET, а import 'dotenv/config' (34) подтягивает локальный .env. Шапка (15-17) прямо допускает локальный запуск. Запуск с ноутбука с DATABASE_URL прода шифрует totpSecret и tgBotToken локальным ключом. encrypt-existing-pii.ts:267-271 при NODE_ENV!='production' и без FIELD_ENCRYPTION_KEY только печатает WARNING и продолжает, а field-cipher.ts:116-129 подставляет детерминированный ключ sha256('dev-only-do-not-use-in-prod'), который выводится из исходников. Runbook (74-79) предлагает запускать backfill как `FIELD\_ENCRYPTION\_KEY=<KEY> DATABASE\_URL=... tsx ...` с любой машины, и при пустом или опечатанном KEY получается то же самое. Проверка на 267 к тому же игнорирует FIELD_ENCRYPTION_KEY_V<n>. Ни один скрипт не пробует сначала расшифровать уже существующую ячейку, чтобы убедиться в совпадении ключа.

G2-12 P3 · НИЗКИЙ целостность данных · требует проверки на живых данных

HTTP-stress-скрипты против neurofax помечают реальный неоплаченный визит как оплаченный и затирают адрес клиники без восстановления

ГДЕ

scripts/stress-payments-analytics-ai.ts:124, scripts/stress-payments-analytics-ai.ts:196, scripts/stress-settings-crud.ts:388, scripts/stress-cases-scenarios.ts:818, scripts/stress-payments-analytics-ai.ts:16

СЦЕНАРИЙ

Для проверки прода кто-то запускает stress-payments с STRESS_BASE_URL=https://neurofax.uz. Визит реального пациента, который должен был оплатить на кассе, уже числится «Оплачено наличными». Пациент уходит без оплаты, а касса вечером не сходится. После stress-settings пациенты получают напоминания с адресом «ул. Стрессовая, 9 (test)».

ПОСЛЕДСТВИЯ

Недополученная выручка, расхождение кассы, неверный адрес клиники в сообщениях пациентам.

ЧТО СДЕЛАТЬ

Запретить stress-скриптам работать не с localhost или с базой, где есть непомеченные данные. Создавать для оплат собственные тестовые записи и пациентов, восстанавливать изменённые настройки клиники в finally. Фильтровать удаления по clinicId.

КРИТЕРИЙ ПРИЁМКИ

Прогон stress-скриптов не создаёт оплат на записях, которые он сам не создавал, и оставляет Clinic.addressRu неизменным. С не-localhost BASE без явного флага скрипты отказывают.

ДОКАЗАТЕЛЬСТВО В КОДЕ

stress-payments-analytics-ai.ts логинится как 1@1.uz/1 (16-17), ищет среди COMPLETED-записей первую без оплаты (106-127), то есть реальный визит, по которому ресепшн ещё не принял деньги, и создаёт на неё Payment PAID CASH на полную priceFinal (145-160). Ещё одна оплата PAID на 1_000 тийинов уходит реальному пациенту (190-199). Всё это не удаляется. stress-settings-crud.ts:387-389 делает PATCH /api/crm/clinic с addressRu «ул. Стрессовая, 9 (test)» и не восстанавливает адрес: он попадает в {{clinic.address}} шаблонов напоминаний, на лендинг и в печать. stress-cases-scenarios.ts:818 делает service.deleteMany({ code startsWith 'STRESS_' }) без clinicId, а 810-813 обнуляет serviceId у записей всех клиник. Шапка при этом утверждает «ALL writes go inside clinicId='neurofax' so we never touch demo data».

backfill-birth-year-from-name.ts меняет ФИО и дату рождения пациентов всех клиник без фильтра по клинике и без аудита

ГДЕ

scripts/backfill-birth-year-from-name.ts:35, scripts/backfill-birth-year-from-name.ts:85, src/lib/patients/parse-identity.ts:59

СЦЕНАРИЙ

Скрипт с `--apply` запускают ради neurofax. В другой клинике у пациентки с заметкой в имени появляется год рождения 2019, в карте «5 лет», и возрастные проверки дозировок работают неверно. Кто и когда это изменил, узнать нельзя.

ПОСЛЕДСТВИЯ

Неверный возраст в картах чужих клиник, изменение ПДн без следа в аудите.

ЧТО СДЕЛАТЬ

Требовать `--clinic` и фильтровать по `clinicId`. Писать `AuditLog` с исходным и новым значением. Пропускать имена, где число стоит не в конце или сопровождается скобками или словами.

КРИТЕРИЙ ПРИЁМКИ

Без `--clinic` скрипт отказывает. Каждое изменение сопровождается строкой аудита, а тест на «Ахмедова (ребёнок 2019)» не меняет запись.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Выборка `patient.findMany({ where: { birthDate: null } })` (35-39) идёт без `clinicId`, хотя обоснование в шапке касается только привычки одного врача NeuroFax. Для каждого найденного выполняется `update fullName` и `birthDate` (85-88) без записи в `AuditLog`. `parsePatientIdentity` берёт ПОСЛЕДНЕЕ четырёхзначное число в диапазоне 1900..текущий год в любом месте имени (`parse-identity.ts:59-68`). Имя вроде «Ахмедова (мать, ребёнок 2019)» или номер карты «Каримов 2024» превращается в год рождения 2019 или 2024, а само число вырезается из ФИО.

cleanup-test-conversations.ts в SYSTEM-контексте выводит все чаты всех клиник и удаляет переписки по префиксу Telegram chat id во всех тенантах

ГДЕ

scripts/cleanup-test-conversations.ts:7, scripts/cleanup-test-conversations.ts:20, scripts/cleanup-test-conversations.ts:36, scripts/cleanup-test-conversations.ts:48, src/lib/prisma.ts:211

СЦЕНАРИЙ

Разработчик чистит свои тестовые чаты командой из `usage` (`--prefix 7770`) на проде. Удаляются переписки реальных пациентов всех клиник, у которых Telegram ID начинается на 7770, вместе со всей историей сообщений операторов. Вывод со сводкой чатов всех клиник остаётся в логах и терминале.

ПОСЛЕДСТВИЯ

Безвозвратная потеря переписки с пациентами в чужих клиниках. PHI всех тенантов уходит в вывод.

ЧТО СДЕЛАТЬ

Требовать `--clinic <slug>` и фильтровать по `clinicId`. Удалять только диалоги с тестовой меткой, не по префиксу `chat id`. По умолчанию работать в режиме `dry-run` и не печатать тексты сообщений.

КРИТЕРИЙ ПРИЁМКИ

Без `--clinic` скрипт отказывает. С префиксом, совпадающим с реальным `chat id`, удаляются только помеченные тестовые диалоги указанной клиники.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`runWithTenant({ kind: 'SYSTEM' })` (7) отключает авто-скоуп `tenant`-расширения (`prisma.ts:211-217`). `conversation.findMany` без фильтра (8-18) печатает для каждого чата всех клиник `externalId`, имя, `@username` и первые 30 символов последнего сообщения (20-24), и так при каждом запуске, даже без аргументов. Отбор идёт по `c.externalId?.startsWith(prefix)` (36-38) без `clinicId`, затем `message.deleteMany` и `conversation.deleteMany` (48-53). У TG-диалогов `externalId` равен настоящему `chat id` пациента (см. `stress-appointments.ts`, где `externalId = String(tgIdNum)`). Пример из `usage` «`--prefix 7770`» совпадёт с реальными ID вида 7770xxxxxx. `Dry-run` только по флагу, подтверждения нет.

connect-tg-bot.ts не проверяет, что бот уже привязан к другой клинике, и не пишет аудит

ГДЕ

scripts/connect-tg-bot.ts:62, scripts/connect-tg-bot.ts:92, scripts/connect-tg-bot.ts:102, src/app/api/crm/integrations/tg/connect/route.ts:103

СЦЕНАРИЙ

Ops по ошибке указывает CLINIC_SLUG другой клиники с токеном бота neurofax. Вебхук бота перенаправляется на клинику B, и ответы пациентов neurofax попадают в инбокс чужой клиники. Сообщения, пришедшие во время сбоя, потеряны, а в журнале нет следа смены.

ПОСЛЕДСТВИЯ

Переписка пациентов одной клиники уходит в другую, теряются входящие сообщения, смена бота не отражена в аудите.

ЧТО СДЕЛАТЬ

Добавить ту же проверку bot_in_use, запись в AuditLog, опцию сохранения pending updates и updateMany вместо update.

КРИТЕРИЙ ПРИЁМКИ

Скрипт с токеном, уже привязанным к другой клинике, завершается ошибкой без вызова setWebhook, а при успешном запуске появляется строка аудита.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ops-аналог мастера подключения ищет клинику по slug (62-66) и сразу регистрирует вебхук и сохраняет токен (86-109). Проверки коллизии, как в мастере (route.ts:103-113: tgBotUsername у другой клиники → 409 bot_in_use), нет. Аудита tg.connect нет, хотя мастер пишет его (route.ts:238-248). drop_pending_updates: true (92) выбрасывает накопленные входящие сообщения пациентов. clinic.update (102) возвращает полную строку, от чего encrypt-auth-secrets специально уходит на updateMany из-за P2022 при отставших миграциях.

guard-e2e.ts заводит в живой клинике аккаунт врача guard-e2e@neurofax.uz с паролем из репозитория и без 2FA

ГДЕ

scripts/guard-e2e.ts:22, scripts/guard-e2e.ts:23, scripts/guard-e2e.ts:27

СЦЕНАРИЙ

После ручного E2E-теста на проде забыли выполнить `guard-e2e.ts cleanup`. Любой, кто читал репозиторий, входит как врач guard-e2e и получает доступ к спискам и картам пациентов клиники.

ПОСЛЕДСТВИЯ

Несанкционированный доступ к медицинским данным через известный пароль.

ЧТО СДЕЛАТЬ

Не создавать учётки в клинике neurofax. Генерировать случайный пароль и печатать его, требовать mustChangePassword или ограничивать учётку демо-клиникой. Отказывать при NODE_ENV=production.

КРИТЕРИЙ ПРИЁМКИ

В прод-образе скрипта нет или он отказывает. В БД прода нет пользователя guard-e2e@neurofax.uz.

ДОКАЗАТЕЛЬСТВО В КОДЕ

LOGIN_EMAIL = 'guard-e2e@neurofax.uz', LOGIN_PASSWORD = 'Guard12345' (22-23), «2FA off» по шапке (4-5). getClinicId берёт slug neurofax (27-30), то есть реальную клинику. Удаление аккаунта требует отдельного запуска cleanup. Скрипт лежит в прод-образе worker. В #354 учтены пароли в seed.ts, seed-neurofax-real и upsert-dev-admin, а этот источник туда не вошёл. Аналогично stress-appointments зашивает recept@neurofax.uz/recept, а stress-payments и stress-settings используют 1@1.uz/1.

poke-webhook.ts отправляет секрет вебхука прод-клиники на захардкоженный адрес trycloudflare

ГДЕ

scripts/poke-webhook.ts:7, scripts/poke-webhook.ts:12, scripts/poke-webhook.ts:27

СЦЕНАРИЙ

В контейнере worker кто-то запускает poke-webhook для диагностики, и секрет вебхука прода уходит на чужой хост. Получатель может подделывать апдейты Telegram для /api/telegram/webhook/neurofax, в том числе нажатия «подтвердить» или «отменить» запись от имени пациентов.

ПОСЛЕДСТВИЯ

Компрометация аутентификации входящих Telegram-апдейтов клиники.

ЧТО СДЕЛАТЬ

Удалить скрипт или брать URL из аргумента с проверкой на собственный домен. Не использовать прод-секрет в отладочных скриптах. После возможной утечки перевыпустить tgWebhookSecret.

КРИТЕРИЙ ПРИЁМКИ

В репозитории нет захардкоженных внешних URL, на которые отправляется секрет. Скрипт отказывает без явного URL на домен приложения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Скрипт читает clinic.tgWebhookSecret клиники neurofax из DATABASE_URL (7-10) и шлёт POST с заголовком x-telegram-bot-api-secret-token на <https://arrangements-mike-dose-allow.trycloudflare.com/api/telegram/webhook/neurofax> (12, 27). Это эфемерный quick-tunnel, давно не принадлежащий проекту. update содержит захардкоженный chat.id 200479724 (17-18). Скрипт лежит в прод-образе worker.

prisma/seed-drugs.ts при перезапуске удаляет бренды госреестра у курируемых препаратов и откатывает добавленные формы: CDS и поиск перестают узнавать торговые названия

ГДЕ

prisma/seed-drugs.ts:81, prisma/seed-drugs.ts:73, scripts/import-uzpharm-registry.ts:168, scripts/enrich-drug-forms.ts:123, src/server/cds/drug-check.ts:118

СЦЕНАРИЙ

После обновления справочника кто-то перезапускает seed-drugs. Врач пишет в назначении «Конкор», который пришёл из реестра, но CDS его больше не распознаёт, и предупреждение о взаимодействии с другим препаратом не показывается. В конструкторе назначений пропала инъекционная форма.

ПОСЛЕДСТВИЯ

Тихо ослабевают клиническая проверка взаимодействий и аллергий, пропадают формы и бренды в поиске.

ЧТО СДЕЛАТЬ

Удалять и пересоздавать только бренды, которые пришли из статического каталога (помечать источник), а бренды реестра не трогать. Формы объединять, а не перезаписывать. Либо документировать обязательный порядок seed-drugs → import-uzpharm → enrich-drug-forms и выполнять его одной командой.

КРИТЕРИЙ ПРИЁМКИ

После seed-drugs количество DrugBrand с manufacturer не уменьшается, и формы, добавленные enrich-drug-forms, сохраняются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-drugs.ts:79-81 с комментарием «Brands are catalog-only... replacing them wholesale» выполняет drugBrand.deleteMany({ where: { drugId: d.id } }) для каждого курируемого препарата. import-uzpharm-registry.ts (шапка 10 и createMany на 168) дописывает к этим же курируемым препаратам бренды из госреестра с manufacturer, и все они стираются. drug.upsert update: fields (73-77) включает forms, поэтому откатывается объединение форм, которое сделал enrich-drug-forms.ts:123 (например, инъекционная форма АЦЦ Инжект). CDS сопоставляет текстовые назначения с препаратами по DrugBrand.name (drug-check.ts:118, 135), а поиск каталога ищет по brands (catalogs/drugs/route.ts:104).

prisma/seed.ts при повторном запуске переписывает реальные реквизиты клиники neurofax заглушками «ул. Пример, 1» и тексты шаблонов уведомлений

ГДЕ

prisma/seed.ts:51, prisma/seed.ts:258, prisma/seed.ts:806, scripts/seed-neurofax-real.ts:227

СЦЕНАРИЙ

Разворачивают новую клинику и по совету из seed-neurofax-real запускают prisma/seed.ts на проде. В реминдерах пациентам neurofax теперь телефон +998 71 200 00 01 и адрес «ул. Пример, 1», а тексты напоминаний, отредактированные админом, заменены шаблонными.

ПОСЛЕДСТВИЯ

Пациенты получают неверные контакты клиники. Настройки админа теряются.

ЧТО СДЕЛАТЬ

Сделать сид аддитивным: создавать клинику только при отсутствии, в update ничего не менять. Не менять isActive и тексты существующих шаблонов. Убрать из seed-neurofax-real совет запускать seed.ts на проде.

КРИТЕРИЙ ПРИЁМКИ

Повторный запуск seed.ts на базе с реальной клиникой не меняет ни одного поля Clinic и NotificationTemplate.

ДОКАЗАТЕЛЬСТВО В КОДЕ

clinicsToSeed для slug neurofax содержит addressRu 'г. Ташкент, ул. Пример, 1', phone '+998712000001', email 'info@neurofax.uz' (49-58). clinic.upsert в ветке update переписывает nameRu, nameUz, addressRu, addressUz, phone, email, brandColor и active (258-269). notificationTemplate.upsert в update ставит isActive: true и заменяет bodyRu на шаблонное `Здравствуйте, {{patient.fullName}}! \${t.nameRu}.` (795-816). seed-neurofax-real.ts:227-229 при этом прямо отправляет: «run prisma/seed.ts first to bootstrap the platform». Скрипт идёт в прод-образ вместе с prisma/.

seed-drug-interactions.ts стирает все взаимодействия глобально и вставляет их по одному без транзакции, а в деплое его никто не запускает

ГДЕ

prisma/seed-drug-interactions.ts:23, prisma/seed-drug-interactions.ts:34, prisma/migrations/20260518110000_0_drug_interactions/migration.sql:1

СЦЕНАРИЙ

Новый сервер разворачивают по DEPLOY.md. Врач назначает варфарин и аспирин, и CDS молчит, потому что пар взаимодействий в базе нет.

ПОСЛЕДСТВИЯ

Функция проверки взаимодействий выглядит рабочей, но пуста или временно пуста.

ЧТО СДЕЛАТЬ

Перенести загрузку пар в миграцию или шаг деплоя. Сид выполнять в одной транзакции через upsert вместо wipe. Отчёт о пропущенных парах выводить как ошибку.

КРИТЕРИЙ ПРИЁМКИ

После чистого деплоя по документации SELECT count(*) FROM "DrugInteraction" > 0. Параллельный CDS-запрос во время ресида видит полный набор.

ДОКАЗАТЕЛЬСТВО В КОДЕ

drugInteraction.deleteMany({}) (23) затрагивает все клиники, дальше 43 последовательных create (27-45) без \$transaction. Всё время прогона, а при падении и после него, CDS видит пустую или частичную таблицу. Пары с отсутствующим препаратом тихо пропускаются (28-31). Миграция 20260518110000 не содержит ни одного INSERT, а DEPLOY.md, NEW-CLINIC.md и RUNBOOK.md не упоминают запуск сида. На свежем развёртывании таблица DrugInteraction пуста, и проверка взаимодействий ничего не находит.

seed-joe-two.ts выдаёт номер пациента в обход атомарного счётчика и создаёт walk-in без queuedAt и номера талона у захардкоженного прод-врача

ГДЕ

scripts/seed-joe-two.ts:17, scripts/seed-joe-two.ts:41, scripts/seed-joe-two.ts:57, scripts/seed-joe-two.ts:61

СЦЕНАРИЙ

Во время ручного теста ресепшн одновременно регистрирует пациента и получает 500. На табло появляются два walk-in без номера талона, которые встают в очередь непредсказуемо.

ПОСЛЕДСТВИЯ

Сбой регистрации, некорректная живая очередь, тестовые пациенты в прод-данных.

ЧТО СДЕЛАТЬ

Использовать allocatePatientNumber, заполнять queuedAt, ticketSeq и queueOrder, как _live-queue-seed, пометать пациентов и не держать прод-ID в коде.

КРИТЕРИЙ ПРИЁМКИ

Параллельная регистрация через API во время скрипта не падает, и у созданных walk-in заполнены queuedAt и ticketSeq.

ДОКАЗАТЕЛЬСТВО В КОДЕ

DOCTOR_ID захардкожен как 'cmq6oqd1x000407mjs6unib0l' (17). base = clinic.patientCounter читается без блокировки (41), пациенты создаются с patientNumber base+1 и base+2 (46), затем patientCounter перезаписывается значением base+2 (55-58). Если ресепшн в этот момент регистрирует пациента через allocatePatientNumber, получается P2002 у одной из сторон либо откат счётчика. phoneNormalized записан без '+' (49), не в каноническом виде. Записи WALKIN WAITING (61-76) создаются без queuedAt, ticketSeq и queueOrder, а живая очередь упорядочивается по queuedAt (queue-ordering.ts:47-60) и печатает ticketSeq. Демо-пациенты «Тестов Алишер» и «Каримова Дилноза» остаются в реальной клинике.

stress-appointments.ts до любых HTTP-вызовов удаляет в neurofax все оплаты без пациента и записи, а группа Z подделывает /start от имени реального пациента

ГДЕ

scripts/stress-appointments.ts:527, scripts/stress-appointments.ts:471, scripts/stress-appointments.ts:1928, scripts/stress-appointments.ts:36, src/server/schemas/payment.ts:21, prisma/migrations/20260422080121_phase-1-initial/migration.sql:948

СЦЕНАРИЙ

Разработчик запускает stress-appointments в контейнере worker. Логин падает, но оплаты пациентов, стёртых по DSAR, из клиники уже удалены. При прогоне на стейдж-URL с прод-БД реальный пациент получает в Telegram приветствие бота, которого он не запрашивал.

ПОСЛЕДСТВИЯ

Уничтожаются финансовые записи, которые обязаны пережить удаление пациента. Реальному пациенту приходит сообщение, а в инбокс — фальшивое входящее.

ЧТО СДЕЛАТЬ

Удалить stress-скрипты из прод-образа. Сузить очистку до строк, созданных самим прогоном (по idempotencyKey или метке). Для группы Z использовать только тестового пациента с заведомо фиктивным chat.id. Требовать явный флаг и отказывать при NODE_ENV=production.

КРИТЕРИЙ ПРИЁМКИ

Запуск в контейнере worker не удаляет ни одной строки Payment, не созданной этим прогоном. Группа Z не использует telegramId реальных пациентов.

ДОКАЗАТЕЛЬСТВО В КОДЕ

main() первым делом вызывает cleanupPriorTestData() напрямую через DATABASE_URL (527), ещё до login() на STRESS_BASE_URL (по умолчанию localhost:3000). Поэтому в контейнере worker, где localhost:3000 не приложение, удаление успевает выполняться, а потом скрипт падает. Внутри: payment.deleteMany({ clinicId, patientId: null, appointmentId: null }) (470-472) с обоснованием «Real payments always have at least one of the two». Это неверно: CreatePaymentSchema допускает оба поля null (payment.ts:21-22), а FK Payment→Patient и Payment→Appointment объявлены ON DELETE SET NULL (migration:945/948). У пациента, удалённого по DSAR

HARD_DELETE (data-deletion.ts:159), его оплаты без записи превращаются ровно в такие строки, а их нужно хранить. Группа Z (1920-1990) берёт первого пациента neurofax с telegramId, чьё имя не начинается с «Stress Patient», и шлёт на вебхук клиники поддельный update /start с его chat.id и секретом из БД. Бот обрабатывает это как настоящий /start и отвечает в чат реального пациента, а в инбоксе появляется «/start» (скрипт сам проверяет, что строка Conversation обновилась).>Login по зашитым receipt@neurofax.uz / receipt (36-37). Группа P вешает time-off «stress:» на реальных врачей и снимает его только в конце прогона.

G2-23 P3 · НИЗКИЙ безопасность · требует проверки на живых данных

tg-relay-worker.js — открытый ретранслятор Bot API: проксирует любой чужой токен

ГДЕ

scripts/tg-relay-worker.js:35, scripts/tg-relay-worker.js:57

СЦЕНАРИЙ

Адрес *.workers.dev попадает в сканер или утекает. Посторонние гоняют через него свои боты из заблокированных сетей, выбирают дневной лимит бесплатного плана Cloudflare или получают блокировку аккаунта. Напоминания пациентам клиники перестают уходить.

ПОСЛЕДСТВИЯ

Злоупотребление инфраструктурой владельца и отказ в доставке уведомлений.

ЧТО СДЕЛАТЬ

Требовать общий секрет (заголовок, который добавляет только приложение) и/или allowlist ID ботов, ограничить методы Bot API.

КРИТЕРИЙ ПРИЁМКИ

Запрос без секрета или с токеном не из allowlist получает 403, а бот клиники продолжает работать.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Единственная проверка — форма пути `^/(bot\d+|file\bot\d+)/` (35). Нет ни общего секрета в заголовке, ни allowlist ID ботов клиник. Любой запрос с любым токеном пересылается на api.telegram.org с пробросом заголовков и тела (41-57). Шапка прямо называет relay «token-agnostic... serves every clinic's bot». При TELEGRAM_API_BASE, указывающем на этот воркер (bot-api.ts:15, send.ts:82), доставка всех уведомлений зависит от его квоты.

G2-24 P3 · НИЗКИЙ безопасность

Демо-пациенты сидов получают настоящие Telegram ID и номера телефонов и ничем не отделены от реальных: напоминания уходят посторонним, колл-центр получает задачи звонить незнакомцам

ГДЕ

scripts/seed-demo-data.ts:368, src/server/miniapp/handler.ts:223, scripts/seed-prod-demo.ts:328, scripts/seed-mega-neurofax.ts:242, src/server/appointments/walkin.ts:109, src/lib/phone.ts:38, src/server/notifications/no-channel-action.ts:41, src/server/workers/medication-reminder.ts:113

СЦЕНАРИЙ

После mega-сиды в Action Center у ресепшна 200 задач «нет канала связи, позвоните пациенту». Оператор звонит на +998 9X XXX XX XX, а это посторонний человек, которого «записали» к неврологу. Человек с номером +998 99 910 01 23 приходит в киоск: его встречают как «Каримова Азиза» с чужой историей визитов.

ПОСЛЕДСТВИЯ

Сотрудники контактируют с посторонними от имени медицинской клиники. Реальный человек может оказаться в демо-карте с чужой историей. Бот шлёт напоминания о лекарствах на чужие Telegram ID. Аналитика и сегменты искажены.

ЧТО СДЕЛАТЬ

Для демо-данных использовать заведомо невыделяемые идентификаторы: отрицательные или заведомо фиктивные telegramId и номера из диапазона, не выделенного операторам. Добавить в Patient явный флаг isDemo (или договорённый тег) и исключать таких пациентов в планировщике уведомлений, medication-reminder, Action Center, аналитике и поиске по телефону в киоске и walk-in.

КРИТЕРИЙ ПРИЁМКИ

Ни один сид не создаёт telegramId или телефон из реальных диапазонов. Для пациента с флагом демо не создаются NotificationSend, MedicationReminderSend и PATIENT_NO_CHANNEL, и такой пациент не находится поиском по телефону в киоске.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-demo-data.ts:368 выдаёт каждому третьему демо-пациенту telegramId `\${5\_000\_000 + i}`: это реальные аккаунты Telegram 2013-2014 годов. Mini-app находит пациента по telegramId внутри клиники (handler.ts:223, findFirst), поэтому реальный владелец такого ID, открыв mini-app клиники, входит в демо-карту. seed-clinical-life создаёт им ACTIVE Prescription с remindersEnabled, и medication-reminder.ts:113 рассылает напоминания о приёме препаратов на эти ID. seed-prod-demo.ts:328 даёт 540 пациентам телефоны 99910XXXX, то есть реальный блок UCell +998 99 910 00 00 ... 05 39, а seed-mega-neurofax.ts:242 даёт 260 пациентам случайные реальные мобильные номера. walkin.ts:109 и kiosk/checkin ищут пациента по phone IN phoneSearchVariants, куда входит локальная часть номера (phone.ts:38), поэтому реальный человек с таким номером склеивается с демо-картой. У TG-less демо-пациентов с будущими бронями планировщик создаёт PATIENT_NO_CHANNEL Actions (no-channel-action.ts:41, вызовы из notifications-scheduler.ts:228/244), то есть задачу «позвонить» с номером постороннего. grep по src не находит ни одного фильтра demo: или isDemo: демо-пациенты участвуют в аналитике, сегментах, реактивации и напоминаниях наравне с реальными.

G2-25 РЗ · НИЗКИЙ целостность данных

Ротация и бэкфилл шифрования перезаписывают строки по id без проверки версии и теряют параллельные правки; ошибки батчей не отражаются в коде выхода

ГДЕ

scripts/rotate-encryption-key.ts:125, scripts/rotate-encryption-key.ts:175, scripts/encrypt-existing-pii.ts:118, src/server/workers/voice-soap.ts:144, scripts/rotate-encryption-key.ts:283

СЦЕНАРИЙ

Во время плановой ротации врач диктует SOAP, воркер сохраняет черновик, и через долю секунды скрипт возвращает поле к версии до диктовки. Врач видит, что текст пропал.

ПОСЛЕДСТВИЯ

Тихая потеря свежих правок медицинского текста или паспортных данных. Частичный сбой ротации остаётся незамеченным для автоматизации.

ЧТО СДЕЛАТЬ

Писать через updateMany({ where: { id, <поле>: <прочитанное значение> } }) и учитывать строки с count=0 как конфликт для повторной обработки. При errors>0 завершать процесс с ненулевым кодом.

КРИТЕРИЙ ПРИЁМКИ

Тест: параллельная запись между чтением и записью скрипта сохраняет новое значение. При ошибке батча exit code не равен 0.

ДОКАЗАТЕЛЬСТВО В КОДЕ

rotate-encryption-key.ts читает батч по 200 строк (101-107), перешифровывает в памяти и пишет patient.update({ where: { id }, data: rest }) (125-133) без условия на старое значение. Так же устроены medicalCase.soapDraft (175-182) и prescription.notes, а encrypt-existing-pii (118-126, 167-174) и encrypt-auth-secrets (138-146) повторяют ту же схему. Runbook называет ротацию zero-downtime, то есть её гоняют при работающем приложении. Если между чтением и записью ресепшн сохранит notes через PATCH /api/crm/patients/[id] (route.ts:73) или voice-soap воркер запишет новый soapDraft (voice-soap.ts:144), скрипт перезапишет это значение перешифрованной старой версией. Ошибки батча только увеличивают stats.errors, а main завершается кодом 0 (283-288).

G2-26 РЗ · НИЗКИЙ мокап / заглушка

Сиды и stress-скрипты путают единицы денег: цены 2 000 сум, LTV VIP 30–100 тыс. сум, долги по 500 сум

ГДЕ

scripts/total-stress-seed.ts:56, scripts/total-stress-seed.ts:83, scripts/seed-mega-neurofax.ts:275, scripts/seed-mega-neurofax.ts:277, scripts/stress-cases-scenarios.ts:117

СЦЕНАРИЙ

Владельцу на демо показывают сегмент VIP: «LTV 45 000 сум», а рядом визиты по 300 000. В stress-данных МРТ стоит 8 000 сум.

ПОСЛЕДСТВИЯ

Демо и стресс-данные показывают абсурдные KPI и маскируют настоящие ошибки единиц в UI.

ЧТО СДЕЛАТЬ

Использовать в сздах хелпер SUM(uzs) и вычислять ltv и balance из созданных оплат.

КРИТЕРИЙ ПРИЁМКИ

В сздах нет денежных литералов без SUM(); у демо-пациентов LTV равен сумме их оплат.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Деньги хранятся в тийинах (formatMoney делит на 100, seed-neurofax-real использует $SUM(x)=x*100$). total-stress-seed.ts:56-60 задаёт priceBase 200_000, 800_000 и 350_000, то есть «Консультация невролога 2 000 сум» и «МРТ 8 000 сум», а pricePerVisit 200_000 (83-84) даёт 2 000 сум. seed-mega-neurofax.ts:275 ставит ltv VIP 3_000_000 + rand(7_000_000) тийинов (30-100 тыс. сум) при 8-28 визитах по 200-300 тыс. сум, причём LTV не связан с созданными оплатами. 277: balance от -50_000 до -250_000 тийинов (долги 500-2 500 сум). stress-cases-scenarios.ts:117/130 и stress-reminders-scenarios:72 делают то же самое.

G3 · Сквозная матрица «мутация → событие → SSE → обновление экрана» на всех поверхностях

G3-01 P2 · СРЕДНИЙ мёртвая механика

«Я на месте» из мини-аппа: отметка нигде в CRM не отображается, кроме 4-секундного тоста на странице ресепшена, а свипер потом ставит пациенту «Не явился»

ГДЕ

src/app/api/miniapp/appointments/[id]/checkin/route.ts:108, src/app/[locale]/crm/reception/_hooks/use-reception-live.ts:417, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:65, src/server/workers/appointment-lifecycle-sweep.ts:69, src/server/workers/appointment-lifecycle-sweep.ts:91, src/app/c/[slug]/my/_messages/ru.ts:68

СЦЕНАРИЙ

Пациентка пришла на запись 14:00, нажала в мини-аппе «Я на месте» и села в холле, потому что приложение пообещало «вас встретят». Регистратор в этот момент был на странице «Записи» или отошёл, тост мигнул 4 секунды на другой вкладке, либо не появился вовсе. В карточке и списке никаких признаков, что пациентка пришла, нет, в очередь врача её не ставят. В 15:30 воркер ставит «Не явился» и отправляет ей сообщение о неявке.

ПОСЛЕДСТВИЯ

Пациент ждёт в холле впустую и получает оскорбительное сообщение о неявке. Функция, которую клиника рекламирует пациентам, для персонала фактически невидима.

ЧТО СДЕЛАТЬ

Отдавать arrivedAt в CRM API записей и показывать постоянный бейдж «Отметился в приложении» в списке ресепшена, в панели очереди и в карточке записи до нажатия «Пришёл». Уведомление держать до подтверждения, а не 4 секунды. Слушать patient.arrived глобально (layout CRM), а не только на странице ресепшена. Свипер не должен ставить NO_SHOW записи с arrivedAt ≠ null: вместо этого создавать задачу ресепшену.

КРИТЕРИЙ ПРИЁМКИ

Пациент нажимает «Я на месте». На любой странице CRM регистратор видит постоянное уведомление, а в списке ресепшена бейдж у записи, пока не нажмёт «Пришёл». Если никто не отреагировал, через 60 минут после конца слота запись не становится NO_SHOW и пациент не получает сообщение о неявке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Чек-ин ставит только Appointment.arrivedAt и публикует patient.arrived (checkin/route.ts:106-113). В кодовой базе arrivedAt читают только мини-апп (use-appointments.ts:21, home-hero.tsx:334-346); ни один CRM- или doctor-экран и ни одно CRM API его не показывают. Единственная реакция персонала — тост sonner (по умолчанию около 4 с) в useReceptionRealtime (use-reception-live.ts:417-429), который смонтирован только на странице ресепшена (reception-page-client.tsx:65). Инвалидация списков по patient.arrived (use-reception-live.ts:393-395) ничего не меняет, потому что arrivedAt не рендерится. Авто-NO_SHOW свипер берёт BOOKED/CONFIRMED с endDate старше 60 минут и не проверяет arrivedAt (appointment-lifecycle-sweep.ts:69-82, 91-100), ставит NO_SHOW и шлёт пациенту уведомление о неявке (fireTrigger appointment.no-show). Пациенту при этом показано «Вы отметились — вас встретят» (_messages/ru.ts:68).

G3-02 P2 · СРЕДНИЙ баг

Аллергия, внесённая медсестрой или в CRM, не доходит до открытого экрана приёма: CDS продолжает показывать зелёное «Конфликтов нет»

ГДЕ

src/app/api/crm/patients/[id]/allergies/route.ts:49, src/app/api/crm/patients/[id]/allergies/[allergyId]/route.ts:30, src/server/realtime/events.ts:40, src/app/[locale]/doctor/reception/_hooks/use-cds-drug-check.ts:64, src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:152, src/app/[locale]/doctor/reception/_hooks/use-patient-history.ts:52, src/components/providers/query-provider.tsx:31, src/app/api/crm/patients/[id]/diagnoses/route.ts:43, src/app/[locale]/doctor/reception/_hooks/use-patient-diagnoses.ts:24

СЦЕНАРИЙ

Врач открыл приём пациента, выбрал амоксициллин; CDS проверил и показал зелёную плашку «Конфликтов нет». Пациент в это время говорит медсестре, что у него была анафилаксия на пенициллин, медсестра вносит аллергию SEVERE в карточку в CRM. У врача экран не меняется, плашка остаётся зелёной, он подписывает

заключение с амоксициллином. Обратный случай: врач записал аллергию через быструю кнопку в CDS, а у медсестры на карточке пациента вкладка «Медицина» её не показывает до перезагрузки.

ПОСЛЕДСТВИЯ

Врач принимает клиническое решение по устаревшей проверке безопасности, которая при этом выглядит как свежая («Конфликтов нет»). Это прямой риск назначить противопоказанный препарат. Страдает пациент, ответственность ложится на клинику.

ЧТО СДЕЛАТЬ

Ввести доменное событие изменения медкарты (например `patient.medicalRecordChanged` с `patientId` и видом: `allergy/diagnosis/chronic`) и опубликовать его через `publishViaOutbox` в одной транзакции с записью во всех `POST/PATCH/DELETE` этих роутов (`tenantScope.patientId`). На экране приёма врача подписаться на это событие и инвалидировать `["cds-drug-check", patientId]`, `patientDiagnosesKey(patientId)` и ключи сводки пациента; в CRM инвалидировать `["patient", id, "allergies"]` `["diagnoses"]` `["chronic"]`. Дополнительно перед подписанием (`flushDraftEdits/finalize`) принудительно перезапустить CDS-проверку.

КРИТЕРИЙ ПРИЁМКИ

Врач держит открытым приём с назначенным амоксициллином. В другом браузере медсестра добавляет аллергию «пенициллин, SEVERE». Не позже чем через 2 секунды у врача, без перезагрузки и без правки назначений, зелёная плашка сменяется красным предупреждением ALLERGY. Удаление аллергии так же снимает предупреждение. Вкладка «Медицина» в CRM сразу показывает аллергию, записанную врачом из CDS.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`POST/PATCH/DELETE` аллергий (`allergies/route.ts:49-79`, `[allergyId]/route.ts:30-79`), диагнозов (`diagnoses/route.ts:43-66`, `[diagnosisId]/route.ts:29-72`) и хронических болезней (`chronic-conditions/route.ts:40-62`, `[conditionId]/route.ts:26-68`) пишут в БД и `audit()`, но не публикуют ни одного события, и в `EVENT_TYPES` (`events.ts:40-124`) вообще нет типа для изменения медкарты. CDS на экране приёма: `useCdsDrugCheck` (`use-cds-drug-check.ts:64-80`) с ключом `["cds-drug-check", patientId, diagnosisCode, prescriptions, drugIds]`, `staleTime` 30 с, без `refetchInterval`; в `QueryProvider` `refetchOnWindowFocus/refetchOnReconnect = false` (`query-provider.tsx:31-32`). Сервер читает аллергии заново только при запросе (`server/cds/drug-check.ts:247` `prisma.patientAllergy.findMany`). Единственная инвалидация `["cds-drug-check"]` происходит в `onSuccess` локальной мутации врача `useRecordAllergy` (`use-patient-history.ts:52-55`). Итог: пока врач не меняет список назначений (ключ не меняется), карточка `CdsWarningsCard` продолжает рендерить ветку `warnings.length === 0` с «`cds.noConflicts`» (`cds-warnings-card.tsx:152-160`). Аллергии на экране приёма больше нигде не показываются. Аналогично «История диагнозов» (`use-patient-diagnoses.ts:24-28`, `staleTime` 60 с) и вкладка «Медицина» в CRM (`["patient", id, "allergies"]`, `use-patient-medical.ts:61`) не узнают об изменениях, сделанных на другой поверхности.

G3-03 P2 · СРЕДНИЙ целостность данных

Исправление заключения (amendment) нигде не транслируется: события нет, экран визита в мини-аппе всегда показывает исходный диагноз и рекомендации

ГДЕ

`src/app/api/crm/visit-notes/[id]/amendments/route.ts:102`, `src/app/api/miniapp/visit-summary/[appointmentId]/route.ts:39`, `src/server/workers/visit-note-handout.ts:195`, `src/server/workers/visit-note-handout.ts:246`

СЦЕНАРИЙ

Через 2 дня после приёма врач обнаруживает ошибку в дозировке в рекомендациях и добавляет исправление. Пациент открывает в мини-аппе экран визита и продолжает читать старую рекомендацию с неверной дозой. Об исправлении ему никто не сообщает, оно есть только внутри PDF в разделе «Документы».

ПОСЛЕДСТВИЯ

Пациент следует ошибочным рекомендациям, хотя врач их исправил. Медико-юридически исправление формально выдано, но до пациента не доходит.

ЧТО СДЕЛАТЬ

Публиковать через `outbox` событие `visit-note.amended` (`patientId`, `appointmentId`, `visitNoteId`) и добавить его в `MINIAPP_DELIVERABLE_TYPES` и в карту инвалидации (`["miniapp", "visit-summary"]`, `["miniapp", "appointments"]`). В `visit-summary` API отдавать `amendments` и показывать их блоком «Исправления» под исходным текстом. Отправлять пациенту уведомление «Врач внёс исправление в заключение».

КРИТЕРИЙ ПРИЁМКИ

Врач добавляет исправление к заключению старше 24 часов. На открытом экране визита в мини-аппе в течение нескольких секунд появляется блок «Исправления» с текстом и датой, пациент получает Telegram-уведомление, в CRM на карточке визита видно исправление.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST amendments создаёт VisitNoteAmendment и ставит handoutStateAt (route.ts:102-122), затем только audit() (124-129). События нет, пациенту ничего не отправляется. Экран визита в мини-аппе берёт из VisitNote только diagnosisName и patientHandoutMarkdown (visit-summary route.ts:39-76), amendments не выбираются и не отдаются; в src/app/api/miniapp и src/app/c слово 'amendment' не встречается вовсе. Исправление попадает только в перерендеренный PDF (buildPdfAmendments, visit-note-handout.ts:195), после чего воркер шлёт document.created (246-266), а мини-апп на него обновляет лишь список «Документы». Экран визита, на котором пациент читает рекомендации, исправление не покажет никогда. (Отличие от #37: там история визитов у врача, здесь поверхность пациента и отсутствие события.)

G3-04 РЗ · НИЗКИЙ мёртвая механика

Аллергии и лекарства из анкеты перед визитом не доходят ни до врача, ни до CDS; событие previsit.submitted у персонала никто не слушает

ГДЕ

src/app/api/miniapp/pre-visit/[appointmentId]/route.ts:154, src/app/api/crm/doctors/me/today/route.ts:286, src/server/cds/drug-check.ts:247, src/app/c/[slug]/my/_hooks/use-miniapp-live-events.tsx:99, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:343

СЦЕНАРИЙ

Пациент заполнил анкету: «аллергия на карбамазепин, принимаю варфарин». На приёме врач этого не видит ни на «Мой день», ни на экране приёма, CDS не предупреждает о взаимодействии. Сейчас сценарий редкий: приглашение к анкете не отправляется (#250), но экран /my/pre-visit существует и данные принимаются.

ПОСЛЕДСТВИЯ

Медицински значимые сведения от пациента теряются по дороге к врачу, функция анкеты бессмысленна даже после починки рассылки.

ЧТО СДЕЛАТЬ

Показывать заполненную анкету на карточке текущего пациента и на экране приёма. При отправке анкеты предлагать врачу или медсестре перенести аллергии в PatientAllergy (или создавать их со статусом «со слов пациента» для CDS). Подписать кабинет врача на previsit.submitted.

КРИТЕРИЙ ПРИЁМКИ

Пациент отправляет анкету с аллергией. Через 2 секунды на «Мой день» и на экране приёма врача видна плашка «Анкета заполнена» с аллергиями и лекарствами, а CDS учитывает заявленную аллергию (или видна кнопка её подтверждения).

ДОКАЗАТЕЛЬСТВО В КОДЕ

Анкета сохраняет complaints/allergies/medications только JSON-ом в Appointment.preVisitData (pre-visit route.ts:147-160) и публикует previsit.submitted (161-189). В payload описано: «Cabinet view uses this to show 'пациент заполнил' tile». Единственный потребитель события — мини-апп (use-miniapp-live-events.tsx:99-102), в CRM и кабинете врача подписчиков нет. Кабинет врача берёт жалобы только из Appointment.comments или Patient.notes (doctors/me/today/route.ts:283-292), preVisitData в src/app/[locale]/doctor не читается. CDS проверяет только таблицу PatientAllergy (drug-check.ts:247). Анкету видит лишь регистратор в карточке записи (appointment-drawer.tsx:343-350).

G3-05 РЗ · НИЗКИЙ целостность данных

Дыры в аудите мутаций: перенос записи пациентом из мини-аппа, привязка случая, walk-in и чек-ин с киоска не попадают в журнал аудита

ГДЕ

src/app/api/miniapp/appointments/[id]/route.ts:202, src/server/realtime/envelope.ts:141, src/server/workers/outbox-pumper.ts:133, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:40, src/app/api/c/[slug]/queue/walkin/route.ts:42, src/server/appointments/walkin.ts:242, src/app/api/c/[slug]/queue/checkin/route.ts:113

СЦЕНАРИЙ

Пациент жалуется: «я записывался на 10:00, а меня перенесли на 16:00 к другому врачу». В журнале аудита нет ни одной записи о том, что перенос сделал сам пациент из мини-аппа. Анонимно созданные с киоска визиты (в том числе спам, #67) и выданные талоны по журналу не отследить.

ПОСЛЕДСТВИЯ

Нельзя разобрать спор с пациентом и найти источник изменения записи и цены. Медико-юридический след и расследование злоупотреблений публичными эндпоинтами невозможны.

ЧТО СДЕЛАТЬ

В мини-апп РАТЧН эмитить appointment.moved (при смене даты или врача) либо сделать appointment.updated auditable для surface=MINIAPP; в attach-case писать аудит (лучше через outbox-событие). В публичных walkin/checkin записывать AuditLog с actorLabel вида kiosk:<slug>/ip и перевести их события на publishViaOutbox в транзакции.

КРИТЕРИЙ ПРИЁМКИ

После переноса записи из мини-аппа, привязки случая пациентом, walk-in с киоска и чек-ина с киоска в /crm/settings/audit видна отдельная запись по каждому действию с актором (patient:<id> / kiosk) и старым и новым значением.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Аудит через outbox пишется, только если тип auditable (outbox-pumper.ts:131-134, getEventMeta). В EVENT_META_OVERRIDES аудируются appointment.created/statusChanged/cancelled/moved, а appointment.updated нет (envelope.ts:141-146). Перенос из мини-аппа (дата, врач, услуги и перезапись priceFinal = priceBase) эмитит именно appointment.updated и queue.updated (miniapp appointments/[id]/route.ts:196-227), прямого audit() в файле нет (grep 'audit' находит только комментарий в строке 10). TZ §7.5 требует для переноса auditable appointment.moved. attach-case в мини-аппе вообще без аудита и события (route.ts:40-106). Публичный walk-in с киоска вызывает registerWalkin (walkin/route.ts:42-59), у которого по контракту «The caller owns the audit row» (walkin.ts:17), но роут audit() не вызывает, а события уходят через publishEventSafe в обход outbox (walkin.ts:242-258). Публичный чек-ин меняет статус BOOKED→WAITING и выдаёт талон (checkin/route.ts:85-121) тоже без аудита.

G3-06 РЗ · НИЗКИЙ баг

Изменение назначений после подписи (правка в 24 ч, откат визита) не публикует prescription.updated: открытый экран «Лекарства» в мини-аппе показывает отменённый препарат и старую дозу

ГДЕ

src/server/workers/visit-note-handout.ts:566, src/server/workers/visit-note-handout.ts:613, src/app/api/crm/appointments/[id]/route.ts:256, src/app/api/crm/visit-notes/[id]/route.ts:236, src/app/api/miniapp/events/route.ts:89

СЦЕНАРИЙ

Врач в пределах 24 часов убирает из назначений препарат, который вызвал реакцию. У пациента в мини-аппе открыт экран «Лекарства»: препарат и кнопка «Принял» остаются, пока пациент не свернёт и не развернёт приложение. На экране визита по-прежнему старый диагноз.

ПОСЛЕДСТВИЯ

Пациент может принять уже отменённый препарат по экрану, который выглядит актуальным (живая точка «live» горит). Ограничено тем, что при возврате в приложение данные перечитываются.

ЧТО СДЕЛАТЬ

В реконсильаторе публиковать prescription.updated (status/deleted) для каждого обновлённого, реактивированного и отменённого курса. В откате визита публиковать prescription.updated для курсов с отключёнными напоминаниями и событие о снятии подписи заключения. Правку подписанной заметки сопровождать доставляемым пациенту событием (например visit-note.updated), которое инвалидирует ["miniapp","visit-summary"] и ["miniapp","appointments"].

КРИТЕРИЙ ПРИЁМКИ

Экран «Лекарства» открыт в мини-аппе. Врач удаляет препарат в окне 24 ч или откатывает визит. Через время одного прохода воркера (около 30 с) препарат исчезает с экрана без сворачивания приложения, а экран визита показывает исправленный диагноз.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Реконсильатор bridgeNote публикует prescription.created только для новых строк (if (!existing), visit-note-handout.ts:566-600). Обновлённые курсы (новая доза или расписание), реактивированные курсы (upsert update) и отменённые (updateMany → CANCELLED, 613-620) меняются молча. Откат визита выключает remindersEnabled у всех курсов заметки и переводит заключение в DRAFT (appointments/[id]/route.ts:236-266) без prescription.updated и без события по заключению. Правка подписанной заметки в 24-часовом окне публикует только visit-note.draftSaved (visit-notes/[id]/route.ts:236-260), а этот тип отсутствует в MINIAPP_DELIVERABLE_TYPES (miniapp/events/route.ts:89-115) и в карте мини-аппа. Мини-апп слушает prescription.updated → ["miniapp","medications"] (use-miniapp-live-events.tsx:106-108), но его здесь никто не шлёт.

Карточка «Заключение готово» и кнопка PDF в мини-аппе не появляются вживую: document.created инвалидирует не тот ключ

ГДЕ

src/app/c/[slug]/my/_hooks/use-miniapp-live-events.tsx:128, src/app/c/[slug]/my/_hooks/use-miniapp-live-events.tsx:115, src/server/workers/visit-note-handout.ts:246, src/app/api/miniapp/visit-summary/[appointmentId]/route.ts:86, src/app/c/[slug]/my/_components/home-hero.tsx:728

СЦЕНАРИЙ

Пациент после приёма ждёт в мини-аппе. Врач подписал заключение, экран визита обновился, но кнопки «Скачать заключение» нет. Карточка «Заключение готово» на главной не появляется, пока пациент не свернёт и не развернёт приложение.

ПОСЛЕДСТВИЯ

Пациент думает, что заключения нет, и обращается на ресепшен. Обещанная «живая» доставка заключения не работает.

ЧТО СДЕЛАТЬ

В MINIAPP_INVALIDATION_MAP для document.created добавить ["miniapp", "appointments"] и ["miniapp", "visit-summary"] (или делать это только для documentType=CONCLUSION).

КРИТЕРИЙ ПРИЁМКИ

Мини-апп открыт на главной. Врач подписывает заключение. После рендера PDF (до 30 с) без действий пациента появляется карточка «Заключение готово», а на экране визита кнопка PDF.

ДОКАЗАТЕЛЬСТВО В КОДЕ

conclusionUrl в ответах мини-аппа строится из VisitNote.conclusionDocument (visit-summary route.ts:86-89, miniapp appointments/route.ts:108-116). Этот Document создаёт воркер handout спустя до 30 с после подписи (sweep раз в 30 с, workers/start.ts:104) и тогда публикует document.created (visit-note-handout.ts:246-266). В карте мини-аппа document.created → только ["miniapp", "documents"] (use-miniapp-live-events.tsx:128). visit-note.finalized инвалидирует appointments и visit-summary (115-118), но приходит раньше, чем PDF появился. Карточка «Заключение готово» на главной требует a.conclusionUrl (home-hero.tsx:728-737), поэтому без ручного обновления не появляется. TZ §7.3 требует, чтобы карточка визита получала conclusionUrl вживую.

Мини-апп attach-case перепривязывает любую запись пациента, включая завершённые и уже привязанные врачом, к другому случаю, неатомарно и без следа

ГДЕ

src/app/api/miniapp/appointments/[id]/attach-case/route.ts:45, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:70, src/app/api/miniapp/appointments/[id]/attach-case/route.ts:101

СЦЕНАРИЙ

Пациент (или любой клиент с его initData) отправляет attach-case для прошлого завершённого визита с caseId другого открытого случая. Визит из курса лечения, который вёл врач, переезжает в другой случай. У врача в карточке случая пропадает визит, и в журнале ничего нет.

ПОСЛЕДСТВИЯ

Пациент может менять клиническую группировку своих визитов, врач теряет историю курса. Возможны пустые случаи-сироты.

ЧТО СДЕЛАТЬ

Разрешать attach-case только для будущих записей в статусах BOOKED/CONFIRMED и только если medicalCaseId ещё null. Выполнять create+update в одной транзакции, писать аудит и публиковать событие (см. находку о привязке случаев).

КРИТЕРИЙ ПРИЁМКИ

attach-case для COMPLETED-записи или для записи с уже заданным medicalCaseId возвращает 409. Ошибка на втором шаге не оставляет пустого случая. Каждая привязка видна в журнале аудита.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Запись ищется только по id/clinicId/patientId (route.ts:45-53), статус не проверяется. Выбранный appt.medicalCaseId никак не используется, существующая привязка молча перезаписывается (81-84, 101-104). Ветка create делает medicalCase.create и appointment.update двумя отдельными запросами без транзакции (70-84): при сбое второго остаётся пустой случай. Нет audit(), нет события, нет пересчёта цены (последнее уже

в #268). UI зовёт роут только сразу после бронирования, но API открыт для любого id записи пациента.

G3-09 РЗ · НИЗКИЙ бар

Мини-апп не получает события подтверждения записи и авто-неявки: у них нет patientId, серверный фильтр их отбрасывает

ГДЕ

src/server/appointments/confirm.ts:201, src/server/workers/appointment-lifecycle-sweep.ts:155, src/app/api/miniapp/events/route.ts:134, src/app/api/miniapp/events/route.ts:174

СЦЕНАРИЙ

Пациент стоит у стойки с открытым мини-аппом, регистратор подтверждает запись по телефону. В мини-аппе статус остаётся «Записан/не подтверждено». Или запись ушла в «Не явился», а на экране пациента это всё ещё предстоящая запись с кнопкой «Я на месте».

ПОСЛЕДСТВИЯ

Мини-апп показывает устаревший статус собственной записи при заявленной живой синхронизации. Исправляется только сворачиванием приложения.

ЧТО СДЕЛАТЬ

В confirmAppointment добавить patientId в tenantScope и payload обоих envelope. В свипере добавить patientId в payload (выбирать его в select) и перевести публикацию на outbox.

КРИТЕРИЙ ПРИЁМКИ

При открытом мини-аппе регистратор подтверждает запись, а свипер переводит другую запись в NO_SHOW. В обоих случаях статус на экране пациента меняется в течение 2 секунд без сворачивания.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В confirmAppointment tenantScope = { clinicId, doctorId, appointmentId } без patientId, в payload queue.updated и appointment.statusChanged patientId тоже нет (confirm.ts:201-244). shouldDeliverToMiniApp пропускает v2-событие, только если tenantScope.patientId или payload.patientId входит в allow-set пациента (miniapp/events/route.ts:134-147), поэтому подтверждения из CRM, TG-кнопки, входящего звонка и центра действий до мини-аппа не доходят. Авто-NO_SHOW свипер публикует v1 appointment.statusChanged без patientId (appointment-lifecycle-sweep.ts:155-163), а shouldDeliverV1ToMiniApp требует payload.patientId (174-175). Индикатор «live» в мини-аппе при этом горит.

G3-10 РЗ · НИЗКИЙ бар

Открытая карточка записи (drawer) в ресепшене, календаре и «Записях» никогда не обновляется по SSE: статус, время и цена остаются на момент открытия

ГДЕ

src/app/[locale]/crm/appointments/_hooks/use-appointment.ts:97, src/app/[locale]/crm/appointments/_hooks/use-appointments-list.ts:199, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:130, src/app/[locale]/crm/appointments/_components/appointment-drawer.tsx:590, src/app/[locale]/crm/reception/_components/reception-page-client.tsx:361, src/components/providers/query-provider.tsx:31

СЦЕНАРИЙ

Регистратор открыл карточку записи пациента, чтобы принять оплату. В это время пациент отменил запись в Telegram (или врач начал и завершил приём, или врач привязал визит к случаю с бесплатным повтором). Карточка по-прежнему показывает «Записан» и полную цену. Регистратор жмёт «Пришёл» и получает 409 с непонятной ошибкой, либо переносит отменённую запись (сервер не проверяет статус при переносе, #100), либо берёт деньги по старой цене.

ПОСЛЕДСТВИЯ

Регистратура действует по устаревшим данным в самой частой рабочей форме: ложные ошибки, лишние действия с отменёнными записями, неверные суммы к оплате.

ЧТО СДЕЛАТЬ

В общих realtime-подписках (useAppointmentsRealtime, useReceptionRealtime, useCalendarRealtime) или в самом useAppointment инвалидировать ["appointment", payload.appointmentId] на appointment.*, queue.updated и visit-note.finalized. Альтернатива: подписка внутри drawer, пока он открыт.

КРИТЕРИЙ ПРИЁМКИ

В одном браузере открыта карточка записи. Из мини-аппа пациент отменяет запись, в другом окне врач меняет статус или привязывает визит к случаю. Не позже чем через 2 секунды карточка показывает новый статус, время и «Итого» без закрытия и повторного открытия.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Карточка записи читает useAppointment(id) с ключом ["appointment", id], staleTime 15 с (use-appointment.ts:97-113). Ни один SSE-подписчик этот ключ не инвалидирует: useAppointmentsRealtime инвалидирует только ["appointments", "list"] (use-appointments-list.ts:199-213), ресепшен только ["reception", ...] (use-reception-live.ts:385-406), календарь только ["calendar", "appointments"] (use-calendar-data.ts:115-125). ["appointment"] инвалидирует только собственная мутация сотрудника (invalidateAppointmentSurfaces, use-appointment.ts:83-95). Фокус-рефетч выключен (query-provider.tsx:31-32). Drawer монтируется на ресепшене (reception-page-client.tsx:361), в календаре (calendar-page-client.tsx:197) и в «Записях». Кнопки действий и «Итого» строятся из устаревшего appt.status/appt.priceFinal (appointment-drawer.tsx:377, 444, 590, 654).

G3-11 P3 · НИЗКИЙ баг

Подтверждение записи закрывает задачу «К подтверждению» в БД без события: у операторов виджет и центр действий показывают уже подтвердивших, а «Риск на сегодня» не слушает отмены и смену статуса

ГДЕ

src/server/appointments/confirm.ts:162, src/server/appointments/confirm.ts:265, src/app/[locale]/crm/call-center/_hooks/use-unconfirmed.ts:67, src/app/[locale]/crm/action-center/_hooks/use-risk-today.ts:52, src/app/api/telegram/webhook/[clinicSlug]/route.ts:572

СЦЕНАРИЙ

Утром пациент нажимает «✓ Подтверждаю» в Telegram-напоминании. Администратор в колл-центре по-прежнему видит его в «К подтверждению» и звонит, пациент раздражён. В «Риск на сегодня» строка отменившего пациента висит до минуты и тоже попадает в обзвон.

ПОСЛЕДСТВИЯ

Лишние звонки уже подтвердившим и отменившим пациентам, недоверие к спискам задач, потерянное время операторов.

ЧТО СДЕЛАТЬ

В closeOpenConfirmActions (или после неё в той же транзакции) публиковать action.updated через outbox по каждой закрытой задаче (id, type, severity), тот же приём использовать в других доменных закрытиях задач. В useRiskToday добавить в events appointment.statusChanged, appointment.cancelled, appointment.moved и queue.updated. Виджету «К подтверждению» добавить подписку на appointment.statusChanged/cancelled как страховку.

КРИТЕРИЙ ПРИЁМКИ

Открыт виджет «К подтверждению» и секция «Риск на сегодня». Пациент подтверждает запись кнопкой в Telegram, другой пациент отменяет в мини-аппе. Через 2 секунды обе строки исчезают у всех операторов без перезагрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

confirmAppointment в транзакции вызывает closeOpenConfirmActions (confirm.ts:162-167), а та делает tx.action.updateMany → status DONE (265-300). Публикуются только queue.updated и appointment.statusChanged (201-244); action.updated не публикуется. Идемпотентная ветка тоже закрывает задачи молча (117-129). Виджет «К подтверждению» (use-unconfirmed.ts:32-62) без refetchInterval и инвалидируется только на action.created/action.updated (67-70); центр действий тоже только на action.* (use-actions.ts:109-112). «Риск на сегодня» (use-risk-today.ts:52-60) слушает только appointment.created и appointment.updated. Подтверждение (statusChanged), отмена (cancelled) и перенос (moved) его не трогают, остаётся 60-секундный поллинг. Путь TG-кнопки «Подтверждаю» идёт через confirmAppointment (telegram webhook route.ts:572).

G3-12 P3 · НИЗКИЙ баг

При переводе записи к другому врачу у прежнего врача «Мой день», расписание и табло у двери не обновляются: событие несёт только нового врача

ГДЕ

src/server/appointments/emit-change.ts:79, src/app/api/crm/appointments/[id]/route.ts:545, src/app/api/crm/appointments/[id]/route.ts:782, src/app/[locale]/doctor/my-day/_hooks/use-doctor-today.ts:135, src/app/[locale]/doctor/my-day/_hooks/use-doctor-schedule.ts:64, src/hooks/use-doctor-board.ts:146, src/app/[locale]/crm/calendar/_components/calendar-view.tsx:287, src/app/api/miniapp/appointments/[id]/route.ts:202

СЦЕНАРИЙ

Администратор в календаре перетаскивает запись пациента от невролога А к неврологу Б, потому что А задерживается. У Б запись появляется сразу. У А на «Мой день» пациент остаётся в очереди и в карточке

«Следующая запись» до первого события по его собственным записям. А нажимает «Вызвать», получает 403 и общий тост «не удалось вызвать». На табло у двери кабинета А пациент ещё до 25 секунд висит в списке ожидающих.

ПОСЛЕДСТВИЯ

Врач видит в своей очереди чужого пациента, тратит время на вызов, пациента могут звать в два кабинета. Табло у двери вводит пациентов в заблуждение.

ЧТО СДЕЛАТЬ

В `emitAppointmentChangeViaOutbox` передавать полный `before` (как минимум `doctorId`) и при смене врача добавлять в `payload` `previousDoctorId` (или эмитить второй `envelope` для прежнего врача). То же сделать в мини-апп `PATCH`. Расширить `eventTargetsDoctor` и фильтр `use-doctor-board` так, чтобы событие считалось своим, если `doctorId` или `previousDoctorId` совпадает с врачом.

КРИТЕРИЙ ПРИЁМКИ

Открыты «Мой день» врача А и табло у двери кабинета А. Администратор переводит `WAITING`-пациента от А к Б через календарь или карточку записи. Не позже чем через 2 секунды пациент исчезает из очереди, расписания и табло врача А и появляется у Б, без перезагрузки. Перенос с врачом из мини-аппа даёт тот же результат.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`emitAppointmentChangeViaOutbox` получает `before` только как `Pick<Appointment, "status" | "queueStatus">` (`emit-change.ts:30-31`), а в `payload` и `tenantScope` кладёт только `after.doctorId` (`emit-change.ts:66-88`). В `PATCH /appointments/[id]` смена `doctorId` считается `timeChanged` (`route.ts:545-549`), поэтому эмитится `appointment.moved` (`route.ts:782-807`) с `doctorId` НОВОГО врача, прежний врач нигде не упоминается. Мини-апп при смене врача эмитит `appointment.updated/queue.updated` тоже только с `after.doctorId` (`miniapp appointments/[id]/route.ts:196-226`). Потребители у врача фильтруют по своему `id`: `eventTargetsDoctor` возвращает `payloadDoctorId === doctorId` (`use-doctor-today.ts:135-145`), так инвалидируются «Мой день» (`use-doctor-today.ts:194-198`) и расписание дня (`use-doctor-schedule.ts:64-68`). У «Мой день» нет `refetchInterval` (`staleTime 15 c`, `use-doctor-today.ts:161-175`), фокус-рефетч выключен. Табло у двери кабинета отбрасывает события чужого врача (`use-doctor-board.ts:144-146`), обновляется только поллингом раз в 25 с. Сценарий частый: перетаскивание в календаре между колонками врачей шлёт `doctorId` (`calendar-view.tsx:284-288`).

G3-13 РЗ · НИЗКИЙ бар

Привязка и отвязка визита к случаю (CRM и мини-апп) пересчитывает цены нескольких записей, но не публикует ни одного события: у других сотрудников и у пациента старая цена

ГДЕ

`src/app/api/crm/cases/[id]/attach-appointment/route.ts:68`, `src/app/api/crm/cases/[id]/attach-appointment/route.ts:117`, `src/app/api/crm/cases/[id]/detach-appointment/route.ts:59`, `src/app/api/miniapp/appointments/[id]/attach-case/route.ts:81`, `src/app/[locale]/crm/appointments/_components/case-selector-dialog.tsx:219`, `src/app/[locale]/crm/appointments/_components/appointments-table.tsx:414`, `src/app/c/[slug]/my/_components/appointments/appointments-screen.tsx:215`

СЦЕНАРИЙ

Врач в кабинете привязывает сегодняшний повторный визит к открытому случаю, срабатывает бесплатный повтор, `priceFinal` становится 0. На ресепшене у регистратора в «Записях» и в карточке записи висит полная цена, и он берёт с пациента полную сумму. При отвязке наоборот: цена выросла, а на экране ноль. В мини-аппе пациент видит старую цену.

ПОСЛЕДСТВИЯ

Прямые денежные ошибки на кассе (переплата или недоплата), конфликт с пациентом, расхождение кассы с начислениями.

ЧТО СДЕЛАТЬ

В `attach/detach` (CRM) и `miniapp attach-case` публиковать через `outbox` в той же транзакции `appointment.updated` для каждой записи, у которой пересчиталась цена или сменился случай (с `patientId` и `doctorId` в `tenantScope`), либо отдельное событие `medical-case.appointmentsChanged`, которое потребители маптят на `appointment-ключи`.

КРИТЕРИЙ ПРИЁМКИ

Открыты «Записи» у регистратора и мини-апп пациента. Врач привязывает визит к случаю, и срабатывает бесплатный повтор. Через 2 секунды без перезагрузки у регистратора и в мини-аппе видна новая цена. То же при отвязке.

ДОКАЗАТЕЛЬСТВО В КОДЕ

attach-appointment в транзакции меняет medicalCaseId и вызывает recomputeAppointmentPrice для самой записи и всех соседей по старому и новому случаю (route.ts:68-94), после чего пишет только audit() (117-141), без publishViaOutbox/publishEventSafe. detach-appointment делает то же (59-74, 97-118). Мини-апп attach-case меняет medicalCaseId (81-84, 101-104) тоже без события. Инвалидация только локальная, в браузере того, кто кликнул (case-selector-dialog.tsx:219-240, use-case.ts:224-229). Цена priceFinal показывается в таблице «Записи» (appointments-table.tsx:414), в «Итого» карточки записи (appointment-drawer.tsx:444), в правой панели календаря (calendar-right-rail.tsx:88), в карточке случая и в мини-аппе (appointments-screen.tsx:215). Всё это обновляется только при appointment.*, которого здесь нет.

G3-14 P3 · НИЗКИЙ бар

Событие notification.sent для канала INAPP молча отбрасывается CRM-клиентом: схема payload не знает INAPP

ГДЕ

src/server/realtime/events.ts:280, src/server/notifications/record-delivery.ts:136, src/server/workers/notifications-send.ts:186, src/hooks/use-live-events.ts:48, src/app/[locale]/crm/notifications/_hooks/use-queue.ts:66

СЦЕНАРИЙ

Администратор запускает рассылку во внутренний инбокс мини-аппа (INAPP) и смотрит «Уведомления» в CRM. Отправленные строки не меняют статус до ближайшего 60-секундного поллинга.

ПОСЛЕДСТВИЯ

Экран уведомлений отстаёт, счётчики не живые. Заодно это пример расхождения схемы: любое v2-событие с полем вне v1-схемы тихо теряется для всей CRM.

ЧТО СДЕЛАТЬ

Добавить "INAPP" в NotificationPayload.channel. В publishViaOutbox дополнительно валидировать payload по AppEventSchema для данного type, чтобы такие расхождения падали на вызове, а не терялись в браузере.

КРИТЕРИЙ ПРИЁМКИ

При доставке INAPP-уведомления экран «Уведомления» в CRM обновляется в течение 2 секунд. Юнит-тест: parseLiveEvent(v2 envelope notification.sent с channel INAPP) возвращает событие, а не null.

ДОКАЗАТЕЛЬСТВО В КОДЕ

NotificationPayload.channel = z.enum(["SMS", "TG", "EMAIL", "CALL", "VISIT"]) (events.ts:277-280), а NotificationSend.channel может быть INAPP. Доставка INAPP вызывает recordNotificationDelivery с channel "INAPP" (notifications-send.ts:173-196), и в payload уходит channel: input.send.channel (record-delivery.ts:134-137). publishViaOutbox проверяет только конверт (payload: z.unknown()), строка уходит в шину. На CRM-клиенте parseLiveEvent после распознавания v2 повторно валидирует payload против AppEventSchema и возвращает null (use-live-events.ts:48-58), поэтому useNotificationsRealtime (use-queue.ts:66-71) это событие не получает. Мини-апп проверяет только конверт, у него всё работает.

G4 · Клинические справочные данные и реальное покрытие CDS (риск ложного «всё безопасно»)

G4-01 P1 · ВЫСОКИЙ целостность данных

В базе взаимодействий CDS всего 43 пары на 28 препаратов и ни одной на 78 неврологических и психиатрических препаратов: на противопоказанных сочетаниях врач видит зелёное «Конфликтов не найдено»

ГДЕ

prisma/_drug-interactions-data.ts:19, prisma/seed-drug-interactions.ts:23, src/server/cds/drug-check.ts:255, src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:151, prisma/_drug-data.ts:1039, prisma/_protocol-data.ts:770

СЦЕНАРИЙ

Невролог назначает при нейропатической боли «Трамадол 50 мг» и «Амитриптилин 25 мг» (риск серотонинового синдрома и судорог). Эпилептологу добавляет «Ламотриджин 25 мг» к «Депакин хроно» (вальпроат удваивает концентрацию ламотриджина, растёт риск синдрома Стивенса–Джонсона). Пациенту с болью в спине и циститом назначены «Сирдалуд 4 мг» и «Ципрофлоксацин 500 мг» (противопоказано). Во всех трёх случаях под назначениями горит зелёное «Конфликтов не найдено · распознано: 2».

ПОСЛЕДСТВИЯ

Врач получает ложное подтверждение безопасности как раз на профильных для клиники сочетаниях. Риски: тяжёлые побочные реакции, кровотечения, серотониновый синдром, гипотония. Подсистема, которая выглядит как защита, для неврологии фактически пустая.

ЧТО СДЕЛАТЬ

Расширить курируемую базу пар под неврологию и психиатрию с участием клинического фармаколога: противосудорожные, антидепрессанты, опиоиды, бензодиазепины, триптаны, миорелаксанты, антикоагулянты. Ввести правила на уровне классов и АТС-групп (например, «СИОЗС/СИОЗСН + трамадол/триптаны», «любой НПВС + антикоагулянт»), чтобы покрывать и препараты из реестра. Дать админу клиники интерфейс для добавления пар. Заменить формулировку зелёной плашки: писать, по скольким препаратам данные о взаимодействиях есть и по каким их нет, вместо безусловного «Конфликтов не найдено».

КРИТЕРИЙ ПРИЁМКИ

На тестовом визите сочетания трамадол + амитриптилин, вальпроат + ламотриджин, тизанидин + ципрофлоксацин, силденафил + нитроглицерин и лизиноприл + спиронолактон дают красные или оранжевые предупреждения. Для препарата без данных о взаимодействиях карточка явно пишет «нет данных о взаимодействиях» и не показывает «Конфликтов не найдено».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Массив DRUG_INTERACTIONS в _drug-interactions-data.ts:19-346 содержит 43 записи (grep -c '^ a: ' = 43). Они ссылаются на 28 id: aspirin, aspirin_cardio, atorvastatin, azithromycin, berodual, bisoprolol, captopril, ciprofloxacin, clarithromycin, clopidogrel, dexamethasone, diclofenac, domperidone, enalapril, furosemide, ibuprofen, indapamide, iron_sorbifer, ketorolac, levofloxacin, lisinopril, losartan, metoclopramide, nimesulide, omeprazole, pantoprazole, prednisolone, salbutamol. В статическом каталоге 265 препаратов (_drug-catalog.ts + _drug-catalog-extra.ts), из них 78 с категорией NEUROLOGICAL/PSYCHIATRIC, и ни один не входит ни в одну пару. Таблицу DrugInteraction пишет только seed-drug-interactions.ts:23-44 (deleteMany + create). В src нет ни одного писателя: grep по drugInteraction находит только чтение в drug-check.ts:255. Движок берёт взаимодействия только из этой таблицы (drug-check.ts:255-265). DUPLICATE_CLASS (333-352) ловит лишь одинаковый 5-значный префикс АТС. Если предупреждений нет, карточка рисует зелёную плашку t('cds.noConflicts') = «Конфликтов не найдено» с «распознано: N» (cds-warnings-card.tsx:151-166). Собственные данные каталога противоречат этому. У тизанидина в противопоказаниях указано «Совместный приём с флувоксамином или ципрофлоксацином» (_drug-data.ts:1039), у силденафила «Совместный приём нитратов» (1860), у спиронолактона «Совместный приём калийсберегающих средств» (1749). Пар для этих сочетаний нет. Протокол ХСН сам назначает лизиноприл вместе со спиронолактоном (_protocol-data.ts:770-772), и CDS на нём показывает «Конфликтов не найдено». Для сочетаний вальпроат + ламотриджин, трамадол + сертралин/эсциталопрам/венлафаксин/дулоксетин/амитриптилин, варфарин + НПВС/аспирин/амиодарон/метронидазол/флуконазол, диазепам/феназепам + трамадол/прегабалин/габапентин, метоклопрамид + леводопа, карбамазепин + кларитромицин оба препарата есть в каталоге, но пары нет, и АТС-группы у них разные.

G4-02 P1 · ВЫСОКИЙ бар

Проверка аллергии сравнивает подстроки: аллергия на «пенициллин» или «Амоксициллин» не срабатывает на Амоксиклав и ампициллин, а пищевая аллергия на «мед» блокирует Сумамед, варфарин и десятки других препаратов

ГДЕ

src/server/cds/drug-check.ts:280, src/server/cds/drug-check.ts:247, prisma/_drug-catalog.ts:100, src/app/c/[slug]/my/_messages/ru.ts:341, src/app/api/miniapp/pre-visit/[appointmentId]/route.ts:152

СЦЕНАРИЙ

В карточке пациента записана аллергия «Амоксициллин (крапивница)». Невролог при присоединившемся синусите добавляет «Амоксиклав 625 мг». CDS показывает зелёное «Конфликтов не найдено». У другой пациентки записана аллергия на мёд («мед»), и при назначении «Сумамеда» или «Варфарина» появляется красное «Аллергия: мед — Не назначать».

ПОСЛЕДСТВИЯ

Риск анафилаксии при назначении препарата с тем же действующим веществом или того же класса, хотя система «проверила». Одновременно ложные тревоги приучают врача нажимать «Я учёл», не читая.

ЧТО СДЕЛАТЬ

Сопоставлять аллергию по действующим веществам (МНН в одном алфавите, компоненты комбинаций) и по классам через АТС и таблицу перекрёстной реактивности: пенициллины (J01C), цефалоспорины, сульфаниламиды, НПВС и аспирин, местные анестетики, йод/контраст. Сравнивать по границам слов, а не подстрокой, и не сопоставлять аллерген с брендами длиной 3–4 символа. При записи аллергии давать выбрать вещество или класс из справочника. Подтягивать в CDS аллергии и текущие лекарства из анкеты перед визитом.

КРИТЕРИЙ ПРИЁМКИ

Аллергия «пенициллин» даёт предупреждение на амоксициллин, Амоксиклав, ампициллин и сультамициллин. Аллергия «Амоксициллин» даёт предупреждение на Амоксиклав. Аллергия «аспирин» или «НПВС» даёт предупреждение на ибупрофен и диклофенак. Аллергия «мед» не даёт предупреждения на азитромицин и варфарин.

ДОКАЗАТЕЛЬСТВО В КОДЕ

drug-check.ts:271-307 проверяет аллергию только двусторонним includes по нормализованным строкам: inn.includes(sub) || sub.includes(inn) || nameRu.includes(sub) || sub.includes(nameRu) || любой бренд includes(sub)/sub.includes(бренд). Классов, групп АТС и перекрёстных реакций нет. У Амоксиклава nameRu «Амоксиклав», intl «Amoxicillin + Clavulanate», бренды «Аугментин», «Флемоклав» (_drug-catalog.ts:100-103). Поэтому аллергия, записанная по-русски как «Амоксициллин», не совпадает ни с одним полем. Проверка алгоритма на статическом каталоге и на симуляции БД после импорта реестра (Python-копия normaliseToken и match) дала такие результаты. «пенициллин» не совпадает ни с amoxicillin, ни с amoxiclav, ampicillin, sultamicillin. «Амоксициллин» совпадает только с amoxicillin, зато после импорта ложно срабатывает на моксифлоксацин, потому что бренд реестра «Мокси» является подстрокой слова «амоксиксиллин». «аспирин» не совпадает с ibuprofen, diclofenac, ketorolac. «НПВС», «цефалоспорины», «сульфаниламиды» не совпадают ни с чем. Обратная сторона: «мед» уже в курируемом каталоге совпадает с azithromycin (бренд «Сумамед»), warfarin, thiocolchicoside («Мускомед»), itopride («Итомед»), trimebutine («Тримедат»). После импорта таких препаратов 82, в том числе ceftriaxone («Медаксон®») и ketorolac («МЕДРОЛГИН»). Мини-приложение само предлагает пациенту вписывать классы: «Например: пенициллин, орехи» (ru.ts:341). Аллергии из анкеты перед визитом сохраняются в preVisitData.allergies (pre-visit route.ts:152), но CDS читает только таблицу patientAllergy (drug-check.ts:247-250).

G4-03 P2 · СРЕДНИЙ мёртвая механика

CDS проверяет только назначения текущего визита: текущая терапия пациента (активные курсы, лекарства из анкеты), хронические диагнозы и противопоказания из карточки препарата не учитываются

ГДЕ

src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:81, src/server/cds/drug-check.ts:246, prisma/schema.prisma:3055, prisma/_drug-data.ts:428, prisma/_drug-data.ts:1014

СЦЕНАРИЙ

Пациент на варфарине от кардиолога, курс заведён прошлым визитом в этой же клинике, приходит к неврологу

с болью в спине. Невролог назначает «Кеторолак». Проверка не знает о варфарине. Пациенту с диагнозом визита G40 (эпилепсия) назначен метоклопрамид, пациенту после ТИА (G45) суматриптан, и предупреждений нет.

ПОСЛЕДСТВИЯ

Самые опасные взаимодействия возникают между новым назначением и уже принимаемыми лекарствами, а именно их система не видит.

ЧТО СДЕЛАТЬ

Включить в проверку активные курсы пациента (с учётом окончания курса, см. проблему с незавершающимися Prescription), лекарства из анкеты перед визитом и хронические состояния. Ввести структурированные противопоказания по префиксам МКБ-10 и сверять их с диагнозом визита и хроническими диагнозами.

КРИТЕРИЙ ПРИЁМКИ

Если у пациента есть активный курс варфарина, назначение кеторолака на новом визите даёт предупреждение. Метоклопрамид при диагнозе G40 и суматриптан при G45/I63 дают предупреждение о противопоказании.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Входы CDS берутся только из `note.visitPrescriptions` и `note.prescriptions` текущей заметки (`structured-fields-panel.tsx:81-99`). `drug-check.ts:246-266` запрашивает только аллергии, пол и дату рождения, пары. Активные курсы из модели Prescription (`status 'ACTIVE'`, `schema.prisma:3055-3090`, туда при подписи переносятся назначения прошлых визитов), `preVisitData.medications`, `PatientChronicCondition` и текстовые `Drug.contraindications` не читаются. Проверка «диагноз—препарат» есть только как `riskDiagnoses` у 6 пар. При этом каталог содержит противопоказания, которые движок мог бы проверять по коду диагноза визита: у метоклопрамида «Эпилепсия» (`_drug-data.ts:428`), у суматриптана «Цереброваскулярные нарушения (инсульт/ТИА)» и «ИБС» (1010-1014), у трамадола «Неконтролируемая эпилепсия».

G4-04 P2 · СРЕДНИЙ мёртвая механика

Библиотека памяток — мёртвая функция: врачу негде вставить ни 17 глобальных памяток, ни памятки клиники (выбор в приёме удалён), а среди глобальных нет ни одной неврологической

ГДЕ

`src/app/[locale]/doctor/reception/_hooks/use-handouts.ts:44`, `src/messages/ru.json:6418`, `prisma/_handout-ata.ts:32`, `prisma/_handout-data.ts:370`

СЦЕНАРИЙ

Админ клиники пишет в настройках памятку «Мигрень: что делать при приступе». Невролог на приёме нигде её не видит и не может добавить пациенту, вкладка «Памятка пациенту» собирается только из полей визита.

ПОСЛЕДСТВИЯ

Админ тратит время на контент, который не доходит до пациента, а раздел настроек создаёт впечатление работающей функции.

ЧТО СДЕЛАТЬ

Вернуть в приёме выбор памяток (поиск, фильтр по диагнозу, вставка в памятку) или убрать вкладку «Памятки» из настроек. Добавить неврологические памятки: мигрень, эпилепсия (первая помощь при приступе), боль в спине, инсульт/ТИА, головокружение, бессонница. Подставлять телефон клиники вместо «___».

КРИТЕРИЙ ПРИЁМКИ

Врач на приёме может найти памятку клиники по диагнозу G43 и вставить её в памятку пациента. В памятке пациенту нет строк с «___».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Хук `useHandouts` (`use-handouts.ts:44`) нигде не вызывается: `grep` по `useHandouts`(и `use-handouts` в `src` находит только определение. Компонента диалога нет, хотя `i18n`-ключи `doctor.receptionDialogs.handout` («Библиотека памяток», «Подберите готовый блок для пациента и вставьте в памятку», `ru.json:6418-6419`) остались. `/api/crm/catalogs/handouts` читает только экран настроек (`handouts-tab.tsx:74`), где админ создаёт и редактирует «памятки вашей клиники» (`ru.json:4250`). Автоматическая памятка (`handout-composer`) `HandoutTemplate` не использует. В `_handout-data.ts` `matchPrefixes` охватывают только I10–I15, E10–E14, J00–J11, J45, K21, K25–K27, D50–D53, E03, I50 (строки 32–287). Для G43, G40, G44, M54, G47, F41, H81 памяток нет. В шаблонах есть незаполненные места: «Телефон клиники: ___» (370), «через ___ дней» и «Открыт с ___ по ___» для больничного, выдачу которого уже убрали.

G4-05 P2 · СРЕДНИЙ UX

В карточке CDS не видно, к какому препарату относится предупреждение об аллергии или «одном классе», а одинаковые заголовки склеиваются: «Я учёл» гасит сразу несколько предупреждений

ГДЕ

src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:97, src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:454, src/server/cds/drug-check.ts:299, src/server/cds/drug-check.ts:346

СЦЕНАРИЙ

У пациента аллергия «мед». В назначениях «Сумамед» и «Медаксон». Врач видит две одинаковые красные строки «Аллергия: мед. Не назначать» без названия препарата. Нажимает «Я учёл» на одной, исчезают обе. При ламотриджине, леветирацетаме и топирамате видны три одинаковых «Один класс ATC: N03AX», и непонятно, о какой паре речь.

ПОСЛЕДСТВИЯ

Врач не может понять, какой препарат убрать. Подтверждение одного риска молча закрывает другой, а журнал отказов теряет записи.

ЧТО СДЕЛАТЬ

Показывать в строке предупреждения drugA/drugB (название из назначения). Включить id препаратов в warningKey и React key. Сохранять отказ по каждому предупреждению отдельно.

КРИТЕРИЙ ПРИЁМКИ

Каждое предупреждение об аллергии и о классе называет препарат или пару. Подтверждение одного предупреждения не меняет остальные. В консоли нет предупреждений о дубликатах key.

ДОКАЗАТЕЛЬСТВО В КОДЕ

WarningRow выводит только warning.title и warning.detail (cds-warnings-card.tsx:454-458), поля drugA/drugB не показываются. У ALLERGY заголовок `Аллергия: \${allergy.substance}` и описание «Зафиксирована аллергия. Не назначать.» (drug-check.ts:299-302), препарат не назван. У DUPLICATE_CLASS заголовок `Один класс ATC: \${aPrefix}` и общее описание (346-347), препараты тоже не названы. warningKey = `\${kind}:\${severity}:\${title}` (cds-warnings-card.tsx:97-100) используется и как React key (188-190), и как ключ набора acknowledged. Если одна аллергия совпала с двумя препаратами или в одном классе три препарата (три пары), ключи совпадают: React получает дубликаты key, а подтверждение одной строки зачёркивает все, и сохраняется одна CdsOverride.

G4-06 P2 · СРЕДНИЙ целостность данных

В поле «Как принимать» подставляется справочный текст дозирования для врача («Старт..., титровать до...», «Депрессия: ...; нейропатическая боль: ...»), и он уходит пациенту в памятку и печать, хотя в свёрнутой строке назначения его не видно

ГДЕ

src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:103, prisma/_drug-data.ts:916, src/app/api/crm/visit-notes/[id]/finalize/route.ts:111, src/app/api/crm/visit-notes/[id]/print/route.ts:127, src/lib/catalogs/prescription-format.ts:126

СЦЕНАРИЙ

Невролог выбирает в каталоге «Амитриптилин 10 мг» на ночь при головной боли напряжения и подписывает визит. Пациент получает в Telegram и на бумаге: «Амитриптилин — 10 мг. Депрессия: 25–75 мг/сут с повышением; нейропатическая боль: 10–25 мг на ночь». Для «Карбамазепина» пациент читает «титровать до 400–1200 мг/сут» и начинает сам повышать дозу.

ПОСЛЕДСТВИЯ

Пациент получает противоречивые указания с диапазонами доз и чужими диагнозами. Возможны самостоятельное повышение дозы и отказ от лечения («у меня не депрессия»). Документ при этом выглядит так, будто его подписал врач.

ЧТО СДЕЛАТЬ

Не заполнять инструкцию пациенту из defaultDosing. Держать отдельное поле «памятка для пациента» простым языком без диапазонов, или оставлять инструкцию пустой и показывать справку врачу подсказкой. Если автоподстановка остаётся, показывать инструкцию в свёрнутой строке и учитывать возраст пациента (pediatric/elderly).

КРИТЕРИЙ ПРИЁМКИ

После выбора карбамазепина, амитриптилина или топирамата в памятке и печати нет слов «Старт», «титровать», «Депрессия:», «Эпилепсия:», если врач сам их не написал. Любой текст, который уйдёт пациенту, виден в свёрнутой строке назначения.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`draftFromDrug` (`prescription-constructor.tsx:89-106`) ставит `instructionRu = d.defaultDosing?.adult, a timesOfDay = []`. Тексты `adult` в `_drug-data.ts` написаны как справка для врача. Примеры: `valproate` «Старт 10–15 мг/кг/сут, поддержание 1000–2000 мг/сут в 2 приёма» (916), `carbamazepine` «Старт 100–200 мг 1–2 раза в день, титровать до 400–1200 мг/сут», `topiramate` «Эпилепсия: 200–400 мг/сут; профилактика мигрени: 50–100 мг/сут...», `amitriptyline` «Депрессия: 25–75 мг/сут с повышением; нейропатическая боль: 10–25 мг на ночь», `rivaroxaban` «Фибрилляция предсердий: ...; ТГВ/ТЭЛА: ...», `valacyclovir` «Herpes labialis: ...», `warfarin` «...подбор по МНО». Такой формы (Старт/титр/«Диагноз:»/в/в) примерно 60 из 156. `finalize` (`route.ts:109-114`) собирает памятку через `formatPrescriptionLines(..., { withInstruction: true })`, печать делает то же (`print/route.ts:1127-1131`). `prescription-format.ts:126-133` дописывает инструкцию к строке. Свёрнутая строка конструктора показывает `formatPrescriptionLine(row, locale)` без инструкции. Строка, добавленная из ящика каталога (`structured-fields-panel.tsx:110-118`), не раскрывается, поэтому врач не видит, что пойдёт пациенту. Для детей и пожилых всё равно берётся `adult`: поля `pediatric` и `elderly` не используются.

G4-07 P2 · СРЕДНИЙ целостность данных

Дозой по умолчанию становится первая «доза» каталога, а это часто концентрация или упаковка («100 ЕД/мл» для инсулина, «667 мг/мл», «5%», «1 флакон», «1мл» из реестра). Форму выбрать нельзя: цитиколин всегда уходит как инъекция, ацикловир как крем

ГДЕ

`src/app/[locale]/doctor/reception/_components/prescription-constructor.tsx:89`, `prisma/_drug-catalog.ts:845`, `prisma/_drug-catalog-extra.ts:840`, `src/lib/catalogs/prescription-format.ts:86`, `scripts/import-uzpharm-registry.ts:160`

СЦЕНАРИЙ

Эндокринологического больного ведёт невролог и добавляет «Инсулин гларгин» из каталога, не раскрывая строку. В памятке пациенту: «Инсулин гларгин — 100 ЕД/мл, вечером». Цитиколин внутрь (раствор 100 мг/мл) печатается с концентрацией инъекционной ампулы.

ПОСЛЕДСТВИЯ

Неверная или опасно двусмысленная доза в документе для пациента и аптеки. Для инсулина цифра «100 ЕД» может быть прочитана как доза.

ЧТО СДЕЛАТЬ

Разделить в каталоге дозировку (концентрацию или упаковку) и типовую разовую дозу. В строке назначения дать выбор формы и дозировки. Не подставлять концентрацию в «Дозу» для жидких, инъекционных и наружных форм: оставлять поле пустым и требовать ввод. При импорте нормализовать дозировки: пробелы, запятая, дубли, отдельно объём упаковки.

КРИТЕРИЙ ПРИЁМКИ

При добавлении инсулина, лактулозы или витамина D3 поле «Доза» пустое и обязательно. Для цитиколина можно выбрать `DROPS_ORAL`. В списке дозировок реестра нет пар вида «200 мг»/«200мг».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`draftFromDrug` (`prescription-constructor.tsx:89-99`) берёт `firstForm = d.forms[0]`, `strength = firstForm.strengths[0]` и `dose = strength ?? '1'`. Выбора формы или дозировки в строке конструктора нет: `grep` по `strength/form` находит только эти присваивания. Первая «доза» каталога часто не является дозой. Примеры: `insulin-glargine` и `insulin-aspart` «100 ЕД/мл» (`_drug-catalog-extra.ts:840`), `lactulose SYRUP` «667 мг/мл», `vitamin_d3` «500 МЕ/капля», `cyancobalamin` «500 мкг/мл», `otipax` «1 флакон», `levomekol` «1 туба 40 г», `bepanten/acyclovir/clotrimazole CREAM` «5%»/«1%». У `citicoline` первая форма `INJ_IV` «500 мг/4 мл» (`_drug-catalog.ts:845`), у `acyclovir` первая форма `CREAM` (672), у `gentamicin INJ_IM`, у `betamethasone CREAM`. Всего так у 30 курируемых препаратов. `prescription-format.ts:86-88` выводит `strength` в заголовке, если доза отличается. Врач меняет дозу на «10 мл» и получает «Цитиколин 500 мг/4 мл — 10 мл». Реестр пишет `forms` как есть (`import-uzpharm-registry.ts:160`): в 546 из 3296 записей форм есть дубли вида «200 мг»/«200мг», в 592 десятичная точка («24.0 мг/мл»), в 388 список дозировок пустой. Упаковки смешаны с концентрациями: у глюкозамина `INJ_IM` первая дозировка «1мл».

Импорт госреестра заводит отдельные строки для уже известных веществ (Тромбо АСС, КЛОСАРТ, КАРБАЛЕКС, «Диклофенак натрия», комбинации с НПВС и ИАПФ): у них нет ни пар взаимодействий, ни категории беременности, ни противопоказаний

ГДЕ

scripts/import-uzpharm-registry.ts:91, scripts/import-uzpharm-registry.ts:153, src/server/cds/drug-check.ts:258, src/server/cds/drug-check.ts:360

СЦЕНАРИЙ

При люмбалгии невролог находит в поиске популярный «Диоксафлекс В12» (бетаметазон + диклофенак) и добавляет «Мелоксикам» или «Ибупрофен». Предупреждения о суммировании НПВС и сочетании со стероидом нет. Пациентке 28 лет назначен «Карбалекс®» из реестра: предупреждения о беременности (категория D) нет, хотя при выборе «Карбамазепина» оно появляется. «Тромбо АСС» вместе с «Кеторолаком» тоже проходит без предупреждения, хотя пара аспирин + кеторолак помечена MAJOR.

ПОСЛЕДСТВИЯ

Одно и то же вещество получает или не получает проверку в зависимости от того, какую карточку врач выбрал в поиске. Большинство торговых названий, с которыми приходят пациенты, остаются без защиты.

ЧТО СДЕЛАТЬ

В импорте сопоставлять по АТС и нормализованному МНН. Торговые названия того же вещества прикреплять брендами к курируемой строке, а не создавать новые Drug. Для комбинаций хранить компоненты (ссылки на Drug компонентов), а в CDS раскладывать комбинацию на компоненты для проверки пар, аллергий и беременности. Для оставшихся строк реестра наследовать категорию беременности и правила взаимодействий по АТС.

КРИТЕРИЙ ПРИЁМКИ

После импорта «Тромбо АСС», «КЛОСАРТ» и «КАРБАЛЕКС» либо являются брендами курируемых строк, либо дают те же предупреждения CDS, что и курируемые аналоги. Сочетание «Диоксафлекс В12» + «Ибупрофен» даёт предупреждение о суммировании НПВС.

ДОКАЗАТЕЛЬСТВО В КОДЕ

import-uzpharm-registry.ts:91-103 ищет «дом» для сущности реестра только по norm(e.nameRu), e.id и названиям брендов. INN (e.inn = «uzr:...») и АТС не используются. Всё, что не совпало, создаётся новой строкой Drug (153-163) только с полями id/inn/nameRu/atcCode/category/forms/rxOnly. pregnancyCat остаётся по умолчанию UNKNOWN, contraindications пустые, пар DrugInteraction нет. Офлайн-симуляция импорта по prisma/uzpharm-registry.json (2705 сущностей) поверх статического каталога дала примерно 2420 новых строк. Из них 160 имеют тот же 7-значный АТС, что и курируемый препарат. Среди них: B01AC06 (aspirin_cardio): «Тромбо АСС», «КОКСОР», «Атромб», «Кардиомид», «АТРОМБО», «ПАСКАРД®», «АЦЕКАРД®», «АСК», «Тромбопол®» и другие, всего 13; N02BA01 (aspirin): «Ацетилсалициловая кислота-УБФ», «...-REMEDY», «АЛКА-ЗЕЛЬТЦЕР®»; C09CA01: «КЛОСАРТ®»; N03AF01 (категория D): «КАРБАЛЕКС®». Строка «диклофенак натрия» (бренд Диклофорд) пришла с atcCode = null. Ещё 72 новые строки являются комбинациями с веществами из пар: «Диклофенак + парацетамол», «Бетаметазон + гидрокобаламин + диклофенак» (РОДИНАК В12, ДИОКСАФЛЕКС В12), «Диклофенак + пиридоксин + цианокобаламин» (КЛОДИФЕН НЕЙРО), «Амлодипин + лозартан», «Индапамид + лизиноприл», «Гидрохлортиазид + эналаприл». Пары ищутся строго по id (drug-check.ts:255-265), беременность проверяется только для D/X (360), поэтому на этих строках движок молчит.

Пересев пресетов (seed-presets.ts и SQL-вариант для прода) стирает все пресеты, которые врачи-неврологи и кардиологи создали сами, во всех клиниках

ГДЕ

prisma/seed-presets.ts:45, prisma/seed-presets-sql.ts:48

СЦЕНАРИЙ

Невролог за месяц настроил 30 своих кнопок-шаблонов жалоб и назначений. Разработчик обновляет набор пресетов для новой клиники и запускает SQL-скрипт. У всех неврологов всех клиник пропадают их пресеты, остаётся стандартный набор.

ПОСЛЕДСТВИЯ

Потеря рабочих шаблонов врачей и межклиничное вмешательство одним скриптом.

ЧТО СДЕЛАТЬ

Добавить в DoctorPreset признак источника (seed/user) и удалять только посеянные строки. Ограничить скрипт конкретной клиникой или врачом.

КРИТЕРИЙ ПРИЁМКИ

После повторного запуска сида пресеты, созданные врачом через настройки, остаются. Пресеты другой клиники не меняются.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-presets.ts:34-47 выбирает врачей всех клиник по specializationRu contains «невролог»/«кардиолог» и делает doctorPreset.deleteMany({ where: { clinicId, doctorId } }), удаляя все пресеты врача, а не только посеянные.

seed-presets-sql.ts:48-51 генерирует для прода DELETE FROM "DoctorPreset" WHERE "doctorId" IN (SELECT id FROM "Doctor" WHERE "specializationRu" ILIKE '%невролог%'). В самой модели пресета нет признака «системный», а врачи создают свои пресеты через /api/crm/doctors/me/presets.

G4-10 P2 · СРЕДНИЙ целостность данных

Повторный запуск seed-drugs.ts после импорта госреестра удаляет около 1800 торговых названий, прикреплённых к курируемым препаратам

ГДЕ

prisma/seed-drugs.ts:81, scripts/import-uzpharm-registry.ts:105

СЦЕНАРИЙ

Разработчик добавляет в статический каталог новый препарат и перезапускает seed-drugs.ts. Врач больше не находит в поиске «Мезакар» и «Берлиприл». CDS перестаёт распознавать эти названия в текстовых строках, а аллергия, записанная на бренд, перестаёт совпадать.

ПОСЛЕДСТВИЯ

Справочник тихо деградирует после рутинной операции, а поиск по брендам (основной способ поиска врачами) ломается.

ЧТО СДЕЛАТЬ

В seed-drugs удалять только бренды, которых нет в источнике и которые не пришли из реестра (добавить в DrugBrand поле source), либо делать upsert брендов без wholesale-удаления.

КРИТЕРИЙ ПРИЁМКИ

После последовательности «импорт → seed-drugs» количество DrugBrand у карбамазепина и кеторолака не уменьшается.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-drugs.ts:79-86 для каждого курируемого препарата выполняет drugBrand.deleteMany({ where: { drugId: d.id } }) и заново создаёт бренды только из статического файла. В комментарии это обосновано так: «Brands are catalog-only... replacing them wholesale keeps the list in step with the source file». Импорт реестра, наоборот, дописывает торговые названия именно к курируемым строкам (import-uzpharm-registry.ts:105-119: «matched existing drugs (brand-enriched only)»). По симуляции на payload это 1788 брендов у 198 курируемых препаратов: у карбамазепина «МЕЗАКАР® SR», «Карбамазепин-ФС», у кеторолака 23 бренда, у эналаприла «ЭНАП®», «БЕРЛИПРИЛ®» и т.д. Нигде не описано, что после seed-drugs нужно заново запустить импорт.

G4-11 P2 · СРЕДНИЙ целостность данных

Повторный запуск seed-protocols.ts удаляет личные протоколы врачей и протоколы клиники с теми же кодами МКБ, а скрытые клиникой глобальные протоколы снова появляются

ГДЕ

prisma/seed-protocols.ts:22, src/app/api/crm/protocols/route.ts:65, src/app/api/crm/catalogs/protocols/route.ts:71

СЦЕНАРИЙ

Невролог сохранил личный протокол «M54 — люмбоишиалгия» с назначениями и контрольным визитом. После обновления стандартов пересевом его протокол бесследно исчезает. Протокол «ОРВИ», который админ скрыл, снова появляется у врачей.

ПОСЛЕДСТВИЯ

Безвозвратно теряются клинические шаблоны, которые врачи создавали сами, а настройки клиники тихо сбрасываются.

ЧТО СДЕЛАТЬ

Удалять и обновлять только глобальные строки (clinicId IS NULL AND doctorId IS NULL). Ввести стабильный код протокола и делать upsert по нему. Хранить скрытие по коду, а не по cuid.

КРИТЕРИЙ ПРИЁМКИ

После повторного запуска seed-protocols.ts личные и клинические протоколы с префиксом M54 на месте, скрытые клиникой глобальные протоколы остаются скрытыми.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-protocols.ts:21-24 выполняет prisma.clinicalProtocol.deleteMany({ where: { diagnosisCodePrefix: { in: prefixes } } }) без фильтра clinicId: null и doctorId: null. Среди этих кодов G43, M54, F41, G47.0, I10 и другие, всего 20. В ту же таблицу пишутся протоколы клиники (ADMIN) и личные протоколы врача «сохранить приём как протокол» (protocols/route.ts:65-86, clinicId и doctorId заполнены). Глобальные протоколы пересоздаются с новыми cuid, а скрытие у клиники хранится по id (catalogs/protocols/route.ts:71-76: «overlay rows key by `id` (cuid)»), поэтому после пересева скрытие перестаёт работать. Заголовок сида ссылается на несуществующий seed-protocols-sql.ts.

G4-12 P2 · СРЕДНИЙ баг

Проверка «Один класс АТС» даёт ложные тревоги на стандартной политерапии (ламотриджин + леветирацетам, пирацетам + цитиколин) и пропускает реальные дубли (два бензодиазепина, один и тот же НПВС двумя строками, комбинации с тем же веществом)

ГДЕ

src/server/cds/drug-check.ts:338, src/server/cds/drug-check.ts:186, prisma/_drug-data.ts:1346, src/server/cds/drug-check.ts:346

СЦЕНАРИЙ

Эпилептолог ведёт пациента на ламотриджине с леветирацетамом и каждый визит видит жёлтое «Один класс АТС: N03AX». Он привыкает нажимать «Я учёл» и пропускает настоящую проблему: пациенту параллельно выписан «Нурофен» к уже назначенному «Ибупрофену», и об этом CDS молчит.

ПОСЛЕДСТВИЯ

Усталость от предупреждений на рациональной терапии и пропуск реальных двойных назначений.

ЧТО СДЕЛАТЬ

Для групп с X в конце кода (N03AX, N06BX, N07XX, M01AX и др.) сравнивать полный 7-значный код или вести курируемый список «настоящих» классов. Исправить АТС феназепама на N05BA. Проставить АТС препаратам из extra-каталога. Для комбинаций сравнивать компоненты. Если одно вещество встречается в нескольких строках, выдавать отдельное предупреждение «одно вещество назначено дважды».

КРИТЕРИЙ ПРИЁМКИ

Ламотриджин + леветирацетам не дают предупреждения, феназепам + диазепам дают. Строки «Ибупрофен 400 мг» + «Нурофен 200 мг» дают предупреждение о двойном назначении. «Лозартан» + «Гидрохлоротиазид + лозартан» дают предупреждение.

ДОКАЗАТЕЛЬСТВО В КОДЕ

DUPLICATE_CLASS сравнивает atcCode.slice(0, 5) (drug-check.ts:338-340) и всегда выдаёт MODERATE «Проверьте необходимость дублирования». Группы с X в конце кода (разнородное «прочее») дают ложные срабатывания. N03AX объединяет ламотриджин, леветирацетам, топирамат, габапентин и прегабалин, и типичная противоэпилептическая политерапия помечается дублем. N06BX объединяет пирацетам, цитиколин, винпоцетин и фенибут. Аминалон из реестра (N03AG) попадает в один класс с вальпроатом. Одновременно реальные дубли не ловятся. У феназепама atcCode указан как N05BX (_drug-data.ts:1346), а это бензодиазепин (N05BA), поэтому феназепам + диазепам не дают предупреждения, а феназепам + афобазол дают. У 109 препаратов из _drug-catalog-extra АТС нет: флуоксетин + пароксетин, клоназепам + диазепам, эзомерпазол + омепразол не проверяются. Комбинации имеют другой код (M01AB55, C09DA), поэтому «Гидрохлоротиазид + лозартан» + «Лозартан» не определяются. Две строки с одним веществом («Ибупрофен» из каталога + «Нурофен 200 мг» текстом) схлопываются дедупликацией по id (186-191, 228-238), и о двойной дозе не сообщается вообще.

G4-13 P2 · СРЕДНИЙ целостность данных

Проверка беременности молча пропускает около 95% каталога: у 124 курируемых и у всех препаратов реестра категория UNKNOWN (симвастатин, периндоприл, телмисартан, фенитоин, пароксетин, клоназепам, метотрексат, изотретиноин), а у пациенток без указанного пола проверка вообще не запускается

ГДЕ

src/server/cds/drug-check.ts:356, src/server/cds/drug-check.ts:360, prisma/seed-drugs.ts:67, prisma/_drug-catalog-extra.ts:13, src/server/appointments/walkin.ts:126, src/app/api/miniapp/auth/route.ts:90

СЦЕНАРИЙ

Пациентка 30 лет записалась через Telegram, пол в карточке не указан. Невролог назначает «Престариум» (периндоприл) и «Симвастатин», позже «Делакин». Ни одного предупреждения о беременности нет, хотя при «Аторвастатине» для пациентки с указанным полом CDS показывает красное «Категория X».

ПОСЛЕДСТВИЯ

Врач доверяет проверке, которая для большинства препаратов и для основных каналов поступления пациентов не выполняется. Есть риск назначить тератоген женщине детородного возраста.

ЧТО СДЕЛАТЬ

Заполнить категории (или современные метки PLLR/«противопоказан при беременности») для курируемых препаратов и по АТС для реестра, с проверкой фармацевтом. Если категория UNKNOWN или пол/возраст пациента неизвестен, показывать в карточке CDS явное «проверка беременности не выполнена» вместо зелёного статуса. Собирать пол при регистрации в мини-приложении и в живой очереди. Разрешить клинике переопределять категорию беременности.

КРИТЕРИЙ ПРИЁМКИ

Для женщины 18–45 лет симвастатин, периндоприл, фенитоин и метотрексат дают предупреждение о беременности. Для пациентки с незаполненным полом карточка CDS пишет, что проверка беременности не выполнена, и не показывает «Конфликтов не найдено».

ДОКАЗАТЕЛЬСТВО В КОДЕ

drug-check.ts:356-373 выдаёт PREGNANCY только при pregnancyCat === 'D' || 'X' и только если patient.gender === 'FEMALE', а возраст известен и лежит в диапазоне 12–55. seed-drugs.ts:67 ставит pregnancyCat: enr.pregnancyCat ?? 'UNKNOWN'. У всех 109 препаратов из _drug-catalog-extra.ts нет обогащения: это сделано сознательно, в заголовке файла (13-17) написано «категории беременности... намеренно отсутствуют». По данным каталога: UNKNOWN у 124 препаратов, D у 18, X у 4. Возникает несогласованность внутри класса. Аторвастатин и розувастатин имеют категорию X и дают CONTRAINDICATED, у симвастатина UNKNOWN и проверки нет. Эналаприл, лизиноприл, лозартан, валсартан и рамиприл имеют категорию D, у периндоприла, телмисартана и ирбесартана UNKNOWN. Диазепам и феназепам D, клоназепам UNKNOWN. У фенитоина и пароксетина UNKNOWN. Импорт реестра категорию не ставит, поэтому примерно 2420 строк UNKNOWN, среди них «Метотрексат», «Изотретиноин», «Мизопростол», «Лефлуномид», «Микофеноловая кислота», «Кандесартан», «Олмесартан» и все комбинации ИАПФ/БРА. Пол при создании пациента не заполняется ни в Telegram-регистрации (miniapp/auth/route.ts:90-103), ни в живой очереди (walkin.ts:126-136, там из ФИО извлекается только год рождения). У таких пациенток gender = null, и проверка беременности не выполняется ни для одного препарата. Во всех этих случаях карточка показывает зелёное «Конфликтов не найдено». Переопределение pregnancyCat клиникой невозможно: поля нет в OVERLAY_FIELD_WHITELIST.DRUG (clinic-overlay.ts:27-35).

G4-14 P2 · СРЕДНИЙ баг

Текстовое распознавание в CDS ломается на брендах с ®, дефисом, «+» или скобками («Энап», «Но-шпа», «Витамин D3», «Леводопа + карбидопа») и путает бренд с коротким названием («Лизинокор» → «Лизин», «Кардилопин» → дилтиазем, «Аскорутин» → «АСК»)

ГДЕ

src/server/cds/drug-check.ts:144, src/server/cds/drug-check.ts:155, src/server/cds/drug-check.ts:169, prisma/_preset-data.ts:670

СЦЕНАРИЙ

Кардиолог кликает пресеты «Энап 10 мг» и «Лозартан 50 мг». Двойная блокада РААС (пара эналаприл + лозартан, MAJOR) не показана, CDS пишет «Конфликтов не найдено · распознано: 1 · не распознано: 1». Строка «Лизинокор 10 мг» распознаётся как лизина эсцинат, и все пары лизиноприла теряются.

ПОСЛЕДСТВИЯ

Взаимодействия и аллергии не проверяются для препаратов, введённых текстом, а часть строк сопоставляется с чужими веществами. Это даёт ложное спокойствие или ложные тревоги.

ЧТО СДЕЛАТЬ

Нормализовать ключи индекса той же функцией `normaliseToken`, убирая ®™ и пунктуацию. Сопоставлять по целым словам. Искать сначала точное совпадение бренда или названия по всей длине, и только потом префикс. Выбирать самое длинное совпадение среди названий и брендов вместе.

КРИТЕРИЙ ПРИЁМКИ

«Энап 10 мг», «Но-шпа 40 мг», «Леводопа + карбидопа 250 мг», «Витамин D3 2000 ME» распознаются как нужный препарат. «Лизинокор» распознаётся как лизиноприл, «Аскорутин» не распознаётся как аспирин.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ключи индекса строятся без нормализации: `prefix: d.nameRu.toLowerCase()` и `brand: b.name.toLowerCase()` (`drug-check.ts:144-148`). Строку же нормализуют через `normaliseToken`, который заменяет всё кроме букв и цифр пробелами (155). Названия вида «Леводопа + карбидопа», «Витамин D3 (холекальциферол)», «Цианокобаламин (B12)» и бренды «Но-шпа», «L-Тироксин», «Де-Нол», «ЭНАП®», «БЕРЛИПРИЛ®» поэтому никогда не находятся. В курируемом каталоге так 16 названий и 7 брендов, в симуляции после импорта 826 названий и 1445 брендов. Кроме того, шаг 2 перебирает все названия раньше брендов, и `startsWith` работает без границы слова (169, 176). Более короткое название реестра перехватывает точный бренд. Результаты прогона Python-копии `resolveDrugs`: «Лизинокор 10 мг» → «Лизин» (C05CX), «Кардилопин» → дилтиазем, «Аскорутин» → «АСК» (B01AC06, аспирин), «Супрастин» → «СУПРА», «Аспаркам» → «АСПА», «Энап 10 мг» → не распознан. Текстовыми строками идут пресеты врача и протоколы без `prescriptionItems`: весь сид протоколов (`structured-fields-panel.tsx:189-193`), кнопка «Энап 10 мг — по 1 таб 2 раза в день» (`_preset-data.ts:670`), свободные строки конструктора.

G4-15 P3 · НИЗКИЙ целостность данных

seed-handouts.ts при каждом запуске деактивирует все памятки, созданные клиниками

ГДЕ

`prisma/seed-handouts.ts:50`, `src/app/api/crm/knowledge/handouts/route.ts:20`

СЦЕНАРИЙ

Админ клиники в «Настройки → База знаний → Памятки» завёл 10 своих памяток. После обновления глобальной библиотеки сидом все они становятся неактивными («Памятки не найдены»).

ПОСЛЕДСТВИЯ

Контент клиники тихо выключается. Админу придётся вручную включать каждую памятку, если он вообще заметит.

ЧТО СДЕЛАТЬ

Деактивировать только глобальные строки: добавить `clinicId: null` в условие `updateMany`.

КРИТЕРИЙ ПРИЁМКИ

После запуска сида памятки с `clinicId ≠ null` сохраняют `active = true`.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`seed-handouts.ts:50-53` выполняет `updateMany({ where: { code: { notIn: codes }, active: true }, data: { active: false } })` без условия `clinicId: null`. Памятки клиники создаются с `code = `c-${randomUUID()}`` и `clinicId = ctx.clinicId` (`knowledge/handouts/route.ts:20-23`), их коды никогда не входят в список сида.

G4-16 P3 · НИЗКИЙ баг

«Риск при диагнозе» не повышает серьёзность: пара НПВС + ИАПФ при ХБП или ХСН остаётся жёлтой MODERATE

ГДЕ

`src/server/cds/drug-check.ts:316`, `prisma/schema.prisma:1022`

СЦЕНАРИЙ

Пациенту с кодом визита N18 (ХБП) назначены «Эналаприл» и «Ибупрофен». Строка «Риск при N18» такая же жёлтая, как у пациента без болезни почек.

ПОСЛЕДСТВИЯ

Повышенный риск визуально не выделяется и сортируется наравне с умеренными.

ЧТО СДЕЛАТЬ

При совпадении `riskDiagnoses` поднимать серьёзность на ступень (MODERATE → MAJOR) или хранить

отдельную серьёзность для группы риска. Учитывать хронические диагнозы пациента.

КРИТЕРИЙ ПРИЁМКИ

Эналаприл + ибупрофен при диагнозе N18 или I50 отображаются как MAJOR (красным).

ДОКАЗАТЕЛЬСТВО В КОДЕ

По комментарию в схеме riskDiagnoses — это «ICD-10 prefixes that elevate this interaction's risk (e.g. "I50" for heart-failure raising the floor of NSAID risk)» (schema.prisma:1022-1023). В drug-check.ts:316-325 при совпадении диагноза меняются только kind на DIAGNOSIS_RISK и заголовок, а severity остаётся it.severity (все 5 пар с riskDiagnoses имеют MODERATE). Хронические диагнозы не учитываются, только diagnosisCode визита, а он теперь необязателен.

G4-17 P3 · НИЗКИЙ бар

Аллергия со степенью по умолчанию «Лёгкая» выводится жёлтым «Умеренное» с текстом «Не назначать», а реакция «анафилаксия» степень не повышает

ГДЕ

src/server/cds/drug-check.ts:290, src/app/api/crm/patients/[id]/allergies/route.ts:21, src/app/[locale]/crm/patients/[id]/_components/tabs/medical-tab.tsx:355

СЦЕНАРИЙ

Регистратор вносит «Цефтриаксон, реакция: анафилактический шок» и не меняет степень. При назначении цефтриаксона врач видит жёлтое «Умеренное» среди прочих умеренных предупреждений.

ПОСЛЕДСТВИЯ

Самое опасное предупреждение визуально выглядит как рядовое.

ЧТО СДЕЛАТЬ

Любое совпадение с лекарственной аллергией показывать минимум как MAJOR. Реакции «анафилаксия», «отёк Квинке», «ССД/ТЭН» автоматически поднимать до CONTRAINDICATED. Сделать степень обязательной при вводе.

КРИТЕРИЙ ПРИЁМКИ

Аллергия со степенью «Лёгкая» и реакцией «анафилаксия» даёт красное CONTRAINDICATED.

ДОКАЗАТЕЛЬСТВО В КОДЕ

По умолчанию степень MILD: форма CRM (medical-tab.tsx:355-357) и API (allergies/route.ts:21, SeveritySchema.default('MILD')). drug-check.ts:290-295 переводит MILD в CDS-серьёзность MODERATE (жёлтая), при этом текст «Не назначать» (300-302). Поле reaction на серьёзность не влияет.

G4-18 P3 · НИЗКИЙ целостность данных · требует проверки на живых данных

Импорт реестра сопоставляет строки и с собственными препаратами других клиник: глобальный препарат может «влиться» в частную строку одной клиники и пропасть у остальных

ГДЕ

scripts/import-uzpharm-registry.ts:57, scripts/import-uzpharm-registry.ts:105

СЦЕНАРИЙ

Клиника А до импорта завела свой «Цитофлавин». Импорт вливает в эту строку все бренды реестра. Клиника В не находит «Цитофлавин» в справочнике.

ПОСЛЕДСТВИЯ

Данные реестра смешиваются между арендаторами. Пока на проде одна клиника, но при подключении второй это проявится.

ЧТО СДЕЛАТЬ

При сопоставлении учитывать только глобальные строки (clinicId IS NULL).

КРИТЕРИЙ ПРИЁМКИ

Препарат клиники с тем же названием не влияет на создание глобальной строки реестра, бренды реестра не прикрепляются к строкам с clinicId.

ДОКАЗАТЕЛЬСТВО В КОДЕ

existingDrugs = prisma.drug.findMany({ select: { id, inn, nameRu } }) и existingBrands выбираются без фильтра clinicId (import-uzpharm-registry.ts:57-62). Собственные препараты клиник (Drug.clinicId, их создаёт /api/crm/knowledge/drugs) попадают в handleToDrug. Если название совпадает, сущность реестра не создаётся глобально, а её бренды пишутся к частной строке (105-119). Поиск фильтрует clinicId IN (null, ctx.clinicId),

поэтому другие клиники этот препарат не увидят, а глобальные бренды окажутся у частной строки.

G4-19 РЗ · НИЗКИЙ целостность данных

Кнопки быстрой записи аллергии в CDS предлагают технические коды («uzr:karbaleks», «aspirin_cardio», «iron_sorbifer») и сохраняют их в карточку пациента

ГДЕ

src/app/[locale]/doctor/reception/_components/cds-warnings-card.tsx:239, prisma/seed-drugs.ts:49, scripts/import-uzpharm-registry.ts:156

СЦЕНАРИЙ

Врач отмечает непереносимость Кардиомагнила одной кнопкой. В карточке пациента, в печати и у регистратуры аллергия записана как «aspirin_cardio».

ПОСЛЕДСТВИЯ

В медицинской карте появляются непонятные записи, а проверка по ним работает только частично.

ЧТО СДЕЛАТЬ

Предлагать русское МНН или название препарата (и класс), а не поле inn. Исправить fallback INN в seed-drugs (задать intl).

КРИТЕРИЙ ПРИЁМКИ

Кнопки-подсказки аллергии показывают русские названия веществ. Ни одна запись PatientAllergy не содержит «uzr:» или «_».

ДОКАЗАТЕЛЬСТВО В КОДЕ

innSuggestions берёт d.inn распознанных препаратов (cds-warnings-card.tsx:235-245), и клик записывает эту строку в PatientAllergy.substance (268-274). У препаратов реестра inn = «uzr:<транслит>» (import-uzpharm-registry.ts:156). У 9 курируемых препаратов без intl INN совпадает со слогом: seed-drugs.ts:49 `const inn = enr.atcCode ? (d.intl ?? d.id) : (d.intl ?? d.id)` (обе ветки одинаковые) даёт smecta, simethicone, aspirin_cardio, vitamin_d3, magnesium_b6, iron_sorbifer, levomekol, sulfacyl, otirax. Остальные курируемые предлагаются латиницей («Carbamazepine»), и такая аллергия не совпадёт с русскими названиями строк реестра.

G4-20 РЗ · НИЗКИЙ целостность данных

Контент протоколов: «Острый средний отит» рассчитан на детей, но предлагает взрослые таблетки (Амоксиклав 625 мг ×3, Парацетамол 500 мг); опечатка «Бекламетазон»; 16 из 20 протоколов не неврологические

ГДЕ

prisma/_protocol-data.ts:417, prisma/_protocol-data.ts:435, prisma/_protocol-data.ts:659

СЦЕНАРИЙ

Врач ставит H66 ребёнку двух лет и нажимает «Применить стандарт». В назначения добавляется Амоксиклав 625 мг в таблетках три раза в день.

ПОСЛЕДСТВИЯ

Возможна детская передозировка, если врач не заметит. Для основного профиля клиники функция стандартов почти не работает.

ЧТО СДЕЛАТЬ

Переписать H66 на дозирование по массе тела (суспензия, мг/кг) или пометить протокол как взрослый. Исправить название беклометазона и добавить его в каталог. Добавить неврологические протоколы с проверкой невролога.

КРИТЕРИЙ ПРИЁМКИ

Протокол H66 не подставляет таблетированные взрослые дозы. В J45 стоит «Беклометазон». Для G40 и G44 есть стандарты.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Протокол H66 в summary пишет «У детей <2 лет и тяжёлых форм — антибиотик» (417), в жалобах есть «беспокойство ребёнка» (422), но назначения взрослые: «Амоксиклав 625 мг — по 1 таб 3 раза в день» и «Парацетамол 500 мг» (435-436). Применение протокола возраст не учитывает (structured-fields-panel.tsx:160-218). В J45 «Бекламетазон 100 мкг» (659): название написано с ошибкой (правильно «Беклометазон»), в каталоге такого препарата нет, CDS строку не распознаёт. Из 20 протоколов к неврологии относятся только G43, G47.0, M54, F41. Для G40, G44, G45, G50/G51, G62, H81, I63/I67, G20, G35

стандартов нет.

G4-21 РЗ · НИЗКИЙ целостность данных

Одинаковые препараты заведены в каталоге дважды под разными id (леводопа + карбидопа, Магне В6, Панангин, витамин D3, Сорбифер, тизанидин МР), и копия из extra-каталога лишена АТС, категории беременности, дозирования и пар

ГДЕ

prisma/_drug-catalog-extra.ts:189, prisma/_drug-catalog.ts:923, prisma/_drug-catalog-extra.ts:885, prisma/_drug-catalog.ts:623

СЦЕНАРИЙ

Врач ищет «Сорбифер», видит две карточки и выбирает ту, где нет данных. Пара «железо + омепразол» и категория беременности пропадают.

ПОСЛЕДСТВИЯ

Результат проверки зависит от того, какую из двух карточек выбрали, а справочник выглядит неряшливо.

ЧТО СДЕЛАТЬ

Слить дубли в одну строку: перенести бренды и формы в курируемую, копию деактивировать, VisitPrescription перепривязать. Добавить проверку уникальности бренда при сиде.

КРИТЕРИЙ ПРИЁМКИ

Поиск «Сорбифер», «Наком», «Магне В6», «Панангин», «Аквадетрим» возвращает по одной карточке с АТС и категорией беременности.

ДОКАЗАТЕЛЬСТВО В КОДЕ

levodopa-carbidopa (extra:189, бренды «Наком», «Тидомет») дублирует levodopa_carbidopa (core:923, те же бренды). magnesium-b6 (extra:877, «Магне В6») дублирует magnesium_b6 (core:613). potassium-magnesium-asparaginate (extra:904, «Панангин», «Аспаркам») дублирует potassium_mg_asparaginate (core:1615). colescalciferol (extra:856, «Аквадетрим», «Вигантол») дублирует vitamin_d3 (core:603). ferrous-sulfate (extra:885, бренд «Сорбифер Дурулес») дублирует iron_sorbifer (core:623-625, тот же бренд). У iron_sorbifer есть пары с ИПП, у копии нет. tizanidine-mr (extra:962) не связан с tizanidine. Уникальность INN (schema.prisma:948) дубль не ловит, потому что intl различаются («Levodopa/Carbidopa» и «Levodopa + Carbidopa»). Протокол D50 распознаётся CDS как ferrous-sulfate (без АТС), а не как iron_sorbifer.

G4-22 РЗ · НИЗКИЙ баг

Пары взаимодействий не учитывают лекарственную форму: глазные капли ципрофлоксацина с азитромицином или гель диклофенака с ибупрофеном получают MAJOR «Не комбинировать»

ГДЕ

prisma/_drug-catalog.ts:130, prisma/_drug-catalog.ts:235, prisma/_drug-interactions-data.ts:195, src/app/[locale]/doctor/reception/_components/structured-fields-panel.tsx:83

СЦЕНАРИЙ

Пациенту с люмбалгией назначены «Ибупрофен 400 мг» внутрь и «Диклофенак гель 1%» местно. Появляется красное MAJOR «Стэкинг НПВС → удвоение ЖКТ-/почечного риска. Оставить один препарат». То же при «Ципрофлоксацин глазные капли» + «Азитромицин».

ПОСЛЕДСТВИЯ

Ложные серьёзные предупреждения на безопасных сочетаниях подрывают доверие к CDS и приучают игнорировать MAJOR.

ЧТО СДЕЛАТЬ

Передавать в CDS форму строки и помечать пары как системные: для наружных, глазных, ушных и назальных форм не применять системные пары или понижать их до MINOR. Либо разделить местные формы на отдельные строки Drug с собственным АТС (S01AE, M02AA).

КРИТЕРИЙ ПРИЁМКИ

«Ибупрофен таб» + «Диклофенак гель» и «Ципрофлоксацин капли глазные» + «Азитромицин» не дают MAJOR, а «Ибупрофен таб» + «Диклофенак таб» дают.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В каталоге системные и местные формы собраны в одну строку Drug. У ciprofloxacin есть форма DROPS_EYE «3 мг/мл» (_drug-catalog.ts:130), у diclofenac форма GEL «1%, 5%» (235), у moxifloxacin DROPS_EYE (1132). Пары

заведены по drug id: azithromycin + ciprofloxacin MAJOR «Удлинение QT... Не комбинировать» (_drug-interactions-data.ts:195-200), ibuprofen + diclofenac MAJOR «Не комбинировать НПВС между собой» (21-27). В CDS передаются только drugId строк (structured-fields-panel.tsx:83-89), форма в проверку не попадает, и drug-check.ts:255-265 форму не видит.

G4-23 P3 · НИЗКИЙ мёртвая механика

Референсные диапазоны лабораторного справочника (с учётом пола) нигде не используются, возрастных нет, а в протоколах вместо названий анализов видны коды

ГДЕ

prisma/_lab-data.ts:13, prisma/seed-labs.ts:45, prisma/schema.prisma:1365, src/app/[locale]/doctor/reception/_components/apply-protocol-dialog.tsx:144

СЦЕНАРИЙ

Врач открывает протокол «Сахарный диабет» и видит в рекомендуемых анализах «HBA1C, MALB, PANEL_LIPID» вместо «Гликированный гемоглобин, микроальбумин, липидограмма».

ПОСЛЕДСТВИЯ

Справочные данные, собранные с учётом пола, мертвы, и если их подключить, для детей они дадут ложные отклонения. В протоколах торчат коды.

ЧТО СДЕЛАТЬ

Либо использовать refRanges для автоматической пометки результатов, предварительно добавив возрастные диапазоны, либо убрать их. В протоколах показывать nameRu из LabTest или LabPanel по коду.

КРИТЕРИЙ ПРИЁМКИ

В диалоге протокола отображаются названия анализов. Если refRanges используются, у анализов с отличающимися детскими нормами есть возрастные диапазоны.

ДОКАЗАТЕЛЬСТВО В КОДЕ

seed-labs.ts:45-48 записывает LabTest.refRanges (schema.prisma:1365). grep по refRanges в src (без generated) пуст, то есть их никто не читает. Результаты анализов (LabResult) хранят свой ручной refRange и flag. Поле ageMinMo объявлено только в типе (_lab-data.ts:15), ни у одного анализа нет детских диапазонов: для ребёнка ЩФ 40–150 Ед/л (ALP, строка 223) была бы «повышена». Экран заказа анализов снят (lab-order-dialog не смонтирован), поэтому справочник анализов виден только как список кодов «Рекомендуемые лабы» в диалоге протокола (apply-protocol-dialog.tsx:140-146): «CBC», «PANEL_LIPID», «HBA1C», «MALB», «COPRO».

G5 · Платформенная панель SUPER_ADMIN и жизненный цикл подписки живой клиники

G5-01 P2 · СРЕДНИЙ баг

«Продлить триал» не возвращает клинику с истёкшим триалом в TRIAL, два пути продления ведут себя по-разному, а «Восстановить (14 дн)» переводит платящую клинику в пробный режим

ГДЕ

src/app/api/admin/clinics/[id]/subscription/extend-trial/route.ts:100, src/app/api/admin/clinics/[id]/lifecycle/route.ts:114, src/app/api/admin/clinics/[id]/lifecycle/route.ts:150, src/app/admin/clinics/[id]/billing/_components/billing-page-client.tsx:338, src/app/admin/clinics/_components/clinics-page-client.tsx:386

СЦЕНАРИЙ

У клиники закончился триал, воркер перевёл её в PAST_DUE, и у всего персонала горит красный баннер. SUPER_ADMIN жмёт «Продлить триал на 30 дней» и видит «Триал продлён». Баннер не пропадает, статус «Просрочена», даты триала на карточке нет. Он пробует «Восстановить (14 дн)» у NeuroFax, которая уже переведена в «Активна»: клиника становится пробной и через две недели снова получает баннер «Пробный период истёк».

ПОСЛЕДСТВИЯ

Основная операция поддержки («дать клинике ещё время») не выполняет своей задачи и при этом сообщает об успехе. Попытка «починить» может разжаловать оплаченную клинику в триал, а журнал содержит разнородные записи, которые трудно сопоставить.

ЧТО СДЕЛАТЬ

Свести продление в одну серверную функцию. При продлении подписка в PAST_DUE (и по решению в CANCELLED) возвращается в TRIAL, а в ответе и тосте фигурируют реальные статус и дата. «Восстановить» разрешить только для CANCELLED (или PAST_DUE), и пусть оно возвращает прежние план, статус и даты из аудита, а не всегда 14-дневный TRIAL. Названия действий в аудите унифицировать. Операции сделать действительно идемпотентными (ключ запроса или сравнение с ожидаемым trialEndsAt).

КРИТЕРИЙ ПРИЁМКИ

Для подписки PAST_DUE «Продлить триал» даёт status TRIAL, trialEndsAt = now+30d, баннер исчезает. Для ACTIVE пункт «Восстановить» недоступен или выдаёт ошибку. Обе кнопки продления дают одинаковый результат и одинаковое действие в аудите.

ДОКАЗАТЕЛЬСТВО В КОДЕ

extend-trial/route.ts:94-104 сдвигает trialEndsAt и НЕ меняет status (так прямо написано в докстринге :9-11). Для PAST_DUE (основной случай: триал уже истёк) статус остаётся PAST_DUE, get-feature-flags и баннер продолжают считать триал истёкшим, а тост на клиенте пишет «Триал продлён на 30 дней» (billing-page-client.tsx:232-238). Карточка для PAST_DUE показывает «Период до» по currentPeriodEndsAt (:353-361), так что новую дату триала SUPER_ADMIN даже не увидит. Второй путь, пункт «Пробный +30 дней» в меню строки (lifecycle/route.ts:147-153), меняет только CANCELLED→TRIAL, а PAST_DUE тоже оставляет. Итог: для CANCELLED кнопка на странице тарификации оставляет статус «Отменена», а пункт меню того же смысла восстанавливает TRIAL. «Восстановить (14 дн)» (lifecycle/route.ts:114-123, пункт меню clinics-page-client.tsx:386-404 доступен для любой клиники) без проверки текущего статуса ставит status TRIAL и trialEndsAt = now+14d. У ACTIVE-клиники через 14 дней шедулер ставит PAST_DUE. Докстринг lifecycle (:13-14) обещает идемпотентность, но extend-trial при каждом вызове добавляет ещё 30 дней. Кроме того, названия действий в аудите для одних и тех же операций различаются: subscription.extend_trial и CLINIC_TRIAL_EXTENDED, subscription.cancel и CLINIC_SUSPENDED.

Бессрочная подписка: пробный период и оплаченный период никогда не заканчиваются, а красный баннер «Пробный период истёк — оплатите» висит у всего персонала вечно

ГДЕ

src/server/workers/trial-expiry-scheduler.ts:93, src/server/workers/trial-expiry-scheduler.ts:127, src/server/platform/get-feature-flags.ts:54, src/components/layout/trial-banner-state.ts:82, src/server/billing/invoice.ts:214, src/messages/ru.json:1

СЦЕНАРИЙ

Через 30 дней после создания клиники воркер в 10:03 переводит её в PAST_DUE. С этого момента у регистратора, медсестры, колл-оператора и админа сверху каждой страницы CRM висит красное «Пробный период истёк — оплатите подписку, чтобы не потерять доступ». Персонал ничего оплатить не может, а доступ не пропадёт никогда: колл-центр и Telegram-инбокс работают бесконечно. Клиника, один раз переведённая в ACTIVE, остаётся платной навсегда, даже если больше не платит.

ПОСЛЕДСТВИЯ

Биллинговая модель не работает: платформа не может ни отключить неплательщика, ни закончить оплаченный период. Персонал живой клиники каждый день видит тревожный и ложный баннер. Владелец платформы никто не сообщает, что у клиники истёк триал: ни аудита, ни уведомления.

ЧТО СДЕЛАТЬ

Замкнуть жизненный цикл: у PAST_DUE должен быть явный срок (например, currentPeriodEndsAt или graceEndsAt ставится при переходе), по истечении которого шедулер переводит подписку в CANCELLED или приостанавливает её. Для ACTIVE при оплате ставить currentPeriodEndsAt = конец периода счёта, а шедулер при истечении переводит в PAST_DUE. Каждый автоматический переход писать в AuditLog и уведомлять ADMIN клиники и платформу. Баннер оплаты показывать только ADMIN, а текст держать в соответствии с реальным поведением.

КРИТЕРИЙ ПРИЁМКИ

В тесте шедулера подписка PAST_DUE с истёкшим сроком льготы переходит в CANCELLED, ACTIVE с истёкшим currentPeriodEndsAt переходит в PAST_DUE, и каждый переход создаёт строку AuditLog. После оплаты счёта currentPeriodEndsAt заполнен. Регистратор и медсестра не видят баннер оплаты.

ДОКАЗАТЕЛЬСТВО В КОДЕ

trial-expiry-scheduler.ts переводит только TRIAL→PAST_DUE (nextStatusFor :93, update :127-132). Во всём src нет кода, который переводит PAST_DUE в CANCELLED: grep по записи "CANCELLED" находит только ручные cancel/lifecycle suspend/PATCH. get-feature-flags.ts:52-55 для PAST_DUE отдаёт полный набор функций тарифа, то есть «льготный период» бесконечен. currentPeriodEndsAt не пишет ни один UI: invoice.ts:214-222 при оплате ставит status ACTIVE без currentPeriodEndsAt, админская форма не имеет поля даты. Ничто не проверяет, что период истёк, поэтому ACTIVE тоже вечен. trial-banner-state.ts:82-83 при PAST_DUE показывает баннер «expired», а без currentPeriodEndsAt берётся текст crmShell.trialBanner.expired.body: «Премиум-функции работают в льготном периоде — оплатите подписку, чтобы не потерять доступ». Баннер рендерится в src/app/[locale]/crm/layout.tsx:195 для любой роли с clinicId. Сам переход в PAST_DUE не пишется в аудит и не рассылается как уведомление (в тике только console.info).

Клиника, созданная из /admin, получает подписку не при создании: до первого открытия «Тарификации» она живёт на Basic, а при открытии страницы ей молча выдаётся 30-дневный Про-триал

ГДЕ

src/app/api/platform/clinics/route.ts:76, src/server/platform/get-feature-flags.ts:49, src/app/admin/clinics/[id]/billing/page.tsx:39, src/app/api/admin/clinics/[id]/subscription/route.ts:65, src/app/api/admin/clinics/[id]/lifecycle/route.ts:54, src/app/api/public/signup/confirm/route.ts:173

СЦЕНАРИЙ

SUPER_ADMIN заводит в /admin новую клинику (например второй филиал-юрлицо) с плейбуком «Неврология». Колл-оператор не находит раздел «Звонки», регистратура не видит Telegram-инбокс. Через неделю SUPER_ADMIN заходит в «Тарификацию» проверить тариф, и у клиники внезапно появляются Про-функции, а 30-дневный триал отсчитывается с этого дня, а не с даты подключения.

ПОСЛЕДСТВИЯ

Новая клиника первые дни работает без оплаченных возможностей, пробный срок и тариф определяются случайным моментом просмотра страницы, а две точки входа в онбординг расходятся (basic и pro, 30 и 14 дней).

ЧТО СДЕЛАТЬ

Создавать Subscription в той же транзакции, что и клинику в POST /api/platform/clinics, с явным выбором плана и срока триала в диалоге создания. Убрать неявное автосоздание из GET и RSC страницы тарификации (оставить явную кнопку «Создать подписку»). Свести ensureSubscription к одной функции с одним сроком по умолчанию.

КРИТЕРИЙ ПРИЁМКИ

Сразу после создания клиники из /admin у неё есть Subscription с выбранным планом и trialEndsAt. Открытие страницы тарификации ничего не пишет в БД. Флаги функций у новой клиники совпадают с выбранным планом.

ДОКАЗАТЕЛЬСТВО В КОДЕ

POST /api/platform/clinics (:76-107) в транзакции создаёт только Clinic и User, Subscription не создаётся. При саморегистрации signup/confirm/route.ts:173-180 подписку создаёт: TRIAL на basic. Пока строки нет, get-feature-flags.ts:49 отдаёт DEFAULT_FLAGS, то есть без колл-центра, Telegram-инбокса и white-label. current-subscription.ts:53 при этом не показывает баннер, а trial-expiry-scheduler такую клинику не видит. Как только SUPER_ADMIN открывает /admin/clinics/[id]/billing (billing/page.tsx:39-57) или вызывается GET/PATCH/cancel/extend-trial, «защитный» ensureSubscription создаёт TRIAL на плане «pro» на 30 дней (subscription/route.ts:65-85). Lifecycle-ветка создаёт такой же TRIAL, но на 14 дней (lifecycle/route.ts:54). Тем самым срок и план триала зависят от того, какую кнопку нажали первой.

G5-04 P2 · СРЕДНИЙ баг

Страницы /admin/users и /admin/audit падают при загрузке: у SelectItem пустое значение value="", Radix Select бросает исключение

ГДЕ

src/app/admin/audit/_components/audit-page-client.tsx:102, src/app/admin/users/_components/users-page-client.tsx:152, src/app/admin/users/_components/users-page-client.tsx:165, src/app/admin/users/_components/users-page-client.tsx:341, src/components/ui/select.tsx:82

СЦЕНАРИЙ

Владелец платформы (SUPER_ADMIN) хочет найти уволенного врача NeuroFax и деактивировать его или посмотреть в журнале, кто и когда сбрасывал пароль владельца. Он открывает «Пользователи» или «Аудит» в сайдбаре /admin, видит на секунду таблицу, после чего страница сменяется экраном «Что-то пошло не так». «Повторить» даёт тот же результат.

ПОСЛЕДСТВИЯ

Два из шести разделов платформенной панели не работают совсем. Глобально управлять пользователями (деактивация, перенос, смена роли) и читать сквозной журнал аудита нельзя. Во время инцидента с безопасностью оператор остаётся без инструмента.

ЧТО СДЕЛАТЬ

Не использовать пустую строку как значение SelectItem. Для «все» взять sentinel (например "__all__") и переводить его в пустой фильтр при сборке запроса, либо убрать пункт «все» и добавить отдельную кнопку сброса. Для «без клиники» в ReassignDialog тоже нужен sentinel. Проверить все остальные SelectItem в src/app/admin/**. На странице пользователей добавить пагинацию по nextCursor.

КРИТЕРИЙ ПРИЁМКИ

/admin/users и /admin/audit открываются без ошибки в консоли и без error boundary. Фильтры «Все роли» и «Все клиники» сбрасывают фильтр. Диалог «Переназначить» открывается и сохраняет изменения. При количестве пользователей больше 50 видна кнопка догрузки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

audit-page-client.tsx:102 `<SelectItem value="">Все клиники</SelectItem>`; users-page-client.tsx:152 `<SelectItem value="">Все роли</SelectItem>`, :165 `value=""` «Все клиники», :341 `value=""` «— (только для SUPER_ADMIN)». UI-обёртка src/components/ui/select.tsx построена на @radix-ui/react-select 2.2.6 (package.json:52) и оборачивает Content в SelectPrimitive.Portal. В Radix SelectContent в закрытом состоянии после первого layout-effect рендерит детей в DocumentFragment (node_modules/@radix-ui/react-select/dist/index.mjs:257-266), а SelectItem при `value === ""` делает `throw new Error("A <Select.Item /> must have a value prop that is not an empty string...")` (там же :823-826). То есть исключение летит сразу после монтирования страницы, без открытия списка. Фильтры-селекты стоят в верхней части обеих страниц, поэтому весь клиентский компонент падает в src/app/admin/error.tsx («Что-то пошло не так»). Тестов на эти страницы нет. Дополнительно в

users-page-client.tsx:68-82 курсор nextCursor никогда не передаётся и кнопки «показать ещё» нет: даже без падения видно только первые 50 пользователей.

G5-05 РЗ · НИЗКИЙ безопасность

GET/PATCH/DELETE /api/platform/clinics/[id] отдают в браузер всю строку Clinic, включая webhook-секрет Telegram, токен бота и kioskPin

ГДЕ

src/app/api/platform/clinics/[id]/route.ts:46, src/app/api/platform/clinics/[id]/route.ts:99, src/app/api/platform/clinics/[id]/route.ts:124, prisma/schema.prisma:326, src/app/api/crm/clinic/route.ts:20

СЦЕНАРИЙ

SUPER_ADMIN переключает статус клиники. Ответ с webhook-секретом и, возможно, открытым токеном бота оседает в DevTools, HAR-файле, который прикладывают к тикету, в расширениях браузера и логах прокси. С секретом вебхука можно слать на вебхук клиники поддельные апдейты Telegram от имени пациентов.

ПОСЛЕДСТВИЯ

Утечка учётных данных бота клиники за пределы сервера без надобности. Выполнить её может только SUPER_ADMIN или то, что имеет доступ к его браузеру, поэтому риск низкий, но нарушен собственный принцип «секреты не уходят в браузер».

ЧТО СДЕЛАТЬ

В платформенных роутах клиники возвращать явный select без tgBotToken, tgWebhookSecret и kioskPin (или маску "****" и флаг hasSecret), как в /api/crm/clinic.

КРИТЕРИЙ ПРИЁМКИ

Ответы GET, PATCH и DELETE /api/platform/clinics/[id] не содержат полей tgBotToken, tgWebhookSecret и kioskPin в открытом виде. UI /admin/clinics работает как прежде.

ДОКАЗАТЕЛЬСТВО В КОДЕ

GET возвращает `ok(row)` (:44-46) после `prisma.clinic.findUnique({ where: { id } })` без select. PATCH возвращает `ok(updated)` (:99), DELETE тоже `ok(updated)` (:124). Каждое переключение «Активна» на /admin/clinics вызывает PATCH и получает полную строку. В строке есть tgWebhookSecret (schema.prisma:327, хранится открытым текстом, по нему Telegram аутентифицирует вебхук), tgBotToken (:326, шифротекст, но в старых строках допускается открытый текст: «Legacy plaintext rows are tolerated on read»), kioskPin (:328). CRM-эндпоинт той же сущности маскирует секрет: api/crm/clinic/route.ts:20 `out.tgWebhookSecret = c.tgWebhookSecret ? "\*\*\*\*" : null`.

G5-06 РЗ · НИЗКИЙ целостность данных

PATCH /api/platform/users/[id] переносит и понижает сотрудников без проверок, которые есть в CRM: можно оставить клинику без ADMIN, а у врача обрывается связь с профилем Doctor

ГДЕ

src/app/api/platform/users/[id]/route.ts:85, src/app/api/crm/users/[id]/route.ts:66, prisma/schema.prisma:839, src/app/api/platform/clinics/[id]/reset-owner-password/route.ts:41

СЦЕНАРИЙ

SUPER_ADMIN переносит врача из демо-клиники в NeuroFax через «Переназначить». В NeuroFax врач входит и видит пустой кабинет, а завести ему профиль нельзя: userId уже занят профилем в старой клинике. В другой раз SUPER_ADMIN деактивирует единственного админа клиники, и сбросить пароль «владельца» тоже нельзя.

ПОСЛЕДСТВИЯ

Сломанные связи врач↔пользователь между клиниками, а клиника может остаться без администратора. Хорошо проверенные правила CRM обходятся через платформенный путь.

ЧТО СДЕЛАТЬ

Перенести в платформенный PATCH проверки из CRM: last_admin для понижения, деактивации и переноса ADMIN; для DOCTOR запрещать перенос между клиниками, пока профиль Doctor не отвязан или не перенесён, либо переносить его явно. Писать в аудит новые значения полей, а не только их список.

КРИТЕРИЙ ПРИЁМКИ

Попытка деактивировать, понизить или перенести последнего активного ADMIN клиники через /api/platform/users/[id] возвращает 409 last_admin. Перенос пользователя с привязанным Doctor в другую клинику либо отклоняется, либо корректно переносит или отвязывает профиль.

ДОКАЗАТЕЛЬСТВО В КОДЕ

platform/users/[id]/route.ts:66-102 проверяет только существование целевой клиники и запрещает себе самопонижение. Нет guard'a «последний активный ADMIN», хотя CRM-путь его имеет (crm/users/[id]/route.ts:61-73 и :136-145, reason last_admin). Нет обработки профиля врача: Doctor.userId @unique (schema.prisma:839) остаётся в старой клинике, а в CRM повышение в DOCTOR требует привязки к существующему Doctor (crm/users/[id]/route.ts:75). При переносе врача в другую клинику его Doctor, записи и расписание остаются в клинике А и ссылаются на пользователя клиники В. В клинике В кабинет врача не находит Doctor по userId (например crm/doctors/me/patients/route.ts:74). После деактивации или переноса единственного ADMIN reset-owner-password отвечает 409 no_active_owner (:41-43).

G5-07 РЗ · НИЗКИЙ UX

«Пароль владельца» сбрасывает пароль «самого старого ADMIN» и заранее не показывает, чей именно, а окно с одноразовым паролем закрывается по Esc или клику мимо

ГДЕ

src/app/api/platform/clinics/[id]/reset-owner-password/route.ts:36, src/app/admin/clinics/_components/clinics-page-client.tsx:325, src/app/admin/clinics/_components/clinics-page-client.tsx:708

СЦЕНАРИЙ

Владелец NeuroFax просит восстановить доступ. SUPER_ADMIN жмёт «Пароль владельца», и сбрасывается пароль первой созданной ADMIN-учётки (например демо- или сид-админа), а не владельца. Временный пароль этой чужой учётки уходит владельцу. В другой раз SUPER_ADMIN случайно нажимает Esc, окно с паролем исчезает, и приходится сбрасывать ещё раз.

ПОСЛЕДСТВИЯ

Можно сбросить пароль не тому человеку и выдать доступ к чужой учётной записи. Одноразовые учётные данные легко потерять.

ЧТО СДЕЛАТЬ

Показывать в подтверждении конкретную учётку (имя и email), а лучше давать выбрать ADMIN из списка. Хранить признак владельца или выбирать по invitedById при создании клиники. В CredentialsModal блокировать onEscapeKeyDown и onInteractOutside.

КРИТЕРИЙ ПРИЁМКИ

В диалоге подтверждения виден email учётки, пароль которой будет сброшен. Окно с временным паролем закрывается только кнопкой «Я сохранил, закрыть».

ДОКАЗАТЕЛЬСТВО В КОДЕ

reset-owner-password/route.ts:36-40: владельцем считается `findFirst({ where: { clinicId, role: "ADMIN", active: true }, orderBy: { createdAt: "asc" } })`. Понятия владельца в схеме нет. Подтверждение в UI (clinics-page-client.tsx:325) говорит «Сбросить пароль владельца клиники «...»?» и не называет учётную запись. Логин становится известен только после сброса. Окно CredentialsModal (:704-711) по комментарию должно закрываться «only via the explicit button», но `onOpenChange={(v) => { if (!v) onClose(); }}` закрывает его по Esc и по клику вне окна. Одноразовый пароль при этом теряется, и нужен повторный сброс, который снова меняет пароль. Отзыв сессий и 2FA описаны в #361 и #371 и здесь не повторяются.

G5-08 РЗ · НИЗКИЙ UX

В платформенной панели /admin нет выхода из аккаунта, а у раздела «Шифрование» в шапке написано «Клиники — CRUD платформы»

ГДЕ

src/app/admin/_components/admin-sidebar.tsx:84, src/app/admin/_components/admin-topbar.tsx:8

СЦЕНАРИЙ

SUPER_ADMIN закончил работу на чужом или общем компьютере и хочет выйти из самой привилегированной учётки. В /admin нет кнопки выхода: нужно перейти в CRM и искать выход там.

ПОСЛЕДСТВИЯ

Сессия с полным доступом ко всем клиникам легко остаётся открытой. Мелкая путаница в заголовках.

ЧТО СДЕЛАТЬ

Добавить в AdminTopbar меню пользователя с «Выйти» (signOut с редиректом на /ru/login). Добавить в TITLES заголовок для encryption-health.

КРИТЕРИЙ ПРИЁМКИ

В шапке /admin есть «Выйти», после нажатия сессия завершается и открывается страница входа. На

/admin/encryption-health заголовков «Шифрование».

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ни один файл в src/app/admin не содержит signOut или «Выйти» (grep пуст). В сайдбаре внизу только ссылка «Вернуться в CRM» (admin-sidebar.tsx:84-91). В admin-topbar.tsx:8-14 в TITLES нет ключа encryption-health, поэтому срабатывает фолбэк `TITLES.clinics` (:24), и на /admin/encryption-health шапка показывает «Клиники / CRUD платформы».

G5-09 P3 · НИЗКИЙ безопасность

Окончание 60-минутной имперсонации не попадает в журнал: ветка SUPER_ADMIN_IMPERSONATE_EXPIRED недостижима, грант не закрывается, переход из клиники в клинику не пишет ENDED

ГДЕ

src/lib/auth.ts:274, src/app/[locale]/crm/layout.tsx:94, src/app/[locale]/crm/layout.tsx:103, src/app/api/platform/session/switch-clinic/route.ts:97, src/server/platform/impersonation.ts:123

СЦЕНАРИЙ

SUPER_ADMIN входит в NeuroFax с причиной «разбор жалобы», час работает с картами пациентов, а затем переходит в другую клинику или просто продолжает кликать после истечения гранта. В журнале есть STARTED, но нет ни ENDED, ни EXPIRED. Грант в БД выглядит незакрытым, а сам SUPER_ADMIN оказывается в CRM без клиники.

ПОСЛЕДСТВИЯ

По журналу нельзя восстановить, когда закончился доступ оператора платформы к медицинским данным клиники. Интерфейс после истечения ведёт себя непредсказуемо.

ЧТО СДЕЛАТЬ

При обнаружении истёкшего гранта в JWT-callback (или в отдельной проверке в проху/layout по cookie гранта) вызывать endGrant(id, "expired"), писать IMPERSONATE_EXPIRED с clinicId гранта и перенаправлять на /admin/clinics?expired=1 с понятным сообщением. При переключении клиники писать ENDED для предыдущего гранта. Не писать ENDED, если активного гранта не было.

КРИТЕРИЙ ПРИЁМКИ

Через 60 минут после входа в клинику следующий запрос SUPER_ADMIN возвращает его на /admin/clinics с сообщением, в AuditLog есть IMPERSONATE_EXPIRED с clinicId, у гранта заполнены endedAt и endedReason=expired. Переход A→B даёт ENDED для A.

ДОКАЗАТЕЛЬСТВО В КОДЕ

auth.ts:274-284: если грант неактивен, JWT-callback одновременно обнуляет `token.clinicId`, impersonationGrantId и impersonationMode. Страховочная ветка в crm/layout.tsx:94-123 срабатывает только при `session.user.role === "SUPER\_ADMIN" && session.user.clinicId` и `!session.user.impersonation`, но clinicId к этому моменту уже null. Поэтому запись SUPER_ADMIN_IMPERSONATE_EXPIRED и redirect("/admin/clinics?expired=1") недостижимы (параметр expired к тому же нигде в /admin не читается). endGrant(..., "expired") нигде не вызывается (grep endGrant: только switch-clinic с "user_exit"), поэтому истёкший грант навсегда остаётся с endedAt=null. switch-clinic:97-100 при входе в клинику B закрывает грант клиники A как user_exit, но не пишет IMPERSONATE_ENDED для A. Выход без активного гранта (:159-182) пишет ENDED с clinicId null. После истечения SUPER_ADMIN остаётся в /ru/crm в платформенном контексте без клиники, а не возвращается в /admin.

G5-10 P3 · НИЗКИЙ UX

Переключатель «Активна» в /admin/clinics одним кликом без подтверждения отключает у живой клиники мини-апп, киоск, ТВ-табло очереди и форму записи на сайте

ГДЕ

src/app/admin/clinics/_components/clinics-page-client.tsx:299, src/app/api/platform/clinics/[id]/route.ts:87, src/app/api/platform/clinics/[id]/route.ts:97, src/server/miniapp/handler.ts:127, src/server/clinic-public/resolve.ts:67, src/app/api/tv/d/[token]/route.ts:81, src/lib/public-clinic.ts:34

СЦЕНАРИЙ

SUPER_ADMIN в разгар приёма тянется к кнопке «Войти» в строке NeuroFax и задевает соседний переключатель «Активна». Мини-апп у всех пациентов показывает ошибку, киоск в холле не пускает на отметку, ТВ-табло очереди в коридоре и экраны у кабинетов гаснут, форма записи на сайте отдаёт 404. В журнале видно лишь «clinic.update changed: active», без указания, выключили клинику или включили.

ПОСЛЕДСТВИЯ

Полная остановка всех каналов клиники, обращённых к пациентам, от одного случайного клика. Время простоя тянется, пока кто-то не свяжет симптомы с флагом, а журнал не помогает понять, что произошло.

ЧТО СДЕЛАТЬ

Перед выключением показывать подтверждение с перечнем того, что перестанет работать (мини-апп, киоск, табло, запись), лучше с вводом slug клиники. Переключатель отодвинуть от «Войти» или перенести в меню действий. В аудит писать значения before/after для active и остальных изменённых полей.

КРИТЕРИЙ ПРИЁМКИ

Клик по «Активна» открывает диалог, отмена ничего не меняет. После подтверждения в AuditLog есть запись с active: true→false. Повторное включение возвращает мини-апп и табло.

ДОКАЗАТЕЛЬСТВО В КОДЕ

clinics-page-client.tsx:298-302: `<Switch checked={c.active} onChange={() => toggleActive.mutate(c)} />` без confirm. Переключатель стоит в той же строке, что и кнопка «Войти», которая при !c.active сразу блокируется (:310-311). PATCH /api/platform/clinics/[id] (:87) записывает active. Clinic.active=false проверяют: весь Mini App API через server/miniapp/handler.ts:127 (404 reason clinic), ТВ-экраны врачей api/tv/d/[token]/route.ts:81, публичная очередь, табло, walk-in и check-in через server/clinic-public/resolve.ts:67, киоск и лиды сайта через lib/public-clinic.ts:34, api/miniapp/clinic/route.ts:36. Аудит при этом пишет только `meta: { changed: Object.keys(parsed.data) }` (:97), то есть «changed: [active]» без нового значения. Персонал CRM продолжает работать (это отдельная проблема #369), поэтому регистратура сбой не заметит. Похожий переключатель у админа клиники описан в #165, здесь другая поверхность: платформенная панель.

G5-11 РЗ · НИЗКИЙ мокап / заглушка

Платформенная страница «Интеграции» — фасад: Telegram-подключение и его выключатель ни на что не влияют, платёжные ключи не читаются, карточка SMS мёртвая, а единственный реально читаемый секрет (SIP) хранится и показывается открытым текстом

ГДЕ

src/app/admin/clinics/[id]/integrations/_components/integrations-page-client.tsx:63, src/app/admin/clinics/[id]/integrations/_components/integrations-page-client.tsx:163, src/server/notifications/adapters/index.ts:40, src/app/api/calls/sip/event/route.ts:113, src/app/api/platform/clinics/[id]/integrations/route.ts:88, src/server/schemas/platform.ts:198

СЦЕНАРИЙ

В клинике начался спам через Telegram-бот. SUPER_ADMIN открывает «Интеграции» клиники и выключает переключатель у строки TELEGRAM, но бот продолжает отвечать и рассылать напоминания. Для телефонии он вводит webhook-секрет ATC в поле «Секрет» (оно зашифровано): все события ATC отбиваются, пока секрет не прописан в JSON config, где он лежит открытым текстом и виден целиком любому, кто открыл редактор.

ПОСЛЕДСТВИЯ

Оператор платформы думает, что управляет интеграциями клиники, а на деле ничего не включает и не выключает. Выключить Telegram в экстренной ситуации отсюда нельзя. Обещание шифрования секретов ложно именно для того секрета, который используется.

ЧТО СДЕЛАТЬ

Либо подключить ProviderConnection к реальным потребителям (TG-адаптер уважает active и секрет строки, вебхук SIP читает расшифрованный secretCipher), либо убрать с платформенной страницы семейства без потребителей (SMS, PAYMENT) и честно показывать, что Telegram настраивается через Clinic.tgBotToken. Для SIP хранить webhookSecret только в secretCipher, отдавать в браузер маску и вычищать секретные ключи из config в ответе API. Проверять label "sip" для TELEPHONY на сервере.

КРИТЕРИЙ ПРИЁМКИ

Выключение TG-подключения на платформенной странице реально останавливает отправку через бота (или переключателя нет). SIP-вебхук принимает событие с секретом, введённым в поле «Секрет». GET /api/platform/clinics/[id]/integrations не содержит открытых секретов ни в одном поле. Карточки SMS нет.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Карточка TG описана как «Бот клиники: токен, webhook-secret» (:68-72), но адаптер (adapters/index.ts:40-46) выбирает реальный Telegram только по Clinic.tgBotToken: `if (hasBotToken) return new TelegramClinicAdapter`. label, config и secret строки TELEGRAM не используются, выключатель active строки тоже ничего не отключает. PAYME, CLICK и UZUM в ProviderConnection не читает ни один код (grep providerConnection: только platform/crm

integrations, telephony/index.ts, sip/event, adapters). Карточка SMS (:63-67) остаётся в FAMILY_META, но FAMILY_KINDS (schemas/platform.ts:198-202) её не содержит: allowedKinds=[], «Добавить» шлёт family "SMS" с kind "", zod отвечает 400, и пользователь видит «HTTP 400». Телефония: вебхук ищет строго kind OTHER и label "sip" (sip/event/route.ts:108-111), а секрет читает из `config.webhookSecret` открытым текстом (:113-116). Поле «Секрет», которое шифруется, вебхук игнорирует. Метка по умолчанию пустая (label null), а UI её не навязывает. Заголовок страницы обещает «Секреты зашифрованы AES-256-GCM. В UI видны только последние 4 символа» (:163), хотя GET отдаёт config целиком (integrations/route.ts:88) и редактор выводит его в textarea (:359-361). В отличие от #166/#482/#516 (настройки клиники в CRM), речь о платформенной панели SUPER_ADMIN.

G5-12 P3 · НИЗКИЙ мокап / заглушка

Раздел «Здоровье» показывает зелёный ОК для Redis, BullMQ и MinIO по одному наличию env-переменной, ничего не пингуя, и не показывает состояние воркеров

ГДЕ

src/app/api/platform/health/route.ts:49, src/app/api/platform/health/route.ts:62, src/app/api/platform/health/route.ts:75, src/app/api/platform/health/route.ts:86

СЦЕНАРИЙ

Redis упал, BullMQ-воркеры перестали отправлять напоминания пациентам, MinIO не отдаёт файлы. Владелец открывает /admin → «Здоровье» и видит четыре зелёных «ОК».

ПОСЛЕДСТВИЯ

Панель мониторинга платформы вводит в заблуждение ровно тогда, когда нужна, и откладывает реакцию на сбой напоминаний и файлов.

ЧТО СДЕЛАТЬ

Пинговать Redis (PING через ioredis с таймаутом), проверять MinIO (HeadBucket) и показывать heartbeat воркера (например, отметка времени последнего тика в Redis или БД). Статус not_configured и ok ставить только по результату проверки.

КРИТЕРИЙ ПРИЁМКИ

При остановленном контейнере redis или minio карточка показывает DOWN и overall=degraded. При остановленном worker'e отдельная карточка показывает давность последнего тика.

ДОКАЗАТЕЛЬСТВО В КОДЕ

checkRedis (:39-50) возвращает `status: "ok"`, если REDIS_URL задан. checkBullmq (:52-63) делает то же самое. checkMinio (:65-76) возвращает ok, если задан MINIO_ENDPOINT или S3_ENDPOINT. В

docker-compose.yml:80-81 обе переменные на проде заданы всегда. Реально проверяется только Postgres (SELECT 1). overall (:86-90) при этом становится «ок». Воркер (docker-compose.yml:98, trial-expiry, напоминания, outbox) не проверяется вовсе. Страница /admin/health опрашивает эндпоинт каждые 15 с и рисует зелёные галочки. Это не публичный /api/health из #439, а платформенная страница.

G5-13 P3 · НИЗКИЙ мокап / заглушка

Раздел «Использование»: KPI «SMS» всегда 0, а «TG сообщения» считают все исходящие сообщения чатов (включая in-app) и не учитывают Telegram-напоминания

ГДЕ

src/app/api/platform/usage/route.ts:59, src/app/api/platform/usage/route.ts:68, src/app/admin/usage/_components/usage-page-client.tsx:98

СЦЕНАРИЙ

Владелец смотрит «Использование» NeuroFax за месяц, чтобы оценить нагрузку на Telegram-бота перед выставлением тарифа. Видит «SMS: 0» и «TG: 312», хотя бот отправил тысячи напоминаний, а 312 — это в основном ответы в чате мини-аппа.

ПОСЛЕДСТВИЯ

Цифры платформенной аналитики не отражают реальное использование каналов, и решения по тарифам принимаются на неверных данных.

ЧТО СДЕЛАТЬ

Убрать SMS из UI (или показывать только для исторических периодов). tgMessages считать как исходящие Message в Conversation.channel=TG плюс NotificationSend channel TG со статусами SENT и DELIVERED. In-app сообщения выводить отдельной колонкой.

КРИТЕРИЙ ПРИЁМКИ

На /admin/usage нет колонки SMS (или она явно помечена как историческая). Колонка TG совпадает с суммой исходящих TG-сообщений и отправленных TG-уведомлений за период, in-app сообщения в неё не входят.

ДОКАЗАТЕЛЬСТВО В КОДЕ

usage/route.ts:59-67 считает NotificationSend с channel SMS. По докстрингу (:11-17) SMS удалены, новых строк нет, но usage-page-client.tsx:98 и :110 по-прежнему выводят KPI и колонку «SMS». Подсчёт «tgMessages» (:68-75) — это `message.groupBy` по direction OUT без фильтра по Conversation.channel. Conversation.channel бывает TG, INAPP и другие (schema.prisma:2463, enum CommunicationChannel :88-95), так что в число попадают ответы в in-app чате мини-аппа. При этом основной объём Telegram, напоминания и рассылки (NotificationSend channel TG), в счётчик не входит.

G5-14 P3 · НИЗКИЙ UX

Смена тарифа и статуса в «Тарификации» срабатывает одним выбором из списка без подтверждения, посреди дня отключает колл-центр, Telegram-инбокс и Про-функции, а аудит не сохраняет прежних значений для отката

ГДЕ

src/app/admin/clinics/[id]/billing/_components/billing-page-client.tsx:212, src/app/admin/clinics/[id]/billing/_components/billing-page-client.tsx:222, src/app/admin/clinics/[id]/billing/_components/billing-page-client.tsx:171, src/app/api/admin/clinics/[id]/subscription/route.ts:156, src/app/api/admin/clinics/[id]/subscription/route.ts:181, src/app/api/admin/clinics/[id]/lifecycle/route.ts:109, src/server/platform/get-feature-flags.ts:56

СЦЕНАРИЙ

В 11:00 SUPER_ADMIN открывает «Тарификацию» NeuroFax, чтобы посмотреть дату триала, и случайно выбирает в выпадающем списке «Basic» или статус «Отменена». Изменение применяется мгновенно. У колл-оператора список звонков начинает получать 404, пункт «Колл-центр» исчезает, регистратура теряет Telegram-инбокс, мини-апп и CRM теряют фирменные цвета. Админская карточка продолжает показывать галочки у колл-центра. Чтобы откатить, SUPER_ADMIN открывает журнал, но там записано только «changed: [planId]» без прежнего значения.

ПОСЛЕДСТВИЯ

Одно неловкое движение отключает колл-центру и регистратуре живой клиники рабочие разделы. Восстановить прежнее состояние (план, даты, статус) по журналу нельзя, а админский экран вводит в заблуждение, какие функции у клиники реально включены.

ЧТО СДЕЛАТЬ

Для смены плана и статуса сделать явное подтверждение с перечнем функций, которые включатся или отключатся. Статус CANCELLED через PATCH должен ставить cancelledAt, а выход из CANCELLED должен его очищать. В аудит писать before/after для planId, status, trialEndsAt, currentPeriodEndsAt и cancelledAt, в том числе в cancel и lifecycle. Карточку на админской странице строить через ту же серверную getFeatureFlags (с учётом статуса) и показывать все флаги, включая white-label и субдомен.

КРИТЕРИЙ ПРИЁМКИ

Выбор нового плана или статуса открывает диалог подтверждения, отмена ничего не меняет. После подтверждения в AuditLog видны старые и новые значения. У отменённой подписки админская карточка показывает колл-центр и Telegram как выключенные, а cancelledAt заполнен.

ДОКАЗАТЕЛЬСТВО В КОДЕ

billing-page-client.tsx:212-230: onChangePlan и onChangeStatus сразу вызывают PATCH из onChange у Select без confirm. confirm есть только у кнопки «Отменить подписку» (:241). PATCH subscription/route.ts:156-172 применяет status/planId как есть. Статус CANCELLED, выбранный в списке, НЕ ставит cancelledAt, поэтому карточка показывает «Отменена —» (:363-371). Аудит: route.ts:174-182 пишет только `meta: { changed: Object.keys(parsed.data) }` без старого и нового plan/status. cancel/route.ts:95 пишет только cancelledAt, lifecycle suspend (:109) пишет только previousStatus, без плана и дат. Последствия CANCELLED или Basic по get-feature-flags.ts:56-58 и DEFAULT_FLAGS: /crm/call-center даёт notFound (call-center/page.tsx:22), /api/crm/calls даёт 404 (calls/route.ts:20, calls/[id]/route.ts:22), /crm/telegram даёт notFound (telegram/page.tsx:27), пункты пропадают из сайдбара, /api/crm/analytics/funnels даёт 404, white-label выключается и в CRM (crm/layout.tsx:145), и в мини-аппе (c/[slug]/my/layout.tsx:89-94), настройки брендинга дают 404. Бот и напоминания продолжают работать. Карточка тарифа при этом берёт флаги из plan.features без учёта статуса (billing-page-client.tsx:171-173): у отменённой клиники она показывает ✓ «Колл-центр» и ✓ «Telegram-инбокс». Её локальная копия parsePlanFeatures (:46-84) вообще не знает hasWhiteLabel, hasCustomSubdomain и квоты.

Страница «Шифрование» каждую минуту пишет строку в журнал аудита и гоняет 12 полных COUNT по таблицам пациентов, заваливая платформенный аудит

ГДЕ

src/app/admin/encryption-health/_components/encryption-health-client.tsx:53, src/app/api/admin/encryption-health/route.ts:150, src/app/api/admin/encryption-health/route.ts:185

СЦЕНАРИЙ

SUPER_ADMIN оставил вкладку «Шифрование» открытой на рабочем дне. К вечеру в /admin/audit сотни одинаковых ENCRYPTION_HEALTH_CHECKED, среди которых нужно выискивать реальные события: сбросы паролей, входы в клиники, смены тарифа. База постоянно делает полные сканы таблиц пациентов.

ПОСЛЕДСТВИЯ

Журнал аудита теряет читаемость, растёт впустую, а по мере роста числа пациентов увеличивается лишняя нагрузка на БД.

ЧТО СДЕЛАТЬ

Убрать автообновление (оставить ручную кнопку «Обновить») или не писать аудит на фоновые рефетчи. Писать аудит не чаще раза в N минут на пользователя. Для счётчиков использовать один запрос с FILTER вместо трёх.

КРИТЕРИЙ ПРИЁМКИ

Страница, открытая час, создаёт не больше одной записи ENCRYPTION_HEALTH_CHECKED (или только при ручном нажатии «Обновить»).

ДОКАЗАТЕЛЬСТВО В КОДЕ

encryption-health-client.tsx:47-54: `refreshInterval: 60\_000`. Каждый запрос route.ts:150-156 запускает countColumn для четырёх колонок, по три SQL на колонку (COUNT(*), COUNT IS NULL, GROUP BY по регулярке) над Patient, MedicalCase и Prescription целиком. Затем :184-216 создаёт AuditLog ENCRYPTION_HEALTH_CHECKED с clinicId null и полными счётчиками. Открытая вкладка даёт 60 строк аудита в час.

G6 · Рабочее место оператора Telegram: правая панель чата, композер, рассылки

G6-01 P1 · ВЫСОКИЙ безопасность

Черновик, вложения и inline-кнопки композера не сбрасываются при переключении диалога: файл и текст для пациента А уходят пациенту В

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-pane.tsx:373, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:176, src/app/[locale]/crm/telegram/_components/message-composer.tsx:97, src/app/[locale]/crm/telegram/_components/message-composer.tsx:164, src/app/[locale]/crm/telegram/_components/message-composer.tsx:264, src/app/api/crm/conversations/[id]/messages/route.ts:177, src/app/api/crm/conversations/[id]/attachments/route.ts:112, src/app/api/crm/conversations/[id]/attachments/file/route.ts:53, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:145

СЦЕНАРИЙ

Регистратор в чате пациентки Каримовой прикрепляет PDF с результатами МРТ и ещё не отправил. Приходит тост «Новое сообщение», регистратор жмёт «Открыть» (или кликает другой диалог) и попадает в чат Юсупова. В композере остались файл Каримовой и начатый текст. Регистратор дописывает «Да, ждём вас завтра в 10:00» и жмёт Enter, и Юсупову в Telegram уходит PDF с медданными Каримовой.

ПОСЛЕДСТВИЯ

Медицинские документы и персональные данные уходят постороннему человеку через бот клиники. Отозвать такое сообщение из CRM нельзя. Ресепшн отправляет файлы весь день, поэтому ошибку легко сделать.

ЧТО СДЕЛАТЬ

Сбрасывать композер и форму создания пациента при смене диалога: key={conversation.id} на ChatPane/MessageComposer/CreatePatientForm, либо хранить черновики в Map по conversationId и никогда не переносить вложения в другой диалог. На сервере в POST /api/crm/conversations/[id]/messages принимать только вложения, чей url/key лежит под clinics/<clinicId>/chat/<этот id>/, иначе отвечать 400.

КРИТЕРИЙ ПРИЁМКИ

Прикрепить файл и набрать текст в чате А, переключиться на В: композер пустой. POST в диалог В с вложением, у которого url от диалога А, возвращает 400 и ничего не уходит в Telegram.

ДОКАЗАТЕЛЬСТВО В КОДЕ

ChatPane рендерится в telegram-page-client.tsx:176 без key, а внутри него `<MessageComposer conversation={conversation} />` (chat-pane.tsx:373) тоже без key. Состояние `text`, `buttonRows`, `attachments` — это useState в MessageComposer (message-composer.tsx:97-99), поэтому при смене `selected` с А на В тот же экземпляр компонента сохраняет черновик и вложения. uploadOne шлёт файл на `/api/crm/conversations/\${A}/attachments` и получает capability-URL `/api/crm/conversations/A/attachments/file?key=clinics/<c>/chat/A/<uuid>` (attachments/route.ts:112). onSend (стр. 264-275) берёт текущий `conversation.id` (В) и те же readyAttachments. POST messages (route.ts:162-187) без проверки берёт `att.url` из тела, делает его абсолютным и вызывает sendPhoto/sendDocumentUrl в чат В. Прокси файлов не аутентифицирован и проверяет только то, что ключ совпадает с id диалога в пути самого URL, то есть с А (file/route.ts:53-58), поэтому Telegram скачивает файл без ошибок. Та же ошибка в CreatePatientForm: он рендерится без key (chat-right-rail.tsx:145), и введённые ФИО и телефон переходят в следующий непривязанный диалог.

G6-02 P2 · СРЕДНИЙ целостность данных

«Записать» из Telegram-чата создаёт запись с каналом «Телефон», и она сразу считается подтверждённой

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:260, src/components/appointments/NewAppointmentDialog.tsx:140, src/components/appointments/NewAppointmentDialog.tsx:47, src/app/api/crm/appointments/route.ts:157, src/app/api/crm/appointments/route.ts:205

СЦЕНАРИЙ

Пациент пишет в бот «Хочу к неврологу в пятницу». Оператор жмёт «Записать» в правой панели и не трогает поле «Канал». Запись сохраняется как «Телефон» и «подтверждена», хотя пациент ничего не подтверждал. В отчётах по каналам Telegram-записи попадают в «Телефон».

ПОСЛЕДСТВИЯ

Искажена аналитика источников записи. Статус подтверждения ложный, поэтому не запускается подтверждение и каскад напоминаний (см. #102), и растёт риск неявки.

ЧТО СДЕЛАТЬ

Добавить в NewAppointmentDialog проп initialChannel и передавать "TELEGRAM" из правой панели и из быстрого действия композера. Запись из чата не автоподтверждать.

КРИТЕРИЙ ПРИЁМКИ

Запись, созданная из Telegram-инбокса без ручной смены канала, имеет channel=TELEGRAM и confirmedAt=null.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Правая панель открывает NewAppointmentDialog только с patientId (chat-right-rail.tsx:260-268). Проп для канала у диалога нет (props на стр. 47-67), и при каждом открытии он ставит channel: "PHONE" (стр. 140). API считает PHONE каналом автоподтверждения (AUTO_CONFIRM_CHANNELS, route.ts:157) и передаёт autoConfirm: true (стр. 205), после чего проставляется confirmedAt. Канал записи используется как измерение в отчётах (server/analytics/dimensions.ts:49). Отсутствие напоминаний у PHONE-записей уже описано в #102; здесь корень в том, что чат не передаёт канал TELEGRAM.

G6-03 P2 · СРЕДНИЙ баг

Вкладка «Неотвеченные» непригодна: открытый диалог сразу помечается прочитанным и через секунду исчезает из списка и из окна чата; при входе в раздел свежий диалог «читается» без участия оператора

ГДЕ

src/app/[locale]/crm/telegram/_components/conversation-list.tsx:110, src/app/[locale]/crm/telegram/_hooks/use-conversations.ts:112, src/app/api/crm/conversations/route.ts:32, src/app/[locale]/crm/telegram/_components/chat-pane.tsx:107, src/app/[locale]/crm/telegram/_hooks/use-mark-read.ts:44, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:71, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:76

СЦЕНАРИЙ

Утром администратор открывает Telegram → «Неотвеченные» (12 диалогов) и кликает первый. Переписка мелькает и через секунду пропадает, справа «Выберите диалог», в списке остаётся 11. Ответить можно только через «Все» и поиск. В это же время второй регистратор просто открывает раздел Telegram, и самый свежий непрочитанный диалог молча помечается прочитанным: он пропадает из «Неотвеченных» у всех, счётчик в шапке уменьшается, а ответа никто не дал.

ПОСЛЕДСТВИЯ

Разбирать очередь обращений нельзя, вопросы пациентов о записи и переносах теряются. Ресепшн работает с этим экраном весь день.

ЧТО СДЕЛАТЬ

Разделить «прочитано» и «отвечено»: «Неотвеченные» определять по последнему входящему без последующего исходящего (например, поля lastInboundAt/lastOutboundAt). Выбранный диалог держать открытым, даже если он выпал из текущей выборки (догружать через GET /api/crm/conversations/[id]). Автоматически выбранный при загрузке диалог не помечать прочитанным, либо убрать автовыбор.

КРИТЕРИЙ ПРИЁМКИ

В «Неотвеченных» открытый диалог остаётся на экране и уходит из вкладки только после ответа оператора. Открытие раздела Telegram не меняет unreadCount ни у одного диалога.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Вкладка «Неотвеченные» (unanswered) задаёт filters.unreadOnly=true (conversation-list.tsx:110-111), и API возвращает только `unreadCount > 0` (conversations/route.ts:32). Как только выбран диалог с unread>0, ChatPane вызывает markRead.mutate (chat-pane.tsx:107-112). onSettled инвалидирует [tg-conversations] (use-mark-read.ts:44-46), и повторный запрос больше не возвращает эту строку. После этого `selected = rows.find(r => r.id === selectedId) ?? null` (telegram-page-client.tsx:71) становится null, ChatPane и правая панель показывают «Выберите диалог». Автовыбор не срабатывает повторно, потому что conv уже есть в URL. Кроме того, при первом входе в раздел эффект на стр. 76-80 выбирает rows[0], и тот сразу помечается прочитанным. Подпись вкладки «Неотвеченные»/«Javobsiz», но фильтр проверяет «не прочитано», а не «нет ответа».

G6-04 P2 · СРЕДНИЙ баг

Кнопка «Шаблоны» в композере вставляет шаблоны уведомлений с неподставленными {{patient.firstName}}, {{appointment.time}}, и пациент получает текст с фигурными скобками

ГДЕ

src/app/[locale]/crm/telegram/_components/message-composer.tsx:305, src/app/[locale]/crm/telegram/_components/message-composer.tsx:777, src/app/api/crm/conversations/[id]/messages/route.ts:193, src/server/notifications/default-templates.ts:58, src/app/api/crm/notifications/templates/route.ts:15

СЦЕНАРИЙ

Регистратор выбирает «Напоминание за 1 день» и жмёт Enter. Пациент получает: «{{patient.firstName}}, напоминаем: завтра в {{appointment.time}} вы записаны к {{appointment.doctor}} в {{clinic.name}}...».

ПОСЛЕДСТВИЯ

Пациенты получают технически сложенные сообщения от имени клиники, возникает путаница со временем приёма, и это выглядит непрофессионально.

ЧТО СДЕЛАТЬ

Перед вставкой подставлять значения (пациент, ближайшая запись, клиника) тем же render(), что и в уведомлениях, и явно пометать поля, для которых нет данных. Либо не показывать в композере шаблоны с полями записи. Язык брать из preferredLang пациента. Ролям без доступа кнопку скрыть или показать понятную ошибку.

КРИТЕРИЙ ПРИЁМКИ

После вставки любого шаблона в поле ввода нет «{{}}». Пациенту с языком UZ вставляется узбекский текст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

TemplatePicker загружает `/api/crm/notifications/templates?channel=TG&limit=50`, то есть шаблоны автоуведомлений (напоминания и т.п.) (message-composer.tsx:777), и onPickTemplate вставляет `tpl.bodyRu/bodyUz` как есть (стр. 305-307). В прямой отправке из чата подстановки нет: route.ts:193-198 передаёт body.body прямо в sendMessage. Тела шаблонов содержат {{patient.firstName}}, {{appointment.date}}, {{appointment.time}}, {{appointment.doctor}}, {{clinic.phone}} (default-templates.ts:58-60). Язык выбирается по локали интерфейса оператора, а не по preferredLang пациента. GET шаблонов разрешён только ADMIN/RECEPTIONIST/CALL_OPERATOR, поэтому врач и медсестра получают 403, а UI показывает «Нет шаблонов».

G6-05 P2 · СРЕДНИЙ баг

Новые входящие в уже открытом чате остаются непрочитанными: бейдж, «Неотвеченные» и счётчик в шапке растут, пока оператор смотрит на переписку

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-pane.tsx:109, src/app/api/telegram/webhook/[clinicSlug]/route.ts:219, src/app/[locale]/crm/telegram/_hooks/use-tg-messages.ts:59

СЦЕНАРИЙ

Регистратор переписывается с пациентом, тот присылает три сообщения подряд. У этого же диалога в списке бейдж «3», он «горячий», у второго регистратора он в «Неотвеченных», в шапке «Telegram 3». Второй регистратор тоже отвечает, и пациент получает два разных ответа.

ПОСЛЕДСТВИЯ

Счётчики врут, операторы отвечают параллельно, приходится каждый раз уходить из чата и возвращаться, чтобы сбросить бейдж.

ЧТО СДЕЛАТЬ

Помечать прочитанным каждое новое входящее в активном диалоге, если вкладка в фокусе, и сбрасывать lastMarkedRef при переходе unread 0→N.

КРИТЕРИЙ ПРИЁМКИ

Пока диалог открыт и вкладка активна, unreadCount остаётся 0 при новых входящих.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Эффект пометки прочитанным делает `if (lastMarkedRef.current === conversationId) return;` (chat-pane.tsx:109), то есть срабатывает только один раз на открытие. Вебхук при каждом входящем делает `unreadCount: { increment: 1 }` (webhook route.ts:219). useTgMessagesRealtime только обновляет сообщения (use-tg-messages.ts:59-72), в прочитанное их никто не переводит.

Открытый чат показывает не последние сообщения: прокрутка остаётся сверху (самые старые из 50) или сохраняет позицию предыдущего диалога

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-pane.tsx:115, src/app/[locale]/crm/telegram/_components/chat-pane.tsx:122, src/app/[locale]/crm/telegram/_components/chat-pane.tsx:312

СЦЕНАРИЙ

Оператор кликает диалог с длинной историей и видит сверху сообщения недельной давности. Последний вопрос пациента («Можно сегодня в 15:00?») за пределами экрана, и оператор отвечает на старое или вообще не замечает новое.

ПОСЛЕДСТВИЯ

Новые вопросы пациентов пропускаются, ответы уходят невпопад, каждый чат приходится прокручивать вручную.

ЧТО СДЕЛАТЬ

При смене conversationId и после первой успешной загрузки принудительно прокручивать к низу (useLayoutEffect по conversationId + isSuccess) и сбрасывать messageCountRef. Как вариант, ремонтировать ChatPane по key.

КРИТЕРИЙ ПРИЁМКИ

Любой диалог (первое и повторное открытие, 50+ сообщений) открывается с последним сообщением внизу без ручной прокрутки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Единственная автопрокрутка — эффект по [messages.length] (chat-pane.tsx:115-129). Он прокручивает вниз только если `nearBottom`, то есть до низа меньше 120px. При первой загрузке scrollTop=0, и для любого чата длиннее экрана условие ложно. messageCountRef при смене диалога не сбрасывается. При переходе между закэшированными диалогами, где по 50 сообщений (это размер страницы), messages.length не меняется, эффект не запускается, и остаётся scrollTop прошлого чата. Других scrollTop/scrollIntoView при открытии в каталоге telegram нет (проверено grep), контейнер (стр. 312-315) не использует flex-col-reverse.

Переход к конкретному диалогу не работает: виджет ресепшн передаёт ?с= вместо ?conv=, а ?conv= из поиска и кнопка «Открыть» в тосте дают пустую панель, если диалога нет на загруженной странице или в текущем фильтре

ГДЕ

src/app/[locale]/crm/reception/_components/tg-preview-widget.tsx:113, src/app/[locale]/crm/telegram/_hooks/use-conversations.ts:86, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:71, src/components/layout/global-search.tsx:508, src/app/[locale]/crm/telegram/_hooks/use-tg-inbox-alerts.ts:102

СЦЕНАРИЙ

На экране ресепшн в виджете Telegram регистратор кликает «Саидова: Можно перенести?». Открывается инбокс с другим, самым свежим диалогом, и он помечается прочитанным, а Саидову приходится искать вручную. Поиск по фамилии давнего пациента открывает пустое окно.

ПОСЛЕДСТВИЯ

Лишние действия на каждом переходе. Непрочитанные чужие диалоги молча помечаются прочитанными, и обращения теряются.

ЧТО СДЕЛАТЬ

Исправить параметр в виджете на conv. В инбоксе, если conv не найден в загруженных строках, догружать диалог через GET /api/crm/conversations/[id] и показывать его, при необходимости сбрасывая фильтры.

КРИТЕРИЙ ПРИЁМКИ

Клик по диалогу в виджете ресепшн открывает именно его. Ссылка ?conv=<id старого диалога> открывает переписку. «Открыть» из тоста при вкладке «В работе» открывает нужный чат.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Инбокс читает только параметр `conv` (use-conversations.ts:86), а виджет на экране ресепшн ведёт на `/crm/telegram?c=\${row.id}` (tg-preview-widget.tsx:113). Получается selectedId=null, срабатывает автовыбор rows[0], и этот диалог ещё и помечается прочитанным. Выбранный диалог ищется только среди загруженных страниц текущего фильтра: `rows.find(...) ?? null` (telegram-page-client.tsx:71), по 50 строк, без догрузки по id. Поэтому ссылка из глобального поиска (global-search.tsx:508) на старый диалог и «Открыть» из тоста

(use-tg-inbox-alerts.ts:102) для диалога вне текущей вкладки (например, бот-диалог при активной «В работе») показывают «Выберите диалог».

G6-08 P2 · СРЕДНИЙ мёртвая механика

Рассылки и автоматические сообщения бота не попадают в переписку: оператор видит ответ пациента, но не видит, на что тот отвечает

ГДЕ

src/server/notifications/adapters/tg-clinic.ts:46, src/server/campaigns/launch.ts:267, src/app/api/crm/conversations/[id]/messages/route.ts:109, src/app/api/telegram/webhook/[clinicSlug]/route.ts:269, src/app/[locale]/crm/telegram/_components/chat-pane.tsx:94

СЦЕНАРИЙ

Админ отправляет рассылку «Скидка 20% на массаж до пятницы» на 800 пациентов. Десятки отвечают «Да, запишите» или «А сколько стоит?». В инбоксе оператор видит только эти ответы, самой рассылки в истории нет. Так же с напоминанием «завтра в 10:00»: пациент пишет «Не смогу», и оператор не понимает, о какой записи речь.

ПОСЛЕДСТВИЯ

Лишние уточнения у пациентов и неверные ответы. Если пациент говорит «мне ничего не приходило», в переписке нет следа отправки.

ЧТО СДЕЛАТЬ

При успешной доставке TG-уведомления или рассылки записывать OUT Message (senderId=null, признак источника campaign/notification) в диалог пациента по его telegramId (find-or-create по externalId) и обновлять lastMessageAt/lastMessageText. В пузыре показывать бейдж «Рассылка/Напоминание».

КРИТЕРИЙ ПРИЁМКИ

После рассылки в чате каждого получателя видно исходящее сообщение с её текстом. Напоминание видно в переписке раньше ответа пациента.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Строки Message создаются только в трёх местах: при отправке из CRM (messages/route.ts:109), во входящем вебхуке и в recordOutgoing бот-FSM (webhook route.ts:242, 269-283), и в чате мини-аппа (grep `message.create`). TelegramClinicAdapter.send (tg-clinic.ts:46-53) только вызывает sendMessage: он не создаёт Message и не обновляет Conversation.lastMessageAt. Рассылка (launch.ts:267 создаёт NotificationSend, дальше воркер и адаптер), а также напоминания и памятки уходят пациенту, но в историю диалога, которую показывает ChatPane (useTgMessages), не попадают.

G6-09 P3 · НИЗКИЙ мёртвая механика

«+ Пополнить баланс» и меню «Ещё → Случаи / Платежи / Документы» в панели чата открывают только обзор карточки: параметры ?action=topup и ?tab= никто не читает

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:431, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:553, src/app/[locale]/crm/patients/[id]/_components/patient-card-client.tsx:83, src/app/[locale]/crm/patients/[id]/_components/patient-card-client.tsx:93

СЦЕНАРИЙ

Регистратор в чате жмёт «Ещё → Платежи», чтобы проверить оплату пациента, попадает на «Обзор» и ищет вкладку вручную. «+» у баланса ничего не пополняет.

ПОСЛЕДСТВИЯ

Лишние клики, а кнопка «Пополнить» обещает функцию, которой нет.

ЧТО СДЕЛАТЬ

Читать ?tab= в PatientCardClient. Убрать «Пополнить» до появления функции баланса. Использовать ссылки с учётом локали.

КРИТЕРИЙ ПРИЁМКИ

«Ещё → Платежи» открывает вкладку «Платежи», кнопки «Пополнить» нет или она запускает рабочий сценарий.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Ссылки ведут на `/crm/patients/\${id}?action=topup` (без префикса локали, стр. 431) и на `?tab=cases|payments|documents` (стр. 553-571). PatientCardClient стартует с `useState<TabKey>("overview")` (стр. 83) и обрабатывает только hash `#case-` (стр. 93). useSearchParams в patients/[id] не используется нигде (grep),

обработчика topup нет. Баланс при этом никогда не пишется (#138), поэтому рядом с кнопкой всегда «0 сум».

G6-10 РЗ · НИЗКИЙ баг

«Авто-сообщения»: при ошибке загрузки спиннер крутится бесконечно, текст «Не удалось загрузить» никогда не показывается

ГДЕ

src/app/[locale]/crm/telegram/_components/auto-messages-dialog.tsx:144, src/app/[locale]/crm/telegram/_components/auto-messages-dialog.tsx:148

СЦЕНАРИЙ

/api/crm/settings/auto-messages вернул 500 или 403. Админ открывает «Авто-сообщения» и видит вечный спиннер без объяснения.

ПОСЛЕДСТВИЯ

Админ не понимает, что настройки не загрузились, и ждёт.

ЧТО СДЕЛАТЬ

Проверять isError раньше, чем !draft.

КРИТЕРИЙ ПРИЁМКИ

При ошибке API в диалоге показывается текст ошибки.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Условие `query.isLoading || !draft` проверяется раньше `query.isError` (стр. 144-151). Если запрос упал, draft так и остаётся null (он заполняется только из query.data, стр. 62-64), поэтому до ветки loadError код не доходит.

G6-11 РЗ · НИЗКИЙ баг

«Быстрые действия → Записать на приём» в композере ничего не делает, если правая панель скрыта

ГДЕ

src/app/[locale]/crm/telegram/_components/message-composer.tsx:609, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:160, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:183

СЦЕНАРИЙ

Оператор скрыл правую панель, чтобы расширить чат, жмёт « → Записать на приём». Поповер закрывается, и ничего не происходит.

ПОСЛЕДСТВИЯ

Функция выглядит сломанной, оператору приходится записывать пациента через другой экран.

ЧТО СДЕЛАТЬ

Перенести NewAppointmentDialog в ChatPane/page client или открывать панель перед отправкой события.

КРИТЕРИЙ ПРИЁМКИ

При скрытой панели «Записать на приём» открывает диалог записи.

ДОКАЗАТЕЛЬСТВО В КОДЕ

onBook отправляет window-событие dispatchOpenAppointment и закрывает поповер (message-composer.tsx:603-611). Слушает это событие только LinkedPatientRail (useOpenAppointment, chat-right-rail.tsx:160), а при railOpen=false правая панель не монтируется (telegram-page-client.tsx:183-190). В итоге диалог записи не открывается, и никакой реакции нет.

G6-12 РЗ · НИЗКИЙ баг

«Риск неявок» в панели чата занижен: процент считается от всех записей пациента, включая будущие и отменённые

ГДЕ

src/app/api/crm/patients/[id]/stats/route.ts:47, src/app/api/crm/patients/[id]/stats/route.ts:59, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:828

СЦЕНАРИЙ

У пациента 1 неявка из 2 прошедших визитов (реально 50%), плюс 4 отменённые и 2 будущие записи. Панель показывает 13% и «Средний» вместо «Высокий», и оператор не просит у него подтверждения.

ПОСЛЕДСТВИЯ

Неверная оценка риска неявки у ненадёжных пациентов.

ЧТО СДЕЛАТЬ

В знаменателе считать только прошедшие визиты (COMPLETED + NO_SHOW).

КРИТЕРИЙ ПРИЁМКИ

Для пациента с 1 неявкой из 2 прошедших визитов показывается 50% «Высокий».

ДОКАЗАТЕЛЬСТВО В КОДЕ

groupBy по статусу берётся по всем записям пациента (stats/route.ts:45-49), totalAppointments суммирует все статусы (стр. 59), включая будущие BOOKED/CONFIRMED и CANCELLED. noShowPct = NO_SHOW/total, и панель переводит его в «Низкий/Средний/Высокий» (chat-right-rail.tsx:828-836). Этот endpoint используется только правой панелью Telegram.

G6-13 РЗ · НИЗКИЙ мокап / заглушка

«Связанные темы» считаются по русским подстрокам: узбекские сообщения не учитываются, «сум» ловит «сумка» и «сумма», клик по теме часто ничего не находит

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:782, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:796, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:736, src/app/[locale]/crm/telegram/_components/chat-pane.tsx:155

СЦЕНАРИЙ

Пациент пишет «Narxi qancha? Qabulga yozilsam bo'ladimi?», и карточка тем пустая. Другой пациент спрашивает «какая сумма?», карточка показывает «Стоимость 1», но по клику ничего не подсвечивается.

ПОСЛЕДСТВИЯ

Виджет выглядит как аналитика, но выдаёт случайные числа и занимает место в панели.

ЧТО СДЕЛАТЬ

Убрать карточку или заменить реальными данными (теги, категории обращений). Если оставлять, то с двуязычными словарями словоформ и поиском по тому же набору слов.

КРИТЕРИЙ ПРИЁМКИ

Карточки нет, либо узбекские сообщения учитываются и клик всегда подсвечивает найденное сообщение.

ДОКАЗАТЕЛЬСТВО В КОДЕ

countTopics ищет в тексте подстроки «запись»/«приём»/«приём», «невролог», «цен»/«стоимость»/«сум» (стр. 796-808), только по загруженным сообщениям и включая исходящие от операторов. Узбекских слов (narx, qabul, yozil) нет. Поиск по клику использует только одно слово TOPIC_TERMS, например «цен» (стр. 782-786, 736). Если тема насчиталась по «сум»/«стоимость», useChatFind ничего не находит и ничего не происходит (chat-pane.tsx:155-175). «цен» при этом совпадает с «оценка» и «лицензия».

G6-14 РЗ · НИЗКИЙ целостность данных

«Создать пациента» в чате молча привязывает диалог к существующей (в том числе удалённой) карточке с тем же телефоном; отвязать нельзя, ошибки показываются сырыми кодами

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1218, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1237, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1264, src/app/api/crm/patients/route.ts:165, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:142

СЦЕНАРИЙ

Оператор вводит «Алиев Жасур» и номер с одной ошибкой, который совпадает с номером пациентки Рахимовой (или удалённой карточки). Тост «Пациент привязан», и чат Алиева теперь связан с картой Рахимовой: в панели её LTV и визиты, «Записать» создаёт запись на Рахимову, врачу Рахимовой видна переписка Алиева. Исправить это из интерфейса нельзя.

ПОСЛЕДСТВИЯ

Переписки и записи привязываются не к тем людям, чужие данные видны в панели и у врача, чистить приходится вручную в БД.

ЧТО СДЕЛАТЬ

При 409 показывать найденного пациента (ФИО, год рождения) и спрашивать «Привязать к этой карте?». Удалённые карточки исключать или возвращать для них отдельную причину. Добавить действие «Отвязать/сменить пациента» для привязанного диалога. Локализовать ошибки.

КРИТЕРИЙ ПРИЁМКИ

Ввод телефона существующего пациента показывает его ФИО и ждёт подтверждения. Удалённый пациент не

подставляется. У привязанного диалога есть «Отвязать». При неверном номере показывается понятный текст.

ДОКАЗАТЕЛЬСТВО В КОДЕ

На 409 с reason=phone_already_exists клиент берёт j.patientId и сразу делает PATCH диалога с этим patientId (chat-right-rail.tsx:1218-1248), затем показывает тост «patientLinked». Чья это карточка, не показывается, введённое ФИО отбрасывается. На сервере поиск дубля — `prisma.patient.findFirst({ where: { phoneNormalized } })` без фильтра deletedAt (patients/route.ts:165), а в Prisma-расширении мягкого удаления нет (grep по src/lib). Форма есть только у непривязанного диалога (стр. 142-147), у привязанного нет действия «Отвязать/сменить пациента». Ошибки выводятся как `err.message`: «ValidationError» при неверном номере, «Forbidden» у NURSE/CALL_OPERATOR (POST разрешён только ADMIN/RECEPTIONIST/DOCTOR, route.ts:138).

G6-15 РЗ · НИЗКИЙ баг

Быстрые ответы: {{patient.firstName}} пустой в непривязанных диалогах (приходит «, здравствуйте!»), язык выбирается по интерфейсу оператора, данные клиники могут подставиться пустыми

ГДЕ

src/app/[locale]/crm/telegram/_components/message-composer.tsx:866, src/app/[locale]/crm/telegram/_components/message-composer.tsx:852, src/app/[locale]/crm/telegram/_components/message-composer.tsx:858, src/app/[locale]/crm/telegram/_lib/placeholders.ts:19

СЦЕНАРИЙ

Ответ «{{patient.firstName}}, здравствуйте! Клиника {{clinic.name}}, телефон {{clinic.phone}}» в новом диалоге из бота превращается в «, здравствуйте! Клиника , телефон ».

ПОСЛЕДСТВИЯ

Пациенты получают неаккуратные сообщения без имени и контактов клиники.

ЧТО СДЕЛАТЬ

Использовать имя из Telegram (contactFirstName) как запасное, язык брать по preferredLang пациента, не давать вставлять ответ до загрузки данных клиники, подсвечивать незаполненные подстановки.

КРИТЕРИЙ ПРИЁМКИ

В непривязанном чате подставляется имя из Telegram, пока данные клиники не загружены, пункты не кликабельны.

ДОКАЗАТЕЛЬСТВО В КОДЕ

`const name = conversation.patient?.fullName ?? ""` (стр. 866). Большинство бот-диалогов не привязаны к пациенту (#215), поэтому firstName = "", и запасного варианта с contactFirstName из Telegram нет. Переключатель RU/UZ по умолчанию ставится по локали интерфейса (стр. 852-854), а не по preferredLang пациента. Данные клиники загружаются только после открытия поповера (useClinicInfo(open), стр. 858). Если список быстрых ответов уже в кэше, клик до загрузки /api/crm/clinic подставляет пустые clinic/phone/address (стр. 867-876).

G6-16 РЗ · НИЗКИЙ мокап / заглушка

Карточка «AI-ассистент» в чате — это эвристика по трём русским словам с зашитой «уверенностью 92%»; флаг AI_ENABLED делает её «живой», и пациенту будут уходить инструкции для оператора; бейдж «верифицирован» никогда не показывается

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:586, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:595, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:667, src/lib/ai-enabled.ts:11, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:217

СЦЕНАРИЙ

После включения AI_ENABLED ради других AI-функций оператор видит «AI-ассистент · Уверенность 92%», нажимает рекомендацию, и пациенту уходит «Предложить утренний слот для удобства.»

ПОСЛЕДСТВИЯ

Выдуманные показатели выдаются за AI, пациентам уходят бессмысленные сообщения.

ЧТО СДЕЛАТЬ

Удалить карточку или подключить её к реальному API, убрать константную уверенность, убрать isVerified или реализовать его.

КРИТЕРИЙ ПРИЁМКИ

В коде нет константы уверенности. При AI_ENABLED=true карточка либо берёт данные из API, либо отсутствует.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Комментарий в коде прямо говорит: «Crude topic detection... Real AI service ships separately» (стр. 586-588). `const confidence = 92` (стр. 595). `deriveAiRecs` всегда добывает до трёх рекомендаций-заглушек (стр. 690-695). Рекомендации — строки вроде «Предложить утренний слот для удобства.», то есть задачи для оператора, и они вставляются в композер как текст пациенту (`dispatchComposerInsert`, стр. 591). Сейчас всё это приглушено через `InDevelopment`, потому что `AI_ENABLED=false` (`ai-enabled.ts:11`). Этот флаг — единый выключатель для возврата настоящего AI, поэтому при его включении оживёт и эта подделка. Поля `isVerified` (стр. 70, 217, 315) нет ни в одном API и в схеме (греп), значит бейдж недостижим.

G6-17 P3 · НИЗКИЙ мокап / заглушка

Карточка «Статистика Telegram · за 30 дней» в панели чата считается по подгруженным сообщениям; «Ответы бота» включают ответы операторов; «Среднее время ответа» искажает автоприветствие

ГДЕ

`src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:924`, `src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:942`, `src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:974`, `src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1067`, `src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1075`

СЦЕНАРИЙ

У диалога 300 сообщений за 2 месяца. Карточка показывает «Сообщений 50», «Ответы бота 24» (это ответы регистратора), «Среднее время ответа 3с» (бот мгновенно поздоровался). Если прокрутить чат вверх, цифры меняются.

ПОСЛЕДСТВИЯ

Руководитель по этим цифрам делает неверные выводы о скорости ответа операторов.

ЧТО СДЕЛАТЬ

Считать на сервере за реальные 30 дней, разделять бот и оператора по `senderId`, время ответа считать до первого ответа оператора, локализовать единицы. Либо убрать карточку.

КРИТЕРИЙ ПРИЁМКИ

Цифры не меняются от прокрутки и совпадают с SQL-подсчётом за 30 дней, ответы операторов не попадают в «Ответы бота».

ДОКАЗАТЕЛЬСТВО В КОДЕ

`messages` — это `flattenMessages` загруженных страниц, по 50 штук (`use-tg-messages.ts:31-33`), фильтра по 30 дням нет, хотя заголовок `t('period')` = «за 30 дней» (стр. 974). `outbound` считает все OUT, включая сообщения операторов с `senderId`, но подписан «Ответы бота» (стр. 925, 942-947). `computeAvgReplySeconds` связывает каждое IN со следующим OUT, в том числе с автоприветствием бота, которое вебхук пишет сразу (`recordOutgoing, senderId=null`) (стр. 1075-1095). `formatDuration` выводит английские «s/m/h» при любой локали (стр. 1067-1073). При прокрутке чата вверх догружаются страницы, и цифры меняются.

G6-18 P3 · НИЗКИЙ UX

Колл-оператор и медсестра видят в Telegram-чате «Создать пациента» и «Записать», но API отвечает 403, и в тосте появляется «Forbidden»

ГДЕ

`src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:474`, `src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1305`, `src/app/api/crm/patients/route.ts:138`, `src/app/api/crm/appointments/route.ts:161`, `src/app/api/crm/conversations/route.ts:13`

СЦЕНАРИЙ

Колл-оператор отвечает пациенту в Telegram, жмёт «Создать пациента», получает тост «Forbidden» и не понимает, что не так.

ПОСЛЕДСТВИЯ

Колл-оператор не может выполнить основную задачу из чата и не понимает причину.

ЧТО СДЕЛАТЬ

Дать `CALL_OPERATOR` права на создание пациента и записи (по смыслу роли это нужно) либо скрыть кнопки для ролей без прав.

КРИТЕРИЙ ПРИЁМКИ

Для роли без прав кнопок нет, для роли с правами создание работает.

ДОКАЗАТЕЛЬСТВО В КОДЕ

API инбокса разрешено NURSE и CALL_OPERATOR (conversations/route.ts:13), страница /crm/telegram по роли не ограничена. При этом POST /api/crm/patients и POST /api/crm/appointments разрешены только ADMIN/RECEPTIONIST/DOCTOR (patients/route.ts:138, appointments/route.ts:161). Кнопки в панели (стр. 474-477, 1305-1319) и в композере роль не проверяют.

G6-19 P3 · НИЗКИЙ баг

Окно рассылки пишет «Рассылка завершена» и перестаёт обновляться, пока часть сообщений ещё в статусе SENDING; счётчик «х/у» так и не доходит до конца

ГДЕ

src/app/[locale]/crm/telegram/_components/broadcast-dialog.tsx:167, src/app/[locale]/crm/telegram/_hooks/use-broadcast.ts:153, src/app/api/crm/campaigns/broadcasts/route.ts:134, src/server/notifications/record-delivery.ts:188

СЦЕНАРИЙ

Рассылка на 500 человек. Когда в очереди не осталось QUEUED, а последние ~10 сообщений ещё отправляются, окно показывает «Рассылка завершена 490/500» и больше не обновляется.

ПОСЛЕДСТВИЯ

Админ видит недостоверный итог рассылки и может запустить её повторно.

ЧТО СДЕЛАТЬ

Считать QUEUED+SENDING как «в очереди» и опрашивать до campaign.status=DONE.

КРИТЕРИЙ ПРИЁМКИ

«Завершена» появляется только когда отправлено + ошибки = всего или кампания в статусе DONE.

ДОКАЗАТЕЛЬСТВО В КОДЕ

В окне pending = sbs.QUEUED, a done = total>0 && pending===0 (broadcast-dialog.tsx:167-169). Опрос прекращается, когда QUEUED=0 (use-broadcast.ts:150-154). Строки в SENDING (воркер уже взял их в работу) при этом не учитываются нигде. Сервер же считает SENDING незавершёнными (record-delivery.ts:188). История рассылок тоже выводит «done», как только queued==0 (broadcasts/route.ts:134).

G6-20 P3 · НИЗКИЙ UX

После «Открыть в Telegram» из карточки пациента инбокс остаётся отфильтрованным по одному пациенту: фильтр не виден и снять его нельзя

ГДЕ

src/app/[locale]/crm/telegram/_hooks/use-conversations.ts:47, src/app/[locale]/crm/telegram/_components/conversation-list.tsx:110, src/app/[locale]/crm/telegram/_components/conversation-list.tsx:250, src/app/[locale]/crm/patients/[id]/_components/patient-hero.tsx:327

СЦЕНАРИЙ

Регистратор открыл чат пациента из карточки и продолжает работать в инбоксе. Во всех вкладках виден только этот диалог, обращения других пациентов видны лишь в тостах, и у сотрудника складывается впечатление «Телеграм не работает».

ПОСЛЕДСТВИЯ

Обращения других пациентов пропадают из списка, пока сотрудник не догадается уйти через меню.

ЧТО СДЕЛАТЬ

Показывать чип «Пациент: ФИО *» и сбрасывать patientId при переключении вкладок или поиске.

КРИТЕРИЙ ПРИЁМКИ

При фильтре по пациенту виден чип, клик по нему возвращает все диалоги.

ДОКАЗАТЕЛЬСТВО В КОДЕ

patientId читается из URL (use-conversations.ts:47), и в комментарии прямо сказано «no UI chip». setTab меняет только mode/unreadOnly (conversation-list.tsx:110-114), подсказка в пустом состоянии есть только для фильтра «Мои» (стр. 250-258). Ссылки из карточки пациента ведут на ?patientId= (patient-hero.tsx:327, patient-right-rail.tsx:155).

Предпросмотр рассылки не совпадает с тем, что придёт пациенту: **жирный**** показан жирным (в Telegram придут звёздочки), HTML-теги наоборот, данные клиники — заглушки «ул. Примерная, 1», неизвестные {{...}} видны в превью, а пациенту уходят пустыми**

ГДЕ

src/app/[locale]/crm/telegram/_components/broadcast-preview.tsx:66, src/app/[locale]/crm/telegram/_components/broadcast-preview.tsx:138, src/app/[locale]/crm/telegram/_components/message-bubble.tsx:38, src/server/notifications/adapters/tg-clinic.ts:47, src/server/notifications/template.ts:59

СЦЕНАРИЙ

Админ пишет «****Акция**** до {{appointment.date}}, звоните {{clinic.phone}}». В превью видит жирное «Акция», «{{appointment.date}}» и телефон-заглушку. Пациенты получают «****Акция**** до , звоните +998...».

ПОСЛЕДСТВИЯ

Админ не может проверить, что реально уйдёт сотням пациентов, и кривые рассылки уходят массово.

ЧТО СДЕЛАТЬ

Рендерить превью той же функцией, что и сервер (render + HTML-режим), подставлять реальные данные клиники, предупреждать о неизвестных плейсхолдерах и блокировать с ними отправку.

КРИТЕРИЙ ПРИЁМКИ

Для текста с ****x****, **y**, {{clinic.phone}} и {{appointment.date}} превью совпадает с сообщением, которое пришло тестовому получателю.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Превью рисуется через MessageBubble/mdLite, где работают ****bold****, **italic** и автоссылки (message-bubble.tsx:38-51). Доставка идёт с parse_mode: "HTML" (tg-clinic.ts:47): markdown там не разбирается, а **** разбирается. Плейсхолдеры клиники в превью заполняются i18n-заглушками «Клиника», «+998 90 000-00-00», «ул. Примерная, 1» (broadcast-preview.tsx:66-72), хотя настоящие данные доступны через /api/crm/clinic. fillPlaceholders знает только 5 ключей и оставляет остальные как есть, а серверный render() заменяет неизвестные ключи пустой строкой (template.ts:59-63).

Пустые диалоги (открытые из мини-аппа или карточки пациента без сообщений) висят сверху инбокса и открываются автоматически; счётчики «Все/Горячие/Тёплые/Холодные» считают только загруженные строки

ГДЕ

src/app/api/crm/conversations/route.ts:93, src/server/conversations/find-or-create.ts:136, src/app/api/miniapp/conversations/find-or-create/route.ts:26, src/app/[locale]/crm/telegram/_components/telegram-page-client.tsx:77, src/app/[locale]/crm/telegram/_components/conversation-list.tsx:107

СЦЕНАРИЙ

Каждый пациент, который нажал «Чат» в мини-аппе и ничего не написал, и каждое «Открыть в Telegram» из карточки создают диалог без сообщений. Все такие диалоги с подписью «Нет сообщений» стоят над живыми переписками, при входе в раздел открывается пустой чат, а на 400 диалогов показано «Все 50».

ПОСЛЕДСТВИЯ

Живые обращения опускаются вниз списка, оператор тратит время на пустые чаты, счётчики ошибочные.

ЧТО СДЕЛАТЬ

Сортировать `[{ lastMessageAt: { sort: 'desc', nulls: 'last' } }, { id: 'desc' }]` или по coalesce(lastMessageAt, createdAt), курсор строить по этой паре. Не выбирать автоматически диалог без сообщений. Счётчики получать с сервера или подписывать «из загруженных».

КРИТЕРИЙ ПРИЁМКИ

Диалоги без сообщений стоят ниже диалогов с сообщениями, при входе открывается последний живой диалог, счётчик «Все» совпадает с числом диалогов в БД.

ДОКАЗАТЕЛЬСТВО В КОДЕ

Conversation.lastMessageAt допускает NULL (schema.prisma), и холодный старт диалога в findOrCreateConversation (find-or-create.ts:136-146) его не заполняет. Эту функцию вызывают мини-апп и кнопки «Открыть в Telegram». Список сортируется `orderBy: { lastMessageAt: "desc" }` без nulls:'last' и без второго ключа (route.ts:93), а в Postgres при DESC значения NULL идут первыми. Страница автоматически выбирает rows[0]

(telegram-page-client.tsx:77-79). Счётчик «Все» равен rows.length (≤50 на загруженную страницу), горячие/тёплые/холодные тоже считаются по загруженным строкам (conversation-list.tsx:95-108), и в UI это никак не обозначено.

G6-23 РЗ · НИЗКИЙ бар

Рассылка уходит пациентам без согласия: аудитория игнорирует consentMarketing, поэтому галочка «Согласен получать уведомления» в мини-аппе и «Согласие на рассылки: Нет» в карточке ничего не меняют

ГДЕ

src/server/campaigns/audience.ts:69, src/server/notifications/consent-gate.ts:43, src/app/c/[slug]/my/_components/profile-screen.tsx:139, src/app/[locale]/crm/patients/[id]/_components/patient-info-panel.tsx:128, src/app/api/crm/patients/route.ts:202, src/app/[locale]/crm/telegram/_components/broadcast-preview.tsx:101

СЦЕНАРИЙ

Пациентка снимает в мини-аппе галочку «Согласен получать уведомления» и сохраняет. Через неделю админ отправляет рассылку «Все», и ей приходит реклама. В её карточке в CRM при этом написано «Согласие на рассылки: Нет».

ПОСЛЕДСТВИЯ

Рекламные сообщения уходят без согласия: жалобы, блокировки бота и регуляторный риск по персональным данным. Счётчик «Получат» вводит админа в заблуждение.

ЧТО СДЕЛАТЬ

Выбрать один источник правды. Либо в marketing-рейте и в превью считать consentMarketing=false отказом (отдельная строка «Без согласия»), либо убрать галочку согласия из мини-аппа и карточки и перенести её значение в marketingOptOut.

КРИТЕРИЙ ПРИЁМКИ

Пациент со снятой галочкой согласия не входит в «Получат» в превью и не получает рассылку. Значения в карточке и в аудитории рассылки совпадают.

ДОКАЗАТЕЛЬСТВО В КОДЕ

filterEligible передаёт в isAllowedToReceive только marketingOptOut (audience.ts:69-76), а рейт отсекает только `marketingOptOut === true` (consent-gate.ts:43). Поле consentMarketing (согласие, при создании пациента в CRM по умолчанию false, patients/route.ts:202) нигде в отправке не проверяется. В мини-аппе два чекбокса. Первый, «Согласен получать уведомления», пишет только consentMarketing (profile-screen.tsx:139, 56). В CRM карточка показывает «Согласие на рассылки: Да/Нет» по consentMarketing (patient-info-panel.tsx:127-128), а превью рассылки при этом считает таких пациентов в «Получат».

G6-24 РЗ · НИЗКИЙ мёртвая механика

Теги в правой панели чата ни на что не влияют: пишутся в Conversation.tags, но не фильтруют инбокс и не доступны в «Рассылке → По тегам» (там Patient.tags); при быстром добавлении теги теряются

ГДЕ

src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1113, src/app/[locale]/crm/telegram/_components/chat-right-rail.tsx:1154, src/app/[locale]/crm/telegram/_hooks/use-conversation-meta.ts:83, src/server/schemas/conversation.ts:23, src/server/campaigns/audience.ts:118, src/app/[locale]/crm/telegram/_hooks/use-broadcast.ts:237

СЦЕНАРИЙ

Оператор помечает 30 чатов тегом «ботокс», чтобы сделать по ним рассылку. В «Рассылке → По тегам» такого тега нет, а ввод вручную даёт 0 получателей. Другой случай: оператор вводит «VIP» + Enter и сразу «повтор» + Enter, в итоге остаётся только «повтор». Если два оператора правят теги одновременно, побеждает последний.

ПОСЛЕДСТВИЯ

Сегментация, которую операторы делают руками, пропадает впустую, и рассылки по ней невозможны.

ЧТО СДЕЛАТЬ

Решить, чей это атрибут. Для привязанных диалогов писать теги в Patient.tags, либо добавить фильтр инбокса и сегмент рассылки по Conversation.tags. Сохранять теги операциями добавить/удалить на сервере вместо замены массива, блокировать Enter во время сохранения.

КРИТЕРИЙ ПРИЁМКИ

Тег, добавленный в чате, находится в фильтре инбокса или в подсказках «По тегам», и рассылка по нему доходит до этих пациентов. Два быстрых добавления сохраняют оба тега.

ДОКАЗАТЕЛЬСТВО В КОДЕ

grep показывает, что Conversation.tags читает только TagsCard. В QueryConversationSchema (conversation.ts:23-37) нет фильтра по тегам. Сегмент рассылки kind=tag фильтрует `where.tags = { hasSome }` по Patient (audience.ts:118-121), подсказки берутся из /api/crm/patients/stats → topTags по Patient.tags (use-broadcast.ts:237). useUpdateConversationMeta не делает оптимистичного обновления (стр. 83), а commit собирает массив из `conversation.tags` из кэша списка (chat-right-rail.tsx:1113-1118). Enter (стр. 1154-1159) не блокируется во время сохранения, и PATCH заменяет массив целиком.

G6-25 РЗ · НИЗКИЙ переводы

Центр уведомлений показывает тексты с HTML-сущностями («G'ulom», «"..."») и сырые значения статусов и каналов (SENDING, DONE, CANCELLED, TG)

ГДЕ

src/server/notifications/template.ts:59, src/server/campaigns/launch.ts:105, src/app/[locale]/crm/notifications/_components/notifications-details-rail.tsx:172, src/app/[locale]/crm/notifications/_components/notifications-activity-list.tsx:135, src/app/[locale]/crm/notifications/_components/campaigns-list.tsx:149, src/app/[locale]/crm/notifications/_components/campaigns-list.tsx:136

СЦЕНАРИЙ

Регистратор открывает уведомление пациента «Abdullayev G'ulom» и видит «G'ulom, напоминаем...». В списке кампаний статусы «SENDING», «CANCELLED» без перевода.

ПОСЛЕДСТВИЯ

Персонал видит «битые» тексты и не может с уверенностью сказать, что пришло пациенту.

ЧТО СДЕЛАТЬ

Хранить неэкранированный текст и экранировать при отправке либо декодировать сущности при показе, перевести статусы и сегменты.

КРИТЕРИЙ ПРИЁМКИ

В карточке уведомления «G'ulom» показывается без «'», статусы кампаний переведены на русский и узбекский.

ДОКАЗАТЕЛЬСТВО В КОДЕ

render() экранирует значения плейсхолдеров как HTML (template.ts:59-63), и уже экранированный текст сохраняется в NotificationSend.body (launch.ts:105, триггеры используют тот же render). Правая панель и лента выводят `{row.body}` как обычный текст (details-rail.tsx:171-173, activity-list.tsx:134-136), поэтому апостроф в узбекских именах показывается как «'». CampaignsList выводит `{row.status}` как enum (стр. 149), в колонке сегмента у всех рассылок, кроме dormant, стоит «—» (стр. 26-31, 136), канал показан как «TG».

Приложение А. Отклонено проверкой

Находки, которые проверяющий опроверг по коду. Приведены, чтобы было видно, что проверялось.

- **drug-check не проверяет связь врача с пациентом: любой врач, медсестра или админ клиники может выяснять аллергии и пол/возраст любого пациента**

Новой утечки нет: аллергии любого пациента клиники и так открыты без проверки связи. GET /api/crm/patients/[id]/allergies (allergies/route.ts:31-45) доступен ADMIN/RECEPTIONIST/DOCTOR/NURSE/CALL_OPERATOR, GET /api/crm/patients/[id] тоже (roles там же, пол и дата рождения). drug-check (роли ADMIN/DOCTOR/NURSE) раскрывает не больше, чем уже доступно этим ролям.

- **После отката визита, подписанного больше 24 ч назад, экран приёма выглядит редактируемым, но каждое сохранение отклоняется**

Экран приёма работает только с сегодняшними записями: useDoctorQueue берёт from/to за сегодня (use-doctor-queue.ts:53-83), pick и inProgress ищутся только в этой очереди (reception-context.tsx:81,133-145). Визит недельной давности после отката на экран приёма не попадёт. А сегодняшний визит не может быть впервые подписан больше 24 ч назад, так что сценарий недостижим.

- **Дедупликация сообщений по (clinicId, message_id) склеивает разные чаты: входящие сообщения пациентов молча теряются, а доставленные ответы из CRM помечаются как FAILED**

Код описан верно (schema.prisma:2509 @@unique([clinicId, externalId]); webhook route.ts:239-257 глотает P2002 после upsert с unreadCount+1 на 216-222; messages/route.ts:204-219 ставит FAILED при ошибке update). Но ключевая посылка неверна: в личных чатах message_id, который видит бот, берётся из общего «ящика» сообщений аккаунта бота (MTPROTO message box общий для всех приватных чатов и обычных групп; поэтому messages.deleteMessages для них принимает id без peer). Входящие и исходящие во всех ли

- **fix-double-inprogress.ts принудительно закрывает живые визиты и создаёт реальным пациентам фиктивные оплаты PAID со случайным способом**

Сам скрипт делает то, что описано (fix-double-inprogress.ts:32-83: окно по UTC, фильтра по демо нет, Payment PAID со случайным method). Но в текущем коде сценарий «пациента отправили на ЭКГ, врач начал следующего» заблокирован. Приложение не даёт врачу вторую IN_PROGRESS: findOtherActiveVisit (src/server/appointments/active-visit.ts:12-28, без ограничения по дате) проверяется при старте в PATCH /api/crm/appointments/[id] (route.ts:521-537), при возврате COMPLETED→IN_PROGRESS (route.ts:184-198, 3

Приложение В. Покрытие

Что каждый аудитор реально прочитал и что признал непокрытым.

Экран приёма врача (заключение, диагноз, назначения, рекомендации, подпись)

Прочитано полностью: `src/app/api/crm/visit-notes/route.ts`, `[id]/route.ts`, `[id]/finalize/route.ts`, `[id]/amendments/route.ts`, `[id]/previous/route.ts`, `[id]/send-telegram/route.ts`, `[id]/print/route.ts` (все 1584 строки); `src/server/visit-notes/*` (`conclusion-pdf`, `edit-window`, `prescription-diff`, `previous-visit`, `render-handout`); `src/server/cds/drug-check.ts`; `src/server/prescriptions/prescribe.ts`; `src/server/prescription/cipher-fields.ts`; `src/lib/catalogs/conclusion-parse.ts`, `brand-match.ts`, `handout-composer.ts`, `prescription-format.ts`, `treatment-diff.ts`; `src/app/api/crm/cds/drug-check`, `cds-overrides`, `protocols` (`+ [id]`); `src/server/schemas/visit-note.ts`, `protocol.ts`, `cds-overrides.ts`. Страница и компоненты `reception`: `page.tsx`, `reception-context`, `use-visit-note`, `use-loud-patch`, `use-cds*`, `use-clinical-protocols`, `use-doctor-queue`, `use-previous-visit`, `use-frequent-drugs`, `use-drug-search`, `use-doctor-favorites`, `use-patient-history`, `use-patient-diagnoses`, `use-reception-ai`; компоненты `visit-action-bar`, `notes-editor-panel`, `structured-fields-panel`, `prescription-constructor`, `advice-panel`, `cds-warnings-card`, `parsed-from-text-card`, `apply-protocol-dialog`, `active-patient-card`, `editable-phone`, `session-tabs/tab-content`, `diagnosis-history-card`, `active-ai-rail`, `ai-summary-panel`; частично `catalog-drawer`, `icd-catalog-drawer`. `_components`: `diagnosis-follow-up-cards`, `telegram-send-panel` полностью; `doctor-sidebar`, `doctor-search`, `document-edit-dialogs` только бегло. Чтобы проследить потоки, выходил за зону: воркер `visit-note-handout.ts` (рендер PDF и мост напоминаний), откат визита в `appointments/[id]/route.ts`, `drugs/[id]/photo`, `documents route` и `file-прокси`, `miniapp visit-summary`, `conclusion-detail`, `tenant-extension` (`src/lib/prisma.ts`), `api-handler`, `tenant-allowlist`. `i18n`: проверил, что статические и динамические ключи зоны есть в `ru` и `uz` (скрипт), расхождений нет. НЕ разбирал детально: осиротевшие диалоги (`e-prescription`, `sick-leave`, `referral`, `lab-order`, `save-protocol`; установил только, что они нигде не подключены), `drug-detail.tsx`, `last-visit-card`, `last-diagnosis-card`, `use-lab-catalog/use-clinical-forms/use-referrals/use-handouts/use-diagnosis-guide`, `atc-groups.ts`, маршруты каталогов (`/api/crm/catalogs/*`), `/v/[token]`, воркер `medication-reminder` (кроме условия `remindersEnabled`). Тесты, сборку и рантайм не запускал. Выводы о приватности бакета `MinIO` для прямых `<img>` по фото упаковки не включал в находки: это нельзя проверить статически, в коде есть противоречивые признаки.

Остальной кабинет врача

Прочитано полностью: все роуты `src/app/api/crm/doctors/me/**` (`today`, `schedule`, `patients`, `patient-segments`, `sidebar-stats`, `labs POST/PATCH`, `patients/[id]/visits`, `summary`, `diagnoses`, `visits/export`, `reminders` + `[id]`, `profile`, `signature`, `notification-prefs`, `security-summary`, `presets` + `[id]`, `analytics`, `frequent-drugs`, `conversations/find-or-create`); `labs/unread` и `patients/[id]/labs[documents]prescriptions` — просмотрены частично (проверка доступа и выборки). `src/lib/doctor-*.ts` целиком. `layout.tsx`, `page.tsx`, `_ROADMAP.md` (сверка обещаний: ссылка `security-tab` «FALSE ALARM» и тезис про проху-гейт оказались неверны). `my-day`: все компоненты и хуки. `schedule/agenda-shell` целиком. `patients`: `page`, `context`, `hooks`, `header`, `filters`, `pagination`, `ai-assistant-panel`, `patients-table`, `selected-patient-card`, `segmentation-card` (частично), `[id]/patient-detail`, `overview-section`, `visits-section` (частично). `conclusions`: `list`, `hook`, `detail` целиком, `amendments-section` частично. `messages`: `context`, `hooks`, `chat-panel`, `patient-context-panel`, `thread-list-sidebar` частично. `settings`: `profile`, `signature`, `notifications`, `security`; `presets-tab` только поверхностно. `analytics`: `route` и KPI-часть дашборда. `references`: `icd10-browser`, `references-tabs`, `drug-photo-upload/drug-similar/drug-browser` частично. `visits`: все `page.tsx`, `header/meta`, `print button`, `visits-list` частично; `visit-note-readonly` только `grep`. `documents`: `upload dialog` и `table` частично. `doctor/_components`: `topbar`, `sidebar`, `search`, `telegram-send-panel` частично. Прослежено за пределы зоны: `api-handler`, `prisma tenant extension`, `tenant-context`, `proxy.ts`, `crm/layout.tsx`, `appointments/[id] PATCH` (`revert/call/forward`), `visit-notes list/PATCH/finalize/print`, `documents upload/file`, `minio.ts`, `conversations routes`, `global-tg-alerts`, `ticket-number`, `queue-order`, `patient cipher-fields/field-cipher`, `book.ts`. Проверка одним `node-однострочником`: `new Response` с кириллицей в `Content-Disposition` бросает `ByteString`. НЕ сделано: зона `reception` (кроме точек пересечения), `notifications-list/reminder-row UI`, `documents-context/filters`, `diagnosis-follow-up-cards` и `document-edit-dialogs` изнутри, `drug-browser` фильтры, мобильная вёрстка; тесты не запускались; прод-окружение (`ANTHROPIC_API_KEY`, `require2faForAll` у клиники, реальная политика бакета `MinIO`) не проверялось — выводы о `MinIO` основаны на коде (`docker-compose` без `policy`) и комментарии в `use-patient-documents.ts`.

Живая очередь, киоск, ТВ-табло, талоны

Прочитал полностью: `src/lib/queue-ordering.ts`; `src/server/services/ticket-number.ts`; `src/server/appointments/{walkin,queue-order,queue-projection,intake,completion,active-visit,ticket-code,emit-change,cancel(тело cancelAppointment)}.ts`; `src/server/queue/{index,bullmq-adapter}.ts` (инфраструктура джоб, по очереди пациентов дефектов не нашёл); `src/app/api/crm/appointments/{walkin,reorder,bulk-status,[id]/queue-status}/route.ts` и `[id]/route.ts` (`GET/PATCH/DELETE` целиком); `src/app/api/c/{slug}/queue/{board,events,checkin,lookup,walkin,doctors}`; `src/app/api/kiosk/{checkin,doctors}`; `src/app/api/queue/status/[id]`; `src/app/api/tv/d/[token]`; `src/app/kiosk/page.tsx`; `src/app/tv/{page,_shared}.tsx`; `src/app/tv/d/[token]/page.tsx` (первые ~200 строк, логика вызова/оверлея); `src/app/q/[id]/page.tsx`; `src/app/t/[code]/page.tsx`; `src/app/ticket/[id]/*`; `src/hooks/{use-queue-board,use-doctor-board,use-public-clinic-slug}.ts`; `src/server/realtime/board-stream.ts`; `src/server/clinic-public/resolve.ts`; `src/lib/{public-clinic,rate-limit,phone}.ts`; `src/app/api/crm/doctors/me/today/route.ts`; `doctor my-day live-queue-card`, `add-walkin-dialog`, `use-appointment-status-mutation` (первые 140 строк); `reception`: `walkin-ticket-dialog`, `doctor-queue-panel`, `doctor-queue-card` (основная логика), `queue-column` (разбиение полос), `use-reception-live`; `use-appointment.ts` (`useSetQueueStatus`, `useReorderQueue`); `appointment-drawer` (обработчики статуса и канала); `lifecycle.ts`, `appointment-transitions.ts`; `worker appointment-lifecycle-sweep.ts` (основной проход); схемы `Appointment/Doctor/Patient/DoctorSchedule/TimeOff` и миграции `EXCLUDE` для `walk-in`; `docs/TZ-two-lanes.md`; `nginx/nginx.conf`

(заголовки прокси). Сверил ключи i18n ru/uz для неймспейсов зоны — расхождений нет. Не проверял/проверял поверхностно: остальную часть /tv/d/[token]/page.tsx (вёрстка), doctor-queue-list.tsx и reception-list-drawer.tsx (только места разбиения полос), current-patient-card и schedule-card врача, mini-app очередь (use-queue-status, ticket-sheet — только в части ticketCode), per-visit ETA-модель predictETA (lib/ai/eta-predictor), реализацию tenant-расширения Prisma (полагался на заявленное поведение: SYSTEM не инжектит clinicId), outbox-pumper, шаблоны уведомлений (наличие шаблонов отмены/по-show в БД не проверено — отмечено как условие). Тесты не запускал, dev-сервер/браузер не поднимал; поведение React-эффекта «залипания» оверлея /tv выведено из кода (deps [call, doctors] + cleanup), не воспроизведено вживую. Наличие реального использования общего табло /tv в клинике (vs только /tv/d) не знаю — влияет на фактическую серьёзность находки про оверлей.

Записи, календарь, ресепшн, слоты, цены визита

Корень проекта: /Users/joe/Desktop/medbook/medbook-uz. Статический аудит, только чтение: ничего не запускалось (ни тесты, ни dev-сервер, ни прод).

Прочитано полностью (сервер):

- src/app/api/crm/appointments/[id]/route.ts (GET/PATCH, ветки revert и call, DELETE), src/app/api/crm/appointments/route.ts
- маршруты appointments: [id]/queue-status, bulk-status, bulk-reschedule, bulk-reminders, reorder, walkin, slots/available
- src/lib/booking-validation.ts, src/lib/appointment-transitions.ts, src/lib/appointments/{lifecycle,overdue}.ts, src/lib/queue-ordering.ts (частично)
- src/server/pricing/recompute-appointment-price.ts, src/server/services/appointments.ts, src/server/schemas/appointment.ts
- src/server/appointments/{book,cancel,walkin,intake,queue-order,active-visit,completion,ticket-code}.ts
- src/lib/prisma.ts (тенант-расширение), src/lib/api-handler.ts

Прочитано полностью (UI):

- NewAppointmentDialog, SlotPicker
- страница «Записи»: appointment-drawer, use-appointment, appointments-right-rail, appointments-page-client, appointments-bulk-bar, export-button
- календарь: use-calendar-data, use-conflict-detector, calendar-page-client, calendar-utils
- ресепшн: reception-page-client, use-reception-live, kpi-strip, bottom-row, walkin-ticket-dialog, urgent-alerts-widget

Прочитано по потокам за пределами зоны:

- публичные маршруты киоска: /api/c/[slug]/queue/{walkin,checkin,lookup}, /api/kiosk/checkin, src/app/kiosk/page.tsx (часть), src/server/clinic-public/resolve.ts, src/lib/public-clinic.ts
- страницы /ticket/[id] и /t/[code], /api/miniapp/slots
- уведомления: части triggers.ts и workers/notifications-send.ts, default-templates, scripts/reminder-cadence-5d3d1d3h.ts
- appointment-lifecycle-sweep, visit-notes finalize (эффекты после коммита), dashboard route (queue groupBy), exports worker и route
- permissions/matrix.ts, update-schedule, doctors schedule route, nginx.conf (XFF), Dockerfile (TZ)

Прочитано частично или просмотрено по grep:

- calendar-view.tsx (логика drag/resize и событий), calendar-tiles, calendar-right-rail
- doctor-queue-card, doctor-queue-panel, queue-column, doctor-queue-list, reception-list-drawer
- appointments-table (действия строк и пагинация), appointment-lifecycle, case-selector-dialog
- use-appointments-list, use-appointments-filters, calls-widget
- проверено совпадение ключей i18n ru/uz для namespace appointments, calendar, reception, appointmentLifecycle, crmToasts.appointment: расхождений нет, но отсутствуют ключи для ряда кодов конфликтов.

Не проверено или проверено поверхностно:

- bulk-reschedule-dialog, reschedule-confirm-dialog (частично), calendar-toolbar/legend, onboarding-checklist, doctor-panel-settings, day-picker (частично)
- pre-visit-questionnaire-card, patient-picker, services-picker, doctor-picker
- src/server/appointments/{emit-change,confirm,queue-projection}.ts (confirm частично)
- маршруты attach/detach для случаев, модуль платежей, доска ТВ и /q
- поведение мини-аппа при бронировании (только слоты и вызов bookAppointment)
- Не проверял на практике, как Prisma пагинирует курсором при orderBy по неуникальному полю date: теоретический риск дублей и пропусков строк на границах страниц в календаре и на ресепшн не подтверждён, поэтому в находки не включён.

Находки, корень которых формально лежит вне основных путей зоны, включены, потому что напрямую ломают поток ресепшн: киоск и печатный талон, воркер неявок (queueStatus), шаблоны напоминаний.

Пациенты и медицинские случаи в CRM

Прочитано полностью: все API зоны — src/app/api/crm/patients/** (route, [id], allergies, chronic-conditions, diagnoses, communications, family, referral, stats, ltv, summary, summary/refresh, telegram-invite, data-export, export, stats), src/app/api/crm/cases/** (route, [id], attach/detach, prescriptions, prescriptions/[id], pdf), src/app/api/crm/dsar/** ; src/server/dsar/*

(anonymize, bundle, zip, expiry), src/server/cases/attach.ts, src/server/patient/* (cipher-fields, last-contacted), src/server/medical-case/cipher-fields.ts, src/lib/phone.ts, src/lib/patient-number.ts, src/lib/patients/parse-identity.ts, src/lib/timeline/group-by-day.ts. UI: patients page client, tiles, kpi-tabs, filters, right rail, sources widget, new-patient dialog, export button, segment view, table (~560 из 748 строк), use-patients-list/filters; карточка: card client, hero, info panel, finance, recommendations, right rail, timeline, summary card, delete dialog, visits/cases/payments/overview tabs, хуки use-patient*, telegram-invite-dialog (частично), documents-tab и preview (частично), medical-tab (первые ~200 строк + grep по формам), tag-editor/inline-field (частично); случай: case-detail-client целиком, use-case, soap-draft-card, prescriptions-card (частично), close-case-dialog (частично). Для трассировки прочитаны: lib/api-handler, lib/prisma, tenant-context, tenant-allowlist, workers data-export/data-deletion/medication-reminder (фрагмент)/exports, server/queue, storage/minio (fetchObject/getSignedUrl), services/ltv и patient-number, pricing/recompute-appointment-price, appointments/book.ts (фрагменты), miniapp/auth и account/delete, telegram/invite-token, telegram webhook (фрагмент), visit-notes print (фрагмент), payments route, settings/dsar review client (фрагмент), схема Prisma по Patient/MedicalCase/связям и FK в миграциях. Проверено экспериментально только одно: локальный OpenSSL 3.6.3 отвергает `openssl enc -aes-256-gcm` («AEAD ciphers not supported») и опцию -tag. Не сделано: не прочитаны до конца medical-tab (формы ~800 строк), подпись документов (signature dialog), communications-tab детали, patient-referral-card, use-patient-family, skeleton/loading; тесты не запускались; прод-данные не проверялись — в частности не проверено, существует ли на проде бакет MinIO «exports»/MINIO_EXPORTS_BUCKET, сколько COMPLETED-записей без completedAt, настроен ли freeRepeatDays у услуг NeuroFax (от этого зависит масштаб находок про lastVisitAt и бесплатные повторы). Находки про Mini App auth (захват карты по телефону) и SUPER_ADMIN в createApiListHandler имеют корень вне основных путей зоны, но напрямую затрагивают привязку/доступ к картам пациентов — включены сознательно, их стоит сверить с аудитом зон Mini App и платформы на дубли.

Настройки клиники, пользователи, филиалы, кабинеты, права

Прочитано полностью: src/lib/api-handler.ts, src/lib/prisma.ts, src/lib/tenant-allowlist.ts, src/lib/tenant-context.ts, src/lib/permissions/matrix.ts, src/lib/view-only.ts, src/lib/feature-flags.ts, src/server/platform/get-feature-flags.ts, src/server/platform/feature-guard.ts, src/server/platform/branch-cookie.ts, src/server/branches/resolve-branch.ts, src/server/onboarding/apply-playbook.ts; все роуты src/app/api/crm/{users,users/[id],users/[id]/reset-password,branches,branches/[id],branches/active,cabinets,cabinets/[id],clinic,clinic/secrets,integrations,integrations/[id],integrations/verify-password,integrations/tg/{connect,disconnect,set-webhook},exchange-rates,onboarding-status,settings/{letterhead,branding,auto-messages,notifications/templates,notifications/templates/[id]}}, audit и audit/patient-views, billing/upgrade и invoices/[id]/charge; UI: settings layout/page/sidebar/hook, users-settings-client (весь), clinic-settings-client (весь), integrations-client (весь), branches-settings-client (весь), exchange-rates-client, billing page + pay stub, branch-switcher, onboarding-checklist. Прослежены потоки за пределами зоны, где корень в зоне: lib/auth.ts (JWT/поль/active), proxy.ts (UserSession, mustChangePassword, matcher), doctor/layout.tsx и crm/layout.tsx (редирект-цикл), payments/route.ts и services/ltv.ts (кырп), services/appointments.ts (слоты), notifications-scheduler.ts dynamic pass, notifications/rules.ts, triggers.ts (whereForTrigger/runScheduledTriggers/buildContext), auto-messages.ts, telegram webhook secret check и poll.ts, adapters (TG/LogOnly), telephony/index.ts, calls/sip/event, storage/minio.ts, docs/architecture/SECURITY.md (приватный бакет), schema.prisma (Clinic, User, Branch, Cabinet, Service, Payment, ExchangeRate). Частично/выборочно: cabinets-settings-client и services-settings-client (обработчики, цена, тумблеры), notifications-client (правила и сохранение, не весь редактор тела), roles-matrix-client (только источник данных), tg-connect-wizard (мутации), audit-log-client (фильтры), playbooks/index.ts (шаблоны и маппинг триггеров), knowledge-роуты — только проверка владения clinicId в PATCH/DELETE (drugs/guides/handouts/protocols, дефектов не найдено). Не покрыто: DSAR-клиент и /api/crm/dsar, вкладки knowledge UI (drugs/guides/handouts/protocols) по существу, billing-client целиком, branding-page-client целиком, платформенная сторона /admin и /api/platform (кроме деактивации клиники), (dev)-страницы CRM. Тесты, сборка и прод не запускались; выводы о поведении MinIO (AccessDenied для «голых» URL) опираются на собственную документацию и комментарии кода проекта, а редирект-цикл врача и неприменение проверок в /doctor — на условие DOCTOR_CABINET_ENABLED=1.

Управление врачами (CRM)

Прочитано полностью: src/app/api/crm/doctors/route.ts, [id]/route.ts, [id]/services, [id]/schedule, [id]/time-off, [id]/finance, [id]/reviews, [id]/case-stats; src/app/api/crm/services/route.ts и [id]/route.ts; src/server/doctors/deactivation.ts, update-schedule.ts; src/lib/doctors.ts; все файлы src/server/services (appointments, ticket-number, patient-number, document-number, ltv, family, treatment-plan); src/server/schemas/doctor.ts, service.ts, doctor-services.ts; UI: doctors-page-client, doctor-card, doctors-tiles, doctors-quick-book, doctors-kpi-tabs, doctors-ai-recommendations, new-doctor-dialog, cabinet-select-field, doctor-profile-client, doctor-header, doctor-services, schedule-editor, doctor-time-off, doctor-finances, doctor-cases, cabinet-picker-dialog, хуки use-doctor, use-doctor-schedule, use-doctors-stats, use-doctors-list, use-doctors-filters, use-doctor-appointments, use-doctor-finance; services-settings-client (на него ведёт /crm/services). Частично (верх файла/логика расчёта): doctors-heatmap, doctors-stats-panel, doctors-top-revenue, doctor-heat-grid, doctor-patients-list, doctor-reviews. Для трассировки открывал: api-handler, tenant-context, prisma extension, tenant-allowlist, schema.prisma (Doctor/Service/ServiceOnDoctor/Schedule/TimeOff/Appointment/User/PatientReview/ExchangeRate), book.ts, walkin.ts, queue-order.ts, kiosk/doctors, miniapp/slots, crm/appointments list, notifications/triggers, users routes, ru/uz.json (ключи зоны совпадают в обоих локалях, отсутствующих ключей не найдено). Поведение zod (limit=500 → ошибка, coerce.boolean('false') → true) проверено однострочным node-скриптом. Не делал: маршруты /api/crm/doctors/me/* (исключены), тесты не запускал, прод-данные не проверял (например, реальные значения priceBase/pricePerVisit в БД — надо сверить при фиксе), branch-скоупинг расписаний не разбирал глубоко (в клинике одна ветка, переключатель скрыт), mini-app family

claim-путь (корень в /api/miniapp/family, вне зоны) не включён.

Telegram-бот, переписки, рассылки, уведомления, воркеры

Корень: /Users/joe/Desktop/medbook/medbook-uz. Только статический анализ; сервер, тесты, прод не запускались, env прода (TG_BOT_AUTOREPLY, TG_USE_POLLING, SMTP_*) неизвестен, поэтому находки, которые от них зависят, помечены условием.

Прочитано полностью: src/app/api/telegram/webhook/route.ts и [clinicSlug]/route.ts;
src/server/telegram/{send,bot-api,state,messages,poll,invite-token,inbound-media,voice-handler,call-notice,auth}.ts;
src/lib/telegram.ts, src/lib/email.ts (+ src/app/api/leads/route.ts, src/lib/rate-limit.ts); src/server/notifications/{triggers (все 1773 строки),template,rules,auto-messages,default-templates,rate-limit,consent-gate,record-delivery,no-channel-action}.ts и adapters/*;
src/server/workers/{start,notifications-send,notifications-scheduler,pre-visit-questionnaire,post-visit-nps,medication-reminder,voice-soap,outbox-pumper,appointment-lifecycle-sweep}.ts; data-deletion.ts (основная логика), data-export.ts (доставка в TG);
src/server/queue/{index,bullmq-adapter}.ts; src/server/campaigns/{launch,audience,dormant-audience}.ts;
src/server/conversations/{find-or-create,doctor-scope}.ts; все роуты
src/app/api/crm/{campaigns,notifications,conversations,canned-responses,communications,telegram};
api/crm/settings/auto-messages. UI: message-bubble, template-editor, triggers-panel, notifications-kpi-strip, broadcast-history (воронка), telegram page + stats bar, mode-switch, хуки
use-send-message/use-mark-read/use-takeover/use-tg-inbox-alerts/use-tg-messages/use-tg-stats/use-queue/use-triggers, части message-composer (быстрые действия, inline-кнопки, onSend) и chat-right-rail (привязка пациента). Сверялись смежные места: schema.prisma (Message/Conversation/NotificationSend/EventOutbox, FK в миграциях), book.ts, appointments PATCH/queue-status/miniapp PATCH, visit-notes finalize, onboarding playbooks, сиды, next.config CSP, nginx, docker-compose, i18n ru/uz (паритет ключей OK).

Не проверено или только поверхностно: chat-right-rail (большая часть из 1323 строк), message-composer (шаблоны/эмодзи/загрузка), conversation-list, chat-pane, broadcast-dialog/audience/preview, ai-copy-suggest и /api/crm/ai/marketing-copy, notifications-details-rail и activity-list целиком, campaigns-list, use-broadcast/use-canned; воркеры visit-note-handout и referral-document (только частично), exports, analytics-refresh, patient-summary-refresh, scheduled-reports (только доставка), trial-expiry-scheduler; внутренности realtime (publish/SSE/envelope), мини-апп сторона чата и inbox; /api/crm/settings/notifications и integrations/tg (connect/set-webhook) — только точно. Утверждение о коллизии message_id опирается на документированный контракт Bot API («unique inside this chat»); на проде стоит подтвердить SQL-проверкой из критерия приёмки.

Мини-апп пациента и публичные страницы клиники

Прочитано целиком и прослежено (UI → API → сервер → БД): src/server/miniapp/{handler,active-patient,idempotency}.ts; все роуты src/app/api/miniapp: auth, profile, appointments (GET/POST), appointments/[id] (PATCH/DELETE), checkin, attach-case, ics, family, family/[id], documents, documents/[id]/file, labs, treatment-plan, pre-visit, nps, medications, medications/[id], referral, inbox, inbox/[id], conversations, find-or-create, events (SSE), client-errors, clinic, doctors, services, slots, account/delete|export|cancel-deletion; conversations/[id]/messages только первые ~60 строк. Публичные: src/app/api/c/[slug]/queue/{lookup,checkin,walkin,board,doctors,events}, src/server/clinic-public/resolve.ts, src/lib/public-clinic.ts, src/app/api/public/signup (+confirm), src/app/v/[token], src/app/api/verify/{recipe,sick-leave}. src/lib/patient-experience/* и src/server/patient-experience/referral-mint.ts целиком. Вне зоны, но для трассировки: book.ts, cancel.ts, detectConflicts/findAvailableSlots, walkin.ts, invite-token.ts, cases/attach.ts (grep), recompute-appointment-price (шапка), treatment-plan computeProgress, proxy.ts, prisma.ts fail-closed, tenant-allowlist, next.config CSP, nginx.conf, crm documents file proxy и preview dialog, kiosk/checkin, next-intl middleware (исходник в node_modules). Клиент мини-аппа прочитан полностью: auth-provider, use-miniapp-api, use-active-context, use-booking-draft, use-appointments, use-doctors, use-slots, use-queue-status, service/doctor/slot-picker, book-confirm, book-done (первые 120 строк), appointments-screen, appointment-detail-dialog, family-switcher, mini-app-shell (частично), home-hero (основные части), miniapp-home (первые 160 строк), profile-screen, account-delete-screen (частично), layout, visit-summary (рендер), treatment-plan-card (частично), mini-ui форматтеры, live-events (карта инвалидации), error-boundary (report). Бегло или только grep'ом: nps-screen, labs-screen, medications-screen, pre-visit-screen, documents-screen, family-add-screen, clinic-info-card, inbox-banner, ticket-sheet, toast, skeleton, wizard-*, use-tg-buttons, live-reconnect, labs-unseen, screen-state, i18n-словари (ключи RU/UZ совпадают, проверено diff'ом). Ничего не запускалось: ни сервер, ни тесты, ни curl. Два вывода сделаны по коду без рантайм-проверки и требуют подтверждения curl'ом на проде: 404 на /v/ и /t/ из-за matcher proxy + rewrite next-intl (по исходнику next-intl 4.9.0), а также конкретный порядок строк при дублях telegramId. Не проверял: воркеры pre-visit/nps/data-export и шаблоны уведомлений (как выглядят deer-link'и в мини-апп), страницы /q/[id], /t/[code] и /kiosk вне зоны, содержимое экспорта данных, CRM-сторону merge пациентов.

Аналитика, выручка, оплаты, биллинг, экспорты

Прочитано полностью:
src/app/api/crm/analytics/{route,funnels,cases,financial,forecast,loss,doctors,cohorts,schedule-heatmap,refresh}/route.ts, reports/run, reports/[id]/run, reports/route.ts, reports/[id]/schedules/route.ts (+ выборочно reports/[id]/route.ts и schedules/[scheduleId]/route.ts); src/app/api/crm/payments/route.ts и [id]/route.ts;
src/app/api/crm/billing/{invoices,upgrade,invoices/[id]/{charge,simulate-pay,pdf}}; src/app/api/crm/exports/* +

src/server/workers/exports.ts; dashboard и shell-summary; src/server/analytics/* (range, funnels, query-builder, measures, dimensions, report-config, report-runner, csv, cadence, delivery, schedule-validation, saved-reports, все resolver'ы; pdf.ts — первые 200 строк); src/server/revenue/* (avg-visit, forecast-data, loss-data, empty-slot, reactivation, scheduler); src/server/billing/{invoice,invoice-number,usage,plan-limits,payments/payme,payments/click}; src/lib/revenue/{forecast,loss-aggregation}.ts, src/lib/revenue.ts, src/lib/analytics/dashboard-math.ts; миграция 20260507130000 (MV); воркеры analytics-refresh и scheduled-reports; UI: analytics-page-client, analytics-charts, funnel-cards, cases-section, analytics-hub-cards, financial page+client, doctors page+client (частично), cohorts page+client (частично), schedule-heatmap page+client, loss/forecast page-clients (основная часть), report-builder-client (ключевые участки), report-view-client (экспорт), doctor/analytics page+hook+route /api/crm/doctors/me/analytics; смежно: api-handler, prisma tenant-extension, tenant-allowlist, branch-cookie, services/ltv, patient/last-contacted, payments-tab, appointment-drawer, kpi-strip, webhooks billing, Dockerfile/next.config. Проверено node-однострочником: Response с кириллицей в content-disposition бросает TypeError (Node 22). НЕ проверено/не прочитано: src/server/billing/pdf.ts и остаток analytics/pdf.ts (пендеп), loss-chart/forecast-chart, reports-list-client и schedules-section/schedule-form-dialog детально, billing-client.tsx и admin/clinics billing UI, telegram/send.ts (доставка через WARP), реальные данные прода (есть ли строки ExchangeRate, тариф NeuroFax, hasAnalyticsPro) — выводы о проде условны. Поведение Payme/Click протоколов оценено по знанию их спецификаций, без доступа к документации в сессии. Тесты не запускались.

Центр действий, действия, AI, база знаний

Зона прочитана построчно: src/app/api/crm/actions/** (route, [id], dismiss, done, snooze, reopen, outcome, recompute, sla), src/app/api/crm/action-center/{risk-today,mark-contacted}, src/server/actions/{engine,repository,scheduler,config,handler-utils} и все 10 детекторов + _shared, src/lib/actions/{types,format,icons}, src/server/schemas/action.ts, клиент src/app/[locale]/crm/action-center/** (page, action-center-client целиком, risk-today-section: логика строк/исходов/меню/форматирование, action-card, snooze-popover; хуки use-actions, use-risk-today, use-risk-today-filters частично), src/app/api/crm/ai/* (все 9 роутов + _lib/reception-context), src/server/ai/{llm,tool-loop,per-visit-eta,resolve-eta,resolve-queue-scores,resolve-reassign,patient-summary-cache,soap (структуризация/запись),transcribe (провайдер/mock),reception-warnings}, tools/{index,types,find-patient,search-actions,get-appointments-today, find-free-slots частично}, src/lib/ai/{no-show-risk,eta-predictor,queue-score}, src/lib/ai-enabled.ts, src/app/api/crm/{knowledge/**,guides,search}. Потоки за пределами зоны прослежены для подтверждения: confirm.ts/cancel.ts, appointments/[id] DELETE и queue-status, payments POST, visit-note-handout (эмиттер VISIT_FOLLOW_UP_DUE), NPS-роут мини-аппа, no-channel-action, TG-вебхук + voice-handler + voice-soap worker, crm-sidebar/crm layout, call-center use-unconfirmed/use-active-call/unconfirmed-widget, reception action-briefing, i18n ru/uz (паритет ключей actionCenter/ai/search проверен скриптом — расхождений нет), TZ-risk-outcomes.md. Существование целевых страниц для deeplink проверено через find. НЕ прочитаны детально: src/server/ai/marketing-copy.ts, summary.ts (только вызов LLM/knownNames), reception-clarifying/-conclusion/-icd10 (только knownNames), redact.ts (только первые 120 строк), lib/ai/reassign-engine.ts, dismiss-dialog.tsx и risk-today-filters.tsx (бегло), UI настроек базы знаний (только источники данных). Тесты не запускались; наличие ANTHROPIC_API_KEY/OPENAI_API_KEY на проде не проверялось (в .env.example и docker-compose их нет), поэтому находка по voice→SOAP описывает оба варианта. Утверждение о возможной двойной отправке уведомления при параллельной отмене не подтверждено (в триггерах есть проверка идемпотентности) и в находки не включено как факт.

Аутентификация, мультитенантность, безопасность, платформа

Прочитал полностью: src/proxy.ts, src/lib/{auth.ts, api-handler.ts, tenant-context.ts, tenant-allowlist.ts, prisma.ts, rate-limit.ts, pin.ts, auth-or-pin.ts, post-login-redirect.ts, audit.ts, audit-server.ts, view-only.ts, public-clinic.ts, doctor-cabinet.ts}; src/server/auth/{user-session, session-security, security-policy, recovery-codes, totp (частично)}; src/server/crypto/secret-fields.ts (+ grep по field-cipher/secrets); src/server/platform/{handler, impersonation, clinic-override, branch-cookie, get-feature-flags, current-subscription}; src/server/miniapp/handler.ts; src/server/clinic-public/resolve.ts; src/app/api/auth/{...nextauth}; src/app/api/crm/auth/totp-required; src/app/api/crm/me/{password, totp/enroll, totp/verify, totp/disable (+regenerate частично)}; src/app/api/me; src/app/api/crm/users (+[id], [id]/reset-password); src/app/api/crm/audit (+patient-views роли); src/app/api/platform/{clinics, users/[id], session/switch-clinic} и гейтинг остальных platform/admin роутов; src/app/api/admin/{encryption-health, clinics/[id]/lifecyle}; src/app/api/internal/metrics; src/app/api/webhooks/billing/{click,payme} + src/server/billing/payments/*, invoice.markInvoicePaid, plan-limits (экспорты/вызовы); src/app/api/public/signup (+confirm) и signup-форма; src/app/login (+2fa); src/app/admin/layout и admin/clinics/[id]/billing/page; CRM layout, doctor layout, doctor visit pages (гейтинг); /api/events; /api/leads; /api/kiosk/checkin; /api/c/[slug]/queue/{lookup,checkin,walkin}; /api/queue/status/[id]; SIP-вебхук (аутентификация); telegram webhook (проверка секрета); crm/clinic/secrets; crm/branches/active; doctors/[id]/services; appointments/[id] (GET include, PATCH FK); patients/[id] (аудит); DSAR anonymize/data-deletion (аудит-снимок); prisma/seed.ts и scripts/seed-neurofax-real.ts, upsert-dev-admin.ts; nginx/nginx.conf; next.config.ts (CSP); node_modules next-auth/@auth/core (session refresh, CSRF, signIn/signOut) и Next 16 docs (auth в layout). Полный whole-repo grep: runUnscoped (все 10 мест просмотрены по сути), kind:'SYSTEM' (перечислены, проверены request-driven в зоне), \$queryRaw/\$queryRawUnsafe/\$executeRaw (все параметризованы или идентификаторы из закрытых enum — дыр не найдено), prisma.user.* вне auth (ручной фильтр clinicId присутствует везде, где нужно), сверка schema.prisma ↔ MODELS_WITHOUT_TENANT (расхождений нет). НЕ проверял глубоко: остальные ~300 CRM-роутов на IDOR по *Id из тела (проверен только appointments PATCH как показательный пример), мини-апп хендлеры (все работают в SYSTEM и обязаны вручную ставить clinicId/patientId — отдельная зона), телеграм-вебхук целиком, воркеры BullMQ, хранилище/MinIO (/files/ в nginx идёт прямо в MinIO — не проверял), PDF/print-шаблоны на XSS, i18n-ключи. Состояние прода (какие

сид-пароли реально живы, стоит ли DISABLE_2FA=1) из кода проверить нельзя — это указано в acceptance; упоминание DISABLE_2FA на проде взято из заметок эксплуатации, не из кода. Тесты и сборку не запускал.

Публичный лендинг, запись с сайта, SEO

Прочитано полностью: src/app/[locale]/(site)/{layout,page,privacy/page,terms/page,doctors/[id]/page}.tsx; все src/components/sections/*.tsx (cta, directions, doctors, faq, hero, lead-form, mobile-call-bar, reviews, services, telegram-showcase, visit); src/components/layout/{header,footer,mobile-nav,language-switcher}.tsx; src/components/providers/{doctors-provider,theme-provider}.tsx; src/components/locale-html-lang.tsx; src/app/api/leads/route.ts; src/lib/{constants,doctors,rate-limit,public-clinic,phone,email}.ts; src/app/{robots,sitemap,layout}.ts(x); src/app/[locale]/{layout,not-found}.tsx; src/app/not-found.tsx; next.config.ts; src/proxy.ts; src/i18n/{routing,config,request}.ts; nginx/nginx.conf; public/robots.txt; namespaces в ru.json/uz.json для лендинга (nav, hero, visit, tgShowcase, doctors, services, reviews, faq, directions, contact, footer, mobileBar, leadForm, doctorPage, legal). ru/uz для лендинга сверены программно, пропущенных ключей нет. Прослежены цепочки вне зоны: PATCH /api/crm/doctors/me/profile (источник XSS), DELETE /api/crm/doctors/[id], /api/crm/online-requests, prisma-модели Lead/OnlineRequest/Service, ops/backup.sh, scripts/seed-mega-neurofax.ts (вайн Lead), node_modules next-intl middleware/syncCookie/resolveLocale, next build reduceAppConfig и порядок filesystem-роутера, docs по sitemap-кешированию. Проверена гипотеза о сдвиге даты (node, TZ=Asia/Tashkent). Браузер, dev-сервер и прод не запускались, поэтому поведение Telegram Web в iframe и фактический прод-sitemap выведены из кода, заголовков и документации Next, а не наблюдались. Не проверено: наличие SMTP_* в прод-.env на сервере (судил по .env.example/.env локально); существование почтовых ящиков врачей. Вне зоны, но стоит передать ответственному за auth/public API: POST /api/public/signup + /api/public/signup/confirm (src/app/api/public/signup/route.ts:107, confirm/route.ts) позволяют анонимному посетителю без rate-limit и без подтверждения почты создать на проде новую клинику с ADMIN-учёткой (токен возвращается прямо в ответе, temp-пароль в ответе confirm). Это открытая регистрация tenants в общей БД с реальными данными пациентов. Также вне зоны: clientIp в src/lib/pin.ts:29-31 и src/lib/audit.ts:20-21 берёт первый, подделываемый клиентом элемент X-Forwarded-For; лимитер kiosk/checkin делит бакет с лидами (ключ без префикса).

Клинические документы, больничные, рецепты, анализы, направления, файлы

Корень репозитория: /Users/joe/Desktop/medbook/medbook-uz. Все пути в находках относительно него. Аудит статический: ничего не запускал (ни dev-сервера, ни тестов, ни сборки, ни браузера, ни ssh/curl на прод).

Прочитано полностью:

- API документов: src/app/api/crm/documents/{route.ts, [id]/route.ts, [id]/sign/route.ts, file/route.ts, upload/route.ts}; src/server/schemas/document.ts
- Больничные: src/app/api/crm/sick-leaves/{route.ts, [id]/route.ts, [id]/print/route.ts}
- Рецепты: src/app/api/crm/e-prescriptions/{route.ts, [id]/route.ts, [id]/print/route.ts}
- Анализы: src/app/api/crm/lab-orders/{route.ts, [id]/route.ts, [id]/print/route.ts}
- Направления: src/app/api/crm/referrals/route.ts, src/server/schemas/{clinical-forms,referrals,lab}.ts, src/server/clinical-forms/numbering.ts
- Хранилище и PDF: src/server/storage/minio.ts, src/server/referrals/referral-pdf.ts, src/server/workers/referral-document.ts
- Публичная проверка: src/app/v/[token]/route.ts, src/app/api/verify/{recipe,sick-leave}/{token}/route.ts
- Mini App: src/app/api/miniapp/documents/{route.ts, [id]/file/route.ts}
- UI CRM: src/app/[locale]/crm/documents/* (page, client, upload-dialog, хук)
- UI врача: src/app/[locale]/doctor/documents/* (все компоненты и хуки); диалоги src/app/[locale]/doctor/reception/_components/{e-prescription,sick-leave,referral}-dialog.tsx и их хуки
- Инфраструктура: document-preview-dialog.tsx, src/lib/{prisma,tenant-context}.ts, api-handler.ts (обёртки), src/lib/tenant-allowlist.ts (начало), next.config.ts, src/proxy.ts, next-intl middleware из node_modules, src/i18n/routing.ts

Прочитано частично:

- src/app/api/crm/visit-notes/[id]/print/route.ts: строки 1-700, 800-880, 1070-1095, 1380-1584 и поиск по форматированию дат и неэкранированным вставкам
- src/server/workers/visit-note-handout.ts: персистенция, sweep, amendments
- documents-tab.tsx: загрузка, планшет подписи, удаление, подписи типов
- send-telegram (хелпер ключей и цикл отправки), lab-order-dialog (submit), visits API (выборка документов), visits-section (ссылки), signature-tab, doctor signature API, letterhead route (только персистенция URL), outbox-pumper (ветка auditable), handler Mini App (резольв пациента)
- cases/[id]/pdf: только скан на неэкранированные вставки; экранирование в шаблонах выглядит корректным

Не проверено:

- conclusion-pdf.ts целиком (только форматирование дат)
- роуты результатов анализов, кроме POST /doctors/me/labs и Mini App labs
- роуты фото препаратов и брендинга (кроме факта хранения голого URL)
- DSAR-выгрузки; прокси чат-вложений (только прочитан, он вне зоны)
- экраны Mini App, кроме списка документов

Допущения:

- Приватность бакета MinIO (403 на голый URL) опирается на явные комментарии в коде (miniapp/documents/route.ts:93-99, documents/file/route.ts:4-8) и заметки проекта; в проде не проверял.
- nginx.conf взят из репозитория, прод может отличаться.
- Вывод о 404 на /v основан на matcher в proxy.ts и коде next-intl middleware; ошибка MissingTenantContextError (500) не зависит от этого вывода.
- В коммите 1622b12 (15.07.2026) диалоги рецепта, больничного, анализов и направления сняты с экрана намеренно. Поэтому часть дефектов этой подсистемы помечена как латентная, с пониженной серьёзностью.

Справочники: препараты, МКБ-10, услуги, оверлеи клиники, избранное

Полностью прочитал (файлы зоны): src/app/api/crm/catalogs/{drugs/route.ts, drugs/facets, drugs/[id]/similar, drugs/[id]/photo, labs, handouts, protocols}; src/app/api/crm/{icd10/search, clinic-catalog-overlays, doctor-favorites}/route.ts; src/server/catalog/clinic-overlay.ts; src/server/icd10/{search.ts, clinic-catalog.ts, data.ts}; src/lib/icd10-query.ts; все файлы в src/app/[locale]/doctor/references (page, tabs, drug-browser, drug-photo-upload, drug-similar, highlight, icd10-browser, icd10-chapters, хуки); scripts/import-uzpharm-registry.ts, scripts/enrich-drug-forms.ts, scripts/build-icd10-catalog.mjs; модели Drug/DrugBrand/ClinicCatalogOverlay/DoctorFavorite/ClinicDiagnosis в schema.prisma и миграцию оверлея; src/lib/prisma.ts и tenant-allowlist.ts. Прошёл связанные потоки за пределами зоны: diagnosis-follow-up-cards.tsx (пикер), icd-catalog-drawer.tsx, catalog-drawer.tsx, use-drug-search.ts, use-doctor-favorites.ts, drug-detail.tsx, drugs-tab.tsx (админские переопределения), место вызова learnClinicDiagnosis в finalize, minio.ts, nginx /files/, cds/drug-check.ts (сверка аллергий), атрибуция роутов в api-handler. Проверки: офлайн-запуск searchIcd10 через tsx на ~60 реальных неврологических запросах; анализ data.json (форматы кодов, дубли, покрытие глав, обрывки названий); анализ prisma/uzpharm-registry.json (сущности, коллизии брендов, симуляция склейки при импорте, маппинг категорий, моделирование обрезки поиска при limit=12); zod coerce.boolean на 'false'; офлайн-валидация Prisma без БД для overlay.create без createdById (подтверждена ошибка) и для фильтра Json {not:null} (проходит валидацию, поэтому как дефект НЕ заявлен). Не делал: прод-БД и сеть не трогал, поэтому не проверял фактическое содержимое прод-таблиц (есть ли уже overlay-строки с фото, сколько ClinicDiagnosis накоплено, реальную collation Postgres для сортировки nameRu). Курируемые строки из БД в симуляции поиска не учтены: реальная обрезка для «парацетамол» может быть только хуже. Глубоко не аудировал роуты src/app/api/crm/knowledge/* (CRUD собственных препаратов и памяток), use-frequent-drugs, PDF-воркер памяток (рендер bodyMd из оверлея) и guides; это соседние зоны.

Realtime/SSE, очереди BullMQ, схема БД и миграции, деплой, бэкапы

Прочитано полностью: src/server/realtime/* (event-bus, redis-adapter, channels, publish, outbox, envelope, events, board-stream), src/app/api/events/route.ts, src/app/api/miniapp/events/route.ts, src/app/api/c/[slug]/queue/events/route.ts, src/app/api/health/route.ts, src/app/api/internal/metrics/route.ts, src/server/observability/metrics.ts, src/instrumentation.ts, src/server/queue/{index, bullmq-adapter}.ts, src/server/workers/{start, outbox-pumper, notifications-scheduler, notifications-send, medication-reminder, appointment-lifecycle-sweep, trial-expiry-scheduler, referral-document, post-visit-nps, pre-visit-questionnaire, exports}.ts. Выборочно: visit-note-handout.ts (обатика, старт), data-deletion.ts, data-export.ts (регистрация, выгрузка), analytics-refresh.ts, scheduled-reports.ts (тик, delivery), revenue/scheduler.ts, actions/scheduler.ts. Инфраструктура: Dockerfile, Dockerfile.worker, docker-compose.yml, .dockerignore, next.config.ts, nginx/nginx.conf, nginx/conf.d/*, ops/{deploy, backup, restore, watchdog}.sh, ops/crontab.example, .env.example, .github/workflows/ci.yml, docs/operations/DEPLOY.md и частично RUNBOOK.md. Клиентские потребители: src/hooks/use-live-events.ts, use-live-query.ts (начало), use-miniapp-live-events.tsx, query-provider.tsx, /q/[id]/page.tsx, /api/queue/status/[id], /api/c/[slug]/queue/{board, lookup}. Схема и миграции: скриптом (python, в scratchpad) сверил все @@index/@@unique/@@unique, все enum-значения и все скалярные колонки schema.prisma с 85 migration.sql. Дрейфа колонок, индексов и enum не найдено (Doctor_cabinetId_key создан как CONSTRAINT, это нормально). Вручную проверил onDelete для FK на Patient, MV аналитики (миграция phase18_w1), EventOutbox, индексы Appointment, NotificationSend, AuditLog, VisitNote, Prescription. Поведение BullMQ 5.79 (every/offset, emit error) и Next 16 (signalFromNodeResponse) сверил по источникам в node_modules.

Ограничения и что НЕ сделано: не запускал ни БД, ни prisma migrate diff, ни тесты, ни браузер. Прод-версии docker-compose.yml и nginx.conf на сервере помечены skip-worktree и могут отличаться от репозитория (находки по Redis allkeys-lru, /files/, certbot, общей сети относятся к версиям в репо и к описанию в DEPLOY.md). Реальный _deploy.sh видел только в копии из DEPLOY.md. Счётчики в проде (число ACTIVE-рецептов, строк EventOutbox) не проверял, оценки выведены из кода и RUNBOOK. Глубоко не аудировал (зоны других агентов): src/server/notifications/triggers.ts (кроме контраста buildContext, дедуна и lang='ru'), telegram poll/webhook, voice-soap, patient-summary-refresh, внутренности криптографии DSAR-экспорта, report-runner, детекторы action engine, ops/certbot-init.sh, ops/migrate-secrets.ts, ротацию ключей. i18n-словари ru/uz не сверял. Находки про фото препаратов и логотип (бакет приватный) опираются на комментарии кода о приватности бакета, реальную политику бакета на проде не проверял.

Колл-центр, кабинеты, профиль, dev-страницы, документы CRM, телефония

Проект: /Users/joe/Desktop/medbook/medbook-uz (пути в находках указаны относительно корня). Прочитано полностью: src/app/[locale]/crm/{page.tsx, layout.tsx, error.tsx}, весь call-center (page, 4 компонента, 5 хуков), rooms/page.tsx, (dev)/components/page.tsx (начало), me/change-password (page+client), me/security/page.tsx и логика security-client.tsx (мутации/ошибки), documents (page, hook, page-client, upload-dialog), src/app/api/calls/sip/event/route.ts, src/server/telephony/{adapter, index, log-only}.ts, src/app/api/crm/calls (оба роута), api/crm/me/{password, totp/enroll, verify,

disable, recovery-codes/regenerate}, api/crm/online-requests (оба), api/crm/referrals, src/components/layout/{crm-sidebar, crm-topbar, global-search, branch-switcher, clinic-switcher, impersonation-banner, global-tg-alerts, trial-banner-state, header, mobile-nav, crm-right-rail, частично trial-banner, footer, language-switcher}, src/components/dev/missing-key-warner.tsx. Для трассировки открывал: src/proxy.ts, src/lib/prisma.ts, src/lib/api-handler.ts (TOTP-рейт), src/lib/auth.ts (jwt callback), node_modules/@auth/core/lib/{index,init}.js (CSRF), api/crm/documents/{route,upload,file,[id]/sign}, api/crm/patients/[id], api/crm/appointments/[id]/queue-status (поли), api/crm/actions (поли), api/crm/shell-summary, dashboard, analytics/funnels (фрагмент), api/crm/search, miniapp/documents (MIME allowlist), workers referral-document/visit-note-handout (uploadedById), doctor/layout.tsx, doctor/settings security-tab, settings/integrations client (карточка телефонии), next.config.ts (CSP), cmdk command-score, i18n ru/uz (паритет ключей по пространствам зоны совпадает; отсутствует только docsLibrary.types.CONCLUSION). НЕ проверял: ai-ask-panel.tsx (AI_ENABLED=false, панель не рендерится), подробно security-client.tsx (UI-разметку), остальные строки footer/trial-banner, реакцию Auth.js на MissingCSRF в рантайме (вывод о петле смены пароля — по коду @auth/core, тестом не подтверждён), фактическое значение DOCTOR_CABINET_ENABLED/hasCallCenter/require2faForAll в проде (взято из docs/architecture/OVERVIEW.md), серверы/БД/сеть не трогал, тесты не запускал. Ресепшн-виджет звонков (use-reception-live) и Mini App вне зоны — упомянуты только как источник данных.

Сквозной проход: мокапы, заглушки, фейковые данные, i18n

Repo: /Users/joe/Desktop/medbook/medbook-uz (HEAD 61dd266). All paths above are relative to that root. Static read-only audit; no builds/servers/tests run (only node/python one-off scripts over messages + a direct intl-messageformat parse to confirm ICU runtime failure).

What I did systematically:

- i18n: full ru/uz key parity (5913/5913, no gaps), Cyrillic-in-uz and identical/English values; scripted scan of every useTranslations/getTranslations/useT binding vs literal t() keys (found drugs.detailsDescription; others were false positives); enum-driven dynamic keys checked against Prisma enums (found docsLibrary.types.CONCLUSION); ICU parse of all 5913 ru+uz strings with @formatjs parser + argument-set parity (9 broken messages, 0 arg mismatches); mini-app dictionaries (_messages/ru.ts vs uz.ts, 373/373); hardcoded Cyrillic in CRM/doctor/public JSX.
- Mockup/stub sweep: TODO/FIXME/mock/fake/stub/synthesized/heuristic/Math.random greps; heuristic scanner for Button/button without handlers across src; toast-only handlers; AI_ENABLED/inDevelopment surfaces and the server paths they still trigger; payment/telephony/SMS/email/LLM/transcribe stub fallbacks; settings saved-but-never-read (integrations, branding/customSubdomain, referral, doctor notification prefs, clinic settings fields, trigger configs); workers registered in start.ts vs enqueued jobs (exports lazy worker, summary, voice-soap).
- Traced end-to-end: landing lead form → /api/leads → (no consumer); /crm/doctors aggregates → /api/crm/appointments schema limit; analytics funnel/charts synthesis; reception KPI strip → /api/crm/dashboard and shell-summary; call-center + SIP webhook + telephony adapters; CALL_OPERATOR CTAs vs route role lists vs permission matrix; signup → confirm; ticket page and visit-note read-only server rendering (timezone); privacy texts vs ops/backup.sh and deploy docs; exports hook → API → in-memory registry; notification template test-send → FK.

Not covered / only skimmed: individual API route internals outside the zone (tenant scoping, IDOR, XSS in message-bubble/print templates — only noted where on my flows, e.g. unescaped lead email HTML and a DOCTOR-without-Doctor-row branch in /api/crm/documents that I did not report as out-of-zone); doctor reception visit editor, prescriptions/lab/sick-leave dialogs, CDS; mini-app booking/queue logic beyond i18n and referral; admin /admin panel (hardcoded Russian, not reported as it is SUPER_ADMIN-only); calendar/appointments business logic, queue ordering, BullMQ worker correctness; TG bot FSM and webhook; DSAR workers; analytics reports builder/cohorts/forecast/loss/schedule-heatmap internals (only grep-level); PDF/print HTML templates. Could not verify runtime env on prod (whether ANTHROPIC/OPENAI/SMTP keys are set, real bot username, actual clinic phone) — findings state the conditional where it matters. Landing bot handle «@neurofaxbot» and hardcoded price list in messages were noticed but not reported (unverifiable against prod data).

Журнал доступа к медданным и полнота аудита (кто смотрел, кто менял, сколько хранится)

Прочитано полностью: src/server/audit/patient-view.ts, src/lib/audit.ts, src/lib/audit-server.ts, src/lib/audit-actions.ts (проверен каждый из 131 ключей на использование), src/app/api/crm/audit/route.ts, src/app/api/crm/audit/patient-views/route.ts, audit-log-client.tsx, crm/settings/audit/page.tsx и settings/layout.tsx, crm/patients/[id]/page.tsx, api/crm/patients/[id]/route.ts (GET/PATCH/DELETE), api/crm/visit-notes/[id]/route.ts и /previous, api/crm/documents/file, conversations/[id]/attachments/file и attachments (upload), miniapp/documents/[id]/file, miniapp/family (POST) и family/[linkedPatientId], server/miniapp/handler.ts и active-patient.ts, src/server/crypto/field-cipher.ts, server/patient/cipher-fields.ts, me/totp/recovery-codes/regenerate, recovery-codes.ts consume, lib/auth.ts authorize/jwt, user-session.ts mint, api/auth/[...nextauth], exports worker (реестр и запись файла), exports/route.ts и [jobId]/download, patients/export, doctors/me/patients/[patientId]/summary, doctors/me/security-summary, doctor/visits/[patientId]/[visitId]/page.tsx, outbox-pumper.ts writeAuditLog, envelope.ts EVENT_META, visit-note-handout.ts (ключ и upsert PDF), фрагменты appointments/[id] (GET и revert), bulk-status, allergies/diagnoses/chronic [id]-роуты, documents/[id] (аудит), схема PatientView/AuditLog и onDelete-связи Patient, миграция phase17, nginx.conf (XFF), scripts/_destructive-guard.ts и seed-mega (wipe). Через grep построена матрица «роут → audit/recordPatientView» по doctors/me, visit-notes, documents, conversations, miniapp, patients, cases, appointments, dsar.

Уточнения к брифу: RECOVERY_CODE_USED на деле пишется строковым литералом в lib/auth.ts:139.

PATIENT_FAMILY_LINKED/UNLINKED, NPS и PRE_VISIT заменены outbox-событиями event:patient.familyLinked и т.п., которые аудируются (дефект только в ключе entityId, см. находку про «семью»). PATIENT_MERGED, INVOICE_VOIDED и MINIAPP_BOOKING_SUGGESTED — зарезервированные константы под отсутствующие фици, сами по себе не дефект. PATIENT_DELETED не используется, потому что CRM пишет legacy-строку "patient.delete". Реально пропущен сигнал ENCRYPTION_DECRYPT_FAILED (см. находку). Троттлинг PatientView: время серверное и согласовано с БД (один хост). Параллельные вставки могут дать дубль (findFirst+create без уникального ключа), это безвредно. Ключ троттлинга без contextRef учтён в первой находке. Удалить или изменить AuditLog/PatientView через API нельзя: эндпоинтов нет, пользователи не удаляются (purge врача деактивирует User). Но PatientView уходит каскадом при удалении пациента или клиники, а сид-скрипты его чистят (за guard'ом). Перерендер PDF заключений и направлений идёт по стабильному ключу, поэтому сирот не плодит, но затирает подписанную версию (см. находку). Сироты в MinIO от вложений чата, логотипов и фото препаратов не выносил отдельно: не PHI или уже покрыто #224 и #406.

Не успел или не делал: построчно не читал doctors/me/patients/[patientId]/visits, documents, labs, prescriptions и diagnoses (проверены только сигнатуры и отсутствие аудита), print/route.ts целиком (есть #26), data-export.ts (DSAR покрыт #144), SSE и события, остальные ~200 CRM-роутов за пределами матрицы. Тесты и vitest не запускал.

Операционные скрипты, сиды и демо-данные на живом проде

Сначала прочитан /private/tmp/.../titles.txt (532 строки) и отфильтровано всё, что касается scripts/seed/encrypt/relay. Уже известные дефекты не повторялись: #354 (пароли в seed.ts, seed-neurofax-real, upsert-dev-admin), #249 (seed-prod-demo:170, case.repeat-due), #136 и #290 (статистика визитов), #404 и #405, а также находки по каталогам (import-uzpharm, build-icd10). Скрипты не запускались, работа только статическая.

ПРОЧИТАНО ЦЕЛИКОМ: _destructive-guard.ts, Dockerfile.worker, prisma/seed-drug-interactions.ts, rotate-encryption-key.ts, encrypt-existing-pii.ts, encrypt-auth-secrets.ts, src/server/crypto/field-cipher.ts, secret-fields.ts, secrets.ts (шифрование), api/admin/encryption-health, docs/runbooks/encryption-key-rotation.md, docs/operations/RUNBOOK.md, tg-relay-worker.js, bootstrap-super-admin.ts, connect-tg-bot.ts (со сравнением с api/crm/integrations/tg/connect), set-tg-webhook.ts, check-tg-webhook.ts, poke-webhook.ts, seed-demo-data.ts (все 1606 строк), seed-neurofax-real.ts, seed-today-live.ts, _live-queue-seed.ts, wipe-neurofax-demo.ts, seed-prod-demo.ts, seed-notification-templates.ts, backfill-new-templates.ts, reminder-cadence-5d3d1d3h.ts, backfill-patient-visit-stats.ts, backfill-birth-year-from-name.ts (вместе с parse-identity.ts), fix-double-inprogress.ts, cleanup-test-conversations.ts, seed-joe-two.ts, seed-labs-reminders-dev.ts, upsert-dev-admin.ts, inspect-users.ts, prisma/seed-drugs.ts, enrich-drug-forms.ts.

ПРОЧИТАНО ЧАСТИЧНО (опасные участки): seed-clinical-life.ts (wipe, заключения, е-рецепты, кейсы, reminders, audit, main), seed-mega-neurofax.ts (wipe, пациенты, оплаты), stress-appointments.ts (шапка, cleanup, ensurePatients, группа Z), stress-payments-analytics-ai.ts (платежи), stress-settings-crud.ts (врач и клиника), stress-cases-scenarios.ts (setup и purge), stress-reminders-scenarios.ts (переключение шаблонов), total-stress-seed.ts (шапка и цены), seed-doctor-qa.ts (clean и обновление врача), guard-e2e.ts (шапка), prisma/seed.ts (клиника, врачи, шаблоны), import-uzpharm-registry.ts (бренды).

Для проверки цепочек читались: миграции FK (Payment, Referral, VisitNote, Patient), schema.prisma (Payment, Patient, User, Doctor, DrugInteraction), patients/route.ts, patient-number.ts, walkin.ts, kiosk/checkin, phone.ts, miniapp/handler.ts, medication-reminder.ts, notifications-scheduler.ts (динамический проход), triggers.ts (findTemplateFor), no-channel-action.ts, queue-ordering.ts, outbox-pumper.ts, appointment-lifecycle-sweep.ts, auth.ts (TOTP), data-deletion.ts, DSAR и patient DELETE, NEW-CLINIC.md, SECURITY.md.

НЕ ПРОБЕРЕНО: тело seed-knowledge.ts (кроме шапки), stress-medical-cases.ts, verify-medical-case.ts, i18n-*.ts, build-*.mjs, check-*.mjs, invariants.mjs, schema-peek.mjs, inspect-neurofax.ts, probe-payment.ts (кроме шапки), seed-handouts, seed-labs, seed-protocols, seed-presets, seed-presets-sql в деталях, ops/backup.sh и ops/migrate-secrets.ts целиком, seed-mega-neurofax.ts после блока оплат, большая часть групп stress-appointments.

Какие скрипты реально запускались на проде и какие env там заданы (TELEGRAM_API_BASE, APP_SECRET отдельно от AUTH_SECRET), статически проверить нельзя. Поэтому вероятность находок про relay, про ротацию и про прогон демо-сидов зависит от фактических действий ops. Ключевые файлы: /Users/joe/Desktop/medbook/medbook-uz/scripts/, /Users/joe/Desktop/medbook/medbook-uz/Dockerfile.worker, /Users/joe/Desktop/medbook/medbook-uz/docs/operations/RUNBOOK.md, /Users/joe/Desktop/medbook/medbook-uz/docs/runbooks/encryption-key-rotation.md.

Сквозная матрица «мутация → событие → SSE → обновление экрана» на всех поверхностях

Прочитано полностью: src/server/realtime/{events,publish,outbox,channels,env,board-stream}.ts; src/server/appointments/{emit-change,confirm (ключевые блоки),cancel (env),book (env),walkin (tx + publish)}.ts; src/hooks/{use-live-events,use-live-query,use-queue-board,use-doctor-board}.ts; src/app/c/[slug]/my/_hooks/{use-miniapp-live-events.tsx,use-queue-status,use-appointments (мутации),use-visit-summary}; src/app/api/events/route.ts; src/app/api/miniapp/events/route.ts; src/app/[locale]/crm/reception/_hooks/use-reception-live.ts; crm/calendar/_hooks/use-calendar-data.ts; crm/appointments/_hooks/{use-appointments-list,use-appointment (ключи, оптимистичные апдейты)}; crm/action-center/_hooks/{use-actions,use-risk-today}; crm/call-center/_hooks/use-unconfirmed.ts;

doctor/my-day/_hooks/{use-doctor-today,use-doctor-schedule,use-appointment-status-mutation};
doctor/reception/_hooks/{reception-context,use-cds-drug-check,use-patient-history,use-patient-diagnoses};
doctor/reception/_components/cds-warnings-card.tsx; роуты allergies/diagnoses/chronic-conditions (все методы),
doctors/[id]/schedule (+server/doctors/update-schedule.ts), doctors/[id]/{services,time-off} (наличие событий),
cases/[id]/{attach,detach}-appointment, cases/[id]/prescriptions (наличие событий), visit-notes/[id]/{amendments,finalize,
PATCH-emit}, miniapp appointments/[id]/{route,checkin,attach-case}, miniapp pre-visit, miniapp visit-summary, crm/payments
(POST/PATCH), c/[slug]/queue/{checkin,walkin}, appointments/[id]/{route (revert/call/main emit),queue-status}, reorder, bulk-status,
bulk-reschedule; workers: outbox-pumper (deliverOne), visit-note-handout (render + bridge), appointment-lifecycle-sweep,
notifications-send (INAPP), notifications/record-delivery; docs/TZ-cross-surface-sync.md §6–§10.

Сверка TZ §7: 7.1 (бронь из мини-аппа) работает (outbox, patientId/doctorId есть); 7.3 частично: PDF-ссылка не живая (находка 10); 7.4 draftSaved без потребителей (уже #29); 7.5 работает, но прежний врач не узнаёт о переводе (находка 2), а перенос пациентом не аудируется (находка 7); 7.6 работает (queue.updated по ТЗ не шлётся, но все потребители слушают appointment.cancelled); 7.7 в мини-апп не доходит (уже #282/#466), слушателей в CRM и кабинете нет (считаю покрытым #466); 7.9, 7.10, 7.11 (создание) работают, обновления назначений молчат (находка 9); 7.12 только аудит. §10.2: моки кабинета врача удалены, выполнено.

Сознательно не заявлял (уже есть в списке или незначимо): отпуск врача без события (#201), замороженный семейный набор SSE (#465), мёртвый replay (#447), outbox→Redis (#448), draftSaved (#29), чужие закрытия задач (#352), тосты TG у врача (#48). Отдельно не заявлял: услуги врача без события (PUT doctors/[id]/services не публикует, но мини-апп перечитывает при фокусе, а корень записи чужой услуги в #280); payment.paid без CRM-потребителя (при #289 оплаты не привязываются к визиту, эффект нулевой); чек-ин с киоска шлёт только queue.updated без statusChanged/patientId (киоск по #69 практически не доходит до BOOKED-записей); латентный баг useActionsPaged с накопителем при loadMore (loadMore нигде не вызывается).

Не успел или не проверял глубоко: telegram webhook и SIP-события (вне зоны), лабораторные исследования и направления (UI мёртв по #55/#491), экран ТВ-табло и киоска кроме хуков, пересчёт use-doctor-sidebar-stats, CRM-карточку случая (live-подписка только на soap-draft). Тесты и сборку не запускал.

Клинические справочные данные и реальное покрытие CDS (риск ложного «всё безопасно»)

Прочитано полностью: src/server/cds/drug-check.ts, cds-warnings-card.tsx, use-cds-drug-check.ts, api/crm/cds/drug-check/route.ts, apply-protocol-dialog.tsx, prisma/_drug-interactions-data.ts, seed-drug-interactions.ts, seed-drugs.ts, seed-protocols.ts, seed-handouts.ts, seed-labs.ts, seed-presets.ts, seed-presets-sql.ts, scripts/import-uzpharm-registry.ts, src/lib/catalogs/prescription-format.ts, atc-groups.ts. Прочитаны все протоколы в _protocol-data.ts, все памятки в _handout-data.ts, все PRESCRIPTIONS/ADVICE-пресеты из _preset-data.ts (COMPLAINTS/ANAMNESIS/EXAMINATION пролистаны выборочно). Поля _drug-catalog.ts, _drug-catalog-extra.ts, _drug-data.ts (ATC, категория беременности, adult-дозирование, формы) и _lab-data.ts выгружены целиком через tsx-импорт TS-файлов, без БД. По связанным местам прочитаны structured-fields-panel.tsx (входы CDS, применение протокола), draftFromDrug и строка конструктора в prescription-constructor.tsx, finalize/print (использование withInstruction), clinic-overlay whitelist, protocols/handouts API, модели в schema.prisma. Цифры по реестру (≈2420 новых строк, 160 дублей по ATC, 72 комбинации, 1788 брендов, 82 совпадения на «мед») получены офлайн-симуляцией логики импорта и resolveDrugs на Python по prisma/uzpharm-registry.json поверх статического каталога. Это приближение: реальное состояние прод-БД (был ли импорт с APPLY=1, собственные препараты клиник) я не проверял, и доступа к БД не было. Не делал: не запускал тесты и БД, не проверял правильность каждой из 156 записей противопоказаний и побочных эффектов (просмотрены выборочно для нейро-препаратов), не проверял клиническую точность каждого референсного диапазона, не проверял узбекские переводы клинического контента (в данных их практически нет), не смотрел seed.ts (второй копии пресетов) и overlay-экраны настроек базы знаний. Отмечу без отдельной находки: seed-drug-interactions.ts пересоздаёт пары без транзакции (на время пересева CDS пуст). Заголовки seed-drugs.ts и seed-protocols.ts ссылаются на несуществующие seed-drugs-sql.ts и seed-protocols-sql.ts. id пар после повторного seed-drugs сохраняются (upsert по id), так что пары не отрываются, но импорт реестра пар не наследует.

Платформенная панель SUPER_ADMIN и жизненный цикл подписки живой клиники

Прочитал полностью: src/server/platform/handler.ts, current-subscription.ts, feature-guard.ts, current-flags.ts, get-feature-flags.ts, impersonation.ts, clinic-override.ts; src/server/workers/trial-expiry-scheduler.ts (и место занула в workers/start.ts, адантеры queue/index.ts и bullmq-adapter.repeat); все роуты зоны: api/platform/{users, users/[id], integrations/[id], clinics, clinics/[id], clinics/[id]/integrations, clinics/[id]/reset-owner-password, usage, health, audit, session/switch-clinic}, api/admin/{plans, clinics/[id]/subscription, cancel, extend-trial, lifecycle, encryption-health}; весь UI /admin: layout, error, page-обёртки, admin-sidebar, admin-topbar, clinics-page-client (782 строки), clinic-tabs, integrations-page-client, billing page + billing-page-client, users-page-client, audit-page-client, usage-page-client, health-page-client, начало encryption-health-client. Прошёл потоки за пределы зоны: потребители ProviderConnection (notifications/adapters, telephony, sip/event), потребители флагов (call-center, telegram, calls API, funnels, branding, mini-app layout, crm/layout), потребители Clinic.active (miniapp handler, clinic-public/resolve, lib/public-clinic, tv/d), trial-banner и его тексты ru/uz, invoice.markInvoicePaid, auth.ts (JWT-логика имперсонации), crm/users/[id] (guard'ы), схема Plan/Subscription/Clinic/ProviderConnection/Doctor. Проверил поведение Radix Select 2.2.6 в node_modules. Ответы на вопросы задачи: POST /api/platform/users не существует (только GET и PATCH [id]);

интеграционные роуты секреты маскируют, кроме config, где лежит SIP webhookSecret (включено в находку); platformAudit секреты не пишет; reset-owner-password не отзывает сессии и не трогает 2FA — это уже есть в #361 и #371, новое только в выборе учётки и в окне с паролем. Не повторял уже известное: #157, #165, #166, #176, #321, #361, #363, #369, #371, #372, #439, #482, #493 (confirm «Отмена=WRITE» есть и в clinics-page-client.tsx:158, это та же проблема, что #493), #516, #532. Не делал: не запускал тесты и приложение (баг с Select подтверждён чтением исходника Radix, а не прогоном), не проверял прод-данные (реальный статус подписки NeuroFax: TRIAL, PAST_DUE или ACTIVE — от этого зависит, видят ли сотрудники баннер прямо сейчас), не читал src/server/platform/subdomain.ts и branch-cookie.ts (вне основных путей), CRM-страницу settings/billing и middleware proxy.ts глубже того, что нужно для имперсонации.

Рабочее место оператора Telegram: правая панель чата, композер, рассылки

Всё прочитано статически, ничего не запускалось. Полностью прочитаны: chat-right-rail.tsx (все 1323 строки), message-composer.tsx (все 1204), chat-pane.tsx, conversation-list.tsx, telegram-page-client.tsx, broadcast-dialog.tsx, broadcast-audience.tsx, broadcast-preview.tsx, auto-messages-dialog.tsx, mode-switch.tsx, хуки use-broadcast, use-canned, use-tg-events, use-conversations, use-tg-messages, use-mark-read, use-conversation-meta, use-send-message, use-takeover, use-tg-inbox-alerts, а также _lib/placeholders.ts. Из notifications: notifications-details-rail, notifications-activity-list, campaigns-list, ai-copy-suggest, notifications-page-client; use-queue.ts прочитан частично. Серверная часть: /api/crm/conversations (список, [id] GET/PATCH, messages GET/POST, attachments POST и file-прокси), server/conversations/find-or-create.ts, campaigns (broadcast, preview, [id], cancel, broadcasts), server/campaigns/audience.ts и launch.ts, notifications/template.ts, adapters/tg-clinic.ts, consent-gate.ts, воркер notifications-send.ts и record-delivery.ts (частично, в части статусов), canned-responses API, GET /api/crm/clinic, POST /api/crm/patients, /api/crm/patients/[id]/stats, GET шаблонов уведомлений, NewAppointmentDialog (props и дефолтный канал), POST /api/crm/appointments (поли и autoConfirm), в вебхуке — запись сообщений, профиль мини-аппа (API и экран) в части согласий, ссылки на инбокс из tg-preview-widget и global-search, обработка вкладок в patient-card-client. Не повторял уже известные находки: #213—#256 (XSS через файлы, inline-кнопки, «Подтвердить запись», режим «Бот», 10 000 лимит и двойной запуск, воронка «Доставлено 0», шаблоны и авто-сообщения на сервере), #102/#138/#135/#137/#215/#324. Не проверены: нижняя половина message-bubble.tsx (покрыта #213/#221/#240), broadcast-history.tsx после строки 120, telegram-stats-bar (покрыт #255), notifications-types-sidebar и kpi-strip (#235/#256), template-editor, template-tree и triggers-panel (зона settings/telegram-comms), серверная логика auto-messages (#179/#186/#231), бот-FSM вебхука за пределами записи сообщений, кабинет врача (doctor/messages). Тесты не запускались. Выводы про порядок NULLS в Postgres и про сохранение состояния React без key сделаны по коду, в браузере не воспроизводились.